



AN INTRODUCTION TO PRIVACY **FOR TECHNOLOGY PROFESSIONALS**

Travis D. Breaux, CIPT
Executive Editor

An **iapp** publication

An Introduction to Privacy for Technology Professionals

**Executive Editor
Travis D. Breaux, CIPT**

Contributing Authors

Lujo Bauer

Chris Clifton

Lorrie Faith Cranor, CIPT

Simson L. Garfinkel, CIPP/US

David Gordon

David James Marcos, CIPM, CIPT

Aaron Massey

Florian Schaub, CIPP/US, CIPT

Stuart S. Shapiro, CIPP/G, CIPP/US

Manya Sleeper

Blase Ur

An IAPP Publication

© 2020 by the International Association of Privacy Professionals (IAPP)

All rights reserved. No part of this publication may be reproduced, stored in a retrieval system or transmitted in any form or by any means, mechanical, photocopying, recording or otherwise, without the prior written permission of the publisher, International Association of Privacy Professionals, Pease International Tradeport, 75 Rochester Ave., Portsmouth, NH 03801, United States of America.

CIPP, CIPP/US, CIPP/C, CIPP/E, CIPP/G, CIPM and CIPT are registered trademarks of the International Association of Privacy Professionals, Inc., registered in the United States. CIPP, CIPP/E, CIPM and CIPT are also registered in the EU as Community Trademarks (CTM).

Copy editor and proofreader: Julia Homer

Indexer: Hyde Park Publishing Services

ISBN: 978-1-948771-91-7

Contents

[About the IAPP](#)

[Acknowledgments](#)

[Marla Berry, CIPT](#)

[Preface](#)

[Travis D. Breaux, CIPT](#)

[Introduction](#)

[Cathleen R. Scerbo](#)

[Chapter 1: Introduction to Privacy for the IT Professional](#)

[1.1 Who Should Use This Book?](#)

[1.2 What is Privacy?](#)

[1.3 What Are Privacy Risks?](#)

[1.4 Privacy, Security and Data Governance](#)

[1.5 Privacy Principles and Standards](#)

[1.6 The Data Life Cycle](#)

[1.7 Individual Expectations of Privacy](#)

[1.8 Summary](#)

[Chapter 2: Engineering and Privacy](#)

[2.1 Privacy in an IT Ecosystem](#)

[2.2 Privacy Risk Management](#)

[2.3 Requirements Engineering for Privacy](#)

[2.4 High-Level Design](#)

[2.5 Low-Level Design and Implementation](#)

[2.6 Testing, Validation and Verification](#)

[2.7 Summary](#)

[Chapter 3: Encryption and Related Technologies](#)

[3.1 Encryption, the Mathematics of Privacy Protection](#)

[3.2 Secret Key \(Symmetric\) Encryption](#)

[3.3 Cryptographic Hash Functions](#)

[3.4 Public Key \(Asymmetric\) Encryption](#)

[3.5 Public Key Infrastructure](#)

[3.6 Cryptographic Systems: Putting It All Together](#)

[3.7 Summary](#)

[Chapter 4: Identity and Anonymity](#)

[4.1 What Is Identity?](#)

[4.2 Authentication](#)

[4.3 Identity Issues](#)

[4.4 Anonymization](#)

[4.5 Summary](#)

[Chapter 5: Usable and Useful Privacy Interfaces](#)

[5.1 Why User-Centered Privacy Design?](#)

[5.2 Privacy Decision-Making, Behavior and Concerns](#)

[5.3 Usability and User Experience](#)

[5.4 Design of Privacy Interfaces](#)

[5.5 Usability Testing and User Studies for Privacy](#)

[5.6 Summary](#)

[Chapter 6: Tracking and Surveillance](#)

[6.1 Internet Monitoring](#)

[6.2 Web Tracking](#)

[6.3 Blocking and Controlling Web Tracking](#)

[6.4 Location Tracking](#)

[6.5 Audio and Video Surveillance](#)

[6.6 Sensor-Based Surveillance](#)

[6.7 Behavioral Modeling](#)

[6.8 Summary](#)

[Chapter 7: Interference](#)

[7.1 Framework for Understanding Interference](#)

[7.2 Interference from a Technology Perspective](#)

[7.3 Summary of Lessons Learned and Recommended Steps of Action](#)

[7.4 Summary](#)

[Chapter 8: Privacy Governance](#)

[8.1 Privacy and IT: Roles and Responsibilities](#)

[8.2 Privacy Governance and Engineering: Bridging the Gap](#)

[8.3 Privacy Engineering: Effective Implementation within an Organization's IT Infrastructure](#)

[8.4 Evaluating Success: Assessing Sufficiency and Effectiveness of IT Privacy Governance](#)

[8.5 Summary](#)

[Chapter 9: Cybersecurity and Privacy](#)

[9.1 The Breadth of Computer Security Work](#)

[9.2 Attacks and What Makes Them Possible](#)

[9.3 Security Properties and Types of Adversaries](#)

[9.4 Access Control](#)

[9.5 Principles for Building and Operating Systems to Be More Secure](#)

[9.6 Summary](#)

[**About the Contributors**](#)

[**Index of Searchable Terms**](#)

About the IAPP

The International Association of Privacy Professionals (IAPP) is the largest and most comprehensive global information privacy community and resource, helping practitioners develop and advance their careers and organizations manage and protect their data.

The IAPP is a not-for-profit association founded in 2000 with a mission to define, support and improve the privacy profession globally. We are committed to providing a forum for privacy professionals to share best practices, track trends, advance privacy management issues, standardize the designations for privacy professionals and provide education and guidance on opportunities in the field of information privacy.

The IAPP is responsible for developing and launching the only globally recognized credentialing programs in information privacy: the Certified Information Privacy Professional (CIPP®), the Certified Information Privacy Manager (CIPM®) and the Certified Information Privacy Technologist (CIPT®). The CIPP, CIPM and CIPT are the leading privacy certifications for thousands of professionals around the world who serve the data protection, information auditing, information security, legal compliance and risk management needs of their organizations.

In addition, the IAPP offers a full suite of educational and professional development services and holds annual conferences that are recognized internationally as the leading forums for the discussion and debate of issues related to privacy policy and practice.

Acknowledgments

In the years since *Introduction to IT Privacy: A Handbook for Technologists* was published, we've seen the rapid evolution of privacy technology and the growing importance of technologists in both ensuring compliance and creating a culture of privacy within their organizations. This book, *An Introduction to Privacy for Technology Professionals*, is the new edition of *Introduction to IT Privacy* and reflects these changes in the field. The IAPP is delighted to present this book in support of the Certified Information Privacy Technologist (CIPT) credential.

We would like to thank the many professionals who contributed their time and expertise to the development of this comprehensive resource. It's a collaborative effort, and without them, it would not be possible.

The training advisory board members provide ongoing support of our training products. We rely on their knowledge and guidance to develop the highest quality resources. Thank you to these members, past and present. Current members include: **Francesco Banterle**, CIPP/E

Punit Bhatia, CIPP/E, CIPM

Machiel Bolhuis, CIPP/E, CIPM, FIP

Michaela Buck
Duncan Campbell, CIPP/US

Ionela Cuciureanu

Evan Davies, CIPP/E

Karen Duffy, CIPP/E

Marjory Gentry, CIPP/E, CIPP/US, CIPM

Promila Gonsalves, CIPP/C

Ryan Hammer, CIPP/E, CIPP/G, CIPP/US, CIPM, CIPT, FIP

Missi Hart-Kothari, CIPP/US

Richard Ingle

Laura Kiviharju, CIPM

Henri Kujala, CIPP/E, CIPM, FIP

Viviane Maldonado

Ana Monteiro, CIPP/E, CIPM, CIPT, FIP

Michelle Muthiani, CIPP/E, CIPP/US

James Park, CIPP/E, CIPT

Anna Pateraki

Cassandra Porter, CIPP/US, CIPM, FIP

Stephen Ramey

Brandon Schneider, CIPP/G, CIPT, FIP

Thea Sogenbits

Tiina Suomela, CIPP/E, CIPM, FIP

Liisa Thomas

Maaïke van Kampen-Duchateau, CIPP/E, CIPT, FIP

Emily Wall, CIPP/US, CIPM

Ben Westwood, CIPP/E, CIPP/US, CIPM, FIP

Christin Williams, CIPP/E, CIPP/US

Brett Wise, CIPP/US, CIPT, FIP

Matthew Woldin, CIPP/US, CIPM, FIP

Laurel Yancey, CIPP/E, CIPP/US, CIPM

Philip Yang, CIPM

We are grateful that Travis D. Breaux, CIPT, served as executive editor for both *Introduction to IT Privacy* and *An Introduction to Privacy for Technology Professionals*. For both editions of the book, Travis assembled a team of top thought leaders in the field and, in addition to contributing to the text himself, led the books through all stages of content development. Other contributors to these books include Lujo Bauer; Chris Clifton; Lorrie Faith Cranor, CIPT; Simson Garfinkel, CIPP/US; David Gordon; Malcolm Harkins; David Hoffman, CIPP/US; David James Marcos, CIPM, CIPT; Aaron Massey; Florian Schaub, CIPP/US, CIPT; Stuart S. Shapiro, CIPP/G, CIPP/US; Manya Sleeper and Blase Ur. Thank you to Travis and all of the contributors for their dedication and continued support of our CIPT program and textbook.

Many thanks to Anne Christman; Biju Dasappan, CIPT; Jonathan Fox, CIPP/US, CIPM; Javier Salido, CIPP/US, CIPT, FIPP and Thea Sogenbits for reviewing the draft manuscript and providing thoughtful feedback that helped shape the final text. We are grateful for Julia Homer's meticulous eye in both copy editing and proofreading the text. Thank you to Hyde Park Publishing Services for creating the book index.

We are so appreciative for the many professionals who contributed to this textbook. We hope that you will find it to be both an indispensable resource in preparing for your certification as well as a practical resource for your professional career.

Marla Berry, CIPT

Training Director

International Association of Privacy Professionals

Preface

Since the first edition of this book, *Introduction to IT Privacy*, was published in 2014, we have observed significant new advances in information technology and public policy that affect privacy. In many ways, this eight-year period tells a story where technologies that historically lived in research laboratories have seen wider commercial adoption as new forms of automation. These technologies include autonomous and semiautonomous vehicles, voice-activated assistants, smart devices and biometrics. While the conveniences afforded by some forms of automation are still being understood, the deployment is already raising new privacy challenges. Google Glasses, the eyeglasses that could snap photos and later record video, were introduced in 2012 and quickly raised questions about reasonable expectations of privacy in public spaces. While this technology did not become mainstream with the public, voice-activated smart speakers, which consumers deploy in their homes and use to check the weather and play music, are quite popular, with multiple manufacturers competing for market share, including Amazon, Apple and Google.

The privacy risks introduced by these technologies are varied, including new ways to acquire personal data, new ways to build richer personal profiles, and new challenges in discerning the truth about a person from mere fabrication. Machine learning and robotics, for example, have led to commercial drones that allow individuals to more easily acquire overhead video and sensor data, smart televisions that detect which content is being viewed and then share this information with device manufacturers, and health sensors that track real-time fitness and blood pressure. These advances in many ways integrate with and extend the smartphone revolution that led to the novel collection of real-time location by mobile apps and advertisers. Additionally, increased deployment of sensors, often to enable new consumer products and safety features, allow for the creation of richer personal profiles. In 2015, telematics devices introduced by insurance companies were capable of recording driving distances, braking patterns and speed traveled for the purpose of informing insurance rates. In 2016, a popular social media site deployed an algorithm to classify its users by their political preferences, which contributes to other factors in behavioral profiles,

such as affinities for specific racial groups. Lastly, advances in generative machine learning now allow one to create fake images and fake video, called deep fakes because they rely on deep neural networks to generate the content. This includes an app that was designed to “auto-undress” photos of women as well as an app that allows a person to speak into a camera and record audio that is transformed into the video and audio of a public personality. These technologies raise new questions about the veracity of information and the use of data to misrepresent a person’s character or beliefs, potentially poisoning the public record.

Finally, in recent years, we’ve seen major advances in regulatory practices aimed at addressing privacy in a world where data is increasingly shared globally. In Europe, the General Data Protection Regulation (GDPR) replaces the EU Directive 95/46/EC with a major change that requires companies to obtain an individual’s consent before they can build user profiles. In addition, the National Institute for Standards and Technology (NIST) conducted a series of workshops with U.S. companies, government agencies and the public to develop a framework for privacy engineering. The framework aims to guide companies in how to select actions for reducing privacy risk within their enterprise. Going forward, regulators face great challenges in ensuring that regulation keeps pace with emerging technology as it shapes how we define and promote privacy. For example, how should companies treat machine learning models trained on data of EU citizens who choose to be forgotten?

In this new edition, we enshrined advances in technology, policy and practice in updates to all the existing chapters. This includes advances in cryptographic algorithms in Chapter 2 and database reconstruction attacks and new deployments of biometric authentication services in Chapter 4. In Chapter 6, we have new material on sensor-based surveillance, due in part to the emergence of the internet of things (IoT). Chapter 7 includes new material on deep fakes as well as on fairness and bias in machine learning, and Chapter 8 has been updated to focus more on enterprise privacy for cloud computing. Finally, we added two new chapters: Chapter 5, on how to make privacy usable given that users play an increasingly large role in managing their privacy preferences; and Chapter 9, on cybersecurity and how security frameworks support protecting privacy. While these are a few highlights for the new edition, I believe you’ll find this updated volume offers a single source on the topic of IT privacy that is simply unparalleled in terms of breadth and depth.

Travis D. Breaux, CIPT

Executive Editor

Introduction

A universal aspect of being a technology professional is that change is not only expected but guaranteed. Change ensures the opportunities to learn never wane—that's what keeps many of us in the profession. However, in recent years, the pace of change is both increasing dramatically and expanding to affect the broad population. People have come to expect the same quality of engagement with day-to-day technology regardless of channel or industry.

On my own journey, finding myself in the privacy industry now feels reminiscent of the early days of information security. There wasn't a roadmap on the work, just passionate, tech-savvy people who cared about making sure company assets were safe from emerging security threats.

Privacy engineering is today's equivalent. While privacy laws and guidelines have been with us for decades, to date the approach has been about terms and conditions and contractually holding suppliers and service providers accountable for company behavior. With the ever-increasing presence, dependence, and personal implications of technology on individuals, the contractual is no longer enough.

The stakes are increasing. The prevalence of internet-of-things (IoT) devices like smart watches, smart homes and smart cities is increasing both our digital footprint and its perceived value and usage. Technology has made it possible to capture and track people's movements, interests and personal information and aggregate it for marketing insights or nefarious intentions.

While technology has become a convenience for many—making it easy to order food and clothes, track our exercise or health, and keep in touch with friends and family—it has also become a necessity. Our personal and work lives frequently rely on today's technologies to simply meet day-to-day expectations. People want the convenience but are recognizing that giving up our personal data is becoming annoying, creepy or the source of lost time, data or money because of the frequency of data breaches. Additionally, incidents of malware, ransomware and identity theft are fostering distrust of technology. More and more, people are becoming fatigued by the trade-off.

Recently, however, the laws have evolved to require organizations to manage this within the technology ecosystem. Specifically, the General Data Protection Regulation (GDPR) introduced the requirement of data protection by design and by default, radically changing the paradigm from the contractual to the automatic. For technology professionals, this means a new way to design, build, test and maintain our applications, infrastructure and processes. These guidelines place the individual's needs front and center, and require protection of their rights and interests to be built in our systems, processes and infrastructure.

Today's technology professional recognizes the urgency to quickly adapt to the pace of change. The emergence of user-centric design, the wide adoption of DevOps and Agile practices, and the increased commitment to diversity and inclusion in building software today are all evidence of this recognition. In line with the now table-stakes expectations of building secure solutions, technology professionals need to adapt to the growing demand for privacy.

This book offers technology professionals a better understanding of privacy issues and their implications for today's technology solutions, processes and infrastructure. Any person in the technology solutions ecosystem will benefit from the concepts, guidelines, tools and frameworks available in this book to ensure privacy by design in their solutions. Further, the book will give tech-savvy professionals a common language with which to speak with lawyers, compliance officers, business stakeholders and others involved in the definitions needed to design, build, test and maintain solutions with privacy in mind.

Cathleen R. Scerbo

Vice President and CIO

International Association of Privacy Professionals

CHAPTER 1

Introduction to Privacy for the IT Professional

Travis D. Breaux, CIPT

Information technology (IT) continues to revolutionize modern life through increasing automation and innovation. Automation includes transforming existing, often paper-based, practices into electronic form-based processes that aim to save time and reduce waste. The migration from paper-based medical records to electronic health records and the transition to electronic voting are just

two examples of IT automation. Alternatively, IT innovation occurs when new services are realized that were never before in reach due to technological limitations. Recently, social networking and handheld mobile devices have led to extensive innovation by bringing data and information into the context of personal and professional activities. These have led to a paradigm shift in how we manage and interact with information on a daily basis. The challenge for modern IT, however, is that new types of system quality and value are now necessary to sustain this emerging ecosystem. Whereas the early days of IT were driven by value produced primarily from improved performance, better reliability and stronger integrity, modern IT systems must increasingly contend with value produced from better usability, security and privacy. In particular, increasing privacy concerns arise as personal information is collected, processed and transferred in new ways that challenge existing legal and social norms.

To prepare IT professionals with the skills they need to support the privacy goals of the organization, this book provides a roadmap for navigating the complex IT ecosystem from the viewpoint of an IT administrator or developer. As a roadmap, the book cannot reasonably cover every detail needed to train an IT professional to become an expert in privacy. However, it does include several important *signposts* that serve to direct the IT professional to more easily identify and understand critical terminology for discovering and incorporating privacy and security best practices into their workplace responsibilities. This terminology can later be studied in depth in a manner commensurate with the role and responsibilities of the IT professional in their larger organization. Furthermore, the book aims to prepare the professional to identify common pitfalls that have previously led to privacy harms that, in some cases, cost companies millions of dollars in fines and lost revenue. In this chapter, we begin by defining what we mean by an *IT professional*, make the case for why some IT professionals *must become privacy experts*, and finally conclude by providing a brief, multi-viewpoint definition of privacy and laying out an initial privacy framework that IT professionals can use to contextualize content from the remaining chapters as they work to become privacy experts. After studying this book, the IT professional should be knowledgeable about how privacy integrates into their daily practices and the daily practices of others around them, and with whom they should coordinate to improve privacy throughout their information systems.

1.1 Who Should Use This Book?

Today, IT has evolved into a rich ecosystem of stakeholders who participate in the development, acquisition and administration of IT systems. Together, these stakeholders ensure that IT systems are sustainable over time and that these systems continue to deliver value to customers and others. In this book, we focus on three broad categories of IT professional:

- *IT Developers*—personnel who are responsible for researching, designing, developing and testing IT systems to meet broad market demand, or to more narrowly satisfy an organization's business needs. For many organizations, IT development includes translating customer or other stakeholder requirements into system specifications. For other organizations, a separate research and development group is responsible for envisioning "leap ahead" technologies that can surface new, unforeseen privacy risks. In either situation, privacy concerns are less expensive to address in the early stages of development than during the later stages. Privacy engineers, who are increasingly found in companies with advanced privacy programs, will fall into this category.
- *IT Acquisition*—personnel who are responsible for acquiring open source or commercial software and hardware to fulfill their organization's business needs. The IT professional should be able to identify privacy-enabling and privacy-threatening product features and their relationship to privacy risks. When the IT professional is working on the potential acquisition of IT systems, they are responsible for reviewing contracts to ensure that the necessary privacy requirements are included in the system targeted for acquisition.
- *IT Administration*—personnel responsible for installing, configuring and maintaining IT systems. These professionals sustain and manage the connection between IT and business functions, often finding ways to bend and flex existing systems to meet the unique needs of their organization. Similar to IT acquisition personnel, administrators need a strong vocabulary for describing the technologies that concern privacy. However, the administrator is more similar to the IT developer when the administrator is required to integrate technology into the organization's infrastructure and command the technical details of

various technologies, sometimes refactoring or gluing systems together to share information in new ways.

This book aims to cover these three perspectives in different ways. Chapter 2 describes engineering practices for IT developers who design and construct their own IT systems. These practices include methods for identifying privacy requirements from a variety of recognized sources, tracing these requirements into system design and implementation and, finally, testing these systems for conformance to privacy. Strategies for identifying and managing privacy risk that build on legal and philosophical foundations of privacy are also presented in Chapter 2. Integrators, administrators and acquisition staff should use these risk management practices when assessing privacy-preserving technology in an off-the-shelf product. The next four chapters cover specific technologies that IT developers may use in their designs, such as technologies to support confidentiality and encryption in Chapter 3, identifiability and access control in Chapter 4, user interface design in Chapter 5 and tracking and surveillance in Chapter 6. These four chapters are relevant to IT acquisition and IT administration personnel, who can use this information when selecting and evaluating products and systems to support privacy in their organization. Chapter 7 describes the consequences of interference that can arise when IT systems use personal information to yield outcomes that are potentially privacy invasive. Because individuals often cannot see how their information is used, this chapter provides specific coverage to behind-the-scenes privacy issues that may arise, such as system personalization based on consumer preferences and cloud computing. This chapter is organized as a series of case studies to illustrate the effects of poorly designed IT systems that failed to preserve privacy. Chapter 8 describes privacy governance, risk and compliance terminology, and best practices, particularly for cloud-based and service-oriented systems. These techniques address the human dimension of IT management, including the role of privacy policies and notices, and several techniques that mature organizations use to manage privacy compliance through IT asset management, training and incident response. Finally, Chapter 9 describes how cybersecurity practices relate to privacy. This chapter can inform all three roles (development, acquisition and administration) in terms of how they leverage and coordinate existing IT security frameworks and practices to address issues in privacy. Notably, security and privacy are not equivalent, and one cannot rely on security practices alone.

The topics presented in this book may be applied to any system that processes personal information. This coverage ranges from general business systems, such as customer relationship management (CRM) systems, human resources (HR) systems (e.g., payroll, benefits) and enterprise resource planning (ERP) systems to domain-specific systems, such as electronic medical records, online storefronts and industry-specific, self-service kiosks. The practices can be applied to desktop systems or mobile applications. One challenge for IT professionals is understanding when information is personal or when it describes a data subject. Examples of personal information include an individual's contact information, account numbers or unique biometric or health data. In this case, payroll systems, workplace computers that may be used for personal reasons and corporate Wikis all contain personal information. Less obvious examples include information that describes personal preferences, such as political or lifestyle preferences or information generated by systems that may be uniquely linked to an individual, such as their personal vehicle or mobile computer. We cover in depth issues of identifiability in Chapter 4, and how technology can be used to track and surveil individuals in Chapter 6.

1.2 What is Privacy?

Privacy has a rich history in law and philosophy that can meaningfully inform how IT professionals think about privacy in their IT systems. Because many definitions of privacy consider one or more separate perspectives on privacy, the IT professional should be prepared to work in a *privacy pluralistic world*. In other words, a privacy expert is prepared to distinguish different definitions of privacy and recognize when another person is using a particular definition to review and analyze an IT system. Each definition is not exclusive of the other; rather, the definitions serve to highlight specific issues. To briefly illustrate, we consider a few prominent viewpoints on privacy that have served to define privacy in different ways:

- *Alan Westin's Four States of Privacy*—These include *solitude*—the individual stands by themselves, separate from the group and remains free from the observations of others; *intimacy*—the individual is part of a small unit, wherein trust, information sharing and the rules of secrecy are negotiated with members of the unit; *anonymity*—while the

individual is in public, they still maintain freedom from identification and surveillance; and *reserve*—while the individual is in a large group, they maintain the ability to withhold communication or disengage from others to create a psychological barrier against unwanted intrusion.¹ These four states can be used to characterize individual expectations of privacy and how IT works to achieve or conflict with those expectations.

- *Helen Nissenbaum's Contextual Integrity*—Privacy can be expressed as norms that should govern information access. Norms are domain specific; for example, the norms governing banking information will differ from the norms governing medical information. In addition, norms are context specific, such that each individual can have their own reasons for controlling access to their information in specific situations based on their own expectations, which govern those situations.² This viewpoint presents a challenge to IT professionals: how to identify relevant norms and preserve norms when they introduce new or changing technology?
- *Daniel Solove's Taxonomy of Privacy*—Privacy is understood by the activities and mechanisms that violate privacy as described in court proceedings. This includes activities such as interrogation and surveillance to compel information disclosure, secondary use and appropriation or distortion, especially of another's image.³ These activities can be used to determine when IT enables privacy-threatening outcomes. (See Chapter 2 for more discussion of the individual activities and risks posed to individuals.)
- *Ryan Calo's Harm Dimensions*—Objective harms are measurable and observable, wherein a person's privacy has been violated and a direct harm is known to exist. Subjective harms exist without an observable or measurable harm, but where an expectation of harm exists.⁴ Subjective harms may have the same impact on individual privacy because the individual takes similar steps to protect themselves. For IT professionals, the challenge is to recognize that the perception of harm is just as likely to have a significantly negative impact on individual privacy as experienced harms. Thus, IT professionals may need to rely

on privacy notice and privacy controls to build and retain trust from individuals.

Information technology provides the capability to shift the states of privacy as defined by Westin for a particular individual. For example, IT can be used to interrupt one's solitude, reveal an intimate moment, identify a person in a crowd or infer and expose an individual's attitudes and opinions despite their active reserve. This may occur in social networking environments, where others have the freedom to disclose intimate details about another person, or where participation is preconditioned on easing access to information about oneself by others. Finally, Solove's taxonomy and Calo's dimensions both reflect the risks that can result from an IT system violating a person's privacy or creating the perception of a potential violation. While these concepts form a strong philosophical foundation for privacy, the IT professional bears the unique responsibility of translating these concepts into IT system features that work to protect an individual's sense of privacy.

1.3 What Are Privacy Risks?

In the context of this book, privacy risks concern the *likelihood* that a privacy threat will exploit an IT vulnerability and the *impact* of this exploit on the individual and organization that retains information on the individual. The source of a threat, called the threat agent, may be internal to an organization (i.e., an *insider threat*), or it may be external. Common insider threats include malicious threats, such as an employee stealing personal information about a customer to later use that information to conduct fraudulent transactions on that person's behalf, called *identity theft*. According to the 2018 Javelin Strategy & Research Report on identity theft, 16.7 million U.S. adults were victims of identity theft in 2017.⁵ The average out-of-pocket cost of identity theft to the consumer was \$290 per incident, and the average time required by the individual to resolve the incident was 15 hours.⁶ With respect to the companies that host personal information, the Ponemon Institute reports that companies lose, on average, \$233 per customer record as a result of a data breach, including costs from legal defenses.⁷ In addition, companies who experienced a data breach also experienced an average 6.7 percent customer churn as a result of the breach.⁸

Celebrities or high-profile customers are subject to a different kind of insider threat, where employees steal personal details about the customer or their family and plan to sell this information to tabloids and newspapers. This risk is especially high in hospitals, where medical details of a celebrity's newborn baby or psychological assessment may be purchased for publication and outing of these personal details.

Nonmalicious insider threats can be due to carelessness, mistakes, insufficient training, weak security policies and ineffective controls, just to name a few causes. Lost or stolen mobile devices are frequently a source of gross data losses. This situation arises when employees take laptops out of the office for business or other travel purposes and the laptop is lost, misplaced or stolen. If the laptop hard drive is unencrypted, then anyone who discovers the laptop can more easily gain access to the company files. This is particularly threatening to individual privacy when those files contain sensitive personal information, such as Social Security numbers, financial account numbers or medical information. Other examples of lost or stolen devices include unencrypted USB flash drives and unencrypted backup drives and tapes that are stored in offsite locations that may be less secure than the primary work location.

External threats employ many of the same techniques to steal information that IT security analysts aim to prevent. These techniques include *phishing*, which is a form of social engineering that uses a routine, trusted communication channel to capture sensitive information from an unsuspecting employee. Phishing occurs most commonly in email messages that appear to be authentic and encourage the employee to click on a link or respond to the message by disclosing their personal information, such as passwords, birth dates and/or financial account numbers. When clicking a link, the employee may be led to a website that collects the information, or they may unknowingly install malicious software on their computer that aims to collect the information. Phishing is called *spear-phishing* or *whaling* when the activity targets high-profile personnel, such as corporate executives or HR managers who have more extensive access or access to more sensitive information. To reduce these risks to an organization's IT infrastructure, IT staff must combine a technical understanding of the available privacy-enabling and privacy-threatening technology described in this book with strategies for managing data through IT governance, which is discussed further in Chapter 8.

For individuals, threats may exploit how the individual uses a broad range of computing devices. For example, individuals may install on their computers

otherwise innocuous browser plug-ins or personal software, such as file-sharing software, that engage in covert collection of personal information. This can affect IT staff as well, because workplace computers succumb to the same threats when employees use their work computers for both work-related and personal reasons. Throughout this book, we explore in greater detail the kinds of threats that affect individuals with respect to various dimensions of privacy, including confidentiality in Chapter 3, identifiability in Chapter 4, tracking and surveillance in Chapter 6, interference in Chapter 7, and threats due to security lapses in Chapter 9. In Chapter 5, we present how the lack of usable privacy can limit a data subject's ability to manage their own privacy risk.

1.4 Privacy, Security and Data Governance

Within an organization, privacy is commonly situated in the legal department or other group responsible for data governance. This creates a challenge for IT professionals, as the focus on privacy has often followed compliance with laws and regulations, which generally hold a narrower view of how privacy impacts individuals. Furthermore, weak or infrequent communication between the legal and IT departments is problematic, as legal needs to communicate the goals of privacy protections to IT, and IT must be allowed to determine the appropriate IT controls to support those goals. Chapter 2 aims to bridge traditional engineering practices that are used to develop IT systems with privacy goals to enable IT professionals to engage legal in meaningful and frequent communication and relevant IT decisions that affect privacy. Chapter 8 is written from the perspective of privacy governance, which includes a greater emphasis on the legal perspective and thus complements the developer view embodied in Chapter 2.

Prior to privacy becoming a more prominent focus in IT, security had been receiving increasing attention within IT departments. The increasing focus on security is evident in the rising number of companies with a dedicated security executive position, which has been reported at 29 percent in 2008, 44 percent in 2009 and 53 percent in 2011.² Security is traditionally defined as a set of activities that supports three different quality attributes: *confidentiality*, which ensures that information is only accessible by authorized individuals; *integrity*, which ensures that information has not been unintentionally modified; and *availability*, which ensures that information is readily available whenever it is needed. Some have argued that privacy is simply a subset of security, because privacy includes

restricting access to information or ensuring confidentiality. This is convenient, as it suggests that organizations who practice good security practices have already addressed privacy. For example, one might argue that existing security standards, such as the ISO 27000 series, already cover those concerns that are raised by privacy. However, multiple privacy theories show that privacy is much broader than security. For example, the well-respected jurist Charles Fried argues that people do not always enjoy more privacy when others know less about them, which means confidentiality or restriction of access to personal data alone cannot increase a person's sense of privacy.¹⁰ While privacy certainly includes an individual's ability to grant and deny access to their information, privacy also concerns an individual's ability to control the granularity of information that others have access to. The privacy scholar Julie Cohen further expounds upon the value of privacy to individual autonomy, noting that the ability to make first moves and false starts is necessary to develop individual identity.¹¹ Recent research on "regrets" illustrates how individuals will willingly share information, only to later regret that this information will be permanently remembered and made available by technology.¹² Whereas a security expert will see access control in these examples, a privacy expert will see a broader range of issues that concern information access, including surveillance, interrogation, feelings of insecurity and being exposed, appropriations and distortions of one's image, and so on.¹³ Despite this gap in perspectives, IT security professionals are well positioned to extend their expertise with an additional focus on privacy. IT security experts have the technical knowledge of IT administration and development practices required to integrate privacy into IT systems, as well as the understanding of risk management practices that can be adapted to privacy, as we discuss in Chapter 2. In addition, at the end of the book, we review in Chapter 9 the set of security problems and practices that commonly align with privacy.

In addition to IT security departments, U.S. regulations and international standards have led to the development of data governance groups within organizations. Examples of regulations and standards that affect data governance and can support internal, organizational privacy standards include the following:

- Sarbanes-Oxley (SOX), which aims to improve corporate accounting
- Basel II, which aims to improve credit risk calculations

- The HIPAA Privacy Rule, which requires accounting for medical information disclosures

These rules affect data management practices, and thus organizations respond by developing internal data governance policies to comply. Data governance policies are implemented by IT managers and leverage many of these same practices in the pursuit of improved privacy, such as identifying data assets and mapping regulatory controls onto IT systems that store governed data. In Chapter 8, we discuss how governance, risk and compliance practices can be extended to include compliance with privacy regulations. However, data governance policies are only complementary to a strong privacy program, and IT professionals must also develop risk management strategies, such as those discussed in Chapter 2, and account for specific privacy-preserving and -threatening technologies, such as those discussed in Chapters 3-7.

1.5 Privacy Principles and Standards

The privacy profession is led by established principles and standards that should be used to guide IT professionals, particularly developers in requirements, design and testing, toward better privacy-preserving systems. Privacy principles have their origin in the Fair Information Practices (FIPs), which were first established by the Health, Education and Welfare Advisory Committee on Automated Data Systems in 1972.¹⁴ Today, there are several interpretations and extensions to the original FIPs, and recent calls for privacy by design (PbD) have sought to use the FIPs as the foundation for an early integration of privacy into software.¹⁵ The more prominent principles that developers should be familiar with include the following:

- *The Fair Information Practice Principles (FIPPs) (1977)*, published by the U.S. Federal Trade Commission (FTC) and used as guidance to businesses in the United States
- *The Guidelines on the Protection of Privacy and Transborder Flows of Personal Data (1980)*, published by the Organization for Economic Cooperation and Development (OECD)
- *The Privacy Framework (2005)*, published by the Asia-Pacific Economic Cooperation (APEC)

- *The Generally Accepted Privacy Principles (GAPP)* (2009), published by the American Institute of Certified Public Accountants (AICPA) and The Canadian Institute of Chartered Accountants (CICA)
- *NISTIR 8062, An Introduction to Privacy Engineering and Risk Management in Federal Systems* (2017), published by the U.S. National Institute of Standards and Technology (NIST)

The 1980 OECD Guidelines provide a foundational and international standard for privacy. The guidelines contain principles that are not found in the FTC's FIPPs, such as the collection limitation principle, and the GAPP largely refine the guidelines into more concrete privacy controls in a similar manner to the NIST privacy controls. The guidelines are reprinted below from the OECD website:

1. *Collection Limitation*—there should be limits to the collection of personal data and any such data should be obtained by lawful and fair means and where appropriate, with the knowledge or consent of the data subject.
2. *Data Quality Principle*—Personal data should be relevant to the purposes for which they are to be used, and, to the extent necessary for those purposes, should be accurate, complete and kept up-to-date.
3. *Purpose Specification Principle*—The purposes for which personal data are collected should be specified not later than at the time of data collection and the subsequent use should be limited to the fulfillment of those purposes or such others as are not incompatible with those purposes and as are specified on each occasion of change of purpose.
4. *Use Limitation Principle*—Personal data should not be disclosed, made available or otherwise used for purposes other than those specified, except: (a) with the consent of the data subject; or (b) by the authority of law.
5. *Security Safeguards Principle*—Personal data should be protected by reasonable security safeguards against such risks as loss or unauthorized access, destruction, use, modification or disclosure of data.

6. *Openness Principles*—There should be a general policy of openness about developments, practices and policies with respect to personal data. Means should be readily available of establishing the existence and nature of personal data, and the main purposes of their use, as well as the identity and usual residence of the data controller.
7. *Individual Participation Principle*—An individual should have the right: (a) to obtain from a data controller, or otherwise, confirmation of whether or not the data controller has data relating to him; (b) to have communicated to him, data relating to him within a reasonable time; at a charge, if any, that is not excessive; in a reasonable manner; and in a form that is readily intelligible to him; (c) to be given reasons if a request made under subparagraphs (a) and (b) is denied, and to be able to challenge such denial; and (d) to challenge data relating to him and, if the challenge is successful to have the data erased, rectified, completed or amended.
8. *Accountability Principle*—A data controller should be accountable for complying with measures which give effect to the principles stated above.

The principles provide a common language through which to speak about privacy: Chief privacy officers (CPOs) and the legal department should have a reasonable understanding of the meaning of purpose specification, but IT professionals are more likely to know the technical details of tracing data through various databases, server and client applications to ensure that data is not repurposed. Moreover, the principles work in tandem, and IT professionals can apply the principles in a systematic manner to their systems by using the data life cycle.

1.6 The Data Life Cycle

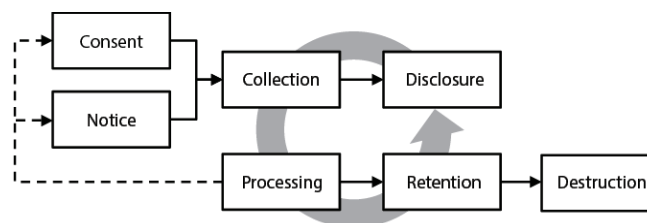
As we explore further in Chapter 2, privacy-preserving systems exist in a rich ecosystem with a diversity of actors who have different viewpoints: Lawyers aim to maintain a defensible position in a court of law; IT developers focus on developing robust, extensible and useful software; IT managers aim to deliver value to their customers; and so on. The unifying theme across all these professions is how data lives in the IT ecosystem and how the IT developer can

take steps that protect the privacy of that data in a manner that is consistent with these other viewpoints. To this end, we present the data life cycle and refer to activities in the life cycle throughout this book.

The data life cycle (see Figure 1-1) provides a generic, high-level overview that describes how data flows through an organization, including through its business processes and supporting IT systems. The life cycle is generic as a means to be adaptable in different situations; however, the technical details of how data is collected or used, for example, can vary widely based on the technology, and thus these details can introduce additional considerations not captured by the life cycle. Despite this limitation, the life cycle provides a means for an IT professional to think about end-to-end privacy protection.

In the data life cycle, it is the responsibility of a privacy-respecting organization to specify the purpose for which information will be used and maintain consistency between actual uses and stated uses. The challenge for IT professionals is that the users of the data determine the purposes, and these purposes will evolve as the organization evolves their business practices. Under EU Directive 95/46/EC, for example, the maintainers of data are the data controller and the users of data are the data processors.

Figure 1-1: The Data Life Cycle



Data collection occurs at various points within an information system. A few types of data collection include: (1) *first-party collection*, when the data subject provides data about themselves directly to the collector, e.g., in a web-based form that is only submitted when the data subject clicks a button; (2) *surveillance*, when the collector observes data streams produced by the data subject without interfering with the subject's normal behavior; (3) *repurposing*, which occurs when the previously collected data is now assigned to be used for a different purpose, e.g., reusing a customer's shipping address for marketing and (4) *third-party collection*, when previously collected information is transferred to a third-party to enable a new data collection.

Each of the above four collection types may be either *active*, which occurs when a data subject is aware of the collection, or *passive*, when the data subject is unaware. Various consent mechanisms exist to engage the data subject in the collection activity to make the collection more overt. The best practice is to obtain consent prior to the collection, to avoid any misconceptions and allow the data subject to opt out of or opt in to the collection before it occurs. In an *explicit consent*, the individual is required to expressly act to communicate consent. Examples of explicit consent include the following:

- Clicking a checkbox that appears alongside the collection disclosure statement in a web-based or other data-entry form, e.g., “By clicking this checkbox, you agree to allow us to collect...”
- Clicking a button to acknowledge the receipt of a privacy notice, which may be displayed above the button or made obtainable through an additional step, such as a hyperlink or file download, e.g., “By clicking this button, you agree to the terms and conditions stated in...”
- Responding to an automatically generated email or other type of private communication to indicate receipt of the privacy notice, e.g., “This notice was sent to you by email because...” and “Please click the link in this email to acknowledge...”

Passive or implied consent is generally obtained by including a conspicuous link to a privacy notice that describes the collection activities. These links may appear at the foot of a web page, for example, or embedded in installation instructions or a user manual. However, no actions are taken by the IT system to engage the individual with the notice; instead, use of the system is assumed to imply consent.

The extent to which the data subject obtains the privacy notice and infers the specific types of collections taking place determines whether the collection is overt. For example, a privacy notice may state that collections are performed for marketing purposes (e.g., to enable third-party collection by a marketing service). Such general purposes may not lead a data subject to believe they would be the subject of online behavioral advertising through this type of collection. If collection disclosure statements are intentionally or unintentionally vague, the collection may reasonably be viewed as covert when the data subject cannot anticipate the scope of collection.

IT professionals should ensure that the purposes for which data is collected trace to appropriate uses and disclosures of that data throughout their information system. The act of *repurposing* occurs when data is collected for one purpose and then used for an entirely different purpose. This can be a source of privacy harms to the individual and may be illegal under some regulatory frameworks. Examples include collecting airline passenger data directly from passengers to schedule airline travel and then reusing this information to develop a terrorist threat detection system or, alternatively, collecting a mobile user's location to provide a route between two locations and then reusing repeated location samples to develop general profiles of traffic patterns.¹⁶ While repurposing is not always viewed negatively by data subjects, it is important to assess the risk to privacy before proceeding to repurpose data.

Finally, IT professionals should consider how long data is retained by their system and, when retention is no longer needed, how they choose to destroy the data. Data may be retained to fulfill ongoing business needs or legal obligations. For example, an airline must retain consumer travel information for their bookings at least until the traveler has completed their flight; however, this information may be retained longer to comply with government regulations, to fulfill the internal requirements of customer loyalty programs, to profile their customers for marketing purposes or to offer their customers improved services. However, this data may eventually have limited value to any of the company's existing practices, at which point, the company may consider destroying the data to reduce the risks associated with retaining the data. The U.S. NIST Special Publication 800-88, Appendix A, describes several media-appropriate techniques for sanitizing storage devices and destroying data that range from clearing the data by overwriting the data with pseudorandom data, to degaussing electromagnetic devices to, finally, incinerating the physical media. The level of destruction required is determined by the sensitivity of the data, and, in many situations, simply deleting the data may offer adequate protection.

The data life cycle is shaped by the privacy objectives and business practices of an organization, and the systems that they develop will be adapted to meet these objectives. Table 1-1 presents the data life cycle from two extreme perspectives: (1) a *maximize-information-utility* objective, which views data as the basis for monetization and new revenue and seeks to collect and retain as much data as possible and (2) a *minimize-privacy-risk objective*, which views data as potentially toxic with inherent risks that can result in significant, irreversible privacy harms.

Depending on the data type, a single organization may prefer to mix these two cultures in their philosophical approach to engineering privacy-preserving systems.

Table 1-1: Envisioning Two Data Life Cycle Extremes from the Perspective of the Data Collector

	Maximize Information Utility	Minimize Privacy Risk
Collection	Collect any data that is available, as the value will be realized later when we envision new services and products; post generic privacy notices to accommodate broadly defined, future collections	Only collect data for established purposes and always collect consent from data subjects for sensitive data; allow data subjects to opt out of services they deem unnecessary and before collecting the data, when possible
Processing	Ensure open access to data within the organization; easy access drives innovation and creative new uses lead to increased utility and market competitiveness	Only use data for the purpose of the original collection; any new uses require additional consent from the data subject, and/or the sending of new privacy notices
Disclosure	Enable disclosures with third parties to leverage new marketing and outsourcing opportunities or to enable previously unplanned third-party services	Limit disclosures to those purposes for which data was originally collected; any new disclosures require additional consent from the data subject, and/or the sending of new privacy notices
Retention	Retain data as long as reasonably practical; long-term retention enables longitudinal analysis of data subjects to better accommodate their long-term needs and to build lifetime services	Destroy data when it is no longer needed to complete the transaction; any new uses that motivate longer retention periods require additional consent from the data subject and/or the sending of new privacy notices
Destruction	Avoid destruction by using long-term backups, or reduce access to data, but retain original data or a summary of the data for future uses or for reinstating services	As soon as data is no longer needed, ensure the data and any derivatives are removed from all systems using appropriate methods to prevent recovery

As we see in Table 1-1, organizations have different viewpoints based on their business objectives. In the maximize-information-utility culture, information is broadly collected and shared, and retention persists up to the physical limits of the organization's storage devices. In the minimize-privacy-risk culture, collection and retention are driven by need and new uses are planned commensurate with consent from the data subject. While both of these views are extreme, they may be practiced separately for different types of data within the same organization.

1.7 Individual Expectations of Privacy

Individuals, whether they are employees, students, customers or citizens, are concerned about their privacy. In a privacy study by Acquisti and Grossklags, we learned that 73 percent of individuals believe they do not have enough privacy.¹⁷ An overwhelming majority of those surveyed define privacy as control over their information (90 percent), with more than half of those surveyed viewing privacy as necessary to preserve their personal dignity (61 percent) and to develop personal autonomy (50 percent). However, it was further discovered that individuals do not behave in a manner consistent with what they say—in other words, while individuals value privacy, they may be observed as freely exchanging their privacy for services and other conveniences. Acquisti and Grossklags effectively argue that bounded rationality limits the human ability to acquire, memorize and process all relevant information when making privacy choices. This includes information about the long-term impact of sharing personal details with others, all the various ways that personal information might be used, and how that use can affect the person's long-term desire to feel safe from outside interference and surveillance and remain free to express themselves within a private community. Even with complete information, such as information that could be gleaned from an extensively detailed privacy notice, individuals are still susceptible to weigh losses heavier than gains, miscalculate their own future preferences, draw inaccurate conclusions from past experiences and trade future utility for immediate gratification. These behaviors may lead individuals to assume that a given situation is private because the individual's past experiences do not include new technologies that challenge their previous experiences by collecting sensitive, personal details. It also could lead an individual who suffers a privacy harm from rejecting a service indefinitely—never trusting that the technology can be adapted to protect their privacy in the future.

For IT professionals, these insights present important ethical and risk-related challenges to how technology is used to collect and protect personal information. One approach is to transfer control to the individual whenever possible to allow them to manage their own privacy risks. While this approach requires designing systems to expose this level of control to users, the underlying premise is that individuals know their unique privacy risks better than outsiders, whereas IT professionals may misjudge the risk or be unfamiliar with the individual's personal circumstances. However, this cannot be the whole solution, as individuals can still

miscalculate their long-term preferences. Thus, IT professionals must be vigilant to observe privacy harms and refactor their systems with privacy controls to prevent these harms in the future. Often, to protect an individual, more information (e.g., gender, age, lifestyle) must be collected to determine the person's privacy risks, which only further exposes them to additional privacy threats. Thus, IT professionals must strike the right balance that respects individual expectations of privacy against the business needs for the data.

1.8 Summary

In this chapter, we provided a general overview of this book by identifying who should read this book, comparing alternative definitions of privacy and illustrating a few sources of privacy risk to organizations and individuals. In addition, we briefly introduced a framework for IT professionals that can be reused across the remaining chapters of this book. The framework defines the relationship between privacy and security, which explains that security can be used to support privacy but does not alone ensure IT privacy. Rather, privacy requires that IT professionals coordinate technology and policy to construct a holistic solution. This framework includes the privacy principles that have become the foundation for discussing privacy in a domain-independent manner and that can be used to evaluate technology and policy to identify and mitigate privacy risks. For IT professionals, the privacy principles are most meaningful in the context of the data life cycle. We discuss how the data life cycle can be used to envision two extreme perspectives on personal information use: the maximize-information-utility culture, and the minimize-privacy-risk culture. These two perspectives illustrate the trade-offs that organizations face when making choices about privacy-enabling and -threatening technology and policy—choices that impact the acquisition, development and deployment of IT systems. Finally, we close by discussing the inherent conflict in how individuals view their personal privacy: on the one hand, freely exchanging very private details for convenient products and services and, on the other hand, wishing they had more privacy. As stewards of personal data, IT professionals must grapple with this tension throughout the data life cycle and recognize when to invoke ethical decision-making as an individual's personal rewards exceed their personal protections afforded by IT and IT policy.

Endnotes

- 1 Alan Westin, *Privacy and Freedom*, (The Bodley Head Ltd., 1970).
- 2 Helen Nissenbaum, *Privacy in Context: Technology, Policy, and the Integrity of Social Life*, (Stanford Law Books, 2009).
- 3 Daniel J. Solove, “A Taxonomy of Privacy,” *University of Pennsylvania Law Review*, no. 3, (2006).
- 4 M. Ryan Calo, “The Boundaries of Privacy Harm,” *Indiana Law Journal*, vol. 86, no. 3, (2010), 1131–1162.
- 5 Javeline Strategy & Research, “2018 Identity Fraud: Fraud Enters a New Era of Complexity,” February 2018.
- 6 Javeline Strategy & Research, “2018 Identity Fraud.”
- 7 Ponemon Institute, LLC, “Cost of a data breach study,” July 2018.
- 8 Ponemon Institute, LLC, “Cost of a data breach study.”
- 9 PriceWaterhouseCoopers, “2010 Global State of Information Security: Trial by fire,” October 2009; PriceWaterhouseCoopers, “2011 Global State of Information Security: Respected – but still restrained,” 2010.
- 10 Charles Fried, “Privacy,” *The Yale Law Journal*, 77: (1968), 475–93.
- 11 Julie E. Cohen, “Examined Lives: Information Privacy and the Subject as Object,” *52 Stanford Law Review*, (2000), 1373–1426.
- 12 Yang Wang, Gregory Norcie, Saranga Komanduri, Alessandro Acquisti, Pedro Giovanni Leon and Lorrie Faith Cranor, “‘I regretted the minute I pressed share’: a qualitative study of regrets on Facebook,” *Proceedings Seventh Symposium on Usable Privacy and Security*, (2011), 1–16.
- 13 Solove, “A Taxonomy of Privacy.”
- 14 U.S. Department of Health, Education and Welfare, Secretary’s Advisory Committee on Automated Personal Data Systems, Records, computers, and the Rights of Citizens (1973).
- 15 Ann Cavoukian, *Privacy by Design: Take the Challenge*, 2009.
- 16 Antón, Annie et al., “Inside JetBlue’s Privacy Policy Violations,” *IEEE Security and Privacy*, 2004.
- 17 Acquisti, Grossklags, “Privacy and rationality in individual decision making,” *IEEE Security and Privacy* 3(1): (2005), 24–30.

CHAPTER 2

Engineering and Privacy

**Stuart S. Shapiro, CIPP/G, CIPP/US; Travis D. Breaux, CIPT; David
Gordon**

In this chapter, we examine the role of IT systems engineering in protecting personal privacy and explore in particular how IT developers can integrate privacy in software development. Software engineering is a disciplined approach to the construction of software. While considerable amounts of software are created by

end-user programmers who initially work to solve a personally familiar problem, these personal projects quickly become large-scale endeavors developed and maintained by hundreds, if not thousands, of professional engineers.¹ The emerging complexity that results from scaling small software projects into large projects requires a sophisticated IT ecosystem consisting of well-trained professionals and well-established processes.²

IT professionals should consider how their systems affect privacy whenever these systems contact personal information (sometimes referred to as personal data). Information-intensive systems include web-based retail, hospitality and travel reservation systems, banking systems, electronic health records and social networking, to name a few. However, under the privacy theories of autonomy and freedom, privacy also concerns systems that may not directly collect or use personal information but still affect the personal development, free expression and movement of individuals throughout society.³ This includes transportation systems, electronic voting systems and systems that provide citizens with information about the activities of their local and national government. Because of the personal nature of privacy, it is critical that IT developers consider the role that software plays in privacy and take steps to design systems to protect individual privacy. In Section 2.1, we examine the larger privacy ecosystem and discuss how it relates to different software development models. This section illustrates how various professions play an important role in privacy-preserving IT engineering and also presents a brief introduction to software engineering practice. In Section 2.2, we introduce the fundamentals of risk management and demonstrate how risk can drive decisions to increase or decrease a project's investment in privacy. Sections 2.3 through 2.6 address specific techniques for managing privacy during all stages of software engineering, including requirements, design, testing, deployment and beyond.

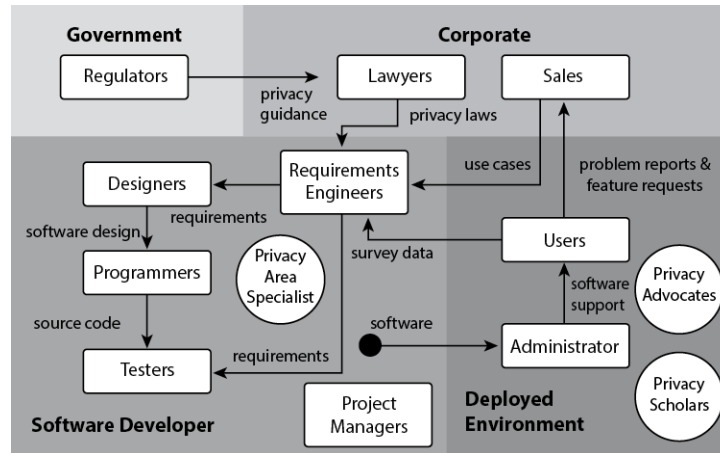
2.1 Privacy in an IT Ecosystem

A useful way of thinking about how privacy is situated within a large IT project is to consider the broader ecosystem, which consists of multiple professions that all interact during the development and use of hardware and software.⁴ In addition to the developers who write the software, the surrounding ecosystem includes other roles that hold a stake in how the system is developed (see Figure 2-1):

- *Project managers*, who ensure that adequate resources are available to construct the system and that team members communicate effectively during construction, deployment and maintenance.
- *Marketing and sales*, who work with customers to establish new requirements and promote the software in the marketplace. Salespeople should understand how their software protects the privacy of individuals at an appropriate technical level for their clientele.
- *Lawyers*, who track regulatory issues relevant to the software's function or manner of construction. This includes monitoring privacy legislation developments in markets where software is deployed, monitoring emerging threats to privacy that could reshape the regulatory environment or consumer trust, and communicating these issues to developers who are responsible for aligning software with legal and social norms.
- *Requirements engineers*, who collect, analyze and manage requirements.
- *Designers*, who translate software requirements into an architecture or design. Designers are responsible for tracing privacy-related requirements, such as anonymity, confidentiality and integrity requirements, throughout the software architecture.
- *Programmers*, who translate software design into source code using best practices and standard libraries and frameworks.
- *Testers*, who validate that the software conforms to the requirements. Testers must discover ways to "break the system" or ways in which privacy may be violated by a misuse or abuse of the software's functionality.
- *Users*, who operate or interact with the software to perform their daily work or recreation. Users who are also data subjects must be aware of and informed about how software uses their personal information, and they must be provided a reasonable degree of control over that information.
- *Administrators*, who install and maintain the software. Administrators, who may also be users, have responsibilities to ensure that operational assumptions behind the software's design are implemented, whether these assumptions are in the physical environment or in the operating

system. Administrators rely on adequate documentation to ensure software is properly installed and maintained.

Figure 2-1: An Incomplete View of the Software Ecosystem for Privacy



2.1.1 The Privacy Engineer

The diversity of stakeholders in the software ecosystem can be managed by appointing an *area specialist* who serves as a repository of knowledge and works to tailor this knowledge for the different stakeholders.⁵ In our experience, this specialist begins as a software developer and later becomes a software project manager before taking on the role of area specialist. The area specialist has several responsibilities: to collect critical regulatory requirements from lawyers, to validate that marketing requirements are consistent with laws and social norms, to meet with designers to discuss best practices when translating requirements into design specifications, and to collect user feedback and monitor privacy blogs, mailing lists and newspapers for new privacy incidents. As a privacy engineer, the area specialist develops a *community of practice*—“a collective process of learning that coalesces in a shared enterprise,” such as reducing risks to privacy in technology.⁶

The community of practice includes professionals outside the specialist’s organization. For example, prominent bloggers, including privacy law scholars and nonprofits, track emerging issues and report on newsworthy items that affect their profession. In June 2012, emerging state legislation on driverless vehicles and autonomous aircraft (drones) was closely monitored by Ryan Calo, a prominent privacy scholar at the University of Washington. The Center for Democracy and Technology also maintained policy research and analysis on a range of privacy-

sensitive topics, such as behavioral advertising, location, identity management, data breaches and more. In addition, regulators often provide guidelines to organizations that inform how to interpret various regulations. The U.S. Federal Trade Commission (FTC) regulates privacy using its statutory authority to pursue unfair and deceptive trade practices. In privacy, such practices arise from a misalignment between privacy policies, which promise a level of privacy protection to consumers, and broken information practices that violate those policies. Through decades of experience, the FTC has published case highlights, guidelines, reports and workshop summaries that privacy area specialists can integrate under the constraints of their software enterprise to explore where consensus is forming around emerging issues in privacy. Finally, organizations such as the International Association of Privacy Professionals (IAPP) sponsor workshops and training seminars to improve the privacy profession by enabling networking opportunities across industries and government. By monitoring these varied sources of information and by learning about prominent thought leaders, area specialists can remain current as to how privacy evolves in response to technology and learn to improve how they deliver relevant input into their organization's software engineering process.

2.1.2 Software Process Models

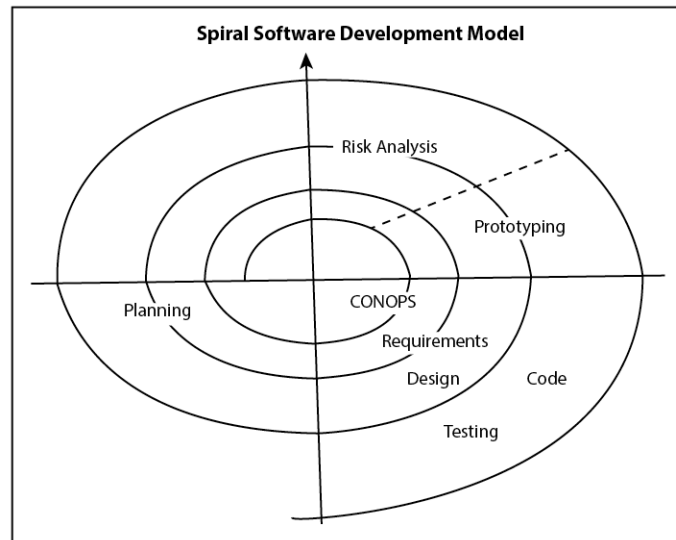
Since the 1968 North Atlantic Trade Organization (NATO) conference on software engineering that produced the Garmisch report, software engineers have employed software process models and methods to manage engineering complexity and coordinate the steps in constructing software.⁷ Software process models define the various stages of software development and the conditions by which development is allowed to transition from an early stage to a later stage, as well as the artifacts produced at each stage. These models may also designate developer roles and responsibilities. Today, one can choose from a variety of software processes: Plan-driven methods, such as the waterfall and spiral models, emphasize up-front documentation and planning, in contrast to lighter-weight, Agile methods, such as Extreme Programming and Scrum, which emphasize personal communication and small, dynamic development teams.⁸ There is even a middle ground, such as the Team Software Process, which emphasizes process measurement and team building early on.² This is not an exhaustive list, but independent of the process one uses, software developers will address the following six activities in some capacity:

- *Requirements Engineering*—The activity that yields requirements that describe constraints on the software system. Requirements include environmental factors, stakeholder goals and functional and behavioral properties of the system, including privacy, performance and reliability.
- *Design*—The activity that yields software designs and architectures, which describe how a particular system will operate and may include modular components with assigned functionalities as well as connectors that link components, such as an information flow between a client and a server.
- *Implementation*—The activity of writing the source code to implement a particular design, including the development of the setup and configuration process to support the system for the very first time.
- *Testing*—The activity of verifying that the runtime system conforms to the requirements. This includes developing test cases, which test specific functions in the software, and conducting user testing to discern how users operate the software.
- *Deployment*—The activity of installing and configuring the software in its operational environment. This may include user training to ensure users can operate the software.
- *Maintenance*—The activity of extending and fixing software over the course of its lifetime, either to repair bugs after deployment or to provide users with new functionality.

In plan-driven and Agile software development methods, software development activities are coordinated at different development stages and levels of developer commitment. In Figure 2-2, the spiral model requires multiple iterations of development that yield working prototypes to manage engineering risk. Going from the center of the spiral outward, this model shows how developers begin with a concept of operations (CONOPs) and proceed to refine these ideas into requirements, design and eventually code and test cases. At each iteration point, the development team reassesses project risks such as: Are the requirements correct? Is the system design feasible? In the Scrum model, developers employ timeboxing (in 24-hour and 30-day cycles) to achieve similar effects on controlled portions of functionality within a limited time frame. Requirements, called user

stories, are contained in a product backlog managed by the product owner; the team, which generally excludes the product owner, decides which portion of the backlog to implement in each iteration, taking into account working functionality, priorities and time constraints.

Figure 2-2: Spiral Software Development Model

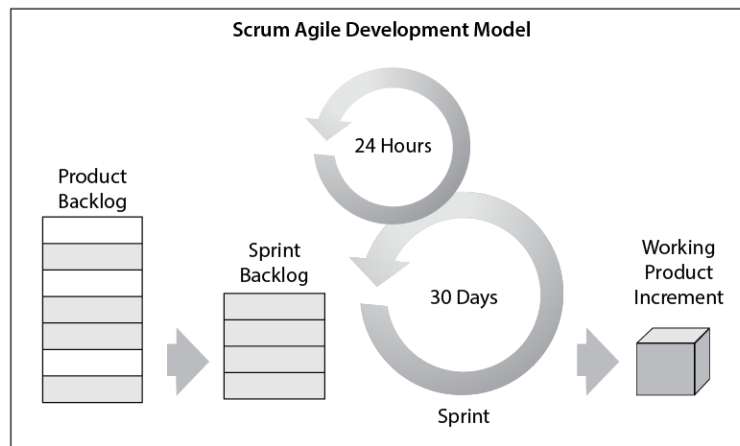


Boehm and Turner characterize the choice between plan-driven or Agile methods as determining which types of risk dominate a software project.¹⁰ Privacy can be integrated into either type of method; however, the preservation of legal requirements and the privacy specialist's observations acquired from monitoring the community of practice necessitate a minimum level of planning to respond to privacy risks in a systematic way. In the spiral model, privacy must be considered from the very beginning, at the CONOPs and requirements stage in the center of the spiral. Alternative designs are produced to address privacy requirements before project planning begins in the lower-left quadrant. The risk analysis phase of the upper right quadrant concerns *project risks*, raising questions such as: Is the scope of planned effort feasible? Which design alternative is best suited to solve a particular problem? Can we explore designs and reduce risks using prototypes of novel or complex functionality? While IT developers can return to or repeat earlier iterations in the spiral model, this type of revision is costly and should be avoided. Therefore, in plan-driven methods, there is a need to address privacy early using a comprehensive toolkit of requirements and design techniques.

As Boehm and Turner argue, even Agile methods can include some planning when the risks outweigh the benefits of increased agility. In the Scrum process, for

example, the product owner prioritizes requirements, called user stories, which will be developed during an iteration, called sprint. Developers determine how much time is required to implement each story. (See Figure 2-3). To bridge Scrum and privacy, the area specialist can participate in developing user stories to help identify privacy risks and harms and then propose strategies to mitigate those risks.

Figure 2-3: Scrum Agile Development Model

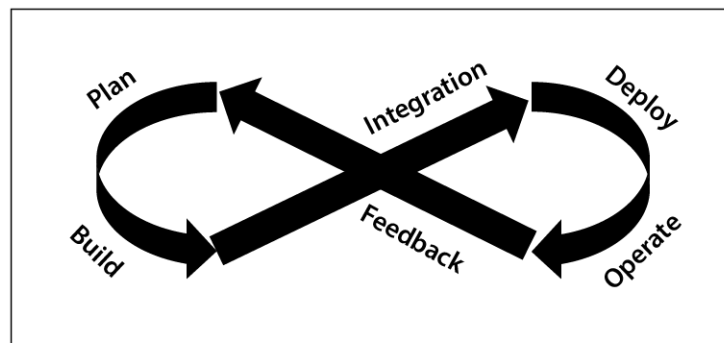


Furthermore, the area specialist may review the sprint backlog, which contains the list of stories that will be implemented during the current sprint, to ensure that the working increment produced by the iteration does not contain major privacy risks. For example, imagine a new web-based product developed for children under 13 that would be governed by the COPPA. In an upcoming sprint, the product owner may wish to see a new login facility for the product. To comply with the COPPA, however, this working increment will need to support a parental consent mechanism before collecting the child's personal information. While the login facility could be prototyped without this privacy control, it should not be tested on children without the control in place, since the control plays a critical role in protecting privacy. Therefore, the area specialist can intervene and review the sprint plans to catch dependencies between privacy-enabling and privacy-threatening functionality and suggest changes to the sprint backlog before these functions go live. In general, the project manager should decide when and where to involve the area specialist to reduce privacy risks during software development and to ensure that other developers respect this person's contributions.

More recently, an Agile-related model under the general rubric of DevOps has been gaining favor. DevOps aims to more closely integrate system development

and system operation, speeding up both the development and the deployment of updated systems.¹¹ DevOps emphasizes a continuous, looping activity stream that takes feedback on system performance, identifies a set of necessary or desired changes and enhancements, rapidly engineers these and then fields them. As a result, the DevOps model (see Figure 2-4) is frequently visualized as a figure eight. While it enables fast evolution of IT systems, the velocity of DevOps can present challenges to ensuring that properties such as privacy are appropriately embedded and maintained in a system.

Figure 2-4: DevOps Model of Software Development



It should be noted that some proposed methods for engineering privacy into systems basically amount to specialized life cycles themselves. These include the Privacy Management Reference Model and Methodology (PMRM)—promulgated by the Organization for the Advancement of Structured Information Standards (OASIS)—and the PReparing Industry to P_rivacy-by-design by supporting its A_pplication in R_earch (PRIPARE) privacy and security-by-design methodology, funded by the European Commission.¹² Other privacy engineering methods, in contrast, are much more atomic and aimed at specific engineering activities. These include the LINDDUN threat modeling method developed at KU Leuven in Belgium and the Privacy Risk Assessment Methodology (PRAM) developed by the U.S. National Institute of Standards and Technology (NIST).¹³ While more focused methods enable flexible mixing and matching of techniques, the more holistic approaches can potentially (but not necessarily) reduce the number of distinct decisions that must be made. Which method or combination of methods makes the most sense will be highly contextual and dependent on system and environmental characteristics, including the extent to which the system may be considered complex and the process standards and supporting tools of the organization engineering it.

2.1.3 Defect, Fault, Error, Failure and Harm

Our premise is that many functional violations of privacy can be avoided by the correct design, implementation and deployment of software. The IT developer is able to limit privacy violations by carefully managing steps leading up to system failure. The Institute of Electrical and Electronics Engineers (IEEE), one of the largest engineering professional associations, defines software engineering defects, faults, errors and failures as follows; we include the definition of harm as it relates to privacy:¹⁴

Defect—A flaw in the requirements, design or implementation that can lead to a fault

Fault—An incorrect step, process or data definition in a computer program

Error—The difference between a computed, observed or measured value or condition and the true, specified or theoretically correct value or condition

Failure—The inability of a system or component to perform its required functions within specified performance requirements

Harm—The actual or potential ill effect or danger to an individual's personal privacy, sometimes called a hazard

A functional violation of privacy results when a system cannot perform a necessary function to ensure individual privacy. For example, this occurs when sensitive, personally identifiable information (PII) is disclosed to an unauthorized third party. In this scenario, the *defect* is the one or more lines of computer source code that do not correctly check that an access attempt is properly authorized, and the *fault* is the execution of that source code that leads to the error. The *error* is the unauthorized access, which is an observed condition that is different from the correct condition—"no unauthorized access will occur." The *failure* is the unauthorized third-party access; failures are often described outside the scope of source code and in terms of business or other practices. *Privacy harms* may be objective or subjective: An *objective harm* is "the unanticipated or coerced use of information concerning a person against that person"; a *subjective harm* is "the perception of unwanted observation," without knowing whether it has occurred or will occur.¹⁵ In public reports, we frequently learn about a system failure and subjective privacy harms or potential for harm. Less often do we hear about the

underlying errors, faults and defects that led to the system failure, and occasionally we learn about specific individuals who suffered objective harms.

Daniel Solove has identified four risk categories of privacy harm: *information collection*, *information processing*, *information dissemination* and *invasion*.¹⁶ Solove writes that information collection harms resulting from surveillance and interrogation may lead to a degree of coerciveness. Observing a user click on age-relevant website links (e.g., links to music from a particular age-specific era) is an example of surveillance, whereas asking a user to provide their age as a condition of using a service is a form of interrogation. We discuss Solove's harms in further detail in Section 2.2.1.4 under risk management. While these harms can overlap in practice, a robust privacy design applies special consideration to each of these harms to avoid unintended threats to an individual's privacy.

When a privacy incident occurs, the reported description often refers to the failure or harm. Because individuals personally experience harms and share these experiences with others, the engineer may discover harms reported in news articles or blogs. In addition, regulatory agencies conduct investigations in response to reported harms and, as a consequence, regulatory enforcement actions can detail additional evidence in the form of errors or failures that link the software's operation and installation to the reported harm. As we discuss in Section 2.3, there are techniques that IT developers can use to anticipate and mitigate the risk of potential harms based on regulatory enforcement reports and news articles. In addition, there are techniques for identifying and removing defects from design documents and programs, which we discuss in Sections 2.4 and 2.5 on high- and low-level design, respectively.

2.2 Privacy Risk Management

Risk management is an integral aspect of developing reliable systems. IT development projects must address multiple types of risk, including programmatic risk, such as the risk of project cost and schedule overruns, and technical risk, which includes the risks associated with specific technologies. Thus, an IT professional may be required to perform the role of a privacy risk analyst.

Risk is defined as a potential adverse impact along with the likelihood that this impact will occur. The classic formulation of risk is an equation: $\text{risk} = \text{probability of an adverse event} \times \text{impact of the event}$. In practice, analysts may express probability and impact numerically and compute a numerical result that can be

used to compare risk levels across different events. Risk comparisons are used to prioritize risks, nominally on the basis of the risk score, but sometimes based primarily on the highest impact or highest probability. However, it is often the case that a technical or empirical basis for one or both of these numbers is nonexistent, in which case an ordinal measure is used, such as assigning a value of low, medium or high impact to an adverse event.

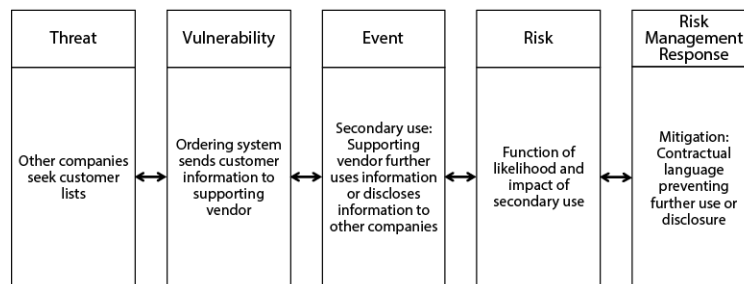
Ordinal measures are subject to the limitations of human perception and bias, as are numerical measures, and all measures with the same level (e.g., low) remain contextually relative and not easily comparable. One approach is to identify a relative median event that a risk analyst can use to assign values to other events (e.g., event X is higher or lower impact than event Y). However, caution should be used when treating such measures as quantitative data, because normal arithmetic may not be applied to this data: One cannot, for example, take the sum of two or more ordinal values, that is, $\text{low} + \text{high} \neq \text{medium}$, though explicit relations that map combinations of ordinal values to a resultant value can be rationalized. Hubbard and Seiersen as well as Freund and Jones, though, assert that when properly approached, quantitative measures are readily ascertainable and that any imprecision pales in comparison to that of qualitative, ordinal measures.¹⁷

In pursuit of a quantitative risk score, Bhatia and Breau introduced an empirically validated privacy risk scale based on the theory of perceived risk described by Paul Slovic.¹⁸ The scale is used to measure how willing data subjects are to share their personal data based on their social and physical distance to the privacy harm. The scale can be incorporated into a survey that is distributed to a company's data subjects to measure the perceived risk to specific data types. The measurements are multiplicative, such as that a data type with a risk score of 4 is twice as risky as a data type with a risk score of 2. The scale has been used to grade data types as more or less risky in the event of different types of privacy harms, and these grades can be used to prioritize data protections for types with the most risk. The findings of the evaluation further include that induced disclosure harms are perceived as lower risk than surveillance and insecurity harms in Solove's privacy risk taxonomy, that subjects perceive lower risk when they perceive the greater benefits of sharing (consistent with the Privacy Paradox), and that likelihood was not a multiplicative factor when computing privacy risk.¹⁹

Effective privacy risk management employs a risk model that an analyst uses to identify and align threats with the system vulnerabilities that the threats may exploit to yield risks, which are adverse events associated with degrees of

likelihood and impact (see Figure 2-5). For guidance in applying the risk model, the analyst uses a risk management framework, which is a step-by-step process for identifying threats, vulnerabilities and risks and deciding how best to manage the risks. Conventional risk management options can include (1) accepting the risk as is, (2) transferring the risk to another entity (which is how property insurance works), (3) mitigating the risk by introducing an appropriate privacy control or a system design change or (4) avoiding the risk (e.g., by abandoning particular functionality, data or the entire system). Risk avoidance may be impractical or impossible in many situations. For example, the risk of laptop theft is generally impossible to avoid, and thus assuming this vulnerability will always exist may lead to using encryption as a means to mitigate the loss of private data stored on these devices. Furthermore, any one of these risk management options may introduce a new risk, thus creating a risk-risk trade-off. A risk-risk trade-off is not risk avoidance per se, but the result of interdependent risk mitigation and acceptance decisions.

Figure 2-5: Risk Model Alignments



2.2.1 Privacy Risk Models

Privacy risk analysts can now choose from a number of privacy risk models that they may employ individually or in combination. The most frequently used and long-standing privacy risk models are the compliance model and the Fair Information Practice Principles (FIPPs). Over the last decade or so, other models have been introduced, including Calo's subjective/objective dichotomy, Solove's taxonomy of privacy problems and Nissenbaum's contextual integrity heuristic. Recently, NIST's Privacy Engineering Program promulgated its own privacy risk model. We review each of these widely recognized models in the following sections. In addition, a number of emerging models aim to provide analytical leverage in specific areas, including online manipulation and the interdependencies of social media participants. While this list is not exhaustive,

these models serve to illustrate the variety of options that system developers can incorporate into their projects.

2.2.1.1 The Compliance Model

Most systems that handle personal information do so within a related legal and/or policy regime. Legal regimes, which include statutory and regulatory mandates at any level of government, usually prescribe or proscribe certain aspects of a system in terms of what data it contains, what the system does with that data and how the system protects that data. While the EU's General Data Protection Regulation (GDPR) has garnered much attention owing to its scope, many other relevant statutory and regulatory mandates could be of concern depending on jurisdiction. Some, such as the Security Rule of HIPAA, are designed to be flexible and therefore require analysts to make interpretations based on their own security risks and available security controls. This flexibility manifests itself in the Security Rule in the form of prescribed security controls that are "addressable." This means that an organization, if its environment renders such a control unreasonable or inappropriate, may substitute alternative controls that achieve an equivalent level of risk management. The organization can even forgo alternative controls if they are not reasonable and appropriate.

In addition, systems may fall under an organizational policy regime with obligations and prohibitions that must be met. The compliance model is relatively straightforward; risks are delineated as the failure to do what is required or to avoid what is prohibited. For those laws, such as HIPAA, that require a risk assessment or reasonableness standard, however, a privacy risk model can be used to comply with this requirement. Under the compliance model, identification and alignment of threats and vulnerabilities amounts to examining the elements of the system that relate to each specific legal or policy requirement. To maintain a record of compliance, the privacy risk analyst can employ a traceability matrix, as discussed in Section 2.3.3.

2.2.1.2 FIPPS

The FIPPS often dovetail with the compliance model, as they frequently form the basis of privacy-related legal and policy regimes. For example, the FTC and U.S. Department of Homeland Security (DHS) have both adopted the FIPPs in their privacy risk management recommendations: The FTC recommends the FIPPs to industry, whereas DHS applies the FIPPs to their internal practices, including privacy impact assessments. The presence or absence of an associated compliance

regime notwithstanding, the FIPPs can be used in a similar fashion to a law, regulation or policy. FIPPs mostly prescribe, and in some cases proscribe, specific qualities and behaviors of systems that handle personal information. However, because FIPPs sit at a higher level of abstraction than legal and policy strictures typically do and because most of the principles are relative to the *purpose of the system*, significant interpretation by analysts and developers is necessary to determine how the FIPPs should manifest themselves in a given system. Once an appropriate interpretation has been established, that interpretation can be employed as a risk model in much the same way as a legal and policy regime. Identification and alignment of threats and vulnerabilities entails examining the elements of the system that relate to each specific FIPP.

2.2.1.3 Subjective/Objective Dichotomy

Ryan Calo's subjective/objective dichotomy (S/OD) focuses on privacy harms, which he argues fall into two categories: *Subjective harms* are grounded in individual perception (irrespective of its accuracy) of unwanted observation, while *objective harms* arise out of external actions that include the unanticipated or coerced use of that person's information.²⁰ The relationship between subjective and objective harms is analogous to the legal relationship between assault and battery. Assault is the threat of unwanted physical contact, while battery is the experience of unwanted physical contact. Similarly, subjective privacy harms amount to discomfort and other negative feelings, while objective privacy harms are actual adverse consequences.

Harms are equivalent to adverse events in terms of risk models. Thus, this model establishes a coarse-grained point of reference for events, to which threats and vulnerabilities must be aligned. Under the S/OD model, any privacy threat that is perceivable by individuals corresponds to a subjective privacy harm. Julie Cohen and Alan Westin argue that the fear of privacy harm can limit an individual's sense of freedom and expression, which may negatively affect the target system, such as a user choosing not to use a system due to a subjective harm.²¹ To assess the potential for subjective and objective harm, an analyst may examine elements of the system that relate to individuals' expectations of how their information may be used, actual usage—including surveillance or tracking—and consent or lack thereof to the collection and use of that information.

2.2.1.4 Taxonomy of Privacy Problems

Daniel Solove's taxonomy of privacy problems arose out of specific cases.²² Rather than promoting high-level privacy precepts (as is done in the FIPPs and S/OD models, for example), Solove surveyed specific instances that—based on cultural analysis using historical, philosophical, political, sociological and legal sources—are recognized as problematic from a privacy standpoint. From these observations, he derived a generic set of privacy problems. The taxonomy consists of 16 distinct privacy problems, organized into four categories: information collection, information processing, information dissemination and intrusion and decisional interference.

Information Collection

- *Surveillance* involves the observation and/or capturing of an individual's activities. Example: An advertising website embeds HTML iframes into multiple third-party news, social networking and travel websites to track users by what pages they visit and what links they click on.
- *Interrogation* involves actively questioning an individual or otherwise probing for information. Example: A website requires a user to enter their mobile phone number as a condition of registration, although the website's primary function does not require the phone number and there is no statutory or regulatory requirement to do so.

Information Processing

- *Aggregation* involves combining multiple pieces of information about an individual to produce a whole that is greater than the sum of its parts. Example: A retail company correlates purchases of unscented lotions, large tote bags and prenatal vitamins to infer that a customer is likely pregnant.
- *Identification* links information to specific individuals. Example: A website uses cookies, a recurring IP address or unique device identifier to link an individual's browsing history to their identity.
- *Insecurity* results from failure to properly protect individuals' information. Example: A website fails to encrypt private communications, thus exposing users to potential future harm.

- *Secondary use* involves using an individual's information without consent for purposes unrelated to the original reasons for which it was collected. Example: A retailer uses an email address for marketing purposes when the address was originally collected to correspond about a purchase.
- *Exclusion* denies an individual knowledge of and/or participation in what is being done with their information. Example: A marketing firm secretly purchases consumer data to advertise to the customer under a different company name without their knowledge.

Information Dissemination

- *Breach of confidentiality* results from revealing an individual's personal information, despite a promise not to do so. Example: A platform releases a user's data to a third-party plug-in despite the platform's privacy notice promising not to disclose the data to anyone.
- *Disclosure* involves revealing truthful information about an individual that negatively affects how others view them. Example: A private "lifestyle" service discloses a list of members, which is obtained by groups who disapprove of the lifestyle.
- *Distortion* involves spreading false and inaccurate information about an individual. Example: An employment history verification service incorrectly identifies a job applicant as a felon.
- *Exposure* results from the revelation of information that we normally conceal from most others, including private physical details about our bodies. Example: A person's prior purchase of a urinary incontinence product is used as a promotional endorsement and sent to the person's broader social network.
- *Increased accessibility* involves rendering an individual's information more easily obtainable. Example: A children's online entertainment service allows any adult to register and interact with child members, leaving these children accessible to strangers without parental consent.
- *Blackmail* is the threat to disclose an individual's information against their will. Example: An overseas medical claims processor threatens to

release patient data to the internet unless new employment conditions are met.

- *Appropriation* involves using someone's identity for another person's purposes. Example: An online dating service uses a customer's personal history, including age, biography and education, to promote its website to new customers.

Intrusion and Decisional Interference

- *Intrusion* consists of acts that disturb an individual's solitude or tranquility. Example: A mobile alert notifies potential customers that they are within the proximity of a sale.
- *Decisional interference* involves others inserting themselves into a decision-making process that affects the individual's personal affairs. Example: A website limits access to negative product reviews to bias a new user toward a specific product selection.

A few of these potential problems, such as breach of confidentiality and blackmail—which amount to harms and adverse events—can be quickly ruled out by well-intended, ethical IT developers. However, the increasing extent to which IT systems are distributed across multiple firms means that IT developers may depend on subcontractors to fully protect the system against these more ethical harms. Moreover, identifying and aligning threats and vulnerabilities for the remaining harms requires a risk analysis that includes an assessment of the likelihood that a particular problem will arise. Similar to the FIPPs, three of Solove's categories correspond to the data life cycle or how data moves through a system. These categories can be addressed by analyzing the system's data collection, processing and dissemination practices for the risk of these problems.

2.2.1.5 Contextual Integrity Heuristic

Helen Nissenbaum defines *contextual integrity* as maintaining personal information in alignment with informational norms that apply to a particular context.²³ The contextual integrity heuristic posits that privacy problems arise out of disruptions to these informational norms. Contexts are socially constructed settings characterized by, among other things, norms or rules and internal values in the form of purposes or goals. Context-relative, informational norms involve

actors (information senders, recipients and subjects), attributes (information types) and transmission principles that govern the flows of information. When an IT system violates or otherwise disrupts a context's informational norms, this can result in a perceived privacy problem. Using the contextual integrity heuristic entails analysis to surface what norms govern a given context. Unlike the preceding risk models, there is no preexisting reference point for adverse privacy events, such as privacy principles or categories of harm. To apply this heuristic, an analyst must first establish the existing informational norms and, second, determine how the system may disrupt those norms. Once identified, these disruptions can be interpreted as privacy vulnerabilities, thereby enabling a stable reference point from which to identify threats and adverse events.

Consider an example in healthcare. A patient may share information about a medical condition to enable the doctor to provide an accurate prognosis. The doctor expects the patient to be candid, although she may also expect the patient to be cautious during the first encounter. When the doctor has obtained the patient's trust, the doctor and patient will freely exchange information under the norms of this medically necessary engagement. However, the information the doctor obtains may be shared categorically and electronically with a pharmaceutical company that has treatment options available to the patient. If these treatment options were mistakenly communicated by postal mail to the patient's home or work address, thus unintentionally revealing the presence of the condition to others, then the system would have disrupted the informational norms governing the patient-doctor transaction. To mitigate this risk, the system can explicitly ask the patient to opt in to these communications, or the system may consider exposure risks under Solove's taxonomy and how to mitigate these risks.

2.2.1.6 NIST Privacy Risk Model

The specifics of NIST's privacy risk model are embedded in its Privacy Risk Assessment Methodology (PRAM), though its structure is discussed elsewhere.²⁴ NIST's model is noteworthy as it is relatively complete, explicitly addressing vulnerabilities, adverse events, and the relative likelihoods and impacts of those events. However, NIST employs different terminology in referring to these vulnerabilities and events. In NIST's model, vulnerabilities are problematic data actions. These describe system behaviors with privacy implications that, while they may be authorized, create the potential for adverse events. These adverse

events are prosaically termed *problems for individuals* and represent how problematic data actions may affect individuals in negative ways.

While not necessarily exhaustive, NIST's catalog of problematic data actions is wide ranging:

- *Appropriation* occurs when personal information is used in ways beyond what is expected or authorized by the individual
- *Distortion* involves the use or dissemination of inaccurate or misleading personal information
- *Induced disclosure* takes place when individuals are pressured to provide personal information
- *Insecurity* involves lapses in data security
- *Surveillance* occurs when personal information is tracked or monitored out of proportion to system objectives
- *Unanticipated revelation* is unexpected exposure of facets of an individual as a result of processing
- *Unwarranted restriction* involves imposition of unjustified constraints on individuals regarding access to the system and its information as it relates to them

The catalog of problems for individuals is equally expansive:

- *Loss of autonomy* involves self-imposed restrictions on behavior
- *Exclusion* denies individuals knowledge about their personal information or the ability to act upon that knowledge
- *Loss of liberty* improperly raises the possibility of arrest or detainment
- *Physical harm* is direct bodily harm to an individual
- *Stigmatization* links information to an identity so as to stigmatize the person associated with that identity
- *Power imbalance* enables abusive or unfair treatment of an individual
- *Loss of trust* can result from violations of implicit or explicit expectations or agreements regarding the treatment of personal information

- *Economic loss* involves direct or indirect financial loss

The relationship between problematic data actions and problems for individuals is not necessarily one to one. A single problematic data action can result in multiple problems for individuals.

2.2.1.7 Combining Models

As the astute reader will have noticed, the models described above are not mutually exclusive. If there is any applicable compliance model for a system—and there often will be at least one, since the compliance model includes policy as well as legal requirements—then use of the compliance model becomes mandatory. Even the most comprehensive compliance models, however, are unlikely to foresee every possible privacy risk for every system envisioned. Similarly, relevant risks can slip past a FIPPs-based model, because the FIPPs model is data-purpose centric. There is no reason to presume that any other model is infallible, either. Because there are likely diminishing marginal returns to integrating each new privacy risk model into an organization's risk management framework, a privacy analyst should instead pursue a limited but advantageous combination.

A limited combination of models can have the practical benefit of rendering the risk identification process more manageable when using fewer prescriptive models. For example, the contextual integrity heuristic can be used to identify vulnerabilities in the form of disruptions to informational norms. However, the analyst must decide how particular threats might exploit those vulnerabilities to yield privacy risks. In contrast, both the S/OD and taxonomy of privacy problems models provide a set of potential adverse privacy events but do little to assist in finding the threats and corresponding vulnerabilities that could lead to these events. Combining either of these models with the contextual integrity heuristic could provide mechanisms for recognizing both vulnerabilities and events, leaving only threat identification as an exercise for the analyst.

The above discussion focused on hybrid models, i.e., models constructed by simply combining distinct risk models. It is also possible to synthesize new risk models using existing models as inputs. One could, for instance, take a version of FIPPs together with the taxonomy of privacy problems and group-related, and in some cases effectively identical, adverse privacy events. In the case of FIPPs, adverse privacy events are negations of each of the FIPPs. Each of the constructed categories can then be contextualized based on the nature of the system and its

environment, yielding both a significant reduction in the number of adverse privacy events in the resulting model and a set of adverse events whose definitions are contextually specific. For example, in the context of a connected vehicle deployment, one could combine data minimization FIPPs with the surveillance and aggregation problems to synthesize tracking as an adverse privacy event in lieu of the original individual events.

2.2.2 Privacy Risk Management Framework

Risk management frameworks provide a process for applying a risk model to a specific information system in order to identify and address risks. Risk models directly address the domain-specific issues, while risk management frameworks are more about process and are therefore more generic. ISO 31000 is an example of an existing generic risk management framework. Indeed, ISO 31000 is so generic that it essentially includes construction of a risk model as part of the process. The risk management framework described here is a synthetic framework based on a variety of frameworks across multiple domains and adjusted to better accommodate the different ways in which privacy risk models may be built out. It should be noted that risk management frameworks are far more similar than they are different; as long as a framework is capable of incorporating an appropriate privacy risk model, it should suffice. This framework proceeds in six steps: (1) characterization; (2) threat, vulnerability and event identification; (3) risk assessment; (4) risk response determination; (5) risk control implementation and (6) monitoring and reviewing.

2.2.2.1 Characterization

The first stage of any privacy risk management framework involves characterizing the system that is the target of privacy threats in a way that renders it amenable to privacy risk analysis. This includes identifying the purpose of the system, what and how personal information flows throughout and is processed by the system, and what technologies are in place to support this system. The privacy risk analyst may choose to employ the data life cycle as an additional framework to walk through the various system components that handle the data or use requirements and design artifacts, such as use cases, goal diagrams or data flow models. For example, Figure 2-6 presents a basic use case template instantiated as a retail website that links customer purchase histories to the customer's social network to personalize promotions of the retailer's products to the customer's friends.²⁵ This

characterization identifies the primary actor (the friend) and assumes that the secondary actor (the original customer who bought the product) is no longer of issue. Because use cases may focus on the primary functional intent (e.g., to promote products), a privacy analyst may need to modify or extend the use case to include additional information about who may be harmed; in this case, the original customer.

Figure 2-6: Example Use Case for Performing Characterization

Name	Personalized Customer Promotions
Description	The system shall share a customer's product purchase with people in their social network, called friends
Primary Actor	Friends in the customer's social network
Precondition	The customer has purchased a product
Trigger	The customer's friend visits a product previously purchased by the customer

Fortunately, the choice of risk model may determine the amount of additional context that is required during the characterization stage. For example, the contextual integrity heuristic specifically targets the human-computer interactions between the system and its environment. These interactions include the various stakeholders that interact with each other and the norms that govern those interactions. Under contextual integrity, the original customer may expect that the retailer may use their purchase information only for the purpose of completing the transaction and will not share this information and the customer's identity with third parties, even friends. Similarly, the S/OD and taxonomy of privacy problems models both concern the data subject and their perceptions of privacy risk. Accounting for those perceptions will require characterizing stakeholders outside the system's physical boundary and data flows, but it will enable the next stage in risk analysis.

2.2.2.2 Threat, Vulnerability and Event Identification

Risk models may emphasize a particular reference point in the form of threats, vulnerabilities or adverse events. In practice, vulnerabilities and events tend to be more commonly used than threats. Events become risks when associated with some notion of impact and likelihood (possibly based on threats and/or vulnerabilities). To the extent the events or vulnerabilities are specified, each one

acts as an initial fixed or quasi-fixed point from which the analysis can extend out to identify and incorporate the specifics of the other elements for a given system. For example, once we know a given event, we can work backward to identify the relevant vulnerabilities and threats. The S/OD and taxonomy of privacy problem models emphasize adverse privacy events (i.e., what can go wrong), whereas the contextual integrity heuristic emphasizes vulnerabilities (i.e., which information norms can be disrupted). Thus, the analyst begins by identifying the elements that correspond to the privacy risk model in use.

Returning to the use case in Figure 2-6, the events may be characterized using Solove's taxonomy. This includes disclosure and exposure, depending on what products the customer has purchased. Products that are linked to lifestyle choices or that are used to treat bodily functions, for example, could lead to harassment or embarrassment when revealed to the customer's coworkers. Alternatively, the coworkers may view this information as an unwanted intrusion. The use case also leads to an appropriation event, because the company is using the customer's likeness to market the product. In all cases, the threat is the implementation of the use case wherein the customer would not want to be associated with certain products.

Once the risk model's elements have been identified, the privacy risk analyst then proceeds to complete the risk analysis. If vulnerabilities were identified under the contextual integrity heuristic, then the analyst proceeds to identify the threats that seek to exploit those vulnerabilities and the adverse events that would result from a successful exploitation. At this point, combining multiple privacy risk models that complement each other may be helpful. After identifying a vulnerability, the analyst may, for example, apply the taxonomy of privacy problems to discover potential events.

2.2.2.3 Risk Assessment

Risk assessment is the process of assigning likelihoods and impacts to previously identified events, which yields risks. Likelihood may be expressed as an ordinal value (low, medium, severe) or as a numerical value (0.0–1.0). Likelihood is sometimes assumed to mean the probability that the vulnerability would be exploited to yield the given event. Where specific threats can exploit specific vulnerabilities, the likelihood associated with that risk is significant. Where a vulnerability does not align with any specific threat, the likelihood may be less significant. The ability to identify threats depends on an analyst's knowledge of a

variety of political, social and economic issues that change over time (i.e., threats may be functionally required by the system to process information, or they may be motivated by politics, social groups or economics). Thus, the inability to identify a specific threat doesn't imply that the threat does not or will not eventually exist.

While impact may also be expressed numerically, this is a subjective judgment in the absence of metrics such as calculated or statistical financial cost or loss. Using a numerical scale for purely subjective judgments could be an exercise in misleading or false precision. Similarly, likelihood could be treated as a numerical value as well in the absence of any objective basis for its estimation. It can be argued that a less misleading approach is to use ordinal values to measure likelihood and impact. However, this can produce its own problems when attempting to “multiply” or “average” these values to score the risk. Depending on the circumstances, assigning a combined ordinal value of low, moderate or severe may be used to represent a combined judgment regarding the level of concern merited by the risk, though caution should be used when viewing these measures as ground truth.

In Table 2-1, we present a list of threats, adverse events and risk scores. Some threats to personal information arise from conducting normal business, such as determining whether a person is an adult, whereas other threats are external, such as law enforcement access. Still other threats arise from the imperfect design of systems (e.g., restoring from outdated backups as a patch to a periodically failing system or database). The events in Table 2-1 were identified using Solove's taxonomy of privacy problems as the risk model; other events could have been identified for these same threats. For example, law enforcement access to data could also produce insecurity (exposure to possible future harm due to the failure to protect a person's information) and secondary use (using information for purposes other than those for which it was originally collected).

Table 2-1: Example Assessments That Link Threats and Events to Risk Scores

Threat	Adverse Event	Risk
Law enforcement may request that we disclose a user's IP address from web server logs	Identification: The disclosure allows others to link pseudo-anonymous comments to a person's real identity	Low
We collect a person's date of birth to determine if they are over 18, which is a condition of using our service	Interrogation: The person may not wish to provide date of birth	Moderate

We periodically refresh our financial database from weekly backups when we encounter a system crash	Distortion: The backup may introduce data errors that misrepresent a person's financial history	Severe
---	---	--------

We now discuss how to respond to identified risks.

2.2.2.4 Risk Response Determination

After the risks have been assessed, the privacy risk analyst can determine how to respond. The type of response must account for real-world resource constraints, such as time, money and people, in addition to the risks themselves. Recall, the analyst has four choices when responding to a risk:

- *Accept the risk*—If the risk is low, then it may be reasonable and necessary to accept the risk. In Table 2-1, if the disclosure reveals only consumer reviews about products, then privacy risk of identification may be minimal. The person may suffer from other risks—for example, the risk of being connected to a crime for reasons outside the scope of the system. However, accepting the risk may make sense for a low-level risk. Another reason to accept risk is when the cost to transfer, mitigate or avoid the risk is too high.
- *Transfer the risk*—If there are other entities that can do a better job managing the risk, transferring the risk may be the best option. For example, using third-party services that can manage payroll, payment and other financial services using high privacy and security standards may be preferable to developing an equivalent system from the ground up. This is especially important when using a compliance model, where these third-party services have been engineered to conform to specific privacy laws, such as the variety of data breach notification laws. While the original organization may still bear ultimate legal responsibility, it has nonetheless transferred relevant risks in part to the third-party service, as it is the service that must contend with those risks at an operational level.
- *Mitigate the risk*—Mitigation is the best option when the IT developer can implement privacy controls that reduce the risk. This may be through a software component or through a change in business processes. In Table 2-1, the distortion risk may be mitigated by performing daily backups and consistency checks on the data or

remedied by allowing the person access to correct errors in their data. We discuss this mitigation in more detail in the following section.

- *Avoid the risk*—Avoidance occurs when one can avoid the adverse event by changing the system design or business process. In Table 2-1, the interrogation risk can be avoided by replacing the function that collects the person's date of birth with a function that asks a yes/no question, such as "Are you over 18 years of age?" This change is sufficient to address the original requirement (determine if the user is a legal adult by local law) and avoid the specific event of probing to reveal a person's date of birth or exact age.

2.2.2.5 Risk Control Implementation

Risk controls fall into three categories: *administrative controls*, which govern an organization's business practices; *technical controls*, which govern software processes and data; and *physical controls*, which govern physical access to hard copies of data and the systems that process and store electronic copies. In privacy, example administrative controls include:

- Appointing a privacy officer who is responsible for organization-wide privacy practices
- Developing and documenting privacy and security procedures
- Conducting personnel training in privacy
- Creating an inventory of personal information to track data practices

We discuss administrative controls in more detail in Chapter 8, which covers governance, risk and compliance.

Technical controls target information systems and should be the focus of IT developers in designing privacy-preserving systems. These include:

- Implementing access control mechanisms
- Auditing information access
- Encrypting sensitive data
- Managing individual consent
- Posting privacy notices

NIST publishes a privacy control catalog for U.S. federal information systems as Appendix J in Special Publication 800-53, Revision 4.²⁶ This control list covers both administrative and technical controls. Revision 5 is expected to integrate the privacy and security control catalogs. In addition to other privacy standards, such as the Generally Accepted Privacy Principles (GAPP), the privacy analyst may employ these controls as a standard means to mitigate several classes of privacy risk. For example, the NIST Privacy Control IP-1 on consent requires the system to provide individuals a mechanism to authorize the collection of their personal information, where feasible. This control may address a class of adverse privacy events, such as exclusion, which occurs when the individual does not have knowledge of, or participate in, the use of their personal information. If this use is made overt and the individual is permitted to authorize the use of their information for this purpose, then this risk to the individual is mitigated.

2.2.2.6 Monitor and Review

Information systems evolve over time, and so do the risks to personal privacy. Thus, it is imperative that privacy risk management frameworks include periodic reviews. An effective framework includes automatic triggers that require a subsequent review before a change can be initiated. In systems engineering, these triggers may be linked to modifying critical program code segments or configuring critical services. For example, before modifying any consent mechanism or before adding new tables to a personal information database, a privacy risk review is required.

In addition, there is a need to monitor the existing set of controls. This requires collecting sufficient information to trigger awareness of a control failure or probing individuals to test their knowledge of failures. Certain privacy controls may serve this goal directly, including personnel training controls that involve performance tests or assessments, and complaint collection and resolution mechanisms that may surface an individual's report of a privacy harm.

2.3 Requirements Engineering for Privacy

Requirements describe constraints on software systems and their relationship to precise specifications that change over time and across software families.²⁷ For IT professionals, understanding and applying privacy requirements is important both when creating new system designs and when selecting a proprietary or open source component to address a particular problem.

Whether the requirements are formally documented in a software requirements specification (SRS), expressed in a mathematical model or briefly summarized in an Agile user story, requirements provide engineers an early opportunity to capture critical privacy properties prior to embarking on design and other deep technological commitments. Barry Boehm, an expert on the economics of software engineering, found that the cost to fix a requirements defect during implementation increases a hundredfold over fixing the defect during the requirements or design phase.²⁸ This guideline is also true for privacy: Any changes to reengineer a software application in response to a known privacy threat will be more costly than addressing the privacy threat during requirements engineering. Thus, it is critical for engineers to capture privacy requirements by participating in the community of practice and monitoring existing sources of information about privacy.

In this section, we will review techniques for acquiring, eliciting, managing and analyzing privacy requirements.

2.3.1 Documenting Requirements

Requirements engineers often distinguish between two types of requirements: functional and nonfunctional. *Functional requirements* describe a specific function of the intended information system. A product tester can evaluate a running system to verify the following functional requirements: “The system shall provide a link to a privacy notice at the bottom of every page” and “The system shall encrypt credit card numbers using AES 256-bit encryption.” *Nonfunctional requirements* describe a constraint or property of the system that an engineer can trace to functional requirements or design elements. Examples of nonfunctional requirements: “The system shall not disclose personal information without authorization or consent” and “The system shall clearly communicate any privacy preferences to the data subject.” In the first nonfunctional requirement, the designer must trace this requirement to all uses of personal information to ensure authorization or consent is verified before disclosure; in the second requirement, the analyst must trace this requirement to any functional requirements that are governed by the data subject’s privacy preferences (e.g., the use of user email addresses or activities for marketing purposes). In addition to a requirements statement, the engineer should provide context for understanding the requirement and attempt to answer any critical questions to aid designers in applying the requirement to their designs.

Requirements are collected in an SRS that uses a standard format or template for presentation. IT professionals can reuse and adapt existing formats to their purposes. Figure 2-7 illustrates a generic example of a requirements template that describes an authorization and consent requirement. The template header includes summary information, such as a unique requirement ID that may be used to cross-reference the requirement, the requirement statement in the optative mood “shall,” the author who can be contacted for additional information, the revision number that is used to track changes to the requirement, the release date, and the keywords that can be used to identify related requirements across the SRS document. In this example, the legal compliance section provides legal cross-references to related regulations that this requirement attempts to fulfill. These and similar cross-references are typically included in trace matrices, which we discuss in Section 2.3.3 and which are used to show conformance among various software artifacts. The template body describes a scenario in which the requirement appears and several design assumptions that underlie a successful implementation of the requirement.

Figure 2-7: Example of an Instantiated Requirements Template

Requirement ID:	REQ-68
Requirement Statement:	The system shall not disclose personal information without authorization and consent
Author:	Sam Brown, System Specialist III
Revision:	1.1
Release Date:	January 1, 2014
Keywords:	Confidentiality, Consent, Access
Legal Compliance:	HIPAA Privacy Rule §164.506, §164.508, EU Directive 95/46/EC (30)
Scenario Description: Whenever an agent attempts to access personal information, the system will check that the agent is authorized to access this information based on the agent’s assigned user role or the data purpose for which the data will be used. If consent is required prior to disclosing this information to this recipient, the system will check that the data subject has previously provided consent for disclosure based on this user role or data purpose.	
Design Assumptions: The system maintains a list of approved user roles and data purposes. The system maintains linkages between data subjects, types of personal information and	

consent decisions and data purposes.

In addition to requirements, the SRS document includes a technical glossary that provides standard definitions to be reused across requirements. Figure 2-8 presents a sample glossary for requirement REQ-68 above: The term *agent* may be defined as a user or process to denote that this requirement applies to both types of objects in the system design. This glossary also contains the term *personal information*, which is refined into a list of appropriate data types: the combination of a person's name and address, or the person's email address, telephone number or credit card number. In addition to standardizing terminology, the technical glossary provides the engineer a mechanism to collect and negotiate descriptions of the system *in text* before committing to more specific descriptions in design and source code. Designers can ask critical questions based on definitions in the glossary, such as "Should all requirements be applied to personal information equally, or should a separate category of information, called sensitive personal information, be created for a subset of these requirements, such as encryption requirements?"

Figure 2-8: Example of a Requirements Glossary Used to Standardize Terms

Agent means a user or process that performs a function within the system.

Data purpose means the approved work-related activities for which data will be collected, used or disclosed. The complete set of approved roles or purposes consists of product or service fulfillment, internal operations, fraud prevention, legal compliance, first-party marketing, third-party marketing and product research.

Data subject means the identified or identifiable, natural person about whom information is related (see EU Directive 95/46/EC, Article 2, paragraph (a)).

Personal data is any information that relates to a data subject. This includes the data subject's first and last name, physical or mailing address, electronic mail address, telephone number or credit card number.

Requirements can be written to be reusable across multiple systems. Reusable repositories of privacy requirements allow the area specialist to coordinate standard approaches across their organization and to discern strategies for handling exceptions, such as a novel technology that deviates from traditional norms. As we discuss in Section 2.4, designers translate requirements into system designs and consider alternative designers to fulfill requirements. For example, designers may distinguish between different types of consent. Under a website's privacy policy, certain types of information may be collected, such as browsing history, whereby use of the site corresponds to passive consent. In this context, the

consent record is inferred from the website's access log: A user agent request for a web page that is linked to the privacy policy corresponds to consent to collect information described in the policy, such as the visitor's IP address, browser type, operating system and so on. Alternatively, the designer may choose to use an explicit checkbox at the start of a transaction with at least two design choices: (1) recording the date and time of the selection in a database or (2) restricting the transaction to those who select the checkbox, in which case evidence of the collected data subsequent to the checkbox can exist only if the checkbox was selected (i.e., the checkbox is required and not optional, and no other workflow leads to the data collection). The decision about which approach is best may depend on the need for retaining and exhibiting evidence of consent to auditors.

In addition to textual documentation, privacy requirements may be specified using visual models. These include process diagrams, information flow diagrams, role and permission matrices and state diagrams, to name a few.²⁹ These models serve to make relationships between the objects of discourse (actors, data, systems and processes) explicit and enable additional analysis. We describe a few analytics that rely on these models in Section 2.3.4.

2.3.2 Acquiring and Eliciting Requirements

Privacy requirements may be acquired from multiple, diverse sources. This includes eliciting requirements from stakeholders using interviews, case studies and focus groups, as well as by extracting or mining text documents—such as contracts, standards, laws, newspapers and blogs—for requirements. There are standard elicitation techniques for working with subject-matter experts. Interview and survey techniques have been established for conducting surveys and focus groups.³⁰ In addition to elicitation, the privacy standards, such as the FIPPs and the NIST privacy control catalog, serve as a source of requirements (see Chapter 1). For example, the use limitation principle stating that “personal data should not be disclosed, made available or otherwise used for purposes other than those specified” may be directly adapted to a nonfunctional requirement using the template above. Similarly, NIST Privacy Control AR-8, which requires organizations to “keep an accurate accounting of disclosures of information held in each system of records under [their] control,” can be adapted to any IT system and not only to those systems governed by the U.S. Privacy Act of 1974.³¹

While standards and guidelines are formatted for easier consumption by software developers, the format of less structured texts, such as laws and

regulations, requires analysis to infer requirements. Regulations are publicly available, and IT professionals can work with their legal counsel to identify relevant privacy regulations that govern their industry. Regulations may be generic or specific in their description of principles and processes that software engineers should employ. *Legal standards* refer to nonfunctional requirements or properties that cut across a system's design and functionality.³² The HIPAA Privacy Rule includes the minimum necessary standard, which requires covered entities, such as hospitals and health insurance companies, to disclose only the minimum information necessary to complete a transaction (see HIPAA §164.502). Alternatively, *legal rules* describe specific steps that should be taken to ensure compliance with a privacy law. Consider the following excerpt from the COPPA Rule:³³

§312.5 Parental Consent.

(a) General requirements.

(1) An operator is required to obtain verifiable parental consent before any collection, use, and/or disclosure of personal information from children . . .

(b) Mechanisms for verifiable parental consent.

(1) An operator must make reasonable efforts to obtain verifiable parental consent . . .

(2) Existing methods to obtain verifiable parental consent that satisfy the requirements of this paragraph include: providing a consent form to be signed by the parent and returned to the operator by postal mail, facsimile or electronic scan; requiring a parent, in conjunction with a monetary transaction, to use a credit card, debit card or other online payment system that provides notification of each discrete transaction to the primary account holder; having a parent call a toll-free telephone number staffed by trained personnel; having a parent connect to trained personnel via video-conference; verifying a parent's identity by checking a form of government-issued identification against databases of such information, where the parent's identification is deleted by the operator from its records promptly after such verification is complete; or provided that, an operator that does not "disclose" children's personal information, may use an email coupled with additional steps to provide assurances that the person providing the consent is the parent.

In this excerpt, the COPPA Rule describes specific steps to obtain consent before collection, including details about approved methods for obtaining consent. These rules frequently include statements with modal verbs, such as *may* and *must*, which indicate discretionary and mandatory requirements, respectively.³⁴ In addition, they contain terms of art whose definitions are needed to determine legal coverage; in the example above, *verifiable parental consent* is a term of art that is defined in 16 CFR §312.5(b)(2). From this example, a requirements engineer can extract or mine the regulatory text to yield a corresponding requirement. The following requirement was derived by tracing phrases from paragraphs (a)(1), (b)(1) and (b)(2):

REQ-72: The system shall obtain verifiable parental consent by having the user complete a credit card transaction prior to collecting a child's personal information.

In this requirement, the engineer commits to one of the five mechanisms permitted by COPPA §312.5(b)(2) in the above excerpt.

Regulatory enforcement actions, newspapers and blogs provide insight into what went wrong when a system fails to meet a privacy requirement. Travis D. Breaux and David L. Baumer performed a retrospective analysis on the FTC's regulatory enforcement actions.³⁵ This analysis yields several security requirements that could have been used to avoid system failures that violated consumer privacy policies and the Gramm-Leach-Bliley Act (GLBA). Alternatively, the IT professional or privacy area specialist can monitor newspapers and blogs for early indications of potential privacy risks. By watching what other companies do and how the press and the public interpret these privacy-related practices, software engineers can avoid privacy pitfalls in their own systems.

2.3.3 Managing Privacy Requirements Using Trace Matrices

The requirements engineer uses trace matrices for encoding relationships between requirements and other software artifacts. Each trace link has a special type that describes the meaning of the link. For example, a trace link from a requirement to a privacy law means the requirement *implements* the law, whereas a trace link to a design element, such as a role-based access control mechanism, means the requirement *is implemented by* the design element. These trace links are many-to-many relations, as a requirement can simultaneously have different relationships

to multiple laws, design elements and test cases. Consider the four requirements numbered REQ-32 through REQ-35:

REQ-32: The system shall only disclose the minimum information required to complete a transaction.

REQ-33: The system shall restrict uses of personal information to only those purposes for which the information was collected.

REQ-34: The system shall only disclose information for purposes for which the data subject has provided explicit or implicit consent.

REQ-35: The system shall provide law enforcement access to personal information by administrative subpoena.

In Figure 2-9, we present a trace matrix that links the above requirements to privacy laws and standards (listed down the first column) and to software requirements (listed along the top row). Where a trace link means the requirement implements the standard or law, an “X” appears in the matrix. We observe that some requirements implement multiple standards and laws, such as REQ-32, which implements both the HIPAA Privacy Rule’s minimum necessary standard and the Organisation for Economic Co-operation and Development’s (OECD’s) use limitation principle. Other standards or laws may be implemented by a conjunction of multiple requirements, such as the GAPP Standard 5.2.1, which simultaneously limits the uses of personal information to specific purposes (REQ-33) and requires consent for all disclosures (REQ-34), but has an exception for law enforcement purposes (REQ-35).

Figure 2-9: Example Trace Matrix Linking Regulations to Requirements

Privacy Laws and Standards	REQ-32	REQ-33	REQ-34	REQ-35	...
Data Minimization					
HIPAA Privacy Rule, 45 CFR §164.502(b), Minimum Necessary Standard	X				
OECD Use Limitation Principle	X	X			
GAPP 5.2.1 Use of personal information		X	X	X	
Government Access					

Stored Communications Act, 18 U.S.C. §2703 (b)(1)(B)(i)				X	
GLBA, 16 CFR §313.15(a)(4)				X	

Because software engineers and legal experts must interpret standards and laws when creating trace links in the trace matrix, the engineer may keep track of the rationale for each link to record these interpretations for future reference. When conducting a traceability exercise, one can use the rationale to answer the question, “Why is this trace link important?” Figure 2-10 presents an example where the rationale is recorded for REQ-35, which allows law enforcement access to personal information by administrative subpoena. The trace link rationale for GAPP 5.2.1 explains that this link is an exception, that describes how requirement REQ-35 should be viewed in the context of REQ-33 and REQ-34. In advanced trace matrices, these exceptions are encoded into separate tables to ensure that a designer who implements REQ-33 integrates the exception into their design. The trace link rationale for the GLBA Privacy Rule includes the cross-reference from the GLBA to the Right to Financial Privacy Act of 1978 that the engineer had to follow to discover this exception.

Figure 2-10: Example Trace Link Rationale

Source	Target	Rationale Description
REQ-35	GAPP 5.2.1	GAPP 5.2.1 provides an exception for any disclosure that is required by law or regulation
REQ-35	GLBA Privacy Rule, 16 CFR §313.15(a)(4)	An administrative subpoena is permitted by cross-reference to the Right to Financial Privacy Act, 12 U.S.C. §3405

While the examples shown above cover upstream tracing of requirements to their origin in laws and regulations, separate trace matrices are also used to trace requirements to downstream artifacts, such as software designs, source code and test cases. In privacy, trace matrices should also trace requirements to user agreements, such as privacy policies, terms of use (ToU) agreements, end-user license agreements (EULA) and so on. Whenever a requirement or IT system component changes, the trace matrices should be consulted to determine the impact of the change on other parts of the system, including privacy policies.

2.3.4 Analyzing Privacy Requirements

Requirements analysis describes activities to identify and improve the quality of requirements by analyzing the system and deployment environment for completeness and consistency. This includes identifying relevant stakeholders to ensure no one was overlooked and examining user stories and requirements for ambiguities, conflicts and inconsistencies. In this section, we focus on two activities that concern privacy: completeness arguments and threat analysis.

2.3.4.1 Developing Privacy Completeness Arguments

For systems of any reasonable size, requirements documents are never complete: There is always some description of the intended system that has been overlooked or only partially described. This incompleteness provides designers flexibility, because they are able to fill in the gaps with different technical approaches based on prevailing technology and other business needs. However, some omissions lead to unwanted behavior, such as privacy harms. To improve requirements quality in general, we recommend constructing completeness arguments that ensure limited aspects of the requirements are complete. These arguments are constructed using stepwise analyses to ensure that a finite list of concerns has been reviewed in its entirety. For privacy, this includes reviewing requirements trace matrices to ensure that all privacy standards, guidelines and laws have been traced to a requirement. Completeness arguments can be used to cover every step in the data life cycle for especially sensitive data types and to expand one's interpretation of a privacy law or regulation, which we now discuss.

Is tracing complete? Completeness arguments can be constructed for privacy policies, wherein the argument determines whether the *tracing is complete* from privacy policy statements to software artifacts that implement those statements. A privacy policy is a promise to users that their personal information and their privacy will be respected according to certain rules. Misalignment of privacy policies with information practices is a great source of concern and can lead to privacy violations.³⁶ Goal-based analysis can be applied to privacy policies to identify *protections*, which are statements that aim to protect a user's privacy, and *vulnerabilities*, which are statements that threaten a user's privacy.³⁷ Consider this excerpt from Google's privacy policy, which was last modified on June 24, 2013:³⁸

We may collect device-specific information (such as your hardware model, operating system version, unique device identifiers, and mobile network information including phone number). Google may associate your device identifiers or phone number with your Google Account.

...

We encrypt many of our services using SSL.

We offer you two step verification when you access your Google Account, and a Safe Browsing feature in Google Chrome.

The first two statements in the excerpt describe a general permission allowing Google to collect device-specific information, such as mobile phone numbers, and link this information to a user's Google account. These statements are potential vulnerabilities, because they enable surveillance and tracking of a user's movement and linking to other information through the account. For example, this vulnerability enables Google's passive collection of the mobile phone unique device identifiers of Android and iPhone users when the user accesses wireless routers, as well as Google's active collection of mobile phone numbers when users log in to their Google account online.³⁹ Any changes to the policy affecting these collections should be traced to these technologies, and vice versa.

The last two statements describe protections: The use of the secure sockets layer (SSL) to encrypt communications, such as access to Gmail, and an optional two-step verification that consists of (1) supplying the username and password and (2) supplying a code sent to the user by text message or voicemail. The first statement improves confidentiality and reduces the likelihood that a third party can read a user's email when they use an unencrypted wireless connection. The second statement provides users a higher level of assurance that third parties cannot access their account without also obtaining access to their mobile phone or to the wireless networks used to send messages to their mobile phones.

Protections and vulnerabilities can be traced to other downstream software artifacts to promote alignment between the privacy policy and system functionality and behavior. Whenever privacy policies change, due to changing laws or new business practices, these changes should be propagated into the trace matrices to determine what aspects of the system have been affected by the policy change. When policies are managed in this way, the IT developer can argue that a software artifact accounts for each privacy statement in the company's privacy policy. However, the issue of quality, or the issue of how well that artifact satisfies the policy statement, may require a more advanced, risk-based argument.

Is the life cycle complete? Completeness arguments can be constructed for a specific data life cycle, wherein the argument asserts that *every step in the data life cycle was visited* for a particular data element or dataset. At each step in the data life

cycle for a specific data type, the engineer considers whether the data type requires special consideration. Does a shopping history have special retention requirements, for example, based on either business needs (to service refunds or warranties) or law enforcement needs (to investigate crimes)? The IT developer may choose to develop only these arguments for especially sensitive data elements, such as financial account numbers or detailed purchase histories. To construct the argument, the IT developer begins by (1) selecting the data element to trace and (2) for each data life cycle stage, identifying requirements in the SRS document that cover the data element. Figure 2-11 illustrates the outcome of this tracing for the data element “credit card numbers” in a fictitious system that processes online shopping orders. The life cycle stages appear in the first column, followed by the ID and Requirement Statement in subsequent columns. Because requirements describe data at different levels of abstraction (from data elements to datasets), the IT developer must map the data element of interest to the datasets that contain this element. The technical glossary can aid the engineer when performing this mapping, assuming that terminology has been standardized across the SRS. In Figure 2-11, the italicized phrases for customer orders, customer’s payment method, billing information and credit card numbers all refer to data or datasets that contain a credit card number.

This example analysis yields two interesting findings for the IT developer. First, the credit card number is not observably shared with third parties, because no requirements that map to data disclosures were discovered. Unwanted disclosures may still occur, but this finding suggests such disclosures are not required. Second, the need to retain billing information is potentially too broad (see REQ-63). While billing information is needed to process certain requests, such as refunds or warranties, this does not include the credit card number. For refunds, the company may retain an approved one-way hash of the credit card number and ask the customer to resupply the number only when they request a refund. Thus, the IT developer can modify REQ-63 to exclude the credit card number from this retention requirement and introduce a new requirement to retain only the one-way hash of the credit card number.

Figure 2-11: Example Matrix for a Data Life Cycle Completeness Argument for “Credit Card Numbers”

Life cycle Stage	ID	Requirement Statement
Collection	REQ-	The system shall process <i>customer orders</i> and ship products to customers

	31	within three business days.
Use	REQ-47	The billing agent shall charge the purchase amount using the <i>customer's payment method</i> .
Disclosure	None	
Retention	REQ-63	The system shall retain <i>billing information</i> for two years.
Destruction	REQ-89	The system shall destroy <i>credit card numbers</i> immediately after completion of the payment transaction.

Is our legal interpretation complete? Completeness arguments can be constructed for compliance with regulatory requirements. While it is impossible to completely cover every prospective interpretation by an auditor, regulator or judge, there are steps that engineers can take to broaden the scope of their interpretations to capture missed requirements. Travis D. Breaux et al. identified five patterns to analyze legal requirements extracted from laws and regulations to improve completeness of the SRS.⁴⁰ These patterns were discovered through empirical analysis of a large manufacturer's SRS and a national technology law. The patterns are applied directly to requirements statements acquired from either laws or standards and can yield new, potentially missing requirements for the system. The patterns are presented below with examples from U.S. data breach notification laws.

Remove or generalize preconditions. Preconditions include phrases in a requirement statement that must be satisfied before a requirement is applied in the system design. These phrases can be recognized by *if* and *when* keywords. Removing or generalizing preconditions for obligations and prohibitions causes the statement to generalize; in other words, the engineer must apply the requirement to more situations than were originally intended. A more general form of this pattern is to apply a requirement to a broader class of stakeholders than legally required, or to a broader class of data and information types. For example, Nevada law governing the security of personal information requires organizations that conduct business in Nevada to take reasonable measures to destroy personal information.⁴¹ Applying this pattern to this requirement would entail generalizing this requirement so that it applies to any personal information, regardless of whether the information concerns practices conducted in Nevada or any other state. This pattern has the benefit of streamlining business practices at

the cost of extending those practices to other situations where they may not be otherwise required by law or standards.

Preclude preconditions, assume exceptions. In legal compliance, some privacy requirements concern specialized situations that can be avoided by writing product or service requirements that assume the exception, which may be a higher standard of care. For example, the Virginia data breach notification law defines a “breach of security of the system” as unauthorized access to unencrypted computerized data.⁴² In the event that an organization detects a data breach, notices are sent to consumers and others to comply with this Virginia law only if the data was not encrypted. By ensuring that this data is encrypted in transit and in storage, the IT developer *assumes the exception* and defines the system as not covered by this legal requirement. Privacy scholars have also called this exception the encryption safe harbor.

Ground legal terms in the domain. Legal terms determine when a privacy regulation applies and are often purposely written to be abstract so as to make laws flexible and adaptable to new situations or technologies. Based on a company’s products and services, these terms may be grounded in industry-specific terminology or product or trademarked names. For example, California Civil Code §1798.29 requires protecting access codes that can be used to access a personal financial account. This code chapter does not define access code or financial account, thus leaving the interpretation to IT developers and their legal counsel. In computing, accounts that allow users to conduct financial transactions during routine use of the system may be subject to these rules. As new technologies arise, traditional interpretations of banking are evolving. In 2008, the U.S. Internal Revenue Service (IRS) explored the tax implications of virtual currencies in online games.⁴³ If the IRS determines these virtual currencies and other property to be taxable, would California state data breach notification law cover the user’s account and password? IT developers should consider the various ways these legal definitions apply to their systems and document when these terms both increase and decrease their perception of coverage by privacy laws.

Refine by refrainment. Privacy laws often describe goals to be achieved or obligations about what a covered organization must meet. In software systems, however, there are activities that can create obstacles to compliance or yield privacy-threatening outcomes that are not explicitly prohibited by the law. This pattern concerns identifying what should not occur as a means to reinforce compliance with mandatory privacy requirements. Under Code of Virginia §18.2-

186.6(A), the act of stealing the cryptographic keys that can be used to decrypt encrypted personal information is not included in the definition of a security breach. However, because this outcome can enable a privacy-threatening scenario, wherein a data thief can now decrypt encrypted personal information, the IT developers can choose to adopt a refrainment, or prohibition, that requires that systems not make these keys accessible to unauthorized users. By expressing this prohibition explicitly, IT developers can conduct analysis on the system to check whether the design violates this requirement.

Reveal the regulatory goal. The rules in privacy laws serve to achieve a broader privacy goal or norm. For example, a privacy goal may be to protect an individual from public embarrassment by an unwanted disclosure or to protect an individual's freedom to travel without fear of excessive surveillance. While an IT developer can seek to comply with the letter of the law, the alternative is to comply with the goal of the law to acquire longer-term benefits, and often the area specialist can help identify these goals. By identifying the regulatory goal and then broadly applying this goal to their systems, IT developers can discover new requirements that are not described in a law. These new requirements may reflect novel technologies in their systems that were not previously foreseen by regulators, or they may leverage emerging interpretations of privacy goals that did not exist when the original regulation was written. This approach may have the added benefit of aligning these technologies with broader privacy expectations of users or of heading off new regulation earlier in the software engineering life cycle. For example, treating online gaming accounts as virtual financial accounts and sending out data breach notices in accordance with privacy law may benefit users: The users can take steps to protect those accounts and review account histories for suspicious activity, which is consistent with how users react to more traditional financial accounts.

2.3.4.2 Identifying Privacy Threats

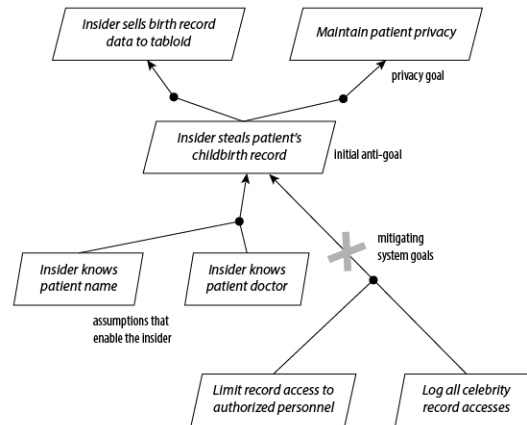
IT developers use threat modeling to identify risks to the system based on concrete scenarios. Threat modeling considers the negative outcomes enabled by a particular threat agent or type of agent. While this analysis has grown out of security engineering, the same techniques may be used to anticipate potential privacy harms, such as Daniel Solove's harms described in Section 2.2.1.4. The LINDDUN privacy-specific threat modeling methodology has been inspired by the STRIDE methodology for security threat modeling.⁴⁴ There are several

examples of security threat analysis artifacts and methods available to the engineer, such as anti-goals and misuse and abuse cases, that can be adapted to privacy.⁴⁵

Anti-Goals are an attacker's own goals or malicious obstacles to a system.⁴⁶ Goal-oriented analysis to identify anti-goals begins with the engineer identifying the system's positive goals, before identifying anti-goals that describe how an attacker could limit the system's ability to maintain or achieve the positive goals. For example, in a hospital, an electronic health records system has the goal of ensuring that doctors and nurses access patient medical records only for authorized purposes. A prospective anti-goal includes a nurse who accesses a patient's medical record to steal Social Security numbers or to reveal the name and gender of a celebrity's expected or newborn baby.⁴⁷ The first three steps of the procedure are as follows: (1) identify the anti-goals that obstruct relevant privacy goals, such as confidentiality and integrity goals; (2) identify the attacker agents who would benefit from each anti-goal and (3) for each attacker agent and anti-goal pair, elicit the attacker's higher-level goal that explains why they would want to achieve this anti-goal. (This step continues in a series of *how* and *why* questions to elaborate the anti-goal graph.) The final steps are: (4) derive anti-models that identify the attacker, object of the attack and anti-goals and (5) operationalize the anti-model in terms of potential capabilities that the attacker agent may use in this scenario.

In Figure 2-12, we illustrate an example anti-goal hierarchy: The blocks represent goals and anti-goals, and the arrows point from subgoals that achieve higher-level goals. The initial anti-goal is that an insider, such as a nurse, steals a celebrity patient's birth record. This theft is intended to fulfill the attacker's goal of selling the record data to tabloids. To accomplish this attack, the insider must know the patient's name and doctor. The system designer, realizing this information cannot be restricted in the healthcare setting, chooses to use technology to mitigate this anti-goal by limiting access and logging accesses. While limiting access may prevent unauthorized insiders, the additional goal of logging access improves the chances of identifying authorized insiders after the attack has occurred.

Figure 2-12: Example Anti-Goal Hierarchy with Mitigating Goals

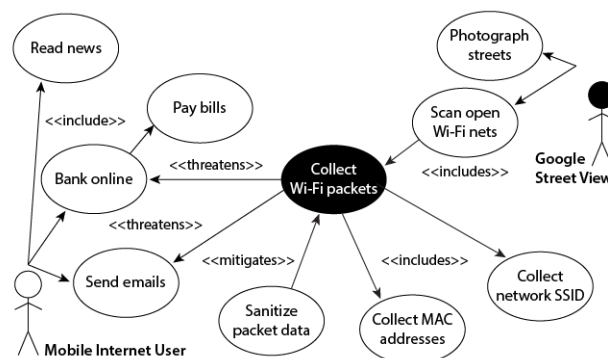


Goals and anti-goals are expressible in first-order logic to yield a more precise specification; however, this may be too cumbersome or time-consuming for broad adoption in every situation. For IT developers preferring a lighter-weight method, misuse and abuse cases were developed to adapt the existing use case methodology to describe negative intents. Similar to anti-goals, an abuse case describes a complete interaction between a user and the system that results in a harmful outcome.⁴⁸ Although misuse and abuse cases were originally developed to describe security attacks, the same notation can be used to describe potential privacy pitfalls. In Figure 2-11, we present an example misuse case. The white actor is the user, and the shaded actor is the misuser. It should not be assumed that the shaded actor in a privacy setting is a bad actor; rather, he or she is an actor who may be prone to misusing personal information in a privacy-threatening manner. Thus, the products and services provided by the misuser are often desirable by some actors, with privacy-threatening side effects that are undesirable by other actors. In the example, actions appear as ovals and are linked to other actions by arrows. The <<includes>> keyword indicates links to an action that is a part of another action, a similar meaning to how subgoals link to goals. The <<threatens>> keyword indicates when an action threatens another action, and the <<mitigates>> keyword indicates when an action serves to reduce the privacy threat from an action.

The Google Street View service is enabled by automobiles that are driven along public streets to capture images of streets and adjacent scenery. The project provides significant value to consumers, because they can use Street View to preview their routes on a computer before driving to their final destination. However, this service raised privacy concerns because unsuspecting individuals had their photographs taken in public and published online. In addition, the Street

View automobile collects wireless packet data from public Wi-Fi networks to provide more precise geolocation to Wi-Fi users who access these networks. Many wireless routers remain installed in the same location, which improves the reliability of this dataset. As the Street View automobile passes by a public Wi-Fi network, the vehicle collects the wireless packet data to determine the wireless router's service set identification (SSID), or unique device identifier, and the media access control (MAC) addresses of any machines connected to the network. During this collection, the car also intentionally or unintentionally captures user login credentials that are sent over the network while a user accesses other internet services, such as online shopping and email accounts. This collection threatens a mobile internet user's goal to securely and privately bank online and send personal emails. In Figure 2-13, we capture this threat by coloring the action "Collect Wi-Fi packets" black. The IT developer can mitigate this threat by introducing a new action, "Sanitize packet data," which removes all unwanted, PII. What about the "Photograph streets" action? What actor does this affect and how would the engineer mitigate this threat?

Figure 2-13: Example Misuse Case Applied to Unwanted Collection of Wi-Fi Data



As previously mentioned, the "Photograph streets" action threatens the ability of individuals to perform daily activities without the fear of surveillance. These individuals might approach surveillance differently, either by dressing differently or avoiding the area altogether. To mitigate this threat, the engineer can use face detection technology to blur faces or allow individuals to report unwanted intrusions that can be remedied by blurring the threatening images.

2.4 High-Level Design

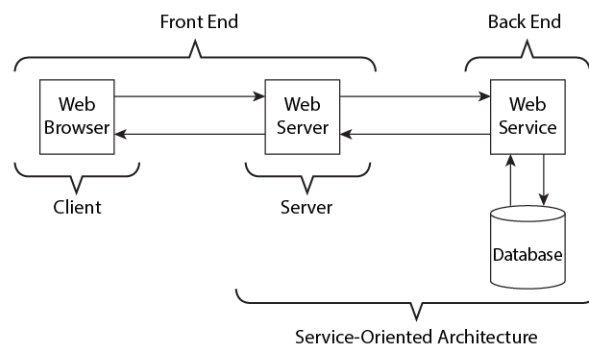
Whereas requirements describe what functional and nonfunctional behaviors the system is supposed to exhibit, designs begin to describe how the system is

supposed to implement those behaviors. Designs are generally expressed using notations that define the processes and the data that those processes operate upon, as well as the high-level components that serve to group these processes and data together into categories of functionality. This includes the Unified Modeling Language (UML), which provides object-oriented diagrams, sequence diagrams, state diagrams and more for describing composition and temporal relationships between elements in the design.⁴⁹ Expert designers will use sophisticated architecture component-and-connector diagrams, architectural styles and other techniques to manage the complexity of working with larger and larger information systems.⁵⁰ In this section, we briefly introduce common IT architectures, quality attributes and design representations for reflecting on privacy by design (PbD).

2.4.1 Common IT Architectures

During the past several decades, architectural paradigms have emerged to describe the relationship among software components. These paradigms serve to orient developers by communicating how their contributions integrate with those components under development by other members of the development team. To orient developers, each architectural paradigm encapsulates a limited viewpoint of the overall system design. Figure 2-14 presents a simple illustration of the various paradigms that we cover here.

Figure 2-14: Common IT Architectures That Describe Different System Viewpoints



The *front end* is the part of the system that the user experiences. It includes user interface elements that mediate between the user and the rest of the system. This involves converting user actions into something that is understandable by the system and converting system responses into something understandable by the user. In Figure 2-14, the front end consists of a web browser that a user employs to

search for a particular product on an e-commerce site. The search request is translated into a database query by the web server or web service. The response from the database is appropriately formatted and returned to the user for display by their browser. In this example, the database and any intermediary services that encapsulate the database and are not directly connected to the user's experience constitute the *back end*. The back end contains the information stores—products, orders, accounts and so on—that underlie the activities the user and the site owner engage in. The front end facilitates communication and manipulation of that information, but it is essentially a façade, in the same way as any storefront.

Privacy affects these two viewpoints in different ways. Ensuring privacy in a system design requires designers to attend to the usability of the front end: Are users effectively notified about the company's privacy practices? Are users able to express their consent about the use of their information, for example, by effectively opting in or out of secondary uses? Poor design practices or frequently changing the front-end design can cause the user to become confused or to incorrectly express privacy preferences. Agile designs that rapidly evolve in response to competitive markets, such as Facebook's changing façade, can be accompanied by online tutorials, one-time introductions to features and other contextual tips that help users navigate new and evolving privacy settings. Back-end components concern what data is collected, when data is used or for what purposes, with whom data is shared and how long data is retained, among other practices. In this case, designers may consider how to map the privacy principles, such as use limitation or data minimization principle, to their back-end services.

Client-server architecture describes the relationship between the *client*, which is typically a program that runs on a local computer, and the server, which is the program that runs on a remote computer. The client-server architecture commonly describes the relationship between a user's website and a remote website (see Figure 2-14). The designer may choose to define the boundary of the server to include any back-end services that facilitate the client-server interaction; however, the server is typically the computer process that responds to client requests. Thus, the back-end architecture may be composed of multiple client-server arrangements (e.g., a web server is a client to a database server).

One advantage of this architectural paradigm is that it allows the service to store computer data on the client side for the purpose of completing transactions. Because the web is asynchronous—that is, the hypertext transfer protocol (HTTP) does not maintain shared data between the client and server and each

request is independent—designers use creative mechanisms to track client behavior across multiple HTTP requests through the use of cookies (see Chapter 6) or session identifiers used in each communication request from browser to server. Storing data on the client may introduce privacy risks if the client data is insecure, or if the storage of this data is not clear to the user and serves the purpose of surveillance or identification when the user would otherwise prefer to remain anonymous. Session identifiers, when used, may be guessable or stolen, allowing an attacker to interact with the server as though they were the victim.

Service-oriented architectures are similar to client-server architectures in that they aim to decouple services from large-scale servers. This enables reuse and separation of concerns and, for increasingly larger systems, improved load balancing by allowing designers to replicate services across multiple machines. Last, *peer-to-peer architectures* are an extreme alternative to client-server architectures whereby each peer is both a client and a server. To enable this distributed scenario, peers often use a directory service to find other peers. This is how peer-to-peer networks, such as BitTorrent, operate. Peer-to-peer architectures can improve performance by reducing the need to work through intermediaries, but the emergent nature of the network allows for peers to be largely anonymous. Anonymity in this context is both a benefit to privacy and a burden because peers may be malicious, and users may be unsuspecting when they transfer their personal information to these anonymous intermediaries in the peer-to-peer network.

In addition to client-server architecture, a *plug-in-based architecture* can be used to extend an application with new features. Modern web browsers support plug-in-based architectures and application platforms, such as Facebook's Application Developer API and the Apple iOS or Android platforms, allow third-party developers to extend a user's experience with new programs, called apps. Plug-in-based architectures and especially app platforms can introduce new privacy risks for users. These risks emerge because the user has a direct relationship with the platform; the platform developer has a vested interest in protecting its user base to widen the adoption of the platform. For example, a user of an iPhone or Android phone has a relationship with Apple or Google, which owns, develops and maintains the platform. However, the platform owner has a third-party relationship with the app developer, who delivers the app to a repository, sometimes called a marketplace, from where the user can then acquire the app.

To enable these apps to interact with the user and their data, the platform exposes services to the app. In the case of mobile phones, these services may include the user's location, contact list or address book, and mobile web browser history. Privacy risks arise when the app accesses information in a manner that is undesirable, either by violating the privacy policy of the platform or by exceeding the privileges required by the app. For designers, the challenge arises in how they enforce the user's privacy settings provided through the platform in the behavior of their services and the behaviors of the apps themselves. A recent enforcement case by the FTC highlights these risks.⁵¹

Cloud-based computing describes the shift of client-based services or services typically run on a company's intranet to an off-site third party. Clouds refer to the collection of services, which may be accessible by anyone (public clouds), restricted to a particular organization (private clouds) or some hybrid of these two options. NIST defines multiple levels of cloud services: infrastructure as a service (IaaS), platform as a service (PaaS) and software as a service (SaaS).⁵² Organizations may choose to outsource their infrastructure or hardware and install, administer and maintain their own platforms or software. The challenge for privacy is that users of a cloud must relinquish control to the third party to protect their data. For example, a cloud provider could have access to data on the clouds that it operates, unless a sophisticated cryptographic scheme was used to decrypt the data once it returned to the client's intranet. Enforcement of privacy in clouds managed by third parties is typically achieved through contract language. In public clouds, users may be required to accept the terms and conditions or privacy policy of the cloud provider, whereas private clouds may be purchased and customized by the client to fit specific needs. A European company that wishes to purchase a private cloud operated in the United States, for example, may seek to use binding corporate rules, under Article 47 of the GDPR to ensure that the cloud provider employs sufficient safeguards to protect personal data of EU citizens. Ultimately, it is the responsibility of the designer to ensure these safeguards are implemented through privacy and security controls in software and hardware.

Federated architectures and systems combine multiple distributed resources to be used together, while keeping these systems under the autonomous control of the system owners. Federated search, for example, enables a search to be performed across multiple distributed databases without integration of their content or without centralized control of the databases. Instead, the search query is

decomposed and parceled out based on the logical organization of the constituent databases. Each database responds to its specific piece of the query, and the results are then integrated and presented as a single result. A more specific example of a federated system is a virtual data warehouse, in which a functional data warehouse can be developed without actually bringing together and integrating the data from multiple data sources. Integration in response to specific queries permits different policies to be applied to different collections of data and mitigates some privacy risks related to comprehensive aggregation. The privacy impact of federation concerns what information can be learned from aggregated data that was originally collected with the purpose of storing the data separately. This also can affect surveillance, as data points are linked together to track a person's behavior over time and across multiple, separate data sources.

2.4.2 Design Representations

Designers use notations to identify and organize various system elements and express critical relationships between these elements. This includes object models, which describe the discrete entities (e.g., servers, program modules, data elements), and process models and data flow diagrams, which describe the order of operations and data exchanges within the system. Historically, entity-relationship (ER) diagrams provided the basis for these representations. Today, there are multiple notations tailored to the specific tasks of high-level and low-level architectures, such as the UML, database schemas, and component-and-connector (C&C) diagrams. We now discuss a few of these representations using industry standard notations.

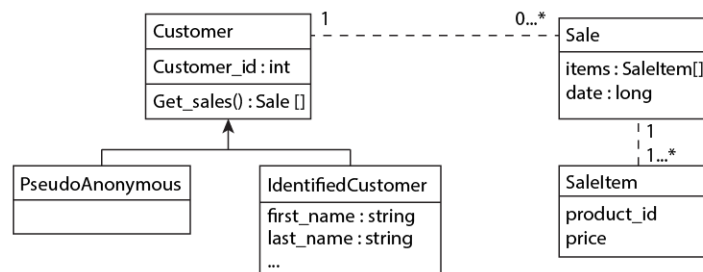
2.4.2.1 Object and Data Models

Object models are used to describe elements of a system and the compositional relationships between these elements. The UML object-oriented class diagram is a commonly used notation for describing object models, because of the wide variety of supporting tools available to draw these diagrams and because some of these diagrams can be used to generate program code. UML class diagrams describe classes, their data elements and functions over that data and associations between objects when one class contains a reference to another class. Privacy analysts can use object models as a lingua franca to enable developer discussions about how personal information will reside in the system, at what fidelity the data will be stored and shared, how to support pseudo-identification, and how to

segregate information to limit or avoid unwanted inferences across large datasets that reveal private details about a person.

Figure 2-15 presents a UML diagram for a customer class. The customer class is named “Customer” and the class has a data element, “customer_id,” which is a type of integer, abbreviated as “int.” This class also has a function called “get sales()” that returns an array of type Sale. The dashed line between the “Customer” class and the “Sale” class denotes that each customer has a relationship to zero or more Sale objects. In this design, the designer chose to use *information hiding*, which is a common object-oriented design practice, to separate the PII into a subclass called “IdentifiedCustomer” in Figure 2-15; the arrow points from the subclass to the superclass. For large systems where developers reuse these classes across their components, one developer can design an interface that shares only “PseudoAnonymous” objects with outsiders and internally operates on the IdentifiedCustomer object to limited unwanted accesses to personal information at runtime. Because the PseudoAnonymous class still inherits the customer_id from its superclass Customer, the PseudoAnonymous customer objects can be used to uniquely identify customers without revealing their personal names or other sensitive information contained in the IdentifiedCustomer class.

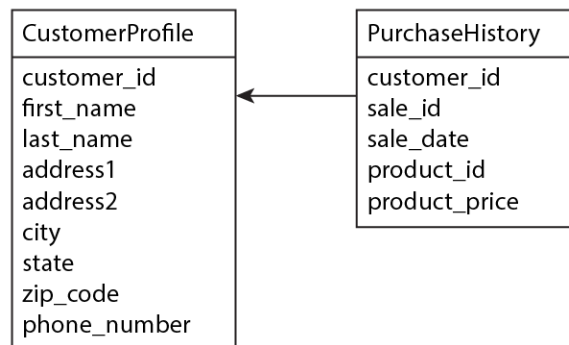
Figure 2-15: Example UML Diagram for a Customer Purchase History



The wide use of databases to store information has led to the development of database schemas. Databases consist of tables containing columns that describe the data elements and rows that describe the data records. Tables may include distinct keys to cross-index records among multiple tables. Figure 2-16 illustrates a database schema for a customer purchase history. The schema includes two tables: “CustomerProfile,” which contains the customer’s personal information, and “PurchaseHistory,” which contains records of purchases indexed by a “sale_id.” The key symbol in the CustomerProfile means that this schema element is unique; that is, each customer has only one unique customer_id. Unlike the

above UML diagram, this schema is simple and keeps the customer information in a single table. However, the purchase history is still separated into a second table. The link between the two tables is the `customer_id`; thus, to cross-reference data, a program requires access to both tables and this id. In this design, designers can limit access to customer information by granting access only to the PurchaseHistory table; this table describes the customer's purchases, some of which may still be sensitive but do not disclose the customer's personal information. To gain access to that information, the program would need to use the `customer_id` to access the CustomerProfile table containing the customer's address, phone number and so on. Commercial database systems include access control features that allow developers to restrict access to tables and, in some cases, individual cells (i.e., row-column locations). This topic is discussed more in Chapter 4.

Figure 2-16: Example Database Schema for a Customer Purchase History



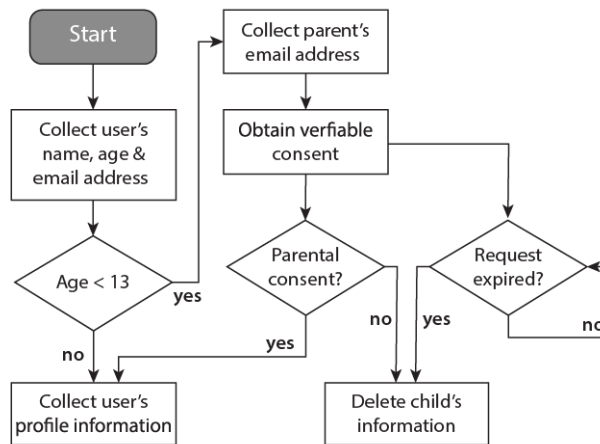
Finally, as designers consider how to map requirements into the design, they should pay special attention to the data dictionary and special requirements pertaining to each data type. The trace matrices that map legal requirements to data types may limit how data can be used, and it is the designer's responsibility to ensure those limits are translated into their design. This translation can be further expressed using process models, which are discussed next.

2.4.2.2 Process Models

Process models complement data models by representing what will be done with that data. Flowcharts are a simple type of process model. Flowcharts represent the system's operations and the sequencing of those operations, including conditional decision points. Figure 2-17 presents a flowchart fragment to express how a user registers for a service. Because some users may be under age 13, the legal age of children under COPPA, the system must obtain verifiable consent from the

parents of those children. This flowchart has two critical design features that are necessary (but not sufficient) to comply with COPPA. First, only if the user is under age 13 and the parent provides verifiable consent will the system collect more information from the child other than name, age and email address. Second, if the parent does not consent, or if a response to the consent request is not received within a reasonable time (i.e., the request has expired), then the system will delete the child's information, including the user's name, age and email address. COPPA allows for some other exceptions that are not represented here, but this example demonstrates how a designer can model the regulatory process in their system design prior to implementation.

Figure 2-17: Example Flowchart Describing a Partial COPPA-Compliant User Registration Process



In addition to flowcharts, designers may use UML sequence diagrams or other notations to express the order of operations for functions in a UML class diagram. Furthermore, they may use flowcharts or similar diagrams to describe data flows among components.

2.4.2.3 Model-Based Systems Engineering

Model-based systems engineering (MBSE) enables construction of a single integrated representation of a system under development. By combining architectural, process, and data models, MBSE supports all life-cycle phases from requirements definition through verification. MBSE is typically performed using supporting tools, which maintain the system representation in machine-readable form and carry out consistency checks. Some of these tools also support dynamic system simulations and provide for the definition of system functionality using programming languages such as Java. However, overall system definition is done

using appropriate modeling languages, including UML and the Systems Modeling Language (SysML).

If a system is being developed using MBSE, privacy and other specialty engineers will need to apply their disciplines in the context of the model and the supporting tool. Since the whole point of MBSE is to evolve and maintain a single reference model of the system, privacy engineers will have to interact with the system design via its MBSE representation and avoid creating independent, descriptive artifacts. Instead, privacy-related system artifacts should be generated directly from the system model. Industrial-strength MBSE tools include the capability to generate different types of engineering artifacts based on the model. While these tools usually come with a variety of predefined document types, they also permit tailoring of those artifacts and the definition of new types. Generating system documentation in this way both ensures currency and consistency, since the basis for all artifacts is the model at the time they are created, and greatly facilitates their production as necessary.

2.4.2.4 Design Patterns

Erich Gamma, Richard Helm, Ralph Johnson and John Vlissides introduced design patterns into mainstream software engineering through object-oriented programming.⁵³ Design patterns describe recurring problems through a shared solution that can be repeatedly reused to solve the problem. As originally conceived, design patterns are considered approaches to emulate so as to solve particular types of frequently encountered problems or achieve common goals, including privacy-related ones. As templates, though, they must be tailored and otherwise configured to produce a contextually specific solution. Conversely, patterns can also capture things to be avoided. So-called dark patterns include those that reduce rather than enhance privacy and are discussed in Section 2.4.2.6.

The design patterns proposed by Gamma et al. serve to improve program code maintenance by providing developers with a common mental model when approaching a recurring problem. They identify four elements of a design pattern:

1. A *pattern name* that enables easy reference to, and communication of, the pattern.
2. A *problem description* that the pattern is intended to solve. This includes sufficient information to recognize when the pattern applies.

3. A *solution* that describes the elements of the design, their relationships, their roles and how they interact. The solution may be presented as a template the designer must instantiate in the context of the design through some modification or extension.
4. The *consequences* that describe the results from applying the pattern and any trade-offs that occur by using or not using the pattern. This information assists the designer in determining whether the pattern's benefits are an improvement to the design.

Recently, work has been done in academia to identify privacy patterns.⁵⁴ Researchers at the University of California–Berkeley School of Information maintain the privacypatterns.org website, which disseminates information on emerging privacy patterns. For example, the ambient notice pattern, which appears in this online repository, describes a general solution to the problem of providing unobtrusive, ongoing notice of real-time location tracking. The challenge with location tracking for mobile users is they may not realize when their location is being monitored, or how often it is monitored, and providing intrusive notices can be as disruptive to the user's privacy as monitoring the user's movement through private settings.

Patterns in the repository are grouped by topic, including notification, minimization, access and transparency, among other topics, and presented in a format similar to the common pattern format described above. In addition to reuse, an added benefit of design patterns is the ability to combine multiple patterns to yield more robust solutions. For example, the ambient notice pattern may be combined with the privacy dashboard pattern, which provides an individual with an overview of all the information that an organization maintains on that person. This combination provides both specific indications of when information is used in a nonintrusive manner, as well as an overview of how different pieces of information are used together by a broad range of services.

2.4.2.5 Design Strategies

Positioned at a higher level of abstraction, privacy design strategies describe broad avenues for addressing privacy in systems. While *privacy design patterns* constitute solution templates aimed at frequently encountered problem types, *privacy design strategies* are intended to represent general approaches which might be implemented in any of several different ways.⁵⁵ Indeed, privacy design patterns

were originally presented as categorizations of design patterns, with the patterns supplying the more specific solutions serving to implement the strategies.

There is no requirement that a privacy design strategy be implemented via a privacy design pattern, and the available privacy design patterns are not exhaustive in any event. However, if organizations are so inclined, they can construct their own internal privacy design patterns that address recurring privacy problems that are particular to their environments and missions. These design patterns can then serve as implementation templates supporting privacy design strategies.

Eight privacy design strategies have been defined to date: minimize, hide, separate, aggregate, inform, control, enforce and demonstrate. They can be employed as a language during system design to drive thinking about how the system will address privacy and have been used as such in at least one design methodology.⁵⁶ Even if they are not used beyond this, simply invoking a design vocabulary with which to talk about the privacy properties of a given system can prove enormously helpful. Other vocabularies are possible as well, though, with no universal expectation regarding the use of any specific one.

2.4.2.6 Dark Patterns

Designers can use techniques, called dark patterns, to de-emphasize, obscure or make ambiguous more privacy-preserving response options; for example, by making opt-out buttons smaller and lower contrast, by not clearly differentiating between required information and information that is optional, or by (and sometimes in combination with) repeatedly asking users to opt-in within the same process in anticipation of fatigue or a mistake. The goal of dark patterns is to encourage the disclosure of personal information, but it could also include agreement to unexpected or more expansive uses and/or disclosures of personal information. Dark patterns and similar practices should be discouraged to ensure users are given the freedom to express their consent.

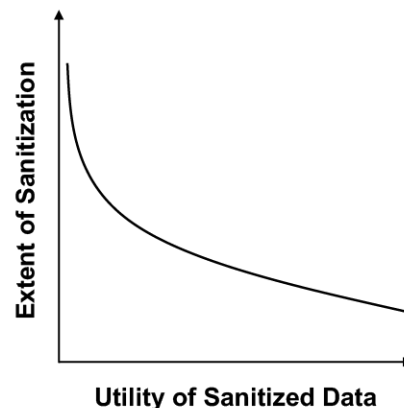
2.4.2.7 Trade-Space Analysis

Trade-offs are an inescapable part of designing systems. There are often instances in which no obviously optimal design choice exists. Instead, one is forced to choose between design elements that involve some combination of relatively positive and negative characteristics. A collection of such choices can be plotted, at least in the abstract, on a multidimensional graph (typically in two dimensions), thereby depicting the relevant trade-space. Trade-spaces are

important tools for helping engineers, including privacy engineers, think through design trade-offs.

A trade-space that most privacy professionals are familiar with is the one juxtaposing the extent of data sanitization (aka de-identification) with the utility of the sanitized data. It's generally recognized that the more extensively personal information is transformed, the less privacy risk it presents but the less useful it is likely to be. The exact nature of that relationship is contingent on the nature of the original data and on the intended use, but one can reasonably expect a trade-off curve somewhat similar to that in Figure 2-18. The trade-off curve represents the feasible design choices. The design choice ultimately made will be a point somewhere on that curve. In some cases, it may be possible to establish actual values along the two dimensions and to plot a curve based on the anticipated relationship between those values. However, even if a specific curve cannot be plotted, just the concept and explicit recognition of a trade-space can support thinking about the available design choices.

Figure 2-18: National Trade-Space for Data Sanitization versus Utility



A less familiar example of a privacy-related trade-space involves biometrics. Biometrics vary in the amount of ancillary information they reveal about people. Fingerprints, for instance, tend to reveal relatively little additional information, such as whether someone has engaged in significant manual labor (as reflected by worn ridges). Retinal images, on the other hand, have the potential to indicate a number of health conditions, including diabetes. Fingerprints, though, by virtue of being a frequently employed biometric (probably second only to facial images), potentially offer a multitude of linkages with other datasets containing auxiliary information. Retinal images, in contrast, are still relatively uncommon as biometric use goes and therefore tend to offer fewer linkage opportunities. Thus,

fingerprints and retinal images would constitute two differently positioned points in a trade-space defined by the two axes of ancillary information and linkage potential. Neither point would be considered optimal (i.e., superior along both dimensions). Even an informal plot with the relative positioning of the biometrics under consideration could help structure the analysis of alternatives.

2.4.3 Quality Attributes

In addition to translating requirements into designs to show how a system implements a client's need, designers must pay special attention to quality attributes. Quality attributes in software engineering describe crosscutting concerns that cannot be addressed by a single function. Privacy is an example of a quality attribute, as are security, usability and accessibility. In security, some quality attributes, such as confidentiality and integrity, are also called security objectives. Because of the complex nature of implementing quality attributes, different designs embody different priorities or emphasize different properties. The next sections discuss several quality attributes required to improve privacy in design.

2.4.3.1 Identifiability

Identifiability concerns the extent to which a person can be identified within a system. Sarah Spiekermann and Lorrie Faith Cranor conceptualize a four-stage scale running from "identified" (stage 0) through "pseudonymous" (stages 1 and 2) all the way to "anonymous" (stage 3).⁵⁷ In each progressive stage, the linkability of data to personal identifiers decreases and privacy protections are based increasingly on technical rather than policy mechanisms. From a privacy perspective, less identifiability is preferable to greater identifiability. While collecting no personal information reduces privacy risk, personal information may be necessary to provide business value; thus, storing personal data separately from other information when no requirement exists to keep this information together is a strategy to reduce identifiability.

Identifiability is manifest in many forms. Information can be identifiable in the absence of a single identifier. Latanya Sweeney demonstrates through *k*-anonymity (see Chapter 4) that the combination of gender, birth date and zip code can likely uniquely identify 87 percent of the population in the United States.⁵⁸ If such quasi-identifiers can be applied to different databases with other personal information such as name and address, then a degree of identifiability

exists in the system. Therefore, when assessing identifiability, one must examine combinations of nonunique identifiers and evaluate how their system design isolates the collection and use of these identifiers to limit drawing unwanted inferences from the data in a privacy-threatening manner. Another example is browser “fingerprinting,” in which the configuration attributes of a user’s browser (e.g., operating system and version, browser version, browser settings) combine to act as a unique identifier and link information together when they are sent in the HTTP request header to the server.⁵⁹ This type of identification constitutes pseudonymity, because the identifier is a substitute for the person’s real identity. To reduce this level of identification, web server log files can be configured to record less information from the HTTP request header. Care must be taken to ensure that the design of the system is actually consistent with goals and assertions regarding identifiability.

2.4.3.2 Network Centricity

Network centricity concerns the extent to which personal information remains local to the client.⁶⁰ When using a client-server architecture, for example, the designer may choose to retain personal information on the client side and transfer this information only for the limited purpose of completing a transaction. Weighting personal information and processing toward the client rather than the server can reduce inappropriate or unwanted disclosure and secondary use, among other risks, and enhance individuals’ control over their personal information. This may create new challenges, however, because the designer must distribute application logic across the client and server, as opposed to centralizing this processing on the server side. One consequence may be frequent updates to the client application to offer new value-added services.

While systems that are network centric can pose privacy risks by consolidating data in server-oriented architecture, a middle ground exists that potentially offers privacy benefits. For example, if network centricity enables personal information to be disaggregated while still making the information available for legitimate uses, the end result may be positive. Federated systems, which distribute personal information across multiple systems but provide clients with a single interface, can potentially mitigate inappropriate dissemination and use, since any given database contains only some fraction of each individual’s personal information. This benefit assumes that appropriate policy and technical controls are in place to prevent inappropriate aggregation; without such controls, network centricity can yield

more risk than it serves to mitigate. Moreover, in situations where the client is insecure, network centricity may be desired to avoid a breach of security on the client side.

2.4.3.3 Confidentiality

Confidentiality refers to the extent to which personal information is accessible by others. Access control lists that specify who is allowed access, role-based access control mechanisms that assign sets of permission to generic roles, which are then assigned to individuals, and attribute-based access control mechanisms that base access decisions on particular characteristics of the requester are just a few design choices that can be used toward this end (see Chapter 4). Access can also be controlled using data encryption and tokenization, such as format-preserving encryption that maintains the readability of some but not all of the data (see Chapter 3). For the designer, determining when to use confidentiality mechanisms depends on tracking business needs throughout the design and aligning authorization with these needs. Tax processors at the IRS, for example, are authorized to access personal information, but only in the context of the specific tax returns being processed. “Browsing” or “snooping” on other returns is expressly prohibited. Complex systems can be designed to cross-reference access logs with role or work assignment logs to identify confidentiality breaches. More generally, confidentiality requires that access control schemes align with business functions and responsibilities. Poor alignment results in excessive accessibility and correspondingly increased risk of compromised confidentiality. If poorly segmented role-based access control is used, for example, users will have to be assigned many roles in order to carry out their tasks, providing access to personal information that is too broad in scope.

2.4.3.4 Availability

Availability is typically referred to as a security property, and the need to ensure that information is available to satisfy business needs. While confidentiality may naturally fit with privacy by restricting access, one might view availability as inherently in conflict with privacy. When choosing to lock down data, the designer should consider whether emergency access to personal information is a requirement. This requirement arises in healthcare situations and is expressly permitted in the U.S. HIPAA Privacy Rule when a patient requires immediate treatment but is incapable of consenting to the access of their medical records. In such situations, strong auditing is recommended as a compensating design control

that ensures that, whenever emergency access is invoked, logs record this access so that any inappropriate uses may be investigated after the emergency is addressed. Because of the potential for misuse, the structure of such mechanisms should be carefully considered. The designer should consider the means to scope emergency access: Who is allowed to invoke this access? What information is made available during this access? How long should this access be available? (What are the exit conditions to access?) And who is responsible for reviewing audit logs or approving access after the incident?

Availability should also be considered with regard to data persistence across the entire system, including on- or off-site backup and storage. Although data may have been deleted from a production database, that data can persist in the form of backups, replication sites and archives. The total time required to delete personal information from the system must be considered as well as the risk implications of data persistence, which may allow data to be accessible outside the scope of normal confidentiality controls. While persistence can provide a safety net—that is, it enables recovery of information in the event of a failure or forensic investigation—it can also provide an opportunity for inappropriate use and disclosure. Establishing retention requirements in the early phases of system development and then tracing these requirements to design and implementation using the data life cycle viewpoint is a means to mitigate such risks during development.

2.4.3.5 Integrity

Integrity refers to the extent that the system maintains a reliable state, including the quality of data as being free from error. For data, integrity can be broken down into three crosscutting concerns: *Accuracy* concerns whether the information is correct and free from errors; *completeness* concerns whether there is missing information; *currency* concerns whether the information is up to date. Inaccurate data can lead to decisional interference—a privacy harm in Solove’s taxonomy discussed earlier. For example, in February 2000, a Kentucky woman named Ms. Boris made several insurance claims to the Kentucky Department of Insurance.⁶¹ The back-end data broker, ChoicePoint, incorrectly recorded these claims and later fed false information to the insurance department that caused Ms. Boris to lose her coverage due to decisions based on incorrect data. Similarly, incomplete information can lead to privacy harms. Missing or outdated information in a person’s medical record can lead to misdiagnosis. To address these risks in design,

the designer should consider how data is collected and restored: Is data entry manual, and if so, are there cross-checks in place so the data entry specialist can verify the entries are correct? Is the data restored from backups, and if so, are there mechanisms to ensure that corrections propagate to backups or are restored when a backup is pushed online? Allowing individuals to participate in maintaining the accuracy of their data can limit designers' reliance on other mechanisms that may be outside their control or prone to failure.

2.4.3.6 Mobility

Mobility is the extent to which a system moves from one location to another. Mobility has become of increasing importance with improvements in laptop and mobile phone hardware. Increasingly, location data and the manner in which it is collected and used introduce privacy risks. In June 2011, Casey Halverson identified a mobile privacy threat in the Nissan Leaf entertainment system, Carwings.⁶² The system included a Rich Site Summary (RSS) news receiver that, upon establishing a remote HTTP request with any server, broadcasts the car's global positioning system (GPS) location, including latitude, longitude and speed. While this information was made available by the new design of the Carwings system, it was not needed to download the RSS feeds. In addition to tracking location, designers should consider the possibility that mobile devices can be lost, misplaced or stolen. Locally storing data on a mobile device may require increased security in the event that the device falls into the hands of an unauthorized individual. Alternatively, minimizing the amount of data stored locally may also reduce this risk.

2.4.3.7 NIST Privacy Engineering Objectives

NIST's Privacy Engineering Program has proposed three privacy engineering objectives intended to be the privacy version of the traditional security objectives of confidentiality, integrity, and availability (CIA triad).⁶³ *Predictability* aims to enable reliable assumptions about a system, particularly its data and the processing of that data, by all stakeholders. These stakeholders include not only the individuals to whom the data pertains, but also system owners and operators. *Manageability* refers to the ability to granularly administer personal information, including modification, disclosure and deletion. *Disassociability* is the minimization of connections between data and individuals to the extent compatible with system operational requirements. This minimization can take many forms, from maximally disassociated data in the form of high-level

aggregated data, for example, to de-identified records pertaining to distinct individuals. Disassociability can also take the form of architectural data separation, in which identifiable personal information is kept segregated, but still linkable to, transactional data.

2.5 Low-Level Design and Implementation

The implementation of software follows from the requirements and design phases to yield working source code that can be tested for conformance to requirements. There are several opportunities to engage engineers in how to improve the quality of their programming practices with respect to privacy. In this section, we briefly review the state of best practice before discussing these opportunities, which include good coding practices and code reviews and reuse of standard libraries and software frameworks.

Programmers sit at the center of a software development project. In small projects, the programmer may take on multiple roles, such as requirements engineer, designer and tester; in large projects, they coordinate with these other roles through software development infrastructure, tools and meetings. This includes source configuration management (SCM) systems, such as the stable Concurrent Versions System (CVS) and more modern systems, such as Subversion and several web-based systems designed for Agile teams. All of these systems allow developers to periodically commit files that they are working on, lock files to prevent others from modifying them and track changes to files with the ability to roll back changes to prior versions. An SCM system can be used to control source code only, or it can be used to control versioning on other software artifacts, including requirements, designs and test cases.

In many development environments, a separate system is used to report and track bugs, which include defects, errors and failures. Companies that provide public access to bug reporting are open to receiving error and failure reports from users. Open source projects that use bug reporting even accept defect fixes by outside developers. For privacy, software developers can especially benefit from privacy complaint monitoring (i.e., failure or harm reporting) that includes a detailed description of how the system came to offend a user's privacy. While developers, like any other individual, are not well suited to receiving negative criticism, these reports can provide early feedback that can be used to

complement other types of requirements analysis, such as completeness arguments and threat analysis discussed in Section 2.3.4.

2.5.1 Good Coding Practices and Code Reviews

Good coding practices have emerged that improve maintainability of code: Easy maintenance can improve a programmer's ability to improve other qualities, such as privacy. This includes using secure coding practices and an object-oriented programming language that supports information hiding and loose coupling to control information processing. *Information hiding* is the practice of encapsulating data in classes and restricting access to the data through limited class functions and methods that operate on that data. Programmers can design a class to be an open container that provides other developers complete access and control over the data, including reading data to compromise its confidentiality and rewriting the data to compromise its integrity. Alternatively, a programmer can restrict access to the data using information hiding and allowing only select, approved classes access to the data. While another programmer can circumvent good information hiding practices by modifying the class or creating a class of the type approved for access, a standard SCM system would expose such circumventions. Rather, strong interfaces that hide information by controlling access to data and operations on data are more likely to reduce casual errors and misuse of data.

In addition, programmers can employ loose coupling to reduce information flows. Coupling *tightens* when objects depend on the inner workings of other objects. By *loosening* coupling, a programmer reduces dependencies among objects. This practice can be used to isolate information processing to a select group of approved classes and reduce the likelihood that other developers can unintentionally repurpose data—for example, when the marketing system reaches into the billing system to collect email addresses by bypassing privacy controls.

Finally, in addition to routine documentation, a programmer can use special codes to annotate source code with privacy attributes. This includes using programming assertions that state compile-time and runtime assumptions about privacy controls. Figure 2-19 illustrates a Java code snippet in which the programmer uses a runtime assertion to check that a user profile permits the system to publish the user's data in a global directory (see line 6). While this check could be made with an if-condition that allowed for a false return value, this programmer assumes this assertion is always true by design. Such assumptions can be made only if the design ensures that no state exists that violates this

assumption in the program execution leading up to this point. Thus, if the function “consentForPurpose” were to return false on line 6, the defect is in the software’s design, which has been modified outside the assumptions of the programmer.

Figure 2-19: Example Assertion in Java to Check an Assumed Data Purpose

```
1 // The user has selected the option to publish their profile in
2 // in the global user directory.
3 UserProfile p = profileManager.getUserProfile();
4
5 // User consent for this function is true
6 assert(p.consentForPurpose(ApprovedPurposes.USER_DIRECTORY));
7 publishUserProfile(p);
```

Code reviews are organized by developers to review critical source code for defects. Unlike branch and path testing, wherein an executable test case identifies defects by visiting code branches and paths, code reviews are in-person meetings that can identify defects in logic or poor practices that cannot be found in a standard testing regime. Code reviews are conducted by three to five developers, with special roles to organize the meeting: the *reader*, who reads the code out loud and offers questions to the developer, the *moderator*, who remains independent and serves to mediate disagreements and conflicts, and the *developer*, who authored the code and who listens to the review feedback and answers questions about the code. The developer cannot be the reader or the moderator, because they may be prone to take a defensive position to critical feedback. Furthermore, the meetings are best limited to two hours; longer meetings can lead to participant fatigue and reduced quality of feedback.

Code reviews provide an opportunity to involve privacy area specialists in the in-depth discussion about how software implementations satisfy privacy requirements. Unlike privacy legal experts, who typically have a law background, area specialists have a technical programming background that allows them to engage developers in technical discussions about how to write and organize source code. Furthermore, the area specialist is likely to be an independent reviewer with broad experience from participating in multiple projects. This diverse experience translates into design alternatives that the area specialist can introduce to the review, as well as knowledge of existing, reusable privacy software

frameworks developed by other project teams that may be relevant to the topic of the review.

2.5.2 Reusing Standard Libraries and Frameworks

Programmers can reuse standard application programming interfaces (APIs) and frameworks to reduce defects in source code. Security APIs can be used to improve confidentiality and integrity in support of privacy. Most general-purpose programming languages, such as C++ and Java, and many web-based scripting languages, such as PHP and Python, include standard libraries for performing a variety of critical security functions. Whenever possible, programmers should reuse these libraries and react to critical security vulnerabilities in existing standards.⁶⁴ Libraries are available to solve multiple standard privacy and security problems, including:

- Authentication and authorization APIs, including fine-grained and role-based access control
- Encryption algorithms, including standard implementations for 3DES, AES
- Public key cryptography, including key and X.509 certificate management
- Secure communications, including SSL and transport layer security (TLS)

In addition to using standard libraries, programmers can build their own frameworks for addressing privacy principles using a standard protocol. These frameworks should be documented, shared and reused across the organization's products and services. Through reuse, the effort expended to validate these frameworks against legal and standards-based privacy requirements, including review by the in-house legal or privacy office, reduces privacy risk in many ways. Because reuse reduces project costs, it helps ensure that privacy remains a priority as opposed to an intractable expense; when projects run over budget or past deadlines, privacy requirements may receive less attention than the core functionality required to deliver a working product. Reuse also reduces deviation from best practices: Feedback from legal experts and privacy area specialists can help to reduce the defects and incorrect interpretations of privacy requirements in

validated frameworks; thus, reuse lowers the likelihood of making common privacy mistakes multiple times across different projects. Opportunities for developing privacy-enabling frameworks include:

- User registration services designed to comply with specific regulations, such as COPPA or the GDPR
- Privacy notice mechanisms, including reusable web-based links and email notification services
- Marketing services that are compliant with the Controlling the Assault of Non-Solicited Pornography and Marketing Act of 2003 (CAN-SPAM)
- Report generation services for law enforcement and other requests based on the Electronic Communications Privacy Act of 1986 (ECPA)

2.6 Testing, Validation and Verification

Testing is perhaps the most crucial phase of the software development process with regard to managing privacy concerns. As defined by the IEEE, a test is “[a]n activity in which a system or component is executed under specified conditions, the results are observed or recorded, and an evaluation is made of some aspect of the system or component.”⁶⁵ In general, testing consists of two sets of activities: *verification*, which ensures that a resultant system performs according to its requirements, and *validation*, which ensures that those requirements themselves satisfy the original needs of the user base for whom the system was developed.⁶⁶ While a system may have been designed and implemented with consideration given to privacy-related requirements, it is only through testing that requirements are deemed satisfied.

Like design, implementation and deployment, testing can be broken down into various phases, based upon the object being tested or the purpose for which testing is conducted.⁶⁷ This includes unit testing, which covers individual functions and system components; integration testing, which covers the interactions between groups of components; and system testing, which covers completed portions of the whole system. Further levels of testing exist beyond system testing as well, including acceptance testing, which covers requirements validation (the question of whether customers accept the system as delivered) and

regression testing, which ensures that changes made to an existing system do not affect (or at the very least, predictably affect) other components within the system.

Although considered a phase, testing often occurs alongside many of the other phases of the development life cycle, notably implementation and deployment. However, depending on when testing occurs in this process, the privacy-related concerns will vary. For example, a developer is tasked with writing a function that copies a subset of thousands of user records from one table in a database to another. Ideally, the developer reviewed requirements pertaining to this function in advance and followed any relevant design specifications. When it comes time to test this function (a unit test), the developer must provide it with suitable data. The most representative data yields the best test results, because the data reflects real-world use of the system. In some cases, this data may be obtained from a data vendor or collected from other runtime systems owned or operated by the manufacturer.⁶⁸ Usage of real data to test a component prior to deployment raises a number of issues regarding how the data was obtained, which dedicated tester performs the test in question, and how the data is accounted for during and after completing the testing process.

Testing functions and system components with representative datasets is tremendously valuable, because failures in the system are more likely to reflect real-world use of the system. However, the data supplied, no matter how closely it may represent that of anticipated users, is at best a proxy for the real thing. To improve testing fidelity, a portion of the system may be exposed to real users through alpha and beta testing. These testing methods involve inviting real people to use the system and provide live data, which raises a number of new privacy issues regarding management of their data and their expectations.

Once testing has concluded and further changes or adjustments made to the system, it will be deployed for active use. Testing continues, however, in the form of both new features and updates that may use the testing methods already discussed and runtime monitoring and auditing of the current system. This may include log analysis, issue tracking, and testing of APIs, which allow other software and remote services to communicate with a system.

In the following section, we briefly review the more common types of testing (unit, integration, system, acceptance and validation) before devoting our primary discussion to usage of data in testing, alpha and beta testing, and runtime monitoring and auditing.

2.6.1 Common Types of Testing

Unit testing is focused on system components, usually the smallest cohesive or self-contained pieces of the implementation. In software, this includes object classes in object-oriented programming and subroutines or procedures in procedural programming. In addition, a single web page or a database script embedded in a web page can be the unit in unit testing. The fundamental principle in unit testing is to determine whether a unit, given a predefined input, will yield an expected output. For testing purposes, some requirements can be assigned to specific units. For example, a privacy requirement to allow a user to configure a privacy setting can be tested by ensuring that a form submission from a privacy setting configuration web page would yield a change in a database entry that stores this setting. However, additional testing would be needed to ensure the database entry is later read by those parts of the system that must behave in accordance with the setting, such as restricting access to the user's personal information.

Integration testing is focused on testing the individual units as members of a subsystem. Unlike individual units, subsystems enable more complex transactions that can be tested against more complex requirements that describe larger behaviors of the system. Returning to our example in unit testing, a tester may wish to observe the effect of changing a privacy setting on those other units of the system that must behave in accordance with the setting. For example, if the setting restricts sharing the user's email with third parties for marketing purposes, and the system has a unit to generate a list of customer emails for an approved third party, the tester can check whether the generated list excludes a user who has configured this setting. While these two units may be tested independently, engineering experience has shown that when components are integrated, additional design assumptions are revealed that lead to failures that would otherwise not be expected. Thus, it is important to incrementally test privacy requirements as portions of the system are completed and delivered rather than waiting to complete the whole system.

System testing is focused on the complete system, including nonfunctional requirements of the system as a whole that cut across individual units and subsystems. System-testing activities include security, performance and stress testing. Privacy requirements that relate to the gross behavior of the system can also be tested at this time. For example, a requirement to ensure that the system does not expose an individual's personal information may be tested by

implementing test cases that search for sensitive data in network traffic, text files or other media that result from operating the entire system. The tester may discover network traffic that contains unencrypted, sensitive information and attempt to trace this issue back to the set of system components responsible for this failure. System testing may feature attempts to “break” the system by using it in unanticipated ways or by trying to defeat controls.

Unlike unit, integration and system testing, which *verify* that the privacy requirements were implemented correctly, acceptance testing *validates* that the system reflects the correct privacy requirements. Thus, *acceptance testing* involves the users of the system or those charged with representing those users. Systems may have multiple distinct types of users, and each of these types should be represented. Moreover, even if the system does not interact directly with the individuals to whom its information will pertain, those individuals are still stakeholders in the system. During acceptance testing, it is important to review data subject expectations and the extent to which the behavior of the system is compatible with those expectations. If, on the other hand, data subjects will directly interact with the system (e.g., a social networking platform), then it is preferable to concretely incorporate their perspective. This can be done via a variety of mechanisms, such as alpha and beta testing, focus groups or having employees independent of the development team stand in for external users. However, employees can be biased by the company culture and may make assumptions about what is acceptable that do not generalize to the target user population.

As changes are made to the system in response to bugs and other defects, the tester may need to repeat existing tests to ensure that these changes have not created new defects. This may occur when a bug fix to a function that supports a business value, such as delivering a web feature to a client browser, leads to disabling a privacy feature that interacts with the bug fix. By establishing test cases for privacy features, changes that break the privacy feature may be detected using regression testing. The scope and nature of the change will determine which tests should be repeated. To the extent that system components exhibit high cohesion and low coupling (i.e., minimal interdependence) with other components, the potential impact of changes can be contained, and regression testing reduced.

2.6.2 Testing with Data

Testing requires data that is representative of the range of operations the system is expected to experience. Privacy requirements that apply to the runtime system should also apply to a testing environment. In a healthcare context, for example, if a tester is testing a function that assigns a wellness score derived from the health data of a real person, then this data must be protected to the same degree that it would be in a deployed system. However, because the testing environment differs significantly from the real environment (e.g., the complete system may not be available, or the tester may use rough, quickly assembled scaffolding to simulate missing pieces of the system), these privacy requirements may not be met. To address this and related issues, the tester should complete a test plan that includes privacy requirements for protecting test data. In addition, the tester may mitigate these problems by using synthetic data, public data, transformed data or purchased data, discussed next.

2.6.2.1 Synthetic Data

Synthetic data is data generated for the purposes of testing when access to real-world data is difficult or restricted. Synthetic data aims to mimic the desired attributes of the real data.⁶⁹ The level of sophistication involved in the data generation process may vary based on the test being conducted. For example, consider a tester who is testing a function that populates a table in a database within a specified time period. Synthetic data may be used if the values in the data do not influence the outcome of the test. Whether a database entry is populated with “John Smith” or “First and last name” is not a significant difference, assuming the second string reasonably represents the first string with respect to the length of average strings in the real dataset. If the tester wants to test the function’s ability to handle non-English characters in the test data (e.g., the character æ), they could use synthetic data that accounts for this variation. If the tester has access to a real dataset, they could derive a statistical profile from the data that is used to generate a synthetic dataset that contains strings with the proper distribution of characters and string lengths as represented by the real dataset. The benefit of using synthetic data is that testers and other developers do not need special privacy training to prevent privacy harms when handling this data. A potential drawback to using such data, though, is that it may not adequately represent the variety and messiness (including errors) of real data.

2.6.2.2 Public Data

Using publicly available datasets, such as U.S. census data, can be extremely valuable.⁷⁰ Census data is comprised of real data about specific individuals that is protected as PII. Furthermore, statistical disclosure controls are applied to this raw data so as to enable the public release of aggregated information that has very low risk of revealing PII. In the case of anonymized data, which has key identifiers removed, correlations with other public datasets raise the possibility that connections may be developed that violate privacy requirements (see Chapter 4 for more discussion on identifiability). In 2006, the online video rental company Netflix released millions of records that it believed comprised anonymized data about subscriber video-viewing tastes in a contest to discover a better recommender system. Although the data had been stripped of personal identifiers, researchers were able to predict the identity of certain reviewers by cross-linking that data with publicly available reviews on the online movie database IMDb.⁷¹ Thus, data that is publicly available may introduce or be vulnerable to re-identification and other privacy risks.

2.6.2.3 Transformed Data

In light of the risks that can be incurred by using real datasets, some organizations turn to data transformation as a means to avoid privacy risks. Data transformation—also known as data masking, data scrubbing, data anonymization, and data sanitization—takes real data as its starting point and applies various kinds of manipulation to reduce the risk represented by the original data while preserving desired properties. Note that this is different from statistically representative synthetic data, which is new fabricated data generated from a statistical model of the real data. Transformation techniques include removal of particular fields, suppression of particular values, shuffling of values across records, encryption or hashing of values and generalization of values to render the data less precise. A variety of commercial products aim to support this process, either as standalone tools or as special-purpose add-ons to larger data management tools.

While transformed data can be effective, it is easy to underestimate the difficulty of creating it. Particularly for large database schemas with many interdependent tables, the act of designing and executing transformations that produce usable data with the needed reduction in privacy risk is not straightforward and can be very labor intensive. There is no simple approach that allows a developer or tester to press a single button and yield perfectly de-identified data. However, if the tester anticipates that the transformed data will be used across multiple IT

development efforts, then the cost and time needed to implement this approach may be worthwhile.

2.6.2.4 Purchased Data

An organization may acquire testing data from another source. This has numerous benefits, as the data is often immediately available in a format convenient for testing. However, it is possible that the data provider will not legally be allowed to divulge that data—and consequently, the organization that receives the purchased data may not be allowed to use it. Notably, this occurred in 2002 when Torch Concepts, a U.S. Department of Defense (DOD) contractor, acquired passenger data from the airline JetBlue in order to test an algorithm that was developed for the purpose of identifying suspected terrorists. This violated JetBlue's privacy policy and may have violated national privacy laws.⁷²

2.6.3 Testing with Live Users

Testing with live users provides developers the opportunity to put their system in front of the actual users for whom the system has been designed. Doing so can provide extremely valuable information during the development process, as live users may use a system in unintended ways and attempt actions that have not been anticipated by the designers. Such attempts can then be addressed and accounted for in the system, especially if they lead to failures. However, live user testing comes with privacy risks because the users populate the system with their personal information or reveal their personal behaviors in ways that the system collects as data. In this section, we discuss some of the attributes of different types of live user testing and address concerns associated with alpha and beta testing, in particular.

While alpha and beta tests share similarities, we believe their differences can be specified along the following attributes, which also are strong determinants of the privacy precautions that should be taken:

- *Feature Completeness*—The number of a system's features that are made available to users during the test. This ranges from a small subset (e.g., only user registration and account confirmation) to the entire gamut of features the system is intended to deliver.
- *Scale*—The number of users who test the software. This can range from small groups of users to the public.

- *Goal*—The intent of the test, with different intents requiring different measurements and evaluations. For example, testing the system’s ability to handle peak user load, which is the greatest number of users on the system at any one time, requires access to a large pool of users; testing the average time it takes a user to complete a specific task in the system may be performed with a smaller sample.
- *Location*—The place where testing is performed, which could include an on-site lab, an outsourcing agency overseas or individual users’ PCs or smartphones.
- *Officiator*—The entity that is conducting the test. Is it the organization developing the software, or another agency performing testing as a service? This could also include the organization for which the software is developed.
- *Test Data Acquisition*—The means by which data is collected and stored for analysis.

2.6.3.1 Alpha Testing

Alpha testing occurs early in the implementation process when a system is not considered feature complete.⁷³ Alpha testing is seldom open to the public and is frequently conducted with small groups of in-house users. Often, this is the first time a significant portion of the system is exposed to users, or to professional testers acting as users. Thus, alpha testing can serve to both identify prominent issues early in development and offer an opportunity for requirements validation based on user input in a manner similar to acceptance testing. Based on the previously specified attributes, alpha testing:

- Is performed on feature-incomplete systems
- Occurs on a small scale, with tens to hundreds of users, rather than thousands or tens of thousands
- Is seldom open to the public
- Is intended to determine major bugs and offer early requirements validation
- Is conducted in-house or through a third-party testing service that will also conduct tests “behind closed doors”

- Will feature extensive means of data collection, given the low number of users involved in the test

Privacy concerns during alpha testing are driven largely by the incomplete and knowingly underdeveloped nature of the system in question. While the absence of some expected functionality might be obvious to users, the absence of proper data handling and security measures may not be transparent to the users who volunteer to test early versions of the system. Thus, any data the user provides to the system may not be fully protected, as it would be in later versions. Consider, for example, a user who volunteers to be an alpha tester for a new social networking site. Logging in, the user populates their profile with personal data and then begins exploring various features made accessible to them. Because this is an alpha test, however, developers focused primarily on implementing the functionality for the user that aligns with core business value and did not address the additional privacy and security requirements. The user may be able to access information about others that has not been adequately protected and could also be at risk of exposing personal information to unintended parties; for example, if the site has not yet been configured to use a secure (encrypted) connection and the user accesses the site using an unencrypted public wireless network.

When developers aim to alpha-test new features, they must ensure that each increment of the system is vetted by a privacy and security analyst. In a fast-paced, highly competitive environment, this analysis may be overlooked. Integrating privacy early in requirements and design will improve the likelihood that privacy concerns are identified and incorporated early, rather than later, at which point alpha tests are at risk of causing privacy harms. Because data gathered from alpha tests may also contain personal information (e.g., recording the screen of a user while they go through the registration process and profile creation screens), the organization must make sure that the data is marked as being personally identifiable and treat this data as it would the same data in a fully operational system. Before using a third-party service for testing, the hiring organization should conduct appropriate due diligence and determine that the testing service has levels of privacy and security protection at least as strict as those in the hiring organization. In Chapter 8, we discuss governance, risk and compliance practices that may be used to assess a third-party testing service.

2.6.3.2 Beta Testing

Many of the concerns that arise during alpha testing apply to beta testing as well, which is usually performed on feature-complete systems with a much larger testing population. Beta tests are often open to the broader public, although they may be capped at a maximum number of participants and often are the last tests that are conducted prior to live deployment of a system. Regarding the testing attributes, beta tests:

- Are performed on feature-complete systems
- Occur on a large scale and are often open to the public
- Are intended to identify bugs and issues that may interfere with live deployment of the system
- Are often conducted on users' personal or employer-owned machines, which may feature a variety of configurations and states
- Are officiated by the organization developing the system
- Rely on user issue reporting and other means of data collection that may continue to be available once the system goes live

Privacy concerns during beta testing largely relate to the *scale* and *openness* with which the test is conducted. As this is the first time the system is made available to the public, any privacy violations or oversights could have drastic implications and should be addressed immediately. Failure to identify and address these issues can result in a significant negative impact to user adoption. In 2010, Google deployed Google Buzz, a social networking platform, for all existing users of its Gmail electronic mail platform.⁷⁴ Google Buzz was deployed with a number of privacy issues, such as exposing a list of the user's most emailed contacts to other users by default; this exposure resulted in heavy criticism for these practices.⁷⁵ Alpha testing can be used to identify concerns early, similar to the use of focus groups in requirements engineering. Unlike alpha testing, user accounts and associated personal information that are created in beta testing may be retained for the live version of the system.⁷⁶ Changes in privacy policies or other privacy mechanisms for the live system should be introduced to beta users to transition these users to the live system.

2.6.4 Testing After Deployment

Testing is an ongoing process that continues after systems have been deployed. Post-deployment testing is similar to runtime monitoring, or analyzing usage and performance data collected from a running system. In addition, some unique testing-related concerns occur after a system is live, including privacy-sensitive bug handling and API testing.

2.6.4.1 Log Analysis

Systems can collect or log a large amount of data regarding user activity, and these logs themselves can become an unintentional source of personal information.⁷⁷ In 2006, AOL released the search terms of over 650,000 of its users; these terms and identifying personal information had been collected while these users interacted with the AOL search service.⁷⁸ The search queries, though not directly attributable to the users, contained sufficient personal information that users could be identified. Because it is difficult to anticipate how runtime data may be used, strict policies should be put in place to limit repurposing of the data. During design, developers may plan for secondary uses as they consider the various ways that data may be sanitized or summarized and the periods for which data may be retained. Once these data sources have been identified, they can be protected or otherwise isolated from the rest of the system as well as regularly sanitized, summarized or destroyed to comply with any applicable data retention policies.

2.6.4.2 Bug Tracking

Bug tracking involves the collection and organization of bugs (errors) in a system. When users encounter bugs, they may be guided to a bug tracker, a piece of software explicitly designed for collecting bug-reporting data.⁷⁹ To report a bug, users are asked to provide sufficient detail regarding the context in which the error occurred as well as the effect of the bug itself, such as the system becoming unresponsive or the user being unable to save data. Systems may be designed with an automated means of collecting and reporting runtime failures to a bug tracker, and the automated report may contain data leading up to the failure, including personal information.

To address these concerns, bug trackers should make explicit any personal information that is collected and present the bug report to the user for review before submitting the report. Systems that are transparent about what information is contained in an automated bug report can improve the likelihood that users will enable submissions. In the event that personal information must be collected and

reported, that information should be encrypted or otherwise protected and appropriately handled during transmission and after receipt.

2.6.4.3 API Testing

Many systems implement application programming interfaces, or APIs, which allow other services to connect to the system in innovative ways.⁸⁰ For example, Google Maps provides users with the means to integrate Google Maps into their websites, generating driving directions, obtaining elevation profiles and enabling other interactive activities. Although an API may be active alongside system deployment, many are released after the system has seen extensive use. When a developer uses an API, they may unknowingly expose personal information under their own control through the API. If the data pertaining to an API remote procedure call is logged, this data may become a potentially unacknowledged repository of personal information or other sensitive data. In this situation, API developers should be careful to extend privacy protections to this data and work with developers who use the API to notify their users about how personal information is used through this API.

2.7 Summary

This chapter presents an overview of the software development life cycle and risk management as these topics relate to developing IT systems that preserve, enhance and enable privacy. From requirements and design to implementation and testing, privacy is a crosscutting concern for IT professionals. Armed with the knowledge in this chapter, IT professionals can aim to incorporate privacy into IT system development and engage in deeper discussions to ensure that privacy requirements trace throughout the software development life cycle. For example, in Chapter 8 we illustrate the critical role of appointing a permanent privacy area specialist, also called a privacy champion, who bridges the technical gap between software engineering and privacy and who consults across multiple IT projects within an organization to share privacy knowledge and reach a higher standard of care. In addition, we introduce and review several privacy risk models and illustrate how these models can be used to drive privacy requirements elicitation that may contribute to addressing privacy risk. Finally, we show by example how many modern software engineering practices can be applied to address privacy requirements in design, implementation and testing.

Endnotes

- 1 The predecessor to Facebook was first developed by Mark Zuckerberg as a local tool to search student profiles at Harvard University: Alan J. Tabak, “Hundreds Register for New Facebook Website,” *Harvard Crimson*, February 9, 2004. The online auction site eBay was single-handedly created by Pierre Omidyar over a single weekend: Adam Cohen, *The Perfect Store: Inside eBay*, (Boston: Back Bay Books, 2003).
- 2 David G. Messerschmitt and Clemens Szyperski, *Software Ecosystem: Understanding an Indispensable Technology and Industry*, (Boston: MIT Press, 2003).
- 3 Alan Westin, *Privacy and Freedom*, (New York: Atheneum, 1967); Julie E. Cohen, “Examined Lives: Informational Privacy and the Subject as Object,” *Stanford Law Review* 52, no. 5 (2000): 1373–1478.
- 4 Messerschmitt and Szyperski, *Software Ecosystem*.
- 5 In larger companies, the area specialist holds the job title Privacy Engineer and serves much the same role as a person who works across products and teams to advocate for privacy-preserving design.
- 6 Etienne Wenger, *Communities of Practice: Learning, Meaning, and Identity*, (New York: Cambridge University Press, 1998).
- 7 Peter Naur and Brian Randell, eds., “Software Engineering: Report on a Conference Sponsored by the NATO Science Committee,” (Garmisch, Germany, October 7–11, 1968).
- 8 Winston W. Royce, “Managing the Development of Large Software Systems,” *Proceedings, IEEE WESCON*, 1970, 1–9; Barry W. Boehm, “A Spiral Model of Software Development and Enhancement,” *ACM SIGSOFT Software Engineering Notes*, 14–24, (August 1986); Kent Beck and Cynthia Andres, *Extreme Programming Explained: Embrace Change*, 2nd ed., (Boston: Addison-Wesley, 2004); Mike Cohn, *Succeeding with Agile: Software Development Using Scrum*, (Boston: Pearson Education, 2009).
- 9 Watts S. Humphrey, *Introduction to the Team Software Process*, (Boston: Addison-Wesley Professional, 1999).
- 10 Barry Boehm and Richard Turner, *Balancing Agility and Discipline: A Guide for the Perplexed*, (Boston: Addison-Wesley/Pearson Education, 2003).
- 11 Len Bass, Ingo Weber, and Liming Zhu, *DevOps: A Software Architect’s Perspective*, (Boston: Addison-Wesley, 2015).
- 12 Organization for the Advancement of Structured Information Standards (OASIS), *Privacy Management Reference Model and Methodology (PMRM) Version 1.0*, Committee Specification 02, May 17, 2016.
- 13 Mina Deng et al., “A Privacy Threat Analysis Framework: Supporting the Elicitation and Fulfillment of Privacy Requirements,” *Requirements Engineering* 16, March (2011): 3–32; <https://www.nist.gov/itl/applied-cybersecurity/privacy-engineering/resources>.
- 14 IEEE Standard 610.12-1990, *IEEE Standard Glossary of Software Engineering Terminology*.
- 15 M. Ryan Calo, “The Boundaries of Privacy Harm,” *Indiana Law Journal* 86, no. 3 (2011): 1131–1162.
- 16 Daniel J. Solove, “A Taxonomy of Privacy,” *University of Pennsylvania Law Review* 154, no. 3 (2006): 477–564.
- 17 Douglas W. Hubbard and Richard Seiersen, *How to Measure Anything in Cybersecurity Risk*, (Hoboken, NJ: Wiley, 2016); Jack Freund and Jack Jones, *Measuring and Managing Information Risk: A FAIR Approach*, (Waltham, MA: Butterworth-Heinemann, 2015).
- 18 Jaspreet Bhatia and Travis Breaux, “Empirical Measurement of Perceive Privacy Risk,” *ACM Transactions on Human Computer Interaction (TOCHI)*, 25(6): Article 34, (2018); Paul Slovic, *The Perception of Risk*, (Earthscan, 2000).
- 19 Alessandro Acquisti and Jens Grossklags, “Privacy and Rationality in Individual Decision Making,” *IEEE Security and Privacy*, 3(1): 26-33, (2005).
- 20 Calo, “The Boundaries of Privacy Harm.”

- 21 Westin, *Privacy and Freedom*; Cohen, “Examined Lives.”
- 22 Solove, “A Taxonomy of Privacy.”
- 23 Helen Nissenbaum, *Privacy in Context: Technology, Policy, and the Integrity of Social Life*, (Stanford, CA: Stanford Law Books, 2009).
- 24 U.S. National Institute of Standards and Technology (NIST), *An Introduction to Privacy Engineering and Risk Management in Federal Systems*, NIST Internal Report (NISTIR) 8062, (January 2017).
- 25 Frank Armour and Granville Miller, *Advanced Use Case Modeling: Software Systems*, (Boston: Addison-Wesley Professional, 2001).
- 26 NIST, *Security and Privacy Controls for Federal Information Systems and Organizations*, Special Publication 800-53, Revision 4, U.S. Department of Commerce (DOC)/NIST, April 2013, <http://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.800-53r4.pdf>.
- 27 Pamela Zave and Michael Jackson, “Four Dark Corners of Requirements Engineering,” *ACM Transactions on Software Engineering and Methodology* 6, no. 1 (1997): 1–30.
- 28 Barry Boehm and Victor R. Basili, “Software Defect Reduction Top 10 List,” *Computer* 34, no. 1 (2001): 135–137.
- 29 Joy Beatty and Anthony Chen, *Visual Models of Software Requirements* (Redmond, WA: Microsoft Press, 2012).
- 30 Don A. Dillman, Jolene D. Smyth and Leah Melani Christian, *Internet, Mail, and Mixed-Mode Surveys: The Tailored Design Method*, 3rd ed., (Hoboken, NJ: Wiley, 2008); Roger Tourangeau, Lance J. Rips and Kenneth Rasinski, *The Psychology of Survey Response*, (Cambridge: Cambridge University Press, 2000); Richard A. Krueger and Mary Anne Casey, *Focus Groups: A Practical Guide for Applied Research*, 4th ed., (Thousand Oaks, CA: SAGE Publications, 2008).
- 31 The Privacy Act defines the term “system of records” as a group of records under the control of any U.S. government agency “from which information is retrieved by the name of the individual or by some identifying number, symbol, or other identifying particular assigned to the individual.” 5 U.S.C. § 552a(a) (5).
- 32 There are other kinds of standards, which are predictable or functional. Industry standards, for example, may be functional or nonfunctional, depending on their scope and level of detail.
- 33 COPPA, 16 CFR Part 312.
- 34 Travis D. Breaux and Annie I. Antón, “Analyzing Regulatory Rules for Privacy and Security Requirements,” *IEEE Transactions on Software Engineering* 34, no. 1 (2008): 5–20.
- 35 Travis D. Breaux and David L. Baumer, “Legally ‘Reasonable’ Security Requirements: A 10-Year FTC Retrospective,” *Computers & Security* 30, no. 4 (2011): 178–193.
- 36 Breaux, “Legally ‘Reasonable’ Security Requirements.”
- 37 Julia B. Earp, Annie I. Antón and Ryan A. Carter, “Precluding Incongruous Behavior by Aligning Software Requirements with Security and Privacy Policies,” *Information and Software Technology* 45, no. 14 (2003): 967–977.
- 38 www.google.com/policies/privacy/.
- 39 Julia Angwin and Jennifer Valentino-Devries, “Apple, Google Collect User Data,” *The Wall Street Journal*, April 22, 2011.
- 40 Travis D. Breaux, Annie I. Antón, Kent Boucher and Merlin Dorfman, “Legal Requirements, Compliance and Practice: An Industry Case Study in Accessibility,” *Proceedings of the 16th IEEE International Requirements Engineering Conference*, Barcelona, Spain, (2008), 43–52.
- 41 NRS 603A.200.
- 42 Va. Code Ann. §18.2-186.6(A).

- 43 National Taxpayer Advocate: 2008 Annual Report to Congress, Department of the Treasury, Internal Revenue Service, vol. 1, 2008, 213–226.
- 44 Deng et al., “A Privacy Threat Analysis Framework: Supporting the Elicitation and Fulfillment of Privacy Requirements.”; Adam Shostack, *Threat Modeling: Designing for Security* (Indianapolis: Wiley, 2014).
- 45 Axel van Lamsweerde, “Elaborating Security Requirements by Construction of Intentional Anti-models,” *Proceedings of the 26th IEEE International Conference on Software Engineering*, 2004, 148–157; Guttorm Sindre and Andreas L. Opdahl, “Eliciting Security Requirements with Misuse Cases,” *Requirements Engineering Journal* 10, no. 1 (2005): 34–44; John McDermott and Chris Fox, “Using Abuse Case Models for Security Requirements Analysis,” *Proceedings of the 15th Annual Computer Security Applications Conference*, 1999, 55–64.
- 46 van Lamsweerde, “Elaborating Security Requirements by Construction of Intentional Anti-models.”
- 47 In 2004, a nurse became the first criminal defendant convicted under the HIPAA Privacy Rule. The nurse stole a cancer patient’s name, birthdate and Social Security number and used that information to obtain several credit cards: Mike Scott, “HIPAA Gavel Drops—A Message to Healthcare,” *Radiology Today* 5, no. 24 (2004): 38.
- 48 John McDermott and Chris Fox, “Using Abuse Case Models for Security Requirements Analysis.”
- 49 Grady Booch, James Rumbaugh and Ivar Jacobson, *The Unified Modeling Language User Guide*, 2nd ed. (Boston: Addison-Wesley Professional, 2005).
- 50 Paul Clements et al., *Documenting Software Architectures: Views and Beyond*, 2nd ed., (Boston: Addison-Wesley Professional, 2010).
- 51 In the Matter of FACEBOOK, INC., a corporation, U.S. FTC Decision and Order, FTC File No. 0923184, Docket No. C-4365, Commissioners: Jon Leibowitz, J. Thomas Rosch, Edith Ramirez, Julie Brill, Maureen K. Ohlhausen, July 27, 2012.
- 52 NIST Cloud Computing Program - NCCP, www.nist.gov/itl/cloud/ (accessed October 2019).
- 53 Erich Gamma, Richard Helm, Ralph Johnson and John Vlissides, *Design Patterns: Elements of Reusable Object-Oriented Software*, (Reading, MA: Addison-Wesley Professional, 1994).
- 54 Sasha Romanowsky et al., “Privacy Patterns for Online Interactions,” *Proceedings of the 2006 Conference on Pattern Languages of Programs*, Article 12, 2006.
- 55 Jaap-Henk Hoepman, “Privacy Design Strategies,” Radboud University, Institute for Computing and Information Sciences, October 25, 2012, <https://www.cs.ru.nl/~jhh/publications/pdp.pdf>.
- 56 R. Jason Cronk, *Strategic Privacy by Design*, (Portsmouth, NH: IAPP, 2018).
- 57 Sarah Spiekermann and Lorrie Faith Cranor, “Engineering Privacy,” *IEEE Transactions on Software Engineering* 35, no. 1 (2009): 67–82.
- 58 Latanya Sweeney, “*k*-Anonymity: A Model for Protecting Privacy,” *International Journal on Uncertainty, Fuzziness and Knowledge-based Systems* 10, no. 5 (2002): 557–570.
- 59 Peter Eckersley and Electronic Frontier Foundation, “How Unique Is Your Web Browser?” *Proceedings of the 10th International Conference on Privacy Enhancing Technologies*, 2010, 1–18.
- 60 Spiekermann and Cranor, “Engineering Privacy.”
- 61 John McCormick, “Records ‘Full of Inaccuracies,’” *Baseline*, June 16, 2005, www.baselinemag.com/c/a/Projects-Security/ChoicePoint-Blur/5/.
- 62 Darlene Storm, “Nissan Leaf Secretly Leaks Driver Location, Speed to Websites,” *Security Is Sexy* (blog), *ComputerWorld*, June 14, 2011, http://blogs.computerworld.com/18461/nissan_leaf_secretly_leaks_driver_location_speed_to_websites.
- 63 NIST, *An Introduction to Privacy Engineering and Risk Management in Federal Systems*.

- 64 In 1996, a critical flaw was discovered in the MD5 cryptographic hash function that led security experts to downgrade the use of MD5 in applications where a collision-resistant function was needed, such as signing digital certificates: Hans Dobbertin, “The Status of MD5 After a Recent Attack,” RSA Laboratories’ CryptoBytes 2, no. 2 (1996): 1, 3–6.
- 65 IEEE Standard 610.12-1990, *IEEE Standard Glossary of Software Engineering Terminology*.
- 66 Stephen J. Andriole, ed., *Software Validation, Verification, Testing, and Documentation*, (Princeton, NJ: Petrocelli Books, 1986).
- 67 William C. Hetzel, *The Complete Guide to Software Testing*, 2nd ed., (Wellesley, MA: Wiley, 1988).
- 68 Privacy Rights Clearinghouse, “Online Data Vendors: How Consumers Can Opt Out of Directory Services and Other Information Brokers,” <https://www.privacyrights.org/online-information-brokers-list> (accessed October 2019).
- 69 Joseph E. Hoag, *Synthetic Data Generation: Theory, Techniques and Applications*, (Ann Arbor, MI: ProQuest, UMI Dissertation Publishing, 2011).
- 70 The home of the U.S. Government’s open data, Data.gov, <https://www.data.gov/> (accessed October 2019).
- 71 Arvind Narayanan and Vitaly Shmatikov, “Robust De-anonymization of Large Sparse Datasets,” *Proceedings of the 2008 IEEE Symposium on Security and Privacy*, 2008, 111–125.
- 72 Annie I. Antón, Qingfeng He and David L. Baumer, “Inside JetBlue’s Privacy Policy Violations,” *IEEE Security and Privacy* 2, no. 6 (2004): 12–18.
- 73 Carlos Delano Buskey, “A Software Metrics Based Approach to Enterprise Software Beta Testing Design,” *ETD Collection for Pace University*, Paper AAI3191871, January 1, 2005.
- 74 Miguel Helft and Brad Stone, “With Buzz, Google Plunges into Social Networking,” *The New York Times*, February 9, 2010.
- 75 Ryan Paul, “EPIC fail: Google Faces FTC complaint over Buzz privacy,” *Ars Technica*, February 17, 2010, <http://arstechnica.com/security/2010/02/epic-fail-google-faces-complaint-over-buzz-privacy-issues/>.
- 76 Juliet Lapidus, “Why Did It Take So Long to Get Gmail Out of ‘Beta?’” *Slate*, July 7, 2009.
- 77 Bernard Jansen, Amanda Spink and Isak Taksa, *Handbook of Research on Web Log Analysis*, (Hershey, PA: IGI Global, 2009).
- 78 Michael Barbaro and Tom Zeller, Jr., “A Face Is Exposed for AOL Searcher No. 4417749,” *The New York Times*, August 9, 2006.
- 79 Sascha Just, Rahul Premraj and Thomas Zimmermann, “Towards the Next Generation of Bug Tracking Systems,” *Proceeding of the 2008 IEEE Symposium on Visual Languages and Human-Centric Computing*, 2008, 82–85.
- 80 Josh Poley, “Best Practices: API Testing,” Microsoft Corporation, February 2008, <http://msdn.microsoft.com/en-us/library/cc300143.aspx>.

CHAPTER 3

Encryption and Related Technologies

Simson L. Garfinkel, CIPP/US

Encryption is the fundamental technology that is used to protect confidentiality in today's digital world. With encryption, large quantities of data can be rapidly scrambled so that they cannot be deciphered or understood by unauthorized entities. The scrambling protects information so that it can be sent over the internet or stored on a laptop without fear of having its confidentiality being

compromised in the event that the (scrambled) data are intercepted or stolen by unauthorized parties.

Beyond protecting confidentiality, encryption can be used to certify documents with *digital signatures*, making it possible for an unaffiliated third party to determine the identity of the person or organization that signed the document and to verify that the document has not been modified since signing.

Encryption is also used for both *identification* and *authentication* in the digital world. For identification, encryption can establish identities that are linked to legal identities, such as the name of a person or corporation, or that are unrevealing pseudonyms. And unlike a name, Social Security number or other identifier, cryptographic identities can be mathematically authenticated by a *relying party*, greatly reducing the chance that the identity is being fraudulent asserted—for example, by a criminal engaged in identity theft. As a result, encryption has long been used by organizations to identify their websites and internet servers, and it is increasingly used by individuals to prove their identity to remote computers over the internet.

This chapter introduces the fundamental concepts, historical context, and modern uses of encryption. It explains the difference between so-called secret key and public key algorithms, also known as *symmetric* and *asymmetric*. The chapter presents a variety of applications for encryption in the modern information economy—some of which may be surprising, and some of which really do no good at all. It explains the factors that go into the security of a system that uses cryptographic techniques, including the strength of the underlying algorithm, the cryptographic implementation, and quantitative measures such as the length of the password or *key* that is used to perform the encryption and decryption. To that end, the second half of the chapter is devoted almost entirely to asymmetric encryption, including the key distribution problem, how *public key infrastructure* (PKI) attempts to solve it, and modern systems that rely on public key technology. Finally, the chapter explains how poor implementation, poor key management, and other common security problems can render worthless even the best cryptographic systems.

3.1 Encryption, the Mathematics of Privacy Protection

Data encryption is a widely used tool that protects information belonging to individuals, businesses and governments. It is often said that sending information over the internet is like sending a postcard—any person or computer along the path can read it. If the information is encrypted, interlopers can still read the postcard, but they cannot decipher the postcard’s meaning. A laptop that’s left at a restaurant or the back seat of a taxi can be a disaster for privacy—anyone who has the laptop can access all of its information—unless the data on the hard drive is encrypted. Indeed, encryption is so powerful and trustworthy that nearly every breach notification law does not require notification if the information available to the attackers was encrypted.

Encryption can even restrict what someone can do with your data *after* you give it to them. Field-level encryption, built into programs like MongoDB, allow individuals’ data fields to be encrypted with their own keys, limiting what a database user (or application) can modify and what they cannot. Cryptographic techniques based on digital signatures can help verify that a document hasn’t been modified since it was created.

Finally, encryption can improve the confidentiality of private data by providing additional mechanisms to identify and authenticate authorized users. As such, encryption is at the root of most two-factor authentication schemes, and schemes that do not use encryption (such as sending an SMS message with a code to a preregistered cell phone number) are now regarded as being significantly less secure than schemes relying on cryptography.

3.1.1 Vocabulary

Encryption can do all of these things and more because encryption changes the way that data is stored in the computer’s memory on hard drives, tapes and flash devices (*data at rest*) and the way that it is sent over a network (*data in motion*). In all of these cases, encryption scrambles (*encrypts*) data so that it cannot be understood or otherwise used without first being *decrypted*. Encrypting and decrypting are thus inverse operations. Encryption protects data by rendering it unusable; decryption takes that encrypted data and makes it usable, leaving it unprotected in the process.

In recent years, a new kind of encryption called *homomorphic encryption* has been developed that allows encrypted information to be manipulated without decrypting it first (*data in use*). Although homomorphic encryption was a research curiosity just a few years ago, it is now fast enough to make practical

some applications requiring high degrees of privacy and security practical. A related technology called *secure multiparty computation* allows two or more computers to participate in a computation and compute a mathematical result without otherwise revealing private information. For example, with multiparty computation, five people can get together and compute their average salary without revealing their individual salaries to anyone—not to each other, and not to a trusted third party. Multiparty computation was used in 2016 as part of the Boston Women’s Salary Survey, allowing businesses to participate in the salary survey without revealing the salaries of their individual employees—the privacy of which was legally protected.¹

In today’s world, the words *encrypt*, *encipher* and *encode* are often used interchangeably to describe the process of locking up information so that it’s unusable to unauthorized users. The word *scramble* above serves a similar purpose. Likewise, the words *decrypt*, *decipher* and *decode* are frequently used to describe the reverse process. In fact, each of these words has a slightly different meaning. Knowing those meanings is important if you want to avoid embarrassing usage mistakes.

According to the *New Oxford American Dictionary*, the word *encrypt* and its derivative *encryption* means to “convert (information or data) into a cipher or code, especially to prevent unauthorized access.”² As the definition states, there are two ways to encrypt information—through the use of a cipher (“enciphering” the data), or through the use of a code (“encoding” the data). Ciphers are typically mathematical transformations of data, in which data is scrambled according to some kind of function. Codes are transformations that typically involve a one-to-one replacement of a word, letter, figure or symbol with another word, letter, figure or symbol. Interestingly, the word *encrypt* only dates to the 1950s, according to the *New Oxford American*, but the terms *cipher* and *code* have been around for hundreds of years.

Cryptographers—people who study the science of encryption—use the word *plaintext* to denote data encryption and the word *ciphertext* to denote the encrypted message. Encryption was originally developed to secure messages that were sent from one location to another—especially diplomatic and military messages. Locks and guards could protect the endpoints, but a message carried by a courier between two protected endpoints was vulnerable—hence the need for encryption. Encryption can also be used to secure messages that are sent to the future: Charles Wesley, the cofounder of the Methodist movement, wrote his

eighteenth-century diary in code to protect the document and its salacious secrets from other people's prying eyes, although presumably Wesley himself could still read those messages.³ More than two centuries later, professor Kenneth Newport of Gresham College spent nine years and successfully cracked Wesley's code.

Both ciphers and codes can be used in a *secure* manner, meaning that the plaintext cannot be readily extracted from the ciphertext, but they can also be used in a manner that is not secure, allowing the messages to be deciphered by an adversary. The security or *strength* of a cipher or code is usually phrased in terms of a *work factor*—that is, the amount of effort that an adversary needs to expend to decrypt the message. In the case of the Wesley messages, the work factor was apparently nine years for a respected English professor.

It's both easy and common to overestimate the strength of an encryption scheme—that is, the amount of effort to decrypt a message. It's also both easy and common to underestimate the effort that an adversary is willing to spend to decrypt a message or find a flaw in an entire encryption scheme. What's more, once a flaw is discovered, the knowledge of how to crack the message can typically be applied to many other messages. Because of these tendencies, privacy professionals should never accept the argument that it is acceptable to use a weak encryption system because no one would go to the effort to crack the data being protected. Instead, it is reasonable to require encryption schemes that are strong enough to resist all of the world's computers working together for millions of years. Such strength is readily obtainable using encryption systems that are on every laptop and mobile phone sold today.

It's also common to inadvertently damage the strength of a cryptographic system by using it incorrectly; such mistakes can be devastating. The German Third Reich possessed what should have been an unbreakable encryption system during World War II, but the Germans used the system in a way that made it susceptible to attack. The Germans also put unrealistic trust in their system—they never realized that the messages they were sending by radio were being systematically intercepted and decrypted by the Allied forces. Historians believe that the ability to crack the Enigma family of ciphers shortened the war by roughly two years.⁴

It's easy to see how mistakes using cryptography can compromise message *confidentiality*. But encryption errors can also prevent data that is encrypted from ever being decrypted again, compromising both *availability* and *integrity*.⁵ Many organizations are so frightened by the possibility of losing access to their encrypted data that they leave unencrypted copies of their data locked away in

presumably secure locations—and sometimes suffer disastrous consequences when those unencrypted copies are themselves compromised. For example, a shipment of unencrypted tapes might be lost on the way to a remote storage vault. Data can also be unexpectedly compromised when a storage system that is locked away inside a secure computing facility fails and needs to be serviced. For this reason, many organizations demand that all stored data be encrypted—even data that they never expect will leave the secure perimeter.

Even though it can't be used to prevent a document from being erased or altered, encryption can be used to detect unauthorized changes to files, documents, database records and other kinds of stored data. Here the techniques used are known as *cryptographic hash functions* and *digital signatures* and are discussed in sections 3.3 and 3.4.2.

All of this cryptographic technology exists for one purpose—to frustrate the will of the *adversary*. This adversary is assumed to be a constant presence in security engineering. It can be an outsider trying to gain access to an organization's private data, or an insider attempting to make unauthorized changes. Sometimes the adversary is a natural force, such as bad weather or a fire. No matter whether you are attempting to design a new data protection system or trying to understand a system that someone else has created, it is important to understand the adversary the system has been designed to protect against, the capabilities that adversary has, and the likely forms of attack the system may experience. This is called *threat modeling*, and it is a critical part of designing any system that is designed to protect privacy. After all, if there is no adversary, there is no need for any protection.

A *cryptographic system* is the collection of cryptographic algorithms, protocols, software and other items that use cryptography to achieve information security goals. Experience has shown that it is very difficult to create cryptographic systems that actually provide confidentiality and integrity commensurate with the strength of their underlying mathematical algorithms, because cryptographic systems frequently contain implementation flaws. Such flaws can be the result of many factors, including:

- Implementation errors (*bugs*).
- Flaws that have been deliberately placed in a product for later exploitation (*back doors*).

- Mathematical vulnerabilities that are unknown when they are developed and deployed but are later discovered (*weaknesses*).
- Erosion over time (*obsolescence*). That's what happened in the 1990s, when computers became so fast that the U.S. government's Data Encryption Standard (DES), developed in the 1970s, was replaced with the Advanced Encryption Standard (AES).

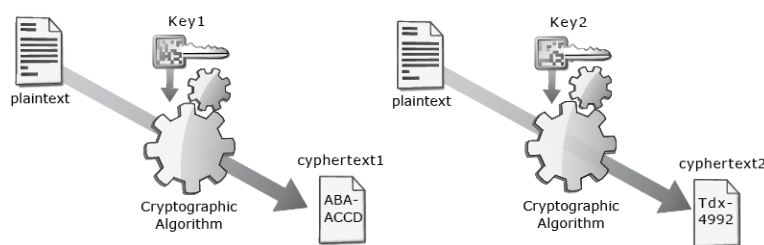
Finally, it is important to remember that all cryptographic systems are designed to protect data against specific kinds of adversaries that have specific technical abilities and limitations. Clearly, there is no need to design against an all-powerful adversary: Such an effort would be futile by definition.

3.1.2 Encryption Algorithms and Keys

Digital computers perform encryption by applying a mathematical *algorithm* to a block of data. In addition to the algorithm, encryption requires a key, which is a small piece of data that controls the algorithm's execution. The same plaintext encrypted with two different keys will produce two different ciphertexts. Likewise, most ciphertexts can be decrypted by one and only one key to produce the original plaintext.

It turns out that merely encrypting with an algorithm and a key is not sufficient to ensure security. It is also necessary to use randomness, also called *entropy*, so that an attacker observing the output of an encryption system cannot determine if the same message is encrypted a second time. This is shown in Figure 3-1.

Figure 3-1: plaintext1 + key1 + algorithm + entropy = ciphertext1; plaintext1 + key2 + algorithm + entropy = ciphertext2; plaintext1 + key1 + algorithm + entropy = ciphertext3



All modern cryptographic systems require entropy for both creating keys and encrypting messages. Indeed, the need to obtain a sequence of numbers that is truly random is one of the defining characteristics of modern cryptography. But high-quality entropy can be hard to obtain in many environments: The difficulty

of obtaining a reliable stream of random numbers has been a source of exploitable weakness in many deployed encryption systems.

Broadly, there are two kinds of encryption algorithms. *Secret key* algorithms, also called *symmetric* algorithms (Section 3.2), use the same key to encrypt and decrypt the plaintext. *Public key algorithms*, also called *asymmetric* algorithms (Section 3.4), are designed so that the plaintext can be encrypted using only public information, but decrypting the ciphertext requires the use of private information. Only some algorithms have this property; they were called *trap door functions* in the 1976 article by Whitfield Diffie and Martin Hellman that introduced the world to the concept of public key cryptography.⁶ Today we call the public information a person's *public key* and the private information their *private key*.⁷

A common metaphor for encryption is a combination lock on a box: The plaintext is the message inside the box, the lock is the algorithm, and the combination is the key. With this metaphor, a secret key algorithm would use the same combination to lock and unlock the box, while public key algorithms use one combination to lock and a second combination to unlock. Likewise, a public key algorithm can be thought of as a locked box with a slot on the top: Anyone can drop a message into the box, but you need the combination to get the message out (Figure 3-2).

A variety of asymmetric algorithms have been proposed. Most are based on some kind of deep mathematical or algorithmic property. One of the most common algorithms is RSA, named after its inventors Rivest, Shamir and Adleman. However, many other public key systems have been created.

Figure 3-2: A Box with a Combination Lock on it (Symmetric Cryptography) and a Slotted Box with a Combination Lock (Public Key Cryptography)



Modern encryption systems use keys that are very large numbers. The most common symmetric algorithm in use today, the AES, is typically used with keys that are either 128 bits or 256 bits in size. Each bit can be either a “0” or a “1.” A 128-bit key therefore has

$2^{128}=340,282,366,920,938,463,463,374,607,431,768,211,456 \approx 3 \times 10^{40}$ possible keys. This is an astoundingly large number.

One way to forcibly decrypt an encrypted message without knowing the key is to try every possible key, because the correct key, when tried, *will* decrypt the message. Such attack is called a *brute force attack* or a *key search attack*, and it is infeasible with 128-bit AES. To understand why, imagine that an organization had a billion computers (10^9), and each computer could try a billion 128-bit AES keys (10^9) every second, for a total of a billion billion (10^{18}) keys per second. Even with such impressive computing machinery, which is many times the computing power available on earth today, it would still take $3 \times 10^{40} \div 10^{18} = 3 \times 10^{22}$ seconds or 258 trillion years to try every possible combination. That's approximately 13,000 times older than the age of the universe.

Here is another way to understand the difficulty of a key search attack on 128-bit AES—by comparing the difficulty of the problem to the mass of the earth. The mass of the earth is approximately 6×10^{24} kilograms, while the mass of a modern microprocessor and heat sink is roughly 100 grams. If we pretend for a moment that the entire earth could be transmuted into microprocessors with heat sinks, and that those processors could crack a million AES keys per second (which they cannot), and that somehow all of those processors could run without power, memory or other hardware, then we would have 6×10^{25} processors each trying 10^6 keys/second, for a total of 6×10^{31} keys/second. Even this earth-shattering computer would still require 5×10^{14} seconds to try all possible 128-bit AES keys, or roughly 16 million years.

Clearly, no one is going to seriously attempt cracking an AES-encrypted message by trying all possible 128-bit encryption keys. But there are ways other than brute force key search to forcibly decipher an encrypted message. Indeed, it is hypothesized that if a sufficiently large quantum computer can be constructed, that computer will be able to crack 128-bit AES with relative ease, but that it will not be able to crack 256-bit AES. For this reason, applications that require that encrypted data be secure for decades typically specify 256-bit AES rather than the 128-bit version.

The security of an encrypted message depends both on the security of the key and the strength of the encryption algorithm. Modern design principles hold that while the key should remain secret, encryption algorithms should be publicly designed and vetted. This is a hard concept for many people to accept—it certainly *seems* that since both the key and the algorithm are needed to decrypt a

message, an encrypted message is probably more secure if both the key and the algorithm are kept secret. The flaw with this thinking is the assumption that secret algorithms are more secure than public ones. It is dramatically more complicated to design a strong encryption algorithm than to come up with a strong key. Any randomly chosen number is a strong key—modern computers can make hundreds of these keys *every second*. But creating a good algorithm takes years of careful design, analysis and testing. If the algorithm is flawed, it may be possible to rapidly decrypt the ciphertext without knowing the key at all, no matter how long the key is. If the strength of secret algorithms and public algorithms were equal, it would indeed be more secure to use a secret algorithm than a public one.

However, secret algorithms are usually far weaker than public ones, by virtue of the fact that they have received far less scrutiny. Thus, the modern consensus is that it is far better to use a strong algorithm that has been publicly vetted with a randomly chosen key than a secret algorithm with unknown weaknesses. Indeed, programmers should never take it upon themselves to develop a new encryption algorithm, or to take an existing algorithm and attempt to strengthen it by making changes to the underlying cryptographic machinery. Instead, programmers should use existing, vetted implementations of strong algorithms.

A *cryptosystem* is the entire collection of materials necessary to encrypt and decrypt information. Cryptographers take this term to mean the algorithms that are necessary to perform encryption or decryption. In practice, security engineers expand this definition to include the collection of hardware, software, equipment and procedures needed to encrypt, decrypt, transmit and otherwise manipulate information that is being protected—that is, the cryptosystem is anything that will jeopardize the security of encrypted communications if it does not perform as expected. Research over the past decade in usable security makes it clear that this traditional definition needs to be expanded to include training, the human context in which the equipment is used and even the psychological state of the human operators.⁸

It is the strength of the overall system that determines the security of encrypted data, not the strength of any single part. For example, a system could have a secure key, but that key could be transmitted in the clear along with the encrypted message. This would be akin to securing a vault with a \$1,500 combination lock but then affixing the lock's combination to the vault's door with a sticky note.

One of the primary goals of a security or privacy professional is to minimize the amount of risk faced by users and customers—and to understand the risk that

remains. This is another reason why it's better to use a well-known algorithm than to use algorithms that are secret. With algorithms that are well known and vetted, the security of the message lies with the key: Keep the key secret and the message is indecipherable; release the key and it's open. But with an algorithm that's secret, the message security requires both that the key be kept secret and that the algorithm be strong. A weak algorithm can compromise a message just as effectively as a weak key. Minimizing risk means minimizing the number of things that can compromise security, which means using algorithms that are widely understood, vetted and accepted.

3.1.3 Cryptographic Keys versus Passwords

Cryptographic keys are similar to passwords in that both are secrets that can be used to control access to information. But keys and passwords are different in important ways:

- With a cryptographic key, access to the controlled information requires that the information first be mathematically transformed from the ciphertext back into the plaintext. When information is encrypted, there is no program or agent that decides whether or not to grant access—the correct key can decrypt the data, and incorrect keys can't. Similarly, there is no way to reset the encrypted information and grant access to a new key if the first key is lost. Keys can be changed, but doing so requires that the information first be decrypted with the correct key and then re-encrypted with a second, a process that is called *re-encryption*.
- With a password, access to the controlled information is mediated by a program running on some computer. The program compares the password provided by the user with a password that's on file; the program grants access if the two passwords match.² Because the program is making a decision as to whether or not access is granted, the decision can be manipulated by factors other than the correctness of the provided password—for example, the program could be modified by malware so that access is always granted on Tuesdays at 5 p.m. local time. Note also that the access-granting software has access to confidential parts of the system even when a password is not being provided. Thus, password-protected information can usually be

accessed by a system administrator or a sufficiently skilled attacker, even if the password itself is unknown.

These are important differences. As a result, cryptographic approaches typically provide stronger confidentiality assurances when compared to password-only approaches—but cryptography is more susceptible to catastrophic data loss. In practice cryptographic approaches offer less flexibility, because access control policies need to be implemented in the rather restrictive language of cryptography. For example, a password system can rather trivially be programmed with time-based access controls, so that even authorized individuals don't have access to data when they are on vacation. It is currently not possible to implement such a restriction solely with cryptography in a manner that cannot be readily subverted.

3.1.4 Encryption Before the Rise of E-Commerce

The principles of symmetric cryptography had been understood since the 1960s, and in 1977 the U.S. government published Federal Information Processing Standard (FIPS) Publication 46, entitled the Data Encryption Standard (DES), as a private key algorithm that U.S. businesses could use to protect digital information. DES was a surprisingly strong encryption algorithm—it was not until 1998 that there was a public demonstration of a message encrypted with DES being forcibly decrypted, and the weakness that the attackers used could be easily overcome by encrypting a message with DES three times over, each time with a different key (a technique called *triple DES* or *3DES*).

Despite the widespread availability of both cryptographic knowledge and DES implementations, cryptography was not widely used in computing until the rise of e-commerce in the late 1990s. This delay was primarily the result of three factors:

- *The lack of workable public key cryptography implementations*—In order for two parties to communicate privately, they must share a cryptographic key. Without public key cryptography, the only way to exchange keys is by courier or by using a trusted third party—and then that third party has the ability to decrypt any communication it might intercept. Securely agreeing upon a key shared by those two parties and no one else (without having to send the key by courier) is the precise problem for which public key cryptography was invented in 1976. But

after this invention, it took more than two decades for the technology to move from the world of computer science research labs to software systems that could be readily used by nonexperts.

- *Export controls*—Cryptography's long association with diplomatic and military communications resulted in the technology being legally regulated as a dual-use military technology for most of the twentieth century. In the 1980s, for example, the U.S. government restricted the exportation of computer hardware and software that could perform any kind of cryptography. The government even restricted software systems that allowed so-called cryptography with a hole—that is, systems that did not implement cryptography directly, but allowed end users to add their own. In the early 1990s, the U.S. government modified its stance on cryptography, allowing the export of cryptosystems that used specific algorithms (RC2 and RC4) at a key length of 40 bits. In 2000, restrictions were eased further, such that today most cryptographic systems can be freely exported provided that the underlying cryptographic software is also available as open source software.
- *CPU speed*—One of the first uses of digital cryptography outside of government sectors was to protect automatic teller machine (ATM) networks, but this was done by special-purpose hardware. Over the following 30 years, computers became dramatically faster, while the algorithms themselves became more efficient. The result is that the percentage of CPU power that needs to be expended on cryptography has dropped precipitously. Whereas the impact of software cryptography was crippling on computers in the 1980s and merely significant in the 1990s, today's computers can encrypt and decrypt data with hardly any perceptible impact. Indeed, Apple's iPhone automatically encrypts data as it moves from the CPU to flash storage and decrypts data when it moves back: Encryption on these devices is essentially free.

The real breakthrough promoting the widespread use of cryptography came in 1995 with the release of Netscape Navigator, the first web browser to incorporate transparent cryptography. Netscape Navigator, and practically every web browser since, allows information that's sent over the internet to be automatically

encrypted as it travels between the web server and the web browser. Netscape Navigator did this with an encryption protocol called the secure socket layer (SSL). This protocol was revised several times, renamed transport layer security (TLS) and adopted as an internet standard in 1999.¹⁰ Today TLS (sometimes called SSL/TLS) is one of the most widely used forms of encryption in the world. TLS protects virtually all of the information sent over the internet, from Google searches and Facebook status updates to stock purchases worth hundreds of millions of dollars and streaming video. Both these low- and high-value transactions use exactly the same protocol.

TLS is generally regarded as a strong protocol. However, TLS has had many vulnerabilities disclosed over the years. One of the most recent is CVE-2011-3389, which allowed a man-in-the-middle attacker to obtain the plaintext of HTTP headers in an HTTPS session due to an error in the way that the TLS Cipher Block Chaining (CBC) mode was implemented. Fundamental cryptographic attacks such as this are infrequent but reoccurring. TLS implementations have also seen their share of flaws: One of the most significant was the Heartbleed bug in OpenSSL (CVE-2014-0160), which allowed attackers to extract cryptographic keys, passwords and other information from web servers. The continuing reoccurrence of both protocol errors and implementation flaws is why it is important for all software to be kept up to date and properly patched.

3.1.5 Encryption Today: Data in Flight, Data at Rest and Data in Use

Because TLS encrypts data before it is sent over the internet and decrypts the data when it is received at the other end, TLS is said to *protect data in flight (or data in transit)*. TLS provides no security for data once it arrives at the other end. TLS also provides no assurance that the recipient of the data is trustworthy.

Web browsers use the URL of a web page to determine if a page is downloaded over TLS. If the URL begins *http://*, such as *http://www.iapp.org/*, then TLS is not used. If the URL begins with *https://*, such as *https://www.iapp.org/*, the TLS is used. However, a single web page may be built from many individual resources, such as JavaScript libraries, fonts, images and data from remote servers. All of these individual resources must be protected with TLS or else an attacker can subvert the pages' integrity. Once a cryptographic channel is established, it protects both information sent from the server to the client, including the content of the web pages and any downloaded files, and information sent from the client

back to the server. TLS can also provide cryptographic authentication of both the server and the client, although in practice only the server is authenticated. Although it was once common practice to use TLS solely for password forms and not for other resources (such as graphics), increasingly web browsers are demanding that all of a pages' resources must be downloaded with TLS or they will be ignored.

TLS is what's known as a *pluggable* cryptographic protocol, meaning that the single protocol supports the use of multiple hash functions and ciphers. When a TLS client connects to a TLS server, the two negotiate the most secure version of each algorithm from the set of algorithms that each implement. This means that TLS can be configured so that it offers strong authentication and integrity, but poor confidentiality—a configuration that has been required by some governments in the past. Thus, simply using TLS is no guarantee of security—it depends on the specific algorithms that are in use.

There are many things that TLS encryption does not protect, such as information about the amount of the data exchanged, the location of the endpoints, or the very fact that data is being exchanged at all. Analyzing this kind of information is called *traffic analysis*, and it can be very easy to do. We explain this by saying that TLS provides neither anonymity nor stealth.

To achieve anonymity, it is necessary to hide one's traffic within a crowd, something that is done by systems such as proxies and mix networks, also called onion routing networks. These systems work by combining traffic from multiple computers into a single channel that is sent between multiple computers and then separating out the traffic again. Simple mix networks might involve a single node where traffic is combined: that's how most commercial mix networks work. The onion router (Tor) uses a more sophisticated system that relies on multiple layers of encryption and sends every users' traffic to at least three different computers in sequence, so that not even the nodes of the mix network know with whom the users are communicating.

For stealth, it is necessary to masquerade one's traffic so that it cannot be observed. This can be done by hiding the traffic using a masking protocol or using steganography.

TLS is just one of several internet protocols for protecting data in flight. Some internet telephony protocols use encryption at the application layer. Encryption is also built into the 802.11 WPA and WPA2 wireless network protocols. Nearly all virtual private network (VPN) systems use encryption to assure that the

encapsulated network traffic cannot be decoded by the networks that it passes over.

Encryption is also used to protect information that is stored for an extended period of time on a computer system—what's called *data at rest*. There are two approaches that are commonly used for data-at-rest encryption:

- *Application-level encryption*, also known as file-level or document-based encryption. This approach encrypts data on a file-by-file basis or record-by-record basis. The technology for performing the encryption is usually built into the application program itself. For example, Microsoft Word and Adobe Acrobat both support application-level encryption when the user saves a file with “password to open.”¹¹ Encryption can also be applied to a file after it is created with add-on file encryption programs.
- *Device-level encryption* is built into the computer's storage subsystem and performs encryption on a block-by-block basis. Disk-level encryption is typically done by the computer's operating system, by a special device driver or inside the hard drive. Apple's laptops, desktops and handheld devices are equipped with a special chip that automatically encrypts data when sent from the microprocessor to the flash memory and decrypts the data when it is read back. The encryption key is derived from the user's password combined with a random key stored inside the chip. The chip is configured so that if the wrong password is provided too many times, the chip automatically wipes itself, rendering the data unrecoverable. And because the key cannot be extracted from the chip, it is not possible to move the encrypted data to a supercomputer cluster and try to crack it there: There just isn't enough time in the universe.

Encryption is increasingly being used to protect information while the information is in use. These techniques open up fundamentally new kinds of applications. For example, it is now possible to add encrypted numbers together without first decrypting them. One application for this technology is secure telephone conferencing. The participants in the conversation each run software that digitizes their voice, encrypts it and then sends the data to a central server. The server adds the encrypted numbers together and then sends the encrypted sums back to each participant, where the software decrypts the numbers and uses

the resulting data to drive a speaker. Each participant can then hear the encrypted voice, but malware running on the server cannot eavesdrop on the contents of the conversation.

Currently there are three approaches for working with encrypted data:

- *Secure enclaves*, such as Intel's SGX technology, rely on modifications to the microprocessor to provide security. Some of these systems rely on *curtained memory*, which prevents the microprocessor from accessing the memory where the secure application is running. Another approach uses specialized hardware within the microprocessor to automatically encrypt memory as it is written and decrypt it as it is read—but the cryptographic key is only available to certain programs running with certain privileges. Secure enclaves offer the highest performance for working with encrypted data, but are the most likely to have implementation flaws that compromise the confidentiality of the data. In particular, some of the microprocessor vulnerabilities based on speculative execution discovered in recent years can be used against some secure enclave systems, including Intel SGX, on some kinds of operation systems.
- *Homomorphic encryption* is a collection of mathematical techniques for working with encrypted data. Generalized approaches for working with encrypted data were first developed in 2009 and have been steadily improved since then, to the point that they are now deployable for some classes of computation.
- *Multiparty computation* is a class of algorithms that allows programs running on different computers to participate in computations such that results can be computed without compromising each party's private data. Currently, multiparty computation algorithms are faster than homomorphic encryption algorithms but harder to set up because of the need to coordinate the computations. Most multiparty systems also have the property that the parties can reveal the private information if they conspire together. As a result, many of these systems assume that the participants are *honest but curious*—that is, they faithfully execute the multiparty protocol (they are *honest*), and the multiparty protocol

prevents each party from learning confidential information (so it doesn't matter that the parties are *curious*).

Finally, encryption can also be used to certify that a document has not been modified since some time in the past, a technique called *digital signatures*.

In the following sections, we discuss the building blocks from which these capabilities are built.

3.1.6 Encryption Tomorrow: Quantum Computing and Quantum Key Distribution

Big changes may be coming to the world of cryptography in a few years—but then again, they may not: It depends on how successful entrepreneurs will be in moving quantum technology from the research lab to the marketplace.

Quantum technology refers broadly to technology based on the various kinds of physical processes which happen at the atomic and subatomic level. At that small scale, the laws of quantum physics do a better job explaining physical processes than do the laws of Newtonian physics that were developed to explain behavior at the macroscopic scale.

Currently, there are two kinds of cryptographic quantum technology that have already been demonstrated in the laboratory:

- *Quantum computers*, if they can be made large enough and reliable enough, will be able to crack many of the algorithms described in this chapter. This includes the RSA encryption system, most hash functions, and 128-bit AES. The National Institute of Standards and Technology (NIST) is now embarked on a *post-quantum cryptography* project with the goal of developing a new suite that can be used if it ever appears that quantum computers are within five or ten years of being perfected.
- *Quantum key distribution* (QKD) is an approach for distributing an encryption key to two endpoints so that it is physically impossible (according to our understanding of physics) for a third party to get a copy of the key. QKD is based on a quantum principle called *entanglement*, which will not be described here. Currently, there are commercial QKD systems that can distribute keys over fiber optic cables between two endpoints that are up to 100 kilometers distant. In 2018, the government of China launched a satellite that uses lasers to

distribute keys between any two ground stations within the satellite's view.

3.2 Secret Key (Symmetric) Encryption

In the last section, we learned that there are fundamentally two kinds of encryption used by digital computers today: secret key (symmetric) encryption, where the same key is used to encrypt and decrypt data, and public key (asymmetric) encryption, where one key encrypts and a second key decrypts. In this section, we'll dig deeper into the specifics of secret key cryptography.

3.2.1 Algorithms and Key Sizes

There are two kinds of secret key algorithms:

- *Stream ciphers* are encryption algorithms that transform one byte of data at a time. The RC4 algorithm was widely used in the 1990s with the Netscape SSL protocol and is still somewhat used today, although its popularity is waning.
- *Block ciphers* transform a small block of data at one time, typically 16, 32 or 64 bytes. Both DES and AES are block ciphers.

Ciphers are based on two mathematical operations: *substitution*, which substitutes one pattern for another according to a code book; and *transposition*, which scrambles the bits within a set of bytes. Traditionally, stream ciphers only used substitution, whereas block ciphers could use both operations, making them somewhat more secure but also somewhat slower. Today's computers are fast enough to allow stream ciphers to be used as block ciphers and vice versa without any perceptible performance impact in the vast majority of applications; the differences between the two kinds of ciphers are no longer as relevant as they once seemed.

The AES algorithm was developed in 1998 by two Belgian cryptographers, Joan Daemen and Vincent Rijmen, and adopted as a U.S. government standard in 2001. After more than a decade of exhaustive analysis, AES is currently regarded as containing no significant algorithmic weaknesses. The only way to forcibly decrypt a message encrypted with AES is to try all possible keys, one by one, until the correct decryption key is found. Although some theoretical attacks on AES

have been published, none of them can be performed in practice—at least, not yet.

AES is actually a family of algorithms. The basic version of AES uses a 128-bit key and is called (not surprisingly) AES-128. The algorithm can also be run with a 192-bit or 256-bit key, and is correspondingly named AES-192 and AES-256. The AES algorithm itself consists of an inner mathematical operation that is repeated. AES-128 repeats this function ten times and is therefore said to have ten “rounds.” AES-192 has 12 rounds and AES-256 has 14 rounds. Additional rounds make messages encrypted with AES harder to decrypt without knowing the key.¹²

Because AES-256 has both a longer encryption key than AES-128 and more rounds, the algorithm is widely regarded as being more secure than AES-128. But how much more secure is it? There is really no way to know. Block mode encryption algorithms can’t be proven secure: They can only be shown to resist specific attacks. It’s possible that in the future some new attack will be discovered that makes AES less secure than it is today. If the past provides any guidance, such developments are likely. The only thing we don’t know is when the vulnerabilities will be discovered. If or when such an attack is discovered, it may be possible for an attacker to decrypt some AES-128 messages but not to decrypt any AES-256 messages.

Another factor that distinguishes AES-128 and AES-256 is their resistance to computers based on quantum mechanics. Today such *quantum computers* are exceedingly expensive, very difficult to program and quite limited in what they can do. However, it is believed by those who research quantum computing that a fully functional quantum computer would be able to quickly crack messages encrypted with AES-128, but not with AES-256.

For these reasons, organizations that are concerned about the long-term confidentiality of their information generally require AES-256 over AES-128—doing so protects against unknown attacks that may emerge in the future as well as against the real possibility of quantum computing. That’s perhaps one of the reasons that the U.S. National Security Agency (NSA) has approved certain AES-256 implementations for encrypting Top Secret data, but no such approval has been given for AES-128.¹³

AES-256 has a real cost: Those additional rounds mean that it takes more computer time (and thus more electricity) to encrypt a message with AES-256 than with AES-128. For many applications, such as encrypting commercial videos downloaded from streaming video services, the extra security may not be cost

effective. Privacy professionals should not assume that because AES-128 is good, AES-256 must be better. For many applications, there is no need to encrypt data so well that it can't be decrypted ten years hence.

There are other symmetric encryption algorithms, and many may be just as strong as AES. Some organizations continue to use triple DES, for example, on the grounds that DES is more thoroughly understood than AES. The government of China has developed its own suite of cryptographic algorithms so that its networks will not be dependent upon algorithms developed elsewhere. One of these algorithms is SM4, which has been standardized in China for protecting wireless networks. Finally, there is increasing interest in so-called lightweight encryption algorithms that are designed to encrypt small amounts of data—just a few bytes—or that must run in low-power environments. Two such algorithms are SIMON and SPECK, both developed by the NSA.

3.2.2 Symmetric Cryptography Attacks and Threats

Cryptanalysis is the process of trying to decipher an encrypted message without knowing the key in advance. The most basic form of cryptanalysis is the brute force attack, in which an attacker tries to decrypt a single message by systematically trying all possible keys. It is important to understand this kind of key search attack because there is fundamentally no way to protect against it—an attacker that gets an encrypted message can *always* try to decrypt it by trying all possible keys. In practice, more sophisticated approaches are used.

Some people believe that a good way to protect against a brute force key search attack is to prevent the attacker from ever acquiring a copy of the encrypted message. Of course, if it is possible to prevent the attacker from acquiring a message, then the message doesn't need to be encrypted in the first place. More realistically, modern cryptographers always assume that the attacker has both the encrypted message and the full system required to decrypt the message, and only lacks the necessary cryptographic key. In part, this is because it is much easier to evaluate the security of a system if the only thing that is kept secret is the key, and in part this is because the key is the only thing that changes from message to message, so everything else is eventually knowable by the attacker.

Other attacks typically rely on analyzing individual mathematical operations that create the encryption algorithm and correlating many applications of the algorithm over a large set of data. These approaches invariably make it possible for

an attacker to break an encryption system with far less work than trying every possible key.

An encryption algorithm can be considered broken under the following circumstances:

- Given a ciphertext C , the attacker can determine the plaintext P . (This is called a *known ciphertext* attack.)
- Given a plaintext P and a ciphertext C , the attacker can determine the encryption key K . (This is called a *known plaintext* attack.)
- Given a plaintext P of the attacker's choosing and the encrypted ciphertext C of that message, the attacker can determine the encryption key K . (This is called a *chosen plaintext* attack.)
- Given a number of similar plaintext messages P_1 through P_N and the corresponding ciphertext messages C_1 through C_N , the attacker can determine encryption key K . (This kind of attack uses a technique known as *differential cryptanalysis*.)
- Given a number of related keys and a collection of ciphertext encrypted with each key, it is possible to learn some or all of the keys, and therefore decrypt some or all of the ciphertext. (This is called a *related key* attack.)

While these attacks may not seem particularly realistic, they are all well within the realm of possibility. Consider the *chosen plaintext attack*. This attack might have been performed in the past by giving a document to the ambassador of a country during the course of diplomatic negotiations. The ambassador would then provide the document to the embassy cryptographers, who would dutifully encrypt the document and send it back to the home country. The opposing country's analysts would intercept the encrypted message; they would now have both a message of their choosing and the encryption of that message using the target country's diplomatic cipher. Similar attacks can be accomplished on modern cryptographic systems as well.

Cryptanalysis means that some encryption algorithms are far weaker than might be assumed based on their key size. For example, the DES algorithm was based on an algorithm called Lucifer developed in 1971. IBM submitted Lucifer to the National Bureau of Standards (NBS, the precursor of today's NIST) as a candidate

for the national standard. Lucifer had a 128-bit key; the algorithm that NBS eventually adopted in 1974 had 56 bits. At the time, many people thought that the NSA had put pressure on IBM and NBS to purposely weaken Lucifer so that the U.S. government would be able to crack messages encrypted with DES.

In the 1980s, cryptographers Eli Biham and Adi Shamir developed an elaborate variant of the chosen plaintext attack they called *differential cryptanalysis*. Instead of sending just a few messages to be encrypted, the attacker would have millions or even billions of messages encrypted and then analyze all of the results to determine a secret key. Reportedly, the two would have published their technique several years earlier, but they had spent most of their time analyzing DES, and DES was surprisingly resistant to differential analysis. But Lucifer was not—Lucifer could be cracked if the same keys were used to encrypt just 2^{36} chosen plaintext messages—roughly 68 billion messages, well within the capabilities of a large corporation or a national government by the late 1980s.¹⁴

As it turns out, conspiracy theorists who had blamed the NSA for weakening the DES had been wrong. The original Lucifer, even with its longer key, was in fact weaker than the 56-bit DES. The change to the substitution boxes that NSA had applied to the original algorithm submitted by IBM had made the algorithm stronger, but it had strengthened the algorithm against an attack that was secret at the time.¹⁵

By the mid-1990s, it didn't matter much that the DES was resistant to differential cryptanalysis, because the algorithm's 56-bit key was no longer sufficiently long: It could be brute-forced by Deep Crack, a million-dollar special-purpose computer created by the Electronic Frontier Foundation (EFF) for the purpose of demonstrating the weakness of the algorithm.

At the time DES was shown to be not secure, parts of the U.S. government were attempting to get industry to standardize on a new 80-bit encryption algorithm embedded in the so-called Clipper chip. Despite the apparent closeness of the numbers 56 and 80, an 80-bit encryption algorithm has $2^{(80-56)} = 2^{24} = 16,777,216$ times more keys than a 56-bit algorithm. This means that if it previously required 22 hours to crack a 56-bit key, it would take 369 million minutes to crack an 80-bit key, or approximately 701 years.

The U.S. computing industry had three main objections to the Clipper chip:

- First, and most publicly, the Clipper chip featured a mandatory key escrow that would have let the U.S. government decode Clipper-

encoded messages with a valid court order. This mandatory key escrow was the chip's *raison d'être*: Because it featured key escrow, the chip posed no threat to law enforcement or the intelligence agencies, and the government proposed that products containing Clipper would be freely exportable. But many industry insiders felt they would be unable to sell products that explicitly could be monitored by the U.S. government.

- Less publicly, but probably equally important, hardware vendors did not want to accept the additional costs and manufacturing complexities of adding a U.S. government chip to their products.
- Finally, organizations that needed more than 56 bits of security but still wished to follow government standards could simply secure their systems approach, called *triple DES* or *3DES*, which involved using the existing DES algorithm three times in a row, creating an encryption system with an effective key length of $56+56+56 = 168$ bits.

The Clipper Chip was not commercially successful, but the discussion did draw attention to the need to replace DES.

Today AES-128 is widely used: It is both faster and more secure than DES or 3DES. However, it is likely that vulnerabilities in the AES algorithm will be discovered in the future. When such vulnerabilities are discovered, it's probable that AES-128 will be more vulnerable than AES-256 because of its shorter key length and fewer number of rounds.

Because encryption algorithms come and go, modern encryption protocols like TLS (see section 3.6.1) allow the algorithms to be specified at runtime. Such systems are sometimes said to implement *pluggable encryption* because different algorithms can be literally plugged in using an application programmer's interface (API). In this way, it is possible to migrate from old algorithms to new ones when vulnerabilities are discovered with minimal software change (see Table 3-1).

Table 3-1: Comparison of Encryption Algorithms

Symmetric Algorithm	Type	Key Size	Block Size	Status
DES	Block Cipher	56 bits	64 bits	Not secure; do not use

Symmetric Algorithm	Type	Key Size	Block Size	Status
3DES (Triple DES)	Block Cipher	168 bits	64 bits	Secure but slow; not widely used
RC4	Stream Cipher	40-2048 bits	8 bits (1 byte)	Was widely used in SSL and WEP; increasingly deprecated
AES	Block Cipher	128, 192 or 256 bits	128 bits	Widely used; generally thought to be secure

3.2.3 Symmetric Cryptography Modes of Operation

Block encryption algorithms, such as AES, DES and 3DES, all operate on relatively small blocks of data, but most data that needs to be encrypted is much longer. Cryptographic *modes of operations* are techniques for combining repeated invocations of block algorithms so that they can be used on more data.

Understanding modes of operation is important for people who are developing or evaluating cryptographic software because the mode of operation can impact the security and flexibility of the system.¹⁶

While many modes of operation have been devised, only a few are widely used:

- *Electronic codebook (ECB)* is the simplest mode of operation to implement, but it's also the least secure. This mode uses the same key to encrypt each block of data. The problem with this mode is that blocks that have the same content will encrypt to yield the same output. In practice, this makes it possible for an attacker to learn a great deal of information about the plaintext merely by observing the repeated portions of ciphertext. For most applications, this mode should not be used.
- *Cipher block chaining (CBC)* overcomes the problem of ECB by encrypting each block as a function of the block's plaintext and the previously block's ciphertext. As a result of this chaining, the same block of plaintext will be encrypted differently each time. Because the first block of the message doesn't have a previous block, it is encrypted

by combining the plaintext and a randomly generated block of data called the *initialization vector* (IV). The IV does not need to be kept secret, but it does need to be different for every message that is encrypted. Because the IV is needed to decrypt the message, it is usually attached to the ciphertext. Disclosing the IV does not jeopardize the security of the ciphertext.

- *Counter mode* (CTR) is similar to CBC, except that the IV is replaced with a counter. This mode shares the advantage with CBC mode that long blocks of data that repeat are encrypted differently. CTR further has the advantage that it is possible to start decrypting at any point in the encrypted data, making this mode a popular choice for disk encryption algorithms. This is in contrast to the CBC mode, which must begin decrypting from the first block in the sequence. CTR further has the advantages that errors in the cipher text do not propagate, and CTR encryption and decryption can be parallelized. Despite these advantages, CTR is not widely used.

One of the problems with the three modes discussed above is that there is no way to validate the authenticity of encrypted data: Any ciphertext can be decrypted with any key. There is no way, in principle, to look at decrypted information and determine if that information is correct or not—that is, there is no way to tell if the encrypted data was not modified or corrupted after it was encrypted. Usually this isn't a problem because most data files have internal structure, and this structure is not correct if the encryption does not succeed. However, it is inappropriate to rely on a chance property, such as being able to display a JPEG or open a file in Microsoft Word, to determine whether or not data is intact, because this property can sometimes be exploited by an attacker.

For this reason, there is another family of modes:

- *Authenticated encryption* (AE) is a family of modes that provide for both confidentiality and authentication. These modes rely on additional information that is injected into the ciphertext so that the decrypting program can verify that decryption was performed using the correct key and that the decrypted plaintext was not modified after it was encrypted. Unfortunately, some of the authenticated encryption modes have been patented and, as a result, they are not widely used.

3.2.4 Entropy, Random Numbers and Key Generation

The security of an encrypted document depends on both the algorithm and the encryption key. Until now, this chapter has mostly focused on technical matters having to do with the algorithm: making sure that the algorithm itself is strong and correctly implemented, for example. However, other than discussing the key's length, this chapter has been silent on the characteristics of a good key or how to make a key.

In general, there are only two hard and fast rules for strong encryption keys. The first is that the key should be truly random. The second is that the key should be used as infrequently as possible—ideally just to protect a single message.

Creating a key that's random is surprisingly difficult. People are notoriously bad at picking random numbers. Surprisingly, so are computers. Computers are designed to be deterministic machines. Given the same input, computers are supposed to generate the same output. But the same output is precisely wrong when it comes to generating encryption keys. We want every key to be different, even if the keys were generated in the same way.

Because encryption keys are both so important and so common, modern computers have special-purpose hardware and software that exists solely for the purpose of creating random numbers appropriate for use in cryptography. Most systems collect randomness from many different sources and use that randomness to scramble the bits in a mathematical structure called an *entropy pool*. Most entropy pools are implemented as a collection of several thousand bits. Every time another random bit is collected, that bit is used to flip *half* of the bits in the pool. The half that's picked depends upon the new random bit and all of the existing bits in the pool—essentially, the pool is a giant cryptographic hash function. When random numbers are needed for generating keys, those numbers are extracted from the pool with additional processing.

There are many sources of randomness that can be used for the entropy pool. For example, a computer can generate a few bits of randomness every time the user strikes the keyboard or moves the mouse—the random bits might be related to the number of nanoseconds since the previous keystroke or mouse movement. Digital cameras, microphones and even network activity are other potential sources of randomness. The best sources, though, derive their randomness from quantum mechanics. For this reason, many microprocessors have a hardware random number generator that acquire entropy from thermal noise.¹⁷

3.2.5 Applications of Symmetric Cryptography

Throughout this section, we've seen a few uses of secret-key encryption. Here they are again, each with a bit more explanation:

- *Documents with passwords.* One of the most common uses of symmetric encryption is to encrypt documents. Both Microsoft Office and Adobe Acrobat use symmetric encryption when a document is given a password to open. Typically, these systems are implemented with a two-step encryption, where the document is encrypted with a randomly generated 128-bit or 256-bit encryption key and then the key itself is encrypted with a hash of the user's passphrase. The encrypted passphrase can be stored with the document or separately from the document for added security. Document encryption systems can also make multiple copies of the encryption key and encrypt each with a different passphrase, allowing multiple passphrases to unlock the document. This is how some systems implement a so-called master password.
- *Block-level disk encryption.* Instead of encrypting at the document level, this approach applies encryption at the driver layer, separately encrypting each disk sector. Block-level disk encryption transparently encrypts every file stored on the disk: It can encrypt nonfile data as well, such as virtual memory and hibernation data (e.g., the contents of physical memory stored on disk during hibernation). Disk encryption schemes typically use a variant of counter mode so that any disk block can be decrypted without decrypting the adjacent blocks.
- *Persistent VPNs.* If two networks are going to be connected for a long period of time using a VPN, it may be advantageous to connect them with a static encryption key. In this case, the system administrator would create a random encryption key and program it into all systems that require access to the VPN.
- *TLS.* After a cryptographic session is established using asymmetric cryptography, symmetric encryption algorithms are used for bulk data encryption for data sent over the world wide web using TLS.

- *Wireless networks.* Symmetric encryption can also be used on wireless networks. For example, the typical use of the WPA2 encryption system requires that all units be programmed with the same passphrase or key. This passphrase or key is then used to derive a specific symmetric encryption key used to secure data sent over the wireless network.

Here are some additional uses of applied secret key encryption that have not been discussed so far:

- *Encrypted databases.* Instead of storing encrypted data in a file, the data can be stored in a database. There are many strategies for database encryption. The entire database file can be encrypted with a single key; individual rows or columns can be encrypted; rows, columns or cells can be encrypted with keys stored in other rows, columns or cells; the database can be encrypted but the index left unencrypted to allow for rapid searching; and so on. Each strategy has different trade-offs regarding security, performance and recoverability. There is no one right way to encrypt databases, as different schemes are designed to address different threats and satisfy different performance requirements. Advanced approaches for encrypting data in databases are discussed in Section 3.6.4.
- *Cryptographic erasure and retention rules.* Taking advantage of the fact that encrypted data cannot be decrypted without the key, there are a number of schemes for ensuring complete erasure of a storage media by simply erasing the key. For example, it typically takes two to three hours to overwrite all of the sectors of a hard drive and another two to three hours to verify that they have been overwritten. If the drive is encrypted with a key, the entire contents of the hard drive can be rendered indecipherable by erasing the key. At a law firm, each case file could have its records encrypted with a case-file-specific key. Then, if all of the records having to do with a case file need to be erased, this specific key could be wiped. This approach would even make inaccessible document backups stored on tape or optical media or in the cloud.
- *Secret sharing.* A single document can be encrypted with a single key that is then split into multiple shares using a mathematical approach

called *secret sharing*. These schemes are quite flexible, allowing a key to be split into any number of shares and allowing it to be recovered with any number of those shares. For example, if an organization has seven auditors, the key could be split so that any three auditors, working together, can recover the encrypted data.

3.3 Cryptographic Hash Functions

Hash algorithms are fast mathematical functions that take an input of any length and produce a small output (typically 16 to 64 characters) that looks random, but that is in fact completely determined by the input. Strong hash functions have the property that the output cannot be predicted from the input without running the algorithm, and changing any bit in the input will change, on average, half of the bits in the output. Hash functions that do not have this property should not be used.

Hash functions are sometimes erroneously referred to as *digital fingerprints* because, in practice, a specific cryptographic hash function for a specific file is distinctive the same way that every person has their own set of distinct fingerprints. But the term is erroneous for a variety of important reasons:

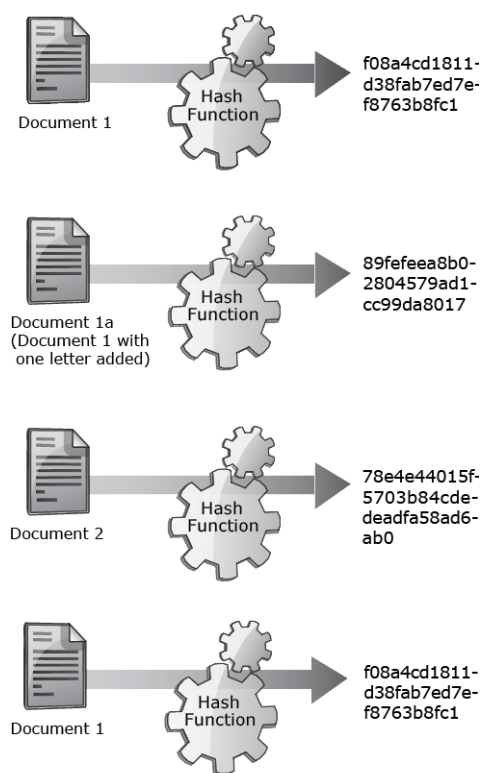
- Different hash functions will produce different outputs for the same document, so in addition to knowing a document's hash, it is important to know the algorithm that was used to produce the hash. Some hash functions can also be *keyed*, so that the document's cryptographic hash depends on the algorithm, the document and the key.
- Even though no two people have been found to have the same fingerprints, it is possible for many different documents to have the same hash value. Such occurrences are called *hash collisions*, and they are the mark of a hash that is no longer secure.
- Because fingerprints are created by a physical process and people's fingerprints change over time, each set of fingerprints or latent prints from the same individual is slightly different. As a result, human fingerprints must be matched with a comparison function that allows for slight variations. Cryptographic hashes, by contrast, are precisely matched bit for bit.

- Latent prints left at the scene of a crime are typically partial prints and can sometimes match many different people. Only an expert can determine whether or not two prints actually match. File hashes, on the other hand, are always complete and can be matched by anyone, or any program—no special training is required.
- Files don't have fingers, so they can't have fingerprints.

Figure 3-3 shows that different inputs, with very minor changes, result in profoundly different hash values.

The idea of cryptographic hash functions first proposed by Ralph Merkle in his 1979 PhD thesis; has been widely adopted for many applications in both computer security and elsewhere.¹⁸ *Digital signatures* combine hash functions with public key cryptography in a way that makes it possible to certify that a document has not been changed since it was digitally signed (see below). Cryptographic hash functions are also a key building block for bitcoin and other cryptographic currencies.

Figure 3-3: A Hash Function Applied to a Variety of Inputs



3.3.1 Cryptographic Hash Algorithms

There are many different cryptographic hash algorithms; Table 3-2 provides a comparison of the popular algorithms currently in use.

Message Digest 5 (MD5), developed by Ronald Rivest, was the first widely used cryptographic hash function. MD5 was fast and secure. The underlying approach used by MD5 was incorporated by NIST into the Secure Hash Algorithm (SHA) when it was first proposed in 1995, and into improvements that were published in 2001. Although SHA-1 was originally much slower than MD5, implementation improvements combined with new instructions added to microprocesses have made the difference insignificant for most applications.

SHA3, a new hash algorithm chosen by NIST through an open competition, is based on a different set of mathematical principles. SHA3 is not intended to replace the previous algorithm. Instead, it is an alternative algorithm that can be used in systems that support pluggable algorithms, such as most TLS implementations. With multiple algorithms based on different underlying mathematics, organizations have more flexibility when algorithmic vulnerabilities are discovered in the future: Instead of having to distribute both new clients and new servers, all that is required is changing a configuration file on the server—a far easier task.

Table 3-2: Comparison of Popular Hash Algorithms. SHA-256, SHA-384 and SHA-512 are all Variants of the SHA-2 Algorithm.

Hash Algorithm	Output Size (bits)	First Published	Status in 2019
MD5	128	1992	Depreciated; should not be used in applications that require confidentiality or integrity
SHA-1	160	1995	Being phased out; should not be used for new applications
SHA-256	256	2001	Widely used
SHA-384	384		
SHA-512	512		
SHA3-224	224	2015	Chosen by NIST through an open competition in 2013; significantly slower than SHA-256 without hardware support
SHA3-256	256		
SHA3-384	384		
SHA3-512	512		

3.3.2 Applications of Hash Functions

There are many applications for hash functions:

- *Converting pass phrases to cryptographic keys.* Encryption keys are typically displayed as hexadecimal strings. For example, a 256-bit key could be written as d0e47486bbf4c16acac26f8b653592973c1362909f90262877089f9c8a4536af. Such keys are hard to type and even harder to remember. Instead, a standard approach is to ask the user to type a passphrase (e.g., “Hello World!”) and convert it to a hexadecimal string using a hash function. (Here, the conversion is done with SHA3-256.)
- *Identifying versions of documents.* No two documents have the same value for a given hash function, and the hash value of a document does not depend on either its file name or its modification time. As a result, the file’s contents can be uniquely identified by simply specifying the document’s value when it is hashed with a hash function—assuming that the hash function hasn’t been broken, of course.
- *Digitally signing documents.* After a document’s contents are hashed, the hash can be cryptographically signed using a public key algorithm and a person’s signing key. The document can then be verified by anyone with the document and the person’s public key by hashing the document and seeing if the signature matches.

Hash functions are easy to use, but like most things in cryptography, it is easy to use them in a way that is not secure. For example, although it’s common to derive an encryption key by simply taking a person’s passphrase and hashing it, this is not secure, because attackers have compiled lists of billions of hashes of popular passwords and passphrases. Instead, it is now regarded as best practice to combine the provided passphrase and a random number, called a *nonce*, and to hash the two together many thousands of times. The system then stores the random *nonce* along with the encrypted document. This approach both eliminates the usefulness of those hashed passphrase lists and significantly slows down brute force attacks that try many different passwords and passphrases.

3.4 Public Key (Asymmetric) Encryption

Asymmetric encryption algorithms use one key to encrypt data and a second key to decrypt the data. These keys are typically called the *public* and *private keys*, and as a result asymmetric cryptography is frequently called *public key cryptography* because one key is made publicly available and the other key is kept private.¹⁹ The terms *public* and *private* can be misleading, however, since the email encryption schemes perform encryption with the public key, while digital signature schemes perform decryption with the public key. To avoid confusion, this chapter will use the phrases *encrypting key* and *decrypting key* when discussing encryption, and *signing key* and *verifying key* when discussing digital signatures.

3.4.1 Algorithms and Key Sizes

Asymmetric algorithms, also called public key algorithms, are typically much slower than their symmetric counterparts. Many are based on mathematical properties that arise through the manipulation of prime numbers. Because of their reliance on certain mathematical properties, they have been harder to discover, but it is easier to understand their security, because the security is directly related to a hard problem in mathematics, such that cracking the encryption system is the same as solving a long-studied, hard problem. Because some of these problems have been studied for decades and, in some cases, for centuries, they are well understood, and the strength of the cryptographic protection can be readily ascertained.

It is generally easier to crack an asymmetric encryption key than a symmetric key of the same key length. In part, this is because symmetric keys are simply random collections of bits, while asymmetric keys are numbers with specific mathematical properties. Another reason is that public keys are public, so an attacker who is targeting a public key system can create any number of chosen plaintext/ciphertext pairs.

There are several public key systems currently in use:

- *RSA* relies on the fact that it is easy to multiply two prime numbers together to create a composite, but it is relatively difficult to take a composite number and decompose it into its prime factors. *RSA* has the property that the private and public keys are interchangeable; that is, messages encrypted with the *RSA* public key can be decrypted with the private key, and messages encrypted with the private key can be decrypted with the public key. In this way, *RSA* keys can be used both

for message secrecy and for digital signatures. This leads to occasional confusion, as some RSA implementations use a single private key for decrypting messages and signing digital signatures, while other implementations use keys that are distinctly created and used for each purpose. The Personal Identity Verification (PIV) and Common Access Card (CAC) smart cards used by the U.S. government actually contain three RSA key pairs: One is used for encryption and decryption, one for electronic signatures and one for logging in to remote systems. RSA was covered under U.S. Patent 4,405,829 (itself a prime number) issued on September 20, 1983; exclusive rights to the patent expired on September 20, 2000.

- *The Digital Signature Algorithm* (FIPS-186) is a public key algorithm created by the U.S. government in the 1990s and published on December 1, 1994, as an alternative to RSA. Compared with RSA, the DSA had three distinguishing features: (1) the algorithm was not covered under the RSA patent; (2) when it was created, the algorithm could be used for digital signatures but not for encryption, and as a result the algorithm did not fall under export control regulations at the time and (3) the DSA requires significantly more computational effort to verify signatures than does RSA. The algorithm itself is described in U.S. Patent 5,231,668, filed on July 26, 1991, by David W. Kravitz, a former NSA employee; the U.S. government made the patent available for use worldwide and royalty free. (This patent right was disputed by Dr. Claus P. Schnorr, who claimed that DSA was actually a variant of the digital signature algorithm described in his patent, U.S. Patent 4,995,082, which has also now expired).
- *Elliptic Curve Cryptography*—Both the RSA and DSA algorithms make use of mathematical properties that arise from performing mathematics in a restricted range of numbers called a *number field*. It is possible to perform the same kinds of operations in a different kind of mathematical range called an *elliptic curve*. Performing the math in an elliptic curve has the advantage of making it dramatically harder to factor numbers and, thus, crack a public key. The result is that public key cryptography performed in elliptic curves can achieve the same security

with much smaller keys, making the resulting cryptography faster and more energy efficient.

In addition to these systems, there are several other public key algorithms. In general, these other algorithms are only of academic curiosity and should not be used in production systems. Even though they work, they do not provide compelling advantages compared to existing standards, and their lack of widespread adoption means that any implementations are more likely to have significant security vulnerabilities.

3.4.2 Digital Signatures

Digital signatures are similar to other kinds of signatures in many ways:

- Like a human signature, a digital signature is a kind of mark that can be affixed to a digital document to identify the signer.
- Just as a person can have many different ways that they sign their name, so too can a person have more than one digital signature.
- Just as corporations and governments can have their own “signatures,” such as the Great Seal of the United States, so too can corporations and governments have their own digital signatures.
- Signatures can be used to authenticate other signatures. For example, in the physical world, a driver’s license typically displays a photo and signature of the driver, and on the sealed plastic is a seal of the certifying state. So too can digital signatures be used to certify one another. This process is performed with *digital signature certificates*, which typically contain a name, address and other kinds of digital identifiers, signed by some kind of certifying authority called a *certificate authority* (CA).

But digital signatures are far more powerful than physical signatures:

- Unlike physical signatures, digital signatures certify that a document hasn’t been modified since it was signed. This property is called *integrity*.
- In order to verify a physical signature, it is necessary to have a copy of the signature. Thus, any organization that can verify a physical signature

can forge it as well. Digital signatures, in contrast, are created with a private key but verified with a public key. As a result, the only way to dispute the authenticity of a digital signature is by making a claim that the private key was compromised or by asserting the digital signature scheme itself mathematically broken. This property is called *nonrepudiation*.

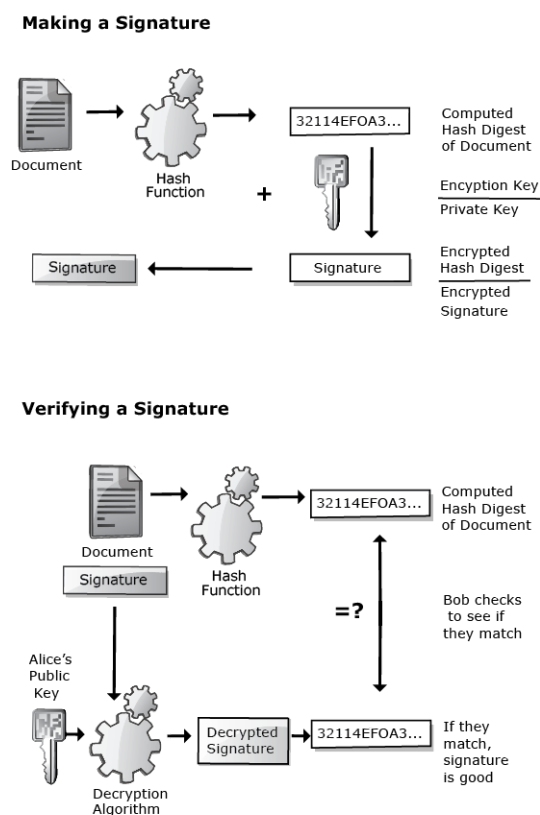
- As a result of *integrity* and *nonrepudiation*, a valid digital signature cannot be lifted from one document and fraudulently used to certify another.
- Although a physical signature must necessarily be affixed to the document that it certifies, this is not true of digital signatures. Thus, a signature can be distributed without a document, and then the document distributed at a later time. Such signatures are called *commitments* because they commit the signer to a statement that might itself be revealed at a later time. Commitments can be used to implement closed-bid auctions in a manner that not even the auctioneer knows the identities of the bidders. In this application, the bids consist of a bid value and a digital signature. The winning bid is published on the internet. At this point, the winner reveals the document that matches the signature. The document contains the bidder's bid and their name.

Digital signatures combine two mathematical techniques discussed earlier in this chapter, cryptographic hash functions and public key cryptography (see Figure 3-4):

- To *sign* a document, a program first computes the hash value of that document. Next, the program encrypts the hash value with the asymmetric signing key.
- To *verify* the signature, the signature is decrypted with the verification key, which has been widely distributed. (For example, it may be on an organization's web page, it may be downloadable from a public directory, or it may be built into software such as a web browser.) This produces the claimed hash value of the document.

- Finally, the document is re-hashed to see if the hash values match. If the two hashes match, the verifier knows two things: (1) The document has not been modified since it was signed and (2) the document was signed by the signing key that matches the verification key.

Figure 3-4: Signing and Verifying a Digital Signature



A private signing key can be thought of as a signature stamp in the physical world—it can stamp a signature on a document or on a piece of paper that is affixed to the document. And just as with the theft of a signature stamp, if person's private signing key is stolen, the thief can sign the victim's signature without anyone being able to tell the difference.

A person or program that verifies a digital signature is called the *relying party* (RP). Verifying the signature requires that the RP obtain the signer's public verification key. These keys are distributed as *digital certificates*, which are themselves digitally signed by organizations called *certificate authorities*. See section 3.5 below for further details.

3.5 Public Key Infrastructure

The inventors of public key cryptography didn't give a lot of thought to the problem of matching up people's names with their public keys. In their seminal paper, "New Directions in Cryptography," Whitfield Diffie and Martin Hellman suggested:

Each user of the network can, therefore, place his enciphering key in a public directory. This enables any use of the system to send a message to any other user enciphered in such a way that only the intended receiver is able to decipher it... The enciphering key E can be made public by placing it in a public directory along with the user's name and address. Anyone can then encrypt messages and send them to the user, but no one can decipher messages intended for him.²⁰

That is, Diffie and Hellman envisioned some kind of public directory containing every person's enciphering key—a directory that would be implicitly trusted by all users of the system. Things haven't worked out that way, at least not yet. Diffie and Hellman's original vision was a massive directory of public keys belonging to individuals that other people could use to send secure electronic mail. Today's public keys are mostly used to certify the identity of organizations—and in particular, their web servers—not individuals. Instead of looking up a public key in a directory, web servers send their public keys directly to the web browser in a digital package containing the organization's name, its public key and the functions for which the public key can be used. The keys are trusted because they are digitally signed by yet another organization, this one trusted to certify that the public key belongs to the organization. The entire system is called PKI.

Properly implemented, PKI provides tools for obtaining and verifying public keys that belong to individuals, web servers, organizations and most other kinds of entities that require some form of digital identification. PKI also contains schemes for revoking keys after they have been abandoned or in the event that they are compromised. But today's PKI implementations have proven to be too complicated for most computer users to comprehend and too technical for them to care much about it. Instead, PKI operates mostly behind the scenes, securing web servers, mobile phones, secure chat and even chip-based credit cards.

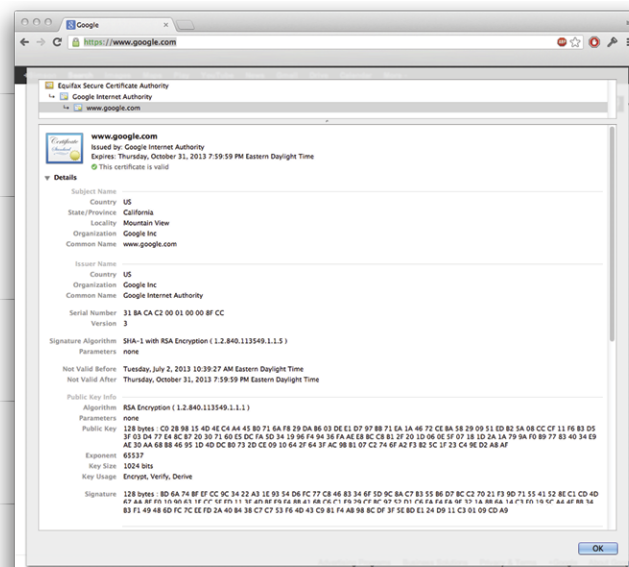
3.5.1 Certificates

PKI is based on the principle of *certification*. An entity called a *certificate authority* (CA) asserts (or certifies) that a particular *public key* belongs to a particular entity.

These assertions are stored in small electronic documents that are called *certificates*.

Figure 3-5 shows a portion of a digital certificate as displayed by the Google Chrome web browser for the *www.google.com* domain name. The certificate says that it was issued by the Google Internet Authority and that authority's certificate was itself certified by the Equifax Security CA. The Equifax authority is built into the computer on which the browser is running, which is why it has a different icon. The certificate was valid from July 2, 2013 through October 31, 2013.

Figure 3-5: The *www.google.com* Certificate as Shown by Google Chrome on MacOS



Google and the Google logo are registered trademarks of Google Inc., used with permission.

The portion of the certificate display that says “Public Key Info” shows the technical information about the key that is being certified. In this case, it is an RSA encryption key that is 128 bytes (1024 bits long). The first byte is C and the last byte is AF. RSA keys require something called an exponent; in this case, the exponent is 65537. The key is certified to be used for encryption, verification and deriving.

This certificate was provided to a web browser when a TLS connection was initiated to the server *www.google.com*. The certificate says that the browser should use the key C0 ... AF when connecting to the server. Having received this certificate, the browser would create a randomly generated session key, encrypt the key and send it back to the server—the very steps that are described above in Section 3.4.2.

The digital certificate represents a promise made by a third party, in this case an organization called Thawte SGC CA, that the public key on the certificate really does belong to a company called Google that operates a web server at *www.google.com*. Here's how:

1. The digital certificate contains not only the server's public key, but also the server's domain name system (DNS) name and the name of the company that runs the web server. The browser uses the DNS name to verify that it has the certificate for the correct server; the browser shows the company name to the user, allowing the user to verify the corporate name.
2. Google got the certificate sometime before October 25, 2011. To get the certificate, Google gave Thawte SGC CA a document called a *certificate signing request* (CSR) which consisted of Google's public key, its corporate name (Google Inc), its domain name (*www.google.com*) and various legal documents that establish that the people who were presenting the information to Thawte actually had permission to act on behalf of Google. Thawte verified this information, put it on a digital certificate, signed the certificate with the Thawte private key and then gave the signed certificate back to Google. At this point, Google took the signed certificate and put it on its web server.
3. The browser can verify the information on the certificate by verifying the digital signature. To verify the signature, the browser computes the cryptographic hash of all the information on the certificate *other than the signature*. Let's call this hash H_1 . Next, the browser takes the signature that's on the certificate and *decrypts the signature with the CA's public key*. Let's call this decrypted value H_2 . Finally, the browser checks to see if $H_1 = H_2$. If they are equal, the signature validates, and the information on the certificate is the same information that was there when the signature was signed.

The previous three steps rely on two presuppositions. First, that the browser has a copy of Thawte's public key; second, that Thawte behaved in a trustworthy manner. Both of these presuppositions are the result of a deal between Thawte and the company that created the web user's web browser. The companies that make

web browsers, including Microsoft, Apple, Google, the Mozilla Foundation and others, have all evaluated Thawte and concluded that the company is a trustworthy CA. That is, they trust Thawte's promises on certificates. As a result of this evaluation, the browser vendors have agreed to put a copy of Thawte's public key into their browsers.

Recall from above that a primary vulnerability of TLS is that a TLS proxy can intercept a TLS connection, decrypt it and then open a new connection to the destination. Digital certificates can't stop such interception attacks, but they make it possible to discover them when they happen. If the web browser in Figure 3-5 were connected to a TLS proxy, then the certificate would be signed by the proxy, and not by Thawte.

3.5.2 Client-Side PKI

In addition to verifying the identity of websites, PKI can also verify the identity of users. This process is similar to the way websites are validated, except the certificate is issued to an individual, not to an organization.

Client-side PKI systems require a means for the individual to securely maintain their private key and to use it to prove their identity with the key when this proof is required. Currently, there are two ways individuals can maintain their private keys:

1. The private key can be stored inside a smart card or another kind of physical token. This is the most secure means for an individual to maintain a private key. The private key never leaves the smart card. Instead, when the individual needs to sign something, the cryptographic hash is provided to the smart card. Most smart cards also require that the individual have a personal identification number (PIN), which is typically four to eight digits long. The user inserts their smart card into a reader, provides the PIN, and the identity is proven. Most smart cards will lock if the wrong PIN is provided three times in a row.²¹
2. The private key can be stored in an encrypted file on the user's computer. In order to use the private key, the user provides a password that is used to decrypt the key.

There are two reasons smart cards are significantly more secure than storing the private key in an encrypted file. First, the private key does not leave the smart card

under normal circumstances. This makes the key more resistant to malware, since malware cannot directly access the key and copy it to another system. The second is that the user normally removes their smart card from the reader when the smart card is not in use. This significantly reduces the chances that the key can be used without the user's knowledge.

Currently, there are four common uses for client-side PKI:

1. Using a web browser, users can provide their identity to a remote website. Here PKI is a useful alternative to a system of usernames and passwords.
2. With client-side PKI, a user can add a signed name to a digital document. Adobe Acrobat provides this functionality.
3. Client-side PKI can also be used to certify the contents of the digital document. Both Microsoft Word and Adobe Acrobat provide this functionality.
4. Users can digitally sign software, asserting that they are the author and that it has not been modified since it was created. Digital signatures on software are available on Microsoft Windows, MacOS, iOS and Android. Sometimes the signatures are created on behalf of organizations, rather than individuals, but even these signatures are created with client-side PKI.

3.5.3 Certificate Revocation

Private keys are valuable, and they can be stolen, which allows the thief to impersonate the certificate's owner. Private keys can also be lost or destroyed, which would prevent the owner from decrypting messages that are sent. To address these two possibilities, workable PKI systems include a feature called *certificate revocation* that allows the certificate's owner or issuer to indicate that a certificate should no longer be used or trusted.

There are three approaches for certificate revocation:

1. When a certificate is issued, the certificate's owner can also obtain a *revocation certificate*. This revocation certificate can then be kept in a secure place and published if the private key is compromised.

2. Alternatively, most CAs operate a *certificate revocation list* (CRL), which is a list of all of the certificates they have issued that have subsequently been revoked. These lists can become quite large, as certificates that have been revoked remain on the CRL until they expire.
3. Finally, most CAs operate an online certificate revocation service. Most of these services are based on the *Online Certificate Status Protocol* (OCSP) standard.

While it is possible to revoke individual certificates, it is not possible to revoke a CA. For example, in July 2011, the CA DigiNotar, a Dutch CA owned by VASCO Data Security International, apparently issued a certificate for the domain name *.google.com. The problem is that DigiNotar didn't issue the certificate to Google—it appears that it was issued by the government of Iran, which allegedly used the certificate to spy on Iranian citizens accessing Gmail and Google docs.²² After this was discovered, vendors such as Apple and Microsoft had to distribute patches for web browsers and operating systems to remove the DigiNotar CA certificates from their systems.

3.5.4 Time

Because certificates have validity periods, it is necessary for computers that use PKI to know the current time. And they must know it securely: If a computer can be forced to have the wrong time, then it can be convinced that a certificate is valid when it has, in fact, already expired. Time is also used by computers to determine if updates can be applied, and for a whole host of other functions. As a result, it is necessary for modern computers to know the correct time.

There are many ways for computers to reliably learn the correct time, including:

- Using the internet Network Time Protocol (NTP)
- Using a global positioning system (GPS) receiver
- Learning the time from a cellular network
- Using the Windows Time Service

Currently, none of these protocols use cryptography to assure that the time provided is correct. Fortunately, attacks on network time are rare.

3.5.5 PKI Limitations and Extended Valuation Certificates

The PKI system works pretty well, but it is far from perfect. In fact, today's PKI system is badly frayed. Worse, the more it is used, the more problems are exposed.

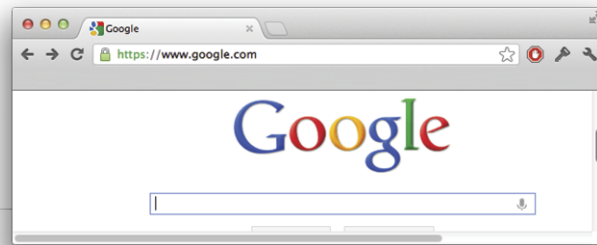
Thawte is a widely trusted CA, but it is hardly the only one. Modern web browsers have more than 100 CAs built into their browsers, including well-known companies like AOL Time Warner and Wells Fargo, the national CAs for Belgium and China, and companies with suspicious-sounding names like "AAA Certificate Services" (which is a name used by Comodo, a commercial CA).

The current system of multiple CAs was designed to allow different countries to have their own CAs, but also to enable competition in the free market. The problem is that there is no practical means for users to distinguish between high-quality CAs and bargain basement ones. As a result, all CAs are equally trusted. This can create problems, as different CAs have different procedures and different security standards. Organizations can publish *Certification Authority Authorization* (CAA) records with their DNS to inform web browsers to only trust certificates from a specific authority. CAA is specified in RFC 6844 and implemented by some web browsers.

Extended Valuation (EV) certificates were an attempt to create a high-quality certificate. EV certificates look different in the web browser, and CAs are supposed to demand higher levels of assurance that they are dealing with the actual entity requesting the certificate. Unlike traditional TLS certificates, EV certificates also contain more information about the provider. Not surprisingly, EV certificates were also more expensive.

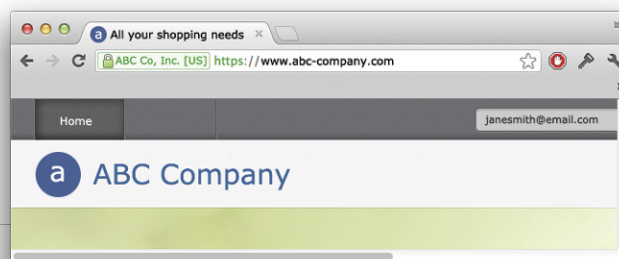
Some security professionals disputed the effectiveness of EV certificates. They argued against the very premise of EV certificates, saying that the rigorous checking of identity and liability protection were supposed to be part of the original certificates and should not be reserved only for EV certificates. What's more, as the price of EV certificates dropped, CAs automated the detailed identity checking and certification that the EV brand required. Today, EV certificates are used to provide additional branding, but they do not appear to provide the additional security hoped for by their creators (see Figure 3-6).²³

Figure 3-6: Website without an EV Certificate



Google and the Google logo are registered trademarks of Google Inc., used with permission.

Figure 3-7: Website with an EV Certificate



3.6 Cryptographic Systems: Putting It All Together

In this chapter, we have separately introduced symmetric cryptography, cryptographic hash functions and asymmetric cryptography, discussing the applications and limitations of each. However, most cryptographic systems combine all of these kinds of algorithms. Such systems are sometimes called *hybrid systems*.

In this section, we discuss three such kinds of systems that are used to secure data sent over the web, email and digital documents.

3.6.1 Securing the World Wide Web with TLS

TLS is a protocol that is used to encrypt data as it is sent over the internet. The most common use of TLS is to encrypt web pages. When a web browser attempts to access a web page that begins with the letters *https*, the browser attempts to download the page using TLS encryption. Asymmetric cryptography is used to encrypt and send a randomly generated symmetric key that, in turn, is used to encrypt the contents of the internet connection and to sign a separate, randomly

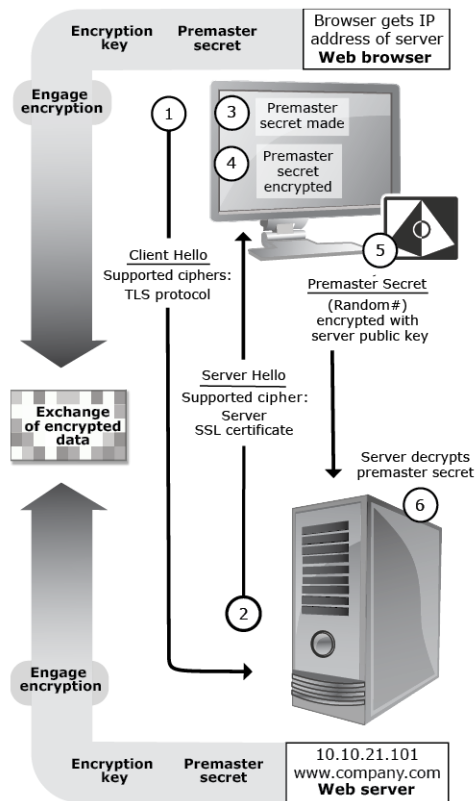
generated number to establish the authenticity of the website and optionally the client. (As mentioned in the introduction, TLS was originally called the SSL and is still occasionally called SSL or SSL/TLS.)

Although the details of TLS and Secure/Multipurpose Internet Mail Extensions (S/MIME) are beyond the scope of this chapter, the remainder of this section presents a skeletal description of both so that you can understand the role played by both asymmetric and symmetric cryptography as well as the need for a functioning PKI, which will be described in the following section.

When a user types the URL *https://www.company.com/* into a web browser, the following typically happens:

1. The web browser issues a DNS request to convert the name *www.company.com* into an internet protocol (IP) address.
2. The web browser opens a TLS connection to the web server at the specified IP address (see Figure 3-8). The browser sends a *ClientHello* message containing information about the TLS protocols that the client supports, a set of ciphers it supports and a random number.
3. The server responds with a *ServerHello* message, which contains information about the server, including the ciphers it will support, a random number, its TLS certificate and a *ServerHelloDone*. The TLS Certificate contains a variety of information including name of the web server (in this case, *www.company.com*), the server's public key and a set of dates specifying the key's validity period (i.e., at what date and time the key started being valid, and when it expires).
4. The web browser creates a randomly generated number called a *PreMasterSecret*. Typically, this key will be 128 or 256 bits in size. Call this K_{Session} .
5. The web browser encrypts the *PreMasterSecret* with the server's public key and sends this to the server.
6. The server decrypts the *PreMasterSecret*.
7. Both the server and the client use the same algorithm to convert the *PreMasterSecret* into an encryption key, which they now use to encrypt the data for all of their subsequent communications.

Figure 3-8: Normal Client-Server TLS Communications



The security of this scheme depends on two things. First, it requires that the web browser be able to make a truly random *PreMasterSecret*. If that value is not random and can be guessed by an attacker, then an attacker can decrypt the SSL session. The first web browsers in the 1990s did not have a good source of randomness and used the time of day to initialize their random number generators. This seemed random to the programmers at the time, as the resulting keys were always different. But “always different” does not mean unpredictable. Academics were able to demonstrate in the lab that it was relatively easy to guess the random number with only a few thousand different attempts. As a result, it was quite easy to render these early cryptographic systems useless.

The second security requirement is that the web browser must have the public key certificate belonging to the authentic server and not some interloper. Of course, it's not possible to distribute web browsers with the public key certificates of every web server on the planet, so instead web browsers are distributed with certificates for CAs, and these CA certificates are used to verify the TLS certificate that is downloaded to a browser.

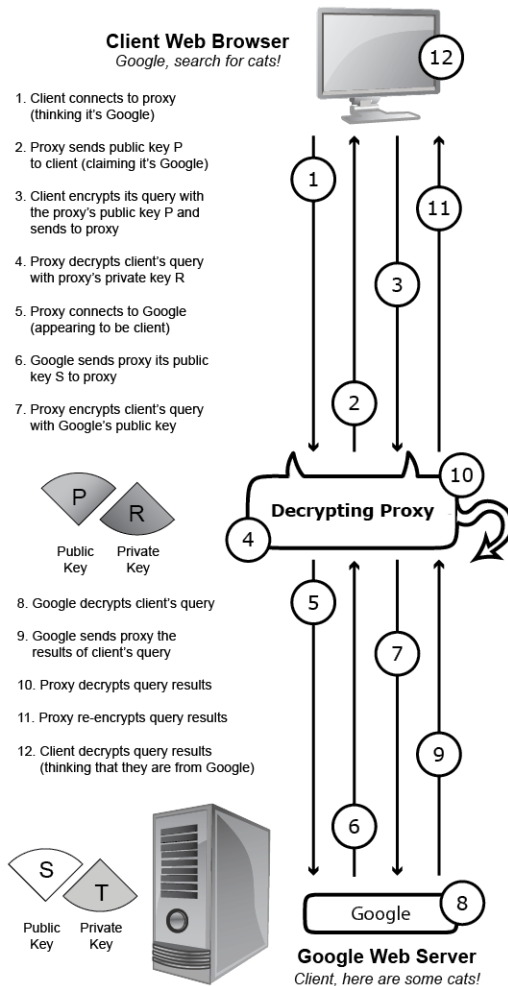
Sometimes a web browser does not connect directly to the web server but instead connects to a TLS decrypting proxy. The browser creates a secure connection to the proxy, which then creates a secure connection to the remote website. This configuration allows the proxy to view the unencrypted contents of the connection. This sort of configuration was once called a man-in-the-middle attack, but it now routinely happens in large organizations that want to monitor the contents of web traffic.

Here is one way that a TLS decrypting proxy can eavesdrop on TLS communications. (The changes specific to the decrypting proxy are presented in **bold**):

1. The web browser issues a Domain Name System (DNS) request to convert the name *www.company.com* into an IP address.
2. The web browser opens a TLS connection to the web server—**but the communication is intercepted and goes to the TLS proxy.**
3. **Now, instead of receiving the authentic server's TLS certificate, it receives a certificate that has the legitimate company's name but the public key belonging to the proxy.**
4. **The proxy opens a TLS connection to the *www.company.com* web server.**
5. The web browser establishes a TLS connection **with the proxy.**
6. **The proxy establishes a TLS connection with the remote web server.**
7. **All three computers, the client, the proxy and the remote web server, are now communicating with encryption, but the connection's contents are being decrypted by the proxy using one key and then re-encrypted by the proxy using another. Both the browser and the server observe that the communications are secure, but they are in fact being systematically monitored.**

This is shown graphically in Figure 3-9.

Figure 3-9: A Decrypting TLS Proxy



Decrypting TLS proxies is controversial. They are widely deployed by organizations that wish to monitor their users' access of the internet, but they are also used by governments that wish to monitor the web use of their citizens. Proxies can be detected by web browsers because the certificate they receive is that of the proxy, not of the remote web server. To help address this potential vulnerability, web browsers can alert users or even be configured to stop operation if a remote website's public key changes. Google's Chrome web browser implements *certificate pinning* and will refuse to connect to *www.google.com*.

As can be seen, TLS is a complex protocol that is the result of many years of engineering, analysis and revision. Although the initial version of the protocol was thought to be secure, additional analysis found important flaws that were later corrected. This is yet another example of why it is better for most organizations to use existing encryption protocols rather than attempt to create their own; when organizations use an existing protocol, they benefit from the work that others have

performed in the past and will continue to perform after the organization adopts the protocol. When flaws are discovered in the future, the organization again benefits from the use of standards, because the software will be patched, and the organization can adopt the patches. On the other hand, organizations that design and implement their own protocols must continue to look for flaws in their implementations and then patch those flaws as they are discovered. Otherwise, their systems will become less secure with the passage of time.

3.6.2 Email Encryption with S/MIME and PGP

The S/MIME protocol allows email messages to be digitally signed to verify the sender and encrypted so that they can only be deciphered by their intended recipient. S/MIME has been an internet standard since 1999 and is fully supported by Microsoft Outlook, Apple Mail (on both the desktop and iPhone) and Mozilla's Thunderbird mail client. Nevertheless, S/MIME is rarely used outside of a few select organizations because using S/MIME requires that email correspondents first obtain digital certificates. Organizations that have been successful deploying S/MIME generally provide digital certificates to their users. For example, the U.S. government provides every employee with an S/MIME certificate on the PIV card used by civilian employees and the CAC used by employees of the U.S. Department of Defense (DOD).

Pretty Good Privacy (PGP) is an alternative system for encrypting email. Unlike S/MIME, PGP using an alternative model for PKI called the Web of Trust. Instead of relying on CAs to certify an individual's public key, individuals create their own PGP public keys and then publish those keys either on a web page or by uploading the key to the PGP key server. Because anyone can upload any public key to the key server, PGP allows individuals to sign each other's public keys. This allows, for example, the human resources department of an organization to create its own PGP key and then use it to sign the public keys of the organization's employees. Alternatively, managers in the organization can sign all of the keys of their own employees as well as the keys of other managers and then instruct their employees to trust the signatures of the other managers. PGP's bottom-up approach to trust made it easier for the technology to take hold in highly technical communities, but the lack of tools for distributing keys to large numbers of people at the same time has limited its scalability. While millions of people use S/MIME on a daily basis, PGP is still largely restricted to small groups of technologists,

although the protocol has also been used by some civil liberties activists throughout the world.

3.6.3 Digital Rights Management

Digital rights management (DRM) systems are another cryptography application that has been widely deployed. Documents, movies and other kinds of digital media are distributed in encrypted form. These systems then use public key technology to identify the computers belonging to specific individuals. If an individual is authorized to access the content, the individual's computer is provided with an appropriate decryption key. Some of these systems perform the decryption in hardware—for example, in a graphics coprocessor—so that the decrypted content can be viewed on a screen or played through a speaker but is less susceptible to being captured in decrypted form and used for other, unauthorized purposes.

Many DRM systems use cryptographic erasure to block access to a document after a time period has expired. The software does this by automatically wiping the decryption key at a predetermined time.

3.6.4 Oblivious Random-Access Memory and Privacy Information Retrieval

Even when the information stored in a database is encrypted, access patterns of reads and writes can still reveal privacy-sensitive information. These access patterns are revealed to any adversary that can monitor when information is being written or read to specific records of a database—for example, by monitoring which encrypted blocks change over time. The access patterns are also revealed to the database itself, of course, which can be especially a concern when the database is being maintained by a third party in a cloud environment.

Using additional layers of encryption combined with sophisticated data access protocols, it is possible to mathematically protect these patterns such that an observer monitoring access patterns learns nothing, even if the observer can observe every read-and-write operation between the user and the database. Because this information is protected from any observer, it is protected from the database as well. This makes it possible for organizations to use cloud providers without fear of leaking sensitive information.

Oblivious Random-Access Memory (Oblivious RAM, or simply ORAM) describes a system that has the property that monitoring reads or writes between the user,

and the database reveals no side channel information. ORAM operates by encrypting the data that is written with a key only accessible to the user. This prevents an observer (or the memory system itself) from decoding the data that is stored. To prevent an observer from learning about the access patterns, ORAM systems typically perform additional read-and-write operations to different parts of memory whenever any information is read or written. Perfect security is obtained by reading and writing *every bit* of the remote memory system for every read or write operation, but this is highly inefficient and is not done in practice. Instead, work has focused on building systems that trade off increased efficiency by providing less than perfect security. (These systems use the word *memory* to describe the part of the ORAM system that stores information; mathematically, there is no difference between a memory bank and a database.)

The phrase *private information retrieval* (PIR) describes a range of protocols in which data can be retrieved from a database without revealing to the database or another observer the information that is retrieved. PIR systems are a subset of ORAM systems, in that they provide for data access but not necessarily for data modification. Some PIR systems allow for the database to perform sophisticated operations, such as searching for documents that match a particular keyword, or for retrieving encrypted documents in sorted order, all without knowing the underlying data that is being operated upon.

Although ORAM and PIR systems have been the subject of academic curiosity since the 1980s, recent advances in cryptography are making these systems practical. In particular, developments in homomorphic encryption aid the development of practical ORAM and PIR systems. It is thought that some of the vulnerabilities that have been discovered in Intel's SGX system can be overcome through the use of ORAM or PIR.

3.7 Summary

As this chapter has shown, encryption and digital signatures are two of the fundamental technologies for assuring privacy and providing security in the digital domain. They are not all-powerful—any technology running on a computer system can be circumvented. But unlike passwords and other technologies, encryption and digital signatures offer the promise of mathematically sound security. For this reason, encryption and digital signatures

are likely to play an increasingly important role in preserving privacy and assuring accountability in the digital world.

Endnotes

- ¹ Andrei Lapets, Nikolaj Volgushev, Azer Bestavros, Frederick Jansen and Mayank Varia, “Secure Multi-Party Computation for Analytics Deployed as a Lightweight Web Application,” www.cs.bu.edu/techreports/pdf/2016-008-mpc-lightweight-web-app.pdf (accessed October 2019).
- ² *New Oxford American Dictionary* Third Edition, (Oxford University Press, 2010).
- ³ Alex Hudson, “The secret code of diaries,” *BBC Today*, August 29, 2008, http://news.bbc.co.uk/today/hi/today/newsid_7586000/7586683.stm.
- ⁴ Andrew Lycett, “Breaking Germany’s Enigma Code,” *BBC History*, February 17, 2011, http://www.bbc.co.uk/history/worldwars/wwtwo/enigma_01.shtml.
- ⁵ The word *durability* is also used to describe the permanence of data stored for a long period of time. Data stored in off-site facilities may have poor availability but high durability.
- ⁶ W. Diffie and M. Hellman, “New directions in cryptography,” *IEEE Transactions on Information Theory* 22, no. 6, 644–654, (November 1976), <https://ieeexplore.ieee.org/document/1055638>.

- 7 Although the popular RSA encryption algorithm (invented by Ronald Rivest, Adi Shamir and Len Adleman in 1977) has the property that public keys and private keys are symmetric—that is, either key can decrypt information that is encrypted with the other—this property is solely a result of the mathematics employed by the RSA algorithm, and is not a property of public key cryptographic systems in general.
- 8 Simson Garfinkel and Heather Lipford, “Usable Security: History, Themes, and Challenges,” *Synthesis Lectures on Information Security, Privacy and Trust*, Morgan & Claypool, (2014).
- 9 Modern password systems don’t actually store the user’s password. Instead, they process the password with a one-way function. The password provided by the user is processed by the same one-way function: If the two processed passwords match, then they must have been the same. More discussion about password hashing can be found in the classic paper “Password security: a case history,” Robert Morris and Ken Thompson, *Communications of the ACM*, 22:11, 1979.
- 10 T. Dierks and C. Allen, “RFC 2246: The TLS Protocol Version 1.0,” January 1999.
- 11 These programs also use encryption when a file is saved with a “password to print” or “password to edit.” However, in these cases the decryption password is stored in the document itself. The restrictions against printing or editing provided by these programs are implemented in code, not with cryptography.
- 12 When attempting to break an encryption algorithm, it is common for cryptographers to first attempt their attacks against “weakened” versions of the algorithm that use fewer rounds. Variants of AES-128 with 9 rounds and AES-256 with 12 rounds have been shown to be susceptible to attack. See Alex Biryukov, Orr Dunkelman, Nathan Keller, Dmitry Khovratovich and Adi Shamir, “Key Recovery Attacks of Practical Complexity on AES Variants with up to 10 rounds,” *Fryptology ePrint Archive: Report 2009/374*, July 29, 2009.
- 13 National Policy on the Use of the Advanced Encryption Standard (AES) to Protect National Security Systems and National Security Information, National Security Agency (NSA), (June 2003), http://www.nsa.gov/ia/programs/suiteb_cryptography/index.shtml.
- 14 Eli Biham and Adi Shamir, “Differential Cryptanalysis of Snefru, Khafre, REDOC-II, LOKI and Lucifer,” *CRYPTO 1991*:156–171.
- 15 D. Coppersmith, “The Data Encryption Standard (DES) and its strength against attacks,” *IBM Journal of Research and Development*, 38 no. 3, May 1994, 243–250.
- 16 National Institute of Standards and Technology (NIST), *Block Mode Ciphers*, Information Technology Laboratory, Computer Security Research Center, last updated September 11, 2019, <http://csrc.nist.gov/groups/ST/toolkit/BCM/index.html>.
- 17 D. Eastlake, S. Crocker and J. Schiller, “RFC 1750: Randomness Recommendations for Security,” December 1994.
- 18 Ralph Charles Merkle, “Secrecy, authentication, and public key systems,” Department of Electrical Engineering, Stanford University, June 1979.
- 19 Many people think that public keys are invariably used for encryption and that private keys are used for decryption, but this is not necessarily the case. Further complicating matters, the most widely used public key algorithm (RSA) has the property that either key can be used for either encryption or decryption—a message encrypted with one key can be decrypted with the other—but this is not necessarily true of other public key algorithms. Further confusing the situation, email encryption schemes typically use the recipient’s public key to encrypt the message (which the receiver decrypts with its private key), but the sender’s private key to sign a message (which the receiver verifies with the sender’s public key).
- 20 Whitfield Diffie and Martin E. Hellman, “New Directions in Cryptography,” *Invited Paper, IEEE Transactions on Information Theory*, 22 no. 6, 644–654, (November 1976).
- 21 Although three times in a row is standard for smart cards, usability is dramatically increased when this number is increased to five or even ten, and increasing the limit does not significantly impact security. See

Sacha Brostoff and M. Angela Sasse, "Ten strikes and you're out: Increasing the number of login attempts can improve password usability," *Proceedings of the CHI 2003 Workshop on HCI and Security Systems*, (2003).

22 "DigiNotar Hacked by Black.Spook and Iranian Hackers," *F-Secure Labs, News from the Lab* (blog), August 30, 2011, <http://www.f-secure.com/weblog/archives/00002228.html>.

23 Jonathan Nightingale, "Fraudulent *.google.com Certificate," *Mozilla Security Blog*, September 6, 2011, <http://blog.mozilla.org/security/2011/08/29/fraudulent-google-com-certificate/>.

CHAPTER 4

Identity and Anonymity

Chris Clifton

IT poses new challenges and new opportunities for managing identity and the resulting impact on privacy. These are nicely summed up in the now-famous cartoon that appeared in the *The New Yorker* magazine in 1993, with the caption “On the Internet, nobody knows you’re a dog.”¹ Information technology enables us to remain anonymous—conducting transactions without revealing who (or

what) we are. But it also poses challenges—we may (wrongly) assume that we know who (or what) someone is.

Furthermore, advances in IT make it easier to defeat anonymization measures. Perhaps nobody knows we're a dog, but based on purchases of dog food, visits to veterinary medicine websites and so on, someone with access to all this information can make a pretty good guess. This poses real risks to personal privacy and the desire to remain anonymous during the course of everyday activities.

This chapter starts by categorizing types of digital identity, describing the different types of identity, how these can be used and how they are typically represented in information systems. This is followed by authentication, giving an understanding of methods of validating identity and the strengths and weaknesses of each. We then look at privacy issues that arise with digital identity, particularly how types of identity map to privacy law and regulation. Finally, we discuss anonymization techniques and challenges, including the basic principles and techniques that are available to de-identify data and the challenges in adequately anonymizing data with respect to privacy legislation.

4.1 What Is Identity?

Information systems don't contain people, only data about people. So, when we refer to identity, we really mean the link between a piece of information and the individual (or individuals) associated with that data. For example, a data item can be about an individual, created by an individual or sent to an individual. Identity captures what we know about who that individual is.

The clearest case of identity is when we know exactly who the individual is—we can link the data to a single person. This gives us an *identified individual*—the strongest form of identity.

A weaker form of identity is a *pseudonym*. With a pseudonym, we can link different data items about the same individual, but we don't know the actual person the data is about. The ability to create and use pseudonyms is a big privacy advantage of digital identity—we can detach online presence from the actual person. However, this kind of privacy can be illusory, as it is often possible to identify the actual person behind the pseudonym. This will be discussed in Section 4.4.1.

The weakest form of identity is *anonymity*. With truly anonymous data, we not only do not know the individual the data is about, we cannot even tell if two data items are about the same individual.

The differences can easily be seen using a formal definition. Assume we have a set of data items $D=\{d_1, \dots, d_n\}$, and an identity function $I(d)$ that gives us information on whom the data item d is about. If we can say that, for a known individual i , $I(d)=i$, then $I(d)$ is an identified individual. If we can say that $I(d_j)=I(d_k)$ (the two data items are about the same individual), but we do not know who that individual is, then $I(d_k)$ is a pseudonym. If we cannot make either statement (identified individual or pseudonym), then the data is anonymous.

A related concept is that of a *role*. Often, it is not important who an individual is, only that the person is authorized to perform an action. For example, a credit card account may have several authorized users, and the merchant only needs to know that one of the authorized users is making a purchase (a role), not which one (an identity). While this can be hard to do in person, electronic systems have capabilities that allow us to quickly distinguish between the role and the identity.

Another issue that arises is who can make the determination of identity. Say that Alice sent an email to Bob. We normally think of the email as being identified if Bob knows that it came from Alice, and he knows the actual person corresponding to the name Alice. However, an alternative exists when Bob doesn't know who Alice actually is, but the real person (Alice) is able to prove she wrote the message. This provides pseudonymity and privacy for Alice, and the option of revealing identity resides with the individual to whom the identity belongs. Keyed hash functions, which are discussed in Chapter 3, provide an easy way to accomplish this. A third alternative is when an independent third party is able to validate that the message came from Alice.

4.1.1 How Is Identity Used?

There are a variety of reasons why an information system may need to know the identity of an individual, or of the individual associated with a piece of data. The most obvious is access control: Should a given individual see a given piece of data? While this seems to be a clear case for having an identified individual, this is often not necessary and, from a privacy point of view, may be inappropriate. For example, access to a subscription-based patent search system needs to be limited to subscribers, but companies may be reluctant to use a system requiring

individual identification because of fears of revealing corporate intentions and plans. Information technology provides ways to support identification based on roles without requiring individual identification—providing the ability to significantly improve privacy.

A second reason for obtaining identity is attribution: the ability to prove who performed an action or generated a piece of data. For example, in a credit card transaction, the merchant needs to be able to show that a purchase is legitimate. Again, while systems are set up to require an identified individual for this purpose, all that is really needed is a role (an authorized user). Though this distinction may be difficult for face-to-face transactions, IT provides new opportunities to protect identity while ensuring correctness of information.

Identity is also used in information systems to enhance the user experience—particularly personalization. For example, web searches by an identified individual can be customized based on expressed desires or previous history of that individual. In this case, all that is needed is a pseudonym—knowing that a set of searches all come from the same individual, including preferences provided by that individual, is equally effective even if I do not actually know the identity of that individual.

4.1.2 Representing Identity

There are a variety of ways to represent identity, each with advantages and drawbacks. The most basic means is to rely on external, easy-to-remember identifiers, such as an individual's name. Unfortunately, names are rarely unique, leading to the possibility of misidentification. This is why hospitals and health insurance companies typically require name and date of birth, and online credit card transactions ask for name and address. The combination of multiple factors is often unique, or the nonunique cases are sufficiently rare that they can be addressed after the fact. Such combinations typically result in an identified individual.

A second representation of identity is to allow a user to specify the identifier for a given system—typically referred to as *user IDs* or login names. This gives certain advantages—the system can guarantee uniqueness by forbidding creation of an already taken ID, and it provides for pseudonymity if the individual is allowed to choose the ID, which is an additional measure of privacy. The disadvantages are that users may want the same user ID—for example, my use of the user ID “clifton” at some websites results in me being locked out due to authentication

failures. Other individuals who have the same last name and who don't remember their user ID can try the ID "clifton" and fail to give the correct password. After a number of failures, the system locks out future attempts, blocking the legitimate user from obtaining access. Some systems try to prevent this by requiring user IDs of a certain length, or requiring combinations of numbers and letters. This is a usability trade-off—while such user IDs are hard to remember, they reduce the chance of conflict.

An alternative is a system-generated user ID or unique number. This provides the same opportunity for pseudonymity and, if properly created, can ensure a degree of privacy—for example, by not using people's names as part of the user ID. While user-generated user ID can provide privacy, a system-generated, unique user ID ensures privacy for all users, even those who do not realize the associated privacy risks of identifiability. To truly provide privacy, system-generated user ID must not be based on other identifying data—for example, U.S. Social Security numbers, which are unique nine-digit numbers, are generated using location and date information that can help to link individuals to their number.²

An increasingly popular approach is to use externally created and managed unique identifiers. This has advantages and disadvantages. Externally created identifiers are often a user-friendly option, because the user can reuse another identifier, and this approach reduces the number of identifiers that a user must remember. Externally created identifiers also outsource the burden of ensuring uniqueness. Finally, these identifiers make it easier to link information across multiple systems. However, linkability also creates a privacy risk—linking information across multiple systems makes it easier to conduct fraud or other misuse of identity. In the United States, the Social Security number was once widely used as a unique identifier, but this eased identity theft and fraud—knowing an individual's Social Security number provided too much access to the individual's information. A better approach is to allow the user to choose the external identifier. Email addresses are a good example—the structure of the internet guarantees that email addresses are unique, but it is possible for a user to have multiple email addresses, including addresses that were created without revealing identity, providing the option of pseudonymity for users who desire it.

Finally, identity can be represented using systems created for that purpose. The X.500 standard provides a flexible framework for storing and maintaining identifying information, as do commercial systems such as Microsoft Passport or Google Wallet. Cryptographic certificates and public-key infrastructure (see

Chapter 3) also provide mechanisms to verify identity. These systems generally combine representations of identity with other identity-related information (name, address) and can provide authentication mechanisms as well, which we discuss in the next section.

Biometrics can also be used for identity. Ideally, this identifies a specific individual and does so with little effort. However, this should be used with care. For example, a 2017 attempt to use face recognition to find individuals on a police watch-list from a large crowd resulted in 92 percent false positives.³ Accuracy may be sufficient to distinguish between a small group of known individuals (e.g., users of a device), but care must be taken to ensure accuracy is appropriate for the planned use. Using the same biometric for both identification and authentication (see Section 4.2.4) poses additional risks, as a false positive would give an individual inappropriate access.

To summarize, identity can come in a variety of manners: identified individual, pseudonymous or truly anonymous, providing progressively greater levels of privacy. It may be sufficient to know a role rather than an identity, and it is important to understand what identity is used in order to ensure that an appropriate level of identity is used. Given these concerns, we can choose appropriate mechanisms to represent identity, providing appropriate trade-offs between level of identification, ease of use and privacy.

4.2 Authentication

Authentication is closely tied to identity. While identity links information to an individual, authentication is used to ensure that an individual performing an action matches the expected identity. Authentication can be accomplished by a variety of mechanisms, each with advantages and drawbacks. These mechanisms fall into four main categories:

1. What you know—secret knowledge held only by the individual corresponding to the identity
2. What you have—authentication requires an object possessed by the individual
3. Where you are—the location matches the expected location
4. What you are—biometric data from the individual

These mechanisms vary in terms of their ability to be defeated, ease of use, cost and privacy implications. In addition to the trade-offs in using authentication mechanisms, any decision to use one should consider the challenges of both creating and revoking credentials. For a particular mechanism, establishing or changing the credentials used to authenticate an individual can be much more expensive and prone to misuse than for other mechanisms. For example, a personal identification number (PIN, such as a four-digit number used for a bank card) that is sent by postal mail can be compromised through theft or by picking through trash, where the PIN may have been discarded. Requiring an individual to appear in person to select a PIN protects against these attacks, but may result in a PIN that can be guessed by someone knowing the individual, because the PIN was not randomized. A recent study of PINs shows that many people choose four- and six-digit PINs according to specific patterns that increase the predictability of PINs.⁴ Revocation, which is the repealing and reissuing of compromised credentials, poses similar issues—in particular, revoking biometric data is generally impossible, so systems using biometric data for authentication must be constructed using strong cryptographic techniques to ensure that such data is never compromised.

Authentication methods typically involve *authentication information* held by the user, *complementation information* held by the server/host, and an *authentication function* that takes a piece of authentication information and a piece of complementation information and determines whether they do or do not match.

4.2.1 Passwords

One of the most common approaches to authenticating a user is through passwords or PINs. This is an example of *what you know* authentication: It is assumed that only the proper individual knows the password. Passwords can provide a high level of assurance that the correct individual is being identified, but when used improperly, they can easily be broken.

Attacks on password-based authentication fall into two categories: attacks on the password itself and password attacks performed directly through the system. One approach, which is most useful with short passwords, such as four-digit PINs, is guessing passwords. This can be prevented by disabling access after too many failed attempts—but this also places a burden on legitimate users who incorrectly enter the password. Setting an appropriate number of failed authentication attempts should balance the need for correct identification against the cost of

resetting a password: If an easy and secure mechanism exists to reset passwords, then locking out is not a big problem. But if a reset requires, for example, a trip to the bank, the system quickly becomes unusable.

The dictionary attack is an example of password guessing. Given a choice, users tend to choose easy-to-remember passwords—typically normal words. There are other forms of authorization, such as *what you have*, that are harder to obtain using social engineering without exposing the attacker to increased risks of detection.

A simple example of a password attack performed directly through the system is the man-in-the-middle attack, in which a computer program intercepts traffic and reads the password contained in the intercept. To combat this attack, passwords are typically encrypted. Instead of presenting the password (authentication information) to a system, the system uses a one-way hash of the password and stores only the hash (complementary information). As it is extremely difficult to discover the password from the hash, this prevents the man in the middle, or an intruder who has gained access to the system, from obtaining a user's password.

While the man in the middle may not know the password, he only needs to replay the hash of the password to gain access; this is called a *replay attack*. This kind of attack is easily combated through system design. *Challenge response* authentication issues a unique challenge for each authentication: The response must be correct for each challenge. With a hashed password, the challenge is an encryption key sent by the system. The user application uses the key to encrypt the hash of the password; this is compared with the system's encryption of the stored value of the hashed password. Each authentication uses a different key, and thus a replay attack fails because the replayed password (response) is not encrypted with the current key (challenge).

The proper design and implementation of password systems are important concerns for information security experts. Because of the risk of stealing an individual's identity through a weak password system, however, there is a growing need for IT professionals who are responsible for privacy to be engaged in this discussion. In addition to passwords, systems will ask security questions (e.g., regarding the name of your high school or where you were born). These questions are often used as a secondary form of authentication; for example, during a password reset mechanism. To reduce the risk of a stolen identity, these questions must target information that is unlikely to be known by an attacker and is therefore likely to be private information. Consequently, the answers must be

protected (e.g., through a hash mechanism similar to that used for passwords) to ensure this data is not disclosed.

4.2.2 Devices

The *what you have* approach to authentication typically uses computing devices. Identification badges or smart cards can be used; these require that the computing terminal have the ability to read the computing device. A convenient approach is to embed a radio frequency identification (RFID) chip in the device; this does require a reader, but the user doesn't actually have to swipe the card. This particular technology introduces a privacy risk in that a malicious actor with a remote RFID reader can detect when the user is nearby, even though they are not actually trying to authenticate. If the actor can read the RFID card, then they may be able to "become" that individual through a replay attack; more advanced RFID approaches use a challenge-response approach to mitigate this attack.

Devices also exist that don't require special hardware at the client's terminal. These are typically in the form of small devices that display a changing PIN; the timing and sequence of PINs are known to the system. The user can type the PIN being displayed by the device just like a password, and the system checks to see if the given PIN matches what the device should be displaying.

Lastly, the computing device may be the computer the person uses to access the system (e.g., a home computer, laptop, smartphone). The system stores the IP address of the device or uses browser cookies to store a unique key on the machine; this allows the system to check whether the attempt to authenticate comes from a device previously used. Since the user already has the device, this requires no additional hardware.

Device-based authentication becomes problematic when devices are lost or stolen—until the loss is recognized and reported, access to the system may be compromised. As a result, these systems are typically combined with passwords or some other form of authentication so that the lost device alone cannot be used to gain access.

4.2.3 Location

Location-based authentication is typically used in corporate networks. Access to corporate resources is limited to computers physically located in the company. This requires an attacker to gain physical access as well as defeat other authentication (such as passwords), making unauthorized access far more

difficult. Of course, this also prevents legitimate use from outside the network, requiring the use of virtual private networks (VPNs). A VPN provides an encrypted link to the corporate network, and typically requires a high standard of authentication to make up for the loss of location-based authentication.

Note that location-based authentication can be used in other ways as well. Credit card issuers may reject transactions at unfamiliar locations unless the customer has provided advance notice of travel. While this may seem invasive from a privacy point of view, such location information will likely be made available anyway—for example, from the credit card use or the IP address used to connect to the system, so little additional information is disclosed when providing a list of authorized locations, such as a travel itinerary.

While location is useful, it should almost always be viewed as a secondary form of authentication, used to provide stronger evidence that the primary form of authentication is correct.

4.2.4 Biometrics

What you are as a form of authentication is growing increasingly popular. Notebook computers are available with fingerprint readers, and cameras and microphones are becoming standard equipment on many devices. Fingerprints, face and voice recognition, and other biometric methods for authentication are becoming increasingly available. This brings advantages, but also raises privacy issues.

First, systems using biometric data must protect that data. If a user's password is compromised, the user can change it—but cannot be asked to change a face or fingerprint. As with passwords, careful system design is needed to ensure that an attacker cannot obtain or spoof the biometric data. In 2009, Duc Nguyen demonstrated how the face recognition software in three different laptop models, manufactured by Asus, Lenovo and Toshiba, could be tricked into believing that a photo of the laptop owner's face was the physical owner, thus bypassing the face recognition software.⁵ The attack scenarios include obtaining a person's face from their website, social networking site or online chat. More advanced approaches include expression or gaze, preventing a static image attack and potentially incorporating a “what you know” type of authentication based on remembering the particular expression used.

Voice authentication has similar issues, depending on how it is done. Text-dependent voice authentication, where a user enrolls a specific passphrase,

provides the ability to change the authentication information if it is compromised. However, this could be subject to recorded authentication being used for a spoofing attack. An alternative is text-independent voice authentication, where a different passphrase is chosen each time, and the user must repeat the passphrase. This is a form of challenge-response that prevents replay attacks, but then becomes subject to the problem that the authentication information cannot be changed. Speech recognition technology, also called voice command, allows users to interact with and control technologies by speaking to them. This can be combined with voice recognition for a hands-free interface incorporating authentication.

Second, use of biometric data raises inherent privacy concerns. While passwords can be associated with a pseudonym, a fingerprint is inherently identifying, and a pseudonymous account using a fingerprint for authentication should probably be considered individually identifiable. There may also be cultural issues; some users may be reluctant to have a photograph taken or to display their face for use in biometric authentication.

A second type of biometrics is based on behavior—for example, typing rate or patterns of mouse movement. While these give only a degree of assurance, they provide the opportunity for continuous authentication. Once a user authenticates to the system, the behavior in using the system can be used to ensure that the user hasn't walked away and someone else has stepped in to use the account.

4.2.5 Multifactor Authentication

Two-factor authentication is becoming an increasingly common practice. The idea behind multifactor authentication is to require two different mechanisms, coming from two of the above categories. A common example is the use of a device (often an individual's cell phone) in addition to a password. Two-factor authentication can be quite transparent; an example is storing a cookie in a web browser after a successful authentication. On future authentications, after checking the identity and password, the server requests a corresponding authentication cookie from the web browser. If the browser has the appropriate (digitally signed) cookie, it proves the user has previously been logged in from that device; the device becomes a “what you have” second factor.

Good implementation of two-factor authentication can make many types of attacks, such as man-in-the-middle attacks, more difficult. The key is that the two factors should proceed through independent channels, such as a password

combined with a one-time temporary security code sent via a text message (SMS). While this does not eliminate attacks, an attacker must now compromise two independent systems. Conversely, forms of two-factor authentication that draw both factors from the same category (such as a password and security questions) are much less effective; a targeted attack to use personal information to guess a password will likely acquire the personal information needed to answer the security questions as well.

4.2.6 Authentication Summary

Authentication is the means by which a system knows that the identity matches the individual who is actually using the system. There are several approaches to authentication. Often, these can be used in combination, significantly decreasing the risk of a successful attack or attempt at impersonating the user.

Authentication can be separated from the systems requiring authenticity. This is a feature of single-sign-on systems. Authentication is performed by a service that provides a time-stamped cryptographic token to the user's system (e.g., web browser). This token can be provided to other systems, which can decide if the source of authentication (secured using a digital certificate), recency of authentication and user identified by the token satisfy access policy without requiring separate authentication.

Authentication must balance assuring the accuracy of an individual's identity and the usability of the system. While authentication needs to be strong enough to protect personal information, excessive use of technology to perform authentication can reduce the practical effectiveness of the system and create new privacy issues by collecting sensitive personal information needed to implement complex authentication mechanisms.

4.3 Identity Issues

How are privacy and identity related? The key is that privacy laws and regulations typically apply only to data that is *individually identifiable*. At first glance, this would suggest that pseudonymous or anonymous data is not subject to privacy law. The problem is that "individually identifiable" is a somewhat broader concept than "individually identified." From an identity point of view, data is individually identified if it specifically tells us which individual the data is about. From a privacy point of view, however, we are also interested in the question of whether or not the data could be linked to a specific individual. The difficulty is in

determining if pseudonymous or anonymous data could be linked to the individual the data is actually about. This continues to be a challenging research problem, although there are several areas where legislation and regulation provide good guidelines.

4.3.1 Individually Identifiable Data

Almost all privacy regulations have some definition of the information to which they apply; for example, the EU General Data Protection Regulation (GDPR) applies to personal data, and the U.S. Healthcare Insurance Portability and Accountability Act (HIPAA) applies to protected health information. What do these terms mean? Unfortunately, this is often not entirely clear. While data that is not about an individual is obviously not covered, and data that is individually identified clearly is, there is a large middle area of data that is not overtly identified but may be identifiable. An obvious case pointed out by Latanya Sweeney is the use of home address and date of birth.⁶ She showed that, given a person's postal code, date of birth and gender, which were contained in state-gathered hospital admission data presumed to be anonymous, she was able to identify numerous individuals by cross-referencing this data with publicly available voter registration data. In fact, she estimates that 87 percent of U.S. persons could be identified from date of birth, postal code and gender. As a result, this data is considered privacy-sensitive and not subject to disclosure under U.S. freedom of information rules.

Little guidance has been given as to exactly how much information is needed to cross the threshold into individually identifiable data. Is it okay if only 10 percent can be identified? Guidance from the European Community Article 29 Working Party (WP29) formed under 95/46/EC suggests that no individuals should be identifiable. However, it is less clear on a related point—what if I am not certain about an individual, but I can identify the person with some degree of confidence? For example, suppose I know a data item is about a doctor in a town containing only two doctors. While the WP29 suggests that if there is only one doctor in town, the record is individually identifiable, the question of how many doctors are needed to make the data nonidentifiable is not clearly answered.⁷ Furthermore, the increasing collection and sharing or disclosure of personal data makes re-identification, such as in the example above from Sweeney, increasingly possible, even using apparently innocuous data. This has resulted in a more specific definition for GDPR, which defines personal data as “any information relating to an identified or identifiable natural person (‘data subject’); an

identifiable natural person is one who can be identified, directly or indirectly, in particular by reference to an identifier such as a name, an identification number, location data, an online identifier or to one or more factors specific to the physical, physiological, genetic, mental, economic, cultural or social identity of that natural person.”⁸ This results in almost any data derived from a person being deemed “personal data,” even if the tie to specific individuals is unclear. (A somewhat surprising example is database reconstruction, discussed in Section 4.4.4.)

In some cases, the answers are clear. For example, most U.S. data breach notification laws are triggered if a last name, first initial and account number are disclosed. HIPAA provides a broader statement: It contains a safe harbor provision that specifies that data can be considered nonidentifiable after the removal or generalization of 18 specific types of potentially identifying information. For example, dates, such as birth date, must be no finer-grained than a year, and postal code can include only the first three digits, or an area encompassing at least 20,000 people. Furthermore, birth year can only be included for individuals under 85. Using this, we can conclude that on average, 67 people could potentially be tied to a record for a male in his early 80s, suggesting that a confidence in identification under 1.5 percent would not be considered individually identifiable. While this guideline is only implied by the rule, it does suggest that data can be sufficiently de-identified to prevent triggering this privacy regulation.

HIPAA also provides a specific example of pseudonymity. A de-identified dataset may include:

*A code or other means of record identification to allow information de-identified under this section to be re-identified by the covered entity, provided that: (1) the code or other means of record identification is not derived from or related to information about the individual and is not otherwise capable of being translated so as to identify the individual; and (2) the covered entity does not use or disclose the code or other means of record identification for any other purpose, and does not disclose the mechanism for re-identification.*²

This is a somewhat convoluted, but precise, legal definition of pseudonymity. The challenge for IT professionals is identifying these various definitions and managing the definitions in a consistent and legally compliant manner across their systems.

4.3.2 Identity Through History

Pseudonymous data and anonymous data pose different privacy risks. Given a set of data items about an individual, such as user purchases, it may be possible to identify the individual even if no individual data item can be linked to that person. Pseudonymous data may be identifiable even if the same data made anonymous is not by itself identifiable. Perhaps the most famous example of this is from web search log data made publicly available by AOL. Reporters were able to identify an individual based on a collection of queries, including information such as names and locations.¹⁰ Similar studies found risks with transaction data released under the Netflix challenge.¹¹

The need to treat pseudonymous data collections with particular care is recognized in law. The U.S. HIPAA Privacy Rule does not apply to *anonymous* data. However, it makes a special provision for “limited data sets,” which are not individually identified; individual identifiers must be replaced with a number. This gives a pseudonymous dataset. Limited datasets can be shared under a data use agreement, but they may not be publicly released.

There has been work on ensuring anonymity in such pseudonymous datasets.¹² However, this is still an open challenge, and extra care must be taken when releasing log files or transaction data. The IT professional may use encryption (see Chapter 3) or rely on contractual agreements with the receiving party (see Chapter 8) to ensure that privacy protections are afforded to potentially re-identifiable data.

4.3.3 Incidental or Unplanned Sources of Identity

There are many nonobvious sources of identifying information. For example, the IP address of a computer making a remote HTTP or HTTPS request is frequently logged. For some network providers, there is evidence that even dynamically assigned IP addresses do not change frequently, thus allowing a client computer to repeatedly be linked to the same IP address for long periods of time. Early implementations of IPv6 used addresses in which a unique 64-bit number derived from a computer’s hardware address was used in every address regardless of which network the computer was on. The WP29 suggested that IP addresses should be considered personally identifiable information (PII); for many people, their computer hosts a website identifying them.¹³ Thus, logs that contain IP addresses need to be treated as PII and protected appropriately.

Browser fingerprinting is another example. In an effort to personalize or customize the user experience, websites can track the user with browser cookies or other techniques. Peter Eckersley demonstrates how advanced techniques can uniquely identify most browsers by using data reported to the web server, including the client operating system, browser plug-ins and system fonts.¹⁴ While tracking can be beneficial to the individual, it also turns anonymous exchanges into pseudonymous exchanges—and, as seen previously, this can make data individually identifiable. (In Chapter 6, we discuss surveillance and tracking technology and the associated privacy risks in more detail.) Finally, logs can include sensitive information that a user may assume is anonymous, resulting in serious privacy risk. Thus, any comprehensive collection of information must be carefully evaluated for privacy risk, and both the risk and cost of protecting the data must be weighed against the value obtained from collecting the data.

4.4 Anonymization

The least restrictive way to utilize data while ensuring that privacy is protected is through anonymization. If data is not individually identifiable, it does not pose a privacy risk. Anonymization techniques attempt to ensure that data is not identifiable. This is a challenging problem: For each anonymization technique, there are attacks showing conditions under which data can be re-identified. Though these attacks sometimes make very strong assumptions, it is clear that any attempt at anonymizing data faces risks. However, these risks are likely to be much smaller than the risk of misuse of identifiable data, through either insider misuse or external attackers gaining access to data.

4.4.1 Strong versus Weak Identifiers and Individual Identifiability

Some information is clearly identifying—for example, identifying numbers such as a national identification, passport or credit card number. These are referred to as *strong identifiers*. Names can be strong identifiers, but common names may not be uniquely identifying. This is why names are typically used in combination with other information (e.g., birth date, address) to identify individuals. Identifiers that must be used in combination with other information to determine identity are referred to as *weak identifiers*. A related concept is *quasi-identifiers*: data that can be combined with external knowledge to link data to an individual.

A related issue is linkable data versus linked data. Given an identifier—either a strong identifier or a collection of weak identifiers—can we determine an individual’s identity? Given a bank account number and nothing else, most of us would not be able to determine who the individual is—the link from bank account number to the individual is generally protected. This raises an interesting issue: Is data individually identifiable if it requires substantial background knowledge to link the data to an individual? Laws on this issue are unclear, but state data breach notification laws provide some hints within the United States. Disclosure of a financial account number alone does not trigger these laws (even though this is typically a strong identifier). It is the financial account number and name in combination that trigger these laws. Generally, if a quasi-identifier can be linked to an individual using publicly available information, it should be considered individually identifiable.

Even if linking data is not public, it is a good idea to consider strong identifiers or a combination of weak identifiers as sufficient to make data identifiable. As an example, the WP29 notes that an IP address should be considered identifiable data. While it is clear that an internet service provider (ISP) is likely to be able to link an IP address to an individual, the WP29 also says this should apply to search engines.¹⁵ The reasoning is that third parties (e.g., through civil litigation) can obtain the data necessary to make the link.

A somewhat murky area is the distinction between identifying a record, which clearly triggers a privacy law, and identifying a sensitive value associated with an individual. While it is unclear whether the latter triggers privacy law, it pretty clearly poses a risk to privacy. This will be discussed further in Section 4.4.3, when we discuss the role of microdata.

4.4.2 Approaches to Anonymization

Anonymization techniques hide identity in a variety of ways. The simplest approach is *suppression*: removing identifying values from a record. Names and identifying numbers are typically handled through suppression.

Some types of data are amenable to *generalization*, which is performed by replacing a data element with a more general element; for example, by removing the day and month from a birth date or removing a street from a postal address and leaving only the city, state or province name. Replacing a date of birth by just the year of birth substantially reduces the risk that an individual can be identified but still leaves valuable information for use in data analysis.

A third approach is *noise addition*. By replacing actual data values with other values that are selected from the same class of data, the risk of identification is lowered. The addition is often aimed at preserving statistical properties of the data, while disrupting future attempts to identify individuals from the data. In many ways, the protection obtained by noise addition is similar to generalization.

Generalization and noise addition not only reduce the risk of identification, they can also reduce the sensitivity of data. For example, birth date is frequently used as a form of authentication—“what you know.” Generalizing birth date to year prevents this data from being used to support identity theft. Because generalized individually identifiable data is still individually identifiable, and thus probably covered by privacy law, it does reduce the risk of damage should data be inadvertently disclosed.

4.4.3 Anonymization of Microdata

The most obvious approach to anonymizing data is using what is commonly referred to as microdata sets. A microdata set contains the original records, but the data values have been suppressed or generalized, or noise has been added to protect privacy. The open question is how much suppression, generalization or noise is needed for data to no longer be considered individually identifiable.

Government publishers of data about individuals, such as census bureaus, have a long history of studying this problem, and numerous techniques have been developed. In addition to generalizing values to ranges (e.g., birth decade rather than birth year), values are often *top-* and *bottom-coded* (e.g., reporting all ages over 80 as “>80” as opposed to reporting decade). Rounding can also be used as a form of generalization (e.g., to the nearest integer, or nearest 10); *controlled rounding* ensures that rounding is done in a way that preserves column summations. Where data must be suppressed, *data imputation* can be used to replace the suppressed values with plausible data without risking privacy. Another technique includes *value swapping*, which means switching values between records in ways that preserve most statistics but no longer give correct information about individuals. Much of this work is summarized in a 2005 U.S. government report.¹⁶

One particularly valuable resource from this community is the “Checklist on Disclosure Potential of Proposed Data Releases.”¹⁷ While it does not contain hard and fast rules, the checklist provides several guidelines, such as generalizing geographic units to regions containing at least 100,000 individuals, and top-coding ages over 85. Furthermore, it provides a comprehensive list of questions

that should be considered before releasing data. Though directed toward U.S. government agencies, the procedures and questions are worth considering for any release of microdata.

Perhaps the only clear legal answer to the question of what makes data individually identifiable is contained in the HIPAA safe harbor rules. These specify the removal or generalization of 18 types of data. Name, identifying numbers (e.g., telephone number, insurance ID) and several other data types must be suppressed. Dates must be generalized to a year and addresses to the first three digits of the postal code or more general if this does not yield a region containing at least 20,000 people. Furthermore, age must be top-coded as follows: All ages greater than 89 must simply be reported as >89. If these steps have been taken, and there is no other reason to believe that the data is identifiable, then the data can be considered de-identified and no longer subject to the HIPAA Privacy Rule.

In addition to regulatory rules and guidelines, formal definitions have been established in computer science. Perhaps the first definition was *k*-anonymity.¹⁸ The *k*-anonymity requires that every record in the microdata set must be part of a group of at least *k* records having identical quasi-identifying information. To achieve this, records with similar identifying information are formed into groups of at least *k* in size, and the identifying information is generalized or suppressed so that all the records have identical quasi-identifiers. This ensures that no record can be individually identified; given identifying information for an individual, there are at least *k* records that are equally likely to belong to the individual. (Note that we are assuming there is only one record for each individual; extending to cases where there are multiple records about an individual is straightforward.)

The *k*-anonymity does not provide an absolute guarantee of privacy protection. For example, suppose we have a microdata set listing occupation. If we assume that occupation is not publicly known, but age and address are, then age and address are quasi-identifiers. Table 4-1 is an example of a 2-anonymous table: For any given age range and address, there are at least two records corresponding to that age/address. Suppose we know Patricia is 19 years old and lives in West Lafayette—we know she is one of the first two records, but we have no idea which one. However, since the occupation of both of these people is “student,” we now know that Patricia is a student—even though the record is not individually identifiable.

Table 4-1: Sample 2-Anonymous Dataset

--	--	--

Age	Address	Occupation
[18-22]	West Lafayette	Student
[18-22]	West Lafayette	Student
[18-22]	Lafayette	Steamfitter
[18-22]	Lafayette	Student
[23-30]	West Lafayette	Teacher
[23-30]	West Lafayette	Farmer

This issue is addressed by l -diversity.¹⁹ The l -diversity extends k -anonymity by further requiring that there be at least l distinct values in each group of k records. This prevents the privacy breach noted above; there are at least l possible occupations for an individual, even if we know which group of k people they belong to.

Even l -diversity has issues. For example, suppose one of the occupations is CEO. Even though we don't know which record belongs to Patricia, we know that CEOs are rare, and since she is one of k people, one of whom is a CEO, the probability that she is a CEO is much higher than we would think without having access to the microdata. This issue spawned a definition t -closeness, which ensures that the distribution of values in a group of k is sufficiently close to the overall distribution.²⁰

While these definitions seem strong, given sufficient background knowledge it is almost always possible to learn private information from such a microdata set. This is even true of the HIPAA safe harbor rules, so it appears that some level of risk to privacy is deemed acceptable. However, there is not yet a generally legally accepted definition of what constitutes nonidentifiable data.

4.4.4 Aggregation-Based Approaches

Instead of publishing de-identified, individual-level records, one can publish aggregate statistics derived from the data. On the face of it, this would eliminate privacy concerns. Unfortunately, it is often possible to determine individual values from such statistics. For example, publishing a table giving statistics on the number of individuals with given income levels broken down by age could reveal both age and income for certain well-known, high-income individuals. More subtle attacks on privacy come from comparison of values across multiple cells; an example of such a problem, and a method to deal with it, can be found in a paper

by Wang et al.²¹ The official statistics community has led the way in techniques to safely publish so-called contingency tables. Many of the techniques are similar to microdata—top- and bottom-coding, suppression and noise addition, to name a few.

A key issue when releasing aggregates is to determine whether the data is *frequency or magnitude* data. The easiest way to distinguish these two types of data is to determine whether individuals contribute equally or unequally to the value released. For example, a count of the number of individuals at a given income and age is frequency data: Each individual contributes one to the cell they are in. A table giving average income by age is magnitude data: Someone with a high income will affect the average much more than an individual whose income is close to the average. For magnitude data, noise addition or entire suppression of the cell is typically needed to ensure privacy; for frequency data, rounding techniques may well be sufficient. The previously described microdata checklist includes a section with recommendations for disclosure of aggregates.²²

Unfortunately, these approaches cannot entirely eliminate privacy risk. With a large enough set of aggregates, *database reconstruction* becomes possible.²³ Database reconstruction builds a dataset that would generate the aggregate statistics. In many cases, it can be shown that such a reconstructed database is unique, or at least that many of the individual records in the dataset are unique (e.g., they must exist in any dataset that generated those aggregates.) While this data is not identified, it is essentially a microdata set and subject to the re-identification attacks discussed in the preceding section. Researchers have shown that this is not just a hypothetical problem; real-world published aggregates such as Census tables are vulnerable to database reconstruction.²⁴ The box gives an example of just how few aggregates are needed to inadvertently reveal individual information.

Database Reconstruction

by Simson Garfinkel

Consider a company that delivers continuing education services and publishes a brochure with the average age of professionals enrolled in their past classes. The first time the course was given, there were three students; the second time, eight students. The average ages were 44.0 and 37.0. Now, say that a customer with a degree in statistics objects to the firm publishing the mean, arguing that medians are far more useful for understanding populations. So, the next time the company publishes its brochure, it reports that there were three cohorts with three, eight and 15 people, with median ages of 30, 35 and 40. Three statistics have now been published for the first cohort: There were exactly three people, with median age of 30 and average age of 44. If the company separately publishes that the oldest person who ever took the training was 72, the company has now exactly revealed that the individuals in the first cohort were 30, 30 and 72, because there is no other combination of three ages that has a median age of 30, a mean age of 44 and a maximum age of 72.

Techniques such as top- and bottom-coding, rounding and suppression do not guarantee protection against database reconstruction. The only way to provide guaranteed limits on the risk of database reconstruction is noise addition. The most widely accepted definition for noise addition at this time is *differential privacy*.²⁵ The idea behind differential privacy is to add sufficient noise to the aggregates to hide the impact of any one individual. The key idea is to compare the difference in the aggregate result between two databases that differ by one individual. Differential privacy requires that the added noise be large relative to that difference, *for any two databases and any individual*. Formally, the definition is as follows:

$$\text{For } S \subseteq \text{Range}(f), \text{ an } \epsilon\text{-differentially private mechanism } M \text{ satisfies} \\ \frac{\Pr[M_f(D_1) \in S]}{\Pr[M_f(D_2) \in S]} \leq e^\epsilon, \text{ where } D_1 \text{ and } D_2 \text{ differ on at most one element.}$$

We can see that when $\epsilon = 0$, the answers must be the same for the two databases—perfect privacy. As ϵ increases, the quality of the answer improves, but the privacy provided decreases. Though perhaps not obvious from the definition, differential privacy is quite general—it can apply to a function f that returns a discrete value, a continuous value or even a set of values (such as a contingency table). The definition can even be applied to the release of microdata, although in practice this would give something closer to synthetic microdata. (One way to imagine this is to think of generating a set of differentially private contingency tables, then do a database reconstruction on those tables. The result would be differentially private microdata.) Furthermore, there are general mechanisms—

adding noise from a Laplace distribution and selecting outcomes from all possible results with an exponentially higher probability of selecting those close to the true value (exponential mechanism)—that can be applied to provide differential privacy. A survey of mechanisms for achieving differential privacy is given by Dwork & Roth.²⁶

Differential privacy deals with a key challenge in the release of aggregates: Even though it may be safe to release two aggregate values (e.g., two tables) independently, given both, is it possible to re-identify individuals from these tables? The answer may be yes. A simple example would be releasing the total payroll of a company, and the total payroll of the company exclusive of the CEO. While neither datum by itself reveals individual salaries, given both of these numbers it is easy to determine the CEO's salary. If we use differential privacy to release two aggregates, one providing ϵ_1 privacy, and the other providing ϵ_2 privacy, the two in combination give at least $\epsilon_1 + \epsilon_2$ privacy.

One open question is the appropriate value of ϵ for differential privacy. It turns out that the parameter ϵ is really a measure of the quality of the aggregate rather than the risk to an individual. *Differential identifiability* is a reformulation of differential privacy that limits the confidence that any particular individual has contributed to the aggregate value:²⁷

$$\forall D' = D - \{i\}, \forall i \in U - D', S \subseteq \text{Range}(f), \text{ a } \rho\text{-differentially identifiable mechanism } M \text{ satisfies } \Pr[I(i) \in D \mid M_\rho(D) = S, D'] \leq \rho.$$

We can compute an expected value for p for the HIPAA safe harbor rules. Assuming a geographic area of 20,000 individuals, we would expect to find 68 males of age 83, giving $p = 1.7$ percent. While the confidence in identifying younger individuals is likely to be lower and, in some cases, the safe harbor rules may not provide this level of protection, we can assume that the goal of the rule is no stronger than this. Differential identifiability guarantees that we limit identification confidence to this level, providing a defensible argument of the sufficiency of the mechanism.

Though still evolving, releasing data aggregates rather than microdata often provides significantly better privacy protection and still meets the needs for data analysis.

4.4.5 Client-Side Control of Anonymization

While anonymization is typically viewed as something done by a data custodian, there are client-side techniques to enhance anonymity. For example, proxy servers can hide the IP address of a request by replacing it with that of the proxy server. Techniques such as onion routing and Crowds further extend this notion of proxies by hiding IP addresses even from the proxy server.²⁸ Tor is a practical example of such a system. Tor is a peer-to-peer network where each request is routed to another peer, which routes it to another peer, and so on until a final peer makes the actual request. Encryption is used to ensure that only the first peer knows where the request came from, and only the last peer knows the server to which the request is being routed.

This hides only the IP address. Most internet traffic contains considerably more identifying information. For example, a typical HTTP request contains information on the browser, last page visited, type of machine and so on. This can make such a request identifiable even if the IP address is not known. Private web search is a browser plug-in that strips such information from the request.²⁹ This leaves only the search text itself, but as we have seen with the AOL query log disclosure, even this may be sufficient to identify an individual. Tools have been developed to generate “cover queries”—fake query traffic that disguises the actual request.³⁰ Supporting such client-side approaches by requesting only necessary information (e.g., requiring use of cookies only when necessary for a transaction) enables users who are concerned about privacy to provide their own protection. This can increase comfort level for privacy-sensitive users.

Noise addition techniques can also be used at the client side. *Local differential privacy* (not to be confused with local sensitivity, a measure of the impact of one individual on the result of a query on a particular dataset) allows individuals to add noise before sending data to a server. The server then computes the aggregate from the noisy data. A classic example of client-side noise addition is randomized response, where those surveyed randomly choose to either answer correctly or provide a random answer.³¹ Any individual response is suspect (it could easily be just a random choice), but it is possible to construct aggregate results that have provable correctness bounds. Randomized response can provide differential privacy.

4.5 Summary

An important privacy concern for IT professionals is how to handle *individually identifiable* data. Data that cannot be linked to a specific individual is generally not constrained by privacy regulations. Unfortunately, it is not easy to determine if data can be linked to an individual. While *anonymous* data can be shared freely, it is difficult to ensure that data is truly anonymous. *Pseudonymous* data can also be safe to share, but it is easier to re-identify the individual associated with this data with anonymous data. As a result, all data about individuals should be treated with care. The level of protections afforded this data should be commensurate with the privacy risk, a topic discussed further in Chapter 2.

Access to data that is individually identified must be controlled, and should be limited to those with a clear need to access data about the individual for purposes that benefit the individual. Authentication should be appropriate to the privacy risk. The main issue is the trade-off between strength of authentication and convenience. Authentication methods that impose a high overhead on users can backfire. For example, requiring complex passwords often leads people to write passwords down, often posting them near their computer—resulting in little security from the password (*what you know*), and replacing it with physical location security (*where you are*). A better approach for authenticating employees is through multifactor authentication, which combines several factors into a single authentication process. Reading an RFID-tagged ID badge (*what you have*) or using a fingerprint reader (*what you are*) along with a simple password can provide better protection and more convenience.

Authenticating external access (e.g., to give people access to data about themselves) is more challenging, as techniques based on ID card readers or biometrics require special hardware that the public is not likely to have. An increasingly common approach is to use text messages as a second factor, but this requires the individual to have and carry a cell phone to authenticate. This leads to a privacy trade-off: Imposing higher hurdles on access to data about oneself does provide greater protection against violations of privacy, but preventing individuals from seeing data about themselves is itself a violation of privacy. The risk of harm to an individual from disclosure of the data needs to be compared with the risk from use of incorrect data or use without the individual's knowledge to determine how easy or difficult individual access should be.

The less likely it is that data can be linked to an individual, the lower the privacy risk. Therefore, data should be stored and used in anonymized form whenever feasible. Even when data must be kept in identified form, creating de-identified

data for analysis and data warehousing is a good idea. A good model is the use of limited datasets for healthcare research: While hospital records need to be identified for use in treating the patient; for use in research, the names, addresses and identifying numbers may be removed. Though many of the records in limited datasets are identifiable (e.g., birth date, postal code) and thus access to them must be restricted, the likelihood of a privacy breach is reduced. (Re-identification requires active effort, as opposed to accidentally spotting the health record of a friend or neighbor when analyzing the data.) The same principle should be applied to any use of data; using anonymization techniques to give access only to the information needed for the task greatly reduces the risk of privacy violations, even if the data could potentially be re-identified.

Data anonymization is still an open research area; progress is being made in ways to both anonymize data and re-identify supposedly anonymous data. While there is often great value in publicly disclosing anonymous data, there is always some potential privacy risk from doing so. The principle of informed consent applies here as well; informing data subjects that their data may be disclosed as part of an anonymized dataset and obtaining consent to do so can go a long way to alleviating the fallout should the anonymization fail to protect against identifying individuals.

Endnotes

- 1 Peter Steiner, “On the Internet, Nobody Knows You’re a Dog,” *The New Yorker*, July 5, 1993, 61.
- 2 Alessandro Acquisti and Ralph Gross, “Predicting Social Security Numbers from Public Data,” *Proceedings of the National Academy of Sciences* 106, no. 27 (July 7, 2009): 10975–10980, www.pnas.org/content/106/27/10975.
- 3 “Welsh police wrongly identify thousands as potential criminals,” *The Guardian*, May 5, 2018, <https://www.theguardian.com/uk-news/2018/may/05/welsh-police-wrongly-identify-thousands-as-potential-criminals>.
- 4 Joseph Bonneau, Sören Preibusch and Ross Anderson, “A Birthday Present Every Eleven Wallets? The Security of Customer-Chosen Banking PINs,” *Financial Cryptography and Data Security: The 16th International Conference*, 2012, 25–40.
- 5 Nguyen Minh Duc and Bui Quang Ming, “Your Face Is NOT Your Password,” 2009, www.blackhat.com/presentations/bh-dc-09/Nguyen/BlackHat-DC-09-Nguyen-Face-not-your-password.pdf (accessed October 2019).
- 6 Latanya Sweeney, “Computational Disclosure Control: A Primer on Data Privacy Protection,” (PhD dissertation, Massachusetts Institute of Technology, 2001).
- 7 Article 29 Data Protection Working Party, “Opinion 4/2007 on the Concept of Personal Data,” adopted June 20, 2007.
- 8 Regulation (EU) of the European Parliament and of the Council of 27 April 2016 on the protection of natural persons with regard to the processing of personal data and on the free movement of such data, and repealing Directive 95/46/EC (General Data Protection Regulation) L4(1), <https://eur-lex.europa.eu/eli/reg/2016/679/oj>, (accessed October 2019).
- 9 HIPAA, 45 CFR 164.514 (c).
- 10 Michael Barbaro and Tom Zeller, Jr., “A Face Is Exposed for AOL Searcher No. 4417749,” *The New York Times*, August 9, 2006, www.nytimes.com/2006/08/09/technology/09aol.html.
- 11 A. Narayanan and V. Shmatikov, “Robust De-anonymization of Large Datasets,” in *Proceedings of the IEEE Symposium on Security and Privacy*, (2008): 111–125.
- 12 Bradley Malin, “Trail Re-identification and Unlinkability in Distributed Databases” (PhD thesis, Carnegie Mellon University, May 2006), <http://reports-archive.adm.cs.cmu.edu/anon/isri2006/abstracts/06-105.html>; Manolis Terrovitis, Nikos Mamoulis and Panos Kalnis, “Privacy-Preserving Anonymization of Set-Valued Data,” *Proceedings of the VLDB Endowment* 1, no. 1 (2008): 115–125, <http://doi.acm.org/10.1145/1453856.1453874>.
- 13 Article 29 Data Protection Working Party, “Opinion 1/2008 on Data Protection Issues Related to Search Engines,” adopted April 4, 2008.
- 14 Peter Eckersley, “How Unique Is Your Web Browser?” Electronic Frontier Foundation, (2010), <https://panopticklick.eff.org/static/browser-uniqueness.pdf>.
- 15 Article 29 Data Protection Working Party, “Opinion 1/2008 on Data Protection Issues Related to Search Engines.”
- 16 Federal Committee on Statistical Methodology, “Statistical Policy Working Paper 22 (Revised 2005)—Report on Statistical Disclosure Limitation Methodology,” Statistical and Science Policy, Office of Information and Regulatory Affairs, Office of Management and Budget, December 2005, <https://www.hhs.gov/sites/default/files/spwp22.pdf>.
- 17 Interagency Confidentiality and Data Access Group: An Interest Group of the Federal Committee on Statistical Methodology, “Checklist on Disclosure Potential of Proposed Data Releases,” Statistical Policy

- Office, Office of Information and Regulatory Affairs, Office of Management and Budget, July 1999, https://nces.ed.gov/FCSM/cdac_resources.asp.
- 18 Pierangela Samarati, "Protecting Respondent's Identities in Microdata Release," *IEEE Transactions on Knowledge and Data Engineering* 13, no. 6 (2001): 1010–1027, <http://ieeexplore.ieee.org/xpl/articleDetails.jsp?arnumber=971193>; Latanya Sweeney, "k-Anonymity: A Model for Protecting Privacy," *International Journal on Uncertainty, Fuzziness and Knowledge-based Systems* 10, no. 5 (2002): 557–570, www.worldscientific.com/doi/abs/10.1142/S0218488502001648.
 - 19 Ashwin Machanavajjhala, Johannes Gehrke, Daniel Kifer and Muthuramakrishnan Venkitasubramaniam, "l-Diversity: Privacy Beyond k-Anonymity," *Proceedings of the 22nd IEEE International Conference on Data Engineering (ICDE 2006, Atlanta, Georgia, April 2006)*, <http://ieeexplore.ieee.org/xpl/articleDetails.jsp?arnumber=1617392>.
 - 20 Ninghui Li, Tiancheng Li and Suresh Venkatasubramanian, "t-Closeness: Privacy Beyond k-Anonymity and l-Diversity," *Proceedings of the IEEE 23rd International Conference on Data Engineering (ICDE 2007, Istanbul, Turkey, April 15–20, 2007)*, <http://ieeexplore.ieee.org/xpl/articleDetails.jsp?arnumber=4221659>.
 - 21 Lingyu Wang, Duminda Wijesekera and Sushil Jajodia, "Cardinality-Based Inference Control in Data Cubes," *Journal of Computer Security* 12, no. 5 (2004): 655–692.
 - 22 Interagency Confidentiality and Data Access Group, "Checklist on Disclosure Potential of Proposed Data Releases."
 - 23 I. Dinur, K. Nissim, "Revealing information while preserving privacy," *Proceedings of the 22nd ACM SIGMOD-SIGACT-SIGART Principles of Database Systems*, 2003, 202–210; <https://doi.org/10.1145/773153.773173>.
 - 24 Simson Garfinkel, John M. Abowd and Christian Martindale, "Understanding Database Reconstruction Attacks on Public Data," *Communications of the ACM* 62(3):46–53, March 2019, <https://doi.org/10.1145/3287287>.
 - 25 Cynthia Dwork, Frank McSherry, Kobbi Nissim, and Adam Smith, "Calibrating Noise to Sensitivity in Private Data Analysis," in *Proceedings of the Third Theory of Cryptography Conference (TCC 2006)*, New York, March 4–7, 2006, 265–284, https://doi.org/10.1007/11681878_14.
 - 26 Cynthia Dwork and Aaron Roth, "The Algorithmic Foundations of Differential Privacy," *Foundations and Trends® in Theoretical Computer Science*: vol. 9: no. 3–4, 211–407. <http://dx.doi.org/10.1561/04000000042>
 - 27 Jaewoo Lee and Chris Clifton, "Differential Identifiability," *18th ACM SIGKDD Conference on Knowledge Discovery and Data Mining*, Beijing, China, August 12–16, 2012).
 - 28 David Goldschlag, Michael Reed and Paul Syverson, "Onion Routing," *Communications of the ACM* 42, no. 2 (1999): 39–41, <http://dl.acm.org/citation.cfm?doid=293411.293443>; Michael K. Reiter and Aviel D. Rubin, "Crowds: Anonymity for Web Transactions," *ACM Transactions on Information and System Security* 1, no. 1 (1998): 66–92, <http://dl.acm.org/citation.cfm?doid=290163.290168>.
 - 29 Felipe Saint-Jean, Aaron Johnson, Dan Boneh and Joan Feigenbaum, "Private Web Search," *Proceedings of the 6th Workshop on Privacy in the Electronic Society* (Alexandria, VA: ACM Press, October 29, 2007), 84–90, <http://dl.acm.org/citation.cfm?doid=1314333.1314351>.
 - 30 Daniel C. Howe and Helen Nissenbaum, "TrackMeNot: Resisting Surveillance in Web Search," in Ian Kerr, Carole Lucock and Valerie Steeves, eds., *Lessons from the Identity Trail: Anonymity, Privacy and Identity in a Networked Society* (New York: Oxford University Press, 2009), 417–436, www.idtrail.org/content/view/full/799; Mummoorthy Murugesan and Chris Clifton, "Providing Privacy Through Plausibly Deniable Search," *Proceedings of the SIAM International Conference on Data Mining*, Sparks,

Nevada, (April 30–May 2, 2009), 768–779,
www.siam.org/proceedings/datamining/2009/dm09_070_murugesanm.pdf.

- 31 S. L. Warner, “Randomised response: a survey technique for eliminating evasive answer bias,” *Journal of the American Statistical Association* 60 (309): 63–69, (Taylor & Francis, March 1965),doi:
10.1080/01621459.1965.10480775.

CHAPTER 5

Usable and Useful Privacy Interfaces

Florian Schaub, CIPP/US, CIPT; Lorrie Faith Cranor, CIPT

The design of a system or technology, in particular its user experience (UX) design, affects and shapes how people interact with it. Privacy engineering and UX design frequently intersect. Privacy laws and regulations require that data subjects are informed about a system's data practices, asked for consent, provided with a mechanism to withdraw consent and given access to their own data—including

options for data portability and data deletion. To satisfy these requirements and address users' privacy needs, most services offer some form of privacy notices, privacy controls or privacy settings through a website or through the user interface of an app or other piece of software.

However, too often privacy notices are not readable, people do not understand what they consent to, and people are not aware of certain data practices or the privacy settings or controls available to them. The challenge is that an emphasis on meeting legal and regulatory obligations is not sufficient to create privacy interfaces that are *usable* and *useful* for users. Usable means that people can find, understand and successfully use provided privacy information and controls. Useful means that privacy information and controls align with users' needs with respect to making privacy-related decisions and managing their privacy. This chapter provides insights into the reasons why it can be difficult to design privacy interfaces that are usable and useful. It further provides guidance and best practices for user-centric privacy design that meets both legal obligations and users' needs. Designing effective privacy user experiences not only makes it easier for users to manage and control their privacy, but also benefits organizations by minimizing surprise for their users and facilitating user trust. Any privacy notice and control is not just a compliance tool but rather an opportunity to engage with users about privacy, to explain the rationale behind practices that may seem invasive without proper context, to make users aware of potential privacy risks, and to communicate the measures and effort taken to mitigate those risks and protect users' privacy.

Privacy laws, privacy technology, and privacy management are typically centered on information—how information is collected, processed, stored and transferred; how it can and must be protected; and how to ensure compliance and accountability. To be effective, designing privacy user experiences requires a shift in focus: While information and compliance are of course still relevant, user-centric privacy design focuses on people, their privacy needs and their interaction with a system's privacy interfaces.

Why is it important to pay attention to the usability of privacy interfaces? How do people make privacy decisions? What drives their privacy concerns and behavior? We answer these questions in this chapter and then provide an introduction to UX design. We discuss common usability issues in privacy interfaces and describe a set of privacy design principles and a user-centric process

for designing usable and effective privacy interfaces, concluding with an overview of best practices.

5.1 Why User-Centered Privacy Design?

If you have ever tried to adjust your privacy settings in a mobile app or a social media site, or tried to figure out how to exercise privacy choices on a website, chances are you encountered a privacy interface that was not all that easy to use. Developers often add privacy interfaces to comply with regulations or company policy, but seldom do they engage user experience experts to design a usable privacy interface or evaluate its usability. However, some privacy laws now include usability requirements, which means that simply providing a choice somewhere in the user interface may not be sufficient to meet legal obligations. Furthermore, people who encounter privacy notices and controls that are difficult to find, use or understand may be surprised when they read a news report and find out about how an organization actually uses their data. Thus, even well-intended organizations may end up disappointing or surprising their customers, which in turn may decrease their trust in the organization. By taking a user-centered approach to privacy design, organizations can meet legal obligations while also minimizing user surprise and facilitating trust.

5.1.1 Meeting Legal Obligations

Many privacy laws include requirements for transparency and choice that include usability requirements. For example, the EU General Data Protection Regulation (GDPR) requires “clear and plain language” and transparency that is “concise, transparent, intelligible and easily accessible.”¹ A number of U.S. laws require privacy policies to be “clear and conspicuous.” Legal requirements related to privacy notice usability focus on text that is readable to users, easy for users to find, and contains information users need to know. Some laws also require that users be presented with easily accessible choices about the use of their data, ways to access the data an organization has collected about them, and mechanisms for requesting that their data be deleted. While following the legal obligations and requirements is important, it is often not enough to ensure that privacy notices and controls are actually useful and usable for users.

5.1.2 Minimizing Surprise

When users are surprised at how their data is used by an organization, they are likely to become angry and lose trust in that organization.²

5.1.2.1 Aligning User Expectations and System Behavior

Users often have preconceived notions about how a system will use and share their personal information. As they use the system, the UX may further shape their expectations. Users may be unaware of data collection that occurs automatically or of inferences that are made based on their behavior. They may assume that companies will use data only to fulfill user requests and not for unrelated purposes. Any unexpected data use or sharing may come as an unpleasant surprise to users when they learn about it through news reports, social media, or because they are affected by how the data is used. For example, in 2018, it was revealed that Cambridge Analytica was able to obtain information about a huge number of Facebook users because Facebook apps could access information not only about those Facebook users who had installed an application but also about the friends of those users, without their knowledge. This data sharing with third parties by Facebook was met with shock and surprise by consumers, and led to the largest regulatory penalty for a privacy violation to date.³

Companies can prevent these surprises by helping users understand how their data will be used and shared, and by drawing the user's attention to data practices most likely to be surprising. For example, a company might highlight potentially surprising practices in a privacy policy and include just-in-time notices where appropriate throughout the system's UX.

Likewise, companies should make an effort to design privacy-related controls so that users can fully understand what they do. When users check a box to opt-out, they should know exactly what they are opting out of; for example, are they opting out of seeing advertising, ads that are targeted to them, or the actual tracking of their behavior for ad targeting? Most advertising-related opt-outs fail to clarify the actual effect of the opt-out.⁴ Likewise, access control settings for social media and calendars are often difficult to understand, and users may inadvertently grant access to more people than intended. Therefore, some calendar programs assist users who change the visibility of a calendar entry by displaying an explanation of how this will impact who can see that entry. The user interface should also make users aware of any side effects that may occur as a result of the settings they choose. For example, allowing an app access to location information might not only enable mapping features, but also enable location-based advertising.

5.1.2.2 Reducing Opportunities for User Regret

Sometimes users take actions that may have an adverse impact on their privacy that they may later come to regret. This may occur when users misunderstand settings, select the wrong settings by mistake, or don't understand or misremember important details. For example, social media users may forget who is in their friends or followers group and thus may be surprised when their parent, boss or coworker sees a post not intended for them, causing regret.⁵ Some systems use “nudges” or time delays to reduce opportunities for user regret. Researchers have developed and tested nudges for Facebook that remind users of who is in the audience for their posts and provide a short count-down timer before posting.⁶ Facebook itself has implemented a nudge to address the problem of users changing their audience setting to public for one post and forgetting to change it back to a more privacy-protective setting next time they post.⁷ Gmail offers users the opportunity to set a delay of 5-30 seconds before sent messages are actually sent, giving users a short opportunity to recall them.⁸ Features such as these that reduce opportunities for user regret can help users help themselves and protect their privacy.

5.1.3 Facilitating Trust

Users are more likely to trust companies that they believe will treat them fairly, communicate clearly about their data practices and privacy protections and offer them meaningful choices and controls.

5.1.3.1 Communicating Privacy Protections

Users are not likely to trust privacy information or notices that appear to users as just a bunch of legalese meant to protect the organization. Furthermore, when users—or the media—find that a company or product engages in data practices that are surprising and privacy invasive, it can destroy trust and reputation. Often practices are unexpected because they were not communicated clearly or conspicuously. For example, in 2019, multiple companies producing smart speakers and smart assistants were criticized because they had employees listen to and manually annotate people's voice commands. While such manual annotation may be necessary to improve speech recognition, a statement in the privacy policy that “your data may be used to improve our services” does not properly convey that people might be listening to what you tell your smart speaker in the privacy of your home. To help build trust, organizations should communicate about privacy

in a clear and straightforward way that will be meaningful to users. Privacy communication does not just serve compliance purposes—it provides opportunities for organizations to communicate their efforts for protecting their users' privacy, which otherwise might be invisible to the user.

5.1.3.2 Providing Meaningful Choices and Controls

Besides communicating clearly about privacy, organizations should offer meaningful choices and controls. A user who fully understands an organization's practices but is not offered any meaningful way to control them may not have a positive view of the organization. On the other hand, privacy controls that enable users to manage their privacy settings in ways that align with their privacy preferences and needs provide a sense of agency and control. This can help foster trust in the organization's ability and intent to properly protect its users' privacy.

5.2 Privacy Decision-Making, Behavior and Concerns

Transparency and *user rights* are core concepts of privacy legislation and guidelines globally, ranging from the Organisation of Economic Co-operation and Development (OECD) privacy guidelines, to the U.S. Federal Trade Commission's (FTC's) fair information practice principles, to Europe's GDPR, and privacy legislation in many other countries.² While specific requirements may vary, companies that collect or process personally identifiable information (PII) typically have to be transparent about their data practices and to inform data subjects about their rights and options for controlling or preventing certain data practices. This is often known as the *notice and choice* model.

Given such transparency and respective choices, consumers are supposed to be able to make informed privacy and consent decisions. However, in practice, privacy decision-making is not quite as simple or straightforward. Understanding how people make privacy decisions and what shapes their privacy concerns is essential for being able to design usable and useful privacy interfaces that effectively make people aware of data practices and support informed privacy decision-making.

5.2.1 Privacy Preferences versus Behavior

The notice and choice model is based on rational choice theory: A rationally acting person ingests information about companies' data practices and uses this

information to engage in a risk-benefit analysis and make rational decisions about which services to adopt or which companies to trust with their personal information. Such decisions are assumed to be consistent with the person's privacy preferences in order to optimize their desired level of privacy. They are also assumed to be stable and consistent across decisions and time. This kind of rational decision-making about privacy is also referred to as the *privacy calculus*.¹⁰ However, in practice people's privacy decisions and behavior are rarely rational or predictable but rather highly context dependent and malleable.

5.2.1.1 Privacy Paradox

Even though research studies and surveys frequently find that people are concerned about their privacy and want to do more to protect their privacy,¹¹ people share copious personal details on social media,¹² express regrets about sharing too much information online,¹³ are frequently surprised by the data practices of services they use,¹⁴ and are often unaware of privacy controls and protections available to them.¹⁵

This contradiction of people being concerned and complaining about data practices while freely providing and sharing personal information is known as the *privacy paradox*: People express certain privacy preferences or intentions but act contrary to them.¹⁶ For example, people may be sensitive about sharing their health information, yet may use fitness trackers, smart watches or consumer genetic testing kits because they provide them insights on their health, even though by doing so, they also end up giving detailed health information to the companies behind those gadgets or services.

5.2.1.2 Self-Censorship and Chilling Effects

While people seem to be sharing information freely despite privacy concerns, research also suggests that people engage in self-censorship because of privacy concerns. For example, some people may opt not to share personal opinions, political leanings or certain updates about their lives online in order to avoid arguments or to manage their self-presentation.¹⁷

Increased awareness about invasive data practices may also cause *chilling effects*. For instance, Edward Snowden's 2013 revelations about the U.S. government's online surveillance practices have been linked to a significant decline in searches for terrorism-related topics (e.g., Al Qaeda, jihad, chemical weapons) both on Wikipedia and Google Search.¹⁸

5.2.2 Factors Affecting Privacy Decision-Making and Behavior

How can the privacy paradox, over-sharing, self-censorship, and chilling effects all exist at the same time? Table 5-1 distinguishes between a set of related yet distinct concepts regarding privacy decision-making, providing a lens through which to view and understand seemingly contradictory privacy behavior.

Table 5-1: Common Concepts in Privacy Decision-Making and Behavior

Concept	Nature	Description
Privacy attitude	Normative	The data subject's general predisposition regarding privacy
Privacy preference	Aspirational	What the data subject prefers to happen
Privacy concern	Hypothetical	What the data subject fears will happen
Privacy expectation	Anticipatory	What the data subject thinks will happen
Privacy decision	Intentional	What the data subject decides or intends to do
Privacy behavior	Factual	What the data subject actually does
Data practice	Factual	The data processing that actually occurs
Privacy harm	Factual	A negative impact of data processing on the data subject's privacy
Privacy regret	Retrospective	The data subject realizing behavior and expectations were harmfully misaligned

A person's *privacy preferences* are aspirational—they describe what the person would prefer to happen in a certain situation, which may be informed by one's general *attitudes* towards privacy, sociocultural norms, and prior experiences. *Privacy concerns* are privacy risks or potential *privacy harm* a person is aware of or worried about; they may range from minor concerns to worst-case scenarios. *Privacy expectations*—what data processing or privacy infringements a person anticipates will occur in a given situation—are shaped by the person's privacy preferences, concerns and awareness of data practices. Such expectations may be

consistent with the actual *data practices*, or may be inaccurate—either assuming a lower privacy risk than exists or expecting privacy risks that are unwarranted.

Privacy preferences, expectations and concerns all factor into a person's privacy decision-making process, both consciously and subconsciously. People rarely make fully rational privacy decisions in which they seek out all available information and optimize their decision to align with their preferences—indeed, in many situations, this would be quite time consuming and may not even be possible. *Privacy decisions* are subject to both external influences (e.g., incomplete information, context) and internal influences (e.g., bounded rationality, experience). As a result, a person's privacy decision in a given situation may not be a consistent reflection of their privacy preference or might even contradict them. The implementation of a privacy decision (*privacy behavior*) may further be affected by external factors, such as choice architecture, in the given situation. We discuss these factors in more detail next.

People experience *privacy regret* when they realize that their privacy behavior or the actual data practices of a system or an organization were misaligned with their privacy expectations in a way that negatively affected them. Data processing can negatively impact the data subject's privacy (*privacy harm*), especially when data practices and the data subject's expectations are misaligned. Sometimes people observe tangible harm, but often they are not aware of the harm. Privacy harms may also not manifest immediately but rather much later. For example, a person's social media posts made years ago as a college student on a long-forgotten social media service may be ingested by a data broker, which sells the information to a job-candidate vetting service, which in turn downgrades the person's job application, resulting in the person not being invited for a job interview. The person might never learn that not being invited to the job interview was a privacy harm.

In light of these many factors influencing privacy decisions and behavior, the often-observed misalignment between people's privacy preferences and actual behavior (the privacy paradox) is less surprising. In particular, *incomplete information, context and bounded rationality* affect privacy decisions and behavior in ways that can result in substantial deviations in a person's privacy-related behavior from their privacy preferences.¹⁹

5.2.2.1 Incomplete Information and Uncertainty

Informed consent and informed decision-making both assume that a person has fully considered all available information to make an informed decision. However, more often than not, people have to make decisions based on incomplete information. In the case of privacy, this might mean that a person is not aware of all data collection, data processing or data transfer practices associated with a transaction. This is particularly the case when information is seemingly collected for one purpose but also used for secondary purposes. For example, a navigation app needs the user's location information to display the correct part of the map and provide navigation support, but the app provider might also use location information to identify roads with traffic congestion or to infer where the user lives and works or what businesses they frequent.

Even if a person is aware of a data practice, they may not be aware of the associated privacy risks or implications. For instance, in the navigation app example, it may not be apparent to all users that inference of their home and work locations not only makes it easier to quickly navigate to those places but may also reveal information about their socioeconomic status or family situation, and that such information could negatively affect other parts of their lives, ranging from what advertisements are shown to them to what interest rate they are being offered on a home or car loan.

People may also have misconceptions about how their privacy is protected in a given context. They might assume that companies securely transfer and store data, but frequent data breaches show that is not necessarily the case. They might assume that they are protected by privacy law, limiting what data can be collected or how it can be used. In practice, legal privacy protections can vary substantially between countries and even between industry sectors in countries with sectoral privacy laws (e.g., the United States). This can lead to misconceptions such as the common assumption that when a website has a link to a privacy policy, it does not share information about its users with third parties, even though the existence of a privacy policy alone does not guarantee privacy-protective data processing.²⁰

Misconceptions may also exist in the other direction: Because of incomplete information or uncertainty about data practices, consumers may assume that a company or product is insecure or engaging in privacy-invasive practices, such as selling their information to third parties, even if it isn't. Thus, helping users develop an accurate understanding of data practices, privacy protections and privacy controls not only provides transparency about data practices but also creates awareness about the measures taken to protect privacy and limit data use,

as well as privacy controls and choices available to the user. In fact, research has shown that users may provide and share more information when they feel they have appropriate privacy controls to determine and adjust who has access to their information. This phenomenon has been dubbed the *control paradox*, as perceived control over privacy may lead to increased sharing, which in turn may increase privacy risks.²¹

5.2.2.2 Bounded Rationality

Generally, humans are limited in their ability and time to acquire, memorize and process all information relevant to making a fully informed and rational decision. Behavioral economists call this deviation from the ideal of a fully rational actor *bounded rationality*.²² To compensate for the inability and impracticality of considering all potential outcomes and risks, humans rely on heuristics in their decision-making to reach a satisfactory solution rather than an optimal one. However, decision heuristics can lead to inaccurate assessments of complex situations.²³ Rational decision-making is further affected by cognitive and behavioral biases—systematic errors in judgment and behaviors.

Bounded rationality also persists in privacy decision-making. Decision heuristics and biases have been shown to substantially affect people's privacy decisions and behavior.²⁴ Prominent decision heuristics and biases that can affect privacy decisions and behavior include the following:²⁵

- *Availability heuristic*—Due to uncertainty about privacy risks, people may look for other available cues to judge the probability of risks and guide their behavior. For example, rather than reading an online store's privacy policy, people rely on readily available cues, such as the store's visual design, the presence of a privacy policy, the vendor's reputation, or even just the company name to make judgments about the privacy risks associated with providing personal contact and payment information to the online store.
- *Representativeness heuristic*—People may perceive privacy intrusions as low-probability events because they rarely encounter privacy intrusions online. However, privacy intrusions, such as behavioral tracking and targeting, may occur frequently or continuously but may just not be visible to the individual.

- *Anchoring*—Available information creates a reference point for future decisions. For example, information or judgments about others' disclosure behavior informs how one reasons about one's own disclosure behavior.²⁶ Anchoring also manifests in ordering effects: Survey participants disclose more information when a survey starts with intrusive questions and gradually reduces in sensitivity compared with a survey that increases in sensitivity.²⁷
- *Loss aversion*—Individuals dislike losses more than they like gains. In the context of privacy, loss aversion helps explain why people report being concerned about companies collecting information about them but are reluctant to pay for better privacy protection (if it is offered).²⁸
- *Hyperbolic discounting*—Providing or sharing information often affords immediate gratification of some kind, e.g., the ability to use a needed app/service or social interactions (e.g., messaging or "likes"), whereas privacy implications and risks are often not immediate, hypothetical and shrouded by uncertainty. Furthermore, privacy considerations are rarely the primary motivating factor for wanting to use a service or to enter into a transaction. Thus, even if people claim to care about privacy, they may discount privacy risks in the moment in favor of immediate gratification.²⁹
- *Optimism bias*—People systematically underestimate the likelihood of being affected by a negative event. For example, even though people recognize that identity theft is a risk after a data breach, they underestimate the likelihood of personally having their identity stolen and, as a result, may not take sufficient protective action.³⁰
- *Status quo bias*—People have a general affinity for default choices. People often keep default settings even if they are privacy invasive, because they are not aware of the setting and/or its privacy implications, because of associated transaction costs (e.g., finding the setting, figuring out how it works, actual costs), or because it is assumed that the default settings are set to protect them.³¹

In practice, multiple such heuristics and biases can affect a person's decisions and behavior at the same time, further exacerbating inconsistencies in behavior and between privacy preferences and actions.

5.2.2.3 Context Dependence

Privacy preferences and concerns can vary from situation to situation. What information someone considers appropriate to share varies based on contextual factors, such as the nature or source of the information, the activity or transaction as part of which information may be shared, as well as the people involved. For instance, you might reveal more about your personal life to a colleague at an after-work event than at work; you adjust how and what you talk about with your friends depending on where you are and who else is around. At the same time, you may also discuss sensitive topics in public spaces, e.g., at a restaurant or on a train, even though others might overhear the conversation. Similarly, people might reveal personal details to a stranger on a plane, their taxi or rideshare driver, or their hairdresser as part of making small talk. Privacy preferences are highly contextual or, as Acquisti et al. state, “the same person can in some situations be oblivious to, but in other situations be acutely concerned about, issues of privacy.”³²

Privacy preferences and expectations are shaped and affected by contextual factors. Gary Marx argues that privacy violations can always be traced back to the breaching of one or more of the following boundaries:³³

- *Natural borders*, such as walls, closed doors, clothing, sealed envelopes and encryption protect information by limiting observation by others
- *Social borders* are assumptions or expectations of social norms about confidentiality and respect of one’s privacy, such as confidential relationships with doctors, lawyers or priests; the integrity and confidentiality of personal correspondence; trust in colleagues, friends and family members to not rifle through one’s personal effects; or the assumption that information is not retained longer than required or used for other purposes
- *Spatial or temporal borders*, such as physical distance or the passing of time, separate information from different periods or aspects of a person’s life
- *Ephemeral or transitory borders* are based on assumptions that certain interactions or communication only exist in the moment and are not recorded permanently

Each of these borders is increasingly weakened by advances in technology. The proliferation of smart home devices, most of which continuously exchange information with the manufacturer's cloud back end, weakens the reliability of natural boundaries to protect privacy. Social, spatial and temporal borders break down in the face of networked publics and social media. Context collapse—the overlapping and intermixing of previously delineated facets of one's life (e.g., family life, work, different circles of friends, hobbies)—is now a common phenomenon in online interactions, especially interactions over social media.³⁴ Assumptions of information being ephemeral or transitory run contrary to the vast digital traces people's interactions with technology create, as well as consumer tracking and profiling efforts by companies.

Helen Nissenbaum's framework of *contextual integrity* ties privacy expectations to context-dependent norms of information flow.³⁵ Information collection, processing and transmission practices that are in accordance with those norms are likely to be perceived as acceptable, whereas practices that do not follow those norms are perceived as privacy violations because they violate contextual integrity.

Contextual integrity can be used to analyze data practices for their appropriateness by identifying the contextual factors of a situation, the informational norms associated with them and whether an actual practice adheres to those norms or violates them. Context-relative privacy norms may be codified, e.g., in laws, rules or procedures, but frequently such norms are implicit as part of conventions, moral values and people's expectations of privacy.

As people go about their daily lives, they transition through many, sometimes overlapping contexts, and in doing so engage in a continuous and dynamic *boundary regulation process* to manage their privacy.³⁶ People's context-specific privacy preferences are affected by *external changes*, such as changes in context, actors, information or transmission principles, as well as *internal changes*, such as changing privacy attitudes, preferences, prior experiences or new knowledge. People make adjustments to their behavior in an attempt to negotiate an achieved level of privacy that aligns with their privacy preferences. As already discussed, this process is subject to uncertainty and bounded rationality, as well as external constraints, such as the inability to prevent a certain data practice.

An important aspect of this dynamic boundary regulation process is the intention to balance privacy preferences, expectations and achieved privacy. If the achieved privacy is less than what is preferred, a privacy invasion occurs. If the achieved privacy is more than desired, it results in social isolation. Thus, privacy

regulation is not just about keeping information private, but rather about finding—and helping users find—the desired balance between privacy and information sharing for a given context.³⁷ This pertains both to managing one’s privacy toward a data processor and managing information in contexts that involve interpersonal interactions. When multiple people or entities have access to certain information, privacy management becomes a collective task that relies on the negotiation of mutually acceptable privacy rules about further processing or sharing of that information. *Private information turbulence*—misalignment of or disagreement about what is appropriate or invasive—occurs when such rules are violated or have not been effectively negotiated in the first place.³⁸

5.2.3 Manipulation of Privacy Behavior

Privacy-related decisions and behavior, such as what information someone is willing to disclose, can be manipulated through system design. A system’s *choice architecture*—what and how choices are presented to a user—has a substantial impact on users’ information disclosure and sharing behavior. Dark patterns are interface or system designs that purposefully exploit cognitive and behavioral biases in order to get people to behave a certain way regardless of whether that behavior aligns with their preferences. Some common privacy dark patterns include the following:³⁹

- *Default settings*—Default settings frequently exploit status quo bias. Most people do not review or change default settings, which in the case of privacy means that opt-out choices, such as opting-out of targeted advertising or marketing use of contact information, are rarely exercised even though people may not like those practices. Similarly, preselecting a certain option nudges users towards accepting that choice.
- *Cumbersome privacy choices*—Making it more difficult, arduous and lengthy to select a privacy-friendly choice compared with a privacy-invasive one deters users from privacy-friendly options.
- *Framing*—How a choice is described and presented can affect behavior. An emphasis on benefits, a de-emphasis on risks or the presentation of trust cues may lead to people making riskier privacy decisions than they would with a neutral presentation of choices.⁴⁰

- *Rewards and punishment*—Users are enticed to select a service’s preferred choice with rewards or are deterred from privacy-friendlier choices with punishments. For instance, granting a mobile app access to location data may enable certain services that are not available otherwise. Rewards and punishments are particularly problematic when they are not directly related to the choice, i.e., when choosing a privacy-friendly option poses stronger constraints than is necessary. Rewards, in particular, such as a meter that goes up when you add more information to your online profile, leverage the human need for immediate gratification.⁴¹
- *Forced action*—Users must accept a data practice or privacy choice in order to continue to a desired service (hyperbolic discounting), regardless of whether they actually agree with the practice. They are forced to act against their privacy preference.
- *Norm shaping*—Other people’s observed information-sharing behavior, say, on a social media service, shapes the perceived norms of information sharing on a platform and individuals’ own disclosure behavior. For example, a controlled experiment showed that people who see more revealing posts in the feed of a photo-sharing service tend to consider such photos more appropriate and are more likely to share more revealing information themselves than those who see less revealing photos.⁴² Thus, the algorithm for determining news feed content, which might purposefully highlight or suppress certain content to activate such anchoring effects, has a lot of power in steering users’ behavior, regardless of whether the displayed posts are actually representative of user behavior.
- *Distractions and delays*—Even small distractions or delays can create a distance between awareness of privacy risks and behavior that can cancel out the effects of a privacy notice.⁴³

Such manipulations of privacy behavior are unethical, as they constrain people in their self-determination and agency over their privacy. Moreover, manipulations of privacy behavior further exacerbate the misalignment between people’s privacy preferences, expectations and their actual behavior and the data practices to which they are subject.

Furthermore, tricking people into agreeing to data practices that do not meet their preferences or behaving in ways that go against their privacy concerns and preferences can result in increased regrets by users. Such regrets may intensify the perception that their privacy has been violated, and ultimately can negatively affect people's adoption of technology or result in outcries in social media as well as bad press.

Even if your intentions are good, the user interface of your privacy notices and controls can unintentionally mislead your users, cause surprise about unexpected data practices, get people to agree to data practices or set privacy settings in ways that do not align with their preferences, or accidentally promote oversharing resulting in regret. Therefore, UX design plays an important role in making privacy information and controls understandable and usable.

5.3 Usability and User Experience

The key to creating usable privacy notices and controls is UX design, sometimes also referred to as customer experience design. Well-designed privacy interfaces support users in forming an accurate understanding of a system's data practices and provide them with the right tools and support for managing their privacy. Depending on the size of your organization, you might have dedicated UX designers, UX researchers or UX engineers who are responsible for the user-facing side of a product, or your organization might outsource some UX research or design work. However, UX professionals are not necessarily trained or experienced in designing privacy user experiences. Therefore, it is important for privacy professionals to work together with UX professionals to ensure that privacy requirements and users' privacy needs are taken into account. It is useful for privacy professionals to be aware of the UX design process and general methods in order to make informed decisions about when and how to work with UX professionals on the design of privacy interfaces. Even just posting a privacy policy on your website is a UX design decision, and too often one that is made without properly considering the UX and how it impacts the user.

5.3.1 What is UX?

UX design has one major goal: designing systems and processes to meet users' needs. This includes fostering understanding of how the system works, building systems that are useful for people and ensuring that people are able to use the system as intended. Ideally, people should also enjoy using the system.

5.3.1.1 Usability

At the core of UX is usability, i.e., how easy a system or interface is to use. ISO 9241-11 defines usability as the “extent to which a system, product or service can be used by specified users to achieve specified goals with effectiveness, efficiency and satisfaction in a specified context of use.”⁴⁴ Jakob Nielsen, one of the pioneers of human-computer interaction, distinguishes the following components that determine a system’s usability:⁴⁵

- *Learnability*—How easy is it for users to accomplish basic tasks the first time they encounter the system?
- *Efficiency*—Once users have learned the system, how quickly can they perform tasks?
- *Memorability*—When users return to the system after a period of not using it, how easily can they reestablish proficiency?
- *Errors*—How many errors do users make, how severe are these errors and how easily can they recover from the errors?
- *Satisfaction*—How pleasant is it to use the system?

Consider, for example, the task of unsubscribing from a promotional email. The effectiveness of an email opt-out mechanism would be determined by whether a person can find the opt-out in the first place and whether they can understand what steps to undertake to complete the opt-out (learnability), execute those steps in the right order and achieve the intended result (success/errors) and later check or change their setting (memorability). Efficiency would be determined by the number of steps and the amount of time it takes to complete the opt-out. Satisfaction would be determined by the perceived ease or difficulty of completing the task and whether it was a pleasant and supportive process or one that was arduous and confusing.

5.3.1.2 Utility

A concept closely related to usability is utility.⁴⁶ Utility is about functionality. Does the system support users in satisfying their needs and accomplishing their goals? An interface can be very usable, but it is useless if it does not align with users’ actual needs and expectations.

For example, the unsubscribe mechanism might be easy, fast and pleasant to use (great usability), but only gives users the option to unsubscribe from all of an organization's communication or none of them, even though some users might want to unsubscribe from marketing emails but continue receiving important notifications about their account activity. As a result, people may not use the very usable opt-out mechanism because it is not useful for them.

A system with high utility meets the exact needs of users. A useful system has both good utility and good usability.

5.3.1.3 User Experience

As the discussion of utility and usability suggests, usability is important but, on its own, often not sufficient to characterize what constitutes a good or bad experience for users. UX design takes a more holistic perspective that places users and their needs at the center and “encompasses all aspects of the end-user's interaction with the company, its services, and its products.”⁴⁷ This might include the actual product; terms of service and privacy policies tied to the product; the product's purchase, unboxing and sign-up experience as well as customer support, documentation, manuals, privacy settings and so on.

A system's UX encompasses the extent to which a system meets users' needs (utility), usability, aesthetics and simplicity, and the joy, emotional reactions and fulfillment a system provides. UX design therefore integrates user interface design, engineering, visual design, product design, marketing and branding as well as business models and related considerations.

5.3.2 User-Centered Design Process

Good UX design does not just happen. Similar to engineering practice, UX design follows a principled and systematic process. At the center of the design process are users—typically a set of anticipated user populations and stakeholders. While different methodologies follow slightly different steps, generally the user-centered design process consists of three phases—research, design, evaluation—with projects typically going through multiple iterations of the user-centered design process to iteratively refine designs and better align them with user needs.

5.3.2.1 UX Research: Understanding Context of Use and User Needs

UX design starts with research and analysis. The goal of this phase is to understand the context in which a certain system and its UX will operate and function. An important aspect of this is identifying a system's user populations

and then analyzing their specific characteristics and needs as they relate to both the system and its context of use. This often includes learning about people's mental models of systems or processes in order to identify and understand potential misconceptions.

Common user research methods and activities include semistructured interviews, diary studies, contextual inquiry, survey research and usability tests (with the current system or related competitors). User research is typically complemented by desk research, involving competitive analysis, heuristic evaluation and review of relevant academic research and literature. Personas, scenarios, user journeys and affinity diagrams are tools used for synthesizing findings into higher-level insights that can be used and referenced throughout the design process.⁴⁸

Based on the research findings, the requirements for the UX design are defined. This includes specifying which user needs and goals have to be addressed to be successful, including respective metrics. Design requirements have to consolidate potentially contradicting user needs, business goals and regulatory requirements.

Conducting UX research is quite comparable to conducting a privacy impact assessment (PIA), despite the different focus (user versus privacy). Like a PIA, UX research requires planning to ensure specific activities are generating relevant information and are comprehensive.⁴⁹ Both a PIA and UX research require identification and consultation of relevant stakeholders. A PIA includes mapping out a system's information flows; UX research involves mapping out users' journeys and interactions with a system. A PIA assesses and identifies privacy risks; UX research identifies user needs and usability issues. A PIA provides recommendations for mitigating privacy risks; UX research produces design requirements to meet user needs and mitigate usability issues. The parallels between PIAs and user-centered design go even further. Just as a PIA is not just "done," but is better understood as a continuous or recurring process in which PIA documentation is updated and adapted according to changes to the system, UX research is also iterative, accompanying development and deployment of systems. These similarities provide opportunities for integrating UX research aspects into PIAs and vice versa.

5.3.2.2 UX Design: Meeting User Needs

The requirements identified in the research phase inform the design phase. UX design aims to find and create solutions that meet user needs, as well as other

system requirements. Good UX design takes users' cognitive and physical characteristics into account. UX design is highly iterative and user centric. Solutions are developed in an iterative process that aims to put potential solution designs into the hands of users early on and throughout the refinement process in order to ensure that designs are properly supporting user needs. Designs typically start with very basic prototypes, often sketches and paper prototypes, which look far from the final product but make it possible to simulate and test interaction flows before investing time, effort and resources in further development. This facilitates creative exploration of the solution space—including unconventional, novel ideas—in relatively little time and at low costs. The fidelity of prototypes increases throughout the design process as ideas from different designs get consolidated or trimmed away based on feedback gained through user testing, until the final design is implemented fully.

Good practice in UX design is to leverage established best practices—design patterns—when possible and appropriate. Design patterns encapsulate reusable solutions for common UX challenges. Leveraging established design patterns or language can substantially ease learnability because people are already familiar with a certain interaction. However, design patterns are patterns rather than off-the-shelf solutions, which means they are concepts that typically have to be adapted to a system's specific context of use and UX requirements.

While we discuss elements of privacy design patterns in Section 5.4, unfortunately, we don't yet have a good set of tested design patterns for privacy interfaces that we can recommend. There are certainly many design patterns for privacy interfaces that are widely replicated across many products and websites, but some of these actually suffer from fundamental usability problems.⁵⁰ For example, many cookie banners ask users to accept a website's use of cookies without actually offering a choice. This could actually be considered a forced-action dark pattern. Better cookie banners either provide an informational notice without requiring user consent or offer users a meaningful choice. So, while we suggest looking for privacy patterns that you might replicate, choose your patterns carefully. Once you have designed and tested a privacy interface within your organization, try to use the same pattern when a similar interface is needed for other products and services your organization offers.

5.3.2.3 UX Evaluation: Validating That User Needs Are Met

Throughout the design process, designs should be iteratively evaluated with current or future users of a system. As such, the design phase and the evaluation phase are closely interlinked. The purpose of UX evaluation is to validate that the system's designs and prototypes indeed meet the user needs and requirements identified in the research phase. Evaluation methods are often the same or similar to the user research methods mentioned in Section 5.3.2.1, with the addition of A/B testing and production deployment of developed solutions. UX validation may include both quantitative assessments (e.g., log file analysis, interaction times, success rates) and qualitative assessments (e.g., perceived usability, perceived cognitive load, joy of use, comprehension), with both providing important insights to evaluate and further refine designs and potentially also the design requirements. We discuss common user research methods for evaluating privacy user experiences in Section 5.5.

5.3.3 Value-Sensitive Design

An important realization for designing privacy interfaces and user experiences that meet people's privacy needs and address their privacy concerns is that privacy constitutes a *value*, i.e., privacy is considered important by individuals and society, but also competes with other values and norms. In addition, privacy preferences, concerns and expectations are not uniform but rather context-specific, malleable and fraught with uncertainty, as we discussed in Section 5.2. Privacy can therefore be more difficult to specify as a design requirement and measure whether a design achieves the desired privacy compared to other usability or UX aspects, such as efficiency or error rates.

Value-sensitive design is a design approach that accounts for ethical values, such as privacy, in addition to usability-oriented design goals.⁵¹ Value-sensitive design methods help to systematically assess the values at play in relation to a specific technology and respective stakeholders and the ways the technology might meet or violate those values. They also help to iteratively develop designs that are sensitive to and respectful of those values. Friedman et al. recommend the following steps to integrate value sensitivity into design practice.⁵² As you will note, many of the steps are also relevant in PIAs as well as in UX research and design in general. The difference is that value-sensitive design places at the center of the design process not just people and their needs but also values important to them.

1. *Clarify project values*—What values do a project and the project team aim to support? What do privacy, informed consent, transparency or other privacy-related values mean for this project and team?
2. *Identify direct and indirect stakeholders*—A value-sensitive approach to stakeholder analysis aims to identify stakeholders directly impacted by technology (e.g., data subjects, data processors) as well as those that are indirectly affected (e.g., bystanders incidentally recorded by the sensors of a self-driving car passing by or other household members that may use a smart home device or be recorded by its sensors). Privacy needs and expectations may also vary based on stakeholders' characteristics and group identities. Individuals may be part of multiple stakeholder groups.
3. *Identify benefits and harms for stakeholders*—What are the potential benefits or harms for each identified stakeholder group? Benefits and harms should be considered on an individual, societal and environmental level. This analysis can include both conceptual as well as empirical investigations, e.g., semistructured interviews or other user research methods. In interviews, a simple but illuminating practice is to ask why when people express positive or negative sentiment about a system or design in order to more deeply understand their reasoning and motivations or concerns.
4. *Identify and elicit potential values*—Identified benefits and harms are a starting point for identifying corresponding values. This mapping can be straightforward, e.g., an unanticipated data-sharing practice affects privacy. But they can also be indirect, e.g., surveillance practices may have a chilling effect, curtailing people's self-expression.
5. *Develop working definitions of key values*—Define what constitutes a specific value and spell out the components that make up the value in order to operationalize it for a specific context. For instance, informed consent is composed of, on the one hand, discovery, processing and comprehension of information and, on the other hand, voluntariness, comprehension and agreement.⁵³ Rather than inventing new definitions for important values, it is useful to rely on prior definitions and research in the literature to more deeply understand a value and its components.

6. *Identify potential value tensions*—Values do not exist in isolation and frequently conflict with each other as well as other requirements. However, value tensions rarely pose binary tradeoffs. (For example, “you can have security or privacy, but not both.”) Rather, they may place constraints on potential designs. (For example, “how might we satisfy the security requirements while also respecting the privacy requirements.”)
7. *Value-oriented design and development*—Value-sensitive design focuses not just on the design of technology but rather on the co-evolution of technologies and social structures. In the case of privacy, this means considering the interplay of technological solutions, regulatory solutions and organizational solutions and their social impact when trying to resolve identified value tensions. The implications of technologies on values can be investigated early on in the design process through value-oriented mockups and prototypes that are evaluated or potentially deployed with users. The ability to iteratively address and refine technologies and user experiences to align with stakeholders’ values can be supported by building flexibility into the technical architecture so necessary changes can be made easily.

5.4 Design of Privacy Interfaces

While the previous section provided an overview of UX design more generally, we now focus on the design of user experiences specifically for privacy. We first discuss prevalent types of privacy interfaces, followed by common usability issues of privacy interfaces, before describing principles for usable privacy design and a process for implementing those principles in design and engineering practice.

5.4.1 Types of Privacy Interfaces

From an information-processing perspective, the data life cycle consists of multiple phases: data collection, data processing, data retention, data transfer and data deletion.⁵⁴ From a UX perspective, these phases need to be accompanied with privacy interfaces that implement established privacy principles and user rights:

- *Transparency* about data collection, processing and sharing practices, as well as privacy and security measures taken to protect user data, and information about who in an organization is responsible for privacy oversight and how to file complaints. Transparency is typically addressed through privacy notices.
- *Choice* regarding (nonessential) data collection, processing and sharing practices, including secondary uses of data. Choice is typically provided through consent interfaces.
- *Control* over the use and exposure of data, e.g., to other users on a platform. User control is typically provided through privacy settings.
- *Access* to the data an organization has about the user in order to facilitate inspection, correction, deletion and export of that data. User access is typically provided via privacy dashboards.

Next, we provide an overview of common privacy interface types for each category.

5.4.1.1 Privacy Notices

Privacy notices aim to provide transparency about an organization's data practices and other privacy-related information, such as measures taken to ensure security and privacy of users' information. Privacy notices need to be provided to users—typically before a data practice takes place—and explain what information about data subjects is being collected, processed, retained or transferred for what purpose. Laws and regulations in different countries may pose specific transparency requirements in terms of what information needs to be provided, when it needs to be provided and how it needs to be provided. Privacy notices can take different shapes and forms:

- *Privacy policies*—Privacy policies are probably the most common type of privacy notice. A privacy policy holistically documents an organization's data collection, processing and transfer practices and also includes other privacy-related information. While most common, privacy policies are also among the most ineffective privacy user interfaces. Most people do not read privacy policies, as they have little incentive to do so. Privacy policies are typically long documents. Aleecia McDonald and Lorrie Faith Cranor estimated in 2008 that

reading all privacy policies of the websites an American internet user visits in a year would take about 244 hours.⁵⁵ Thanks to the proliferation of mobile apps, wearables and internet of things (IoT) devices since then, the number of privacy policies one would have to read and the actual time required for that are likely much higher today. Privacy policies further require advanced reading skills because of heavy use of legal jargon and often remain at an abstract level, especially when organizations use a single privacy policy to cover a multitude of services or products with many different data-processing practices. Thus, even if a user reads a privacy policy, they may not understand how data about them is actually collected, used or transferred in the context of a specific transaction. Finally, the effort required for reading and understanding a privacy policy is rendered useless by the fact that most privacy policies also contain provisions that the policy may be updated at any time.⁵⁶

- *Informational privacy resources*—Organizations often complement privacy policies with informational resources that summarize or highlight important data practices and aim to communicate the value and role privacy plays for the organization to its users. These resources serve the purpose of educating users about how their data is used and protected, as well as what privacy choices and settings are available to them. The content should be consistent with the organization's privacy policy but presented more concisely and often with visual aids or videos to make the information more accessible and easier to understand for a general audience. While better at informing users about data practices than privacy policies, these informational privacy resources still need to be actively sought out by users, which means most users won't see them.
- *Integrated privacy notices*—Privacy policies and privacy information resources are often decoupled from a user's interactions with a service and product—a user must seek them out to learn the pertinent information. Integrated privacy notices are instead presented in a relevant part of the service or product's UX. For instance, an account creation process may include short explanations about how requested information (e.g., email address) will be used and protected.

- *Privacy indicators*—Privacy information can also be conveyed via privacy indicators—cues in a user interface or on a device. Privacy indicators are particularly useful for conveying either the state of a data practice (e.g., an LED indicating when a video camera is recording) or the state of a privacy setting (e.g., a small icon in a social media site’s message posting interface indicating the post’s audience).
- *Privacy reminders*—Organizations may choose or be required to remind people about data practices they are subject to. For instance, financial institutions in the United States are required to provide an annual privacy notice to their customers under the Gramm-Leach-Bliley Act (GBLA). However, privacy reminders can also take a more proactive shape and make users aware of data practices they had previously agreed to or nudge them to check and update their privacy settings.

5.4.1.2 Consent Interfaces

User consent is an established way to legitimize a data practice. To be valid, consent needs to be a freely given, specific, informed and unambiguous indication of an individual’s agreement.⁵⁷ This means consent should pertain to a single data practice rather than be bundled together with consent for multiple data practices. Individuals need to be provided with sufficient information to make a consent decision, and it must be equally possible to agree or disagree. Consent interfaces typically need to enable users to provide or deny initial consent as well as check their consent status and possibly change it, which may mean revoking consent.

Consent interfaces generally support two kinds of consent: opt-in consent and opt-out consent. In the case of an opt-in, consent is obtained before a data practice takes place, i.e., the data processing the consent request pertains to does not start until the data subject explicitly consents. In the case of an opt-out, the respective data practice occurs as if the data subject had provided consent. A person’s use of a service or product is assumed to be an expression of agreement with the respective data practices. An opt-out then is an option for the individual to stop a certain data practice. Opt-in consent can serve to make users aware of a data practice for which they have a choice they might otherwise not be aware of, and they might want to object to. Opt-outs carry the risk of a user not being aware of a data practice and being surprised or angry when they find out the data practice had been going on without their awareness or agreement.

Consent interfaces can be implemented in many different ways—most privacy settings are also consent decisions of some kind—but there are some general types of consent interfaces that can be distinguished:

- *Integrated consent prompt*—Opt-in consent requests are typically integrated into a system's UX. Examples include requests to accept a product's terms of service or privacy policy before use, or checkboxes to opt into data use for nonessential purposes during account creation. Requiring users to uncheck prechecked boxes to opt out of a data practice during setup is a discouraged dark pattern. The risk is that people may overlook the option or see it as a recommendation and continue without properly considering it. While this might mean that more people keep a data practice (i.e., they do not uncheck the prechecked box), it is useless as a documentation of informed consent because it cannot be guaranteed that a user made an actual decision to keep the practice.
- *Decoupled opt-out*—Opt-outs might be decoupled from a user's interaction with a system, e.g., when they are described in a privacy policy, or in separate advertising or cookie policies, or when they are part of privacy settings. The challenge with decoupled opt-outs is that people have to seek them out and may not be aware of their existence or of the data practice they pertain to.
- *Integrated opt-out*—Certain opt-outs are integrated with the UX. One example is an Unsubscribe link in email communication. The advantage of integrated opt-outs is that they are present in the context in which people might need and want to use them.
- *Delegated consent*—Sometimes consent is not directly obtained by the first party but rather by a different service or platform provider. One example for delegated opt-in consent is a mobile permission. Apps do not directly ask users for access to resources on the smartphone (e.g., location, contacts, text messages), but instead programmatically declare required permissions to the smartphone. The smartphone operating system then generates a respective permission prompt, asking the user to accept or deny a permission request. An advantage of this model is that the presentation and functionality of permission requests are

consistent regardless of the underlying app, which facilitates learnability of the interface and reduces cognitive load. An example of delegated opt-outs are opt-outs for ad targeting, which are often provided by third parties—either a specific ad company (e.g., Google, Facebook) or an industry association such as the Digital Advertising Alliance (DAA), Network Advertising Initiative (NAI) and the Interactive Advertising Bureau (IAB). A challenge with such delegated opt-outs is that the first party has little control over the usability of the consent mechanisms.

5.4.1.3 Privacy Settings

Privacy settings typically aggregate the privacy choices and controls available to a user of a given product or service in one place. Privacy settings are typically available from within account settings or referenced in the privacy policy, ideally both. Privacy settings interfaces can integrate a multitude of controls, including controls to inspect and change previously made consent decisions, settings to regulate the granularity of information, settings to regulate the visibility of one's information (e.g., what information is public, visible to friends, or private), and settings to manage the sharing of information with users or with other apps or services. We distinguish two types of privacy settings:

- *First-party privacy settings*—Privacy settings commonly refer to settings made available by the service provider or product manufacturer. The service provider controls what settings are made available, how they are made available and how they are integrated with the overall UX.
- *Platform privacy settings*—What information an app or service has access to is also often controlled by the privacy settings of the respective platform used to provision the service, such as a mobile operating system for mobile apps, a smart assistant platform for voice-based skills or actions, or a web browser. Platform privacy settings may be specific to a certain service or app (e.g., app X can access location; app Y can't) or may allow users to set general privacy settings (e.g., whether third-party cookies are accepted or tracking protections are enabled).

5.4.1.4 Privacy Dashboards

Privacy dashboards typically give users access to the data an organization has about them. This may be in the form of activity timelines, data summaries or

access to the actual data. Privacy dashboards should further provide support for other mandated user/ data subject rights, such as enabling users to correct data or request rectification of inaccurate data. Users should further be able to export their data as well as delete some or all of it.

Often, privacy dashboards not only facilitate data access, edit, deletion and support but also include all of an organization's privacy settings, and possibly privacy information resources and privacy policies, in order to create a single destination for users for all things privacy.

5.4.2 Common Usability Issues of Privacy Interfaces

While privacy interfaces for transparency, control and support of different user rights exist, many privacy interfaces still fail to help people make informed decisions with respect to the collection and processing of their personal information.⁵⁸ This is problematic not just for consumers but also for companies, as it may lead to users being surprised by unexpected data practices and dissatisfied by frustrating user experiences, and may foster general distrust in the company. Many usability problems of privacy interfaces can be traced back to several common issues.

5.4.2.1 Conflating Compliance and User Needs

Frequently the creation of privacy interfaces, including privacy notices, controls and privacy settings or dashboards is driven by the goal of achieving compliance with respective legal and self-regulatory requirements. As a result, privacy interfaces, and in particular privacy policies, are created in a way that will demonstrate compliance to regulators. In turn, regulators such as data protection authorities or consumer protection agencies rely on an organization's privacy notices and controls in their investigation and enforcement of regulatory compliance.⁵⁹ Unfortunately, users' privacy needs are often neglected in the process. Privacy notices are written by lawyers for lawyers, resulting in lengthy privacy policies or terms of service that are necessarily complex because the respective laws, regulations and business practices are complex.⁶⁰ In addition, organizations may create policy statements that are purposefully vague to create leeway for potential future uses of collected data, which makes notices even more difficult for users to understand.⁶¹ Privacy notices are not written as tools for creating awareness and transparency for users. Similarly, privacy controls are implemented according to regulatory requirements, but may not be sufficient to

meet the actual privacy control needs of users. Yet, those privacy notices and controls are treated as if they were providing transparency and control to users.

Designing for users' privacy needs does not require neglecting or ignoring regulatory requirements. Rather, it is essential to distinguish between the information that must be provided for compliance reasons and the information that users might need to make informed privacy decisions—they are sometimes the same, but often not. As users are unlikely to read privacy policies, relevant information needs to be provided to them through additional means in order to reduce surprise. Similarly, privacy controls and choices required by regulation must be provided in a usable and useful manner. Furthermore, additional privacy controls may be necessary to ensure that users can control privacy in alignment with their context-specific privacy preferences and expectations.

5.4.2.2 Lack of Meaningful Choices

Too often, users are forced to make impossible choices: Either accept everything in the terms of service and privacy policy or do not use the service or product. Such take-it-or-leave-it choices are bad for both consumers and organizations. Consumers might accept the terms of service or privacy policy but are unlikely to have read or understood them. This fosters surprise about unexpected data practices and privacy harms, which in turn can result in outcries on social media and in the press and lead to consumer distrust, damaged reputation and possibly investigations by regulators for deceptive practices or violations of transparency requirements if it is not a reasonable expectation that users would be aware of a practice.

Additionally, forcing users to accept data practices they disagree with, because they otherwise cannot use a service or product, fosters digital resignation.⁶² If you rely on consent as the legal basis for processing, it is important to ensure that consent is specific, informed and freely given.

5.4.2.3 Poor Integration with UX

Privacy notices and consent prompts are often shown at inopportune times, without regard for the user's primary task. Providing users with all privacy-relevant information when downloading an app or signing up for a service is common practice, but futile from a UX perspective. When a consumer decides to download an app or sign up for a service, they do so because they want to use the app or service, and anything delaying use—such as asking to accept a long privacy policy or configuring privacy settings—is likely to be dismissed or accepted

quickly without much scrutiny. Privacy management is almost always a secondary task, which means privacy interfaces need to be designed to blend in and augment the primary UX rather than blocking it.

In addition, repeated exposure to seemingly irrelevant privacy notices or dialogs results in habituation. This means that people dismiss the notice or prompt automatically without its content even registering in their cognitive processing system.⁶³

5.4.2.4 Poor Discoverability

Often privacy notices, opt-outs and other controls are decoupled from a system's primary UX. This dissociation of privacy interfaces from a system has severe usability consequences. Without being exposed to privacy interfaces as part of the system's UX, users require substantial digital literacy and an advanced mental model of how a certain technology works in order to anticipate a system's data practices and what privacy information or privacy controls might be available to them.⁶⁴

Furthermore, if a user wants to seek out privacy information or controls, they must know where to look. However, where privacy information and controls are provided is not consistent across services and products. Some might have account settings that include privacy settings, some might have separate privacy settings, others might have privacy settings but also provide additional privacy-related controls under other settings or in policy documents.⁶⁵ As a result, people may have to look in multiple places, search in the wrong places, or even worse, assume that they found all relevant privacy controls without realizing that additional controls are provided in another place.

5.4.2.5 Confusing Interfaces

When privacy interfaces are not designed carefully, they may be confusing and suffer from usability issues that could have been uncovered through user testing. Some common issues include wording or signage (e.g., an icon) that is confusing or ambiguous, privacy choices and opt-outs whose effects are unclear, or privacy controls that behave contradictory to expectations.⁶⁶

5.4.3 Privacy Design Principles

Following a set of privacy design principles and a systematic process makes it possible to design privacy user experiences that are usable, useful and meet users'

needs for information and control while also being compliant with privacy laws and regulation.⁶⁷

5.4.3.1 User Centric

Privacy legislation, privacy technology and privacy management are centered on information. What information flows and practices are permissible? How can information be protected, de-identified or processed to enhance privacy? What information does the organization collect, store, process and transfer, as well as what safeguards and processes are in place to ensure accountability and compliance with internal and external policy? Designing usable and useful privacy user experiences, however, requires a shift in focus: While information is of course still relevant, the focus needs to be on users and their interaction with a system's privacy interfaces. Privacy design must be user centric to be effective.

A UX is successful when it meets users' needs. For privacy interfaces, that means first understanding what the privacy needs of different stakeholders and user populations are, both their informational needs and their control needs. Identifying those needs requires investigating and understanding people's privacy preferences, concerns and expectations with respect to a specific information system. It further requires understanding users' mental models of the technology, its data practices and its privacy protections. Such insights help determine what information may be necessary to help users make informed decisions or create awareness of otherwise unexpected data practices. Furthermore, it is important to understand users' privacy control needs in terms of managing privacy toward the organization and toward other users on multiuser platforms or to regulate the visibility of their data.

When designing privacy notices and controls, it is helpful to be aware of how humans receive, process and react to information. Wogalter's communication-human information processing (C-HIP) model explains how humans perceive, process and react to warnings.⁶⁸ The Human in the Loop (HILP) model adapts the C-HIP model for security (and privacy).⁶⁹ These models describe a similar progression of steps in human information processing, which, if not considered properly, can present a hurdle for a privacy interface in achieving its goal. The key steps of the information processing model as they pertain to privacy are as follows:

1. *Communication*—Human information processing begins with how information is communicated to a person. A user interface aims to communicate something to the user, e.g., certain privacy information or the availability of a privacy control. This communication may be affected by environmental stimuli that compete with the privacy interface; for example, the user's primary task or other interface elements or system features may make it difficult to notice the privacy control. Interference may prevent users from even receiving the communication; for instance, being distracted by other activities, people nearby, or ambient noise when privacy information is shown (e.g., in a video) may cause a user to miss it.
2. *Attention*—Users need to notice the privacy interface before they can process it. Thus, effective communication has to get users to switch attention to the privacy interface and maintain attention long enough to process it. Environmental stimuli, interference and characteristics of the communication (how it is presented and delivered) affect attention switch and maintenance. Habituation also impacts attention, i.e., the effect of a stimulus decreases over time. For example, presenting too many or repetitive privacy notices to users will likely result in them ignoring the notice content.
3. *Comprehension*—Once users notice an interface, they need to understand its purpose. What is it there for and what is it communicating to the user? A person's digital literacy and privacy awareness may affect how they interpret provided privacy information or controls. Are they aware of the privacy risks and implications associated with the options presented in a consent prompt? How accurate is their mental model of the system's data practices and privacy protections?
4. *Intention*—Based on a user's comprehension of the interface, they may or may not be motivated to act upon the provided information or engage with a privacy control. The user's intention is further affected by their privacy preferences, concerns and expectations.
5. *Behavior*—As discussed in Section 5.2, actual privacy behavior can deviate from the user's respective privacy decision. Usability issues with

the presentation of choices as privacy settings and controls can result in users making errors.

User-centric design of privacy interfaces should consider how to best support each of these phases. When trying to analyze usability issues of privacy interfaces, it is further helpful to isolate which information processing phases are affected in order to address them properly.

5.4.3.2 Relevant

Privacy policies are ineffective at supporting privacy decision-making because they aim to provide a complete and comprehensive overview of an organization's data practices. While such an overview is useful for regulators and researchers to analyze an organization's data practices, it holds little value for most consumers. Consumers are asked to complete a complex cognitive task in trying to map a policy's abstract descriptions of data practices to the specific context and transaction in which they are engaging with the respective organization.

To be useful for privacy decision-making and behavior, privacy information and controls need to be relevant to the user's specific context or transaction. For example, for someone visiting a news website for the first time, there is very little use in reading the news site's privacy policy completely. At this point, it would not be relevant to them how the news site uses contact information provided during account setup, how financial information provided when signing up for a subscription is processed and secured or what data is transferred when one enters into a sweepstakes the news site might offer together with a marketing partner. Instead, when visiting the news website without an account, it would be most relevant to the user whether the news site tracks what articles are being read, how that information is used (e.g., for site analytics, ad targeting), whether and which other third-party trackers are present on the news site and whether there is an option to opt out of such tracking. However, finding these pieces of information in a privacy policy is tedious, because the information is often organized around data practice categories (e.g., collection, use, sharing) rather than common types of interaction contexts (e.g., news reading without account, account creation, site use with account, subscription, sweepstakes).

While organizing information in a privacy policy according to typical user contexts can be helpful, rather than hoping that users might find the relevant statement in the privacy policy and then arrive at the accurate interpretation of

the statement, the information or controls that are relevant to a particular context should be provided within the respective UX. This does not mean that every part and step of a system's user interface should be covered in privacy policy text. Instead, relevant information and controls should be easily accessible from within a context and organized according to the steps in user journeys typical for different user populations.

Furthermore, the information and controls provided to users should support their understanding of specific data practices. Rather than providing abstract descriptions, privacy notices should be explicit about what information is specifically being collected, processed or shared in a given context or transaction, why this data practice is necessary and how it benefits the data subject (if at all), and what controls are available regarding the practice. Ideally, privacy notices and controls would not just be specific to a data practice but also to the individual user. For example, Harbach et al. proposed improving mobile permission dialogs by including personal examples from the user's phone of what an app would gain access to if a request were granted (e.g., a location request would show the current location, a photo access request would show thumbnails of a random selection of the user's photos).⁷⁰

Users should also be informed about potential privacy risks associated with certain data practices. While it might seem counterintuitive to emphasize risks associated with one's system—organizations like to highlight the benefits of their products, not associated risks—openly communicating risks can have multiple advantages. First, some users might be thinking of risks anyway, but may overestimate them. Open risk communication can help users calibrate their risk assessments. Second, users who are not aware of the risks might be surprised and angry if they find out about the risks later or are affected by them. Open risk communication can help mitigate surprise and help shape user's mental model of a system. Third, openly communicating risks is also an opportunity to actively communicate the protective measures in place to mitigate the risk and protect the user's privacy.

5.4.3.3 Understandable

When presenting privacy information or providing privacy controls, it is important that the information and controls are understandable by the users they are targeting. This UX best practice is starting to find its way into privacy regulation. For instance, the GDPR requires that “any information and

communication, where processing is addressed to a child, should be in such a clear and plain language that the child can easily understand.”⁷¹

In practice, understanding privacy policies frequently requires advanced reading skills. In 2019, as part of their Privacy Project, *The New York Times* analyzed the privacy policies of 150 popular websites and apps.⁷² They found that most analyzed policies required college-level reading skills. To put this into perspective, they compared the reading skills required for privacy policies with those of popular books. Most of the analyzed policies required higher reading skills than are necessary for understanding Stephen Hawking’s *A Brief History of Time*—a book about the space-time continuum. Some policies even exceeded the reading level required to understand Immanuel Kant’s *Kritik der reinen Vernunft* (*Critique of Pure Reason*)—a seminal work in Western philosophy. Privacy policies are also too long to be useful for consumers. A longitudinal analysis of the 500 most popular websites in each EU member state (over 6,750 websites in total) found that privacy policies were on average 3,044 words long after the GDPR went into effect in May 2018— 42 percent longer than in 2016 when the GDPR was ratified.⁷³

Clearly, users cannot be reasonably expected to fully read the privacy policy of each service, website or app they use. Instead, by focusing on providing user-centric information that is relevant to a user’s specific context, transaction or activity, the provided information can be much shorter and more specific, and thus also be more understandable. Such information would complement the privacy policy rather than replace it, which would also mean the privacy policy could be written specifically for regulators and privacy experts without negatively affecting users.

User-centric privacy notices, such as integrated privacy notices and informational privacy resources, should be written in simple language that is understandable without advanced reading skills, avoiding legal and privacy jargon. For reference, in healthcare, it is recommended that patient educational materials should be written for sixth- to eighth-grade reading skills.⁷⁴ The readability of documents, including privacy notices, can be tested with online readability checkers, such as Readable.com.

An important aspect in achieving understandable privacy notices and controls is to find the optimal level of abstraction that best aligns with users’ privacy needs. For example, cookies and cookie consent notices (commonly known as cookie banners) have received significant attention because of European legislation.

However, providing notices about cookies places the emphasis on the data collection mechanism, whereas people tend to make decisions based on the purposes of data practices. People may not care about cookies specifically, but they might care whether they are being tracked regardless of the specific tracking technology, suggesting that the consent notices may be more effective if they focused on the purposes of cookie use.

5.4.3.4 Actionable

To be useful, information needs to be actionable.⁷⁵ It is typically not advisable to give users a privacy notice without an associated action or choice they can take. While privacy information can support users in making more informed privacy decisions, as well as help correct potentially misaligned mental models or expectations, without something to do with that information, there is not much point in the increased awareness. Users have little incentive to engage with provided information unless there are also options for them to realize their privacy decisions. Therefore, privacy information and privacy controls should go hand in hand whenever possible.

The choices offered also need to be meaningful. Asking users to accept a privacy policy that contains many different data practices is not a meaningful privacy choice. Rather than providing users with agency over their privacy, it asks them to either not use the system or accept even if they disagree with statements in the privacy policy.

Instead, choices should not be bundled, and any kind of feature limitations due to the user's choice should be constrained to the immediate context of that choice. A reasonable example of this is mobile permissions in recent mobile operating systems. Users are presented with a concise prompt when an app wants to access a phone resource for the first time (e.g., location, contacts, photos). Users have the option to allow or deny the request and can continue to use the app even if they select "deny," possibly with the exception of certain features. Ideally, a privacy choice or prompt asks users to make a meaningful decision by providing them with options to choose among. Prompts that ask for confirmation only increase the risk of habituation—users clicking the prompt away without reading it—which in turn makes it difficult to interpret their action as an expression of freely given and informed consent.

5.4.3.5 Integrated

Privacy information and controls should be integrated with a system's primary UX rather than added on. Relevant information should be provided at points in a system's UX where users actually make privacy decisions, or where it might be important to make users aware of data practices or privacy risks in order to help them develop an accurate mental model of the system and its information flows. Similarly, privacy controls and indicators (e.g., to see and control a social media post's audience) should be available at interaction points when they matter (e.g., when writing the post).

Whenever possible, privacy interfaces should use the same interaction methods as the system's primary UX. This ensures that interacting with privacy interfaces feels natural in a system's context and is as easy as any other user interaction with the system. For example, when designing privacy controls for a voice-controlled system such as a smart assistant, privacy controls like "mute" should also be available as voice commands, because the user otherwise needs to make a shift in interaction modality (walk to device and press a physical mute button instead of speaking to the device) that deviates from their typically interaction with the system and may therefore be rarely used.⁷⁶

Furthermore, privacy information and controls that are integrated into the UX can be more concise—both in terms of presented information and choices—than privacy policies and privacy settings because they can rely on the user's interaction context to contextualize the presented information for the user. The proper integration of privacy interfaces into the overall UX can help prevent overloading users with information or presenting privacy prompts at inopportune times.

However, while integrated privacy interfaces are important, a system should still provide a privacy policy, informational privacy resources, privacy settings and privacy dashboards in a centralized place so that users (and regulators) can gain a more comprehensive overview of data practices or verify and adjust their privacy settings in a central place when necessary.

5.4.4 Privacy Design Process

To put the privacy design principles into practice, it helps to follow a systematic privacy design process. We discuss a general process that combines UX, PIA, and value-sensitive design.⁷⁷ This process consists of six steps:

1. *Build on privacy assessment, privacy management and privacy engineering practice* to systematically identify a system's user rights and transparency

requirements

2. *Identify users and their privacy needs* by identifying stakeholders and eliciting their privacy expectations and privacy concerns as well as their privacy information needs and privacy control needs
3. *Identify unexpected data practices*, which are those that users are unaware of or might be surprised by, to help prioritize which data practices and controls to highlight
4. *Integrate privacy interfaces into system's UX* by determining which privacy notices and controls are most relevant to a user at which points in the UX
5. *Leverage the available design space* for privacy notices and controls to develop user-centric privacy interfaces that work within a system's constraints
6. *Conduct user testing* to evaluate the usability and usefulness of developed privacy interfaces

Next, we describe each step in detail and provide practical guidance. The process can and should be adapted to the needs and circumstances of your organization, systems and users.

5.4.4.1 Build on Privacy Assessment, Privacy Management and Privacy Engineering Practice

The essential precursor for designing usable and useful privacy user experiences is a solid understanding of the system's information flows and data practices, as well as the associated privacy implications. Organizations should be conducting PIAs, risk assessments and compliance checks (with internal policies and external regulation) as part of their internal privacy programs. Such assessments can provide a comprehensive overview of a system's data practices. The recommendations resulting from a PIA may include proposed changes to data collection practices, opportunities for data minimization or a requirement for opt-in consent for a certain data-sharing practice. Data minimization helps reduce the risk of using data in ways that deviate from users' expectations—you cannot misuse data you do not collect or retain. Diligent data minimization can further reduce the number or complexity of data practices that need to be communicated to users.

PIAs and compliance checks can also help systematically identify the user rights and transparency requirements pertaining to the system, which are important for the privacy design process. The outcome of a PIA is typically internal documentation of information flows, data inventories and a comprehensive privacy policy for a product or the organization. While the privacy policy is likely not read by users, it can serve as input for designing user-centric privacy notices and controls. Importantly, PIAs and the privacy policy are just the starting point for designing user-centric privacy interfaces.

Considering the privacy implications of a system and associated transparency and privacy control needs early on in a system's development also provides an opportunity to consider and improve constraints the system might pose for privacy interfaces. For example, recognizing that a smart home camera is collecting potentially sensitive information, the device designers may decide to include a recording indicator and a physical lens shutter in the device's hardware design rather than trying to provide notices and controls solely through software at a later stage.

5.4.4.2 Identify Users and Their Privacy Needs

A common part of PIAs is the identification and consultation of stakeholders whose privacy may be potentially impacted by a system. This can be combined with identifying a system's different types of users and eliciting their privacy expectations and privacy concerns as well as their privacy information needs and privacy control needs. For the design of privacy user experiences, it is important to distinguish at least three groups of users:

- *Primary users* are a system's intended audience. The primary user would make the decision to use a certain system and complete an enrollment process (e.g., account setup or configuration wizard) and would be able to configure the system. This may include activating or consenting to certain optional practices (e.g., activating face recognition for a smart home camera), opting out of certain practices (e.g., analytics), and adjusting privacy settings. For websites and mobile apps, the primary user would be the person using the browser or downloading the app; for IoT devices, it would be the person setting up the device.
- *Secondary users* are other people who may use a system in addition to the primary user. Secondary users might be aware of a system and even

actively use it, but they may have an incomplete or inaccurate mental model of the system and its data practices and less control over it compared with the primary user. Examples of secondary users would be a child using a parent's smartphone to play a game or stream a video, or a household member using a smart speaker that's associated with the device owner's account or a smart thermostat that has been configured by someone else. Secondary users may need to be informed about data practices, or even offered controls, in addition to and in ways different from the primary user.

- *Incidental users* might inadvertently and unwittingly become data subjects of a system's data collection and processing. For example, a smart door lock might collect information about all family or household members, including guests.⁷⁸ House guests may be required to use a smart speaker to operate smart lights in the house.⁷⁹ Doorbell cameras, drones or self-driving cars might incidentally record people passing by. Social media and mobile applications enable users to share information with and about others, e.g., by uploading a geotagged photo of someone else without their knowledge. Incidental users may not always be identifiable by a system, which constrains the potential means for providing privacy notices and controls to them.

Depending on the system, other or additional user groups may need to be considered. There may also be specific regulatory requirements for data collection, notice and user rights regarding protected user groups, such as children.

System designers and privacy professionals need to understand how the privacy of each identified user group may be affected by the system. Often a system's user groups are affected by the same data practices. For example, a smart home device may record the same sensor information about the primary user and other household members. However, sometimes user groups may be affected by different data practices, or certain groups may only be affected by a specific data practice. For example, a smartphone's data practices affect mainly the primary user and possibly secondary users, whereas incidental users may only be affected if they are being recorded by the device, for instance, when a primary or secondary user takes a photo or video.

Next, it is important to understand each group's privacy preferences, concerns, expectations, mental models and control needs regarding the system and its data practices. This information can be gained by conducting user studies, which we discuss in more detail in Section 5.5, and potentially through reviewing academic literature that has investigated privacy preferences of specific user groups in specific contexts.

5.4.4.3 Identify Unexpected Data Practices

A particular focus when seeking to understand users' mental models and privacy preferences should be to identify which of the system's data practices people are unaware of and might be surprised about. Knowledge about unexpected practices helps determine what information and controls need to be presented more prominently in the UX. Data practices that are consistent with the transaction context (and therefore with the user's expectations) might not require immediate notice. However, practices that are unexpected or violate the transaction context should be highlighted. For example, Gluck et al. studied which of a fitness watch's data practices people expected. One finding was that almost all participants (94 percent) expected the watch to record steps, but only 31 percent expected the watch to also record location information. Recording steps is a key purpose of such a device and may not need to be specifically highlighted, whereas collection of location data was unexpected for many, indicating a need for user-centric privacy notices focusing on this aspect.⁸⁰ Making people aware of unexpected practices and ideally asking for consent (opt-in) reduces surprise and can potentially increase user trust.

Making users aware of an unexpected data practice is also an opportunity to explain the reasons for the practice, its benefits and the associated privacy risks.⁸¹ It also provides an opportunity to communicate what measures are put in place to limit associated privacy risks and protect user privacy. Privacy and security engineering often happens under the hood—privacy UX design is an opportunity to make concrete the care and effort an organization puts into privacy and data protection.

5.4.4.4 Integrate Privacy Interfaces into System's UX

Once the information has been gathered about the system's data practices, its user groups and the practices that might be more or less expected by different user groups, the next step is to decide when and where to integrate privacy notices, consent prompts and other privacy interfaces into the system's UX. Showing lots

of information and controls at once in a single interface is rarely effective. Instead, the goal is to map specific privacy information and controls onto those points in the system's UX where they are most relevant to the user and where an opportunity exists for the privacy interface to gain the user's attention. Such privacy interfaces can be more concise and require less interpretation by the user because they are integrated into the user's interaction with the system, which therefore makes them less disruptive. This might mean providing certain information and controls at multiple interaction points and with varying levels of detail.

The level of detail provided in a specific notice or control must be appropriate for the respective context and user group. However, notices and controls can be *layered*. A short notice may highlight a practice, fact or control to gain the user's attention and provide a link to additional information or more controls, which in turn might consist of multiple layers that users can reveal and explore as needed. In UX design, this design pattern is called *details on demand*—providing an overview or summary first, with options for users to retrieve details.⁸² Thus, rather than trying to provide a single notice or control that does everything, it's better to craft a privacy UX that is composed of many complementary privacy notices and controls at different levels of detail tailored to the respective user group and context.

A *privacy UX* combines privacy interfaces shown at different times, using different modalities and channels, and varying in terms of content and granularity in a structured approach. With such an integrated and multilayered approach, individual users still receive information and choices for data practices that pertain to them but won't be confronted with data practices that are irrelevant for them until they are using a respective feature of the system. Users should still have the option to read the full privacy policy and explore all privacy settings whenever they want.

Deciding what information or controls to include in a brief integrated notice presented as a top layer is a crucial aspect at this stage, because most users will not seek out more detailed privacy interfaces, even if they are referenced and only a click away. Thus, if such a short notice does not capture all relevant aspects of a data practice, it may hide information and impair transparency.⁸³ This is especially an issue for unexpected data practices. Therefore, privacy interfaces should be hierarchically structured in such a way that the initial notice, prompt or control either already captures the main aspects of the data practice or serves primarily to

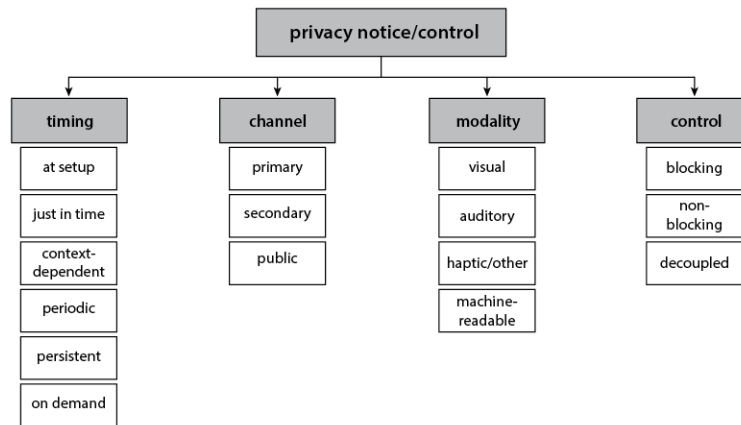
draw the user's attention to more expressive privacy interfaces. For instance, Almuhimedi et al. showed that just notifying smartphone users about how often their location has been accessed by different apps is an effective nudge for users to check and adjust their permission settings.⁸⁴ In contrast, a privacy policy that only shows section headings and requires users to click each heading to read the text is a bad design, because it requires users to make many more clicks and prevents keyword search.⁸⁵ A more effective approach in this context would be to summarize a section's key data practices and respective choices and provide a "learn more" button to reveal a detailed description.

Creating and maintaining a privacy user experience composed of multilayered privacy interfaces does incur engineering and management costs, but it has multiple benefits. Users' privacy needs and the system's data practices can be better aligned. Where user consent is required, this approach can yield properly informed consent. Reducing surprise and explaining privacy protections is likely to facilitate user trust.

5.4.4.5 Leverage the Available Design Space

Once it has been decided what information or controls need to be provided at which points in a system's UX, the next step is the actual design of the user-centric privacy interfaces. Multiple aspects can impose constraints on the design of the privacy user experience. A system has certain input and output modalities, which can affect how different user groups can or cannot be provided with privacy information or express their privacy choices.⁸⁶ For instance, many IoT devices have no screens or only very small ones, which may not be suitable for displaying privacy information or controls. However, a system and its context may also offer unconventional interaction opportunities for privacy interfaces. Identifying constraints and considering the full design space for privacy interfaces helps generate different design ideas for a privacy interface and identify viable solutions. Based on an extensive analysis of the design space for privacy notices and controls, Schaub et al. identified four design dimensions that should be considered in privacy interface design.⁸⁷ The design space with its main dimensions and their design opportunities is shown in Figure 5-1. We provide a short overview of each design dimension and respective key considerations.

Figure 5-1: The Design Space for Privacy Notices and Controls



Timing. The point in time at which privacy information or controls are presented to the user has a substantial impact on a privacy interface’s usability and utility. Users may ignore privacy interfaces shown at inopportune times, but may seamlessly interact with a consent prompt that appears exactly when it is needed. Timing is a key factor in ensuring that a privacy interface is relevant and aligned with users’ needs.

- *At setup* interfaces are often shown on initial use. However, only information and choices that are truly essential before use should be communicated at setup because users’ attention is typically focused on the primary UX at this point. Those privacy information and choices that must be presented at setup should be properly integrated into the setup process (e.g., a configuration wizard or account enrollment) in a way that provides value and meaning to users rather than nudging them to accept a privacy policy or terms of service they have not read.
- *Just-in-time* interfaces are shown in the same transactional context as the data practice they pertain to, which supports reasoning in the moment and means they can be specific and short, communicating only the most relevant information and choices.
- *Context-dependent* privacy interfaces are triggered by certain aspects of the user’s context.⁸⁸ For instance, being in physical proximity to an IoT sensor may cause the device to announce its presence (e.g., flashing an LED, beeping, sending a description of its data practices to the user’s phone). Other context factors might be someone accessing previously uploaded information or analyzing the user’s previous privacy settings behavior to warn about potentially unintended privacy settings. For

example, Facebook displays a message warning that it is about to post publicly when the user's last post was public, but they are typically not in the habit of posting publicly.

- *Periodic* reminders are useful to remind users about data practices that they agreed to previously and to renew consent if the practice is still ongoing, especially if the data practice occurs in the background, invisible to the user.
- *Persistent* privacy indicators are shown whenever a data practice is active. For instance, cameras often have lights to indicate when the camera is recording. Persistent indicators can provide an unobtrusive cue about especially critical data practices, but there's also a risk that the indicator will not be noticed.⁸⁹
- *On demand* privacy information and controls allow users to seek out and review privacy information or their privacy settings and opt-outs any time. On-demand interfaces should be made available in a well-known or easily findable location (e.g., a website should have a "privacy" subdomain or "/privacy/" folder and provide links to privacy controls from their privacy policy and in relevant menus).

Channel. Privacy interfaces can be delivered through different communication channels.

- *Primary channel* is the primary device or system the user is interacting with, such as a smartphone or computer. It is the system that is also primarily involved in the respective data practice, e.g., collecting, storing or processing the data.
- *Secondary channels* are useful when the primary system is too constrained in its input and output capabilities to provide for meaningful interaction with the privacy interface. Typically, a secondary channel presents information on a different device or in a different context. For instance, privacy information and settings for a fitness tracker or smart speaker might be available through a companion app or website. Emails, mobile notifications and even letters can also serve as secondary channels for privacy communication.

- *Public channels* can be used when the system's users or data subjects cannot be reached individually or are not known to the system. For example, public signs can be posted to inform about camera use or other sensing technology in a certain environment.

Modality. Privacy interfaces can be presented in different ways, with different interaction modalities.

- *Visual* privacy interfaces are most common. Privacy notices are presented as text or with icons and illustrations; privacy controls rely on graphical user interfaces. Many aspects can affect the usability of visual privacy interfaces, including color, font, white space, combinations of icons and text, the layout of interface elements and how the state of settings is conveyed. Privacy concepts are difficult to represent as icons only; combining icons with explanatory text or using more expressive visualizations and videos is preferable.
- *Auditory* privacy interfaces use sounds or voice to convey privacy information, or voice commands to enable privacy controls. Certain sounds can convey data collection practices very effectively. Take, for example, a camera's shutter click, which is being replicated on digital cameras and smartphones to indicate when a photo is taken, even though those devices may not have a physical shutter.²⁰ Support hotlines often play an auditory notice before one is being connected with a human operator. (For example, "This call may be recorded for quality assurance purposes.") Voice-based interfaces, such as smart assistants, should offer voice commands to control privacy.²¹
- *Haptic and other* modalities may also be leveraged as privacy interfaces. For instance, device vibration could be used as an indicator for data collection. Olfactory displays could be used to inform about privacy risks with different scents (e.g., lavender scent when visiting a privacy-friendly website; sulphur when visiting a privacy-invasive one). Ambient lights could also serve as privacy indicators. Could taste or skin conduction be used in privacy interfaces? Although it might not be immediately apparent how less conventional modalities could be used for privacy interfaces, the important point is to creatively explore even

unconventional design opportunities. Such exploration often leads to helpful insights that can inform practical solutions.

- *Machine-readable* specifications of privacy notices and controls enable the consistent presentation and aggregation of privacy information and controls from different systems or apps.²² Mobile apps have to declare their permission requests in a machine-readable format, and the mobile operating system is responsible for providing permission prompts and managing the user's consent. IoT devices that lack screens and input capabilities could broadcast their machine-readable privacy notices to smartphones of nearby users, which then present the respective privacy information and choices to the user.²³

Control. User choices, consent dialogs and privacy settings can be delivered in different ways that affect how users interact with them.

- *Blocking* privacy controls force users to interact with the privacy interface in order to be able to proceed. Blocking controls are useful when the user must make a choice, e.g., when consent is needed. However, how choices are presented affects whether the interaction is actually an expression of the user's preference, and so should be considered carefully. For example, presenting a complex privacy policy and providing only the options to accept or not use the app is not suitable for eliciting consent, as users are likely to click the warning away without reading. Preferable are prompts that are specific to a single data practice and provide options to both allow or deny the practice (e.g., mobile permission requests). All choices should be equally easy for the user to exercise.
- *Nonblocking* privacy controls do not interrupt the interaction flow but are rather integrated as user interface elements into the UX. For example, social media apps might provide an audience selector (e.g., private, friends, public) within the interface for creating a post. The control is available but does not have to be used and, at the same time, reminds the user of their current privacy settings.
- *Decoupled* privacy controls are not part of the primary UX. They are useful to provide the user the opportunity to inspect their privacy

settings or the data the system has collected about the user. Common examples are privacy settings and privacy dashboards. The advantage of decoupled privacy controls is that they can be more comprehensive and expressive than integrated controls; the downside is that users need to actively seek them out. Good practice is to provide decoupled privacy controls at a central place and then point to them from other, more concise privacy notices and controls where appropriate.

Frequently, multiple kinds of privacy notices and controls will need to be combined in a multilayered privacy user experience in order to properly address privacy information and control needs of a system's user groups.

5.4.4.6 Conduct User Testing

Privacy user experiences should be developed in a user-centric and iterative design process. Potential users should be involved in the design process from the beginning to account for user needs and to evaluate whether developed privacy notices or controls are usable. Privacy interfaces can be evaluated individually (e.g., by asking whether users understand a particular consent prompt), but the privacy user experience should also be evaluated holistically to gauge whether the combination of privacy interfaces appropriately serves users' needs and how the overall privacy user experience affects user trust in the system and its handling of users' personal information.

5.5 Usability Testing and User Studies for Privacy

Usability testing and user studies are a staple of both research and product development. Many books and guides have been written about how to conduct user studies. In this section, we provide a brief overview of the what, why and how of user testing and user studies as they relate to privacy. Our goal is to convey the importance of user studies for the design of privacy interfaces and give privacy professionals the necessary knowledge to effectively collaborate with UX professionals to design appropriate privacy studies. At least in the beginning, it is useful to work with UX professionals to ensure that a study actually tests what it is intended to test.

5.5.1 Why Test Usability?

Usability testing and user studies play several important roles: they can help to *assess needs, examine tradeoffs, evaluate designs* and *find root causes* of problems.

At the beginning of a design process, exploratory user studies can inform design requirements by providing feedback on which user needs are not being met by existing systems, as well as identify users' pain points and points of confusion. For example, before designing a privacy dashboard, a user study can help designers gain insights into what data users are most interested in seeing and at what level of granularity, as well as what types of controls users are most interested in exercising. Furthermore, designers may learn whether they are likely to satisfy most of their users with a single interface, or whether special interfaces might be needed for certain populations such as advanced or novice users.

Designers often face tradeoffs, and user studies can help provide insights into the pros and cons of each approach under consideration. For example, designers may realize that more granular privacy controls may increase the complexity of privacy choices. Through usability testing, they can gather data that will allow them to weigh the benefits of providing more granular controls against this added complexity. They can observe whether users actually take advantage of the added granularity to adjust settings that best match their personal privacy preferences, and they can observe how much longer it takes users to configure the controls and how often users give up because the controls are too complicated.

While following established usability guidelines and principles is likely to improve usability, the only way to be sure that a system is actually usable by its intended audience is to conduct usability tests with representative users. Thus, usability testing is critical for determining that a design actually meets its stated requirements. Before declaring that their privacy settings allow users to exercise privacy choices quickly and easily, organizations should run usability tests that assess whether users can find privacy settings (discoverability), use them to select the settings that match their personal preferences and understand the effect of the settings they selected.

Finally, after discovering a usability deficiency, usability testing is useful to determine the underlying cause of the problem, which will hopefully lead to solutions. For example, a company may receive complaints from users that their privacy settings are not working. After determining that there is no underlying technical problem, the company may conduct user studies to understand how users believe the privacy settings are supposed to work and where their mental models differ from what the system actually does. This should provide insights

that will allow the company to redesign its privacy settings to better align with users' expectations and privacy control needs or to communicate its current function more clearly.

5.5.2 What to test?

The details of what to test depend on the type of system being tested and where in the design process the test is being conducted. Exploratory testing early in the design process may be less about testing a user interface and more about understanding users' preferences, expectations, concerns and mental models. Once a prototype or complete interface has been developed, testing will generally focus on some or all of the following: awareness and attention, discoverability, comprehension, utility and behavior. However, testing may also investigate learnability, efficiency, memorability, errors, satisfaction and other aspects of UX and information processing phases discussed in Sections 5.3.2 and 5.4.3.

5.5.2.1 Preferences, Expectations, Concerns and Mental Models

System designers benefit from an understanding of users' privacy preferences, expectations and concerns, as well as their relevant mental models. As discussed earlier, preferences, expectations and concerns collectively impact a user's privacy decision-making. In turn, they may impact the types of privacy features and controls users seek out or the types of explanations or assurances that may be needed to ensure that users' concerns are addressed. Surveys, semistructured interviews, and focus groups can all provide insights into users' privacy concerns and needs in a specific context. It can be valuable to conduct these exploratory studies early in the design process.

Numerous papers in the academic research literature explore users' privacy preferences, expectations, concerns, and mental models generally, and in the context of specific technologies (e.g. behavioral advertising, health technology, IoT).²⁴ Such research papers can provide insights to inform the design of privacy interfaces, supplementing or possibly even eliminating the need for exploratory studies in a specific design process.

5.5.2.2 Awareness and Attention

As we discussed earlier in this chapter, following the C-HIP and HILP models, our first big hurdle is getting the user's attention. A just-in-time privacy notice, a privacy-related warning, or an ambient privacy indicator are all useless to users who don't notice them and don't shift their attention to them even briefly. User

studies can test whether users notice privacy-related notices, indicators or controls as they carry out a primary task. For example, Balebako et al. developed a mobile game app and created versions that differed only in when the privacy notice was presented to users. They asked study participants to test the app and answer questions about it, including questions about the privacy notice. The timing of the privacy notice presentation impacted whether users paid attention to and thus could correctly answer questions about the privacy notice.²⁵

5.5.2.3 Discoverability

Users who want to obtain information about data practices or make privacy choices need to be able to find the relevant interfaces. User studies can test the discoverability of privacy interfaces by evaluating whether users are able to find them at all, and if so, whether they can do so easily and efficiently.

5.5.2.4 Comprehension

Users may notice privacy indicators or find privacy interfaces, but they may not fully understand what they mean or how to use them. User studies can test comprehension of wording, symbols, interface components and controls, either in isolation or in the context of relevant tasks. Comprehension testing is often iterative, as designers identify comprehension problems and then test alternative wording or symbols.

Leon et al. conducted a study to determine what users understood about the AdChoices behavioral advertising icon and associated taglines. They found that comprehension rates were fairly low overall, but that some of the taglines they tested resulted in significantly better comprehension of the icon.²⁶

5.5.2.5 Utility

Privacy notices may be discoverable and comprehensible, but they may still leave out important information or settings that users want. For a privacy notice or settings interface to provide utility, it must be aligned with user needs. User studies can help assess the utility of privacy interfaces. Exploratory user studies may also help identify desired utility early in the design process. For example, Emami-Naeni et al. asked IoT device owners about their device purchase experience as well as their privacy and security concerns, and showed them early prototypes of privacy and security labels for IoT devices in order to explore whether the labels' information would address their needs. They found that participants were especially interested in information about their privacy choices

and wanted to see a summary rating as well as detailed privacy and security information.²⁷

5.5.2.6 Behavior

Users who discover and comprehend privacy indicators or warnings may still fail to act for a variety of reasons. Users may lack motivation, feel that their actions will be ineffective, have concerns that privacy protective steps will be inconvenient or result in their inability to use desired features or services, or be uncertain about what to do. Even those who do act may still make mistakes (e.g., press the wrong button or forget to press a final “submit” button), rendering their action ineffective. Likewise, users presented with privacy controls may also make mistakes as they attempt to configure the controls to match their personal preferences.

Ed Hutchins, Jim Hollan and Don Norman identified two common underlying challenges that lead to configuration mistakes: understanding the state of the system (*gulf of evaluation*) and taking action to accomplish a specific goal (*gulf of execution*).²⁸ When users fail to understand the current state of the system, their decisions about what settings to change are based on faulty assumptions. An example of the gulf of evaluation may be a user examining a mobile app privacy setting and incorrectly interpreting the on/off toggle, thus believing that location tracking has been turned off when in fact it is on. Likewise, when users fail to take the correct actions, they will not achieve their desired goals. Thus, a user who clicks an opt-out button on a website but does not scroll to the bottom of the page and click the submit button will fail to achieve the desired goal of opting out due to the gulf of execution.

User studies can test both whether users take privacy actions and whether they execute these actions correctly and effectively to achieve their desired goals. For example, Egelman et al. tested several approaches to providing privacy indicators on websites to determine which had the largest impact on user behavior. They found that privacy indicators had the largest impact on user behavior when they appeared alongside search results rather than on an interstitial or at the top of a web page.²⁹ In addition, when Leon et al. tested whether users could set up behavioral advertising opt-out tools to achieve a desired result, they found that most users struggled to configure these tools. They recommended a number of design improvements to address the problems they observed, including removing

jargon, adding more privacy-protective defaults and providing feedback about what the tool was doing.¹⁰⁰

5.5.3 How to Test?

UX professionals employ many different testing techniques that vary considerably in their cost, time and effort to complete, and types of insights and conclusions they produce. The most appropriate testing may depend on where you are in the design process, available time and resources, and the reason for testing. (For example, is testing being done primarily to improve an interface, to validate that an interface improves on a prior version or a similar product, to address regulatory requirements or to produce generalizable knowledge that can be published in academic research papers?)

5.5.3.1 Formative and Summative Evaluations

Usability evaluation can be categorized as either *formative* or *summative*.¹⁰¹

Formative evaluations are used to gain insights into which aspects of a prototype or product could use improvements, while summative evaluations are used to draw comparisons between a prototype or product and some benchmark (e.g., previous version, competing product). Generally, formative evaluations are small scale and focus on gathering rich qualitative insights that can be used to improve a product. They may be conducted iteratively, with several rounds of evaluation and design changes. Summative evaluations are generally conducted once the design team believes they are done or even after the product has shipped. They are generally larger studies that focus on gathering quantitative data. Summative studies are usually done to validate that the product (hopefully) meets the design requirements or performs better than a previous version or a competing product. Companies may make claims about their product on the basis of these results. For example, a company may be able to show that, as compared with the prior version of their product, in the current version they made it 50 percent faster for users to opt out of behavioral targeting or that they improved the percentage of users who could correctly identify the audience of their social media posts from 40 percent to 80 percent.

5.5.3.2 Small-Scale User Testing

Small-scale testing often provides a large bang for your buck, especially when used as part of a formative evaluation. Relatively inexpensive and quick, a test with even a handful of users can offer important insights about where a UX may need

improvement. Such testing may uncover user concerns and confusing interfaces and help to highlight differences in user attitudes and uses of a set of features or products. Small-scale user testing is often done in a lab, where an experimenter is able to directly observe how a user interacts with an interface and ask follow-up questions. Sometimes the experimenter may ask users to think aloud during a test and provide a real time, blow-by-blow commentary of what they are thinking and doing.¹⁰² This can be useful for capturing users' impressions as they try to understand and use a new interface. A related method is participatory design (or codesign), in which UX designers work together with affected stakeholders to identify and develop design solutions that better meet users' needs.¹⁰³ Rather than only eliciting needs from users and then evaluating new designs with them, users actively contribute to the design.

Small-scale testing can be quite useful for exploratory studies and for iterative design improvements. However, it generally cannot be used to validate a property of an interface or to make statistical claims.

5.5.3.3 Online Panels and Crowdsourcing Services

Recruiting large numbers of participants for a user study can be time consuming and expensive. Research companies recruit and maintain long-standing online panels of people who agree to receive emails recruiting them to participate in online surveys. Often these panels are comprised of people who have been screened for particular characteristics (e.g., age range, gender, occupation, geographic location). Researchers can pay to gain access to these panels to recruit participants for their studies. Some organizations maintain their own in-house panels, recruited from among users of a particular product or members of a university community, for example.

Crowdsourcing platforms such as Amazon Mechanical Turk allow people to sign up as workers and perform tasks for pay (generally at rates similar to minimum wage). These platforms can be a quick and inexpensive way to recruit participants for online surveys and other online user studies. If you use these services, you need to be especially careful about how you screen participants for any desired attributes and make sure that they don't just randomly click through your survey in order to get a quick payment. Some crowdsourcing services such as Prolific and CrowdFlower have been shown to deliver more diverse participants and achieve higher-quality survey results than the more popular Mechanical Turk.¹⁰⁴

While people often think about using panels and crowdsourcing services for surveys, they can also be used for online user testing. If you can make relevant parts of a user interface available through a web interface or an instrumented download, you can ask participants to perform tasks using your interface, collect data about how they use it and ask them questions afterwards. Services such as UserTesting.com specialize in online user testing of interfaces and user experiences.

5.5.3.4 A/B testing

A/B testing refers to tests where some users of a product or service see version A and others see version B. Generally, there are small differences between A and B and some metric to compare the two. For example, A and B may differ based on the placement of buttons, wording of menu items, colors, page layout, graphics or presence of a particular feature. This type of testing is not actually limited to two versions—companies may test many versions in a similar fashion. This testing may be done with users of a deployed service, who generally are not aware that they are part of a test.

In the context of privacy, A/B testing might be used to test the impact of interface changes on the time users spend engaging with privacy settings, or the percentage of users who change privacy settings or opt out.

5.5.4 Usability Testing Best Practices

Regardless of what type of usability test you choose, it is important to keep in mind some best practices. Here, we discuss testing metrics related to privacy, ways to provide a realistic context (sometimes using deception) and strategies for recruiting study participants. We conclude with a brief discussion of ethical considerations for usability testing and user studies.

5.5.4.1 Metrics

Before testing begins, it is important to identify a set of metrics that will be used. Metrics might relate to any of the areas discussed in section 5.2, including discoverability, awareness, comprehension, utility, behavior, satisfaction and other factors. For example, when testing a privacy tool or interface, metrics might include speed with which users complete a task, number of errors made while completing a task and accuracy of users when answering questions about the meaning of symbols or other interface components. Other relevant metrics include the percentage of users who exercise privacy choices and the types of

choices they make. Choosing the right metrics is important for conducting a meaningful evaluation free of blind spots: You don't want to end up in a situation where you conclude that an interface is wonderful because it performs well on a particular metric you tested, while in reality it would perform horribly on several other highly relevant metrics that you didn't evaluate.

Besides identifying metrics, you should identify desired outcomes or objectives that will allow you to determine whether design requirements have been met. For example, one objective may be to increase speed by a specific percentage over the prior version. Another objective may be to reduce the error rate.

Measuring the effectiveness of consent or opt-out interfaces poses challenges. The percentage of users who consent or opt out is not an indicator of the effectiveness of the interface. What we really want to capture is user awareness and comprehension of choices and whether they successfully select options that align with their personal preferences. One way to measure this would be to survey users shortly after they engage with a consent interface to find out what they believe they consented to (or chose not to consent to) and how this aligns with their preferences.

Metrics regarding user privacy behavior may be difficult to agree upon, especially when they conflict with other values in an organization. For example, a privacy objective may be to increase the number of users who visit the privacy settings page and make changes to their settings. However, when users choose more privacy-protective settings, companies may lose opportunities to profit from user data. Thus, meeting privacy objectives may appear to conflict with meeting revenue objectives. On the other hand, users who select privacy-protective settings might be less likely to trust the company or may decide to take their business elsewhere if such settings are not available. Companies need to consider these issues and resolve internal tensions between privacy and business goals.

5.5.4.2 Ecological Validity, Context and Deception

Ecological validity refers to the realism of the methods, materials and setting of a user study or usability test. The most reliable results are obtained through field testing. In field tests, designs are evaluated as part of a production system. The advantage of field testing is that new designs are tested under real-world conditions with real users rather than under artificial lab conditions with recruited participants. However, this also limits them to late stages of the design process,

when a design has sufficiently matured to be used in production systems without placing users at risk or creating liabilities for the organization.

In order to observe the most natural behavior from non-field-study participants, studies should be designed to mimic the real world as much as possible. Thus, when studies are conducted in a lab, the lab may be set up to look like an office or living room, complete with relevant props. For example, when evaluating privacy settings related to smart home devices, conducting the study in a homey living room setting may elicit from participants the types of privacy concerns and behaviors they would exhibit when using these devices in their own homes.

One component of ecological validity is the context in which user study tasks are embedded. If a study participant sitting in a usability lab is shown a privacy policy or any other privacy interface and asked questions about it without being provided with any context or reason for wanting to read the policy, the resulting usability evaluation will lack ecological validity. In this case, participants may pay more attention to the policy than they would in real life, when privacy is likely not their primary concern. Thus, comprehension testing without a real-world context is likely to result in a best-case scenario. Awareness and behavior testing are likely to be difficult to conduct meaningfully without embedding tasks in context.

To evaluate a privacy interface in context, participants should be given a relevant task. For example, participants might be told that a friend who is concerned about their privacy has asked for help in selecting an email service provider. Kelley et al. evaluated prototype “privacy facts” labels in an app store by asking participants to select apps for a friend. They compared the selections made by participants who either used an app store that had privacy facts labels or did not (as a control condition). They found that the privacy facts labels generally influenced which apps were selected. However, other factors also played a role, and sometimes had more of an influence than privacy.¹⁰⁵

Often context is provided by embedding tasks in a hypothetical scenario such as those mentioned above. However, participants may not be motivated to behave realistically in a hypothetical scenario, especially one in which they have to imagine a particular privacy or security risk. Sometimes study designs employ *deception* to increase ecological validity and observe how users behave when simulated privacy or security risk is introduced. For example, Bravo-Lillo et al. advertised a study evaluating online video games to crowd workers. Participants played and evaluated two games on real gaming websites not controlled by the experimenters. When they tried to play a third game, a simulated security warning

appeared in their browser window. The researchers collected data on how participants responded to the warning, and compared results across several warning designs.¹⁰⁶ In this case, there was deception about the purpose of the study and deception about the warnings, which were designed to appear real even though they were triggered by the experimenters. Deception was needed here to observe participants' natural behavior when confronted with warnings that they believed were real and not a part of the experiment. Section 5.5.4.4 addresses ethical issues to consider when conducting deceptive studies.

5.5.4.3 Testing with Representative and Specific User Populations

The strategy used to recruit study participants can have a large impact on results, especially when conducting small-scale studies. The age, gender, socioeconomic status, digital literacy, technical skills, geographic location, cultural background and other characteristics of study participants influence their behavior and responses to survey questions.

When conducting a user study, it is tempting to reach out to a convenient sample of coworkers, friends or family. This can be useful for pilot testing or to help detect problems with a product or service, and it is better than not doing any user testing. However, for the most useful evaluation, testing should be conducted with a representative sample of current or anticipated users of a product or service, or with specific populations that are of interest. Sometimes, it is helpful to recruit participants who represent particular types of users who may have special issues or represent extreme ends of a user spectrum. For example, aware that older adults are now flocking to social media services, a social media company may conduct a study to assess the privacy needs of adults over age 60 and how they use the service's privacy settings. Likewise, a company developing a privacy tool for extremely privacy-conscious users should test the tool with those types of users.

When recruiting participants for privacy-related user studies, it is advisable to not mention *privacy* in the recruitment materials. Privacy is a contentious topic that can lead to self-selection bias: People who already have an interest or opinion regarding privacy will respond, but those who prefer to ignore the topic won't. However, the latter group can often provide more useful insights. Good practice is to be vague about the specific focus of the study in recruitment (e.g. by calling it a "study on mobile app use").

Researchers sometimes conduct studies where they aim to recruit a random, representative, census-balanced sample of a country's population. This is

important if you want to make claims about the entire population of a country, such as “50 percent of all Americans believe ...” However, these studies tend to be expensive to conduct, and this type of sampling is generally not necessary for usability tests.

5.5.4.4 Ethical Considerations

Depending on legal requirements in your country, corporate or institutional policies, and the type of testing you are doing, you may or may not be required to have your study reviewed by an ethics board or institutional review board (IRB) prior to beginning a usability study. In the United States, research conducted at universities that involves identifiable individuals or their information and is designed to contribute to generalizable knowledge must be reviewed by an IRB. Research intended for publication is usually classified as contributing to generalizable knowledge, while research intended to guide development of a specific product or that is being conducted as part of a classroom exercise is usually not.

Even if not required to have a usability study reviewed by an ethics board or IRB, the user study team should still consider ethical issues in their study design. Studies should be designed to minimize the possibility of harm to participants and to treat participants fairly and with respect. If identifiable data is collected only to contact or pay participants, it should be separated from study data. Participants should be able to end their participation at any time and for any reason without penalty. The study team should generally obtain informed consent from participants prior to collecting their data. There are situations where this is not feasible because of concerns about priming participants or because the study uses previously collected data. In cases where consent is not obtained in advance or where deception is used, the study team should brief participants after the conclusion of the study.

While most usability studies related to privacy pose minimal risk to participants, there are some study techniques that have the potential to cause harm and should be considered carefully. For example, a privacy study that collects sensitive data from participants, perhaps to motivate privacy concerns, could increase the risk that participants’ information will be exposed. A deceptive study that simulates security or privacy warnings may leave participants uncertain about whether they may have actually been the victim of an attack or breach. These participants may suffer from added anxiety and may unnecessarily take steps to reset passwords,

cancel credit cards or otherwise recover from an attack that did not actually occur. Study teams should take precautions to minimize these and other harms; for example, by establishing data security protocols and debriefing participants at the end of a study session.

5.6 Summary

This chapter provided an overview of people's privacy decision-making processes and common usability issues in privacy interfaces. We presented design principles and a systematic process for creating privacy interfaces that can help avoid usability issues. We further discussed best practices for conducting usability testing and user studies related to privacy.

The design of usable privacy notices and controls is not trivial, but this chapter hopefully explained why it is important to invest the effort in getting the privacy user experience right—making sure that privacy information and controls are not only compliant with regulations but also address and align with users' needs. Careful design of the privacy user experience can support users in developing an accurate and more complete understanding of a system and its data practices. Well-designed and user-tested privacy interfaces provide responsible privacy professionals and technologists with the confidence that an indication of consent was indeed an informed and freely given expression by the user. Highlighting unexpected data practices and considering secondary and incidental users reduces surprise for users and hopefully prevents privacy harms, social media outcries, bad press and fines from regulators. Importantly, a privacy interface is not just a compliance tool but rather an opportunity to engage with users about privacy, to explain the rationale behind practices that may seem invasive without proper context, to make users aware of potential privacy risks and to communicate the measures and effort taken to mitigate those risks and protect users' privacy.

Endnotes

- 1 Article 29 Data Protection Working Party (WP29), Guidelines on Transparency under regulation 2016/679, adopted on 29 November 2017, as last revised and adopted on 11 April 2018, https://ec.europa.eu/newsroom/article29/item-detail.cfm?item_id=622227.
- 2 See for example Kirsten Martin, “The penalty for privacy violations: How privacy violations impact trust online,” *Journal of Business Research*, vol. 82, (2018), 103–116, <https://doi.org/10.1016/j.jbusres.2017.08.034>. See also Batya Friedman, Peter H. Khan Jr and Daniel C. Howe, “Trust online.” *Communications of the ACM* 43, no. 12 (2000): 34–40, <https://doi.org/10.1145/355112.355120>.
- 3 In 2019, the Federal Trade Commission (FTC) settled with Facebook on a \$5 billion fine and substantial changes to Facebook’s privacy management and compliance structure, <https://www.ftc.gov/news-events/blogs/business-blog/2019/07/ftcs-5-billion-facebook-settlement-record-breaking-history>.
- 4 Hana Habib, Yixin Zou, Aditi Jannu, Neha Sridhar, Chelse Swoopes, Alessandro Acquisti, Lorrie Faith Cranor, Norman Sadeh and Florian Schaub, “An Empirical Analysis of Data Deletion and Opt-Out Choices on 150 Websites,” *Fifteenth Symposium on Usable Privacy and Security*, (2019), <https://www.usenix.org/conference/soups2019/presentation/habib>.
- 5 Y. Wang, S. Komanduri, P.G. Leon, G. Norcie, A. Acquisti and L.F. Cranor, “I regretted the minute I pressed share: A Qualitative Study of Regrets on Facebook,” *Seventh Symposium on Usable Privacy and Security* (2011).
- 6 Y. Wang, P. Leon, A. Acquisti, L.F. Cranor, A. Forget and N. Sadeh. “A Field Trial of Privacy Nudges for Facebook,” *ACM SIGCHI Conference on Human Factors in Computing Systems* (2014).
- 7 Florian Schaub, Rebecca Balebako, Adam L. Durity and Lorrie Faith Cranor, “A design space for effective privacy notices,” *Proceedings of the Eleventh USENIX Conference on Usable Privacy and Security* (2015).
- 8 Katie Rogers, “Gmail Formally Adds ‘Undo Send’ Option,” *The New York Times*, June 23, 2015, <https://www.nytimes.com/2015/06/24/us/gmails-undo-send-option-can-help-end-email-embarrassment.html>.
- 9 Organization for Economic Co-Operation and Development (OECD), The OECD Privacy Framework, 2013, <https://www.oecd.org/internet/ieconomy/privacy-guidelines.htm>; FTC, *Privacy online: a report to Congress*, 1998, <https://www.ftc.gov/sites/default/files/documents/reports/privacy-online-report-congress/priv-23a.pdf>; European Parliament and Council, Regulation (EU) 2016/679 of the European Parliament and of the Council of 27 April 2016 on the protection of natural persons with regard to the processing of personal data and on the free movement of such data, and repealing Directive 95/46/EC [General Data Protection Regulation (GDPR)], 2016, <http://data.europa.eu/eli/reg/2016/679/2016-05-04>.
- 10 Tamara Dinev and Paul Hart, “An Extended Privacy Calculus Model for E-Commerce Transactions. Information Systems Research,” (2006) 17:1, 61–80, <https://doi.org/10.1287/isre.1060.0080>.
- 11 Pew Research Center, “Public Perceptions of Privacy and Security in the Post-Snowden Era,” November 2014, <https://www.pewinternet.org/2014/11/12/public-privacy-perceptions/>.
- 12 Alessandro Acquisti and Ralph Gross, “Imagined communities: Awareness, information sharing, and privacy on the Facebook,” *International workshop on privacy enhancing technologies*, (Springer: Berlin, Heidelberg, 2006), 36–58, https://doi.org/10.1007/11957454_3.
- 13 M. Sleeper, J. Cranshaw, P.G. Kelley, B. Ur, A. Acquisti, L.F. Cranor and N. Sadeh, “i read my Twitter the next morning and was astonished,” a conversational perspective on Twitter regrets, (2013),

- <https://doi.org/10.1145/2470654.2466448>; Y. Wang, "I regretted the minute I pressed share."
- 14 Ashwini Rao, Florian Schaub, Norman Sadeh, Alessandro Acquisti and Ruogu Kang, "Expecting the unexpected: Understanding mismatched privacy expectations online," *Twelfth Symposium on Usable Privacy and Security*, (2016), 77–96, <https://www.usenix.org/conference/soups2016/technical-sessions/presentation/rao>; Hazim Almuhammedi, Florian Schaub, Norman Sadeh, Idris Adjerid, Alessandro Acquisti, Joshua Gluck, Lorrie Faith Cranor and Yuvraj Agarwal, "Your Location has been Shared 5,398 Times! A Field Study on Mobile App Privacy Nudging," *Proceedings of the 33rd Annual ACM Conference on Human Factors in Computing Systems*, (2015), <https://doi.org/10.1145/2702123.2702210>; Joshua Gluck, Florian Schaub, Amy Friedman, Hana Habib, Norman Sadeh, Lorrie Faith Cranor and Yuvraj Agarwal, "How short is too short? implications of length and framing on the effectiveness of privacy notices," *Twelfth Symposium on Usable Privacy and Security*, (2016), 321–340, <https://www.usenix.org/conference/soups2016/technical-sessions/presentation/gluck>.
 - 15 Josephine Lau, Benjamin Zimmerman, and Florian Schaub, "Alexa, Are You Listening? Privacy Perceptions, Concerns and Privacy-seeking Behaviors with Smart Speakers," *Proceedings ACM Human-Computer Interaction* 2, CSCW, Article 102 (November 2018), <https://doi.org/10.1145/3274371>; Alessandro Acquisti, Idris Adjerid, Rebecca Balebako, Laura Brandimarte, Lorrie Faith Cranor, Saranga Komanduri, Pedro Giovanni Leon, Norman Sadeh, Florian Schaub, Manya Sleeper, Yang Wang and Shomir Wilson, "Nudges for Privacy and Security: Understanding and Assisting Users' Choices Online," *ACM Computing Surveys* 50, 3, Article 44 (August 2017), <https://doi.org/10.1145/3054926>; Yixin Zou, Abraham H. Mhaidli, Austin McCall and Florian Schaub, "'I've Got Nothing to Lose': Consumers' Risk Perceptions and Protective Actions after the Equifax Data Breach," *Symposium on Usable Privacy and Security*, USENIX Association, (2018), <https://www.usenix.org/conference/soups2018/presentation/zou>.
 - 16 P.A. Norberg, D.R. Horne, D.A. Horne, "The Privacy Paradox: Personal Information Disclosure Intentions versus Behaviors," *Journal of Consumer Affairs*, (2007), 41(1):100–126, <https://dx.doi.org/10.1111/j.1745-6606.2006.00070.x>.
 - 17 M. Sleeper, R. Balebako, S. Das, A.L. McConahy, J. Wiese and L.F. Cranor, "The post that wasn't: exploring self-censorship on Facebook," CSCW (2013), <https://doi.org/10.1145/2441776.2441865>.
 - 18 See Jon Penney, "Chilling Effects: Online Surveillance and Wikipedia Use," *Berkeley Technology Law Journal*, vol. 31, no. 1, (2016), 117, <https://ssrn.com/abstract=2769645>; Alex Marthews and Catherine E. Tucker, "Government Surveillance and Internet Search Behavior," (February 17, 2017), <https://ssrn.com/abstract=2412564>.
 - 19 Alessandro Acquisti, Laura Brandimarte and George Loewenstein, "Privacy and human behavior in the age of information," *Science*, 347, no. 6221, (2015), 509–514.
 - 20 Joseph Turow, Amy Bleakley, John Bracken, Michael X. Delli Carpini, Nora Draper, Lauren Feldman, Nathaniel Good, Jens Grossklags, Michael Hennessy, Chris Jay Hoofnagle, Rowan Howard-Williams, Jennifer King, Su Li, Kimberly Meltzer, Deirdre Mulligan and Lilach Nir, *Americans, Marketers, and the Internet: 1999-2012*, Annenberg School for Communication, University of Pennsylvania, (April 11, 2014), <http://dx.doi.org/10.2139/ssrn.2423753>.
 - 21 L. Brandimarte, A. Acquisti and G. Loewenstein, "Misplaced Confidences: Privacy and the Control Paradox," *Social Psychological and Personality Science*, 4(3), (2013), 340–347, <https://doi.org/10.1177/1948550612455931>.
 - 22 H.A. Simon, *Models of Man, Social and Rational: Mathematical Essays on Rational Human Behavior in a Social Setting*, (New York: Wiley, 1957).
 - 23 Kahneman, Daniel, *Thinking, fast and slow*, (Macmillan, 2011).

- 24 Acquisti, “Nudges for Privacy and Security: Understanding and Assisting Users’ Choices Online”; Acquisti, “Privacy and human behavior in the age of information”; Alessandro Acquisti and Jens Grossklags, “Privacy and rationality in individual decision-making,” *IEEE Security & Privacy*, vol. 3, no. 1, (January-February 2005), 26–33, <https://doi.org/10.1109/MSP.2005.22>.
- 25 For a comprehensive discussion of privacy-related decision heuristics and biases, see Alessandro Acquisti, Idris Adjerid, Rebecca Balebako, Laura Brandimarte, Lorrie Faith Cranor, Saranga Komanduri, Pedro Giovanni Leon, Norman Sadeh, Florian Schaub, Manya Sleeper, Yang Wang and Shomir Wilson, “Nudges for Privacy and Security: Understanding and Assisting Users’ Choices Online,” *ACM Comput. Surv.* 50, 3, Article 44 (August 2017), <https://doi.org/10.1145/3054926>.
- 26 Daphne Chang, Erin L. Krupka, Eytan Adar and Alessandro Acquisti, “Engineering Information Disclosure: Norm Shaping Designs,” *Proceedings of the 2016 CHI Conference on Human Factors in Computing Systems*, 587–597, (New York: ACM, 2016), <https://doi.org/10.1145/2858036.2858346>.
- 27 Alessandro Acquisti, Leslie K. John and George Loewenstein, “The impact of relative standards on the propensity to disclose,” *J. Market. Res.* 49, 2, (2012), 160–174.
- 28 Alessandro Acquisti, Leslie K. John, and George Loewenstein, “What is privacy worth?” *The Journal of Legal Studies* 42, 2 (2013), 249–274.
- 29 N. Jentzsch, S. Preibusch and A. Harasser, *Study on monetising privacy: An economic model for pricing personal information*, ENISA report, (2012), <https://www.enisa.europa.eu/publications/monetising-privacy>.
- 30 Yixin Zou, Abraham H. Mhaidli, Austin McCall and Florian Schaub, “I’ve Got Nothing to Lose: Consumers’ Risk Perceptions and Protective Actions after the Equifax Data Breach,” *Symposium on Usable Privacy and Security*, (2018), <https://www.usenix.org/conference/soups2018/presentation/zou>.
- 31 Acquisti, “Nudges for Privacy and Security.”
- 32 Acquisti, “Privacy and human behavior in the age of information.”
- 33 G.T. Murky Marx, “Conceptual waters: The public and the private,” *Ethics and Information Technology* 3: (2001), 157, <https://doi.org/10.1023/A:1012456832336>.
- 34 A.E. Marwick and danah boyd, “I tweet honestly, I tweet passionately: Twitter users, context collapse, and the imagined audience,” *New Media & Society*, 13(1), (2011) 114–133, <https://doi.org/10.1177/1461444810365313>; Jenny L Davis and Nathan Jurgenson, “Context collapse: theorizing context collusions and collisions,” *Information, Communication & Society*, 17:4 (2014), 476–485.
- 35 Helen Nissenbaum, *Privacy in Context: Technology, Policy, and the Integrity of Social Life*, (Stanford University Press, 2009).
- 36 I. Altman, “The Environment and Social Behavior: Privacy, Personal Space, Territory, Crowding,” 1975.
- 37 Leysia Palen and Paul Dourish, “Unpacking ‘privacy’ for a networked world,” *Proceedings of the SIGCHI Conference on Human Factors in Computing Systems*, (ACM, 2003), 129–136, <http://dx.doi.org/10.1145/642611.642635>.
- 38 Sandra Petronio, “Communication Privacy Management Theory,” *The International Encyclopedia of Interpersonal Communication*, (eds. C. R. Berger, M. E. Roloff, S. R. Wilson, J. P. Dillard, J. Caughlin and D. Solomon), <https://onlinelibrary.wiley.com/doi/abs/10.1002/9781118540190.wbeic132>.
- 39 This is a subset of the privacy dark patterns described in Forbrunder Rådet (Norwegian Consumer Council), *Deceived by Design: How tech companies use dark patterns to discourage us from exercising our rights to privacy*, (June 2018), <https://www.forbrukerradet.no/undersokelse/no-undersokelsekategori/deceived-by-design/>; Acquisti, “Nudges for Privacy and Security”; Christoph Bösch, Benjamin Erb, Frank Kargl, Henning Kopp and Stefan Pfattheicher, “Tales from the dark side: Privacy dark strategies and privacy dark patterns,” *Proceedings on Privacy Enhancing Technologies*, no. 4 (2016), 237–254, <https://doi.org/10.1515/popets-2016-0038>.

- 40 Sonam Samat and Alessandro Acquisti, “Format vs. content: the impact of risk and presentation on disclosure decisions,” *Thirteenth Symposium on Usable Privacy and Security*, (2017), 377–384.
- 41 See example of the LinkedIn profile strength meter in Acquisti, “Nudges for Privacy and Security.”
- 42 Chang, “Engineering Information Disclosure: Norm Shaping Designs.”
- 43 This effect has been shown in multiple experiments, see for example I. Adjerid, A. Acquisti, L. Brandimarte and G. Lowenstein, “Sleights of Privacy: Framing, Disclosure, and the Limits of Transparency,” <https://doi.org/10.1145/2501604.2501613>; S. Patil, R. Hoyle, R. Schlegel, A. Kapadia and A. J. Lee, “Interrupt now or inform later? Comparing immediate and delayed privacy feedback,” (2015), <https://doi.org/10.1145/2702123.2702165>.
- 44 See International Standards Organization, ISO 9241-11: Ergonomics of human-system interaction—Part 11: Usability: Definitions and concepts, (2018), <https://www.iso.org/obp/ui/#iso:std:iso:9241:-11:ed-2:v1:en>.
- 45 Quoted from Jakob Nielsen, Usability 101: Introduction to Usability, Nielsen Norman Group, January 2012. <https://www.nngroup.com/articles/usability-101-introduction-to-usability/>.
- 46 See Jakob Nielsen, Usability 101.
- 47 Don Norman and Jakob Nielsen, The Definition of User Experience (UX), Nielsen Norman Group, <https://www.nngroup.com/articles/definition-user-experience/>.
- 48 The following book provides a good overview of common design methods and tools: Bruce Hanington and Bella Martin, *Universal Methods of Design: 100 Ways to Research Complex Problems, Develop Innovative Ideas, and Design Effective Solution*, (Rockport Publishers, 2012).
- 49 See, for example, David Wright, “Making Privacy Impact Assessment More Effective,” *The Information Society*, 29:5, (2013), 307–315, “<https://doi.org/10.1080/01972243.2013.825687>.”
- 50 Initial efforts to compile libraries of privacy design patterns include <https://privacypatterns.org/> and <https://privacypatterns.eu/>.
- 51 Batya Friedman, Peter H. Kahn, Jr. and Alan Boring, *Value sensitive design and information systems*, The handbook of information and computer ethics, 69–101, (2008), <https://onlinelibrary.wiley.com/doi/abs/10.1002/9780470281819.ch4>.
- 52 Batya Friedman, David G. Hendry and Alan Boring, “A Survey of Value Sensitive Design Methods,” *Foundations and Trends in Human–Computer Interaction*, vol. 11, no. 2, (2017), 63–125, <http://dx.doi.org/10.1561/11000000015>.
- 53 Friedman, *Value sensitive design and information systems*.
- 54 See information life cycle as described in P. Swire and K. Ahmad, *Foundations of Information Privacy and Data Protection*, (Portsmouth: IAPP, 2012).
- 55 A. M. McDonald and L. F. Cranor, “The cost of reading privacy policies,” *I/S: A Journal of Law and Policy for the Information Society*, 4(3): (2008), 540–565.
- 56 P. M. Schwartz and D. Solove, “Notice and choice,” *The Second NPLAN/BMSG Meeting on Digital Media and Marketing to Children*, (2009).
- 57 This definition is based on the GDPR’s definition of consent (GDPR, Art. 7), which reflects the established understanding of what constitutes valid consent.
- 58 F. Schaub, R. Balebako and L. F. Cranor, “Designing Effective Privacy Notices and Controls” *IEEE Internet Computing*, vol. 21, no. 3, (May-June 2017), 70–77, <https://doi.org/10.1109/MIC.2017.75>.
- 59 L. Cranor, “Giving notice: Why privacy policies and security breach notifications aren’t enough,” *IEEE Communications Magazine*, 43(8) (August 2005):18–19.
- 60 F. Cate, “The limits of notice and choice,” *IEEE Security & Privacy*, 8(2) (March 2010):59–62.

- 61 Schwartz, “Notice and choice”; McDonald, “The cost of reading privacy policies”; J. R. Reidenberg, T. Breaux, L. F. Cranor, B. French, A. Grannis, J. T. Graves, F. Liu, A. M. McDonald, T. B. Norton, R. Ramanath, N. C. Russell, N. Sadeh and F. Schaub, “Disagreeable privacy policies: Mismatches between meaning and users’ understanding,” *Berkeley Technology Law Journal*, 30(1): (2015), 39–88.
- 62 N.A. Draper and J. Turow, “The corporate cultivation of digital resignation,” *New Media & Society*, 21(8), (2019), 1824–1839, <https://doi.org/10.1177/1461444819833331>.
- 63 N. S. Good, J. Grossklags, D. K. Mulligan and J. A. Konstan, “Noticing notice: A large-scale experiment on the timing of software license agreements,” *Proceedings of CHI ’07*, 607–616, (New York: ACM, 2007); B. Anderson, A. Vance, B. Kirwan, D. Eargle and S. Howard, “Users aren’t (necessarily) lazy: Using NeuroIS to explain habituation to security warnings,” *Proceedings of ICIS ’14*, (2014).
- 64 The ability of users to find key user interface components is referred to as *discoverability* by user experience designers. Lawyers use this term to mean something quite different: the fact that one side in a legal case must provide certain documents or information to the other side.
- 65 Habib, “An Empirical Analysis of Data Deletion and Opt-Out Choices on 150 Websites.”
- 66 See, for example, Rebecca Balebako, Richard Shay and Lorrie Faith Cranor, “Is your inseam a biometric? A case study on the role of usability studies in developing public policy,” *Workshop on Usable Security*, USEC, (2014); Pedro Giovanni Leon, Justin Cranshaw, Lorrie Faith Cranor, Jim Graves, Manoj Hastak, Blase Ur and Guzi Xu, “What do online behavioral advertising privacy disclosures communicate to users?” *Proceedings of the 2012 ACM workshop on Privacy in the electronic society*, 19–30, (New York: ACM, 2012), <http://dx.doi.org/10.1145/2381966.2381970>; Pedro Leon, Blase Ur, Richard Shay, Yang Wang, Rebecca Balebako and Lorrie Cranor. “Why Johnny can’t opt out: a usability evaluation of tools to limit online behavioral advertising,” *Proceedings of the SIGCHI Conference on Human Factors in Computing Systems*, 589–598, (New York: ACM, 2012), <https://doi.org/10.1145/2207676.2207759>; Forbrunder Rådet (Norwegian Consumer Council), *Deceived by Design: How tech companies use dark patterns to discourage us from exercising our rights to privacy*, report, (June 2018), <https://www.forbrukerradet.no/undersokelse/no-undersokelsekategorier/deceived-by-design/>.
- 67 The here-described principles are an expanded description of Schaub, “Designing Effective Privacy Notices and Controls.”
- 68 M. S. Wogalter, ed., “Communication-Human Information Processing (C-HIP) Model,” *Handbook of Warnings*, 51–61, (Mahwah, NJ: Lawrence Erlbaum Associates, 2006).
- 69 L. Cranor, “A Framework for Reasoning About the Human In the Loop,” *Usability, Psychology and Security 2008*, http://www.usenix.org/events/upsec08/tech/full_papers/cranor/cranor.pdf.
- 70 Marian Harbach, Markus Hettig, Susanne Weber and Matthew Smith, “Using personal examples to improve risk communication for security & privacy decisions,” *Proceedings of the SIGCHI Conference on Human Factors in Computing Systems*, (New York: ACM, 2014), <http://dx.doi.org/10.1145/2556288.2556978>.
- 71 Quoted from GDPR Recital 58, which expands on the child-specific transparency requirements described in GDPR Article 12.1.
- 72 Kevin Litman-Navarro, “We Read 150 Privacy Policies. They Were an Incomprehensible Disaster,” *The New York Times*, June 2019, <https://www.nytimes.com/interactive/2019/06/12/opinion/facebook-google-privacy-policies.html>.
- 73 Martin Degeling, Christine Utz, Christopher Lentzsch, Henry Hosseini, Florian Schaub and Thorsten Holz, “We Value Your Privacy ... Now Take Some Cookies: Measuring the GDPR’s Impact on Web Privacy,” *Network and Distributed Systems Symposium*, (2019), https://www.ndss-symposium.org/wp-content/uploads/2019/02/ndss2019_04B-2_Degeling_paper.pdf.

- 74 Sameer Badarudeen and Sanjeev Sabharwal, "Assessing readability of patient education materials: current role in orthopaedics," *Clinical Orthopaedics and Related Research* 468, no. 10 (2010): 2572–2580, <https://dx.doi.org/10.1007%2Fs11999-010-1380-y>.
- 75 Schaub, "Designing Effective Privacy Notices and Controls."
- 76 Lau, "Alexa, Are You Listening?"
- 77 Parts of the process description originate from two prior publications of the authors, which describe the process in more detail in Schaub, "Designing Effective Privacy Notices and Controls"; Schaub, "A design space for effective privacy notices."
- 78 B. Ur, J. Jung and S. Schechter. "Intruders versus intrusiveness: Teens' and parents' perspectives on home-entryway surveillance," *Proceedings of UbiComp '14*, 129–139, (New York: ACM, 2014).
- 79 Lau, "Alexa, Are You Listening?"
- 80 Gluck, "How short is too short?"
- 81 Microsoft, Privacy Guidelines for Developing Software Products and Services, Technical Report version 3.1, 2008.
- 82 B. Shneiderman, "The eyes have it: a task by data type taxonomy for information visualizations," *Proceedings 1996 IEEE Symposium on Visual Languages*, (Boulder, CO, 1996), 336–343, <https://doi.org/10.1109/VL.1996.545307>.
- 83 A. M. McDonald, R. W. Reeder, P. G. Kelley and L. F. Cranor, "A comparative study of online privacy policies and formats," *proceedings of PETS '09*, 37–55, (Berlin: Springer, 2009); H. Nissenbaum, "A Contextual Approach to Privacy Online," *Daedalus*, vol. 140, no. 4, (2011), 32–48.
- 84 Almuhimedi, "Your Location has been Shared 5,398 Times!"
- 85 Habib, "An Empirical Analysis of Data Deletion and Opt-Out Choices on 150 Websites."
- 86 Marc Langheinrich and Florian Schaub, "Privacy in Mobile and Pervasive Computing," *Synthesis Lectures on Mobile and Pervasive Computing* 10, no. 1 (2018): 1–139, <https://doi.org/10.2200/S00882ED1V01Y201810MPC013>.
- 87 See the original paper for an expanded discussion of each dimension with extensive examples and pointers to relevant academic research: Schaub, "A design space for effective privacy notices."
- 88 F. Schaub, B. Könings and M. Weber, "Context-Adaptive Privacy: Leveraging Context Awareness to Support Privacy Decision-making," *IEEE Pervasive Computing*, vol. 14, no. 1, (January-March 2015), 34–43, <https://doi.org/10.1109/MPRV.2015.5>; Schaub, "Context-Adaptive Privacy Mechanisms," *Handbook of Mobile Data Privacy*, eds. A. Gkoulalas-Divanis and C. Bettini, (Springer, 2018), https://doi.org/10.1007/978-3-319-98161-1_13.
- 89 R. S. Portnoff, L. N. Lee, S. Egelman, P. Mishra, D. Leung and D. Wagner, "Somebody's watching me? Assessing the effectiveness of webcam indicator lights," *In Proc. CHI '15*, 1649–1658, (New York: ACM, 2015).
- 90 R. Calo, "Against Notice Skepticism in Privacy (and Elsewhere)," *Notre Dame Law Rev.*, vol. 87, no. 3, (2012) 1027–1072.
- 91 Lau, "Alexa, Are You Listening?"
- 92 A standard for machine-readable website privacy policies was published by the World Wide Web Consortium in 2002, but has been retired after failing to receive widespread adoption. See Lorrie Faith Cranor, "Necessary But Not Sufficient: Standardized Mechanisms for Privacy Notice and Choice," *Journal of Telecommunications and High Technology Law*, vol. 10, no. 2, (2012), http://www.jthtl.org/content/articles/V10I2/JTHTLv10i2_Cranor.PDF.
- 93 Langheinrich, Marc, "A privacy awareness system for ubiquitous computing environments," *International conference on Ubiquitous Computing*, 237–245, (Berlin, Heidelberg: Springer, 2002);

- A. Das, M. Degeling, D. Smullen and N. Sadeh, "Personalized Privacy Assistants for the Internet of Things: Providing Users with Notice and Choice," *IEEE Pervasive Computing*, vol. 17, no. 3, (July-September 2018), 35-46, <https://doi.org/10.1109/MPRV.2018.03367733>.
- 94 Maggie Oates, Yama Ahmadullah, Abigail Marsh, Chelse Swoopes, Shikun Zhang, Rebecca Balebako and Lorrie Cranor, "Turtles, Locks, and Bathrooms: Understanding Mental Models of Privacy Through Illustration," *Proceedings on Privacy Enhancing Technologies*, (4): (2018) 5-32; B. Ur, P.G. Leon, L.F. Cranor, R. Shay, and Y. Wang, "Smart, Useful, Scary, Creepy: Perceptions of Online Behavioral Advertising," *Symposium on Usable Privacy and Security*, (2012); Cynthia E Schairer, Cynthia Cheung, Caryn Kseniya Rubanovich, Mildred Cho, Lorrie Faith Cranor and Cinnamon S Bloss, "Disposition toward privacy and information disclosure in the context of emerging health technologies," *Journal of the American Medical Informatics Association*, vol. 26, issue 7, (July 2019), 610-619, <https://doi.org/10.1093/jamia/ocz010>; Pardis Emami Naeini, Sruti Bhagavatula, Hana Habib, Martin Degeling, Lujo Bauer, Lorrie Cranor and Norman Sadeh, "Privacy Expectations and Preferences in an IoT World," *Symposium on Usable Privacy and Security*, Santa Clara, CA, (July 12-14, 2017).
- 95 R. Balebako, F. Schaub, I. Adjerid, A. Acquisti and L. Cranor, "The Impact of Timing on the Salience of Smartphone App Privacy Notices," *5th Annual ACM CCS Workshop on Security and Privacy in Smartphones and Mobile Devices*, (2015).
- 96 Pedro Giovanni Leon, Justin Cranshaw, Lorrie Faith Cranor, Jim Graves, Manoj Hastak, Blase Ur and Guzi Xu, "What do online behavioral advertising privacy disclosures communicate to users?" *Proceedings of the 2012 ACM workshop on Privacy in the electronic society*, 19-30, (New York: ACM, 2012), DOI=<http://dx.doi.org/10.1145/2381966.2381970>.
- 97 Pardis Emami-Naeini, Henry Dixon, Yuvraj Agarwal and Lorrie Faith Cranor, "Exploring How Privacy and Security Factor into IoT Device Purchase Behavior," *Proceedings of the 2019 CHI Conference on Human Factors in Computing Systems*, (New York: ACM), <https://doi.org/10.1145/3290605.3300764>.
- 98 Kathryn Whitenon, "The Two UX Gulfs: Evaluation and Execution," March 11, 2018, <https://www.nngroup.com/articles/two-ux-gulfs-evaluation-execution/>.
- 99 S. Egelman, J. Tsai, L. Cranor and A. Acquisti, "Timing Is Everything? The Effects of Timing and Placement of Online Privacy Indicators," *CHI '09: Proceedings of the SIGCHI conference on Human Factors in Computing Systems* (2009).
- 100 Leon, "Why Johnny Can't Opt Out."
- 101 Joyce, "Formative vs. Summative Evaluations," July 28, 2019, <https://www.nngroup.com/articles/formative-vs-summative-evaluations/>.
- 102 Jakob Nielsen, "Thinking Aloud: The #1 Usability Tool," January 16, 2012, <https://www.nngroup.com/articles/thinking-aloud-the-1-usability-tool/>.
- 103 Douglas Schuler and Aki Namioka, eds., *Participatory design: Principles and practices*, (CRC Press, 1993).
- 104 Eyal Peer, Laura Brandimarte, Sonam Samat and Alessandro Acquisti, "Beyond the Turk: Alternative platforms for crowdsourcing behavioral research," *Journal of Experimental Social Psychology*, vol. 70, (2017), 153-163, ISSN 0022-1031, <https://doi.org/10.1016/j.jesp.2017.01.006>.
- 105 P.G. Kelley, L.F. Cranor and N. Sadeh. "Privacy as Part of the App Decision-Making Process," CHI 2013.
- 106 C. Bravo-Lillo, L.F. Cranor, J. Downs, S. Komanduri, R.W. Reeder, S. Schechter and M. Sleeper, "Your Attention Please: Designing security-decision UIs to make genuine risks harder to ignore," *Proceedings of the Eighth Symposium On Usable Privacy and Security*, Newcastle, United Kingdom, (2013).

CHAPTER 6

Tracking and Surveillance

Lorrie Faith Cranor, CIPT; Blase Ur, CIPT; Manya Sleeper

In today's digital world, our communications and our actions—both online and offline—have the potential to be tracked and surveilled. Reasons for tracking are manifold. On one level, advertising companies wish to profile users so that they can better target relevant ads. Other groups or individuals might wish to spy on a person to blackmail, extort or cause embarrassment to them. On a grander scale, a

government or other organization may hope to gather intelligence to thwart an act of terrorism or perhaps to spy on a group or individual for more insidious purposes. These large-scale goals came into particular focus worldwide in 2013 with disclosures about the PRISM program in the United States one day after disclosures about government collection of telephone call metadata.¹ In the PRISM program, intelligence organizations in the United States and Great Britain established partnerships with major internet companies to facilitate the handover of customers' communication upon request.² The primary oversight mechanism of this previously secret program was a secret court system. These revelations led to public outcry. Though some individuals responded to the revelations with the familiar "I have nothing to hide" argument, privacy scholars argue that the collection, processing and indefinite retention of data about an individual can increase the power imbalance between a government and citizens, have a chilling effect on free communication and leave individuals vulnerable.³

The degree to which individuals are tracked in their daily lives reappeared in the general consciousness in 2018 with revelations that the firm Cambridge Analytica had used data on 50 million Facebook users to identify Americans' personalities, using this information to try to influence the 2016 election.⁴ Tracking and surveillance are not restricted, however, to online behaviors. In a widely discussed example from 2012, one consumer's purchasing history led the retail chain Target to target pregnancy-related advertisements to her before her family learned she was pregnant.⁵ In short, individuals produce huge trails of data both online and offline, and these trails are tracked, recorded and used to draw conclusions about that individual.

Opportunities for surveillance are increasing, not decreasing. As a larger fraction of electronic devices, sensors, microphones and cameras are connected to the internet of things (IoT), more data will be collected by those hoping to track or surveil others. The abilities of facial recognition software to identify individuals and machine-learning algorithms to uncover patterns in large amounts of data are quickly, and seemingly continually, increasing. Tensions between the benefits of ubiquitous data collection and the privacy perils of the same practices promise to become even more stark.

The goal of this chapter is to provide IT professionals with a broader understanding of the techniques that enable tracking and surveillance on a number of levels, along with both an explanation of the countermeasures to these techniques and the limitations of these countermeasures. As the people

responsible for developing IT within a company, government agency or other organization, IT professionals must be aware of the impact that surveillance technology has on individual privacy.

We start by looking at how internet usage can be surveilled on a large scale. Following a brief overview of the main technologies underlying internet communication, we discuss how network traffic can be surveilled using techniques such as deep packet inspection. We also look at more localized approaches for tracking all of a user's communications, such as eavesdropping on a Wi-Fi connection or monitoring a school or workplace network, before explaining how anonymizing systems can help defend against this sort of tracking.

Next, we turn our attention to web tracking, in which companies track the websites that users visit, building user profiles for advertising and other purposes. We discuss how a combination of hypertext transfer protocol (HTTP) cookies and an ecosystem in which a handful of advertising companies serve advertisements on many popular websites enables this sort of tracking. We also discuss additional mechanisms that enable tracking even when HTTP cookies are disabled or deleted. We briefly survey how a user's web searches can be tracked, and how the sender of an email can employ tricks to determine exactly when an email recipient opens the message.

A number of web-blocking tools have been designed to combat the myriad techniques through which a user's web browsing can be tracked. We will introduce a number of these tools and their features and highlight the shortcomings and usability issues of each approach.

Tracking and surveillance aren't limited to interception of communications or logging of web-browsing behaviors. We show how the mere presence of a cell phone or radio frequency identification (RFID) chip in an individual's pocket can reveal their location, in addition to explaining the relationship between global positioning system (GPS) technologies and tracking. We then discuss how the use and misuse of location-sharing features on social media sites can leak potentially private information. We also explain how users can control the disclosure of location information at a finer-grained level.

We then turn to how mechanisms and technologies beyond typical computing devices are increasingly enabling ubiquitous surveillance of spaces ranging from homes to rural public spaces. We outline audio and video surveillance techniques, including how popular voice assistants are extending the moments in daily life that can be tracked. We then discuss how the sensors embedded in everything

from vehicles to wearable devices and household appliances cause new classes of privacy concerns and enable new types of private information to be inferred. Finally, we briefly discuss how tracking and surveillance enable human behavior to be modeled.

It is essential that IT professionals understand the technologies that enable tracking and surveillance in order to prevent privacy violations. From a corporate standpoint, it is critical to avoid privacy violations that could lead to negative press reports, a tarnished reputation or regulatory or legal consequences. It is also important to avoid making users feel that their privacy has been violated, since they may stop using products from companies they do not trust. In addition, knowledge of tools that limit tracking and surveillance is valuable both to illuminate possible opportunities for a company to compete on privacy and to understand steps that users can take to protect their own privacy.

6.1 Internet Monitoring

The internet provides a variety of opportunities for tracking and surveillance. These include a range of activities, from automated monitoring by network administrators to detect malicious software to illegal monitoring by criminals who are trying to steal passwords and account information. Employers may monitor their employees' internet connections to enforce company policies. Law enforcement may obtain warrants that allow them to monitor internet traffic to investigate a crime. Internet service providers (ISPs) or email providers may monitor web-browsing behavior or email to deliver targeted advertising. This section describes the basics of how data travels across the internet and how such data can be picked up in transit. It also outlines several defenses against internet monitoring and surveillance.

6.1.1 An Overview of Internet Communications

To travel from source to destination on the internet, data must be directed across intermediate networking links and switches. Monitoring tools may be placed anywhere along the path that data travels.

6.1.1.1 Packets

When data is sent over the internet, it is broken down into segments and encapsulated in packets. Packets are pieces of data combined with additional information that specifies how they should be directed over a network. In the

internet protocol (IP), which is the primary protocol used to transmit data on the internet, data is put into IP packets before being directed over a series of intermediate links and routers to reach its final destination. The IP is primarily concerned with delivering the data in a packet from a source to a destination based on an address, known as an IP address.

An IP address is a numerical identifier given to internet-connected devices. The network adapters on devices ranging from laptops to smartphones have IP addresses when they are connected to the internet. The IoT concept goes further and proposes assigning an IP address to most electronic devices, from temperature sensors to toasters, making these devices accessible over the internet. As IP addresses are assigned hierarchically, they aid in the process of identifying how to route data to a particular device. A major transition is currently occurring from IPv4 addresses, which have effectively been exhausted, to much larger IPv6 addresses. An IPv4 address is 32 bits (2^{32} possible values), while IPv6 addresses are 128 bits (2^{128} possible values).

Each IP packet consists of a header and the data payload. The exact format of the packet depends on the protocol, but includes the IP address of the data's source and the address of its destination. It also includes a checksum over the header for error checking, as well as information about how the packet should be routed and the protocol that the packet is using.

In the typical case, the information included in an IP packet allows it to be transmitted across networks using packet routing. Using the information included in the header of the IP packet, each router passes a packet on to the next router closer to its final destination. Once packets reach their final destination, the contents are reassembled into their original form, such as an image or other user-friendly file.

Two of the most popular protocols that sit on top of IP are the transmission control protocol (TCP) and user datagram protocol (UDP). Whereas TCP guarantees delivery of a packet and encompasses mechanisms for verifying delivery and resending packets that did not make their way to the destination, UDP makes no such guarantees. As a result, TCP is generally used when it is important that data be delivered in its entirety, even if it takes longer. For instance, TCP would normally be used when downloading a photograph from a website. In contrast, by not making guarantees about the eventual delivery of data, UDP can operate more quickly and with less overhead. In cases where speed trumps reliability, such as in a video stream of a live sports event, UDP is generally used. If

the data for a few seconds of this live video stream were to be lost in transit, it would not be useful to invoke a retransmission procedure and receive this data at a later point since the moment would have passed.

6.1.1.2 Email

One of the myriad types of communications split into packets for transmission across the internet is electronic mail, or email. Emails are structured in two parts: a header containing information about the message and a body that contains the message itself.

A user creates an email message using a mail user agent (MUA) at the application level of their computer. A desktop email client like Microsoft Outlook is an example of a MUA. The email message is made up of a message header and a body. The body includes the email message. The header includes a variety of addressing fields, such as the sender's and recipients' email addresses, the subject, and cc'd recipients.

The email message is transmitted to the user's outgoing mail server and then sent across the internet to its destination using the Simple Mail Transfer Protocol (SMTP). Once the email reaches its destination mail server, it is available for access either directly or by using a mail server protocol, such as the Internet Message Access Protocol (IMAP) or the Post Office Protocol (POP). When using IMAP, the emails remain on the server for access later or for access by multiple clients (e.g., a MUA on a desktop computer or a smartphone). In contrast, in POP, the MUA removes the emails from the server after storing them locally. In POP3, the email server can be configured to leave emails in the inbox.

6.1.1.3 Hypertext Transfer Protocols (HTTP and HTTPS)

Like emails, web pages are split into packets as they are sent across the internet. However, while the SMTP specifies how emails are sent between servers, the HTTP specifies how web pages are transmitted to browsers.

Users typically visit web pages using web browsers, such as Mozilla Firefox, Google Chrome, Microsoft Edge or Apple Safari. The address that a user types into the browser is known as the URL, or uniform resource locator, and it contains four main parts. For instance, a user might send a request to the IAPP's website using the following URL:

`https://www.iapp.org/about/`
[] [] []
service host (:port) resource

The *service* component of a URL specifies the protocol that will be used for the request. Most commonly, web pages use HTTP for communication between a web browser and the web server that hosts the page. Messages sent over HTTP are sent in plaintext, and thus are susceptible to monitoring and tampering by any of the intermediary nodes through which the HTTP packets are sent.

To prevent monitoring or tampering of data traveling over the internet, HTTPS (hypertext transfer protocol secure) can be used. This protocol is similar to HTTP except that data is encrypted using transport layer security (TLS), which improves upon its predecessor, secure sockets layer (SSL). An encrypted connection is specified by HTTPS in place of HTTP in the browser's URL. Historically, many websites preferred to send traffic over HTTP, rather than HTTPS, for performance reasons. Unfortunately, this decision to use HTTP and therefore send web traffic in plaintext also meant that the bulk of web traffic could be monitored. However, the adoption of HTTPS greatly accelerated around 2017.⁶ A number of factors appear to have spurred HTTPS adoption, ranging from how web browsers began to flag the insecurity of sites served over HTTP to the nonprofit Let's Encrypt certificate authority (CA) beginning to offer the X.509 certificates required for HTTPS deployment for free.⁷

The *host* portion of the URL specifies who will receive the request, most often a computer server owned or contracted by the group represented by the website. The host can also be referred to as the site's domain. Along with the host, a *port* can optionally be specified. Ports allow numerous programs and processes on one computer to communicate simultaneously with many other machines without accidentally jumbling the conversations, similar to the way mail can be correctly routed to a resident of a large apartment building that has a single street address by specifying an apartment number. Although a single computer has 65,535 ports for use by both TCP and UDP, there are default ports to which requests following particular protocols should be made. For instance, HTTP requests are sent to TCP port 80 by default, while HTTPS requests are sent to TCP port 443. Since no port was specified in the example URL above, the default port for the HTTPS protocol will be used. Finally, the *resource* portion of the URL specifies exactly which page, image or other object should be returned.

An HTTP request for web content is first initiated by a user's web browser, which sends a request message to the host. First, the name of the *host* is converted to an IP address. For instance, the IAPP's hostname of *iapp.org* is converted to the IPv4

address 34.225.38.165 at the time of press. Once the host's IP address is known, the request can be broken into packets and accurately routed to its recipient.

A browser can make one of several types of HTTP requests, of which GET and POST requests are most relevant for surveillance techniques. In the case of a GET request, the browser simply requests that a particular resource be returned. A POST request is similar to a GET request except that the body of a POST request can contain information sent from the browser to the server, such as the data that a user typed into an online form. A GET request can also send data to the server, though as part of the URL itself. For either type of request, the server replies with a short status code indicating the success of the request (e.g., the code 200 indicates a successful request, whereas 404 indicates that the resource was not found). For successful requests, the content is also included in the body of the response. In the HTTP protocol, a single request results in a single reply. Furthermore, the connection is stateless, which means the server isn't required to recall anything about past requests to fulfill future requests.

Both HTTP requests and HTTP responses include headers, which are short messages containing additional information. For instance, HTTP requests include the verbs *GET*, *POST* or *HEAD* along with the resource requested. They can include the date and time the request was sent in the *date* field, as well as identifiers and version numbers for the web browser and operating system. Other data can be included too, depending on the request and the browser used. When a user clicks on a hyperlink on a page, an HTTP request for the new page is initiated. For these sorts of requests, a *Referer* header is included to indicate to the new page the identity of the page on which the link was clicked. The HTTP response headers can include fields such as *content-language*, specifying the natural language in which the page is written.

6.1.2 Network-Scale Monitoring and Deep Packet Inspection

Only the IP header, the first part of a packet, is required for network hardware to accurately route a packet to its destination. It is possible for network hardware to examine header information for other protocols or the full body of the network packet for a variety of purposes. When nodes look at this additional data, it is called *deep packet inspection*.

Deep packet inspection serves multiple purposes. For example, the ability to examine additional information within packets before they pass into a local organizational network can help determine whether or not the packets contain

malicious content, such as known viruses. Alternatively, examining packets before they leave a network can help prevent data leaks, assuming the organization can scan these packets to detect sensitive information that should not leave the organization.

Deep packet inspection is also used for a variety of nonorganizational purposes. It is used by advertisers to track users' online behavior to better target ads and by government entities to censor or track citizens' online behaviors; both of these activities raise privacy concerns.⁸ In China, deep packet inspection is used as part of the "Great Firewall," which the government uses to perform large-scale censorship on potentially sensitive topics.²

Some opponents of deep packet inspection note that it can be used to violate the principle of net neutrality because it allows network traffic and bandwidth shaping based on the content of a packet. In the United States, for example, the Federal Communications Commission (FCC) previously ordered Comcast to stop using deep packet inspection to limit the bandwidth of peer-to-peer connections, called rate-limiting.¹⁰ Because deep packet inspection can be used to determine the type of content being sent from one host to another, Comcast was able to rate-limit its customer internet use based on whether the use was for peer-to-peer networking applications or file sharing. Note that political changes regarding net neutrality in the United States in 2017 and beyond, however, call into question future applications of this argument.

6.1.3 Wi-Fi Eavesdropping

Monitoring can also occur on Wi-Fi networks. It is possible to eavesdrop on or capture data being sent over a wireless network at the packet level. Several systems for Wi-Fi eavesdropping, including packet sniffing and analysis tools, are freely available.

Unsecured communications sent over an open, or shared, wireless network can be intercepted easily by others. This risk is often present in Wi-Fi hotspots in public spaces, such as hotels or coffee shops, where many users share a common Wi-Fi network that is either unprotected or protected with a password known to a large group of users.

Packet-sniffing systems capture packets sent over such networks. If the data is unencrypted, these packets can be examined and reassembled. These reassembled packets can then provide information about all the network user's activities, including websites they visited, emails and files sent, and the data included in

session cookies (such as website authentication information). Wireshark is one example of a packet sniffing and network analysis tool.¹¹ It captures packet-level data on wired or wireless networks to which a user has access, allowing a user to examine and reassemble packet content. Other examples of packet sniffers include Kismet for Unix and Eavesdrop for Mac.¹²

There are also more specialized Wi-Fi eavesdropping systems. One such tool enabled HTTP session hijacking, or “side-jacking,” attacks. When a user logs in to an internet site, the initial login process is usually encrypted. Sites often store a token on the user’s computer, and this token is sent along with future HTTP requests as proof that the user has logged in. However, some popular sites previously used HTTP, rather than HTTPS, to send this token, which means the token was sent unencrypted. Firesheep was a Firefox extension, released in 2010 but later removed from the Firefox store, that enabled an adversary listening to this Wi-Fi connection to hijack these tokens and impersonate a user who was logged in.¹³ It captured tokens it saw transmitted across the wireless network to which the user was connected. It then displayed information about the captured accounts (e.g., the site, the username, the user’s photo) and allowed the adversary to send requests to the applicable website as if they had originally logged in as that user. At the time of its deployment in 2010, Firesheep was used to allow users to log in to Facebook using other users’ accounts.

Tools like Wireshark are intended to allow users to purposefully eavesdrop on network information included in the body of packets for benevolent or malicious purposes. However, companies using eavesdropping tools can run into trouble when they are careless about how much data they are recording. In a 2010 case involving Google’s Street View cars, Google captured data from unencrypted Wi-Fi networks using packet sniffers that were installed on these cars. The discovery that the captured data included passwords, personal information and other network traffic that consumers never expected would be collected resulted in a public outcry and an investigation by the FCC, as well as actions by other governments across the world. In 2013, Google acknowledged that these actions were a privacy violation as part of a \$7 million settlement in the United States.¹⁴

There are several potential defenses against Wi-Fi eavesdropping. First, Wi-Fi eavesdropping requires that the eavesdropper have access to the Wi-Fi network and be able to read the packets that are sent. Ensuring that Wi-Fi networks are encrypted using strong passwords can limit the danger of Wi-Fi eavesdropping by preventing some adversaries from reading the traffic passing across the network.

However, one Wi-Fi encryption scheme that is still in limited use, Wired Equivalent Privacy (WEP), has significant vulnerabilities and can often be broken within seconds.¹⁵ The Wi-Fi Protected Access (WPA) encryption scheme is also considered insecure and should not be used. At the time of press, however, its successor WPA2 was still considered secure even though its own successor, WPA3, had already been announced. Even the more recent security protocols for Wi-Fi routers can sometimes be defeated, which means that strong Wi-Fi passwords are often not sufficient to protect this communication channel.¹⁶ Virtual private networks (VPNs), which allow users to create secure, encrypted tunnels to send data through more trusted channels, offer a defense against interception on unsecured networks. Additionally, regardless of the security of the network itself, encrypting web requests using HTTPS can prevent eavesdroppers from intercepting sensitive or personally identifiable data.

6.1.4 Internet Monitoring for Employers, Schools and Parents

There are also systems that allow people in positions of power or authority to monitor local networks. Some of these systems are specifically designed for employers, schools and parents. Such monitoring may be used to ensure both security and appropriate behavior on the network, often by blacklisting, or blocking access to, websites considered inappropriate.

Employers in the United States are legally allowed to monitor their employees' internet usage on their organization's network or company-owned machines.¹⁷ Companies monitor email and internet usage for a variety of reasons, including tracking employee productivity, maintaining security within the corporate network and ensuring appropriate behavior among employees. As of 2007, the American Management Association (AMA) found that 66 percent of surveyed companies monitored internet browsing, and 65 percent blocked access to blacklisted websites. Forty-three percent of companies also monitored email, both to limit security breaches and to prevent potential lawsuits.¹⁸ For example, some companies decrypt SSL and TLS protocols for external websites accessed from within their internal networks by intercepting the website's digital certificate and replacing it with the company's own certificate which had been previously installed on workplace computers. This is equivalent to a man-in-the-middle attack, which allows employers to read and intercept communications on their internal networks.

The U.S. Children's Internet Protection Act (CIPA) requires schools and public libraries to install filters to prevent children from viewing inappropriate content online.¹⁹ Many schools also track students' internet usage to prevent inappropriate behavior, such as illegal downloading.²⁰

Parents too can monitor their children's internet usage. A variety of tools allow parents to limit the types of sites their children are allowed to visit, typically using blacklists or keyword filters. Parents can also track the sites their children visit and view the emails and chat messages they send. These tools are designed to help protect children from online predators as well as allow parents to better supervise their children's online activities.

6.1.5 Spyware

Beyond monitoring the network connection, there is also potential for malicious software to surveil data before it even leaves the user's own computer. *Spyware* is malicious software that is covertly installed on a user's computer, often by tricking users through social engineering attacks. Spyware can then monitor the user's activities through a variety of methods. It can track online activity in several ways, including capturing cookie data to determine browsing history or directly monitoring and reporting on browsing behavior. Spyware can also directly monitor what a user is doing on their computer, either by performing screen capture and transmitting an image of the user's screen back to the attacker, or by performing keylogging. In keylogging, malware is installed that tracks all keystrokes performed by the user. This data is then sent back to the attacker, allowing them to capture sensitive information typed by the user, such as passwords.

Antivirus providers offer anti-spyware programs that can be used to protect against known spyware. These systems use anti-malware signatures that are created from components of the malware code to detect and remove spyware from installed software. However, these programs are often reactive, successfully detecting well-known malware, yet failing to detect new types of spyware. Additionally, it is possible for systems to track known spyware websites and block installations coming from those sites at the firewall level.²¹

6.1.6 Preventing Network-Level Surveillance

Even if packets are encrypted when a user accesses the internet, it is often possible for an observer, such as an ISP or government, to learn what sites the user accesses

by examining metadata. Broadly, HTTPS does not provide anonymity. Network observers still can see the source and destination of traffic, which are left unencrypted in the packet headers so that the request or response can be routed to the right destination. For instance, a user who visits *example.com* over HTTPS will reveal to network observers that their IP address is communicating with *example.com*'s IP address. While the body of the request or response, such as the precise page requested and delivered, is encrypted, the privacy provided can be imperfect. Which page is being viewed can sometimes be inferred simply based on the size and the timing of the encrypted data returned, even without observing the unencrypted data itself.²²

This type of tracking is problematic in a variety of circumstances, such as when citizens who live under a hostile regime wish to access political websites secretly. To prevent such tracking, anonymizers can be used to mask the link between the source—the user—and the destination of the network traffic. Two major types of anonymizers are anonymous proxies and onion routers.

Anonymous proxies allow users to anonymize their network traffic by forwarding the traffic through an intermediary. Thus, the user's traffic appears to come from the proxy server's IP address, rather than the original user's IP address. JonDonym is a service that anonymizes traffic by routing packets through a mix of multiple user-chosen anonymous proxies.²³ However, the use of an anonymous proxy requires that the user trust the anonymous proxy, and this approach runs the risk of presenting a single point of failure. *Onion-routing systems*, or *mix networks*, are an alternative to anonymous proxies. Similar to the layers of an onion, packets sent through an onion-routing system are encrypted in layers and then sent through a series of relays in a way that is very difficult to trace. At each stage of the circuit, a node receives a packet from the previous node, strips off a layer of encryption and sends it on to the next node. Because there are multiple nodes within the circuit, each internal node does not know anything beyond the node it received the packet from and the node to which it needs to forward the packet. This configuration allows a layer of anonymity to be inserted into network traffic. However, encryption is still required to keep the data itself anonymous once it leaves the virtual circuit.²⁴ Tor is an implementation of the onion-routing protocol that uses a network of volunteer-run relay nodes to enable a variety of anonymous services.²⁵

A particular concern for users is who controls their data. For instance, even if a user has transmitted their data securely across a network using encryption, and

even if the company follows industry best practices in storing this data securely, the user often still needs to worry whether personal data will be disclosed to a government or other organization through the cooperation of an internet company, without the user's knowledge. The extent of this type of cooperation in supporting government surveillance was one of the major surprises of the 2013 PRISM revelations.²⁶ Users must also carefully evaluate promises made to them by companies, yet they often have no way to do so. For instance, even though Skype had asserted for years that it could not intercept users' communications, the PRISM revelations in 2013 showed this assertion to be patently false.²⁷

6.1.7 Effective Practices

A variety of tools are available for internet monitoring. There are several effective practices to keep in mind, both when performing such monitoring and when trying to prevent such monitoring from occurring.

To minimize privacy impacts, internet monitoring should have a stated and narrow goal. If it is necessary to monitor online activities—for example, within a corporate environment—it should be done in a manner that best protects the privacy of the monitored individuals while achieving the desired goals. Neglecting privacy in pursuit of a goal can result in negative consequences.

As was apparent in the Google Street View example, this often means determining what data is necessary to achieve the desired goal and then capturing only this data. Additionally, whenever possible, this data should be captured in an aggregate or anonymized fashion (see Chapter 4 for more details on data aggregation, sanitization and anonymization). For example, if deep packet inspection is being performed for network statistics, data should be examined in aggregate; the contents of individual packets should not be examined. To further protect privacy and limit liability, data should not be retained or shared beyond a necessary level.

Conducting surveillance at a level that exceeds consumers' expectations can have direct financial implications for an organization, including regulatory fines and lost business. For instance, major companies including Google and Facebook have paid fines as part of settling privacy complaints with the U.S. Federal Trade Commission (FTC) in recent years. In addition, in the wake of the PRISM revelations in 2013, 10 percent of survey respondents indicated that they had canceled a project to use a cloud provider based in the United States.²⁸

There are several effective practices to prevent monitoring. First, HTTPS should always be used for transmitting sensitive information between clients and servers. Additionally, sensitive information should not be sent over unsecured Wi-Fi networks, nor should a user rely on a Wi-Fi network's security to provide confidentiality. VPNs provide some protection in such an environment, although they require that one trust the operator of the VPN. Finally, sensitive information, such as confidential emails, should also be encrypted to provide an additional layer of protection.

6.2 Web Tracking

Companies and websites have many reasons for wanting to track users on the internet, ranging from analysis and personalization on an individual website to targeting advertisements to users based on their activities across multiple websites.

Many websites personalize their content or user experience for each visitor. For instance, if a user has changed their language settings for a website from English to Romanian, the website would want to identify that user when they return and automatically show the page in the correct language. Furthermore, many websites calculate analytics about their own pages, such as how users navigate the layout of the page. Websites also might want to show a particular user the stories or products they believe are most relevant based on that person's past actions or purchases on that website.

Online advertising companies create detailed profiles about what websites a particular user visits so they can target advertisements and offers to that user. For instance, if a company tracks exactly what pages a user visits across the internet over a long period of time, the company can infer information ranging from general categories of user interests to potentially detailed personal information.

On a technical level, the amount of information a determined company could collect about a particular user is nearly limitless. For instance, based on which articles a user views on health websites and the terms they enter into search engines, a company could likely infer the health status of a user, including what diseases they had. Furthermore, even seemingly anonymous data can sometimes be connected to a particular individual. For instance, in 2006, AOL publicly released supposedly anonymized search queries for research purposes, yet some of

the users were identified in real life based on searches they had made about themselves or their neighborhoods.²⁹

In practice, many companies on the internet say that they collect far less information than is theoretically possible, usually outlining in a privacy policy what information they collect and how they will use it. However, it is not possible for an end user to verify what information is actually collected, and a user would need to expend hundreds of hours a year to read the privacy policies for every site they visit.³⁰ Furthermore, it is difficult for users to grasp how data from different online sources can be combined, or particularly how online data can be combined with data from offline sources (e.g., Wi-Fi hotspot data collected in the Google Street View incident).

To better understand what types of information can be collected and by whom, in the rest of this section we delve into common mechanisms for tracking internet users. We begin by discussing how web pages remember settings for a particular user using HTTP cookies and then show how these cookies can be used for tracking that user across the internet. These techniques have applications that even privacy-sensitive users might consider benign, yet they can also be used for potentially privacy-invasive purposes.

6.2.1 HTTP Cookies and Web Tracking

As detailed above, web browsers typically communicate with web servers using HTTP or HTTPS to access websites. Although these protocols are stateless, which means they are not expected to remember past transactions, it is useful for websites to be able to save state about a particular user. For instance, a website should be able to remember that a particular user is logged in. If a user were required to log in to a website anew each time they clicked on a link or navigated to a new page, that person would likely be quite annoyed. Similarly, if a user places an item in an online shopping cart or updates their preferences for how the site is displayed, it is useful for the website to be able to remember these changes not just for that particular visit, but for all future visits from the same user.

To remember state, websites can request that the web browser save small text files, known as HTTP cookies, on the user's computer. In an HTTP response from a server, one possible header is *set-cookie*, which is followed by the value(s) that the site would like to store in the web browser. Along with the value(s) to be stored, a cookie will contain an expiration date, as well as the domain and path for

which that cookie is valid. Taken together, the domain and path define the scope of the cookie, which specifies the parts of a domain to which the cookie applies.

Every major web browser has a particular location on the hard drive of a user's computer where it stores these cookies. Users can examine their cookies, which contain plaintext. However, while some cookies may contain words indicating what has been saved, cookies more commonly contain codes that are intended to be understood only by the website that originally set each cookie.

When a particular website has set one or more cookies on the user's computer, the web browser will include the contents of those cookies as part of the header in HTTP requests sent to that site if the resource being requested falls within the cookie's scope and if the same browser is being used. Cookies are included regardless of the type of content being requested. Therefore, requests for content ranging from the main page of a website to a single image from the web server will include the cookies. If the cookie contains a unique identifier, then the website will be able to determine that the user associated with that identifier has returned to the website and track that user's activity on the site.

Cookies can be set just for a particular visit to a website or for extended periods of time. *Session cookies* are those cookies that are stored only until the web browser is closed and thus contain information only for a particular visit to a page. For instance, a token that can be used to prove to a website that a particular user has successfully logged in to their email account would often be saved as a session cookie and thus sent along with every HTTP request to that site. In contrast, *persistent cookies* can be saved indefinitely and are often used to save website preferences or a unique identifier to correlate multiple visits over time.

Web domains can only read and write cookies that they themselves have set, a practice known generally as the *single-origin policy*. Thus, Facebook cannot directly read cookies set by Google, nor can Google directly read cookies placed by Facebook. However, it is often the case that visiting a single website will result in cookies from multiple companies being placed on a user's computer because websites that appear as a single entity to the user may actually be cobbled together transparently from many different sources. For instance, a news website might load articles from its own internet domain (for instance, *www.news-website.com*). These sorts of cookies from the primary page that the user is visiting are known as *first-party cookies*. However, images on this page might be downloaded from another company (such as *www.photojournalism-aggregator.com*), while each advertisement on the page might be served by a different advertising network

(such as *www.xyz-advertising.com*). Each of these domains can also set its own cookies. Cookies set from all companies other than the primary website whose URL is displayed in a browser are known as *third-party cookies*.

The content contributed by these different third-party companies need not be visible to the user. Elements used for tracking that are not visible to the user in the rendered web page are known as *beacons* or *web bugs*. Beacons are loaded onto a page using elements of the HTML markup language, which is the most widely used language for specifying the layout of a web page. HTML allows text and multimedia from a variety of different sources to be brought together to form a web page. For instance, one HTML tag instructs a web browser to download an image from a remote web server and include it in the web page (the ** tag), which is how images are most commonly displayed on the internet. Similarly, another HTML tag specifies that an entire web page should be included inside another web page (the *<iframe>* tag), while another tag runs computer code written in certain other languages (the *<script>* tag), such as JavaScript.

Since HTTP requests for all types of content include as HTTP headers both the cookie and the referring URL (the Referer header), and since the cookie can contain an identifier unique to that user, beacons can enable tracking. The most canonical example of a beacon is a one-pixel image whose sole purpose is to generate an HTTP request. If a user visits website A and website A embeds third-party content, such as a beacon or an advertisement, the browser will visit the third-party site to get the content and will receive a cookie alongside the content. The third-party tracker receives the cookie with the user's unique ID, as well as the referring URL, thereby concluding that this particular pseudonymous user visited this particular URL. When the user visits a completely different site, website B, that site might also reference content from the same third party. If it does, the browser again visits the third party to fetch that content, and the cookie received on the visit to website A is sent back to the third party. The third party then knows that the user has visited both website A and website B.

Although a company can only track a user's visits to websites on which it serves content, widespread tracking is still possible since a small number of companies include their content and beacons on many popular websites across the internet. For instance, a 2009 study identified ten domains that served content on 70 percent of one thousand popular websites examined.³¹ More recently, a 2016 study of the top one million websites observed 123 different third parties each

present on at least one percent of those websites, with the most prevalent third party (Google) present on the majority of those websites.³²

Much of this tracking across popular sites supports *online behavioral advertising*, also known as *targeted advertising*, which is the practice of targeting advertisements using a profile of a user based on the websites they visits. A common method of profiling involves having a list of interest categories, such as “home and garden.” These interest categories are either selected or unselected for a particular user based on inferences the company makes. As a basis for these inferences, the company can consider which web pages the user has visited. The company can also leverage information collected from other sources, both online and offline, that is funneled through data brokers.³³ They might also misuse personal data provided to them for other purposes, such as security, for targeted advertising.³⁴ Based on this data, advertisers can choose from among tens of thousands of different characteristics on which to target an advertisement.³⁵

Online behavioral advertising has attracted substantial attention in the media and from regulators, and it has also raised privacy concerns for consumers. For instance, in the United States, both the FTC and the White House released privacy reports in 2012 discussing concerns about online behavioral advertising.³⁶ Consumers themselves worry about the potential for discrimination in targeted advertising, and they have a wide spectrum of privacy perceptions based on the particular characteristics that have been inferred.³⁷

Social media sites like Facebook also serve content on many different websites, allowing these social media companies to track a user’s activities across a broad swath of the internet.³⁸ The content served by such companies can take the form of social widgets. For instance, the social network Facebook places a “Like” button on many pages, allowing users to click a button and share that article on their Facebook profile. Whether or not a user clicks on the button, and whether or not the user is logged in to Facebook at the time, Facebook notices the user’s visit to that page.³⁹ On the one hand, these widgets provide a frictionless way for a user to share articles and information with their circle. On the other hand, they raise privacy concerns since they allow the social networking companies to track a user’s movement across many websites.

Websites can also track the links a user clicks on a web page. Using a technique known as *URL rewriting*, a website can be crafted to determine whether or not a user has clicked on an individual link. Understanding how a user has navigated a page can be useful for analytics, such as helping a search engine determine which

of the links it presented to a user were actually clicked on. For example, if a user goes to Google and searches for “privacy organizations,” the results would likely include a link to the IAPP. However, rather than presenting a direct link to the IAPP’s website at <https://iapp.org>, Google might instead present a link of the form:

[http://www.google.com/url?
query=privacy_organization&user=2fE65Da&url=iapp.org](http://www.google.com/url?query=privacy_organization&user=2fE65Da&url=iapp.org)

Such a link would automatically redirect the user to the IAPP website. However, by first directing the user’s browser to Google’s own server, Google is able to learn which link a particular user clicked on from a particular set of results. The unique identifier for the user can be the same unique identifier contained in a cookie that Google stored on that user’s computer, allowing that action to be associated with that particular user. Furthermore, by analyzing the time and IP address associated with this redirection request, Google can reconstruct the order in which the user clicked on links in search results as well as the geographic location and ISP from which the user is connecting to the internet.

JavaScript, a programming language used to create dynamic and interactive websites, can be used to track how a user navigates a web page in even greater detail than simple URL rewriting. In order to enable web pages that dynamically change as a user interacts with the page, JavaScript has functions for determining where a user’s mouse cursor is placed on the page, when a user has placed the mouse cursor over a particular element of the page, what the user has typed and in what sequence. Of course, these functions can be used to capture navigation information in great detail and then to send it to a remote web server for analysis.

6.2.2 Web Tracking beyond HTTP Cookies

While third-party cookies are a primary means of tracking a user’s web browsing, many additional technological mechanisms enable tracking. Some of these technologies have been used to respawn cookies that have been deleted by the user; others present entirely different tracking and surveillance paradigms. As detailed below, in the early 2010s, cookie-like objects such as “supercookies” received much attention, whereas in the late 2010s, much of the attention on tracking beyond cookies has focused on browser fingerprinting.

Though a user’s IP address might initially seem to be a promising mechanism for tracking, the potentially large number of users who share an IP address and the frequency with which users acquire new IP addresses as they move between

locations make the use of IP addresses for tracking less attractive. Users are instead tracked using some of their computers' local storage mechanisms that are accessible to web browsers, as well as through techniques that subtly misuse features of web browsers to glean information about a user. As more devices transition to IPv6, some implementations of which use a device's permanent media access control (MAC) address, tracking by means of the IP address may become more viable.

Web browsers or their plug-ins can write data to the hard drive of the user's computer in a number of ways beyond simple HTTP cookies. Many of these mechanisms have been used for tracking purposes. For instance, the Adobe Flash plug-in that is used to display videos and other interactive content on a number of sites has its own means of storing information, commonly called either local shared objects (LSOs) or "Flash cookies." A particular plug-in will generally be configured to run in each web browser on a user's computer. As a result, a website that utilizes that plug-in can access the same cookies regardless of which web browser is being used. Furthermore, LSOs are stored in a location on the hard drive separate from HTTP cookies, which means that hitting the "clear cookies" button in a web browser may not clear LSOs. While LSOs can be used for purposes such as remembering the volume setting for watching videos on a particular website, they can also be used for storing unique identifiers for users that may not be deleted when a user deletes their cookies.

A 2009 study examined the 100 most popular websites and found that more than 50 percent were using LSOs.⁴⁰ While some of these sites seemed to be using LSOs for caching data, many others, including U.S. government websites, were using them to store unique identifiers about the user. For many years, LSOs were not deleted when a user cleared the cookies in their web browser, during which time some of these sites used LSOs to respawn deleted HTTP cookies. These respawned cookies often contained the same unique identifier as before deletion and thus seemingly contradicted the wishes of a user to clear this information. Notably, a 2014 study of 100,000 top websites observed deleted HTTP cookies being respawned with the same unique identifier based on information stored in other LSOs, even though prior legal settlements had attempted to disincentivize this behavior.⁴¹ Following controversy over the use of LSOs for tracking, the Flash plug-in and some browsers, including Firefox and Chrome, were updated so that choosing to clear the history in the browser would also delete LSOs.

There are a number of similar techniques for using a web browser to store tracking information on a user's computer. For instance, Silverlight isolated storage provides an analogous function to LSOs for Microsoft's Silverlight framework, which competes with Adobe Flash. In addition to these plug-ins, core features of many modern websites, including JavaScript and HTML5, can enable tracking. The JavaScript programming language can store data using a property called `window.name`, which was originally designed for web designers to assign each browser window a name that they could reference in computer code. This JavaScript property allows up to two megabytes of data to be stored during a particular web-browsing session.⁴² Unlike HTTP cookies, the `window.name` property is initially empty each time a new browser window or browser tab is opened, limiting the amount of time a unique identifier will persist. Of course, this method can be used in conjunction with other methods to retain data over a long period of time.

The Internet Explorer browser itself is also able to store information on the local hard drive using `userData` storage, which enables each domain to store up to one megabyte of data. Like the other alternatives to HTTP cookies, a user who deletes their cookies will not delete information stored in `userData`. A more subtle method is a *pixel hack*, in which a unique identifier is written into a minuscule image, generated on the fly, in the form of the color values for one or more pixels. Since images are often cached, or stored locally by the browser to avoid having to download the resource again in the future, these tracking values can often be retrieved later.

HTML5, an updated specification of the HTML markup language for web pages that enables the embedding of videos, audio and visual canvas elements in web pages, also specifies methods for storing information locally, which can lead to tracking. These storage methods, which have been separated from HTML5 for specification purposes and are currently known as either Document Object Model (DOM) storage or web storage, are supported by all major web browsers as of 2012. The session storage method can save information for a particular web-browsing window; other web-browsing windows, even those containing the same application or website, cannot access this information, which is removed when the window is closed. In contrast, the local storage method stores data semipermanently. This stored information is available to all resources on the web domain that stored the data.

Additional methods for DOM Storage have been proposed and debated. For instance, Mozilla Firefox previously supported a storage mechanism called Global Storage, but support for this feature was removed in version 13 of the browser.⁴³ Similarly, Database Storage using SQLite was considered as a possible W3C standard and was implemented in some browsers, but official efforts toward its standardization ended in 2010.⁴⁴

Yet another mechanism for a browser to store information locally leverages the way web browsers cache data. Entity tags (ETags) are HTTP headers that allow a browser to permanently tag a previously viewed resource (a web page or an object contained in the page) with an identifier. They were originally designed to enhance performance when loading previously viewed websites. When a user views a website, browsers generally save a copy of objects viewed on the user's hard drive so that identical content does not need to be downloaded multiple times. A site can tag content with an HTTP ETag identifier, which changes each time the content is updated on the server. As a result, a browser can request a resource from a website while specifying that the resource should be returned only if it has changed, based on the ETag. If the resource has not changed, the site only needs to confirm this fact so that the browser can use the local copy. To enable tracking, a web server need only change and track ETags during each transaction to reidentify a visitor across multiple transactions. ETags are generally not deleted when a user clears their cookies; rather, ETags may be deleted when a user clears the browser's cache of previously viewed pages. Thus, ETags enable tracking even if cookies are deleted.

In recent years, there have been rapid changes in tracking techniques. For instance, a 2011 study found a substantial decline in the proportion of popular websites using LSOs compared to the 2009 study that initially brought attention to the issue.⁴⁵ However, a separate 2011 study noted that HTML5 (DOM Storage) and ETags were being used for the same tracking purposes.⁴⁶ In 2010, a security researcher prototyped a tracking mechanism, the "Evercookie," designed to be extremely difficult to delete.⁴⁷ The Evercookie combined many of the above techniques, storing unique identifiers in more than ten different locations on a user's computer. If data from one storage location were deleted, this data would be respawned from other locations.

Features of web browsers designed to enhance users' experience on the web can also be misused for tracking purposes. By default, web browsers show links on a page that have already been visited in one color, while links that have not yet been

visited are displayed in a different color. Although it cannot directly access a user's browsing history, JavaScript can access the color of any element on a web page, including links. Therefore, in a technique known as *browser history stealing* or *sniffing*, an unscrupulous page can include thousands of invisible links to popular sites and then use JavaScript to query the color of those links and learn whether a particular page has been visited by the client browser.⁴⁸

Another technique that misuses features of JavaScript and HTML for tracking purposes is *browser fingerprinting*, which has become widely used in recent years.⁴⁹ So that websites can adjust their pages to match the configuration of a particular user's computer, there are JavaScript functions that reveal the time zone and screen resolution, as well as fonts and plug-ins that have been installed on a particular computer. A 2010 study found that, even among a sample of potentially privacy-conscious users, 94.2 percent of browser configurations with Flash or Java installed could be uniquely fingerprinted.⁵⁰ That same study also captured an array of browser fingerprinting techniques in use. These fingerprinting techniques leverage the unique characteristics of an individual user's browser—the fonts installed, the particular version of the browser running, the idiosyncrasies of a particular graphics card—as a semi-stable, unique identifier in place of cookies, but for much the same purpose.⁵¹ Measurement studies conducted in 2014 and 2016 observed increasing use of browser fingerprinting in the wild, establishing browser fingerprinting as a major frontier in future tracking efforts.⁵²

6.2.3 Tracking Email Recipients

Many of the mechanisms that can be used to track what websites are visited from a particular computer can also be used to determine whether or not an email has been opened. Knowing when an email has been opened or when a particular link in the email has been clicked on can be useful for advertising companies to evaluate the effectiveness of a campaign, but it can also have more pernicious uses. Two common techniques for tracking email recipients are variants of the beacon and URL rewriting techniques used for web tracking.

Popular email programs, such as Microsoft Outlook and Gmail, can display emails containing HTML code, the markup language used to format many websites. HTML code enables emails to contain different colors, advanced formatting and images, just like websites. Images can be attached to the email, or they can be downloaded automatically from a remote server. To determine whether a particular recipient has opened an email, the HTML code sent in an

email to that user can request that content uniquely tied to that user be downloaded automatically from a remote server when the message is opened by the recipient.

For instance, when Bob opens an email from ABC Advertising, the email's HTML code can instruct the email program to download a one-pixel image with a filename unique to Bob from ABCAdvertising.com. Since the advertising company controls the server, it can tell whether it has ever received a request for this image, which is unique to Bob. If it has, then it knows that Bob opened the email, along with exactly when this occurred. If it has not received a request for the image, Bob may not have opened the email, or he may have opened the email using a mail client configured not to download images.

As on web pages, links to websites that are included in an email can also be customized to track whether or not a user has clicked on them. An email might contain a link that will eventually bring the email recipient to a specific website, such as *www.big-sale.com*, if they click on the link. However, rather than containing a direct link to that page, the email might contain a link to *www.big-sale.com/174cx3a*, where 174cx3a is an identifier sent only to Bob. Therefore, if *big-sale.com* receives a request for the page 174cx3a, it knows this request originated from the email that it sent to Bob.

Alarmingly, a 2018 study found that personally identifiable information (PII), such as the recipient's email address, is frequently leaked to these third-party email trackers.⁵³ Unfortunately, the same study also observed that many existing defenses are insufficient for fully stopping email tracking. These defenses include filtering HTML, accessing content through a proxy, or blocking cookies or Referer headers.

6.2.4 Cross-Device Tracking

Cross-device tracking is the process of tracking a user across multiple devices, such as computers, smartphones, tablets, and smart TVs. This can be useful to users when it allows them to suspend a video on one device and resume watching it on another or maintain state between other types of sessions across their devices. However, cross-device tracking can also be used to build rich user profiles across multiple devices, which companies may use for advertising or other purposes. Companies use both deterministic and probabilistic approaches to facilitate cross-device tracking. When users log in to a service on each of their devices, companies can use deterministic approaches to know that it is most likely

the same user on each device. However, when users do not log in, companies can use probabilistic approaches, for example matching IP addresses, to determine, for example, that the same user is likely logged into two devices simultaneously. Cookies, location and behavioral data can also be used for probabilistic cross-device tracking. Companies build device graphs based on the inferences they have made about the devices used by a particular user. Users are largely unaware that this is occurring. In a 2016 study, researchers reviewed 100 popular websites and observed multiple ways that almost all of the sites could engage in cross-device tracking. However, they were unable to determine definitively from the websites' behaviors or privacy policies which sites actually engage in cross-device tracking.⁵⁴

6.2.5 Effective Practices

In crafting a system that tracks the activities of users on the internet for any purpose, it is essential to adhere to the core privacy principles of “notice” and “consent.” Key goals include providing clear notice about any tracking that occurs, asking users to consent to the collection of data and explaining what information is collected, how it is used and stored, and with whom it may be shared.

Some jurisdictions have legal or regulatory requirements that mandate specific forms of notice or consent, or that restrict the use of trackers. For instance, the General Data Protection Regulation (GDPR), which came into effect in 2018 as the flagship privacy law in the EU, requires that

*Consent should be given by a clear affirmative act establishing a freely given, specific, informed and unambiguous indication of the data subject's agreement to the processing of personal data relating to him or her, such as by a written statement, including by electronic means, or an oral statement. This could include ticking a box when visiting an internet website, choosing technical settings for information society services or another statement or conduct...Silence, pre-ticked boxes or inactivity should not therefore constitute consent.*⁵⁵

As a result of the GDPR and the earlier EU ePrivacy Directive, which came into effect in 2013, most websites have provided opt-in boxes when visitors from the EU first visit their websites. While website should set cookies only if a user has clicked a button or performed a similar opt-in action, a 2019 study found this not to be the case.⁵⁶

Violating either the privacy expectations or the trust of users can lead to serious repercussions in both the legal and public relations domains. For instance, a series

of class-action lawsuits was brought over the use of LSOs for surreptitious tracking, while privacy concerns about some of the tracking technologies discussed in this chapter led to front-page coverage in major media outlets.⁵⁷ On the other hand, communicating clearly with users can directly benefit companies and organizations. For instance, a 2012 study revealed that a confluence of privacy concerns and misconceptions that advertisers collect more personal information than they generally do leads users to oppose behaviorally targeted advertisements, suggesting that openly communicating about practices the average user would deem reasonable might lead to increased user acceptance of tracking.⁵⁸

6.3 Blocking and Controlling Web Tracking

Users who wish to either block or limit web tracking have a number of options at their disposal. In recent years, some web browsers have begun to include strong privacy features and privacy-protective default settings. Unfortunately, there is no one silver bullet that protects a user against most tracking threats. Software that automatically protects users' privacy, such as an email client that blocks images from being downloaded by default, is simplest from the perspective of a user. More commonly, users are able to control web tracking to some degree by taking action, either by adjusting default settings in software they're likely to already have, configuring settings using a web-based interface, or downloading additional software designed primarily for privacy. Of course, for all but the automatic tools, the user must know to take certain steps, perhaps having learned to do so from the news media, a software vendor or a friend.

Tools for blocking or controlling web tracking are often provided by groups who would not benefit directly from the tracking that is being blocked. For example, some tools are provided by organizations or companies that focus on protecting consumer privacy either as a public service or as a business goal. Other tools are provided by companies with a broad mission, including the makers of web browsers. As of 2019, web browsers like Mozilla Firefox, Apple Safari and Brave Browser tout their privacy-protective features as a competitive advantage against other web browsers.

The companies or organizations that are conducting the tracking themselves sometimes also provide tools for blocking or controlling web tracking, often for regulatory compliance or due to pressure from policymakers.

Beyond a user choosing to cease doing business with a particular company, tracking by first parties is much more difficult to prevent than tracking by third parties. Tools that block all requests to trackers, including first parties, would break the functionality of most websites. Furthermore, in the United States, first parties are generally exempt from legal and regulatory frameworks concerning tracking. As a result, one of the few resources left to a user who chooses to engage with those sites is reading those sites' privacy policies to understand their practices. Unfortunately, past research has found that reading long privacy policies leads to unrealistic opportunity costs for the user, that these privacy policies are written at an advanced reading level, and that privacy policies sometimes are not translated into languages to which the rest of the site has been translated.⁵⁹

In this section, we discuss ways that a user can block or limit web tracking by third parties, which include companies whose domains are not shown in the URL bar. After focusing primarily on how a user can block third-party web tracking designed to profile behavior across many websites, we also discuss how a user can prevent their web searches from being tracked as well as how a user can block email tracking.

6.3.1 Blocking Web Tracking

Web browsers' settings are a primary way for users to disable tracking based on HTTP cookies. In some browsers, privacy-protective processes are automatic, and the degree to which this is the case has increased substantially in recent years.

6.3.1.1 Privacy Settings in Browsers and Do Not Track

Browsers differ in the prominence and types of cookie settings that they provide. If a browser blocks third-party cookies, third-party tracking becomes more difficult. Unfortunately, blocking all third-party cookies might cause some nontracking websites to work incorrectly, creating a usability tension between privacy and functionality. Complicating matters, even if third-party cookies are disabled, first-party websites may set tracking cookies that are also embedded in third-party websites.

At a high level, web browsers generally enable users to allow all cookies, allow only first-party cookies or block all cookies. For many years, changing a browser's default settings for cookies has been one of the more straightforward ways to limit, but not completely stop, third-party tracking. As of 2019, browsers differ notably in the prominence of these settings in their user interfaces. Mozilla Firefox's

cookie settings are featured prominently in its Privacy & Security menu, with a series of checkboxes to allow users to block third-party tracking cookies or all third-party cookies. On the other hand, Google Chrome's cookie settings are buried three menus deep: On the "Settings" page, the user must click "Site Settings," and then the sub-menu "Cookies" to see the option for third-party cookies. Rather than requiring users to change a number of settings, some browsers have begun to focus on providing a small number of privacy-level modes to minimize the burden on users. For example, Microsoft Edge has announced that users will be able to choose between "unrestricted," "balanced" and "strict" modes of increasing privacy protection.⁶⁰

Default settings are a powerful tool for privacy because most users do not change default settings. When third-party cookie blocking is not on by default, users hoping to block third-party cookies must change the browser's default setting, which many users never do.⁶¹ Crucially, browsers again differ (as of the time of press) in their default settings for cookies. Apple Safari was the first major browser to block all third-party cookies by default.⁶² As of 2019, Mozilla Firefox similarly blocks third-party cookies from known trackers by default.⁶³ In contrast, Google Chrome and Microsoft Edge allow third-party cookies by default.

To strike a balance between privacy and usability, Firefox uses a list of known trackers curated by Disconnect to decide which third-party cookies to block, though the user can choose to reconfigure Firefox to block all third-party content at the risk of a functionality loss. The idea of having a blacklist identifying tracking domains, as Firefox now offers based on the Disconnect list, has a long history in privacy. For example, the since-deprecated Microsoft Internet Explorer 9 included Tracking Protection Lists (TPLs). With TPLs, third parties could curate lists of domains, and users could download these lists specifying whether or not requests to particular domains should be blocked. Notably, TPLs and browser-based cookie blocking do not require users to rely on websites to honor their requests since communication to those sites is actually blocked.⁶⁴

The Safari and Firefox default settings for blocking third-party cookies are part of their respective Intelligent Tracking Protection and Enhanced Tracking Protection features, which bring together a number of subtle privacy-protective design decisions for minimizing major tracking vectors.⁶⁵ For example, Safari's Intelligent Tracking Protection sets time limits for the retention of the cookies it does allow.⁶⁶

Of course, at best, these methods only prevent tracking that uses cookies exclusively. Even without third-party cookies, however, allowing third-party

requests can still enable tracking if the third party uses a browser fingerprint as a unique identifier or employs other technical tricks, like the LSOs listed above. In response, browsers have begun to make fingerprinting more difficult. For example, Mozilla Firefox introduced a number of anti-fingerprinting features in 2019.⁶⁷

Furthermore, all major browsers offer private browsing modes that disable the storage of browsing data on a user's computer while the mode is enabled. Private browsing can provide a small amount of protection from tracking by deleting the cookies accumulated during that session when the browser is closed. A 2010 study demonstrated, however, that these modes are far from perfect technically; they also offer minimal protection from tracking and surveillance.⁶⁸ Furthermore, a 2018 study demonstrated that users' expectations about the privacy protections provided by these modes often differ from the actual protections they provide.⁶⁹ Browsers like Firefox bundle independent tracking protection features with private browsing mode, potentially adding to confusion about the protections provided across browsers.

Recent years have seen the release of new web browsers designed specifically to be privacy-protective. For example, the Brave Browser initially released in 2016 and the Epic Browser initially released in 2013 utilize many of the types of tracking protection described above, such as blocking trackers or always running in the equivalent of other browsers' private browsing modes.⁷⁰ While the market share of these privacy-focused browsers remains small, some of the same protections have made their way into the default settings of widely used browsers.

In contrast to technical mechanisms that attempt to disallow or circumvent tracking technologies, an idea that received attention earlier this decade was a Do Not Track (DNT) setting. The core idea of DNT is that it is an HTTP header sent alongside requests for web content. This header can indicate that the user has requested not to be tracked, that the user has actively chosen not to make this request or that no preference has been set. Since DNT does not actually block communication with a particular tracker, a user who has enabled this feature relies on companies to honor this request. After Mozilla implemented DNT in Firefox, all other major browsers added the setting. Notably, Microsoft automatically enabled Do Not Track as the default setting in Internet Explorer 10, which led to protracted debate among industry and standards-body groups about whether or not trackers may ignore such default settings.⁷¹ In contrast, Google implemented DNT in Chrome in late 2012, well after the other major browsers, and buried the

setting in an advanced menu and provided a message discouraging users from activating DNT.⁷²

Unfortunately, DNT was mostly a failure for meaningful privacy protection. The exact details of both the meaning and mechanism of DNT were debated over nearly a decade within the World Wide Web Consortium (W3C) as part of the Tracking Protection Working Group.⁷³ For example, one protracted debate about the DNT proposal centered on whether enabling this feature would mean that trackers could not collect information about a user (the preferred position of many privacy advocates), or whether they could collect information but not use the information to target advertising (the preferred position of many ad industry representatives). Questions also persisted about how websites should respond upon receiving a DNT signal. These debates, alongside low voluntary adoption by websites, led to DNT being mostly abandoned as of 2019, including being removed entirely from Apple Safari.⁷⁴

The complex intersection between policy and technology is also visible in the design of deployment of browsers' user interfaces regarding cookies. While Microsoft Internet Explorer has since been replaced by Microsoft Edge, an example of the user interface for cookie preferences from earlier versions of Internet Explorer remains instructive. In contrast to other contemporaneous browsers, Microsoft Internet Explorer had a slider on which users could choose their privacy level, which thereby dictated their cookie settings. The settings for directly disabling third-party cookies, or disabling all cookies, were buried in an Advanced menu. A user's preferences based on this slider were evaluated using websites' Platform for Privacy Preferences Project (P3P) tokens. P3P is a machine-readable language with which websites can express their privacy practices, such as the information that they collect and how this information is used. Microsoft Internet Explorer used P3P policies to decide whether to accept or block a cookie from a particular site. Thus, cookie decisions could be made on the basis of how cookies would be used. The default setting in the Internet Explorer 6 through 10 web browsers blocked third-party cookies when they do not have P3P tokens and when they have P3P tokens, indicating a privacy policy considered unsatisfactory by Microsoft's criteria. Although P3P is a World Wide Web Consortium (W3C) standard, Internet Explorer was the only major web browser that used P3P, and P3P was not widely adopted by websites. Furthermore, some sites misrepresented their privacy policies by using nonsensical or sample P3P tokens, rendering P3P unreliable.⁷⁵ Microsoft sought to

combat this loophole by including a Strict P3P Validation feature in Internet Explorer 10. If a user enabled this feature, which was off by default, the browser blocked “cookies from third-party sites that don’t have valid P3P policies.”⁷⁶

6.3.1.2 Web-Based Privacy Tools

Beyond using software tools already available on their computers, users can take advantage of web-based tools to learn about tracking. Some of these tools can also be used to control tracking in limited circumstances.

For example, a few companies that track users provide web-based dashboards through which users can view and sometimes edit the profiles these companies have constructed of their interests. For instance, Google, Facebook, Oracle BlueKai and Nielsen all provide dashboards or equivalent ad-preferences pages indicating advertising and targeting preferences, and Evidon’s Open Data Partnership allows trackers to show users the behavioral profiles they have created.⁷⁷ Unfortunately, these dashboards tend to provide an incomplete view of the information that has been collected. In particular, the raw data collected is almost never shown to users. Furthermore, a 2018 study found that even the high-level data shown to users was often incomplete and sometimes misleading.⁷⁸

A handful of advertising networks have begun to provide user-facing explanations of why they received a particular ad. These efforts are crucial both because humans struggle to understand the algorithmic processes underlying targeted advertising and because outside nations have used targeted advertising for influencing elections, such as in the 2016 U.S. election.⁷⁹ Unfortunately, these explanations are again incomplete. Predating detailed ad explanations, the industry-standardized AdChoices icon and accompanying tagline has been used to identify targeted advertisements. However, a 2012 study found that these icons and taglines poorly communicated to consumers that advertisements were being targeted to them or that consumers could click on these icons as a step in choosing not to receive targeted ads.⁸⁰ Studies of the more detailed explanations provided by companies like Facebook have shown them to be factually inaccurate or incomplete, as well as insufficient from a usability perspective.⁸¹ Complicating this ecosystem, targeting can be based on data collected directly by a company as well as by data purchased from outside data brokers.⁸²

Notifications about cookies are another mechanism of web-based transparency. As previously mentioned, an informed consent requirement for cookies that is part of the laws in the EU has prompted many websites to provide prominent

notices about cookie options. As a result of the passing of the EU Directive 2009/136EC (“EU Cookie Directive”), implicit consent is no longer considered sufficient notice to consumers in certain cases when websites wish to set cookies.⁸³ As a result, in 2012, some sites began providing consumers with conspicuous notices about the use of cookies, often with options to disallow certain types of cookies on that site. This requirement was reinforced when GDPR came into effect in 2018 with similar consent requirements. Notifications about the use of cookies are now nearly ubiquitous for users in the EU upon their first visit to a website after clearing cookies. Nevertheless, websites sometimes still set cookies before consent is given, and a user who does not wish to accept the cookies is often resigned to not use the website.⁸⁴

A number of companies engaged in tracking also offer a system of opt-out cookies. Rather than being used for tracking, opt-out cookies are HTTP cookies indicating that a consumer has chosen to opt out of receiving targeted advertising. Although users who have opted out will not receive targeted ads from a particular company, some companies will still track those users’ online activities. Opt-out cookies are also problematic from a usability perspective since users who delete their cookies, as many privacy-conscious users might, also delete their opt-out cookies. Furthermore, setting opt-out cookies for each of the hundreds of tracking companies a user might encounter would take a long time. Centralized websites organized by industry groups offer a single place at which a user can opt out from many companies at once.⁸⁵ However, research has identified major usability problems with these centralized websites.⁸⁶

6.3.1.3 Third-Party Browser Extensions

Browser extensions designed for privacy purposes are an additional mechanism for stopping web tracking. A number of companies offer tools specifically designed to stop web tracking conducted by advertising networks, social networks and other companies interested in collecting what websites a user visits. For example, the partially open-source tool Disconnect is provided by a company of the same time. The company Cliqz offers Ghostery, which was formerly owned by Evidon. Similar tools include the open-source Privacy Badger from the nonprofit Electronic Frontier Foundation (EFF).

These tools generally work by blocking, to varying extents, the mechanisms used for tracking. While some tools completely prevent the user’s browser from communicating with those domains or trying to download those resources, others

allow the request to go through, yet prevent the request from including cookies.⁸⁷ Additional subtle modifications to requests, such as removing the HTTP Referer field, can also protect the user's privacy in limited ways.

Some general-purpose browser add-ons can limit web tracking to an extent. For instance, the popular Firefox and Chrome extension Adblock Plus, designed to block large fractions of the advertising on the web, blocks requests to the domains of a number of advertisers and thereby limits the collection of tracking data by those particular advertisers. Similarly, NoScript, a Firefox add-on designed to prevent websites from executing JavaScript code and plug-ins like Flash, can prevent tracking that occurs using those plug-ins. Notably, HTTP cookies are sometimes created using JavaScript, and blocking the Flash plug-in can prevent LSOs from being set.

A major dilemma with all of these tools is the burden they impose on users, who must take a number of steps to protect their privacy. Generally, these tools first require a user to install the tool, either from the developer's website or from a centralized repository. Following installation, tools often ask a user to choose configuration options. Over time, the tool may automatically update itself, or user intervention may be required to install the newest version.

Unfortunately, neither specific privacy tools nor general-purpose add-ons are necessarily easy for an average consumer to use. For example, a 2012 study of web-tracking privacy tools revealed serious usability flaws in all nine of the popular tools it tested.⁸⁸ Pervasive usability flaws identified by the authors included nonprotective default configurations incommensurate with the goals of a privacy tool, confusing interfaces and jargon. In addition, their study participants found it difficult to make decisions required by the tools about what advertising companies to block, what blacklists or whitelists to choose and what tracking technologies to disallow. Furthermore, a 2016 follow-up study found major gaps in users' understanding of the tracking ecosystem even after using these types of tools.⁸⁹

6.3.1.4 Deciding What to Block

Many privacy tools ask users to configure settings and decide what to block. However, a user's decision about what to block can be fraught with complexity. Based on interviews with 48 nontechnical users, a 2012 study concluded that users have great difficulty reasoning about tracking technologies and evaluating companies to block; they also hold major misconceptions about how behavioral

advertising works.⁹⁰ However, users are not alone in facing this difficulty. Software designed for blocking also must decide what to block. If a tool blocks too little, it will be ineffective. However, if it blocks too much, it may break web functionality, leading users to be annoyed and potentially abandon the tool. Furthermore, widespread adoption of a tool that thoroughly blocks existing tracking methods might lead trackers to adopt increasingly surreptitious and subtle methods of tracking.

Instead of asking the user to make a decision about each potential tracker, organizations or individual experts can compile a list of domains or patterns to block. Precompiled lists have been used by tools ranging from the Adblock Plus browser extension to Internet Explorer's Tracking Protection lists. Although they can ease the decision-making process for users, lists have their own drawbacks. Some tools, such as the Disconnect browser extension and Mozilla Firefox's built-in Tracking Protection feature (which also uses Disconnect's default Level 1 block list), maintain a default blacklist of domains or resources tied to tracking.⁹¹ In these cases, users can achieve a fair amount of privacy by keeping the default list, though Disconnect's more aggressive Level 2 block list would achieve greater privacy, albeit at the expense of website functionality. Other tools, however, require users to choose a list from many options. Internet Explorer's Tracking Protection feature took this approach. However, users need to be aware that they must select a list, and they also must be able to evaluate potential choices, both of which have been shown to be difficult.⁹² Furthermore, by their nature, lists will not conform exactly to an individual user's privacy preferences, which tend to be complex. It is also possible for lists created by one organization to cause competitors' pages to be blocked or to serve business interests, further complicating the compilation of lists. The advantage of lists is that they provide users a simple one-size solution that can be tailored to fit their needs.

Some tools use partially automated metrics for determining what to block. For instance, the EFF's Privacy Badger browser extension uses heuristics and algorithmic methods to identify potential tracking and automatically choose what to block.⁹³ In contrast, the since-deprecated Microsoft Internet Explorer used P3P tokens specified by websites in order to determine what to block. Furthermore, some versions of Internet Explorer determined when to block cookies from a domain using frequency counts, which are running totals of the number of different first-party domains on which a particular tracker has been seen by that user's browser.⁹⁴

Other tools are designed to help users visualize this sort of frequency information. For instance, Mozilla's Lightbeam tool (formerly known as Collusion) presents a visualization of which third parties track users across particular websites.⁹⁵

Differences in the extent to which tools block tracking add more complexity to users' efforts. A tool that blocks too little leaves the user easily vulnerable to tracking, whereas a tool that blocks too much can break the functionality of the websites that the user hopes to visit. Some tools, including the general-purpose script-blocking tool NoScript and web-tracking-privacy tool Ghostery, break functionality on websites in ways that may be obvious or opaque to users. To proceed with their browsing, users might try to unblock specific elements until a page loads, disable the tool entirely or adopt ad hoc solutions, such as using a different browser without the privacy tool.

Researchers have coined the term *functional privacy* to capture users' willingness to aim for as much privacy as they can get without breaking the functionality of what they hope to accomplish on the web.⁹⁶ However, it remains to be seen whether such a conception would incentivize trackers to break the functionality of pages intentionally. Along these lines, tools that aim to provide privacy without breaking website functionality have been proposed. For example, ShareMeNot blocks social widgets on websites until a user actually wishes to use the widget, which is a promising direction for the design of privacy tools.⁹⁷ Other tools try to create decoy traffic to obscure the user's true behavior. For instance, the AdNauseum browser extension automatically tries to click on every ad it observes.⁹⁸

In place of a web-based tool or software, some users create ad hoc strategies or adopt overriding strategies. For instance, some users might use different browsers with different privacy settings, using a less privacy-protective browser when a site's functionality breaks with a more privacy-protective setup. In contrast, other users employ privacy-preserving proxies that are designed to scrub their web requests from potential identifying information, such as cookies, HTTP headers and their IP address, along with tunneling requests from many users through the same channel. Like all other solutions, proxies are not a silver bullet and can certainly still leak information about a user. They can also break web functionality.

Implicit among the challenges of protecting user privacy against web tracking is the complex nature of privacy decision-making. Past research has demonstrated that privacy is often a personal process in which different users will have very

different preferences.⁹⁹ Furthermore, privacy depends on context, which is a notion currently unsupported by major privacy tools.¹⁰⁰ Overall, a user has many tough choices and few easy solutions when attempting to stop web tracking.

6.3.2 Blocking Tracking of Web Searches

Users who wish to protect their privacy when using search engines also have a handful of mechanisms available. However, this task is more complex since most privacy tools for limiting web tracking focus on third-party tracking, and disabling certain tracking mechanisms on first-party sites will often break those sites' functionality. As a result, the simplest and most secure way for a user to minimize having private information leaked through web searches is to use a search engine that promises not to track the user. Alternatively, users can download tools that help them obscure their searches by inserting a large number of decoy requests, or they may use proxies or other general-purpose tools to make their searches more private, although only to an extent.

In recent years, a handful of search engines have begun to use privacy-protective practices as a competitive advantage. The most popular search engines generally save a user's search history, including their search queries, when these queries occurred and information such as the user's IP address and unique identifiers from cookies. In contrast, privacy-protective search engines, such as DuckDuckGo, promise to neither collect nor share a user's personal information. By default, DuckDuckGo does not use HTTP cookies except to save preferences about the page layout a user has chosen, nor does it allow the HTTP Referer field to contain information about the search query. However, users must trust DuckDuckGo and similar sites to fulfill their privacy promises.

Users who wish to hide their search history can also download a tool to assist them, although few tools exist for this purpose. TrackMeNot, an add-on for Firefox and Chrome, protects a user's privacy by issuing decoy queries to major search engines.¹⁰¹ As such, it operates by achieving security through obscurity, creating ambiguity about whether a particular query was issued by a user, or whether it was issued automatically by the program. The plug-in's behavior is meant to mimic that of a real user. For example, it sometimes performs a large number of queries in a short amount of time, and it selectively chooses whether or not to click through to a link.

Users can also use general or ad hoc techniques to prevent their searches from being tracked. For instance, a proxy or an anonymizing network such as Tor can

strip some or all of the identifying information from web traffic, making a user's searches more difficult or impossible to track. However, it is possible for private information to leak even when using techniques such as the TrackMeNot plug-in and anonymizing services. Researchers have shown that users who enter their own name or other PII in searches can still be vulnerable to having their searches tracked even if they would otherwise be anonymous.¹⁰²

6.3.3 Blocking Email Tracking

In contrast to web tracking, the issue of email tracking has become a less pervasive problem in recent years without direct user intervention. A number of modern email clients block beacons, images and other content loaded from external sites since this external content could be used for tracking. This behavior disables one of the most widespread techniques for determining whether or not an email has been read. Unfortunately, not all email clients block outgoing requests by default, nor implement related privacy-protective measures.¹⁰³ Furthermore, users are unlikely to realize the privacy-protective benefits of blocking images, and they might turn off this feature without considering the implications.

However, since tracking can still be accomplished through URL rewriting, it is important that a privacy-conscious user also not follow links contained in emails. If a user does not follow links contained in emails, tracking using URL rewriting cannot succeed. Furthermore, due to the threat of phishing attacks, it is generally considered good practice not to follow links in emails whenever the user must enter information at the destination. Even if a link in an email does not seem to contain any type of unique identifier, users who follow the link or otherwise access that information on a site are subject to web-tracking techniques.

Mail servers themselves can also handle external images and beacons in a way that makes emails less able to be tracked. For instance, Gmail automatically serves all images in emails through its own proxy, meaning that Gmail users reveal to trackers when they open an email, but not where they are (as indicated by their IP address).¹⁰⁴ Alternatively, to prevent trackers from even knowing when a user opens an email, mail servers could automatically download external content immediately upon receipt, although this technique again has a number of subtleties in practice.

Finally, a common ad hoc technique to prevent email tracking is for a user to maintain multiple personas online. As it is often free to create an email account, many users have multiple email accounts. If a user has created an account

exclusively for receiving email solicitations, they may not mind if a company knows when that account has read an email since the account may not be tied to any real-life identity. Of course, subtle information leaks are possible. For instance, the date and time that the email has been read, as well as a user's IP address, browser configuration and HTTP cookies, can tell a company substantial amounts of information about that user. In addition, a person who uses a separate email account and then makes a purchase tied to that email address from one company is at risk for having their identity tied to that account, even by other companies with whom this purchase data is shared or to whom this data is sold.

6.3.4 Effective Practices

Currently, a user who hopes to prevent their activities on the web from being tracked is put in a difficult position. To protect against the myriad different tracking threats, a privacy-conscious user must often use a patchwork of tools. Even with substantial effort, it is unlikely that the user can feel fully in control of their privacy. For instance, there are always potential tracking mechanisms that a researcher or newspaper may soon reveal have been put into use, and the data that has been collected about a user's activities is rarely made available to the user. Furthermore, whereas some tools provide a technological solution by blocking one or more mechanisms used for tracking, other tools require a user to trust that a company or website will respect a preference that has been set or follow a practice the company has advertised.

While there are no perfect solutions for users to protect themselves against tracking, there are many effective practices that should be followed by the companies or organizations providing users with tools to protect their privacy. The inclusion of a graphical user interface and colorful icons does not magically make a privacy tool easy to use. Rather, to craft a tool that actually does help consumers protect their privacy, careful consideration and substantive feedback from user studies is essential, albeit often overlooked.

It is important for users to be made aware of tracking in the first place. User education can take many forms, ranging from prominent disclosures from trackers themselves to media stories warning of privacy risks. Regardless of the type of communication, it is essential that communication be both clear and prominent. This issue has taken on particular importance following debate over the EU's disclosure requirements for cookies, in which regulators deemed it insufficient when a user is considered to have implicitly consented to tracking after being

informed of this practice only by a lengthy privacy policy. In contrast, it is considered effective practice to provide users with conspicuous, clear and understandable notice about tracking and to give them the opportunity to choose not to be tracked. Unfortunately, the implementation of EU cookie notices in practice has been of questionable usability and utility for users.

Of course, the mechanisms for allowing users to choose not to be tracked have their own effective practices. First of all, users should not be expected to make decisions about particular technologies. When a user expresses a preference not to be tracked, the developer might wonder whether the user wants to block tracking accomplished using LSOs, only tracking using HTTP cookies, or both. However, this is likely the wrong question to ask. Users' preferences are often technology-neutral. It is essential that privacy tools match this expectation to the greatest extent possible. Furthermore, privacy-protective default behaviors should be chosen when they will not interfere with desired functionality. For instance, in the case of preventing beacons from tracking whether an email has been read, email clients automatically block these requests without requiring the user to do anything. Any actions for which user intervention is required should be able to be completed quickly, and any interfaces presented to the user should be tested extensively in usability studies to ensure that they can be used with few or no errors.

6.4 Location Tracking

As more people carry mobile phones with location-tracking capabilities, the ability to draw on constant location information is becoming increasingly prevalent. Social networking applications, employee-tracking systems and location-enabled media (such as photos) are among the technologies that use this location data to enhance their systems.

Location tracking also extends beyond the mobile phone. RFID chips are increasingly embedded in smart cards as well as in consumer products. If an RFID reader detects a particular RFID chip at a given location, a particular user's location can be revealed. GPS and other tracking technologies are emerging in consumer hardware like cars and cameras. In such a world, those deploying tracking technologies should be aware of their capabilities as well as their potential privacy implications.

This section outlines location-tracking technologies and services, techniques for blocking location tracking and effective practices for those employing location-tracking technologies.

6.4.1 Location-Tracking Technologies

Devices can contain a wide variety of location-tracking technologies, each of which relies on slightly different types of underlying systems. We will describe several of the most common location-tracking technologies: Wi-Fi and cell tower triangulation, GPS, RFID chips, phone tracking, and the use of location data stored in content metadata.

6.4.1.1 Wi-Fi and Cell Tower Triangulation

Wi-Fi and cellular signals can be used to allow a device that is enabled for Wi-Fi or cellular communications to determine its location.

Cellular phones communicate with cellular towers that receive their signal and connect phones to a global network. The time it takes messages from a particular cell phone tower to arrive to a phone, the strength of the signal from that tower and, most simply, which towers a phone can communicate with all reveal information about the phone's location. After determining the phone's position relative to a handful of towers whose locations are known by the cellular provider, the position of the phone can then be determined geometrically through triangulation.

In addition to signals from cell towers, the Wi-Fi signals a phone receives can help determine its location. Wi-Fi signals have a shorter range, allowing for more fine-grained location information. Cell towers provide a more permanent location marker but less granular location data.

Wi-Fi and cell tower triangulation requires the creation of a preexisting database of Wi-Fi access points and cell tower locations that cover the region over which the location tracking will occur. Thus, this type of location tracking is primarily beneficial in urban areas where there is a high density of Wi-Fi access points and cell towers.

6.4.1.2 GPS

GPS satellites can also be used to determine location, specifically the device's longitude, latitude and altitude. Many consumer devices, including mobile phones, are equipped with GPS capabilities for location tracking. Cameras and similar devices can also include GPS capabilities for tagging the location of

photographs taken, and automobile infotainment systems can include GPS capabilities to pull regional content, such as weather and news-related information, into the vehicle's navigation system.

GPS calculates a device's location using signals received from at least four of a set of dozens of geosynchronous satellites positioned in space and run by the U.S. government.¹⁰⁵ Based on the differences in the time it takes messages from these different satellites to arrive to a receiver, a GPS receiver can determine its position relative to the satellites. Since these satellites' positions are known and constant relative to the earth, the GPS receiver can determine its own position geometrically. Because devices receive and do not transmit any signals in the GPS process, devices do not automatically reveal their location by using GPS. However, devices with GPS can also include transmitters that can be used to reveal the device's location to other parties and services. For example, a smartphone that determines its own location by receiving signals from GPS satellites might subsequently, and automatically, share that information with an app or the phone provider.

6.4.1.3 RFIDs

RFID chips are tiny microchips that can be as small as a fraction of a millimeter. Each microchip is identified by a unique serial number and contains an antenna with which it transmits information, such as its serial number, to an RFID reader.

RFID chips can be placed on products or cards or implanted in animals (such as household pets) for tracking purposes. They are commonly used in supply chain management to allow companies to track inventory. Passive RFID chips, which do not contain their own power source, are the most common. When power is applied by an RFID reader, these chips transmit a signal encoding their identifier. Active RFID chips contain their own power source, which allows them to transmit farther than passive chips. Depending on the type of chip and its power, particularly whether it contains its own power source, the signal can be picked up at varying distances. RFID chips transmitting at low frequencies have a range of about half a meter; those that transmit at ultrahigh frequencies can reach readers located dozens of meters away.¹⁰⁶ The unique serial number associated with each RFID tag allows for location tracking. Tagged items are tracked as the readers pick up the tag IDs at different locations. If additional information is stored on the tag, the reader is also able to pick up that information and associate it with the tag's location.

6.4.1.4 Phone Tracking

The location of a mobile phone and the individual to whom the cell phone belongs can be tracked using receivers installed within a building complex. The FCC also requires that phone companies be able to track phones when an emergency (911) call is placed.¹⁰⁷

An application of phone-tracking technology came to light during the 2011 holiday shopping season, when two U.S. shopping malls tested a system to track shoppers within the mall based on the location of their cell phones as part of a “mobile phone survey.” Signs notified the shoppers that the tracking was taking place, and shoppers had the option to opt out by turning off their cell phones. The malls ended the survey early after concerns about shopper privacy and the legality of the survey were raised.¹⁰⁸

6.4.1.5 Metadata

Location information can also be automatically stored in the metadata of content, like photos. *Metadata* is information that is automatically or manually added to content and that can be later accessed and used during processing or by applications. For photos taken with GPS-enabled devices, such as cell phones or GPS-capable cameras, location is often automatically stored in the camera metadata, sometimes without the user’s awareness. When the photos are loaded into photo-browsing or -editing applications, this information is then accessible to the user or application, potentially raising privacy concerns.¹⁰⁹

6.4.2 Location-Based Services

Location-based services draw on the data provided by location-tracking technologies to augment a variety of systems, including social media and other location-based applications. Emerging uses of location-based services include tracking individuals, such as employees or children, and location-based advertising. Location-based information can also be combined with other data to create new applications.

6.4.2.1 Social Media

A variety of social media applications use location tracking as the basis for, or to augment, their services. Some applications are primarily focused on allowing a user to notify others of their location and to track others’ locations. One such application is *Foursquare*, a mobile app that allows users to “check in” at locations and view their friends’ check-ins. Users are further motivated to check in by the

ability to earn badges and receive coupons for participation. Similarly, *Find My Friends* is an Apple application (for iPhones, iPads or iPods) that shows the location of a user's friends who use the service.¹¹⁰

Other applications include location-based features to augment their services. *Facebook Places* allows users to check in at locations as well as tag shared items with location data.¹¹¹ *Yelp*, a site that allows users to rate restaurants and other services, includes a feature with which users can physically check in to the locations of the service providers.

6.4.2.2 Location-Based Applications

A variety of other applications rely on location-based services for functionality. These include applications that provide maps and directions on cell phones or GPS units, local weather applications, and applications that query a user's location to provide information on nearby services, items or individuals.

Applications that provide maps or directions typically rely on location-based services to pinpoint a user's location. The application then provides a map of the user's current location based on a database. GPS navigation is often used in car-based units to help users navigate street maps. The user's location is provided using GPS, and maps are provided based on a database of street maps. In both examples, direction routing is performed based on mapping algorithms.

Smartphones also often provide map and direction functionality, which can use a combination of GPS and Wi-Fi and cell tower triangulation to calculate a user's location. *Google Maps* for mobile devices is one example of such a mapping application.

Other applications use location information to provide location-specific content. For example, weather applications track a user to provide location-specific weather alerts or updates. *iMapWeather Radio* is one such application; it uses location tracking to localize weather forecasts and critical weather alerts for a user.¹¹² Additional applications provide information about services, items, or individuals in a user's vicinity. Many mapping applications allow users to search for the nearest restaurants, gas stations or other services.

When a smartphone or other location-enabled computing device is lost or stolen, location-based applications can also help the owner to locate the device. For example, major smartphone manufacturers have built competing apps with names like *Find My Phone* for this purpose.¹¹³ Upon logging into such an app from another device, the user can often view on a map where the device is. Many of

these apps also enable the user to remotely trigger the device to play a sound or make other audible signals of its location.

The widespread availability of location information on smartphones also enables applications to geotag data, which means to label the data with the geographic location where it was created. For example, users of the popular image-sharing service *Instagram* frequently geotag their photographs.¹¹⁴ Carelessly assigning geographic metadata to content can create privacy and security risks. For instance, geotagged information posted to social media can alert robbers that an individual is away from home or leak an individual's precise address to stalkers.¹¹⁵ Similarly, geotagged photographs posted online enabled enemy combatants to locate and destroy U.S. Army helicopters on a military installation in 2007.¹¹⁶

6.4.2.3 Tracking Children and Employees

Location-based services can also allow users to explicitly track others. Parents can use the GPS in their children's cell phones to perform location tracking. For instance, dozens of parental control apps allow parents to remotely track their child's smartphone.¹¹⁷ Some online services also allow parents to see where their children are throughout the day using either a specialized cell phone or a normal calling plan.¹¹⁸ The usage of these types of location-based apps for parental controls can exacerbate tensions between children and their parents as parents struggle to adapt their parenting strategies to the technologically filled world in which their children live.¹¹⁹

Just as employers can use online surveillance to monitor employee computer usage, so can they use location tracking to monitor or track employee whereabouts. This can be done to reduce company liability, address potential threats to security and track operational efficiency. Employee tracking can be performed using RFID chips or GPS trackers carried by the employees.¹²⁰

6.4.2.4 Location-Based Ads

Location-based information also provides a rich data source to advertisers, allowing them to create advertising that specifically takes an individual's location into account. Advertisers can offer advertisements or marketing offers tailored to a specific location based on data from mobile devices with location identification or a user's self-identified location on services like social networks.

Advertisers can take advantage of user location in a variety of ways. The first is to specifically identify the consumer's physical location, often by determining the location of the consumer's smartphone. An advertiser can either constantly track

the consumer's phone or use a "geofence" to determine when the consumer is in the vicinity of a specific, targeted location. Advertisers can also use consumer's location check-ins on various services like Facebook or *Foursquare* to determine the consumer's location and offer targeted advertising.

Mobile devices equipped with near-field communication (NFC) are another technology that can support location-based advertising. NFC allows devices in close proximity, or that are touching, to transmit information via radio waves. This allows consumers to access content when at a specific location.¹²¹

However, location-based advertising presents privacy concerns. In 2011, a study of theoretical sharing preferences by Kelley et al. found that users had significant privacy concerns about sharing their location with advertisers, but found these concerns were somewhat mitigated when users had the ability to restrict sharing based on their location or the time of day.¹²²

6.4.2.5 Combining with Data from Other Sources

Location information drawn, for example, from mobile devices, can be combined with data from other sources to allow inferences that would not be possible with each data source taken individually. For instance, the *Please Rob Me* website gained media attention in 2010 for its possible privacy implications. This site aggregated information from users' *Foursquare* and Twitter accounts to create a list of people who were likely not at home since they were currently checked in elsewhere. Controversy over the privacy implications of combining location data with data from other sources erupted again in early 2012. This time, the *Girls Around Me* phone application used the gender information from accounts provided to *Foursquare*, as well as location information provided by check-ins, to allow users to search for women in their vicinity. *Foursquare* found that the app violated its policies and shut off the developer's access to *Foursquare* data.¹²³ However, this scenario provides an example of how inferences can be drawn from location-based data and can lead to privacy concerns.

6.4.3 Geographic Information Systems

A geographic information system (GIS), such as a computer database or imaging tool, is a technology used to view and manipulate stored geographic information. Such geographic content could relate to any quantities associated with a particular location, including maps, population or other census statistics, or data about a specific resource at a location.

Uses for GIS are wide ranging. They can include logistics systems used for businesses, such as airlines, that need to track passengers, and utility companies, which need to direct crews, as well as agricultural applications for planting decisions.¹²⁴

6.4.4 Preventing and Controlling Location Tracking

The range of location-tracking technologies and the uses for location tracking can present privacy concerns. It is possible to block some types of location tracking on mobile devices. However, even when a mobile phone is turned off, it is often still possible to use the triangulation techniques discussed in this chapter to track its location as long as the phone's battery is connected. Furthermore, it is not always preferable to block location tracking, as the addition of location data can augment a service. Thus, systems are also being developed to allow more granular control over location sharing for location-based applications. Additionally, current research examines ways to preserve privacy in location-sharing technologies.

6.4.4.1 Blocking Tracking

Depending on the type of location-tracking technology, users can block or limit tracking to varying degrees. For location-based services that automatically include location data or include it when the user opts in (e.g., checks in on a social network), a user can either opt out of location tracking or remove location data from content after the fact. The mechanism for opting out of location tracking varies based on the technology used. For some services, like location-based services that rely on check-ins, users are opted out by default and are required to check in to be tracked. For other services, like adding location data to tweets on Twitter, the user can choose to turn location tracking on or off. Still other services, like some smartphone applications, require that users decide whether or not to enable location tracking when they download the application. In this case, a user can opt out only by choosing not to use the service.

Users can also remove location data from some content after it has been added by the application. For example, it is possible to use photo-editing applications to delete the location metadata from photos after they are taken.

Tracking through RFID chips can be physically blocked, or in some cases, the RFID chip can be physically removed. Because RFID chips rely on a radio wave signal for tracking, a protective sleeve can be placed over an item that contains an RFID chip to prevent the chip from being read until the user desires the chip to be

readable. This is useful for items like passports, which include chips containing information that the user does not want to be accessible until a certain time. RFID chips can also be removed from items like clothing or other products to prevent tracking, although such techniques prevent the use of the information on the RFID chip at a later time.

6.4.4.2 User Controls

Although it is possible to block tracking to various degrees, sometimes it is more desirable to control who has access to different types of location data at different times. Technologies like geofences let users control the boundaries of location tracking using geographic guidelines. Location-based services can enable users to set privacy settings to different levels of granularity, giving users control over who has access to their location information at what times. At a basic level, *Foursquare* allows users to prevent anyone they have not accepted as a “friend” from viewing their check-in location data.¹²⁵ This is known as setting a whitelist, or a priori setting up a group of people who always have access to the data.

It is also possible to allow privacy settings along more granular dimensions. For example, a 2017 study served as a proof of concept for restricting Android phones’ sharing of location data and other types of information to contextually appropriate circumstances.¹²⁶ In earlier work, researchers found that users’ location-sharing preferences varied based on the type of information that they planned to share, the type of group they planned to share with, time of day, day of week and the location.¹²⁷

An important first step in encouraging user control of location data is making them aware in the first place that their location is being shared or used. A 2013 study prototyped an interface for notifying users about data leaks on smartphones.¹²⁸ A subsequent 2015 study demonstrated that quantifying these leaks of location information can nudge users towards more privacy-protective behaviors.¹²⁹

6.4.4.3 Research into Privacy Protections for Location

Beyond methods for controlling location sharing, there is research into methods for providing the benefits of location sharing while preserving a level of user privacy. Privacy-preserving location-based services are difficult to achieve. It is difficult to completely de-identify an individual’s location trace. Patterns in an individual’s location, such as home and workplace, can uniquely identify many people.¹³⁰ In 2011, a group of researchers prototyped a system for detecting, in a

privacy-preserving manner, whether two users of a location-based service were near each other. They used location tags, which are signatures associated with a location, to allow users to detect whether they are in proximity to another user without giving away any user's own exact location, detecting another user's exact location, or revealing locations to any other users.¹³¹

6.4.5 Effective Practices

There are numerous location-tracking technologies and opportunities to include them in location-based applications. Additionally, there are a variety of potential uses for such location-based applications. However, when creating and using systems that use location-tracking technology, it is necessary to keep in mind the privacy implications of tracking an individual's location. Location tracking should be included in a system only if it provides a direct benefit, and, wherever possible, should be an opt-in rather than opt-out. Once data is collected, users should be able to easily see what has been stored about them and delete or update any past location data.

Collected location data should be considered privacy-sensitive. Users should be informed, through a privacy policy or other means, of how their location information will be used. If it is going to be used in an unexpected manner, it is effective practice to ensure that users know about this ahead of time. Additionally, before making location data more publicly available, it is effective practice to carefully consider how it might be reused or combined with other datasets. Combining location data with other sources can provide a rich dataset, as many GIS systems show; however, as the *Foursquare: Girls Around Me* application demonstrated, it can also be privacy invasive.

When using location-based applications to track others, such as in a workplace setting, it is effective practice to limit such tracking to instances where there is a clear need and to inform employees about the tracking whenever possible. Additionally, tracking should take place only while the employee is working. If tracking is done through a mobile phone that an employee also carries during nonwork hours, tracking should be limited to the workday. Once tracking data is collected, it should be used only for necessary purposes and access should be minimized.

6.5 Audio and Video Surveillance

In this section, we consider the role of audio and video devices in enabling surveillance. In recent years, audio and video devices have been widely deployed. Consumer smartphones typically contain both a microphone and a camera. Cameras are being deployed in urban environments and in private environments. Drones are being used to capture images over wider areas and to relocate video surveillance dynamically. Household voice assistants, such as Amazon Echo and Google Home, are being rapidly deployed in homes. The combined effect of these trends is a large-scale network for audio and video surveillance.

6.5.1 Hidden Cameras and Microphones

Hidden cameras and microphones can provide video and audio surveillance without a person's awareness. Such devices can be purpose-built for surveillance, or smartphones, laptops, or other consumer electronic devices can be repurposed through malware to serve as hidden cameras or microphones. Form factors also vary. For example, some hidden cameras and microphones can be very small or disguised as other objects, as is the case with "nanny cams." They can either record information wirelessly or transmit data back to the person performing surveillance.

6.5.1.1 Smartphones as Hidden Cameras and Microphones

An individual's smartphone can be transformed into a hidden camera and/or microphone. Smartphones contain microphones and cameras that can be remotely activated, as well as a connection to the internet that allows for the remote activation and transmission of the surveillance data. This use of a remotely activated smartphone microphone is called a "roving bug."

Under the federal Wiretap Act, it was found legal for the Federal Bureau of Investigation (FBI) to use remotely activated cell phone-based audio surveillance in the case of *United States v. Jon Tomero*.¹³² In the example that led to this case, the FBI used roving bugs on two mob bosses' cell phones to provide surveillance on conversations that occurred near the phones.¹³³

Through malware on the phones, remote attackers can also install roving bugs. Smartphones have little anti-malware protection, and smartphone malware is a growing attack vector.¹³⁴ Through smartphone malware, an attacker can gain control of the microphone and camera and capture surveillance on an individual.¹³⁵

Intimate partner abusers are installing apps on their partners' smartphones that enable them to spy on the victims and transmit audio, video and location data as well as text messages and call logs to the abuser.¹³⁶

6.5.1.2 Monitoring through Laptop and Desktop Computers

Laptop and desktop computers also allow for audio and video surveillance. Like smartphones, computers typically have microphones and cameras with network connections. This makes them vulnerable to eavesdropping.

As with smartphones, surveillance can occur after a user inadvertently installs malware on their computer, allowing an attacker to take control of the camera and/or microphone. Farley and Wang describe an example of how malware can be uploaded onto a computer, take control of a user's microphone for audio surveillance and simultaneously hide its own existence.¹³⁷ These types of malware, often known as Remote Access Trojans (RATs), are controlled by a complex web of operators, as shown in a 2017 measurement study.¹³⁸

Surveillance through computer cameras or microphones can also occur when the computer is owned by one entity and used by another, such as when computers are distributed by an employer or school. However, the use of hidden surveillance has legal implications that are still becoming apparent as privacy issues emerge.

A recent case illustrates this legal issue. In 2010, it was discovered that a Pennsylvania school district was using the webcam feature on district-owned laptops to remotely take pictures while the laptops were in student homes. This remote monitoring became apparent after pictures taken at a student's home were used to confront the student about potentially inappropriate behavior in their home. While the district claimed that the purpose of this feature was to track lost laptops, they had not informed the parents or students that they were able to remotely perform video monitoring using the laptops, despite using the feature 42 times over a 14-month period.¹³⁹ The parents of the student whose surveillance photo initiated the case sued the school district for violation of privacy, leading to a settlement of over \$600,000.¹⁴⁰ There were additional federal and state investigations of whether the district had violated federal wiretap or other privacy laws.¹⁴¹

6.5.1.3 Smart Televisions and Their Use in Audio Surveillance

In recent years, televisions have begun to support richer interactions by connecting to the internet, as well as by sometimes including microphones for

voice control. While these new features can improve the user experience and enable seamless access to a wider array of content, they unfortunately can also enable surveillance.

For most smart televisions to recognize voice commands from users, they transmit the recorded audio to a remote computer server to handle the computationally intensive speech recognition tasks that interpret the spoken command. For example, Samsung SmartTVs transmit these voice commands to a third party for processing, as well as for research into improvements of the speech recognition algorithms. As a result, these smart televisions are continually recording even the incidental conversations that take place in range of their microphones, leading to a number of privacy issues.¹⁴²

As with smartphones and computers, malware can illicitly repurpose these microphones into surveillance devices for others. For example, in 2017 WikiLeaks revealed a CIA program dubbed “Weeping Angel” that deployed malware to transmit the audio from microphones on Samsung smart televisions to the CIA.¹⁴³ Notably, this malware kept the microphone enabled even when the television appeared to be turned off.

The collection of audio data from microphones is not the only privacy concern for these devices. Many smart televisions employ automated content recognition (ACR) to determine what the user is watching. Consumers may not be aware that their detailed viewing habits are being transmitted outside their homes, potentially to entities ranging from the device manufacturer to advertisers.¹⁴⁴

6.5.1.4 Drones and Their Use in Video Surveillance

Unmanned aerial vehicles (UAVs), commonly called drones, are aircrafts without human pilots onboard. While long used for military applications, low-cost consumer drones became popular in the 2010s for recreation, aerial photography and surveillance. Drones may be operated remotely by a human, or they may be operated autonomously by software.

Drones frequently include video cameras, but they may also include infrared cameras, radar or other sensors.¹⁴⁵ In the United States, drones are restricted by Federal Aviation Administration (FAA) regulations from flying near airports and other areas where they may cause hazards. There have been a handful of high-profile incidents of consumers shooting down other consumers’ drones, including a 2015 case in which a Kentucky man shot down a neighbor’s drone in his backyard when he deemed it an invasion of his privacy.¹⁴⁶ Broadly, the practice of

consumers shooting down drones has been deemed a federal crime.¹⁴⁷ It is not just consumers, but also other nations, that shoot down surveillance drones. In a highly publicized June 2019 incident, forces in Iran shot down a U.S. military surveillance drone.¹⁴⁸

In addition to militaries, a number of law enforcement agencies have also begun using drones for surveillance.¹⁴⁹ In the last few years, companies have begun to sell surveillance drones directly to consumers explicitly for home security and surveillance applications, rather than simply recreation or photography.¹⁵⁰

6.5.2 CCTV and Facial Recognition

Closed-circuit television (CCTV) is a type of video-monitoring system that is commonly used by governments for preventing crime or terrorism, but it can also be used in private environments for purposes such as preventing shoplifting, providing security for a private facility, or tracking employees in a workplace.¹⁵¹ While privacy debates over CCTV cameras have occurred for decades, it has become an especially important topic in 2019 as a result of two intertwined technological advances. Recent years have seen the rapid deployment of ubiquitous cameras in urban settings, and vast improvements in the accuracy of facial recognition software enable these images to be processed and acted upon for tracking on a large scale.

In CCTV systems, cameras are set up allowing images to be transferred to a remote destination where footage is available to law enforcement or security personnel for either real-time or post-hoc monitoring. CCTV can encompass a variety of different types of cameras of different levels of sophistication (including both mobile and permanently mounted cameras) and can capture images of varying quality.¹⁵²

Examples of systems that use CCTV include traffic enforcement, such as red-light cameras and license plate recognition programs, and terrorism prevention efforts. CCTV analysis systems can also be augmented with additional technology. For example, biometrics and other facial recognition capabilities are used to try to recognize terrorists in a crowd or in an airport. In the United States, general use of CCTV in public spaces by the government is legal, as long there is not a “reasonable expectation of privacy.”¹⁵³ CCTV can also be used for workplace surveillance, such as for employers to observe employees within the workplace. In this environment, use of video surveillance is legal as long as it is limited to public areas.¹⁵⁴

One of the newest frontiers in large-scale tracking involves facial recognition. Rather than tracking an electronic device (e.g., a smartphone) that an individual is carrying around, tracking that relies on facial recognition necessitates blanketing with cameras the area where an individual is likely to travel. A rapidly increasing density of cameras, combined with recent advances in the machine-learning techniques underpinning facial recognition technologies, have enabled large-scale tracking based solely on images from public cameras, giving rise to fierce debates about privacy.¹⁵⁵

While London has long been known as one of the cities with the highest density of CCTV cameras, China has rapidly deployed cameras in the late 2010s and incorporated these camera feeds into facial recognition software.¹⁵⁶ Facial recognition software is being used in major Chinese cities to identify jaywalkers, delivering fines via text message.¹⁵⁷ It is also being used to track the Uyghur ethnic minority in China.¹⁵⁸ Notably, this software has been designed to algorithmically assign ethnicity labels for the individuals observed in these camera feeds.¹⁵⁹ The potential use of facial recognition technologies for large-scale tracking and applications like these has led the City of San Francisco to ban police and municipal agencies from using these technologies.¹⁶⁰

6.5.3 Tracking voice over IP Conversations

In recent years, voice over IP (VoIP) technologies like Skype have become a popular way to make voice or video calls. These VoIP technologies, however, can also be tracked in both unintentional and intentional ways. Like computer systems, VoIP systems can suffer from vulnerabilities that unintentionally enable eavesdropping.¹⁶¹ Researchers have demonstrated that simply having access to the encrypted version of a message may be sufficient for using linguistic techniques to reconstruct the call if certain types of encryption are used.¹⁶²

A number of intentional mechanisms can also be used to surveil VoIP communications.

In the United States, the FCC has interpreted the 1994 Communications Assistance for Law Enforcement Act (CALEA), which requires companies to be able to intercept communications in response to authorized legal requests, to include VoIP services. Although Skype had made “affirmative promises to users about their inability to perform wiretaps,” Skype was among the services revealed to be accessible as part of the PRISM program in the United States.¹⁶³

Even if the body of the communication is encrypted by the sender, the metadata about a communication can often leak a large amount of the communication. For example, a 2016 study empirically reidentified telephone metadata and used it to infer locations and relationships between individuals.¹⁶⁴

6.5.4 Speech Recognition

In addition to microphones becoming ubiquitous in smartphones and laptops, stand-alone smart speakers with voice assistants have rapidly become popular. Common examples include the Google Home and Amazon Echo (commonly referred to by the name of its voice assistant, Alexa). As of 2018, over one-quarter of U.S. households owned one of these smart speakers.¹⁶⁵ In other words, many households now have a microphone in their living rooms or other personal spaces in the homes. Furthermore, smart assistants such as Apple's Siri, Microsoft's Cortana, and Samsung's Bixby play a similar role on smartphones.

As previously mentioned in the context of voice recognition for smart televisions, the computationally intensive processing involved in turning speech data to text is often performed on a remote computer server outside the consumer's home, not on the standalone smart speaker or smartphone. As a result, a consumer's conversations may inadvertently, or maliciously, be recorded and transmitted. A 2019 study highlighted many privacy concerns raised by users of voice assistants in the home, even though these users perceived voice assistants to also provide important benefits.¹⁶⁶

A number of incidents have brought the privacy of smart speaker voice recordings to newspaper headlines. For instance, in a 2018 incident, an Amazon Echo reportedly recorded and transmitted a conversation to one of a user's contacts unintentionally.¹⁶⁷ In November 2018, the right of access to the recordings made by an Amazon Echo at the scene of a murder were being litigated in a New Hampshire court.¹⁶⁸ Finally, in April 2019, it was revealed that Amazon employs a team of people to listen to recordings made by Amazon Echo's voice assistant Alexa to improve its speech recognition algorithm.¹⁶⁹ Users expressed privacy concerns.

6.5.5 Protecting against Audio and Video Surveillance

User protection against audio and video surveillance on computers and smartphones can take place on several levels. First, it is possible to prevent potential surveillance by avoiding the malware that would allow attackers to take

over a camera or microphone by using antivirus software. Additionally, malware is often delivered through untrustworthy downloaded software, especially on smartphones. Avoiding such software can help lower the risk of an attacker implementing audio or video surveillance.

It is also possible to try to avoid audio and video surveillance by blocking the hardware and software features necessary for surveillance to occur. For example, on some computers, it is possible to physically turn off or block a webcam when it is not being used. From the user's perspective, two primary types of action can combat the misuse of their computers for video surveillance. First, many (but not all) computers include indicator lights to reveal when a camera is active. While the most sophisticated malware can sometimes evade triggering these indicator lights, and while users may not notice or understand these indicators, they are an important first step. A low-tech, yet more effective, solution is to cover the camera when not in use.¹⁷⁰ Stickers, plastic covers and household tape can all serve this purpose.¹⁷¹ Unfortunately, the solutions for covering or otherwise disabling microphones are nowhere near as simple.¹⁷² While researchers have prototyped wearable microphone jammers, effective and inexpensive microphone jammers are not yet available commercially.¹⁷³ Tracking incoming and outgoing network connections and potentially using a firewall to block potentially suspicious activity can also help prevent surveillance, although this process likely requires technical expertise to understand the purposes of different types of traffic transmitted on home networks.¹⁷⁴

6.5.6 Effective Practices

When performing audio or video surveillance, especially within a work environment, it is effective practice to ensure that the minimal amount of surveillance is being performed for the necessary objective and that it is conducted in a legal manner.

Video and audio surveillance can be very privacy invasive and should not be performed unless a necessary objective (e.g., security, efficiency) outweighs the privacy drawbacks. Wherever possible, those under surveillance should be informed about the system to lower the impact of the privacy violation. Additionally, a group should check local privacy laws before putting surveillance in place. In the United States, a first step for employers is making sure that the surveillance is not taking place in an environment in which employees have an expectation of privacy (e.g., inside a bathroom).

As evidenced by the privacy debate following the 2019 revelation that Amazon employees manually listen to Alexa conversations to improve the speech recognition algorithms, it is important not to surprise users. Empirical user research is invaluable in eliciting and documenting consumers' expectations, preferences and mental models about how the audio and video data collected by a device is used.

Once audio and video surveillance data has been gathered, it is effective practice to take proper measures to maintain data security and limit exposure of the content. Whenever possible, use automated systems to analyze the data or employ a separation of duties, where the analyst examines the audio or video and only reports the finding to others; this avoids exposing the raw audio and video to unauthorized repurposing or snooping. In these situations, it is important to securely retain the raw audio or video in the event the finding is ever challenged. To ensure that the data is not misused, one should track access to the data and limit it to necessary personnel. A clear policy should be put in place for who has access to the data and under what circumstances, and for how long the data will be retained. Data should be purged when no longer needed for the intended purpose.

6.6 Sensor-Based Surveillance

With the rise over the last decade of smartphones, wearable devices and the IoT, sensing technologies are being widely deployed. This sort of ubiquitous sensing can enable tracking and surveillance of individual users. It can also allow private information embedded in the aggregated data of many users to be leaked, enabling societal-scale tracking in new domains. In this section, we introduce the new technologies that frequently embed sensors, identify the key risks to tracking and surveillance and highlight how some of these risks can be partially minimized.

6.6.1 Ubiquitous Computing

The broad concept of *ubiquitous computing* (also termed *ubicom*) refers to the transition of computing from purpose-built, independent computing devices to computing that occurs at all times and in all places. As computing occurs ubiquitously, absent the visible boundaries present when interacting with a device like a traditional laptop computer, the types and amount of data that can be collected at scale raise important concerns about privacy, tracking and surveillance. Early research on ubiquitous computing highlighted important requirements for end-user acceptance of this paradigm from a privacy perspective:

The system should have obvious value, the retention of data should be limited and users should be provided both feedback and control.¹⁷⁵ While many of the domains discussed in the rest of this section arguably also fall under the umbrella of ubiquitous computing, in this subsection, we focus on two particular types of ubiquitous computing: smart cities and augmented reality.

At the time of press, the concept of smart cities had begun to attract substantial attention. However, what precisely the term refers to is somewhat ill-defined. Sometimes, the concept of a smart city refers to a city that aggregates and makes available existing data from its traditional functions in an open format and to all citizens. For example, the U.S. city of Chicago has an open data portal that provides information on everything from streets that have been plowed to restaurant inspections to vaccination centers.¹⁷⁶ While these open data portals can have important advantages for government transparency and sometimes the efficiency of government, they can often have important implications for privacy. For instance, even sparse, pseudonymous datasets can often be deanonymized if combined with other datasets.¹⁷⁷

The concept of a smart city is also used to describe cities that introduce large numbers of new sensors and actuators, adding computerized sensing and control to systems that did not previously have such capabilities. For example, smart cities might deploy tracking devices on government-owned vehicles and automated license plate readers to track nongovernment vehicles similarly. They might deploy detailed analytics for utility systems, as well as cameras for a multitude of purposes. They also might deploy street corner sensors to detect environmental factors, gunshots or the movement of pedestrians.¹⁷⁸ In the remainder of this subsection, we mostly discuss the tracking implications of this type of smart city.

The large-scale collection of data in smart cities can enable substantial amounts of surveillance. For instance, the ability for a government to monitor the identity and movements of the populace on a large scale can also have chilling effects on the exercise of rights to protest and dissent.¹⁷⁹ Furthermore, many smart cities have used their large sensing networks for the explicit purpose of policing, which critics highlight can create urban surveillance panopticons despite having debatable impact on public safety.¹⁸⁰ In all of these cases, it's very challenging to figure out how to notify everyone in the city about what data is being collected and to obtain meaningful consent from them.¹⁸¹ It is also challenging for users to determine what information can be inferred from data streams. For example, research has shown that smart meters can infer what a household is watching on

TV from granular information about power consumption, which is impacted by the colors on screen.¹⁸² These kinds of information leakages can be vexingly difficult for users to predict.

Current developments in the Canadian city of Toronto provide an important privacy case study. At the time of press, Sidewalk Labs, which is owned by Alphabet (Google's parent company), is working with the City of Toronto to develop a smart city in Toronto's Quayside. The core technological aspects of the project focus on providing a network of sensors focused on noise, energy usage and transportation, in addition to deploying a large number of autonomous vehicles.¹⁸³ The idea that a combination of companies and government officials would be collecting large amounts of data from the public in open spaces in the city led critics to use the term *surveillance capitalism* to describe the project.¹⁸⁴ The project's decision to allow third parties access to identifiable information from the smart city ignited particular controversy, leading one of the leading privacy scientists on the project to quit in 2018.¹⁸⁵

While smart cities instantiate ubiquitous computing principles through large-scale data and sensing, the idea of augmented reality (AR) brings data to an individual user. In current technologies, users experience AR through special glasses they wear, projections they see or other interfaces that overlay computer-generated content with the real world in front of them. Because AR typically requires rich sensor data to accurately and properly overlay the virtual world on the physical, large amounts of data must be collected, inherently creating privacy tensions.¹⁸⁶ Furthermore, because multiple applications will likely need to interact in AR, and because user input will be provided in a variety of forms, it may become difficult to control data flows in AR. In a 2018 study that used Microsoft HoloLens headsets to make the privacy concerns of AR more tangible, participants surfaced a number of additional concerns, including the use of virtual objects for privacy-related obstruction and the ways AR applications could invade the privacy of their physical world simply through observation.¹⁸⁷

6.6.2 Mobile Device Sensors

Smartphones and similar mobile devices are a nearly constant companion for many individuals in the modern world. To enable their functionality, they also contain myriad sensors. This combination of constant proximity to the user and rich sensing capabilities has led scholars to note that "smartphones are effectively surveillance devices."¹⁸⁸ As discussed elsewhere in this chapter, microphones,

cameras and location-awareness devices all have important implications for surveillance. A typical smartphone has all of these sensors, and more.¹⁸⁹

Accelerometers are one type of sensor frequently found on mobile devices, yet infrequently encountered on other computing devices. Accelerometers enable phones to know when to rotate the screen, measuring the speed of the device when it is in motion as the user walks or bikes, and permit physical interaction with smartphone games. However, the data from an accelerometer can also be used for surveillance. For example, researchers have shown how an accelerometer alone, even without persistent location awareness, can determine the distance traveled and therefore leak information about the user's location relative to a previous position.¹⁹⁰ It can also leak information about the passwords a user types into their phone.¹⁹¹

As smartphones are an integral part of many users' daily lives, users need to authenticate to unlock their phone frequently throughout the day.¹⁹² Because PINs, passwords and other methods can be cumbersome for frequent unlocking, biometric authentication through an onboard fingerprint sensor has become common in part because of its major usability advantages.¹⁹³ While this fingerprint data is typically kept on the device itself and not sent to the manufacturer in current implementations, one can imagine how the widespread collection of biometric data like fingerprints would arouse privacy concerns.¹⁹⁴ Notably, fingerprints are a unique identifier. They are also impossible to replace.

Mobile device sensors, when used creatively, can enable important societal applications. For instance, the mobile health movement has parlayed smartphone sensors into everything from fitness self-tracking devices (discussed elsewhere in this chapter) to healthcare devices. For example, researchers have shown how to detect blood hemoglobin using smartphone cameras.¹⁹⁵ While these sensors can be used for such positive applications, they can unfortunately also be misused in the wrong hands.

6.6.3 IoT

The IoT is the concept of imbuing everyday, physical objects with internet connectivity. Similar to the concept of smart cities, the precise meaning of IoT can differ substantially in different contexts and for different audiences. Other parts of this chapter cover many applications often discussed as part of IoT: wearable health devices, home automation, smart transportation, voice assistants and aspects of smart cities. In this subsection, however, we focus on three tracking-

related IoT applications that are not discussed elsewhere in this chapter: internet-connected toys, internet-connected security systems, and the use of IoT for eldercare. Across all of these IoT devices, providing privacy notices and enabling choices about privacy become difficult because of the frequent lack of traditional user interfaces.¹⁹⁶

In the last few years, manufacturers have begun to connect children's toys to the internet to enable them to perform speech recognition and converse with the children as well as to access extra information. Like speech recognition for smart speakers and voice assistants, this design presents privacy issues because the recordings are sent to a server. Unique to toys, however, the primary users are even less likely to be aware of the consequences of this tracking or understand what is happening because they are so young. For example, a 2017 study of IoT toys found that the children who participated in their study were often unaware of who might have access to the recordings made by these toys, and even that their toy functionally remembered through recordings what they told it.¹⁹⁷ Even worse, some of the popular IoT toys have shipped with major security vulnerabilities, enabling hackers to turn the microphone on at all times and fully turn these IoT toys into surveillance devices.¹⁹⁸

To improve household safety, internet-connected variants of home-security-related devices have been introduced in recent years. For example, internet-connected locks can log when they are unlocked, in addition to providing the homeowner the ability to unlock the door remotely to let people into their house. Internet-connected security cameras can give a homeowner peace of mind that their home is safe when they are away. However, a 2014 study showed how the same characteristics that enables constant monitoring of the home can also functionally place other members of the household under surveillance, creating tensions between parents and teenagers.¹⁹⁹

Related issues appear for using IoT technology with the elderly. A number of efforts have aimed to use technology to help the elderly live independently in their own homes longer than might be possible otherwise. These efforts often use technology to help the senior citizen remember things they might forget, see things they might have trouble seeing and stay connected with their family and friends. However, these efforts, even when well-intentioned, can also cause the senior citizen to feel a loss of control and agency, and sometimes to perceive that their caregivers and family are surveilling them.²⁰⁰ These issues can be particularly acute with the use of vision-based technologies to help elders see.²⁰¹

6.6.4 Home Automation

Beyond the home-security IoT applications discussed above, a number of other household appliances and control systems have been connected to the internet toward the vision of a smart home. For instance, IoT thermostats like the Nest Thermostat can adjust to the patterns they learn about the home's inhabitants and permit remote changes in temperature. Similarly, IoT lighting can be configured to react to outside events. Internet-connected motion sensors can be configured to trigger different behaviors in the home. Unfortunately, connecting these household devices to the internet has important ramifications for tracking and surveillance.

Historically, the home has been considered a private space, yet the actions of a home can be tracked if data is collected inside the home and then shared outside the home. While home-automation systems could conceptually be designed so that data never leaves the home, many current home-automation systems such as Samsung SmartThings and Apple HomeKit funnel sensor data and control through cloud interfaces. Notably, media attention in 2019 focuses on how Amazon and Google aimed to both increase their own devices' data collection in the home and to urge other companies to send them their data from within homes as well.²⁰² These types of decisions enable companies to track and surveil what happens in consumers' homes, in addition to the insight they already have into users' mobility patterns and communications through their smartphones. Unsurprisingly, a 2019 survey found that privacy was consumers' top concern related to smart homes.²⁰³

A 2018 study of owners of smart homes revealed that they make a cost-benefit tradeoff when deploying smart home devices, yet the researchers found that these smart home owners tend to be unaware of how inference algorithms can operate on the data collected.²⁰⁴ Similar to the way home security systems can enable parents to track teenagers, the technical administrators of home automation systems exert control over the other members of their household (passive users of the system).²⁰⁵ They can often track what other members of their household are doing, inadvertently or intentionally.

On a technical level, privacy in homes can be difficult to reason about, which makes tracking especially pernicious. The "smartness" of home automation depends on data being able to flow across devices, yet chains of these information flows can sometimes leak private information outside the home.²⁰⁶ Furthermore,

consumers' preferences about access to data and control within their home rely heavily on context, which few current home automation systems support.²⁰⁷

6.6.5 Vehicle Sensors

Modern automobiles are incredibly complex. In addition to the many mechanical parts that were typical decades ago, recent automobiles tether together a network of sensors and computers.²⁰⁸ While potentially a boon for adding new features and improving the connectedness of vehicles, these sensors and computers also bring with them security and privacy risks. Sensors in modern vehicles measure driving speed, braking, tire pressure, proximity to other vehicles and many detailed aspects of how the driver is interacting with the vehicle. What happens in a vehicle, and where it travels in the first place, can be highly sensitive. For example, a major decision in the Jones case in the U. S. Supreme Court hinged on whether attaching a GPS device to a suspect's car to track his location was a search and therefore required a warrant.²⁰⁹

Cars collecting large amounts of data raises questions about which third parties can access that data, in which circumstances and with what level of informed consent from the driver and passengers.²¹⁰ Whether information from the car might be made available to law enforcement, auto insurance companies, mapmakers, advertisers or others is an important open question. Furthermore, the large amount of data stored in vehicles makes it easy for users to overlook some aspects. For example, newspaper articles in 2018 recounted how borrowers frequently forgot to erase (or did not know they had to erase) information from rental cars' Bluetooth entertainment and communication systems, leaking this information to subsequent users of those cars.²¹¹

Where data is stored is often a critical aspect in privacy, and cars have a number of locations where data might be stored. All new cars sold after 2013, as well as many sold before, must contain a "black box," similar to that in airplanes, which records a number of sensor readings and characteristics.²¹² These black boxes are often examined after accidents and collisions, though one might reasonably be concerned that this data could be used for surveillance.²¹³

While black-box data is typically kept in the car itself, modern cars are becoming increasingly connected to the outside world through networks. From the popular OnStar systems that enable remote control and richer media to the vast array of connections required for operating and updating self-driving cars of the future, there are many opportunities for data to be transmitted from a car over the

network.²¹⁴ Oftentimes, this data transmission is intentional. For example, vehicular networks (sometimes called vehicular social networks) are based on the premise that communications between vehicles can enable more efficient usage of roadways as well richer communications between vehicles to increase safety and security.²¹⁵

Data about vehicles does not necessarily need to come from the car itself, however. Transportation-mapping applications like Google maps typically show real-time information about traffic. This information is generally collected from the phones of other users of the mapping application. In particular, users' apps transmit information about their routes and speed to the mapping company's servers. This data is processed, traffic conditions are inferred, and this real-time information is transmitted to others.

Highly connected cars also present risks for computer security. As cars began to become more complex, computer security researchers began to deconstruct their attack surface and search for potential vulnerabilities. Early researchers noted, for instance, that readings from tire pressure sensors were not properly authenticated, allowing attackers to spoof the sensor readings.²¹⁶ Subsequently, researchers systematically analyzed vehicles' centralized control system, the Electronic Control Unit (ECU).²¹⁷ Those researchers showed that controlling the ECU could lead to attacks that disable brakes, control acceleration and perform other nefarious acts. Over the last few years, car hacking has become even more sophisticated. Proof-of-concept exploits have taken over cars remotely, showing that attacks against cars are a threat on a large scale.²¹⁸

6.6.6 Wearable Devices

In a major transition in recent years, many wearable devices have embedded substantial computing capabilities. Individuals often use these wearable devices for tracking their fitness or other athletic activities, or for more traditional healthcare monitoring.

Popular wearable fitness monitors, such as Fitbit devices, enable a user to monitor how many steps they take each day, in addition to tracking other activities. These devices, however, present a number of risks for tracking and surveillance. While they collect fitness data, this data is not typically characterized as health data and therefore is not afforded the higher privacy protections of health data.²¹⁹ Furthermore, a user's data is typically sent to the manufacturer's

computer server through a connected application on a companion device like a smartphone, creating a centralized repository of fitness data.

Fitness enthusiasts also frequently track their own running or biking routes, which enables them to keep track of their fitness over time, track personal records and share routes with others. Strava is one such application popular with joggers and bikers. However, the data collected and sometimes shared socially embeds potentially private information. For instance, in 2018, it was revealed that heat maps of popular fitness routes released by Strava (collected from its users) functionally outlined U.S. military bases in foreign countries.²²⁰ In essence, data about where an individual went for a run, in concert with similar information from many other users, can reveal important, private secrets.

While many of the devices and services just mentioned are focused on recreational fitness, other applications seek to bring the types of healthcare monitoring typical of medical professionals to wearable devices. For instance, implantable medical devices, such as pacemakers, can be easier to maintain and monitor if they are wirelessly accessible or even internet connected. However, further increasing the connectivity of these devices introduces numerous risks to privacy and security. For instance, data meant to be transmitted wirelessly to a doctor from a pacemaker could be sent elsewhere, not to mention the security risks of an attacker being able to control a victim's pacemaker. Even just the usage of certain classes of medical devices might be sensitive, and these devices' unique serial numbers can ease tracking of the individual if they broadcast a unique identifier.²²¹

While the ability of connected healthcare to enable medical providers to remotely monitor their patients in real time brings both treatment advantages and privacy disadvantages, the long-term storage of this data raises many important privacy questions. For instance, for how long should data be kept, and who should be able to access it? Beyond the potential for wearable healthcare devices to enable tracking and surveillance, electronic health records (EHR) that bring together all of a patient's medical records in a standardized form can leak large amounts of private information.²²²

6.7 Behavioral Modeling

With the increasing ease of data collection on devices ranging from smartphones to IoT devices, large-scale data is often available. This data can be used to model

human behavior, albeit at a privacy cost. In this short section, we briefly outline the role of data in behavioral modeling related to life stages and human behavior, as well as mobility and geography.

6.7.1 Learning Life Stages and Demographics

The concept of targeted advertising makes inferences about users based on their online activities. Frequently, demographics and life stages are among the characteristics inferred about the user. However, beyond inferring demographics for advertising and personalization, efforts have aimed to learn aspects of society from this data. For example, researchers have used smartphones to collect data on how quickly people speak in conversations, the structure of people's days and where people spend their time.²²³ Other work has modeled the dynamics of groups, shedding light into the interactions between people with different functions in the group and at different life stages.²²⁴

6.7.2 Mobile and Social Patterns

The patterns revealed by data from smartphones and other sources can provide large amounts of insight into mobility patterns and social patterns. In recent years, a number of efforts have sought to use data collected from these sources to infer aspects of urban geography, socioeconomic factors and the ways people move throughout their environment.

For example, in a 2016 study, researchers used cell phone records to construct urban mobility patterns at a far greater granularity, and at far less expense, than could be collected through typical travel surveys.²²⁵ Other researchers have also used data from mobile phones to predict socioeconomic indicators like poverty and illiteracy.²²⁶

While those projects used cell phone records for prediction, other efforts have used data from location-based social media applications. The Livehoods Project used location check-in data from the phones of users participating in a location-based social network to map mobility patterns in urban areas.²²⁷ From their data, they concluded that the boundaries of neighborhoods experienced by residents of these cities sometimes differed from the officially established boundaries of those neighborhoods. In a similar vein, researchers used similar types of location check-in data to identify users' mobility patterns and map their purpose-driven activities.²²⁸

6.8 Summary

In this chapter, we presented an overview of tracking and surveillance techniques and countermeasures. We began by explaining how the packets that encapsulate communication over the internet can be surveilled. We then demonstrated how surveillance of low-level communications over the internet can be made more difficult by encrypting web requests using the HTTPS protocol, by sending traffic through an encrypted VPN tunnel or by using an anonymizing network to obfuscate the identity of the sender of a message from the message itself.

We then discussed numerous technologies that can be used to collect information about the websites that a particular user has visited, often for the purpose of better targeting advertisements to that person. While we explained in depth how HTTP cookies enable this sort of tracking, we also introduced technologies that can be used either as alternatives to HTTP cookies or in conjunction with HTTP cookies in order to respawn deleted cookies. These technologies include LSOs, DOM Storage and more subtle techniques, such as browser history stealing and browser fingerprinting. We then explained a number of ways users can block certain types of web tracking. For instance, we introduced the controls built into web browsers and how that ecosystem has evolved in recent years, illuminated the debate over the ultimately unsuccessful Do Not Track mechanism and delved into third-party browser extensions for blocking web tracking. Alongside these methods, we explained their shortcomings, as well as effective practices in the design of privacy tools. We also briefly described ways to prevent tracking of web searches and email messages.

Next, we provided an overview of location-tracking technologies, describing how the location of a phone can be triangulated based on the signal from cell towers and how devices can use GPS to determine their location. We also explained the complex interaction between utility and privacy as users share information about their location on social networking sites, in addition to proposals for limiting the privacy perils of these disclosures.

We then discussed methods for audio and video surveillance. In addition to more canonical examples of surveillance, such as placing hidden cameras and microphones in public or private locations, we demonstrated how smartphones, personal computers, and smart televisions can be co-opted by malware to surveil users. We also highlighted current privacy debates over the intentional use of drones for video surveillance, as well as how audio data from smart speakers and

other voice assistants can enable surveillance, intentionally or otherwise. In addition, we showed how technological advances in facial recognition algorithms have combined with the widespread deployment of cameras in public to enable widespread tracking based on faces. This development has spurred important societal debates about the role of facial recognition and other machine-learning techniques.

Subsequently, we explained how the rise of the IoT and rich sensing has brought privacy debates to the home, wearable devices, children's toys and vehicles. Finally, we concluded with a brief overview of behavioral modeling based on sensor data and how the era of big data and ubiquitous sensing has outlined the confines of the next decade's privacy debates.

Endnotes

- 1 Charlie Savage, Edward Wyatt and Peter Baker, "U.S. Confirms That It Gathers Online Data Overseas," *The New York Times*, June 6, 2013, <https://www.nytimes.com/2013/06/07/us/nsa-verizon-calls.html>.
- 2 Barton Gellman and Laura Poitras, "U.S., British Intelligence Mining Data from Nine U.S. Internet Companies in Broad Secret Program," *The Washington Post*, June 6, 2013, www.washingtonpost.com/investigations/us-intelligence-mining-data-from-nine-us-internet-companies-in-broad-secret-program/2013/06/06/3a0c0da8-cebf-11e2-8845-d970ccb04497_story.html.
- 3 Daniel J. Solove, "'I've Got Nothing to Hide' and Other Misunderstandings of Privacy," *San Diego Law Review* 44 (2007).
- 4 Kevin Granville, "Facebook and Cambridge Analytica: What You Need to Know as Fallout Widens," *The New York Times*, March 19, 2018, www.nytimes.com/2018/03/19/technology/facebook-cambridge-analytica-explained.html.
- 5 Charles Duhigg, "How Companies Learn Your Secrets," *The New York Times*, February 15, 2012, www.nytimes.com/2012/02/19/magazine/shopping-habits.html.
- 6 Adrienne Porter Felt, Richard Barnes, April King, Chris Palmer, Chris Bentzel and Parisa Tabriz, "Measuring HTTPS Adoption on the Web," *Proceedings of the 26th USENIX Security Symposium*, (2017).
- 7 Troy Hunt, "HTTPS adoption has reached the tipping point," blog post, January 30, 2017, www.troyhunt.com/https-adoption-has-reached-the-tipping-point.
- 8 Peter Whoriskey, "Every Click You Make," *The Washington Post*, April 3, 2008, www.washingtonpost.com/wp-dyn/content/article/2008/04/03/AR2008040304052.html.
- 9 Robert Sheldon, "The Situation Is Under Control: Cyberspace Situation Awareness and the Implications of China's Internet Censorship," *Strategic Insights* 10, no. 11, (2011).
- 10 Federal Communications Commission, "Commission Orders Comcast to End Discriminatory Network Management Practices," August 1, 2008, http://hraunfoss.fcc.gov/edocs_public/attachmatch/DOC-284286A1.pdf.
- 11 WireShark, www.wireshark.org (accessed November 2019).
- 12 Kismet, www.kismetwireless.net (accessed November 2019); BauerHome Software, <https://download.cnet.com/developer/baurhome-software> (accessed November 2019).
- 13 Codebutler, <http://codebutler.com/firesheep> (accessed November 2019).
- 14 David Streitfeld, "Google Concedes That Drive-By Prying Violated Privacy," *The New York Times*, March 12, 2013, www.nytimes.com/2013/03/13/technology/google-pays-fine-over-street-view-privacy-breach.html.
- 15 Nikita Borisov, Ian Goldberg and David Wagner, "Intercepting Mobile Communications: The Insecurity of 802.11," *Proceedings of the 7th Annual International Conference on Mobile Computing and Networking*, (2001).
- 16 CERT, "WiFi Protected Setup (WPS) PIN Brute Force Vulnerability" (Vulnerability Note VU#723755), Vulnerability Notes Database, December 27, 2011, revised May 10, 2012, www.kb.cert.org/vuls/id/723755.
- 17 G. Daryl Nord, Tipton F. McCubbins and Jeretta Horn Nord, "E-Monitoring in the Workplace: Privacy, Legislation, and Surveillance Software," *Communications of the ACM* 49, no. 8, (2006).
- 18 American Management Association, "Over Half of All Employers Combined Fire Workers for Email and Internet Abuse," 2007 Electronic Monitoring & Surveillance Survey, February 28, 2008, <http://press.amanet.org/press-releases/177/2007-electronic-monitoring-surveillance-survey/>.

- 19 Federal Communications Commission, Children's Internet Protection Act, www.fcc.gov/guides/childrens-internet-protection-act.
- 20 John Schwartz, "Schools Get Tool to Track Students' Use of Internet," *The New York Times*, May 21, 2001, www.nytimes.com/2001/05/21/business/schools-get-tool-to-track-students-use-of-internet.html.
- 21 Michael McCardle, "How Spyware Fits into Defense in Depth," SANS Institute: InfoSec Reading Room, (2003).
- 22 Shuo Chen, Rui Wang, XiaoFeng Wang and Kehuan Zhang, "Side-Channel Leaks in Web Applications: A Reality Today, a Challenge Tomorrow," in *Proceedings of the 2010 IEEE Symposium on Security and Privacy*, (2010).
- 23 <https://anonymous-proxy-servers.net/>.
- 24 David M. Goldschlag, Michael G. Reed and Paul F. Syverson, "Hiding Routing Information," *Proceedings of the 1st Workshop on Information Hiding*, Lecture Notes in Computer Science, 1174: 137–150, Cambridge, UK (1996).
- 25 <https://www.torproject.org/index.html.en>.
- 26 Savage et al., "U.S. Confirms That It Gathers Online Data Overseas."
- 27 Gellman and Poitras, "U.S., British Intelligence Mining Data."
- 28 Cloud Security Alliance, Government Access to Information Survey Results, July 2013, https://cloudsecurityalliance.org/research/surveys/#_nsa_prism.
- 29 Michael Barbaro and Tom Zeller, Jr., "A Face Is Exposed for AOL Searcher No. 4417749," *The New York Times*, August 9, 2006, www.nytimes.com/2006/08/09/technology/09aol.html.
- 30 Aleecia McDonald and Lorrie Faith Cranor, "The Cost of Reading Privacy Policies," *I/S: A Journal of Law and Policy for the Information Society* 4, no. 3, (2008).
- 31 Balachander Krishnamurthy and Craig E. Wills, "Privacy Diffusion on the Web: A Longitudinal Perspective," *Proceedings of the 18th International Conference on World Wide Web*, (2009).
- 32 Steven Englehardt and Arvind Narayanan, "Online Tracking: A 1-million-site Measurement and Analysis," in *Proceedings of the 2016 ACM SIGSAC Conference on Computer and Communications Security*, (2016).
- 33 Muhammad Ahmad Bashir, Umar Farooq, Maryam Shahid, Muhammad Fareed Zaffar and Christo Wilson, "Quantity vs. Quality: Evaluating User Interest Profiles Using Ad Preference Managers," in *Proceedings of the Network and Distributed System Security Symposium*, (2019).
- 34 Giridhari Venkatadri, Elena Lucherini, Piotr Sapiezynski, and Alan Mislove, "Investigating Sources of PII Used in Facebook's Targeted Advertising," in *Proceedings on Privacy Enhancing Technologies*, (2019).
- 35 Stuart A. Thompson, "These Ads Think They Know You," *The New York Times*, April 30, 2019, <https://www.nytimes.com/interactive/2019/04/30/opinion/privacy-targeted-advertising.html>.
- 36 Federal Communications Commission, Children's Internet Protection Act, "Consumer Data Privacy in a Networked World: A Framework for Protecting Privacy and Promoting Innovation in the Global Digital Economy," February 2012, <https://obamawhitehouse.archives.gov/sites/default/files/privacy-final.pdf>.
- 37 Angelisa C. Plane, Elissa M. Redmiles, Michelle L. Mazurek and Michael Carl Tschantz, "Exploring User Perceptions of Discrimination in Online Targeted Advertising," *Proceedings of the 26th USENIX Security Symposium*, (2017); Claire Dolin, Ben Weinshel, Shawn Shan, Chang Min Hahn, Euirim Choi, Michelle L. Mazurek and Blase Ur, "Unpacking Perceptions of Data-Driven Inferences Underlying Online Targeting and Personalization," *Proceedings of the 2018 CHI Conference on Human Factors in Computing Systems*, (2018).
- 38 Englehardt, "Online Tracking: A 1-million-site Measurement and Analysis."
- 39 Jennifer Valentino-DeVries, "Facebook Defends Getting Data from Logged-Out Users," *Digits* (blog), *The Wall Street Journal*, September 26, 2011, <http://blogs.wsj.com/digits/2011/09/26/facebook-defends->

- getting-data-from-logged-out-users/.
- 40 Ashkan Soltani et al., “Flash Cookies and Privacy,” Social Science Research Network, August 10, 2009, http://papers.ssrn.com/sol3/papers.cfm?abstract_id=1446862.
- 41 Gunes Acar, Christian Eubank, Steven Englehardt, Marc Juarez, Arvind Narayanan and Claudia Diaz, “The Web Never Forgets: Persistent Tracking Mechanisms in the Wild,” *Proceedings of the 2014 ACM SIGSAC Conference on Computer and Communications Security*, (2014).
- 42 Thomas Frank, “Session Variables Without Cookies,” January 20, 2008, www.thomasfrank.se/sessionvars.html.
- 43 Mozilla Developer Network, DOM Storage Guide, <https://developer.mozilla.org/en-US/docs/DOM/Storage>; accessed August 15, 2012.
- 44 W3C, Web SQL Database, W3C Working Group Note 18, November 2010, www.w3.org/TR/webdatabase/.
- 45 Aleecia McDonald and Lorrie Faith Cranor, “A Survey of the Use of Adobe Flash Local Shared Objects to Respawn HTTP Cookies,” CMU-CyLab-11-001 Technical Report, January 31, 2011; Soltani et al., “Flash Cookies and Privacy.”
- 46 Mika Ayenson et al., “Flash Cookies and Privacy II: Now with HTML5 and ETag Respawning,” Social Science Research Network, July 29, 2011, http://papers.ssrn.com/sol3/papers.cfm?abstract_id=1898390.
- 47 Samy Kamkar, “Evercookie—Never Forget,” October 11, 2010, <http://samy.pl/evercookie/>.
- 48 Jeremiah Grossman, “I Know Where You’ve Been” (blog post), August 11, 2006, <http://jeremiahgrossman.blogspot.ro/2006/08/i-know-where-youve-been.html>.
- 49 Englehardt, “Online Tracking: A 1-million-site Measurement and Analysis.”
- 50 Peter Eckersley, “How Unique Is Your Web Browser?” *Proceedings of the 10th International Conference on Privacy Enhancing Technologies*, (2010).
- 51 Englehardt, “Online Tracking: A 1-million-site Measurement and Analysis.”
- 52 Plane, “Exploring User Perceptions of Discrimination”; Dolin, “Unpacking Perceptions of Data-Driven Inferences”; Englehardt, “Online Tracking: A 1-million-site Measurement and Analysis.”
- 53 Steven Englehardt, Jeffrey Han and Arvind Narayanan, “I Never Signed Up for This! Privacy Implications of Email Tracking,” *Proceedings on Privacy Enhancing Technologies*, (2018).
- 54 Justin Brookman, Phoebe Rouge, Aaron Alva and Christina Yeung, “Cross-Device Tracking: Measurement and Disclosures,” *Proceedings on Privacy Enhancing Technologies*, 113, (2017), 117–22, <https://petsymposium.org/2017/papers/issue2/paper29-2017-2-source.pdf>.
- 55 Regulation (EU) 2016/679 of the European Parliament and of the Council of 27 April 2016 on the protection of natural persons with regard to the processing of personal data and on the free movement of such data, and repealing Directive 95/46/EC (General Data Protection Regulation), <http://data.europa.eu/eli/reg/2016/679/oj>.
- 56 Martino Trevisan, Stefano Traverso, Eleonora Bassi and Marco Mellia, “4 Years of EU Cookie Law: Results and Lessons Learned,” *Proceedings on Privacy Enhancing Technologies*, 2019.
- 57 Tanzina Vega, “Code That Tracks Users’ Browsing Prompts Lawsuits,” *The New York Times*, September 20, 2010, www.nytimes.com/2010/09/21/technology/21cookie.html; Tanzina Vega, “New Web Code Draws Concern Over Privacy Risks,” *The New York Times*, October 10, 2010, www.nytimes.com/2010/10/11/business/media/11privacy.html.
- 58 Blase Ur et al., “Smart, Useful, Scary, Creepy: Perceptions of Online Behavioral Advertising,” *Proceedings of the Eighth Symposium on Usable Privacy and Security*, (April 2, 2012; revised July 13, 2012).

- 59 McDonald and Cranor, “The Cost of Reading Privacy Policies”; Mark A. Graber, Donna M. D’Alessandro and Jill Johnson-West, “Reading Level of Privacy Policies on Internet Health Web Sites,” *Journal of Family Practice* 51, no. 7 (2002); Blase Ur, Manya Sleeper and Lorrie Faith Cranor, “{Privacy, Privacidad} Policies in Social Media: Providing Translated Privacy Notice,” *WWW Workshop on Privacy and Security in Online Social Media (PSOSM)*, 2012.
- 60 Martin Brinkmann, “Microsoft unveils new Edge Privacy Tools concept,” *ghacks.net*, May 6, 2019, <https://www.ghacks.net/2019/05/06/microsoft-unveils-new-edge-privacy-tools-concept/>.
- 61 Steve Lohr, “The Default Choice, So Hard to Resist,” *The New York Times*, October 15, 2011, www.nytimes.com/2011/10/16/technology/default-choices-are-hard-to-resist-online-or-not.html.
- 62 Nick Statt, “Advertisers are furious with Apple for new tracking restrictions in Safari 11,” *The Verge*, September 14, 2017, <https://www.theverge.com/2017/9/14/16308138/apple-safari-11-advertiser-groups-cookie-tracking-letter>.
- 63 Emil Protalinski, “Firefox starts blocking third-party cookies by default,” *Venture Beat*, June 4, 2019, <https://venturebeat.com/2019/06/04/firefox-enhanced-tracking-protection-blocks-third-party-cookies-by-default/>.
- 64 Lorrie Faith Cranor, “A First Look at Internet Explorer 9 Privacy Features,” *Technology|Academics|Policy*, March 16, 2011, www.techpolicy.com/Blog/March-2011/A-first-look-at-Internet-Explorer-9-privacy-featur.aspx.
- 65 Ur, “Smart, Useful, Scary, Creepy: Perceptions of Online Behavioral Advertising”; Mike Wuerthele, “Here’s how Apple protects your privacy in Safari with Intelligent Tracking Protection 2.0,” *Apple Insider*, June 20, 2018, <https://appleinsider.com/articles/18/06/20/heres-how-apple-protects-your-privacy-in-safari-with-intelligent-tracking-protection-20>.
- 66 Lohr, “The Default Choice, So Hard to Resist.”
- 67 Mozilla, “How to Block Fingerprinting With Firefox,” (blog) May 21, 2019, <https://blog.mozilla.org/firefox/how-to-block-fingerprinting-with-firefox>.
- 68 Gaurav Aggarwal, Elie Bursztein, Collin Jackson and Dan Boneh, “An Analysis of Private Browsing Modes in Modern Browsers,” *Proceedings of the 19th USENIX Security Symposium*, (2010).
- 69 Yuxi Wu, Panya Gupta, Miranda Wei, Yasemin Acar, Sascha Fahl and Blase Ur, “Your Secrets Are Safe: How Browsers’ Explanations Impact Misconceptions About Private Browsing Mode,” *Proceedings of the Web Conference*, (2018).
- 70 Gregg Keizer, “The Brave browser basics – what it does, how it differs from rivals,” *Computer World*, July 24, 2018, <https://www.computerworld.com/article/3292619/the-brave-browser-basics-what-it-does-how-it-differs-from-rivals.html>; Gregg Keizer, “What is the Epic browser (and what makes it different)?” *Computer World*, July 3, 2018, <https://www.computerworld.com/article/3286605/what-is-the-epic-browser-and-what-makes-it-different.html>.
- 71 Peter Bright, “Microsoft Sticks to Its Guns, Keeps Do Not Track on by Default in IE10,” *Ars Technica*, August 7, 2012, <http://arstechnica.com/information-technology/2012/08/microsoft-sticks-to-its-guns-keeps-do-not-track-on-by-default-in-ie10/>.
- 72 Michael Muchmore, “Google Chrome’s Sham ‘Do Not Track’ Feature,” *PCMag*, November 9, 2012, www.pcmag.com/article2/0,2817,2411916,00.asp.
- 73 W3C Tracking Protection Working Group, www.w3.org/2011/tracking-protection/; Robert X. Cringely, “The Myth of Do Not Track—and the Tragedy of Internet Privacy,” *InfoWorld*, July 31, 2013, www.infoworld.com/t/cringely/the-myth-of-do-not-track-and-the-tragedy-of-internet-privacy-223827; Matthew Humphries, “Safari Drops ‘Do Not Track’ Support As It Allows Users to Be Tracked,” *PC Magazine*, February 7, 2019, <https://www.pcmag.com/news/366407/safari-drops-do-not-track-support-as-it-allows-users-to-be>; Glenn Fleishman, “How the tragic death of Do Not Track ruined the web for

- everyone,” *Fast Company*, March 17, 2019, <https://www.fastcompany.com/90308068/how-the-tragic-death-of-do-not-track-ruined-the-web-for-everyone>.
- 74 Keizer, “The Brave browser basics”; Keizer, “What is the Epic browser?”
- 75 Pedro Giovanni Leon, Lorrie Faith Cranor, Aleecia M. McDonald and Robert McGuire, “Token Attempt: The Misrepresentation of Website Privacy Policies Through the Misuse of P3P Compact Policy Tokens,” *Workshop on Privacy in the Electronic Society*, (September 10, 2010).
- 76 Microsoft, Internet Explorer 10 Privacy Statement for Windows 7, last updated December 2012, <http://windows.microsoft.com/en-US/internet-explorer/ie10-win7-privacy-statement>.
- 77 Bashir, “Quantity vs. Quality: Evaluating User Interest Profiles”; Google, Ads Settings, <https://www.google.com/settings/ads/onweb/>, accessed August 27, 2012; Microsoft, Your Privacy and Microsoft Personalized Ads, <https://choice.microsoft.com/en-US>, accessed August 9, 2013; Yahoo! Ad Interest Manager, http://info.yahoo.com/privacy/us/yahoo/opt_out/targeting/details.html, accessed August 1, 2012; Evidon, Profile Manager, www.evidon.com/consumers-privacy/manage-your-online-profile, accessed October 8, 2013.
- 78 Athanasios Andreou, Giridhari Venkatadri, Oana Goga, Krishna Gummadi, Patrick Loiseau and Alan Mislove, “Investigating ad transparency mechanisms in social media: A case study of Facebook’s explanations,” *Proceedings of the Network and Distributed System Security Symposium*, (2018).
- 79 Motahhare Eslami, Sneha R Krishna Kumaran, Christian Sandvig and Karrie Karahalios, “Communicating algorithmic process in online behavioral advertising,” *Proceedings of the 2018 CHI Conference on Human Factors in Computing Systems*, (2018); Filipe N. Ribeiro, Koustuv Saha, Mahmoudreza Babaei, Lucas Henrique, Johnnatan Messias, Fabricio Benevenuto, Oana Goga, Krishna P. Gummadi and Elissa M. Redmiles, “On microtargeting socially divisive ads: A case study of Russia-linked ad campaigns on Facebook,” *Proceedings of the Conference on Fairness, Accountability, and Transparency*, (2019).
- 80 Pedro Giovanni Leon et al., “What Do Online Behavioral Advertising Privacy Disclosures Communicate to Users?” *Proceedings of the 2012 Workshop on Privacy in the Electronic Society*, 19–30, (New York: ACM Press, April 2, 2012).
- 81 Keizer, “The Brave browser basics”; Keizer, “What is the Epic browser?”; Leon, “Token Attempt: The Misrepresentation of Website Privacy Policies.”
- 82 Giridhari Venkatadri, Piotr Sapiezynski, Elissa Redmiles, Alan Mislove, Oana Goga, Michelle Mazurek, and Krishna Gummadi, “Auditing Offline Data Brokers via Facebook’s Advertising Platform,” *Proceedings of The Web Conference*, (2019).
- 83 Information Commissioner’s Office, “Guidance on the Rules on Use of Cookies and Similar Technologies,” V.3, May 2012, www.ico.gov.uk/~media/documents/library/Privacy_and_electronic/Practical_application/guidance_on_the_new_cookies_regulations.ashx.
- 84 Englehardt, “I Never Signed Up for This! Privacy Implications of Email Tracking.”
- 85 Network Advertising Initiative, www.networkadvertising.org/choices/, accessed August 9, 2013; Digital Advertising Alliance, www.aboutads.info/choices/, accessed August 26, 2012; Evidon, Profile Manager, www.evidon.com/consumers-privacy/opt-out, accessed October 7, 2013.
- 86 Pedro Giovanni Leon et al., “Why Johnny Can’t Opt Out: A Usability Evaluation of Tools to Limit Online Behavioral Advertising,” *Proceedings of the SIGCHI Conference on Human Factors in Computing Systems* (October 31, 2011; revised May 10, 2012).
- 87 Abine, “Frequently Asked Questions About DNT+,” www.donottrackplus.com/faqs.php, accessed August 27, 2012.
- 88 Leon et al., “Why Johnny Can’t Opt Out.”
- 89 Florian Schaub, Aditya Marella, Pranshu Kalvani, Blase Ur, Chao Pan, Emily Forney and Lorrie Faith Cranor, “Watching Them Watching Me: Browser Extensions’ Impact on User Privacy Awareness and

- Concern, “*Proceedings of the NDSS Workshop on Usable Security*, (2016).
- 90 Ur et al., “Smart, Useful, Scary, Creepy.”
- 91 Mozilla Support, Content Blocking, <https://support.mozilla.org/en-US/kb/content-blocking>, accessed June 27, 2019.
- 92 Leon et al., “Why Johnny Can’t Opt Out.”
- 93 Georg Merzdovnik, Markus Huber, Damjan Buhov, Nick Nikiforakis, Sebastian Neuner, Martin Schmiedecker, and Edgar Weippl, “Block Me If You Can: A Large-Scale Study of Tracker-Blocking Tools,” *Proceedings of the 2017 IEEE European Symposium on Security and Privacy*, (2017).
- 94 Jennifer Valentino-DeVries, “How to Use Microsoft’s InPrivate Filtering,” *Digits* (blog), *The Wall Street Journal*, August 1, 2010, <http://blogs.wsj.com/digits/2010/08/01/how-to-use-microsofts-inprivate-filtering/>.
- 95 Mozilla, “Introducing Collusion: Discover Who’s Tracking You Online,” www.mozilla.org/en-US/collusion/, accessed August 9, 2013.
- 96 Robert J. Walls, Shane S. Clark and Brian Neil Levine, “Functional Privacy or Why Cookies Are Better with Milk,” *Seventh USENIX Workshop on Hot Topics in Security*, (2012).
- 97 Franziska Roesner, Tadayoshi Kohno and David Wetherall, “Detecting and Defending Against Third-Party Tracking on the Web,” *Proceedings of the Ninth USENIX Symposium on Networked Systems Design and Implementation*, (2012).
- 98 AdNauseum. <https://adnauseam.io/>, accessed June 27, 2019.
- 99 Ur et al., “Smart, Useful, Scary, Creepy.”
- 100 Helen F. Nissenbaum, “Privacy as Contextual Integrity,” *Washington Law Review* 79, no. 1, (2004).
- 101 Daniel C. Howe and Helen Nissenbaum, “TrackMeNot: Resisting Surveillance in Web Search,” in Ian Kerr, Carole Lucock and Valerie Steeves, eds., *Lessons from the Identity Trail: Anonymity, Privacy, and Identity in a Networked Society* (New York: Oxford University Press, 2009), 417–436.
- 102 Christopher Soghoian, “The Problem of Anonymous Vanity Searches,” *I/S: A Journal of Law and Policy for the Information Society* 3, no. 2 (2007).
- 103 Englehardt, “Online Tracking: A 1-million-site Measurement and Analysis.”
- 104 Official Gmail Blog, “Images Now Showing,” December 12, 2013, <https://gmail.googleblog.com/2013/12/images-now-showing.html>.
- 105 Federal Aviation Administration, “Navigation Services—Global Position System,” 2010, www.faa.gov/about/office_org/headquarters_offices/ato/service_units/techops/navservices/gnss/gps/, accessed July 22, 2012.
- 106 Ari Juels, “RFID Security and Privacy: A Research Survey,” *IEEE Journal on Selected Areas in Communications* 24, no. 2, (February 6, 2006).
- 107 Joel Johnson, “Is Your Carrier Tracing You via GPS and 911 Calls?” *Popular Mechanics*, October 1, 2009, www.popularmechanics.com/technology/how-to/4258805.
- 108 Sean Gallagher, “Mall Owners Pull Plug on Cellular Tracking (For Now),” *Wired*, November 29, 2011, www.wired.com/business/2011/11/mall-pull-plug-cell-tracking/; Sean Gallagher, “We’re Watching: Malls Track Shoppers’ Cellphone Signals to Gather Marketing Data,” *Wired*, November 28, 2011, www.wired.com/business/2011/11/malls-track-phone-signals/.
- 109 Shane Ahern, Dean Eckles, Nathaniel S. Good, Simon King, Mor Naaman and Rahul Nair, “Over-exposed? Privacy patterns and considerations in online and mobile photo sharing,” *Proceedings of the 2007 SIGCHI conference on Human factors in computing systems*, (2007).
- 110 <http://itunes.apple.com/us/app/find-my-friends/id466122094?mt=8>.
- 111 www.facebook.com/about/location/.

- 112 <http://itunes.apple.com/us/app/imapweather-radio/id413511993?mt=8>.
- 113 Bledi Memishaj, "Find My Phone: Track your misplaced Android, iPhone, or Windows Phone," *Gadget Detected*, April 24, 2017, <https://www.gadgetdetected.com/2017/04/find-my-phone/>.
- 114 Laura M. Holson, "Is Geotagging on Instagram Ruining Natural Wonders? Some Say Yes," *The New York Times*, November 29, 2018, <https://www.nytimes.com/2018/11/29/travel/instagram-geotagging-environment.html>.
- 115 Silkstream, "Geotagging on Social Media: Beware of the risks," (blog), August 2016, <https://www.silkstream.net/blog/2016/08/geotagging-social-media-risks.html>.
- 116 Cheryl Rodewig, "Geotagging poses security risks," March 7, 2012, https://www.army.mil/article/75165/Geotagging_poses_security_risks.
- 117 Brett Singer, "11 Best Apps for Parents to Monitor Their Kids," *Parents.com*, October 11, 2018, <https://www.parents.com/parenting/technology/best-apps-for-paranoid-parents/>.
- 118 David Pogue, "Cellphones That Track the Kids," *The New York Times*, December 21, 2006, www.nytimes.com/2006/12/21/technology/21pogue.html.
- 119 Alexei Czeskis, Ivayla Dermendjieva, Hussein Yapit, Alan Borning, Batya Friedman, Brian Gill and Tadayoshi Kohno, "Parenting from the pocket: Value tensions and technical directions for secure and private parent-teen mobile safety," *Proceedings of the Sixth Symposium on Usable Privacy and Security*, (2010); Lorrie Faith Cranor, Adam L. Durity, Abigail Marsh and Blase Ur, "Parents' and teens' perspectives on privacy in a technology-filled world," *Proceedings of the Tenth Symposium on Usable Privacy and Security*, (2014).
- 120 Gundars Kaupins and Robert Minch, "Legal and Ethical Implications of Employee Location Monitoring," *Proceedings of the 38th Hawaii International Conference on System Sciences*, (2005).
- 121 Frost & Sullivan, "Location-based Advertising—Relevant Trends and Technologies," February 16, 2012, www.frost.com/sublib/display-report.do?id=9838-00-31-00-00.
- 122 Patrick Gage Kelley, Michael Benisch, Lorrie Faith Cranor and Norman Sadeh, "When Are Users Comfortable Sharing Location with Advertisers?" *Proceedings of the SIGCHI Conference on Human Factors in Computing Systems*, (2011).
- 123 Andrew Dowell, "Tracking Women: Now There's Not An App For That," *Digits* (blog), *The Wall Street Journal*, March 31, 2012, <http://blogs.wsj.com/digits/2012/03/31/tracking-women-now-theres-not-an-app-for-that/>.
- 124 Michael F. Goodchild, "Unit 002—What Is Geographic Information Science?" *NCGIA Core Curriculum in GIScience*, 1997, www.ncgia.ucsb.edu/giscc/units/u002/, accessed July 29, 2012.
- 125 <https://foursquare.com/privacy/>.
- 126 Lynn Tsai, Primal Wijesekera, Joel Reardon, Irwin Reyes, Serge Egelman, David Wagner, Nathan Good and Jung-Wei Chen, "Turtle Guard: Helping Android Users Apply Contextual Privacy Preferences," *Proceedings of the Thirteenth Symposium on Usable Privacy and Security*, (2017).
- 127 Michael Benisch, Patrick Gage Kelley, Norman Sadeh, and Lorrie Faith Cranor, "Capturing Location-Privacy Preferences: Quantifying Accuracy and User-Burden Tradeoffs," *Personal and Ubiquitous Computing* 15, no. 7 (2011).
- 128 Rebecca Balebako, Jaeyeon Jung, Wei Lu, Lorrie Faith Cranor and Carolyn Nguyen, "Little brothers watching you: Raising awareness of data leaks on smartphones," *Proceedings of the Ninth Symposium on Usable Privacy and Security*, (2013).
- 129 Hazim Almuhammedi, Florian Schaub, Norman Sadeh, Idris Adjerid, Alessandro Acquisti, Joshua Gluck, Lorrie Faith Cranor and Yuvraj Agarwal, "Your location has been shared 5,398 times! A field study on mobile app privacy nudging," *Proceedings of the 33rd Annual ACM Conference on Human Factors in Computing Systems*, (2015).

- 130 Yves-Alexandre de Montjoye, César A. Hidalgo, Michel Verleysen and Vincent D. Blondel, "Unique in the Crowd: The Privacy Bounds of Human Mobility," *Scientific Reports* 3, March 25, 2013, <http://dx.doi.org/10.1038/srep01376>.
- 131 Arvind Narayanan et al., "Location Privacy via Private Proximity Testing," *Proceedings of the 18th Annual Network and Distributed Systems Symposium*, (2011).
- 132 Lewis A. Kaplan, United States District Court, S. D. New York, United States of America v. John Tomero et al., Defendants, No. S2 06 Crim. 0008(LAK), November 27, 2006.
- 133 Declan McCullagh and Anne Broache, "FBI Taps Cell Phone Mic as Eavesdropping Tool," *CNET*, December 1, 2006, <http://news.cnet.com/2100-1029-6140191.html>.
- 134 Neal Leavitt, "Mobile Phones: The Next Frontier for Hackers?" *Computer* 38, no. 4, (2005).
- 135 Ryan Farley and Xinyuan Wang, "Roving Bugnet: Distributed Surveillance Threat and Mitigation," *Emerging Challenges for Security, Privacy and Trust. IFIP Advances in Information and Communications Technologies* 297, (2009).
- 136 Rahul Chatterjee, Periwinkle Doerfler, Hadas Orgad, Sam Havron, Jackeline Palmer, Diana Freed, Karen Levy, Nicola Dell, Damon McCoy and Thomas Ristenpart, "The Spyware Used in Intimate Partner Violence," *IEEE Symposium on Security and Privacy*, (2018).
- 137 Chatterjee et al., "The Spyware Used in Intimate Partner Violence."
- 138 Brown Farinholt, Mohammad Rezaeirad, Paul Pearce, Hitesh Dharmdasani, Haikuo Yin, Stevens Le Blond, Damon McCoy and Kirill Levchenko, "To Catch a Ratter: Monitoring the Behavior of Amateur DarkComet RAT Operators in the Wild," *Proceedings of the 2017 IEEE Symposium on Security and Privacy*, (2017).
- 139 Suzan Clark, "Pa. School Faces FBI Probe, Lawsuit for Using Webcams on Laptops to Watch Students at Home," *ABC Good Morning America*, February 22, 2010, <http://abcnews.go.com/GMA/Parenting/pennsylvania-school-fbi-probe-webcam-students-spying/story?id=9905488>.
- 140 John P. Martin, "Lower Merion District's Laptop Saga Ends with \$610,000 Settlement," *The Inquirer*, October 12, 2010, http://articles.philly.com/2010-10-12/news/24981536_1_laptop-students-district-several-million-dollars/2, accessed August 27, 2012.
- 141 Clark, "Pa. School Faces FBI Probe."
- 142 David Goldman, "Your Samsung TV is eavesdropping on your private conversations," *CNN Business*, February 10, 2015, <https://money.cnn.com/2015/02/09/technology/security/samsung-smart-tv-privacy/index.html>.
- 143 Sam Biddle, "WikiLeaks Dump Shows CIA Could Turn Smart TVs into Listening Devices," *The Intercept*, March 7, 2017, <https://theintercept.com/2017/03/07/wikileaks-dump-shows-cia-could-turn-smart-tvs-into-listening-devices/>.
- 144 Ben Popken, "Your smart TV is watching you watching TV, Consumer Reports finds," *NBC News*, February 7th, 2018, <https://www.nbcnews.com/tech/security/your-smart-tv-watching-you-watching-tv-consumer-reports-finds-n845456>.
- 145 Electronic Frontier Foundation, "Surveillance Drones," <https://www.eff.org/issues/surveillance-drones>, accessed June 27, 2019.
- 146 Bruce Schneier, "Is it OK to shoot down a drone over your backyard?" *CNN*, September 9, 2015, <https://www.cnn.com/2015/09/09/opinions/schneier-shoot-down-drones/index.html>.
- 147 Kelsey D. Atherton, "It Is A Federal Crime To Shoot Down A Drone, Says FAA," *Popular Science*, April 15, 2016, <https://www.popsci.com/it-is-federal-crime-to-shoot-down-drone-says-faa/>.
- 148 Nick Patton Walsh, "What shooting down a \$110M US drone tells us about Iran," *CNN*, June 25, 2019, <https://www.cnn.com/2019/06/25/middleeast/iran-drone-shooting-capabilities-npw-intl/index.html>.

- 149 Jake Laperruque and David Janovsky, “These Police Drones are Watching You,” POGO, September 25, 2018, <https://www.pogo.org/analysis/2018/09/these-police-drones-are-watching-you/>.
- 150 Nick Statt, “Sunflower Labs is building a drone surveillance system for high-end homes,” *The Verge*, December 7, 2018, <https://www.theverge.com/2018/12/7/18129308/sunflower-labs-system-drone-surveillance-bee-hive-home-security-startup>.
- 151 Joyce W. Luk, “Identifying Terrorists: Privacy Rights in the United States and the United Kingdom,” *Hastings International and Comparative Law Review* 25, (2002); Electronic Privacy Information Center, “Workplace Privacy,” <http://epic.org/privacy/workplace/#technologies>, accessed August 27, 2012.
- 152 Martin Gill and Angela Spriggs, *Home Office Research Study 292: Assessing the Impact of CCTV* (London: Home Office Research, Development and Statistics Directorate, 2005).
- 153 Luk, “Identifying Terrorists.”
- 154 Electronic Privacy Information Center, “Workplace Privacy.”
- 155 Parmy Olson and Sam Schechner, “AI, Surveillance Tools Scrutinized by European Regulators,” *The Wall Street Journal*, June 26, 2019.
- 156 Jonathan Ratcliffe, “How many CCTV Cameras are there in London 2019?” *CCTV.co.uk*, May 29, 2019, <https://www.cctv.co.uk/how-many-cctv-cameras-are-there-in-london/>.
- 157 Christina Zhao, “Jaywalking in China: Facial Recognition Surveillance Will Soon Fine Citizens Via Text Message,” *Newsweek*, March 27, 2018, <https://www.newsweek.com/jaywalking-china-facial-recognition-surveillance-will-soon-fine-citizens-text-861401>.
- 158 Paul Mozur, “One Month, 500,000 Face Scans: How China Is Using A.I. to Profile a Minority,” *The New York Times*, April 14, 2019.
- 159 Zak Doffman, “China Is Using Facial Recognition To Track Ethnic Minorities, Even In Beijing,” *Forbes*, May 3, 2019, <https://www.forbes.com/sites/zakdoffman/2019/05/03/china-new-data-breach-exposes-facial-recognition-and-ethnicity-tracking-in-beijing/>.
- 160 Official Gmail Blog, “Images Now Showing.”
- 161 Robert Westervelt, “Cisco Warns Serious VoIP Vulnerability Enables Eavesdropping,” *CRN*, January 11, 2013, www.crn.com/news/security/240146127/cisco-warns-serious-voip-vulnerability-enables-eavesdropping.htm.
- 162 Andrew M. White, Austin R. Matthews, Kevin Z. Snow and Fabian Monrose, “Phonotactic Reconstruction of Encrypted VoIP Conversations: Hookt on fon-iks,” *Proceedings of the 32nd IEEE Symposium on Security and Privacy*, (May 2011).
- 163 Glenn Greenwald et al., “Microsoft Handed the NSA Access to Encrypted Messages,” *The Guardian*, July 11, 2013, www.theguardian.com/world/2013/jul/11/microsoft-nsa-collaboration-user-data.
- 164 Jonathan Mayer, Patrick Mutchler, and John C. Mitchell, “Evaluating the privacy properties of telephone metadata,” *Proceedings of the National Academy of Sciences* 113.20: 5536–5541 (2016).
- 165 Micah Singleton, “Nearly a quarter of US households own a smart speaker, according to Nielsen,” *The Verge*, September 30, 2018, <https://www.theverge.com/circuitbreaker/2018/9/30/17914022/smart-speaker-40-percent-us-households-nielsen-amazon-echo-google-home-apple-homepod>.
- 166 Noura Abdi, Kopo M. Ramokapane and Jose M. Such, “More than Smart Speakers: Security and Privacy Perceptions of Smart Home Personal Assistants,” *Proceedings of the Fifteenth Symposium on Usable Privacy and Security*, (2019).
- 167 Lindsey O’Donnell, “Alexa Eavesdropping Flub Re-Sparks Voice Assistant Privacy Debate,” *Threat Post*, May 25, 2018, <https://threatpost.com/alexa-eavesdropping-flub-re-sparks-voice-assistant-privacy-debate/132284/>.

- 168 Andrew Guthrie Ferguson, “Alexa, What Is Probable Cause?” *Slate*, November 20, 2018, <https://slate.com/technology/2018/11/amazon-echo-alexa-murder-case-new-hampshire-warrant.html>.
- 169 Jordan Valinsky, “Amazon reportedly employs thousands of people to listen to your Alexa conversations,” *CNN Business*, April 11, 2019, <https://www.cnn.com/2019/04/11/tech/amazon-alexa-listening/index.html>.
- 170 Rebecca S. Portnoff, Linda N. Lee, Serge Egelman, Pratyush Mishra, Derek Leung and David Wagner, “Somebody’s Watching Me? Assessing the Effectiveness of Webcam Indicator Lights,” *Proceedings of the 33rd Annual ACM Conference on Human Factors in Computing Systems*, (2015).
- 171 Alex Hern, “Mark Zuckerberg tapes over his webcam. Should you?” *The Guardian*, June 22, 2016, <https://www.theguardian.com/technology/2016/jun/22/mark-zuckerberg-tape-webcam-microphone-facebook>.
- 172 Kellen Beck, “Taping over your computer microphone does nothing — here’s what to do instead,” *Mashable*, June 22, 2016, <https://mashable.com/2016/06/22/computer-microphone-hack/>.
- 173 Yuxin Chen, Huiying Li, Steven Nagels, Zhijing Li, Pedro Lopes, Ben Y. Zhao and Haitao Zheng, “Understanding the Effectiveness of Ultrasonic Microphone Jammer,” arXiv preprint arXiv:1904.08490, 2019.
- 174 Farley and Wang, “Roving Bugnet.”; Danny Y. Huang, Günes Acar, Noah Apthorpe, Frank Li, Arvind Narayanan and Nick Feamster, “IoT Inspector,” <https://iot-inspector.princeton.edu/>, accessed June 25, 2019.
- 175 Jason I. Hong and James A. Landay, “An architecture for privacy-sensitive ubiquitous computing,” *Proceedings of the 2nd international conference on Mobile systems, applications, and services*, (2004).
- 176 City of Chicago, “Data Portal,” <https://data.cityofchicago.org/>, accessed June 20, 2019.
- 177 Arvind Narayanan and Vitaly Shmatikov, “Robust de-anonymization of large sparse datasets,” *Proceedings of the IEEE Symposium on Security and Privacy*, (2008).
- 178 Future of Privacy Forum, “Shedding Light on Smart City Privacy,” March 30, 2017, <https://fpf.org/2017/03/30/smart-cities/>.
- 179 Privacy International, “Smart Cities,” <https://privacyinternational.org/topics/smart-cities>, accessed June 25, 2019.
- 180 Privacy International, “From smart cities to safe cities: normalising the police state?” August 15, 2018, <https://privacyinternational.org/feature/2231/smart-cities-safe-cities-normalising-police-state>.
- 181 Emilie Scott, “The trouble with informed consent in smart cities,” (IAPP blog), February 28, 2019, <https://iapp.org/news/a/the-trouble-with-informed-consent-in-smart-cities/>.
- 182 Elinor Mills, “Researchers find smart meters could reveal favorite TV shows,” *CNET*, January 24, 2012, <https://www.cnet.com/news/researchers-find-smart-meters-could-reveal-favorite-tv-shows/>.
- 183 Peter Kotecki, “Google’s parent company revealed its plan for a high-tech neighborhood in Toronto — and it could be the world’s largest tall timber project,” *Business Insider*, August 15, 2018, <https://www.businessinsider.com/alphabets-sidewalk-labs-reveals-plan-for-quayside-in-toronto-2018-8#dan-doctoroff-sidewalk-labs-ceo-believes-the-quayside-project-can-improve-residents-quality-of-life-by-creating-more-jobs-and-lowering-carbon-emissions-8>.
- 184 Leyland Cecco, “‘Surveillance capitalism’: critic urges Toronto to abandon smart city project,” *The Guardian*, June 6, 2019, <https://www.theguardian.com/cities/2019/jun/06/toronto-smart-city-google-project-privacy-concerns>.
- 185 Gabrielle Canon, “‘City of surveillance’: privacy expert quits Toronto’s smart-city project,” *The Guardian*, October 23, 2018, <https://www.theguardian.com/world/2018/oct/23/toronto-smart-city-surveillance-ann-cavoukian-resigns-privacy>.

- 186 Franziska Roesner, Tadayoshi Kohno and David Molnar, "Security and privacy for augmented reality systems," *Communications of the ACM*, 57(4):88-96, 2014.
- 187 Kiron Lebeck, Kimberly Ruth, Tadayoshi Kohno and Franziska Roesner, "Towards security and privacy for multi-user augmented reality: Foundations with end users," *Proceedings of the 2018 IEEE Symposium on Security and Privacy*, (2018).
- 188 Vivian Ng and Catherine Kent, "Smartphone data tracking is more than creepy – here's why you should be worried," *The Conversation*, February 7, 2018, <http://theconversation.com/smartphone-data-tracking-is-more-than-creepy-heres-why-you-should-be-worried-91110>.
- 189 Manisha Priyadarshini, "Which Sensors Do I Have In My Smartphone? How Do They Work?" *FOSS Bytes*, September 25th, 2018, <https://fossbytes.com/which-smartphone-sensors-how-work/>.
- 190 Jun Han, Emmanuel Owusu, Le T. Nguyen, Adrian Perrig, and Joy Zhang, "ACComplce: Location inference using accelerometers on smartphones," *Proceedings of the 2012 Fourth International Conference on Communication Systems and Networks*, (2012).
- 191 Emmanuel Owusu, Jun Han, Sauvik Das, Adrian Perrig, and Joy Zhang, "ACAccessary: password inference using accelerometers on smartphones," *Proceedings of the Twelfth Workshop on Mobile Computing Systems & Applications*, (2012).
- 192 Marian Harbach, Emanuel von Zeischwitz, Andreas Fichtner, Alexander De Luca, and Matthew Smith, "It's a Hard Lock Life: A Field Study of Smartphone (Un)Locking Behavior and Risk Perception," *Proceedings of the 10th Symposium on Usable Privacy and Security*, (2014).
- 193 Chandrasekhar Bhagavatula, Blase Ur, Kevin Iacovino, Su Mon Kywe, Lorrie Faith Cranor and Marios Savvides, "Biometric Authentication on iPhone and Android: Usability, Perceptions, and Influences on Adoption," *Proceedings of the NDSS Workshop on Usable Security*, (2015).
- 194 Ivan Cherapau, Ildar Muslukhov, Nalin Asanka and Konstantin Beznosov, "On the Impact of Touch ID on iPhone Passcodes," *Proceedings of the 11th Symposium on Usable Privacy and Security*, (2015).
- 195 Edward Jay Wang, William Li, Doug Hawkins, Terry Gernsheimer, Colette Norby-Slycord and Shwetak N. Patel, "HemaApp: noninvasive blood screening of hemoglobin using smartphone cameras," *Proceedings of the 2016 ACM International Joint Conference on Pervasive and Ubiquitous Computing*, (2016).
- 196 Florian Schaub, Rebecca Balebako, Adam L. Durity and Lorrie Faith Cranor, "A Design Space for Effective Privacy Notices," *Proceedings of the Eleventh Symposium on Usable Privacy and Security*, (2015).
- 197 Emily McReynolds, Sarah Hubbard, Timothy Lau, Aditya Saraf, Maya Cakmak and Franziska Roesner, "Toys that Listen: A Study of Parents, Children, and Internet-Connected Toys," *Proceedings of the 2017 CHI Conference on Human Factors in Computing Systems*, (2017).
- 198 Samuel Gibbs, "Hackers can hijack Wi-Fi Hello Barbie to spy on your children," *The Guardian*, November 26, 2015.
- 199 Blase Ur, Jaeyeon Jung and Stuart Schechter, "Intruders versus intrusiveness: teens' and parents' perspectives on home-entryway surveillance," *Proceedings of the 2014 ACM International Joint Conference on Pervasive and Ubiquitous Computing*, (2014).
- 200 Anita Melander-Wikman, Ylva Fältholm, and Gunvor Gard. "Safety vs. privacy: elderly persons' experiences of a mobile safety alarm," *Health & social care in the community* 16.4, 2008.
- 201 George Demiris, Debra Parker Oliver, Jarod Giger, Marjorie Skubic and Marilyn Rantz, "Older adults' privacy considerations for vision based recognition methods of eldercare applications," *Technology and Health Care* 17.1:41–48, (2009).
- 202 Matt Day, "Your Smart Light Can Tell Amazon and Google When You Go to Bed," *Bloomberg*, February 12, 2019, <https://www.bloomberg.com/news/articles/2019-02-12/your-smart-light-can-tell-amazon-and-google-when-you-go-to-bed>.

- 203 Rob Marvin, "Privacy Tops List of Consumer Smart Home Concerns," *PC Magazine*, March 4, 2019, <https://www.pcmag.com/news/366783/privacy-tops-list-of-consumer-smart-home-concerns>.
- 204 Serena Zheng, Noah Apthorpe, Marshini Chetty, and Nick Feamster, "User Perceptions of Smart Home IoT Privacy," *Proceedings of the ACM on Human-Computer Interaction*, (2018).
- 205 Eric Zeng, Shrirang Mare and Franziska Roesner, "End User Security and Privacy Concerns with Smart Homes," *Proceedings of the Thirteenth Symposium on Usable Privacy and Security*, (2017).
- 206 Milijana Surbatovich, Jassim Aljuraidan, Lujo Bauer, Anupam Das and Limin Jia, "Some recipes can do more than spoil your appetite: Analyzing the security and privacy risks of IFTTT recipes," *Proceedings of the 26th International Conference on World Wide Web*, (2017).
- 207 Weijia He, Maximilian Golla, Roshni Padhi, Jordan Ofek, Markus Dürmuth, Earlence Fernandes, and Blase Ur, "Rethinking Access Control and Authentication for the Home Internet of Things (IoT)," *Proceedings of the 27th USENIX Security Symposium*, (2018).
- 208 Ben Wojdyla, "How it Works: The Computer Inside Your Car," *Popular Mechanics*, February 21, 2012, <https://www.popularmechanics.com/cars/how-to/a7386/how-it-works-the-computer-inside-your-car/>.
- 209 SCOTUSblog, "United States v. Jones," <https://www.scotusblog.com/case-files/cases/united-states-v-jones/>, accessed June 20, 2019.
- 210 Byron V. Acohido, "The Dark Sides of Modern Cars: Hacking and Data Collection," *Threat Post*, February 26, 2019, <https://threatpost.com/modern-car-warning/142190/>.
- 211 Rebekah L. Sanders, "Car renters beware: Bluetooth use can reveal your private data," *USA Today*, January 30, 2018, <https://www.usatoday.com/story/money/cars/2018/01/30/car-renters-beware-bluetooth-use-can-reveal-your-private-data/1080225001/>.
- 212 Kim Komando, "Your car's hidden 'black box' and how to keep it private," *USA Today*, December 26, 2014, <https://www.usatoday.com/story/tech/columnist/komando/2014/12/26/keep-your-car-black-box-private/20609035/>.
- 213 Sean Cleary, "Can Your Car's Black Box Help in Case of a Car Accident?" (blog), December 14, 2017, <https://www.seanclearypa.com/blog/car-black-box-car-accident/>.
- 214 OnStar, "Connected Services," <https://www.onstar.com/us/en/services/connected-services/>, accessed June 28, 2019.
- 215 Zhaolong Ning, Feng Xia, Noor Ullah, Xiangjie Kong, and Xiping Hu, "Vehicular Social Networks: Enabling Smart Mobility," *IEEE Communications Magazine* 55(5), May 2017.
- 216 Ishtiaq Rouf, Rob Miller, Hossen Mustafa, Travis Taylor, Sangho Oh, Wenyuan Xu, Marco Gruteser, Wade Trappe and Ivan Seskar, "Security and privacy vulnerabilities of in-car wireless networks: A tire pressure monitoring system case study," *Proceedings of the 19th USENIX Security Symposium*, (2010).
- 217 Karl Koscher, Alexei Czeskis, Franziska Roesner, Shwetak Patel, Tadayoshi Kohno, Stephen Checkoway, Damon McCoy, Brian Kantor, Danny Anderson, Hovav Shacham and Stefan Savage, "Experimental security analysis of a modern automobile," *Proceedings of the 2010 IEEE Symposium on Security and Privacy*, (2010).
- 218 Solove, " 'I've Got Nothing to Hide' and Other Misunderstandings of Privacy."
- 219 Greig Paul and James Irvine, "Privacy Implications of Wearable Health Devices," *Proceedings of the Seventh International Conference on Security of Information and Networks*, (2014).
- 220 Jeremy Hsu, "The Strava Heat Map and the End of Secrets," *Wired*, January 29, 2018, <https://www.wired.com/story/strava-heat-map-military-bases-fitness-trackers-privacy/>.
- 221 Daniel Halperin, Tadayoshi Kohno, Thomas S. Heydt-Benjamin, Kevin Fu and William H. Maisel, "Security and privacy for implantable medical devices," *IEEE pervasive computing* 7.1:30–39, 2008.

- 222 Sciforce, “IoT in Healthcare: Are We Witnessing a New Revolution?” *Medium*, March 7, 2019, <https://medium.com/sciforce/iot-in-healthcare-are-we-witnessing-a-new-revolution-6bb0ecf55991>.
- 223 Gabriella M. Harari, Nicholas D. Lane, Rui Wang, Benjamin S. Crosier, Andrew T. Campbell and Samuel D. Gosling, “Using Smartphones to Collect Behavioral Data in Psychological Science: Opportunities, Practical Considerations, and Challenges,” *Perspect Psychol Sci.* 11(6): (2016) 838–854.
- 224 Malgorzata Turalska and Bruce J. West, “Fractional Dynamics of Individuals in Complex Networks,” *Frontiers in Physics*, 2018.
- 225 Shan Jiang, Yingxiang Yang, Siddharth Gupta, Daniele Veneziano, Shounak Athavale and Marta C. González, “The TimeGeo modeling framework for urban mobility without travel surveys,” *Proceedings of the National Academy of Sciences* 113(37), (September 13, 2016).
- 226 Pål Sundsøy, “Big Data for Social Sciences: Measuring patterns of human behavior through large-scale mobile phone data,” PhD thesis, University of Oslo, 2017.
- 227 Justin Cranshaw, Raz Schwartz, Jason Hong and Norman Sadeh, “The Livehoods Project: Utilizing Social Media to Understand the Dynamics of a City,” *Proceedings of the Sixth International AAAI Conference on Weblogs and Social Media*, (2012).
- 228 Samiul Hasan, Xianyuan Zhan and Satish V. Ukkusuri, “Understanding urban human activity and mobility patterns using large-scale location-based data from online social media,” *Proceedings of the 2nd ACM SIGKDD International Workshop on Urban Computing*, (2013).

CHAPTER 7

Interference

Aaron Massey; Travis D. Breaux, CIPT

Interference is an act that prevents or obstructs a process from continuing or being carried out properly.¹ For individual privacy, interference can be informed by Warren and Brandeis' privacy right "to be let alone" and Alan Westin's notions of solitude and reserve, wherein an individual's preference not to be bothered includes avoiding outside interference from others. Interference can also be

thought of as any disruption of individual autonomy.² Surveillance and tracking technologies, such as those described in Chapter 6, enable interference because they provide access to the individual's physical person as well as to information about the individual's behaviors and preferences. Society's need to protect itself from nefarious individuals sometimes justifies the use of surveillance and tracking technologies. Similarly, businesses need to create accurate information models about individuals in order to ensure routine and reliable business activities. However, the risk of interference for individuals increases with the amount of information collected and maintained. Example activities include an individual's ability to use transportation and banking services, the ability to earn a living wage by finding employment or to exercise a vote in a democratic society. These activities rely on establishing a person's identity and authorization to use services or perform actions, for example, establishing that a person is licensed to drive or creditworthy, that the person is not a criminal felon. If an error exists in a person's credit report, or if a person is incorrectly placed on a "no-fly" list, this individual would suffer from interference with their private matters. In this chapter, we begin by introducing interference in the context of current legal views, definitions and privacy harms. Afterward, we examine interference from different technological perspectives, such as spam, mobile application and other software application programming interfaces (APIs), behavioral advertising, cyberbullying, social engineering and, finally, remote desktop administration. We conclude with lessons learned that the information technology (IT) professional may use in the context of their professional responsibilities.

7.1 Framework for Understanding Interference

Unlike ensuring that an IT system keeps personal information confidential, which is often achievable with cryptographic systems such those described in Chapter 3, interference is a threat to privacy that can result from a sequence of steps in an IT system. Some of these steps may be innocuous, such as collecting a person's zip code, whereas other steps are more prone to error, such as drawing conclusions about someone based on their purchase history.³ Other actions can lead to a process obstruction or unwanted attention, such as sending advertising to a person based on an attribute inferred from data.

Whether an inferred attribute is accurate or not does not lessen the perception of the intrusion, often referred to as "creepiness."⁴ From the perspective of a

business, sending an advertisement based on correlations from behavioral data may have almost no downside. If the correlations are accurate, then the individual may be more inclined to make a purchase. If not, the business is simply out the cost of one advertisement. However, from the perspective of the consumer, the downside risk is much greater. Whether the ad is welcome or unwelcome often depends on the person's privacy preferences. For some pregnant women, advertising can introduce these women to products that increase daily comfort. For others who wish to control the time, location and circumstances when they choose to reveal their pregnancy, their status is a private family matter. In this last case, advertising can interfere in a pregnant woman's personal matters by circumventing her ability to control access to her personal information.

In this chapter, we introduce a framework that classifies three general types of interference by the object that IT interferes with, whether that object is a decision, a personal feeling or a social engagement. The three types borrow heavily from the work by Daniel Solove and William Prosser, which we discuss.

Type 1. Obstruction or decisional interference—any action to interfere with decisions that affect the person's daily life, such as whether to allow the person to travel, to borrow money or to obtain lawful employment. This form of interference is often difficult to detect as it can be concealed in complex business or IT processes. Consequently, this form may not be easily recognizable by the person about whom the decision is made as they may be unaware of the decision-making process, or the decision itself may be hidden from the person.

Type 2. Intrusion into physical, psychological, or informational spaces—any action that affects a person's solitude, including their desire to be alone or to be among a few confidantes of their choosing, and their desire to control who has access to their visual and thoughtful attention or who has access to their information. Such actions include searches of private spaces, curfews or other restrictions of movement, alerts and notifications that grab and divert the attention of the person. While these actions may constitute objective harms under Calo's classification, the act of surveillance is a psychological intrusion and subjective harm, because it can affect whether people feel comfortable behaving as they otherwise would without persistent monitoring.⁵

Type 3. Interference with representation of self—any action that alters how an individual is represented, such as a person's marriage, financial or

employment status, their race, gender or sexual orientation, political views or any other affinity toward specific ideas or social groups. Regardless of whether the representation is accurate or a misrepresentation, individuals may wish to control access to the representation to avoid unwanted attention.

The act of interference may be direct or indirect. An act of direct interference involves the person whose privacy is most affected by the interference. An act of indirect interference is significantly removed from the effects of the act. Type 1 interference can be indirect, if the decision occurs without directly involving the person (e.g., a decision of creditworthiness). Type 2 interference can be direct, if the act interacts with the person's physical, psychological or informational space, such as by reading a person's contact list from their mobile phone.

The three types of interference are not orthogonal. Intrusion can influence obstruction; for example, surveillance of a person's movement can interfere with that person's feeling of oppression, and thus affect their decision about whether to meet their counterparts. Assumptions about the same person's associations that lead to a negative representation of that person may be used to interfere with the person's movement; for example, by prompting the person to take a different path or by detaining the person for questioning. Lastly, misrepresentation can influence obstruction: If a person is misrepresented as a convicted felon, that person may be denied certain types of employment, which is a decision made by a prospective employer.

The three types of interference are based on privacy scholarship, which lends credibility to their application in information technology. William Prosser, a scholar on tort law, codified specific types of interference from hundreds of civil privacy cases in his law review article titled "Privacy."⁶ This analysis resulted in four distinct torts that appear in Table 7-1. In 2002, Daniel Solove expanded upon Prosser's torts in his own taxonomy of privacy harms. We compare Prosser's and Solove's categories in Table 7-1.⁷

Table 7-1 Comparing Prosser's and Solove's Classifications of Interference-Related Privacy Acts

William Prosser's Four Kinds of Torts	Daniel Solove's Taxonomy of Privacy
Intrusion upon seclusion or solitude	Intrusion, decisional interference
Public disclosure of private facts	Breach of confidentiality, disclosure, exposure, increased accessibility
Presentation of an individual in a false light	Distortion

Use of an individual's name or likeness without permission	Appropriation
--	---------------

Solove's taxonomy distinguishes between different categories of intrusion and information disclosure, which results in multiple categories mapping to a single tort in Prosser's view on privacy. For example, intrusion is recategorized into two forms of invasion: decisional interference, which includes acts by a person to insert themselves into a decision-making process about another individual, and intrusion, which includes acts that disrupt a person's sense of solitude, whether physical or psychological.⁸ We adopted this distinction separately in our framework Types 1 and 2, respectively. Solove further refines public disclosure of private facts through various means: Breach of confidentiality is a broken promise to keep facts private, disclosure is revealing private facts to yield negative consequences, exposure is a revelation resulting from revealing private facts, and increased accessibility results when otherwise obscure or hard-to-access public information becomes easier to access due to more pervasive collection, distribution and retention practices. We narrowly consider the second tort and corresponding taxonomic categories as they relate to interfering to obtain a person's private information under Type 2. Whereas these four taxonomic categories are about revealing private facts, the activities of disclosure can also lead to factual inaccuracies about a person, which Solove labels distortion. Lastly, the intentional use of a person's likeness without permission is called appropriation. We consider the last three torts narrowly as they relate to interfering with a person's self-representation. While Solove appropriately distinguishes the subtleties between these categories, the end result is similar for an IT professional: Interference can affect how a person is perceived.

The challenge for IT professionals is that technology does not inherently interfere with individual privacy, and the technological advantages to the individual may outweigh the harms. Telemarketing calls may be welcome or unwanted depending on the person's privacy preferences. Creditworthiness allows the institutions of banking to make better decisions, which makes it easier for higher-risk individuals to obtain loans or make use of bank accounts for safeguarding money. Similarly, public safety in aviation depends upon prohibiting dangerous individuals from boarding aircraft. In situations where the risk exceeds the harm, we recommend IT professionals use a risk strategy to identify specific harms and avoid, transfer, or mitigate those risks with appropriate privacy

controls. Furthermore, after discussing real-world scenarios where interference occurred, we discuss several recommendations that the IT professional may use to specifically evaluate how any technology may contribute to interference.

7.2 Interference from a Technology Perspective

In this section, we examine different technological perspectives on interference with user or consumer privacy concerns. Table 7-2 summarizes the perspectives and how they illustrate the three types of interference in different situations and under different technologies. First, we quickly review the familiar situation of unwanted messages. Then we explore how software APIs can enable access to personal data and result in unwanted disclosure and exposure. Behavioral profiling, the next topic, leads to building complex representations of a person based on surveilling their behavior and then using these profiles to make decisions about the person or to personalize their experiences. Like unwanted disclosure and exposure, cyberbullying often requires exposing a person’s private details or recharacterizing the person beyond the person’s control. Next, we illustrate how social engineering directly interferes in security processes to gain control of a person’s online persona. Finally, we conclude by briefly discussing how administrative activities that manage IT systems can intrude on personal privacy.

Table 7-2 Technology Perspectives and Their Classification in the Interference Framework

Technology Topic	Type 1: Obstruction	Type 2: Intrusion	Type 3: Self-representation
Unwanted messaging		✓	
Select software APIs		✓	✓
Behavioral profiling	✓	✓	✓
Machine learning bias	✓	✓	✓

and fairness			
Cyberbullying		✓	✓
Social engineering	✓		✓
Administrative intrusions	✓	✓	

As we examine these cases, consider some of the following questions: How do companies learn about interference? Where does it come from? How does interference affect individuals? What can be done to prevent, mitigate or respond to interference? What are the differences between an action that causes interference and a failure to act to prevent interference?

7.2.1. Unsolicited Messages, also Called Spam

Unsolicited messages, also called *spam*, can be used to capture an individual's attention for advertising or other purposes. Spam is often restricted to email, but, increasingly, unwanted messages can be sent using other means, such as SMS texts. Spam is estimated to be roughly 78 percent of the total volume of email sent, and it has grown into a serious security and economic threat.² In 2003, the United States passed the Controlling the Assault of Non-Solicited Pornography and Marketing (CAN- SPAM) Act in an effort to regulate spammers, and the U.S. Federal trade Commission (FTC) implemented the CAN-SPAM Act by providing guidelines for businesses that include offering individuals the opportunity to opt out.¹⁰ Spam is often not directed at one specific individual any more than another individual, and response rates to spam are often extremely low compared with other forms of advertising. Under the CAN-SPAM Act, companies are required to provide one-click access within commercial bulk email messages to unsubscribe from mailing lists and future bulk messages. The link to unsubscribe must be prominently displayed, and the receiving website must quickly allow the user to unsubscribe. This means that the receiving website cannot require collecting additional information from the user, nor can the website create obstacles to unsubscribing, such as requiring the creation of user accounts. Under other jurisdictions, such as Europe, companies must first obtain individual consent before sending marketing messages; this is called opt-in consent. Thus, organizations often collect a person's residency status in Europe to determine which mechanism must be applied to such communications.

Unwanted messages generally fall under our second type of interference, which is an intrusion into psychological spaces. Depending on the type of message and time of day, the interference can affect individuals differently. Unwanted email is generally easy to filter using Bayesian algorithms, which use statistical and probabilistic approaches to classify likely spam messages based on keywords and email headers. Email users often customize Bayesian approaches to ensure a low false positive rate so that desirable messages are delivered. Unwanted SMS texts, however, are more intimate, as they arrive on a person's cell phone, which is typically used to receive personal calls. By employing the appropriate opt-in or opt-out mechanism, companies can more effectively communicate with potential customers while affording these individuals with controls over unwanted interference.

7.2.2 Exposing Personal Data through Software APIs

In early February 2012, a social networking application called *Path* made newspaper and blog headlines for interfering with user control over their contacts. *Path* was a social network built primarily through mobile phone applications on the iPhone and Android devices.¹¹ *Path* focused on photo sharing and competes with the *Instagram* network, which is owned by Facebook. A programmer from Singapore named Arun Thampi discovered the interference while creating a social networking application using the *Path* API.¹² He began investigating the *Path* API while using a man-in-the-middle proxy tool to examine specific API calls and learn how the calls operate.¹³ As Arun stated on his blog:¹⁴

*Upon inspecting closer, I noticed that my **entire address book (including full names, emails and phone numbers)** was being sent as a plist to Path. Now I don't remember having given permission to Path to access my address book and send its contents to its servers, so I created a completely new 'Path' and repeated the experiment and I got the same result—my address book was in Path's hands. [Emphasis in original.]*

Thampi discovered that users signing up with *Path* would have their mobile address book copied to *Path*'s servers without notification. Users responded to Thampi's discovery quickly. Many left negative reviews on Apple's App Store. The technical press picked up the story, and it eventually spread to larger media outlets like *USA Today* and *The New York Times*.¹⁵ Dave Morin, the CEO and Cofounder of *Path* as well as an early employee at Facebook, responded to Thampi's blog post

by saying, in part, “We upload the address book to our servers in order to help the user find and connect to their friends and family on *Path* quickly and efficiently as well as to notify them when friends and family join *Path*.” Eventually, Morin also apologized at length on *Path*’s company blog: We believe you should have control when it comes to sharing your personal information. We also believe that actions speak louder than words. So, as a clear signal of our commitment to your privacy, ***we’ve deleted the entire collection of user uploaded contact information from our servers.*** Your trust matters to us and we want you to feel completely in control of your information on Path. [Emphasis in original.]

Path’s privacy violation is strikingly similar to the 2010 violation by Google Buzz, which is a different social networking service.¹⁶ Google users were invited to “Try Buzz in Gmail.” Those who accepted the invitation, found that *Buzz* had automatically begun following those Google users contained in the invitee’s Gmail contacts, which were also made publically available for others to see. Like Google Buzz, *Path* wanted users to connect conveniently with friends on their network. To that end, both Google and *Path* used contact information that was originally collected for one purpose (e.g., private email, phone calls) for another secondary purpose (e.g., bootstrapping social network relationships). Users formally complained about Google Buzz to the FTC, and the FTC found that Google had used deceptive business practices. As a part of the settlement, Google was required to have third-party companies audit its privacy practices for the next 20 years.

Consider one important difference between Google Buzz and *Path*’s use of address book information: Who was responsible for the interference? Since Google maintained copies of both the contacts and the application that used the contacts for the secondary purpose, the Google Buzz violation is rather clear. However, the other case is not as simple. *Path* obviously created the application and infrastructure to upload users’ contact information. However, as a part of Apple’s App Store policies, Apple claims to verify that third-party applications meet their standards. Apple is also responsible for providing the API platform that enables *Path* programmers to gain access to the user’s contact list. It is reasonable to say that both companies, Apple and Path, share some of the responsibility for this interference and are exposed to litigation risks.

The FTC has received multiple complaints in regard to mobile access to contact lists. A class action lawsuit was filed against more than a dozen mobile application makers, including Path and Apple, for their use of address book information

without user consent.¹⁷ At the time of this writing, the outcome of this lawsuit has not been decided. However, based on newspaper accounts of the situation, Path appears to have violated the first three Fair Information Practice Principles (FIPPs) recommended by the FTC: notice/awareness, choice/consent and access/participation.¹⁸ Users were not aware of the collection, they were not provided a choice regarding whether they would like to share their contacts when they started using *Path*, and they were not given appropriate access to all the information *Path* obtained about them. Each of these points has since been addressed as a part of the API calls that allow third-party developers to access address book information on Apple's iOS.¹⁹

While the Google *Buzz* and *Path* cases both illustrate a privacy violation, technologies that mine email inboxes and contact lists to populate social networking sites are available in ways that conform to the FIPPs. For example, Facebook and LinkedIn both use technologies where the user chooses whether to mine their contacts to expand their network. By offering a choice, these IT systems allow users to decide whether the advantage of easily improving their social networking experience through automated contact population is valued over the risk of exposing their personal information to unwanted contacts. Moreover, other safeguards could be used to ensure these services do not exceed their intended purpose, including controls in the software to ensure the service does not collect complementary information, such as the dates, subjects or contents of email messages or dates when calls were placed on the mobile phone.

7.2.3 Behavioral Advertising as Decisional Interference

Electronic commerce on the internet often depends on advertising-based revenue models. The FTC reported to Congress that internet advertising revenues for 1996 totaled \$301 million.²⁰ Only five years later, in 2001, internet advertising revenues rose to \$7.2 billion; by 2007, this number had risen to \$21.2 billion a year, with search-based advertising from companies like Google and Yahoo comprising 41 percent of that total.²¹ In 2018, advertising revenues surpassed \$100 billion for the first time, topping out at \$107.5 billion, with \$69.9 billion on mobile devices that did not exist in 2007.²² Advertisers spend billions of dollars every year on advertising, and, increasingly, they aim to target their ads to users whose behavior indicates they are more likely to purchase their products.²³ This can be a win for consumers and for advertisers: Consumers hear about new

products that improve the quality of their lives, while advertisers are able to more efficiently spread the word about their products.

However, behavioral advertising technologies can raise concerns about interference. The FTC stated that some uses of behavioral advertising interfere with consumer expectations of privacy.²⁴ Government interest in protecting consumers from unfair interference has continued since those reports. In 2007 and 2009, the FTC issued separate documents with guidelines for balancing consumer interests with those of advertisers, both of which were based on discussions held by the FTC prior to release.²⁵ Unfortunately, the difficulty of estimating the value of privacy hampers efforts to balance economic interests with individual privacy expectations.²⁶ An empirical study on the effectiveness of behavioral advertising reported that it could improve advertising effectiveness by at least 670 percent.²⁷ This is a powerful economic motivator for advertising companies, and it resulted in scrutiny from the FTC, U.S. Senate, and the U.S. House of Representatives.²⁸

Early internet advertising consisted primarily of static banner ads placed on sites thought to have visitors who would be interested in the products being advertised. Google Gmail popularized contextual advertising, which leverages user-provided content to deliver ads. Contextual advertising uses an algorithm to examine the content of a page and determine which ad is most relevant to that content. If you were reading an email on Gmail about genealogy, you might be served an advertisement for genealogy software. Behavioral advertising works differently, by constructing a longitudinal profile of an individual's interests and serving ads based on that profile rather than the content on the page. For example, a NASCAR fan might spend considerable time online reading about the latest NASCAR news, following the races and reading personal biographies of the drivers. Behavioral advertising would detect this trend and could select ads based on auto sports advertising across other websites, even when the user wasn't browsing sites related to that topic.

There are two approaches to behavioral advertising: first party and third party. In first-party behavioral advertising, the party with which the user initiated communication is also the party collecting user behavior to create the profile. There are many approaches to first-party behavioral advertising, and not all of them involve sophisticated technology.²⁹ Amazon.com's recommendation service illustrates first-party behavioral advertising.³⁰ Amazon monitors which products a user views before making a purchase, and its site recommends products to users

who have demonstrated interest in related products. The assumption is that similar behavioral profiles will be interested in similar products, or that some products complement each other. Direct access to customer behavior and purchasing decisions is only possible in first-party behavioral advertising systems.³¹

In third-party behavioral advertising, the ad is delivered by a party different from the party with which the user initiates the communication. Websites regularly partner with third-party advertisers to support their website's business. Third parties may work with numerous first-party websites, collecting user profile data across multiple types of sites, such as news, weather, entertainment and travel websites, and delivering ads to users as they surf from one website to another. For effective third-party behavioral advertisers, the accuracy and relevance of the ads is assumed to improve as the number of websites with which a third-party advertiser works increases.³² Behavioral advertising has also been shown to be more effective over short sessions than over long-term profiles.³³

Advertisers using third-party behavioral advertising can use one of two techniques to construct behavioral profiles: web-based profiling and network-based profiling. Web-based profiling uses browser-based technology to track users as they surf the internet. This technique can only collect information on websites with which the advertiser has partnered. Network-based profiling provides more access to user behavior by partnering with internet service providers (ISPs), who provide users with connectivity to the internet. With this level of access and deep packet inspection (DPI), these advertisers can create behavior profiles based on all of a user's network traffic. Network-based behavioral advertising provides ISPs with an additional revenue source to improve the quality their infrastructure, but it poses the most serious risk of interference because of the exceptional level of access to user data.³⁴ Browser plug-ins that users may employ to obstruct behavioral advertisers from monitoring their website usage behavior are ineffective against network-based behavioral advertising. End-to-end encryption can be used to conceal the content of messages, but often not the original headers needed to route the information across the network.

When customers are aware of behavioral profiles and have control over the profiles, behavioral advertising can be mutually beneficial. Consider Amazon's recommendation service. Users often appreciate that they are introduced to products relevant to their interests.³⁵ Behavioral profiles can be used in numerous ways to personalize consumer experiences. For example, someone interested in

true crime dramas may want product lists for television shows and fiction books to display those options more prominently. Personalization is explicitly not advertising. Individuals who have signed up for Netflix or a similar television- and movie-streaming service may want their behavioral profile to influence the options displayed to them simply for convenience and usability. Consider personalized web search engines that take into account the types of searches previously performed and the types of links the user has found useful. Some users may find such an engine far more efficient for their needs if the personalized search results more effectively address what they are looking for. These personalized services require the construction and maintenance of at least a minimal behavioral profile, even if it is as simple as grouping individuals into broad consumer groups or market segments.

The existence of behavior profiles requires responsible organizations to follow safe privacy practices. If organizations maintain but never use the behavior profile that they create, they should still notify users that the profile exists, explain to the users what the purpose of the profile is and seek consent while providing users an opportunity to participate. The mere existence of a behavioral profile may constitute a subjective privacy harm under Calo's taxonomy.³⁶ When users are unaware that they are being profiled and have no control over it, many become concerned. In May 2008, Charter Communications, a U.S. internet service provider, partnered with NebuAd, a behavioral advertising company, to create network-based behavioral profiles and serve ads to its customers. Unfortunately, customers were mostly unaware of the program, and those who were aware complained to U.S. Congress, which held hearings regarding the use of the technology. Although the hearings themselves did not directly result in damages, NebuAd lost its ISP partners, and the company eventually stopped developing behavioral advertising technologies.³⁷

The 2008 U.S. congressional hearings on behavioral advertising technologies did not result in specific legislation; however, advertising has historically been the subject of extensive regulation designed for consumer protection.³⁸ It is worth noting that European regulation of behavioral advertising technologies has decreased consumer satisfaction with purchasing decisions based on advertising.³⁹ Losses in advertising effectiveness adversely affect smaller businesses that don't have the resources for larger, traditional advertising campaigns to promote their innovations.⁴⁰

Behavioral advertising is regulated differently depending on the jurisdiction. In 2008, Dr. Richard Clayton from the University of Cambridge posted an analysis of Phorm's Webwise system, which tracks user behavior for the purpose of serving ads.⁴¹ He argues that Phorm's system violated the UK's Regulation of Investigatory Powers Act of 2000, which makes interception of electronic communications illegal. Phorm's system intercepted communications using DPI and altered the way ads were served to the user. For this system to work, Phorm needed to partner with ISPs willing to provide access to their infrastructure and allow the modification of in-flight communications. In the UK, its partner was British Telecom, which eventually dropped Phorm as a partner because of the privacy concerns raised.⁴²

Behavioral advertising technologies have been shown to be effective. What lessons can we learn from an examination of them? Amazon.com's success may suggest that providing users control over how they are tracked is more acceptable than, say, network-based approaches to behavioral advertising, such as those used by Phorm and NebuAd. In addition, behavioral advertising is a unique combination of interference-prone technologies: the behavioral model, which aims to represent who the person is (Type 2), thus enabling decision-making (Type 1) and the sending of the personalized ad that describes this person's behavior and can reveal that behavior to others who see the ad, thus exposing this person to intrusions on their self-representation (Type 3). As more behavioral data became available for processing, new statistical analysis techniques proved capable of capturing and modeling ever-more-nuanced correlations based on this data. These methods, called machine learning methods, also often capture and model latent or explicit biases in the data they are provided. In Section 7.2.4, we examine how to apply our framework to scenarios involving machine learning.

7.2.4 Machine Learning Bias and Fairness

Machine learning systems based on statistical analysis of large amounts of data are nearly ubiquitous and almost unavoidable.⁴³ These systems are becoming crucial in a wide range of human endeavors, including credit scoring, financial trading, dispute resolution, search engines, recommendation systems, public health, medicine, policing, dating, political campaigns and scientific discovery.⁴⁴

Machine learning systems can produce results that are uncannily accurate and undeniably useful. When they fail, however, explaining the how and why of a particular result from typical machine learning systems is extraordinarily

difficult.⁴⁵ And although machine learning systems can do surprisingly powerful things, such as beating *Jeopardy!* champions, they can also be biased.⁴⁶ For example, in 2013, Sweeney found that personalized advertising served from search engines differed depending on the race name being searched.⁴⁷ For example, searching for names like Latanya and Latisha resulted in advertising suggestive of arrest records and criminal activity, whereas names like Kristin and Jill did not. Sweeney suggests considering how search results like this might impact people who are applying for a job.⁴⁸ From the perspective of job applicants, this constitutes interference under both Type 1, because such a result could obstruct them from obtaining the job, and Type 2, because this result affects how they are perceived.

The *Loomis v. Wisconsin* case demonstrates another important example.⁴⁹ Eric Loomis was arrested in February 2013 and eventually convicted of eluding the police.⁵⁰ During his sentencing, an algorithm called *Compas* was used to estimate the risk that Loomis would commit another crime.⁵¹ Northpointe, Inc., the company that developed *Compas*, claims that its system is backed by research but does not explain how it works. For the moment, consider that this algorithm could be built using a machine learning system. The input data could simply be historical rates of recidivism calculated using arrest records from the last several decades. Calculating a recidivism risk for someone like Loomis, a 34-year old registered sex offender arrested for driving a car that was used in a shooting would be relatively easy, but would it be fair? If bias exists in the data used to train the machine, such as bias about overpolicing minority neighborhoods or underenforcement of white-collar crimes, then recidivism rates will be similarly biased.⁵² One could argue that using historical records generated by an imperfect justice system with both known and implicit structural biases is patently unfair, and that any resulting machine learning system would only serve to hide any problems in the current justice system behind the authority of a computed result. This argument holds despite the fact that the algorithm correctly predicts historical examples from the training data. In our classification, this could be representative of all three types of intrusion. Loomis claimed that the use of a secret, proprietary algorithm violated his due process rights under the Fifth Amendment of the U.S. Constitution and appealed the case to the Supreme Court, where cert was denied.⁵³ For technologists building information systems, however, the question remains: What makes such machine learning systems fair?

Transparency is a tempting answer, but under examination it proves to be less useful than it might appear at first. Although transparency may make information accessible, that information may remain incomprehensible.⁵⁴ Also, transparency may simply provide too much data to examine manually, forcing either a direct evaluation by another algorithm or an indirect evaluation by comparing other approaches. Imagine that Northpointe chose to release the data and algorithms used in *Compas* to make sentencing recommendations. Could Loomis be satisfied that he was treated fairly if there were so much data that it could only be examined using another machine learning system? If the data were regularly updated, then would due process requirements for transparency force Northpointe to store each incremental update used? These are nontrivial questions to answer, and similar to problems with transparency in machine learning systems.

Approaches based on fairness, rather than transparency, are promising, although no one approach is dominant. After all, the notion of fairness is the explicit goal of the FIPPs, which are already applied as a regulatory standard by the FTC. Dwork et al. proposed a mathematical approach to fairness based on similar treatment of individuals who are similar to one another with respect to a task.⁵⁵ Because their approach is mathematical, they can treat fairness as an optimization problem, ensuring efficiency.⁵⁶ They are also able to apply statistical analyses to ensure parity across groups as well as individuals.⁵⁷ Unfortunately, as Dwork et al. demonstrate, there's often a tension between statistical group parity and individual fairness due to differing base rates among groups.⁵⁸

Tensions between group fairness and individual fairness may be exacerbated by individuals who belong to multiple groups that are commonly discriminated against. For example, the lived experience of a black woman may be holistically different from a simple combination of the lived experience of a black man plus the lived experience of a white woman.⁵⁹ Although algorithms can be developed to model and account for these intersectional concerns (e.g., see the recent work from Foulds and Pan), the tradeoffs of these approaches must also be incorporated and evaluated in measures of statistical parity.⁶⁰ Kleinberg et al. demonstrated that tensions between fundamental elements of fairness may make them incompatible with one another.⁶¹ Trade-offs that may have made sense under some initial conditions and data collection may no longer make sense after some time and additional data collection.

So, how should practitioners handle bias and fairness in machine learning? This is an ongoing, rapidly changing concern and an active area of research for both

technologist and legal analysts, but three high-level guiding principles should be considered both now and in the foreseeable future. First, organizations should define and document their goals for fairness along with their rationale and approach to achieving those goals. Technologists, policy analysts, and legal experts must work closely to ensure that their algorithms and automated decisions remain in line with their goals and policy choices.⁶² Second, practitioners must be able to recognize when machine learning systems are not an appropriate solution to a problem. As Eubanks points out while referencing her case study on an algorithmic system designed to address the homelessness crisis in Los Angeles, “Systems engineering can help manage big, complex social problems. But it doesn’t build houses, and it may not prove sufficient to overcome deep-seated prejudice against the poor, especially people of color.”⁶³ Third, machine learning systems are capable of all three types of interference discussed in this chapter. Such systems can use massive financial data that might make it more difficult, fairly or not, for people to borrow money (Type 1). They could subject people to pervasive data collection about their daily lives and activities to provide them better services, including public services (Type 2). They could present to others an image that some may find unflattering or offensive, such as offering to search for arrest records for people with names like Latanya (Type 3).

Machine learning systems may pose additional problems not easily addressed by our classification of interference as a privacy concern. For example, the risk that a machine learning system makes it harder for someone to borrow money differs from an intentional decision to intervene on a particular individual’s decision to borrow. Risk-based, inferential or hypothetical harms have not found traction in current law.⁶⁴ Machine learning systems pose real, if sometimes indirect, privacy risks, and it seems likely that these will be addressed through regulation in the future. Other privacy concerns are more personal and direct. In Section 7.2.5, we discuss several ways to reduce unwanted interference in complex personal interactions mediated through technology.

7.2.5 Cyberbullying as Interference with Personal Identity

Warren and Brandeis were originally inspired to write their law review article defining privacy as “the right to be let alone” due to the invention of the snap camera, a then-new concept that allowed a photographer to quickly take a clear picture without requiring individuals to pose.⁶⁵ Today, such technology is common, and although it continues to enable interference with privacy, a culture

has developed around the use of cameras that allows us to craft reasonably stable social policies to deal with violations. In this section, we examine modern a privacy concerns involving real images captured from remotely accessible web cameras and fake images generated and used for malicious purposes.

On September 22, 2010, a freshman at Rutgers University named Tyler Clementi committed suicide.⁶⁶ Three days prior, his roommate, Dharun Ravi, and Ravi's friend, Molly Wei, had used a webcam to spy on Clementi to confirm Ravi's suspicions that Clementi was gay. After recording Clementi with another man, Ravi posted the video and tweeted about the incident, stating, "Roommate asked for the room till midnight. I went into Molly's room and turned on my webcam. I saw him making out with a dude. Yay."⁶⁷ Clementi read the tweet the next day and requested a room change. Ravi continued to spy on Clementi and invited Twitter followers to watch a second video.⁶⁸ Shortly thereafter, Clementi killed himself.

Clementi's suicide became an international news story about the seriousness of cyberbullying that was picked up by ABC News, CNN, *USA Today*, the BBC and numerous other major media outlets. Ellen DeGeneres said Clementi was "outed as being gay on the internet, and he killed himself. Something must be done."⁶⁹ Ravi and Wei were indicted on two charges of invasion of privacy, one for each spying incident. Ravi was additionally indicted on witness- and evidence-tampering charges. Wei reached a plea agreement for her testimony against Ravi, who was convicted and sentenced to a 30-day jail term.⁷⁰

In 2011, New Jersey enacted the Anti-Bullying Bill of Rights, which was prompted in part by Clementi's suicide.⁷¹ The Anti-Bullying Bill of Rights was designed to address concerns that Ravi's trial and conviction were not adequate responses to his actions. In particular, it explicitly states that students have a right not to be bullied and that speech that "substantially disrupts or interferes with" a student's rights is a violation of the law.⁷² Although the law may be overly restrictive of speech, it is clearly based in the traditional definition of privacy as the right to be left alone.⁷³

Information technology enables a fundamentally different type of bullying: One that is no longer ephemeral or confined to the event or instance but instead persists and compounds as others gain access to participate through the use of IT communications. Researchers Alice Marwick and danah boyd have written extensively about youth culture and bullying. They note that teenagers want to view themselves as "in control of their lives," so they downplay the things they cannot control as mere drama when those things could be quite serious.⁷⁴ This was

certainly true of Tyler Clementi. Shortly after Ravi tweeted about the first time he spied on Clementi kissing another man, Clementi spoke with Hannah Yang, a friend of his from high school.⁷⁵ When Yang suggested that the incident was a serious violation of Clementi's privacy, Clementi downplayed it.⁷⁶

Clementi's case demonstrates how devastating a personal privacy intrusion may be, but cyberbullying no longer requires physical access to an individual to violate their privacy. Fake content or interactions with fake users can constitute interference without any physical access, and intrusions based on fake content can affect millions of people at once because these interactions don't require physical access. While IT professionals may not be able to prevent users from cyberbullying, they can introduce mechanisms to reduce or thwart the effects of bullying by allowing users to report bullying and to quickly respond to reports. Planning in advance for cyberbullying through one's product or platform is a much stronger position than reacting later and downplaying the frequency or seriousness of an event or diminishing one's role as only the technology provider. In fact, Section 230 of the Communications Decency Act (CDA) was explicitly designed to protect companies that take a proactive approach to addressing detrimental conduct on their platforms.⁷⁷

Fake product reviews are a common form of interference based on fake information.⁷⁸ Consumers trust product reviews and rely on them when making purchasing decisions.⁷⁹ Pan and Zhang describe in some detail what makes a product review helpful from the perspective of a consumer.⁸⁰ Nefarious actors can take advantage of this trust to create extremely effective fake product reviews and boost sales, whether they are the product creator, platform owner or an entity in the middle of the supply chain. This use of modern technology violates ethical norms that guided advertising in the decades prior to widespread adoption of the internet, and this sort of deception is precisely the kind of consumer protection the FTC was created to enforce.⁸¹ To that end, the FTC has produced and updated disclosure guidelines for advertisers to ensure consumers are able to differentiate between legitimate user-generated content and paid or faked reviews.⁸² The FTC has also begun bringing cases against companies purchasing fake reviews.⁸³

Fake users present another increasingly common form of interference. The internet has always allowed people to create fake interactions ranging from a single fake profile targeted to deceive a single person (called *catfishing*) to whole armies of fake profiles designed to change public opinion (called *sockpuppeting* or *astroturfing*). The rise of social media along with new, powerful artificial

intelligence (AI) technologies, however, has made this much more efficient, effective and dangerous.⁸⁴ Social bots can “mislead, exploit, and manipulate social media discourse with rumors, spam, malware, misinformation, slander, or even just noise.”⁸⁵ Social bots have been used to stoke political unrest, manipulate the stock market and systematically abuse women and minorities online.⁸⁶ All of these examples constitute interference. Surreptitious efforts to sway public opinion are inherently Type 1 violations because their goal is to affect decision-making. Other examples, particularly abusive examples, are Type 2 violations seeking to intrude on or damage psychological or informational spaces. Social bots are increasingly difficult to distinguish from actual human users, and platforms must develop new technologies to address this ongoing challenge.⁸⁷

Recent advances in AI and machine learning have also allowed for the creation of extremely realistic—but entirely fake—audio, video and photographic content called *deepfakes*.⁸⁸ Suwajanakorn et al. developed an early example of this technology by capturing President Obama’s speech patterns and lip syncing them to an arbitrary audio file using recurrent neural networks.⁸⁹ Their results produced a realistic video of President Obama saying something he never actually said.⁹⁰ Perhaps the first real-world intrusive use of this technology was the creation of pornographic videos using the faces of well-known celebrities, but the technology is generalizable and may profoundly affect many areas of our lives, even threatening our national security or democracy itself.⁹¹

Deepfakes present profound technical and social challenges. From a technical standpoint, the most effective means of detecting deepfakes uses the same technology that created them: neural networks.⁹² This pits one AI system against another in a never-ending arms race of more realistic creation and more sophisticated detection. Detection is also only useful against some of the harms caused by deepfakes. For example, platforms that can detect a deepfake quickly can filter it out, exposing relatively few people and limiting the harm. This can be an extremely important tool for platforms. People acquire information from a wide variety of sources without easily verifying the accuracy of that information, and people tend to share negative and novel information more readily than positive or unsurprising information.⁹³ Both of these tendencies make compelling, realistic deepfakes extremely dangerous for society.

At the individual level, detection alone may be largely ineffective. Consider a recent application called *DeepNude*, which realistically removed woman’s clothes from online images using generative adversarial networks.⁹⁴ Although the dataset

used to create this application was relatively small, it produced frighteningly realistic results. If a malicious actor simply wants to embarrass or threaten a particular woman, they do not necessarily need mass distribution, because simply providing the images to select individuals would suffice. A rape threat accompanied by realistic imagery may be more difficult for the victim.⁹⁵ Worse, conclusively proving images are deepfakes to protect oneself in a court proceeding, to save an otherwise sabotaged relationship or for any number of other reasons, may be more intrusive than the images themselves. Although these examples all focus on deepfakes, other convincingly faked individual content, such as faked handwriting, financial records, legal documents and so on, may prove similarly challenging to address.

The technologies used to create social bots and deepfakes are also being developed by companies for legitimate business purposes. Companies now use chatbots to engage with customers for financial services, initial healthcare triage, technical support, customer service, scheduling and legal services.⁹⁶ In 2011, Gartner predicted that eventually 85 percent of online interactions with customers would be through chatbots.⁹⁷ At Google's I/O Developers Conference in 2018, Google introduced a voice assistant developed using machine learning technologies called *Duplex* that sounds remarkably similar to an actual human, even mimicking human interjections and non-lexical conversation sounds like, "mmhmm" and "uhh" to appear more realistic.⁹⁸ Initial reactions to this hyper-realistic voice indicate that it was "scary as hell" and that it had potential to further erode privacy.⁹⁹ More recently, Apple introduced a feature called "FaceTime Attention Correction" in a beta of iOS 13.¹⁰⁰ The goal of this feature is to make FaceTime calls feel more like actual face-to-face conversations by adjusting users' eyes, which are normally looking at the screen, to appear as if they were looking directly at the camera above the screen.¹⁰¹ Initial reactions to this feature range from calling it "actually a huge improvement" to "overstepping a line of creepiness."¹⁰²

The technical achievement and promise of social bots and machine learning technologies is impressive. They could, for example, eventually be used with augmented reality (AR) glasses to overlay driving directions directly onto the driver's field of vision.¹⁰³ However, cyberbullying and other malicious uses also seem to have an unlimited potential. AR glasses could just as easily be developed to virtually undress women as they could be used to help drivers. Intelligent assistant technologies designed to help with appointment scheduling, shopping

for clothes or assisting with banking could be used to gaslight, catfish or scam unknowing victims at a scale only possible with modern computing platforms.

In this section, we observe how information collection, specifically surveillance, can be used to expose otherwise hidden details about an individual to a broader audience or to fabricate information about an individual to such an audience (a Type 3 interference). In an earlier case, *Path* used an API to gain access to the user's contact list. This activity was a design decision implemented as part of the company's product offerings. In this section, however, we have a situation where individuals use technology to interfere in the affairs of other individuals with the intent to pressure those individuals. When these cases arise, they may use a company's products to disseminate the covertly collected or fake information. While companies may not be able to monitor all uses of their technology, they can include features that help good citizens report abuses that limit the overall impact of the interference. In addition, they can contractually obligate users to conform to a code of conduct that requires users to respect the privacy of other users and avoid using the technology in inappropriate ways.

7.2.6 Social Engineering and Interconnected Systems

On August 6, 2012, a hacker used security flaws at Amazon and Apple to compromise Mat Honan's digital identity.¹⁰⁴ His Twitter account, Gmail account, Apple ID and Amazon.com account all appeared to have been compromised.¹⁰⁵ He first noticed that his iPhone was rebooting. Before he noticed that he wasn't able to connect to his Google calendar, his laptop rebooted and started asking for a four-digit pin that he hadn't set, and his iPad became inaccessible.¹⁰⁶ Meanwhile his Twitter account, which was connected to a company Twitter account, was tweeting racist and homophobic messages.¹⁰⁷ Honan initially believed that his password had been cracked using a brute-force attack, because the password he used was only seven characters long and rather outdated.¹⁰⁸ Instead, the hacker claimed to have gained access to the Twitter account by exploiting two flaws in Apple's and Amazon.com's account recovery services.¹⁰⁹ First, the hacker called Amazon.com by phone to add a credit card to Honan's account. At the time, Amazon.com allowed any caller to add a credit card if they provided the customer's name, email address and physical address, all of which were easily obtained. In addition, Amazon.com only required the last four digits of a credit card on file to change the email address on an account. Thus, the hacker called back a second time and used the last four digits of the credit card they had

provided to reset the email address. Once the email address was changed to an account that the hacker had access to, he was able to reset the Amazon.com password and view the account details.

With complete access to Honan's Amazon.com account, the hacker was able to see the last four digits of the Honan's credit card on file. He assumed this was the same card that was on file with Honan's Apple ID account, and he proceeded to use those digits to gain a temporary password for Honan's Apple ID account. Surprisingly, Apple reset the password despite the fact that the hacker was unable to correctly answer the security questions that Honan established for his Apple ID; this was a violation of Apple's policies.¹¹⁰ Using Honan's Apple ID, the hacker was able to reset Honan's Twitter password and Gmail password through Honan's Apple-based email service. At this point, the hacker had control of the Twitter account, so he proceeded to remotely wipe Honan's various Apple products to prevent Honan from recovering access to the Twitter account.¹¹¹ To the credit of both Amazon.com and Apple, both companies remedied these security flaws after the story was published.¹¹² However, this section illustrates how social engineering tricks can be used to manipulate people and IT systems to gain access to a person's information and, in this case, the company Twitter account that is used to represent both Mat Honan and his company.

Social engineering is any means of using psychology to manipulate people to do something that divulges valuable information or provides access to valuable property. When combined with even rudimentary knowledge of technology, social engineering is a powerful technique that attackers can use to interfere with user privacy. Kevin Mitnick is famous for extensively using social engineering techniques to access computers and avoid capture by the U.S. Federal Bureau of Investigation (FBI).¹¹³ Mitnick would prey on people who wanted to be helpful. Most folks find it hard to say no to someone in need. The employees at Amazon and Apple didn't know that the hacker wasn't really Mat Honan, and the security measures required to prevent such an imposter were insufficient.

Malicious users can interfere with security processes to obtain access to another user's account and information. In Honan's case, social engineering was used to manipulate a human decision process in the customer service center to transfer the data needed to exploit an automated process to reset an account password. This form of interference was further used to gain access to a Twitter account, after which the malicious user made misrepresentations of the actual account holder. IT architects and other professionals should consider how their supported

business processes (both human and machine-controlled) are vulnerable to exploitation by social engineering for conducting privacy attacks.

7.2.7 Administrative Intrusions into Personal Spaces

Organizations often use supervisors to ensure that employees or other members of the organization conform to organizational practices and procedures. This can occur within workplaces, schools and other environments affected by social and political power relationships. In 2010, the FBI investigated the Lower Merion School District in Pennsylvania for using webcams on school-issued laptops to spy on students at home.¹¹⁴ School administrators ensured that student laptops had installed software to allow them to remotely control the machine and ensure that students were not violating school rules. (Although breaking school rules is often less serious than committing a crime, students are usually not free to leave or choose a competing school as a customer might in a traditional business environment. In most jurisdictions, education is compulsory for children of a certain age, and students are considered to be a protected population. Similarly, employees have rights at a workplace that may supersede an employer's right to monitor their actions.) For students at Lower Merion, this administrative monitoring extended to outside the school environment because students were permitted to bring the laptops home. When an administrator claimed that a student had been involved in inappropriate behavior because they had observed the student in their home, the presence of this monitoring came to light. Parents and students brought a class action lawsuit against the school district that was eventually settled out of court.¹¹⁵ The idea of creating software to ensure students aren't misusing school-issued equipment is compelling to school administrators.¹¹⁶ The challenge presented by mobile computing in these situations is that companies or schools that issue property to their employees or students may think their policies may be extended into places where these devices can be carried.

Consider the 2010 U.S. Supreme Court decision in *City of Ontario v. Quon*, which concerned employee privacy rights in the use of employer-provided mobile communications technology.¹¹⁷ The police department for the City of Ontario, California, purchased electronic pagers for officers in its special weapons and tactics (SWAT) unit. These pagers were covered by an internal policy document that allowed some limited personal use of the device. When Sergeant Jeff Quon exceeded his messaging limit several times, the police department obtained

transcripts of his messages to determine whether his overages were work related. Many of Quon's messages were personal and sexually explicit in nature, and he was disciplined. Quon sued, claiming the monitoring was an interference with his privacy. Eventually, the Supreme Court decided that the Ontario Police Department performed a work-related audit, and therefore it was not a violation of Quon's privacy.

While there are valid reasons for this kind of monitoring (for example, protecting intellectual and physical property or auditing employee use of work-related equipment, as in the Quon case), organizations must assess the extent to which this kind of monitoring would interfere with the broader sense of privacy that their employees or students would normally enjoy. No organization should be eager to find itself in a legal battle over administrative monitoring of employees, students or other protected populations. Within our framework, administrative intrusions include encroaching on personal spaces (Type 2) and potentially decisional interference (Type 1) as the information obtained can be used to invoke policies that would otherwise govern the individual under the administration of their organization.

7.3 Summary of Lessons Learned and Recommended Steps of Action

As noted in Table 7-2, each of the five cases illustrates different examples where interference has led to privacy harm. For IT professionals, the challenge is to design their systems and business practices in ways that can reduce the risk or negative outcome of privacy harm. In addition to following the FIPPS or another set of accepted privacy principles, we make the following recommendations based on our review of technological perspectives, while we note this list is by no means complete.

Recommendation 1: Acquire insight into the privacy preferences of those individuals directly or indirectly impacted by your data practices. Focus groups such as those discussed in Chapter 2 can be used to survey users and understand how they view privacy under different scenarios. Focus groups can be conducted anonymously so that the company's brand is protected, and the data can be used to avoid consumer churn that may result in gross violations of privacy. In addition, consumer protection agencies, civil liberties groups and other nongovernmental organizations may be able to help define and codify privacy norms for the

individuals in various jurisdictions. For example, in the United States, the FTC maintains extensive recommendations for data privacy practices.

Recommendation 2: If data collection can be used for any kind of interference, notify the individual about the purpose and, if possible or required by law, allow the individual to opt in or opt out. Data collection processes exist in any virtually every organization, and the data collected by business processes can be extremely sensitive and valuable. In addition to limiting the uses of data to the original purposes for which it was collected, the organization should engage with the person to ensure that uses are consistent with user preferences. In the second perspective, repurposing the contact list to provide new services was unwanted and could have been avoided for users who would not have opted in. Avoiding unnecessary reuse of sensitive information or asking for permission to use collected data for new purposes can reduce interference.

Recommendation 3: Before intruding into a person's private affairs (physical, psychological or self-representation), ensure the technology provides an opportunity for the person to control or limit the intrusion to appropriate times. When a technology is likely to engage with a person in a physical location, attempt to understand the consequences of that engagement. Is the person at work or attending an intimate event with family members? Understand how the engagement might affect the person emotionally. Would the engagement violate contextual integrity by expanding access to sensitive personal information?¹¹⁸ Finally, consider how the engagement can affect a person's self-image and recognize that individuals control these personas by limiting who has access to different versions of themselves.

Recommendation 4: If data is used to make critical decisions that can deny individuals specific benefits, introduce safeguards to detect inaccuracies. Allow individuals to be aware of the decisions through notices, and allow them access to provide opportunities to review the data for accuracy. Increasingly, decision-makers are finding novel ways to gain insight into people's behaviors. As we observed in the third perspective, data can be used to personalize services to individuals. Other examples of decision-making include financial and employment decisions, or decisions about granting access to private information. When data is inaccurate, such as in the altered email address at Amazon.com, the effects of automated decisions can be unpredictable and prone to violate a person's privacy. Even without explicitly inaccurate data, the data available may be biased. Using incarceration data in a machine learning system to produce

sentencing recommendations could result in unfair outcomes if the law enforcement system that created the incarceration data were biased.

Recommendation 5: React quickly to customer concerns. Monitor customer reactions and events and take immediate action to reconcile unwanted interference. Path's reaction to customer complaints was swift and likely saved the company quite a bit of bad press. Similarly, Amazon and Apple reacted quickly to change the policies that led to Mat Honan's hacking. Understand that reacting quickly to customer concerns requires preparation and planning. Reading about these technological perspectives in retrospect can inform the planning that is required to ensure that a company can quickly respond when a customer complains. Responding to a complaint re-establishes an individual's sense of control over the situation when that control is lost through interference.

Recommendation 6: Assume that interference will occur, and plan for it. General-purpose technologies are likely to have both ethically good and ethically bad uses. No IT developer, designer or organization can prevent all forms of privacy violation or security breach. Therefore, it is critical to have a response plan in place and to practice implementing this plan. Conducting interference response drills can prepare a company for potential privacy violations caused by its products and improve its awareness so it can understand how its existing policies and technology help it respond to privacy threats.¹¹⁹ Consider the Tyler Clementi case. Ravi attempted to delete derogatory tweets and conversations. He was eventually convicted of evidence tampering. What policies and procedures needed to be put in place to ensure that Ravi's actions were not irreversible? How should employees of the University of Cambridge, Twitter and other organizations involved ensure that they can respond appropriately? Answering these questions requires planning and practice.

7.4 Summary

In this chapter, we described privacy, and thus interference, as an inherently individualistic social concern. We have also shown that the nature of privacy is such that it is impossible to develop a finite list of clearly defined ways interference can occur. To address and mitigate interference, we discussed several technological perspectives, and we generalized from these situations to report actionable steps IT professionals can take. Because privacy is a social construct, however, no technological solution or mitigation indefinitely addresses

interference concerns. Engineers must continually examine additional cases of interference, generalize from those cases new recommended practices they can adopt to address similar concerns in their products, and apply these recommendations diligently. By taking appropriate action, both engineers and lawyers can enable society to reap the benefits of information technology while limiting the dangers it presents to personal privacy.

Endnotes

- ¹ *New Oxford American Dictionary*, 3rd ed. (2010), s.v. “interference.”
- ² Samuel Warren and Louis Brandeis, “The Right to Privacy,” *Harvard Law Review*, vol. 4, no. 5, (1890): 193–220; Alan Westin, *Privacy and Freedom*, (New York: Atheneum, 1967).
- ³ Charles Duhigg, “How Companies Learn Your Secrets,” *New York Times*, Feb. 16, 2012. In 2010, the retail store chain Target began inferring when a woman was pregnant by her purchase of unscented lotions, special vitamins and large tote bags, among other items.
- ⁴ Omer Tene and Jules Polonetsky, “A Theory of Creepy: Technology, Privacy and Shifting Social Norms,” *Yale Journal of Law & Technology*, vol. 16, no. 59, (2013), <https://papers.ssrn.com/abstract=2326830>.
- ⁵ Ryan Calo, “The Boundaries of Privacy Harm,” *Indiana Law Review*, vol. 86, no. 3, (2011).
- ⁶ William Prosser, “Privacy,” *California Law Review*, vol. 48, no. 383, (1960).
- ⁷ Daniel J. Solove, *Understanding Privacy*, (Boston: Harvard University Press, 2008).
- ⁸ Solove, *Understanding Privacy*.
- ⁹ Dan Fletcher, “A Brief History of Spam,” *Time*, November 2009, <http://www.time.com/time/business/article/0,8599,1933796,00.html>.
- ¹⁰ Federal Trade Commission, “CAN-SPAM Act: A Compliance Guide for Business,” September 2009, <https://www.ftc.gov/tips-advice/business-center/guidance/can-spam-act-compliance-guide-business>.
- ¹¹ Previously available at <https://path.com>. Path shut down in September 2018.
- ¹² Arun Thampi, “Path uploads your entire iPhone address book to its servers,” February 2012, <http://mclov.in/2012/02/08/path-uploads-your-entire-address-book-to-their-servers.html>.
- ¹³ <https://mitmproxy.org/>.
- ¹⁴ Thampi, “Path uploads iPhone address book.”
- ¹⁵ Byron Acohido, “Apple moves to quell Path privacy gaffe,” *USA Today*, February 16, 2012, <https://content.usatoday.com/communities/technologylive/post/2012/02/apple-moves-to-quell-path-privacy-gaff/1>; Nicole Perlroth and Nick Bilton, “Mobile Apps Take Data Without Permission,” *New York Times*, February 15, 2012, <https://bits.blogs.nytimes.com/2012/02/15/google-and-mobile-apps-take-data-books-without-permission/>.
- ¹⁶ Federal Trade Commission, “FTC Charges Deceptive Privacy Practices in Google’s Rollout of Its Buzz Social Network,” March 30, 2011, <https://www.ftc.gov/news-events/press-releases/2011/03/ftc-charges-deceptive-privacy-practices-googles-rollout-its-buzz>.
- ¹⁷ Elinor Mills, “Privacy suit filed against Path, Twitter, Apple, Facebook, others,” *CNET News*, March 16, 2012, <https://www.cnet.com/news/privacy-suit-filed-against-path-twitter-apple-facebook-others/>.
- ¹⁸ Wikipedia, s.v. “FTC fair information practice,” last modified August 26, 2019, 20:55, https://en.wikipedia.org/wiki/FTC_fair_information_practice.
- ¹⁹ John Paczkowski, “Apple: App Access to Contact Data Will Require Explicit User Permission,” *All Things D*, February 15, 2012, <http://allthingsd.com/20120215/apple-app-access-to-contact-data-will-require-explicit-user-permission/>.
- ²⁰ Federal Trade Commission, *Online Profiling: A Report to Congress*, June 2000, <https://www.ftc.gov/reports/online-profiling-federal-trade-commission-report-congress-june-2000>.
- ²¹ Internet Advertising Bureau, “Internet Advertising Revenue Report: 2001 Full Year Results,” June 2002, https://www.iab.com/wp-content/uploads/2015/05/resources_adrevenue_pdf_IAB_PWC_2001Q4.pdf; Internet Advertising

- Bureau, "IAB Internet Advertising Revenue Report: 2007 Full Year Results," May 2008, https://www.iab.com/wp-content/uploads/2015/05/IAB_PwC_2007_full_year.pdf.
- 22 Internet Advertising Bureau, "IAB internet advertising revenue report," May 2019, <https://www.iab.com/wp-content/uploads/2019/05/Full-Year-2018-IAB-Internet-Advertising-Revenue-Report.pdf>.
- 23 A. Goldfarb and C. E. Tucker, "Online Advertising, Behavioral Targeting, and Privacy," *Communications of the ACM*, vol. 54, no. 5, May 2011, 25–27, <http://doi.acm.org/10.1145/1941487.1941498>.
- 24 Federal Trade Commission, "Online Profiling: A Report to Congress (Part 2): Recommendations," 2000, <http://www.ftc.gov/os/2000/07/onlineprofiling.pdf>; Federal Trade Commission, "Online Profiling: A Report to Congress (Part1)," June 2000, <https://www.ftc.gov/reports/online-profiling-federal-trade-commission-report-congress-june-2000>.
- 25 Federal Trade Commission, "Online Behavioral Advertising Moving the Discussion Forward to Possible Self-Regulatory Principles," December 2007, <https://web.archive.org/web/20080216182326/http://www.ftc.gov/os/2007/12/P859900stmt.pdf>; Federal Trade Commission, "FTC Staff Report: Self-Regulatory Principles for Online Behavioral Advertising: Tracking, Targeting, and Technology," March 2009, <https://web.archive.org/web/20090312054035/http://www.ftc.gov/os/2009/02/P085400behavadreport.pdf>.
- 26 B. Szoka and A. Thierer, "Online Advertising and User Privacy: Principles to Guide the Debate," *Progress Snapshot*, vol. 4, no. 19, September 2008, 6; D. J. Solove, *Understanding Privacy* (Cambridge: Harvard University Press, 2008).
- 27 J. Yan, N. Liu, G. Wang, W. Zhang, Y. Jiang, and Z. Chen, "How much can behavioral targeting help online advertising?" *Proceedings*, 2009, 261–270, <https://dl.acm.org/citation.cfm?doid=1526709.1526745>.
- 28 Federal Trade Commission, "Online Profiling: A Report to Congress (Part1)," June 2000, <https://www.ftc.gov/reports/online-profiling-federal-trade-commission-report-congress-june-2000>; Federal Trade Commission, "Online Profiling: A Report to Congress (Part 2): Recommendations," 2000, <http://www.ftc.gov/os/2000/07/onlineprofiling.pdf>; Federal Trade Commission, "Online Behavioral Advertising Moving the Discussion Forward to Possible Self-Regulatory Principles," December 2007; <https://web.archive.org/web/20080216182326/http://www.ftc.gov/os/2007/12/P859900stmt.pdf>; Federal Trade Commission, "FTC Staff Report: Self-Regulatory Principles for Online Behavioral Advertising: Tracking, Targeting, and Technology; U. S. House of Representatives, "What Your Broadband Provider Knows About Your Web Use: Deep Packet Inspection and Communications Laws and Policies," *Hearing before the Committee on Energy and Commerce, Subcommittee on Telecommunications and the Internet*, vol. 110 Cong. 1, 2008; U. S. Senate, "Privacy Implications of Online Advertising," *Hearing before Committee on Commerce, Science, and Technology*, vol. 110 Cong. 1, 2008.
- 29 A. K. Massey and A. I. Antón, "Behavioral Advertising Ethics," in *Information Assurance and Security Ethics in Complex Systems: Interdisciplinary Perspectives*, 162–182, (Hershey, PA: Information Science Reference, 2010).
- 30 Massey, "Behavioral Advertising Ethics."
- 31 Massey, "Behavioral Advertising Ethics."
- 32 Massey, "Behavioral Advertising Ethics."
- 33 J. Yan, "How much can behavioral targeting help online advertising?"
- 34 Massey, "Behavioral Advertising Ethics."
- 35 Massey, "Behavioral Advertising Ethics."
- 36 R. Calo, "The Boundaries of Privacy Harm," *Indiana Law Review*, vol. 86, no. 3, (2011).

- 37 H. Yu, "Lessons from the Fall of NebuAd," *Freedom to Tinker*, 08-Oct-2008, <https://freedom-to-tinker.com/2008/10/08/lessons-fall-nebuad/>.
- 38 Massey, "Behavioral Advertising Ethics."
- 39 Goldfarb, "Online Advertising, Behavioral Targeting, and Privacy."
- 40 Goldfarb, "Online Advertising, Behavioral Targeting, and Privacy."
- 41 R. Clayton, "The Phorm 'Webwise' System," (University of Cambridge, May 2008), <http://www.cl.cam.ac.uk/~rnc1/080518-phorm.pdf>.
- 42 R. Wray, "BT drops plan to use Phorm targeted ad service after outcry over privacy," *The Guardian*, July 5, 2009, <https://www.theguardian.com/business/2009/jul/06/btgroup-privacy-and-the-net>.
- 43 V. Mayer-Schönberger and K. Cukier, *Big Data: A Revolution That Will Transform How We Live, Work, and Think*, (Boston: Houghton Mifflin Harcourt, 2013), <https://www.goodreads.com/book/show/15815598-big-data>; S. Zuboff, *The Age of Surveillance Capitalism: The Fight for a Human Future at the New Frontier of Power*, (New York: Hachette Book Group, 2019), https://www.goodreads.com/book/show/26195941-the-age-of-surveillance-capitalism?from_search=true; J. Angwin, *Dragnet Nation: A Quest for Privacy, Security, and Freedom in a World of Relentless Surveillance*. (New York: St. Martin's Press, 2014), <https://www.goodreads.com/book/show/18465585-drag-net-nation>.
- 44 S. Guha, "Everyday algorithmic decisions and their consequences," (2016); J. Danaher, "The threat of algocracy: Reality, resistance and accommodation," *Philosophy and Technology*, vol. 29, no. 3, (2016), 245–268; B. D. Mittelstadt, P. Allo, M. Taddeo, S. Wachter and L. Floridi, "The ethics of algorithms: Mapping the debate," *Big Data & Society*, vol. 3, no. 2, (December 2016), 68; A. Tutt, "An FDA for algorithms," *Available at SSRN 2747994*, (2016) 1–26; B. Lepri, J. Staiano, D. Sangokoya, E. Letouzé and N. Oliver, "The tyranny of data? The bright and dark sides of Data-Driven Decision-Making for social good," *Transparent Data Mining for Big and Small Data*, (2016), 1–22; J. Danaher, "The threat of algocracy: Reality, resistance and accommodation," *Philosophy and Technology*, vol. 29, no. 3, (2016), 245–268.
- 45 Lepri, "The tyranny of data?"
- 46 J. E. Kelly and S. Hamm, *Smart Machines: IBM's Watson and the Era of Cognitive Computing*. (New York: Columbia University Press, 2013), <https://www.jstor.org/stable/10.7312/kell16856>.
- 47 L. Sweeney, "Discrimination in Online Ad Delivery," *Queue*, vol. 11, no. 3, (March 2013), 10:10–10:29 <http://doi.acm.org/10.1145/2460276.2460278>.
- 48 Sweeney, "Discrimination in Online Ad Delivery."
- 49 *Loomis v. Wisconsin*, 881 N.W.2d 749 (Wis. 2016), vol. 137 S.Ct. 2290 (2017).
- 50 M. Smith, "In Wisconsin, a Backlash Against Using Data to Foretell Defendants' Futures," *The New York Times*, June 22, 2016, <https://www.nytimes.com/2016/06/23/us/backlash-in-wisconsin-against-using-data-to-foretell-defendants-futures.html>.
- 51 Smith, "In Wisconsin, a Backlash Against Using Data to Foretell Defendants' Futures."
- 52 Smith, "In Wisconsin, a Backlash Against Using Data to Foretell Defendants' Futures."
- 53 *Loomis v. Wisconsin*.
- 54 Mittelstadt, "The ethics of algorithms."
- 55 C. Dwork, M. Hardt, T. Pitassi, O. Reingold, and R. Zemel, "Fairness Through Awareness," *Proceedings of the 3rd Innovations in Theoretical Computer Science Conference*, (2002), 214–226, <http://doi.acm.org/10.1145/2090236.2090255>.
- 56 Dwork, "Fairness Through Awareness."
- 57 Dwork, "Fairness Through Awareness."
- 58 Dwork, "Fairness Through Awareness."
- 59 bell hooks, *Ain't I a Woman: Black Women and Feminism*, (South End Press, 1981).

- 60 J. Foulds and S. Pan, “An Intersectional Definition of Fairness,” July 2018, <http://arxiv.org/abs/1807.08362>.
- 61 J. Kleinberg, S. Mullainathan and M. Raghavan, “Inherent Trade-Offs in the Fair Determination of Risk Scores,” September 2016, <http://arxiv.org/abs/1609.05807>.
- 62 J. A. Kroll *et al.*, “Accountable Algorithms,” *University of Pennsylvania Law Review*, vol. 165, 2017; D. R. Desai and J. A. Kroll, “Trust But Verify: A Guide to Algorithms and the Law,” Social Science Research Network, Rochester, NY, SSRN Scholarly Paper ID 2959472, April 2017, <https://papers.ssrn.com/abstract=2959472>.
- 63 V. Eubanks, *Automating Inequality: How High-Tech Tools Profile, Police, and Punish the Poor*, (St. Martin’s Press, 2017).
- 64 “Clapper v. Amnesty International,” 133 S. Ct. 1138, 1151 (2013).
- 65 S. D. Warren and L. D. Brandeis, “The Right to Privacy,” *Harvard Law Review*, vol. 4, no. 5, (1890) 193–220, (1890).
- 66 I. Parker, “The Story of a Suicide: Two College Roommates, a Webcam, and a Tragedy,” *The New Yorker*, January 29, 2012, <https://www.newyorker.com/magazine/2012/02/06/the-story-of-a-suicide>.
- 67 Parker, “The Story of a Suicide.”
- 68 Parker, “The Story of a Suicide.”
- 69 Parker, “The Story of a Suicide.”
- 70 A. Hayes, “Prosecutors to appeal 30-day sentence in Rutgers gay bullying case,” *CNN*, May 2012, <https://www.cnn.com/2012/05/21/justice/new-jersey-rutgers-sentencing/index.html>.
- 71 D. Bambauer, “Cyberbullying and the Cheese-Eating Surrender Monkeys,” *Concurring Opinions*, 2012, <http://www.concurringopinions.com/archives/2012/02/cyberbullying-and-the-cheese-eating-surrender-monkeys.html>.
- 72 Bambauer, “Cyberbullying and the Cheese-Eating Surrender Monkeys.”
- 73 Bambauer, “Cyberbullying and the Cheese-Eating Surrender Monkeys.”
- 74 A. E. Marwick and D. Boyd, “The Drama! Teen Conflict, Gossip, and Bullying in Networked Publics,” Social Science Research Network, Rochester, NY, SSRN Scholarly Paper ID 1926349, September 2011, <https://papers.ssrn.com/abstract=1926349>.
- 75 Parker, “The Story of a Suicide.”
- 76 Parker, “The Story of a Suicide.”
- 77 J. Kosseff, “The Twenty-Six Words That Created the Internet,” (New York: Cornell University Press, April 2019).
- 78 M. Ott, Y. Choi, C. Cardie, and J. T. Hancock, “Finding deceptive opinion spam by any stretch of the imagination,” *Proceedings of the 49th annual meeting of the association for computational linguistics: Human language technologies-volume 1*, 2011, 309–319; T. Fornaciari and M. Poesio, “Identifying fake Amazon reviews as learning from crowds,” *Proceedings of the 14th Conference of the European Chapter of the Association for Computational Linguistics*, (2014), 279–287.
- 79 Y. Pan and J. Q. Zhang, “Born Unequal: A Study of the Helpfulness of User-Generated Product Reviews,” *Journal of Retailing*, vol. 87, no. 4, (December 2011), 598–612, <http://www.sciencedirect.com/science/article/pii/S0022435911000406>.
- 80 Pan, “Born Unequal.”
- 81 Massey, “Behavioral Advertising Ethics.”
- 82 Federal Trade Commission, “Com Disclosures: How to Make Effective Disclosures in Digital Advertising,” March 2013, <https://www.ftc.gov/news-events/press-releases/2013/03/ftc-staff-revises-online-advertising-disclosure-guidelines>.

- 83 Federal Trade Commission, “FTC Brings First Case Challenging Fake Paid Reviews on an Independent Retail Website,” *Federal Trade Commission Press Releases*, February 26, 2019, <https://www.ftc.gov/news-events/press-releases/2019/02/ftc-brings-first-case-challenging-fake-paid-reviews-independent>.
- 84 O. Varol, E. Ferrara, C. A. Davis, F. Menczer and A. Flammini, “Online Human-Bot Interactions: Detection, Estimation, and Characterization,” *Eleventh International AAAI Conference on Web and Social Media*, (2017), <https://www.aaai.org/ocs/index.php/ICWSM/ICWSM17/paper/view/15587>; E. Ferrara, O. Varol, C. Davis, F. Menczer, and A. Flammini, “The Rise of Social Bots,” *Communications of the ACM*, vol. 59, no. 7, (June 2016), 96–104, <http://doi.acm.org/10.1145/2818717>.
- 85 Ferrara, “The Rise of Social Bots.”
- 86 Ferrara, “The Rise of Social Bots”; S. Van Sant, “Nearly 30 Percent Of Anti-Semitic Online Attacks Are Bots,” *NPR National News*, October 31, 2018, <https://www.npr.org/2018/10/31/662630534/nearly-30-percent-of-anti-semitic-online-attacks-are-bots>.
- 87 O. Varol, “Online Human-Bot Interactions.”
- 88 R. Chesney and D. K. Citron, “Deep Fakes: A Looming Challenge for Privacy, Democracy, and National Security,” *California Law Review*, vol. 107, forthcoming, 2019, <https://papers.ssrn.com/abstract=3213954>.
- 89 S. Suwajanakorn, S. M. Seitz, and I. Kemelmacher-Shlizerman, “Synthesizing Obama: Learning Lip Sync from Audio,” *ACM Transactions on Graphics*, vol. 36, no. 4, (July 2017), 95:1–95:13, <http://doi.acm.org/10.1145/3072959.3073640>.
- 90 Suwajanakorn, “Synthesizing Obama.”
- 91 A. Banks, “Deepfakes & Why the Future of Porn is Terrifying,” *Highsnobiety*, February 14, 2018, <https://www.highsnobiety.com/p/what-are-deepfakes-ai-porn/>; Chesney, “Deep Fakes.”
- 92 D. Güera and E. J. Delp, “Deepfake Video Detection Using Recurrent Neural Networks,” *2018 15th IEEE International Conference on Advanced Video and Signal Based Surveillance (AVSS)*, (2018), 1–6.
- 93 Chesney, “Deep Fakes.”
- 94 S. Cole, “This Horrifying App Undresses a Photo of Any Woman With a Single Click,” *Motherboard: Tech by Vice*, June 26, 2019, https://www.vice.com/en_us/article/kzm59x/deepnude-app-creates-fake-nudes-of-any-woman; P. Isola, J.-Y. Zhu, T. Zhou, and A. A. Efros, “Image-To-Image Translation With Conditional Adversarial Networks,” *The IEEE Conference on Computer Vision and Pattern Recognition*, 2017.
- 95 Chesney, “Deep Fakes.”
- 96 D. Faggella, “7 Chatbot Use Cases That Actually Work,” *Emerj*, (May 2019).
- 97 Gartner, “Gartner Customer 360 Summit,” Los Angeles, CA, March 2011.
- 98 C. Welch, “Google just gave a stunning demo of Assistant making an actual phone call,” *The Verge*, May 2018.
- 99 A. Cranz, “Uhh, Google Assistant Impersonating a Human on the Phone Is Scary as Hell to Me,” *Gizmodo*, May 5, 2012.
- 100 D. Etherington, “Apple’s iOS 13 update will make FaceTime eye contact way easier,” *The Verge*, July 2019.
- 101 Etherington, “Apple’s iOS 13 update.”
- 102 Etherington, “Apple’s iOS 13 update.”
- 103 M. Arment, C. Liss, and J. Siracusa, “Your Face is Not Your Face,” *Accidental Tech Podcast*, July 2019, <https://atp.fm/episodes/336>.
- 104 M. Honan, “Yes, I was hacked. Hard.” *EMPTYAGE*, 03-Aug-2012, <https://web.archive.org/web/20121101160737/http://www.emptyage.com/post/28679875595/yes-i-was-hacked-hard>;

- M. Honan, "How Apple and Amazon Security Flaws Led to My Epic Hacking," *Wired*, August 6, 2012 <https://www.wired.com/2012/08/apple-amazon-mat-honan-hacking/>.
- 105 Honan, "Yes, I was hacked. Hard.;" Honan, "How Apple and Amazon Security Flaws Led to My Epic Hacking."
- 106 Honan, "Yes, I was hacked. Hard." Honan, "How Apple and Amazon Security Flaws Led to My Epic Hacking."
- 107 Honan, "How Apple and Amazon Security Flaws Led to My Epic Hacking."
- 108 Honan, "How Apple and Amazon Security Flaws Led to My Epic Hacking."
- 109 Honan, "How Apple and Amazon Security Flaws Led to My Epic Hacking."
- 110 Honan, "How Apple and Amazon Security Flaws Led to My Epic Hacking."
- 111 Honan, "How Apple and Amazon Security Flaws Led to My Epic Hacking."
- 112 N. Olivarez-Giles, "Amazon Quietly Closes Security Hole After Journalist's Devastating Hack," *Wired Gadget Lab*, August 7, 2012, <https://www.wired.com/2012/08/amazon-changes-policy-wont-add-new-credit-cards-to-accounts-over-the-phone/>; N. Olivarez-Giles Nathan and M. Honan, "After Epic Hack, Apple Suspends Over-the-Phone AppleID Password Resets," *Wired Gadget Lab*, August 7, 2012, <https://www.wired.com/2012/08/apple-icloud-password-freeze/>.
- 113 K. Mitnick and W. Simon, *The Art of Deception: Controlling the Human Element of Security*, (New York: John Wiley and Sons, 2002).
- 114 J. Cheng, "School settles laptop spying case to 'protect taxpayers,'" *Ars Technica*, December 10, 2010; <https://arstechnica.com/tech-policy/2010/10/school-settles-laptop-spying-case-to-protect-taxpayers/>.
- 115 Cheng, "School settles laptop spying case."
- 116 B. Schneier, "Security and Function Creep," *IEEE Security Privacy*, vol. 8, no. 1, January 2010, 88.
- 117 City of Ontario, California, et al. V. Quon et al. 560 U.S. 746, vol. 130 S. Ct. 2619, 2010.
- 118 H. F. Nissenbaum, "Privacy as Contextual Integrity," *Washington Law Review*, vol. 79, no. 1, (2004).
- 119 Although this book is not about information security or incident response, both these fields have demonstrated the value of actually practicing by conducting realistic response drills.

CHAPTER 8

Privacy Governance

David James Marcos, CIPM, CIPT

8.1 Privacy and IT: Roles and Responsibilities

Two decades into the twenty-first century, it is manifestly clear that our physical lives are becoming inseparable from our digital lives. Amid this profound societal transformation, information technology (IT) takes center stage in the safeguarding of individual privacy. The centrality of IT in modern privacy

programs demands a focus on scalable technical solutions, developed at once to balance the ever-increasing scope, volume and complexity of information technology as well as the challenges of translating privacy principles and harms into engineering requirements. In short, this is the essence of privacy engineering: bringing the complementary perspectives of privacy professionals and engineers together, grounded in practical solutions capable of measuring and monitoring the ever-changing state of privacy within information technology.

This chapter will focus on the role of IT in privacy, with notable attention on achieving a practical and measurable governance program designed to enable effective privacy engineering that connects the objectives outlined in a privacy program with tangible tools and capabilities within information technology. Critically, the following pages will detail how to work cross-domain between the myriad stakeholders entrusted to cultivate privacy within an organization. This cross-domain approach is a precursor to effective privacy engineering.

Building on the cross-domain approach, this chapter will further describe how to make pivotal connections between disparate aspects of a privacy program, the impetus of which is grounded in the technical solutions actually safeguarding privacy within systems. Tying these pieces together is one of the biggest challenges for a modern privacy program, taking high-level privacy objectives and controls designed to protect against privacy harms and translating them into meaningful, measurable and above all, practical, controls that privacy engineers can implement and monitor.

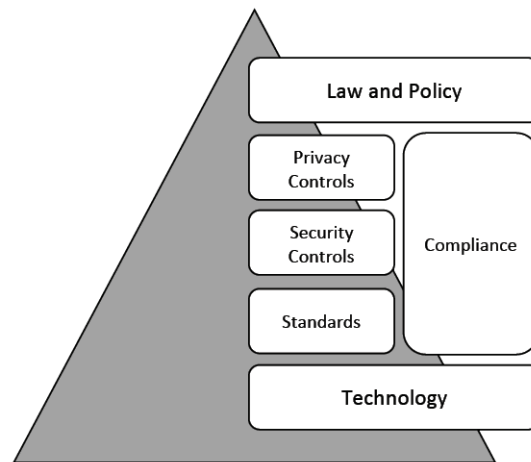
Throughout, the chapter will also detail the various tools availed to privacy professionals and engineers that enable the systematic management of a privacy governance program. Many of these tools overlap in functionality; many are complementary. Described below is how best to both use and organize these tools to develop a successful privacy governance program.

8.2 Privacy Governance and Engineering: Bridging the Gap

Understanding the role of IT in privacy first starts with identifying the elements and associated stakeholders of a privacy governance program. Figure 8-1 illustrates the various elements of a privacy governance program. As this chapter proceeds, we will additively describe these elements, explaining how each layer builds upon, and is reinforced, by the others. Recognizing these different elements

is critical, as each component can easily achieve primacy over others, when in fact they are interdependent and must be interleaved. Absent a structured approach to balance the disparate elements of a privacy program, IT's ability to safeguard privacy greatly diminishes. Merely summarizing legal requirements is insufficient to develop effective engineering solutions. While law is no doubt fundamental to understanding baseline privacy requirements, additional detail is necessary to make legal requirements tangible and practical for engineering.

Figure 8-1: Conceptualizing a Privacy Governance Program



Recognizing these different elements and the ways they are interwoven into a holistic privacy governance model greatly helps ensure the success and increased maturity of a privacy program. Manifest in this recognition is identifying not just the specific roles each element plays, but critically, how to translate between the boundaries of each element of the privacy program. In fact, translation is perhaps the most important aspect of a privacy program to recognize. The privacy professional, ultimately, is a translator, sitting at the center balancing the requirements espoused by various stakeholders and organizing those requirements into structured themes and elements that enable the success of each stakeholder as well as the overall success of the enterprise-wide privacy governance program. This decidedly organizational, and not technical, aspect, once understood, immensely increases the ability of IT to contribute successfully to the effectiveness and maturity of a privacy program. Moreover, this framework, once understood and established, enables iterative improvements as the translations across the elements help different stakeholders to see how their needs and requirements affect, or do not affect, the overall health of the privacy program. This is equally critical as it aids in both understanding and maintaining

the critical needs of the privacy program, again in practical terms, and their implementation within information technology.

8.2.1 Privacy Law and Policy

Law and policy sit at the pinnacle of the privacy governance program pyramid. Ultimately, the aim is to translate these fundamental requirements—whether foundational legal requirements or organizational privacy policies—into tooling that is manageable and scalable with the organization’s IT needs.

In the modern era, an increasing number of privacy-impacting legal frameworks are coming into being. Paramount among modern laws is the EU’s General Data Protection Regulation (GDPR).¹ The California Consumer Privacy Act (CCPA) is also prominent.² Alongside these laws are earlier laws, such as the U.S. Privacy Act of 1974, and prospective laws currently in debate worldwide both at the state level (e.g., Illinois’s Data Transparency and Privacy Act) and at the national level (e.g., India’s Personal Data Protection Bill).³ There are also sector-specific laws tailored to specific areas, such as the U.S. Healthcare Insurance Portability and Accountability Act (HIPAA).⁴

At first blush, the many legal frameworks both currently in existence and on the horizon ostensibly present a major challenge for IT. Each framework is similar to and different from the others. Each one may or may not be tailored to specific areas. For instance, GDPR focuses broadly on personal data and on EU residents. HIPAA focuses narrowly on protected health information (PHI) and is tailored to the United States. See the below example in Table 8-1, which illustrates the similar confidentiality requirements across both HIPAA and GDPR:

Table 8-1: Examples of Privacy Law

Privacy Law	HIPAA - 42 USC §1320a-7e(b)(3): <i>Confidentiality: In determining what information is required...[regulation]...shall include procedures to assure that the privacy of individuals receiving healthcare services is appropriately protected.</i>⁵ GDPR - Article 28(3)(b): <i>[...] ensures that persons authorised [sic] to process personal data have committed themselves to confidentiality or are under an appropriate statutory obligation of confidentiality.</i>⁶
-------------	--

From an IT perspective, this can seem unmanageable. Information technology itself is ever-changing and evolving, just as law is. The timescale at which IT changes is also significantly faster than that of law. Moreover, developing tailored engineering solutions for one law may lead to overly complicated and costly

engineering solutions—and solutions for one law may outright contradict the requirements of another.

In the face of this reality, IT professionals will immediately gravitate toward two questions: What can practically be done? And how can solutions be *future proofed* to forestall the need for additional investment or unnecessary complexity that negatively affects organizational performance or outweighs business value?

Privacy professionals and engineers must look first to the organization’s legal team to help identify the core requirements of disparate privacy laws and the various associated legal risks. This work involves identifying the core policies and associated objectives a given organization deems necessary in order for it to fulfill its obligations. It is important to note that these policies may not stipulate technical solutions. Instead, top-level organizational policies will likely only identify key objectives that must be met. This is acceptable—and desirable—as it affords privacy professionals and engineers flexibility to define the governance program and identify manual and automated aspects. This flexibility also enables iterative maturation: As the privacy governance program and supporting IT solutions evolve, previously manual components of the program will become automated. This natural evolution not only enables the privacy program to become more effective, it also allows the program to evolve with the pace and scale of IT; a necessity given the continued and exponential growth of technology. Building upon the legal examples of HIPAA and GDPR from Table 8-1, consider the following organizational policy in Table 8-2, which identifies a key confidentiality objective to cover both laws’ requirements.

Table 8-2: Additive Example of an Organizational Policy

Privacy Law	HIPAA: <i>Confidentiality: In determining what information is required...[regulation]...shall include procedures to assure that the privacy of individuals receiving healthcare services is appropriately protected.</i> GDPR: <i>[...] ensures that persons authorised [sic] to process personal data have committed themselves to confidentiality or are under an appropriate statutory obligation of confidentiality.</i>
Privacy Policy	Organizational Policy: <i>Employees processing personal data require a legitimate business need.</i>

8.2.2 Privacy and Compliance

Compliance is one of the most important parts of a privacy governance program. Building upon law and established organizational policy, compliance begins the

translation into practical and measurable requirements and the process through which privacy can be implemented and evaluated.

Responsibility for compliance within an organization may sit in various places. Compliance may be part of the legal team, it may be integrated with security, or it may be its own department. Privacy itself may be embedded under compliance. Regardless, compliance offers a strong framework upon which the privacy program can be built. Compliance begins the process of establishing practical controls through which privacy engineers can build effective IT solutions to safeguard privacy.

For privacy professionals and engineers, a short primer identifying key concepts in compliance is valuable. Not only does this help establish common terminology with which to engage compliance teams, the concepts themselves are of immense value when creating the governance model and associated standards necessary to manage an organization's privacy program and ultimately implement it within IT.

Fundamental is the concept of *reasonable assurance*. Reasonable assurance means that requirements and objectives are not absolute, but rather based upon some criteria that is deemed practical to implement and manage. This concept is absolutely key when safeguarding privacy in IT. It affords flexibility and is greatly valuable for managing the potential overengineering of solutions. It also grounds solutions in common sense. Take, for instance, a technical solution designed to identify people in order to delete their data. An *absolute* guarantee would necessitate knowing an individual perfectly; in effect, creating a privacy harm in order to resolve another. What, instead, is reasonable? What are practical measures that can be taken to resolve the need to identify a user in order to delete their data while not at once overengineering and invading privacy as an unintended consequence?

With reasonable assurance as a backdrop, compliance programs aim to develop internal controls. Internal controls are objectives tied to practical measurements and designed to evaluate components governed by the privacy program.⁷ For instance, an internal control might be to review access logs to a system with the objective of identifying unauthorized access. Implementation of the control may be manual, automated or a mix of both.

Internal controls come in two primary flavors. One kind is preventive: designed to stop an activity, a priori, from occurring.⁸ The second is detective: identifying problematic activity posteriori—after the event has occurred.² Continuing with the example from the prior section, consider the following in Table 8-3.

Table 8-3: Additive Example of a Privacy Compliance Internal Control

Privacy Law	HIPAA: Confidentiality: <i>In determining what information is required...[regulation]... shall include procedures to assure that the privacy of individuals receiving healthcare services is appropriately protected.</i> GDPR: <i>[...] ensures that persons authorised [sic] to process personal data have committed themselves to confidentiality or are under an appropriate statutory obligation of confidentiality.</i>
Privacy Policy	Organizational Policy: <i>Employees processing personal data require a legitimate business need.</i>
Compliance Internal Controls	Preventive Privacy Internal Control: <i>Limit access of personal data only to authorized personnel.</i>

In mature compliance programs, internal controls are continuously monitored, ideally through IT capabilities. This enables faster identification of issues and remediation thereof. Alongside, internal controls are often designed to be *overlapping*. Overlapping safeguards are key, as they improve the resiliency of a compliance program and assure that objectives can continue to be measured and issues identified amid failures of other controls. Overlapping safeguards and reasonable assurance strongly reinforce one another and importantly, justify the application of *reasonable* assurance rather than *absolute* assurance.

The value that compliance and its basic concepts offer a privacy governance program is simple: *structure*. A privacy governance program grounded is reasonably assured, overlapping detective and preventive controls enables a clear, measurable and understandable framework through which translation across the various elements of a privacy program can be achieved. It is the first step in translating law and policy into practicable objectives and metrics, and it further provides the mechanism through which to pivot between each element of the privacy program.

8.2.3 Privacy and Security

Security and privacy are deeply intertwined. For privacy, security is where the governance program begins to become significantly technical. Security engineers necessarily deal with more technical aspects tied to IT given the nature of security threats to modern technology. Moreover, security is a necessary precursor to privacy: Absent security, it is difficult to achieve and maintain privacy. Privacy and security, however, have clearly different roles with respect to IT. Principally,

security is about protecting against unauthorized access and malicious actions.¹⁰ Security risk is often framed in terms of confidentiality, integrity and availability (CIA triad).

Privacy, comparatively, is about enforcing *appropriate use* within a secure environment.¹¹ In other words, security can reasonably assure that two parties exchange personal data securely, but it is privacy that reasonably assures that the authorized parties are in fact using the personal data appropriately.

As different sides of the same coin, security and privacy often rely on similar controls and, ultimately, the same IT capabilities. Access control presents one of the more obvious capabilities that is leveraged to the mutual benefit of security and privacy protections alike. Table 8-4 illustrates *security* compliance internal control, which is nearly identical to the example of privacy internal control provided in Table 8-3.

Table 8-4: Additive Example of a Security Compliance Internal Control

Privacy Law	HIPAA: <i>Confidentiality: In determining what information is required...[regulation]... shall include procedures to assure that the privacy of individuals receiving healthcare services is appropriately protected.</i> GDPR: <i>[...] ensures that persons authorised [sic] to process personal data have committed themselves to confidentiality or are under an appropriate statutory obligation of confidentiality.</i>
Privacy Policy	Organizational Policy: <i>Employees processing personal data require a legitimate business need.</i>
Compliance Internal Controls	Preventive Privacy Internal Control: <i>Limit access of personal data to authorized personnel only.</i> Preventive Security Internal Control: <i>Limit access of sensitive data to authorized personnel only.</i>

Security provides multiple benefits to privacy in consequence. Notably, information security is more mature, technologically, than privacy. Likewise, security frameworks and certifications are well established and again, more mature in terms of technological implementation, than those related to privacy. Security thus provides privacy an avenue through which meaningful IT solutions can be developed to safeguard privacy. In addition, as security and compliance are as intertwined as privacy and compliance, reasonably assured internal controls can be repurposed, or extended, as necessary in order to mature the privacy governance program and inculcate privacy safeguards into IT.

The fact that security is naturally a technical undertaking and, comparatively, technically mature, provides an additional and profoundly important benefit for privacy: The ability to translate privacy into meaningful and understandable terminology for engineers. Given that privacy can often be abstract and difficult to describe, it is notoriously challenging to frame it in terms understandable to engineers and computer scientists. In leveraging security terminology—both with respect to adopting the same terminology or contrasting with it—privacy can more effectively describe fundamental requirements and safeguards in ways that lead to truly effective IT safeguards that engineers can readily comprehend and utilize within IT infrastructure.

Considered in this context—a mature, technologically oriented element already understood by engineers—security becomes a critical pillar upon which privacy can rely. Moreover, as much as privacy benefits from security, security likewise benefits from privacy, backstopping security solutions and processes with privacy legal requirements and, in consequence, reinforcing the mutual value of *integrated* privacy and security governance. Additional detail regarding security and its relationship to privacy is described in Chapter 9.

8.2.4 Privacy and Technology

The foundational base of a modern privacy governance program is technology. In the modern era, technology is where a privacy governance program becomes realized and actionable. At the same time, technology presents at once the greatest challenge and the biggest opportunity for privacy. While security greatly assists privacy in translating objectives into meaningful and understandable terms for engineers to implement effective IT solutions, ultimately, privacy must reconcile directly with the nature of information technology and how best to leverage it to the advantage of privacy governance programs and the effective safeguarding of privacy within IT.

Perhaps the greatest challenge for privacy is not technology itself, in terms of the risks it poses to individual privacy, but rather in *how* to utilize it to safeguard privacy. The persistent challenge privacy programs have faced in recent years is precisely this: the translation of abstract privacy harms into tangible, measurable and controllable IT capabilities. In addition, the issue of scalability, it goes without saying, comes to the fore if one is considering managing privacy across a cloud. Moreover, IT is continually developing capabilities that promise to improve privacy, be it differential privacy, homomorphic encryption or various

deidentification techniques. But how best to use these capabilities? How should these capabilities be rationalized in regard to a privacy governance program? Which risks do these capabilities mitigate? Which controls do they support? Is it possible to thematically organize them, and other capabilities, in a manner that facilitates a comprehensive and cohesive set of IT capabilities that support, automate and continuously monitor all or a subset of a privacy governance program?

The first step toward effectively understanding IT with respect to privacy is to recognize the capabilities that information technology generally provides for users. A computer has only so many components with which to (a) interact with a human and (b) manipulate data. Simplistically, the fundamental computational functions of a computer consist of *create, read, update and delete*, also referred to as *CRUD*. Considering IT in light of *CRUD*, although an oversimplification, is valuable to support practical translations of law and compliance controls into tangible solutions. This means that, in the end, all of the innumerable existing or future privacy laws worldwide must, in some fashion, be implemented by IT, and that implementation comes down to permutations of *CRUD*. Like DNA, different combinations of create, read, update and delete yield different, and infinite, potential. But ultimately, everything comes down to those base functions of *CRUD*.

Recognizing this begins the process of making privacy practical and implementable in IT. It also enables effective risk-based discussions as well as the development of consistent controls applicable across a broad range of legal frameworks. In other words, it is to take the *metaphysical* conceptualization of privacy across law, policy, and ethics and *discretize* it into the discrete functionality of computers. The additive examples illustrated in the tables throughout this chapter exemplify precisely this: how to methodically undertake the breakdown of high-level statements and instrument practical, measurable controls into IT itself.

Moreover, these fundamental building blocks can be additively employed, much like DNA, to develop higher-level functionality. Iterating through, sophisticated solutions such as differential privacy suddenly become rationalized in the light of a privacy program. Similarly, internal compliance controls can also be rationalized. Ultimately, this leads to being able to connect the top of the pyramid—law and policy—to the lowest tier, technology.

Additively employing the fundamental building blocks also enables the reasonable iteration of the discretized components of IT in a manner that makes transparent (a) which controls exist to mitigate abstract privacy harms and (b) whether those controls sufficiently discretize the metaphysical aspects of a given privacy harm. It also clearly reveals the practical performance impacts on IT infrastructure that the control may have. This transparency is a profound and critical aspect of an IT-centric privacy governance program as it separates myth from reality and grounds privacy in *measurable* and *real* componentry within IT. Sections 8.2.6 and 8.3 of this chapter will elaborate further on both how this can be undertaken and what core pieces must be considered when bringing IT and privacy together in a privacy governance program.

8.2.5 Industry Standards

As privacy has increasingly challenged IT, privacy-minded industry standards have equally increased as efforts have been undertaken to organize, rationalize and comprehend privacy in ways meaningful for engineers. Many of these standards began with security and, as previously noted, privacy thus has a strong security-centric foundation that can be leveraged to connect privacy with meaningful technical controls in IT. For example, National Institute of Standards and Technology (NIST) Special Publication (SP) 800-53 was initially conceived as a security-centric document. However, by revision 3, the SP 800-53 document had been augmented with privacy controls, detailed in the publication's Appendix J.¹²

Industry standards offer two principal benefits for IT-focused privacy governance. First and foremost is the establishment of a common language to describe privacy controls. When dealing with international standards, this is especially valuable, as the controls represent what industry experts, vetted through an international organization, deem critical to identify and measure across a wide swath of legal frameworks and privacy considerations.

In the establishment of this common language results the second benefit: *transparency*. It goes without saying that each organization will have its own tailored privacy governance program and, alongside, its own IT architecture. Some aspects may be considered confidential—notably IT architecture. Standards provide a mechanism through which an organization can transparently describe its controls tied to governance and information technology in common and accessible terms that do not inadvertently undermine confidentiality. This helps build trust between an organization and its key stakeholders or customers

and, in addition, provides auditability through independent third-party certification. Building upon Table 8-4, consider the following mapping in Table 8-5 of the privacy and security internal controls to NIST SP 800-53.

Table 8-5: Additive Example of SP 800-53 Controls Mapped to Compliance Internal Controls

Privacy Law	HIPAA: <i>Confidentiality: In determining what information is required...[regulation]... shall include procedures to assure that the privacy of individuals receiving healthcare services is appropriately protected.</i> GDPR: <i>[...] ensures that persons authorised [sic] to process personal data have committed themselves to confidentiality or are under an appropriate statutory obligation of confidentiality.</i>	
Privacy Policy	Organizational Policy: <i>Employees processing personal data require a legitimate business need.</i>	
Compliance Internal Controls	Preventive Privacy Internal Control: <i>Limit access of personal data to authorized personnel only.</i> Preventive Security Internal Control: <i>Limit access of sensitive data to authorized personnel only.</i>	
Industry Standard Mapping	Preventive Privacy Internal Control: <i>Limit access of personal data to authorized personnel only.</i>	UL-1: Internal Use—<i>[U]ses [...] PII internally only for authorized purpose(s)[.]</i>¹³
	Preventive Security Internal Control: <i>Limit access of sensitive data to authorized personnel only.</i>	AC-3: Access Enforcement—<i>The information system enforces approved authorizations[.]</i>¹⁴

Industry standards cover the gamut worldwide, with a mix of international and local standards in play. Depending on the sector or locality, a privacy governance program may need to certify against one industry standard or more. In consequence, understanding the basics of varying standards is crucial. Here again, as described in prior sections in this chapter, *translating* the controls of a privacy governance program into various controls identified in varied standards is critical to success.

Standards have different purposes; some attempt to rationalize privacy and IT holistically for a privacy program, and others describe specific aspects deemed beneficial. Above all, the standards attempt to support privacy professionals and engineers through *structure* and recommended *methods of measurement*. The myriad standards in play can prove daunting, notably when attempting to decide which standard or standards should be selected to backstop a privacy governance

program. Many of these standards thus provide tables that cross-map different standards, assisting in portability or reusability.

Table 8-6 describes some of the more prominent standards in effect, or soon forthcoming, that are valuable when building a privacy governance program supported by information technology. It should be stressed that the standards listed below represent only a subset. Again, myriad standards worldwide cover international needs, localized needs or sectoral particularities.

Table 8-6: Select Industry Privacy Standards

Standard	Description
ISO 19944¹⁵	<i>ISO 19944, Cloud Services and Devices: Data Flow, Data Categories, and Data Use</i> , is an ISO standard designed to support transparent description of cloud ecosystems, focusing on taxonomic categories of data, use and dataflow within cloud services.
ISO 270XX Series¹⁶	The ISO 270XX series covers an array of information security controls. ISO 27001 predominates as the primary security standard. ISO 27018 provides privacy-centric controls for personally identifiable information.
Privacy Information Management System (PIMS) – ISO 27552¹⁷	PIMS is a newly developed ISO standard designed specifically to enhance privacy safeguards for ISO 27001. This standard, approved in 2019, accounts for controls identified in GDPR and provides a more fulsome description of privacy controls for data controllers and data processors. PIMS further provides mapping to other standards and laws to facilitate portability.
NISTIR 8062¹⁸	<i>NISTIR 8062, An Introduction to Privacy Engineering and Risk Management in Federal Systems</i> , is a U.S. standard that introduces basic privacy engineering and risk management concepts. Notably, it calls out the concepts of protectability, manageability, and disassociability, the privacy parallels to security's CIA triad concepts.
NIST Privacy Framework¹⁹	The NIST Privacy Framework is a voluntary enterprise risk management tool alongside the NIST Cybersecurity Framework. Currently in draft, the framework is intended to assist organizations in communicating and organizing privacy risk, rationalizing privacy in order to build or evaluate a privacy governance program.
NIST Special Publication 800-53²⁰	<i>NIST SP 800-53, Security and Privacy Controls for Federal Information Systems and Organizations</i> , is the primary standard for U.S. government agencies. The standard is also broadly used by private sector entities and has mappings to ISO 270XX controls. Privacy controls are identified in Appendix J and aligned with the Fair Information Practice Principles (FIPPs).
SOC 2 Type 2²¹	<i>SOC, Systems and Organization Controls</i> , focuses on security, availability, processing integrity, confidentiality, and privacy. SOC has differing levels of standardization, with SOC 2 Type 2 being the more in-depth standard to assess assurance of the controls of a service organization.

8.2.6 Putting it Together: Privacy Governance

As has been previously described, there are myriad elements and stakeholders at play within a privacy governance program. All these elements must be integrated to produce meaningful privacy-centric safeguards in IT. Implementing a privacy governance program depends on the effective *choreography* of elements and stakeholders alike. How best can a program be implemented that interweaves these elements together to the benefit of IT and the effective leveraging of information technology to safeguard privacy?

Figure 8-1 offers a conceptualization of the varying elements at play in a privacy governance program, summarizing the top-down descriptions of the components described in previous sections of this chapter. Alongside, Tables 8-1 through 8-5 additively illustrate how a privacy governance program builds out across its varied elements.

At the top is, of course, law and policy and, below it, the various elements of privacy, security, compliance and industry standards. Providing the base is technology. This depiction differentiates varied elements and organizes them in a manner conducive to structuring the overall governance model for a privacy program.

As explained earlier, the compliance program provides the foundational structure on which to organize the core elements of the program. Across the privacy controls and security controls (which may in part overlap), compliance is the structure on which internal controls are reasonably defined and managed. Standards provide a mechanism both to fact-check if the security and privacy controls meet minimum expectations as defined by outside parties as well as to translate the governance program to auditors, customers and the general public.

While technology serves as the foundation and, ultimately, defined privacy controls must be implemented within information technology, the privacy controls defined in the governance program should strive to be agnostic about manual or automated means. This sets the stage for IT to support privacy engineering of safeguards, as will be described in Section 8.3.

The overall privacy governance program should aim to be (a) structured and (b) enduring. Designed controls should focus on structuring objectives and activities in measurable and discrete ways that connect, but do not embed, higher-order legal requirements or lower-level technological solutions. This intentional design enables flexibility: If laws change, the governance program can absorb and adjust

with little perturbation. Likewise, the governance program can also persist through technological change. The key, again, is the structure, which enables a robust, enduring model. Moreover, this also aids continual maturation and evolution of the governance program. As technology advances, the program can adapt and controls previously undertaken in manual capacity can be automated. This latter point is perhaps the most powerful, as it enables an enduring framework that can scale with the IT infrastructure of an organization, whether it's a small-scale system or a hyper-scale cloud.

Digging deeper, it is further valuable to contrast the abstract model of a privacy governance program depicted in Figure 8-1 with the actual activities typical privacy governance programs manage. Table 8-7 summarizes core activities of a privacy governance program.

Table 8-7: Core Activities Typical of a Privacy Program

Privacy Program Activities	Description
Privacy and Data Protection Impact Assessments	Assessments evaluating privacy harms and issues for major activities undertaken by an organization.
Privacy Reviews	Individual design reviews of systems or activities to evaluate sufficiency of privacy safeguards employed.
Training and Awareness	Educational and awareness activities for personnel supporting privacy functions within the organization. (Awareness may also include external engagement and transparency activities.)
Privacy Incident Management	Management and response for privacy-related incidents within the organization.
Third-Party Relationships	Requirements and privacy safeguards when interacting and sharing personal data with external organizations.
Consent and Notice	Practices and requirements to provide notice and appropriate consent for users of organizational services.

Privacy reviews present an illustrative example to connect the activities of a privacy program with the abstract model of privacy governance in Figure 8-1. In short, the illustration of Figure 8-1 can be implemented for each activity within a privacy program, providing a structured methodology to take key activities, such as privacy reviews, and turn them into tangible and measurable controls that can be implemented by privacy engineers.

Continuing with the example, privacy reviews are fundamentally intended to assess and verify the design of a given service. Privacy reviews will evaluate, among other things, the data and uses of a given service and will further evaluate dataflows (across systems as well as geographic boundaries), consent/notice in keeping with organizational requirements, access control and other aspects as defined by an organization's privacy program.

These facets (e.g., data, use, dataflow, consent/notice) of a privacy review have their foundation in both law and policy. At the same time, it is clear they also have grounding in real IT capabilities. Take dataflow: Top-down, from the legal viewpoint, the EU-U.S. Privacy Shield enforces data protection requirements when transferring data between Europe and the United States.²² Bottom-up, enforcement depends on technical solutions to assure transfers are appropriate and in line with legal requirements. Moreover, dataflow is a control tightly interwoven with security. Here the connection and opportunity are clear: Upholding of the law is dependent upon IT, and given that security has an equal stake in dataflow safeguards, privacy can augment existing controls. In addition, such controls are clearly identified in various industry standards, bringing the pieces together into a theme. Compliance further helps bring the pieces together in a framework: defining the controls across overlapping preventive and detective controls to reasonably assure that cross-border dataflow fulfills legal and policy requirements.

This structuring sets the stage for the actual privacy engineering within IT architecture. It establishes the choreography in which the high-level legal requirement—in this example, safeguarding of cross-border dataflows per the Privacy Shield—is organized into a set of measurable privacy and security controls and in consequence can be mapped to the control points and capabilities built into an organization's IT infrastructure. This stage set, the remaining sections of this chapter will detail how this structure is leveraged to ultimately implement a privacy governance program within IT infrastructure.

8.3 Privacy Engineering: Effective Implementation within an Organization's IT Infrastructure

The preceding section broke down the various elements and associated stakeholders at play within an organization's privacy governance program. Given a

structured privacy governance program, the next step is understanding how to enable IT to effectively implement privacy safeguards within technology in a measurable and above all practical way.

Three key concepts are useful to understand in this endeavor: data governance, technological controls and the engineering development life cycle. Effective privacy engineering rests upon these concepts, as they offer a technical framework in which a privacy governance program can be implemented. Ultimately, the aim is to provide a mechanism to translate various internal controls defined in the privacy governance program into automated and continuously monitored technological controls across IT infrastructure.

8.3.1 Data Governance: Conceptualizing Privacy in Information Technology

In modern data-driven information technology, data governance holds primacy and is critical to understand for effective privacy engineering. Understanding data and associated uses is key, as it enables the creation of effective privacy safeguards and monitoring capabilities in line with the objectives of a privacy governance program.

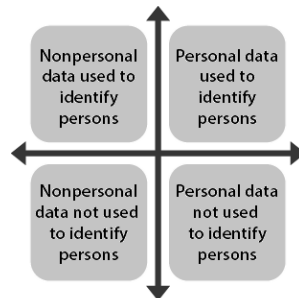
8.3.1.1 Understanding Data and Use

Figure 8-2 below provides a useful depiction to begin the rationalization of data and use toward practical data governance. In Figure 8-2, the x-axis spans from nonpersonal data to personal data, and the y-axis spans from uses not intended to identify persons to uses intended to identify persons. Herein, it begins to become clear where general risks lie and how to begin to model data and use it in a manner easy for an organization to grasp.

The figure illustrates where challenges can arise when addressing privacy in technology and, in consequence, what needs to be done in order to safeguard privacy. When embarking on data governance, organizations initially focus solely on understanding personal data. However, as is evident in the illustration, it is necessary, but insufficient, merely to understand whether personal data is present in an IT system. Key is to understand the use or uses applied as much as the presence of personal data. Immediately, both obvious and non-obvious issues are recognized. For instance, using personal data to identify persons is an obvious scenario—as is using nonpersonal data for uses other than identifying people. Trickier is where personal data is used *not* to identify people, and trickiest of all is

where nonpersonal data is used to identify persons. Imagine an internet of things (IoT) device collecting nonpersonal data sufficiently detailed to identify the unique behavior of a person as they interact with the device.

Figure 8-2: Framing Data and Use



As IT shifts from stovepiped solutions into more cloud-centric systems where data-driven operations predominate, the framing illustrated in Figure 8-2 enables the privacy engineer to understand how differing uses may alter privacy risk for given data sets. Notably, in a cloud, where myriad datasets are processed for unlimited uses, the diagram forces a necessary question: How can you model data and use it in order to continuously monitor changes that affect privacy in IT? Section 8.3.2 will expound on this further, building on the running example throughout this chapter.

8.3.1.2 Modeling and Tagging Data and Use

The modeling and tagging of data and use is core to data governance and is a necessary precondition for measuring and understanding how privacy harms may arise within IT. Fundamentally, the aim is to discretize these two key aspects of privacy: data and use.

Modeling data and use is one of the most challenging undertakings of a privacy governance program. It forces different stakeholders across the governance program to come together to create a common taxonomy. It necessitates a governing model to track and manage data. And in data-driven systems, it requires tagging and tracking of data and uses within the IT infrastructure itself. In addition, organizations often struggle with identifying the proper level of detail. What granularity is needed for data? For uses? How much is overkill, and can it be managed over the long term?

Here is where the structure of the privacy governance program described in the prior section can be leveraged to the benefit of privacy engineering. As the program necessarily must balance the differing needs across the stakeholders of

the privacy governance program, it establishes the framework in which the taxonomic model for data and use can be created and ultimately governed. In addition, industry standards, such as ISO 19944, are invaluable, as they offer tangible taxonomic models to aid the development of a meaningful and explainable framework for data and use. Separate from and alongside ISO 19944, the following three steps are helpful to conceptualize a taxonomic model for data and use specifically tailored to an organization's needs and goals:

1. *Business objective and purpose*—Identifying the business objectives and associated purposes is a first step toward scoping the model necessary for data and use. It grounds a taxonomy in the fundamental business needs of an organization and is valuable to help stakeholders remain focused on the key uses and associated data necessary to achieve business goals.
2. *Law and policy*—Once business objectives and purposes are understood, law and policy help shape the limits of what is and is not allowable. This results in the development of discretized rules tied to data and use or uses and affords the privacy engineer a structure in which to rationalize what to do when data is processed toward the fulfillment of a business objective.
3. *Technology*—Ultimately, the data and uses, tied to business objectives and constrained by rules, must be channeled through technological controls. Building upon the prior section's discussion on CRUD, understanding the control model as implemented in IT ultimately shapes how privacy is safeguarded pursuant to the data, uses and rules fulfilling a given business objective. The following section describes this in more detail.

With the previous three steps in mind, coupled with industry standards such as ISO 19944, a privacy governance program can develop a scalable and practical taxonomy of data and use based upon the core business objectives of an organization. Thus established, a taxonomy of data and use enables a privacy governance program to begin the process of automating the program within IT. Critically, it provides a language in which to translate key privacy needs and harms in an accessible and usable fashion for privacy engineers. Taxonomy in hand, the

next step is to understand how to control data and use within IT infrastructure. The following section describes this second critical concept of privacy engineering: technological controls.

8.3.2 Technological Controls

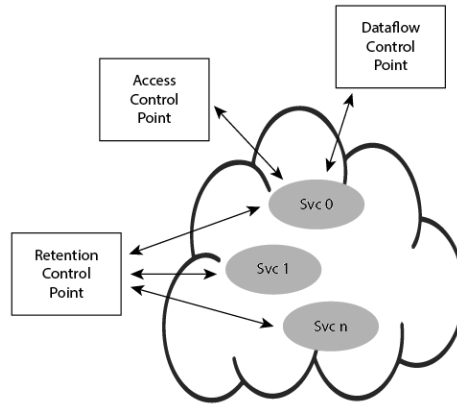
As depicted in Figure 8-1, technology serves as the foundation of a privacy governance program. Key toward enabling IT-centric privacy governance is to tie established internal controls to technological controls implemented within IT. Here is where the crux of compliance internal controls, security and information technology come together to effectuate meaningful privacy engineering.

8.3.2.1 Mapping Technological Controls to Internal Controls

As previously discussed, implementation of internal controls may be manual, automated or a mix of both. In the scheme of an effective privacy governance program, this is an expected and desirable aim. When engineering privacy into IT, internal controls—in part or in full—must be translated into technology—specifically, technological controls. Recalling the discussion on CRUD, this means to discretize an internal control into the set of technological control points within the IT infrastructure that are monitoring various user and system actions.

Figure 8-3 provides an example of some technological control points that may exist within IT infrastructure. The illustration imagines a data-driven environment (e.g., a cloud) with three such control points: access, dataflow and retention, designed to be used by various services to constrain how data is processed. Note that these controls may exist not merely for privacy, but also for security, reinforcing the value of leveraging preexisting security safeguards for the benefit of privacy. To wit, access, dataflow and retention are not just common technological controls enforced by security; they are expressly called out in myriad industry standards for safeguarding both security and privacy.

Figure 8-3: Conceptual Depiction of Technological Control Points for Cloud Services



Using Figure 8-3 as a backdrop, reconsider the privacy and security internal controls described in Table 8-5 as shown in Table 8-8.

Table 8-8: Privacy and Security Compliance Internal Controls

Preventive Privacy Internal Control	<i>Limit access of personal data to authorized personnel only.</i>
Preventive Security Internal Control	<i>Limit access of sensitive data to authorized personnel only.</i>

These internal controls, at first glance, are insufficiently detailed to be of value to an engineer. However, contrasted against Figure 8-3, it becomes evident how to discretize, and thus translate, the internal control into existing technological control points available in the infrastructure. For example, fulfillment of the above high-level internal controls could be met as shown in Table 8-9, adding atop the prior buildout of Table 8-5.

Table 8-9: Additive Example of Technological Controls

Privacy Law	HIPAA: <i>Confidentiality: In determining what information is required... [regulation]...shall include procedures to assure that the privacy of individuals receiving healthcare services is appropriately protected.</i> GDPR: <i>[...] ensures that persons authorised [sic] to process personal data have committed themselves to confidentiality or are under an appropriate statutory obligation of confidentiality.</i>	
Privacy Policy	Organizational Policy: <i>Employees processing personal data require a legitimate business need.</i>	
Compliance Internal Controls	Preventive Privacy Internal Control: <i>Limit access of personal data to authorized personnel only.</i> Preventive Security Internal Control: <i>Limit access of sensitive data to authorized personnel only.</i>	
Industry-	Preventive Privacy Internal Control:	UL-1: Internal Use— <i>[U]ses [...] PII</i>

Standard Mapping	<i>Limit access of personal data to authorized personnel only.</i>	<i>internally only for authorized purpose(s)[.]</i>
	Preventive Security Internal Control: <i>Limit access of sensitive data to authorized personnel only.</i>	AC-3: Access Enforcement— <i>The information system enforces approved authorizations[.]</i>
Technological Controls	Dataflow Control Point: <i>Minimize personal data allowed into the system itself, thereby reducing potential harms by removing data superfluous to organizational business objectives.</i>	
	Retention Control Point: <i>Age data off on a periodic basis aligned to where older data is no longer valuable towards business objectives.</i>	

As can be seen in this simple example, the internal control has been rationalized and discretized into the available control points within the IT infrastructure. Manual controls may still exist beyond the above as overlapping safeguards to meet the high-level internal controls (e.g., manual review of access logs to ensure the Access Control Point is functioning properly). Second, the discretization of the internal controls into technological controls enables a meaningful discussion of privacy risk. The technological control points may or may not be sufficient to mitigate a privacy harm. Discretizing the internal control makes patently clear the power, and limit, of IT. Here is where things come together: The privacy governance program, from the top of the pyramid of Figure 8-1 on down, can identify exactly how privacy safeguards are fulfilled within IT and enable productive discussion among stakeholders across law, policy, compliance, security and privacy on the sufficiency and effectiveness of established privacy safeguards.

8.3.2.2 Data Governance and Technological Controls

Technological controls are further augmented by the tagging of data and use established through data governance. Especially in data-driven systems, the technological control points will need to take into consideration data and use to effectively enforce privacy safeguards. Again, take the above high-level internal controls from Table 8-9 as an example. The internal controls stipulate access is limited to personal data. The control points must thus understand what personal data is to tailor controls accordingly. Likewise, use must also be understood, particularly if an internal control limits access not merely to types of data, as exemplified above, but refines control to a narrow set of authorized uses. Consider the following data categories, qualifiers and uses, which are a subset of the full categories described in ISO 19944 and provide for refinement of the technological controls described in Table 8-10.

Table 8-10: Data Categories, Qualifiers, and Uses from ISO 19944²³

Customer Content Data	Credentials	<i>Data provided by the customer to identify a user[.]</i>
	Personal Health and Medical Records	<i>Personal health data and medical records[.]</i>
End User Identifiable Data	Demographic Data	<i>[D]emographic information about end users[.]</i>
	Biometric and Health Data	<i>Metrics about the...user's inherent characteristics[.] [...] For example, [...] voice prints[,] posture maintained when walking[.]</i>
Data Identification Qualifiers	Identified Data	<i>Data that can unambiguously be associated with a specific person[.]</i>
	Pseudonymized Data	<i>Data for which all identifiers are substituted by aliases[.]</i>
Data Processing and Use	Provide	<i>[Offer] [...] capabilities [...] [to the customer.]</i>
	Market	<i>[P]romote specified products and services to users[.]</i>

With these categories in hand from ISO 19944, reimagine the following technological controls, now enhanced to consider data- and use-driven processing as shown in Table 8-11.

Table 8-11: Additive Examples of Refined Data- and Use-Driven Technological Controls

Privacy Law	HIPAA: Confidentiality: <i>In determining what information is required... [regulation]...shall include procedures to assure that the privacy of individuals receiving healthcare services is appropriately protected.</i> GDPR: <i>[...] ensures that persons authorised [sic] to process personal data have committed themselves to confidentiality or are under an appropriate statutory obligation of confidentiality.</i>	
Privacy Policy	Organizational Policy: <i>Employees processing personal data require a legitimate business need.</i>	
Compliance Internal Controls	Preventive Privacy Internal Control: <i>Limit access of personal data to authorized personnel only.</i> Preventive Security Internal Control: <i>Limit access of sensitive data only to authorized personnel only.</i>	
Industry Standard Mapping	Preventive Privacy Internal Control: <i>Limit access of personal data only to authorized personnel.</i>	UL-1: Internal Use— <i>[U]ses [...] PII internally only for authorized purpose(s)[.]</i>
	Preventive Security Internal Control:	AC-3: Access Enforcement— <i>The</i>

	<i>Limit access of sensitive data to authorized personnel only.</i>	<i>information system enforces approved authorizations[.]</i>
Technological Controls	Access Control Point: <i>1. Limit access of identified personal health and medical records only to authorized users to provide medical insurance</i> <i>2. Prevent access of identified biometric and health data and identified personal health and medical records from authorized users for marketing</i> Dataflow Control Point: <i>1. Minimize the collection of demographic data</i> <i>2. Allow the collection of credentials and identified personal health and medical records</i> Retention Control Point: <i>1. Age-off all identified data after 1 year</i> <i>2. Age-off all pseudonymized data after 5 years</i>	

Just as the discretization of an internal control into technological control points enables a meaningful and productive risk-based discussion, so does the modeling of data and use as applied across the technological control points within IT infrastructure. Taken together, stakeholders across the privacy governance program can holistically evaluate the sufficiency and effectiveness of privacy safeguards instrumented across technological control points, data and uses. In so doing, privacy engineering is actualized—translating the highest-order objectives of a privacy governance program into actionable, practical technical controls, rationalized against an organization’s evaluation of privacy risk and the fundamental capabilities available within the organization’s IT infrastructure.

8.3.3 Engineering Development Life Cycle: Enforcing Privacy Automation at Scale

Modern IT is driven by the engineering development life cycle. The engineering development life cycle aims to build solutions in support of business objectives while addressing reliability and scaling to organizational needs. In modern organizations, such as cloud providers, the engineering development life cycle is an integral part of business processes. While the engineering development life

cycle is described further in Chapter 2, it is valuable to summarize here, as the engineering development life cycle represents the third concept necessary to effectuate privacy engineering.

The engineering development life cycle is the process engineers leverage daily to scale and deliver solutions reliably and securely. Inculcation of privacy into the engineering life cycle will result in privacy becoming an intrinsic component of the development process. Once privacy engineering has been embedded and standardized into IT infrastructure and development practice, a profound goal can be realized: De facto use of an organization's IT infrastructure becomes an implicit act of privacy compliance. Following on the heels of security, which has similarly been embedded into the engineering development life cycle, this achievement ultimately simplifies privacy governance. It further enables inherent enforcement of privacy safeguards by embedding privacy into standardized tools and infrastructure. And as privacy controls become more embedded into infrastructure and development processes, engineers can leverage inherent privacy safeguards, simplifying and speeding the delivery of privacy-protective solutions in line with business needs. Not only does this strengthen the privacy program, it makes privacy itself a core component of business solutions, which is an increasingly critical desire of users of modern information technology. Embedding privacy into the engineering development life cycle ultimately translates privacy into the terminology, practices and culture of engineers. With privacy thus made meaningful to software developers, privacy engineering can be realized in practice, bringing natural, inherent and scalable enforcement of privacy safeguards to IT solutions.

8.3.4 Putting it Together: Creating a Culture of Privacy among Engineers

As much as embedding privacy into IT infrastructure and development practices is critical for the success of a privacy governance program, the establishment of a culture of privacy within engineering communities is equally critical. Engineers, ultimately, must be mindful that the designs and solutions they build respect privacy considerations.

Taken together, data governance, technological controls and, in particular, the engineering development life cycle, the foundation of a culture of privacy within an organization's engineering community can be realized. As has been discussed throughout this chapter, the aim of translating abstract privacy harms into IT-

centric terminology and practices greatly aids improved understanding of not just how privacy is safeguarded within IT, but reciprocally, for engineers themselves, enables realization of both what a privacy harm is as well as how to optimize IT to reduce problematic data actions within the solutions they build.

In making privacy meaningful and practical for engineers, culture will naturally evolve to be more mindful of privacy challenges. Herein, enforcement thus becomes not an external action by the privacy governance program but an intrinsic mindset of engineers. Moreover, through the building blocks of data governance, technological controls and the engineering development life cycle, training programs can be developed for privacy engineering. And as awareness increases, an additional benefit equally comes about wherein engineers can explain IT solutions to other stakeholders across the privacy governance program. This achievement brings the privacy governance program full circle and in this, the role of privacy in IT not just establishes itself, but demonstrably strengthens the governance program as a whole, founded upon IT itself as illustrated in Figure 8-1. With privacy thus institutionalized in IT, privacy engineering in consequence becomes professionalized. And in these twin goals, a culture of privacy naturally arises throughout the engineering community.

8.4 Evaluating Success: Assessing Sufficiency and Effectiveness of IT Privacy Governance

Information technology itself enables and increases the ability to measure the effectiveness and sufficiency of a privacy governance program. As the thread gets pulled from the top down of a privacy governance program, evaluating the program becomes at once clearer and more measurable. Assessing effectiveness begins with the structure of the compliance program underpinning privacy governance, as it establishes the key objectives and associated internal controls to evaluate the health of the overall program, fundamentally grounded in reasonable assurance. This structure provides the framework wherein risk assessment in accordance with standard risk management methodologies can be conducted.²⁴

As this skeletal structure of the privacy governance program is translated into IT infrastructure, fine-grained, measurable controls take shape, spanning both the discretized technical controls safeguarding privacy throughout the infrastructure as well as the data governance established to enable tailored control of data and use accordingly. With this structure, the privacy governance program can begin to

evaluate various aspects of the program—in real time—to measure when, where and how internal controls are enforced. Coupled with data governance, the program can further understand where personal data is and how and when it is used, thus providing greater insight into the overall privacy health of the organization and the sufficiency of the varied overlapping controls emplaced.

Importantly, not only does this enable both greater insight and faster evaluation, it enables meaningful and understandable evaluation of the technological controls as constructed in IT. For instance, considering Figure 8-3, access, dataflow and retention are not necessarily sufficient controls to safeguard against privacy harms, nor do they adequately address necessary internal controls in all situations. Additional control points may be needed pursuant to certain scenarios. Through the structure of the privacy governance program, top to bottom, tangible risk evaluation can be developed and, in consequence, improvements in privacy governance become backstopped—and grounded—by empirical evidence resulting from measurements arising from the technological controls within the IT infrastructure itself. Reasonable assurance in mind, empirically backed risk evaluation can be undertaken to determine whether IT solutions sufficiently safeguard against the privacy harms the governance program is designed to prevent. Together with the engineering development life cycle, adjustments to control structures can be quickly made, enabling rapid response and improvement across the entirety of the IT infrastructure. And ultimately, leveraging the structure depicted in Figure 8-1, and exemplified in the built-out example in Table 8-11, such adjustments can be translated across the components and associated stakeholders of the privacy governance program, enabling transparent understanding of where and how privacy risk is mitigated.

Data governance also enables improved ability to assess—and iterate upon—the proper modeling of data and use. Just as data and use must be modeled to align with business objectives, they must similarly be modeled sufficiently to identify data types and uses with enough granularity to reasonably safeguard against privacy harms. For instance, if a model only includes email addresses and individuals' names, this personal data in itself is likely insufficient to support providing of medical or financial services. Data governance makes this apparent to all stakeholders in the program and, in consequence, refinement can be had to ensure technological implementation and modeling can adequately safeguard privacy within IT, thereby improving existing technological controls in place.

8.5 Summary

Ultimately, as a privacy governance program evolves and matures to address the privacy challenges of IT, IT itself reciprocally improves the ability, fidelity and effectiveness of the program itself. Moreover, in light of the engineering development life cycle, it enables the privacy governance program to scale with technology, which is a necessity in the Information Age. The role of IT in privacy, once established, inherently strengthens the privacy governance program, as it forces the development of structured, measurable and scalable controls. This modernized approach to privacy governance, established through the strengthened role of IT in privacy, enables deep insight into privacy-impacting activities within an organization. This chapter has presented a structured approach in which such insight can be achieved, interweaving the various aspects of privacy governance: law, policy, compliance, security and technology into a coherent choreography of activities fundamentally underpinned by—and demonstrating the value of—IT's role in privacy.

Endnotes

- 1 European Union, General Data Protection Regulation, adopted 2016, <https://eugdpr.org/>.
- 2 California Department of Justice, California Consumer Privacy Act, adopted 2018, <https://oag.ca.gov/privacy/ccpa>.
- 3 Illinois General Assembly, SB1502: Illinois Right to Know Data Transparency and Privacy Protection Act, <http://ilga.gov/legislation/fulltext.asp?DocName=10000SB1502eng&GA=100&SessionId=91&DocTypeId=SB&LegID=104068&DocNum=1502&GAID=14&Session=> (accessed October 2019); Government of India, Ministry of Electronics & Information Technology, “The Personal Data Protection Bill, 2018,” https://meity.gov.in/writereaddata/files/Personal_Data_Protection_Bill%2C2018_0.pdf (accessed October 2019).
- 4 U.S. Department of Health and Human Services, Health Information Privacy, <https://www.hhs.gov/hipaa/for-individuals/guidance-materials-for-consumers/index.html> (accessed October 2019).
- 5 U.S. Congress, Healthcare Insurance Portability and Accountability Act of 1996 (HIPAA), <https://www.congress.gov/104/plaws/publ191/PLAW-104publ191.pdf> (accessed October 2019).
- 6 European Union, EU General Data Protection Regulation, <https://eugdpr.org/> (accessed October 2019).
- 7 COSO defines internal controls as “a process...designed to provide reasonable assurance regarding the achievement of objectives relating to operations, reporting, and compliance.” Committee of Sponsoring Organizations of the Treadway Commission (COSO), *COSO Internal Control - Integrated Framework*, January 2019, <https://www.coso.org/Documents/COSO-CROWE-COSO-Internal-Control-Integrated-Framework.pdf>.
- 8 COSO, Preventive controls are “designed to avoid an unintended event...at the time of initial occurrence.” *COSO Internal Control - Integrated Framework*.
- 9 COSO, Detective controls are “designed to discover an unintended event...after the initial processing has occurred.” *COSO Internal Control - Integrated Framework*.
- 10 NIST, *Security and Privacy Controls for Federal Information Systems and Organizations, Special Publication 800-53, Revision 4I*, U.S. Department of Commerce (DOC), January 22, 2015, <https://csrc.nist.gov/publications/detail/sp/800-53/rev-4/final>.
- 11 NIST, *An Introduction to Privacy Engineering and Risk Management in Federal Systems*, NISTIR 8062, DOC, January 2017. <https://csrc.nist.gov/publications/detail/nistir/8062/final>.
- 12 NIST, *Security and Privacy Controls for Federal Information Systems and Organizations*.
- 13 NIST, *Security and Privacy Controls for Federal Information Systems and Organizations*.
- 14 NIST, *Security and Privacy Controls for Federal Information Systems and Organizations*.
- 15 International Organization for Standardization (ISO), ISO/IEC 19944:2017: Information Technology – Cloud Computing – Cloud services and data: Data flow, data categories and data use, 2017, <https://www.iso.org/standard/66674.html>.
- 16 ISO, ISO/IEC 27000 family - Information security management systems, 2013, <https://www.iso.org/isoiec-27001-information-security.html>.
- 17 ISO, ISO/IEC PRF 27552: Security techniques - Extension to ISO/IEC 27001 and ISO/IEC 27002 for privacy information management - Requirements and guidelines, 2019, <https://www.iso.org/standard/71670.html>.
- 18 NIST, NISTIR 8062.
- 19 NIST, Privacy Framework, <https://www.nist.gov/privacy-framework> (accessed October 2019).

20 NIST, *Security and Privacy Controls for Federal Information Systems and Organizations*.

21 American Institute of Certified Professional Accountants (AICPA), System and Organization Controls: SOC Suite of Services, <https://www.aicpa.org/soc> (accessed June 2019).

22 DOC, European Commission and Swiss Administration, "Privacy Shield Framework," <https://www.privacyshield.gov> (accessed October 2019).

23 ISO, ISO/IEC 19944:2017 - Information Technology - Cloud Computing - Cloud services and data: Data flow, data categories and data use, 2017, <https://www.iso.org/standard/66674.html>.

24 An example of a risk management methodology is ISO 31000, which provides standard guidelines, principles, framework and process for assessing risk. ISO, "ISO 31000 - Risk Management," June 29, 2019, <https://www.iso.org/iso-31000-risk-management.html>.

CHAPTER 9

Cybersecurity and Privacy Lujo Bauer Computer security—commonly also called cybersecurity and IT security—seeks to maintain the correct and intended functioning of computer systems in the face of attacks.

Security and privacy in computer systems are closely connected. Probably the most visible aspect of this connection is that many privacy breaches are the result

of security failures—unpatched software bugs, poorly configured security mechanisms or reuse of credentials—that enable an attacker to compromise a computer system and steal sensitive private data.

In the May 2017 Equifax data breach, for example, over 100 million people's sensitive information was stolen, including names, Social Security numbers, dates of birth and credit card numbers.¹ Two failures conspired to make this breach possible:² The first failure was a bug in the software that Equifax used to build its web applications. This bug made it possible for an attacker to trick the web server hosting the Equifax website into running software *created by the attacker*. Clearly, this bug could be taken advantage of to perpetrate a range of harms, including stealing data, which is what happened. The second failure was a *process* failure. It turns out that the software bug in question was fixed by the vendor in March of 2017—two months before it was taken advantage of to perpetrate the breach. It was public knowledge that the bug had been fixed and an updated version of the software was available in March; if appropriate processes had been instituted for reacting to newly disclosed vulnerabilities, Equifax's website might have been updated, and this particular method of attacking the website would not have succeeded.

The Equifax example shows that software vulnerabilities and failures in security processes can lead to privacy breaches. There are many other connections between computer security and privacy, however. To mention but a few: Many of the aspects of computer security that concern themselves with *process* and *regulation*, rather than directly with technical security mechanisms, have analogues that specifically concern privacy rather than, or in addition to, security. The specific security goals that we try to achieve by implementing security mechanisms are often also privacy goals, but sometimes achieving a security goal will come at the expense of privacy. Security mechanisms themselves can have software vulnerabilities or other flaws that allow an attacker to circumvent the protection mechanism.

This chapter will provide an overview of the aspects of computer security that are most relevant to privacy. We will start by discussing the different places in the *systems development life cycle* where security activities need to take place, referring to the categories of computer security work defined by the U.S. National Institutes of Standards and Technologies' (NIST's) National Initiative for Cybersecurity Education (NICE) framework.³

Next, we will provide an overview of the *ways in which software fails*, either in the face of an attack or when left to its own devices. Following that, we will examine the so-called CIA triad properties—confidentiality, integrity, and availability—that security mechanisms commonly seek to provide. The careful reader will immediately notice that one of these, confidentiality, is important for achieving privacy goals; it turns out that the others, as well, are significant, and not just because they are tightly connected to each other. We will also discuss *access control*, the process by which a computer system tries to ensure that data is only accessed or modified by the users who have the right to do so.

Then, we will review some of the basic principles for designing secure software, like the principle of *least privilege* and the *defense in depth* principle, both of which are important even when the main focus is on preventing privacy leaks that are not the result of security failures.

Finally, this chapter will discuss a collection of operational processes or issues that impact security and privacy. Some of these processes are for detecting and reacting to breaches or for learning about and reacting to discovered vulnerabilities—either of which could have helped avoid most of the data theft that took place during the Equifax breach. Others concern today’s common practice of allowing employees to use their personal computers or mobile devices for company needs; we usually refer to this as “bring your own device” (BYOD). We will examine how managing these operational issues causes privacy to sometimes be traded off for convenience or security.

9.1 The Breadth of Computer Security Work
Keeping computer systems and their data secure is a large task composed of many specialized ones. As part of many of these tasks, privacy goals also need to be specifically considered or privacy considerations weighed. One taxonomy of computer security work, i.e., of the tasks that need to be accomplished to keep computer systems secure, is advanced by NIST’s NICE

framework. The NICE framework divides computer security work into the following categories: *securely provision, operate and maintain, protect and defend* **and** *investigate*—**all of which can be thought of as focusing on a specific computer system—and** *analyze, oversee and govern, and collect and operate, all of which generally have a broader scope.*

Securely provision. This category encompasses the tasks narrowly focused on developing software to be secure. Software development starts with *system requirements planning*, during which both security and privacy requirements must be defined. These are drawn from various stakeholders, such as potential customers, and may include legal and regulatory considerations. For example, software may need to be designed to support the controls mandated by the EU's General Data Protection Regulation (GDPR), such as the ability to efficiently identify all the personal data stored in a computer system that belongs to a single individual.

After requirements are defined and before writing the software starts, the *architecture of a system is designed*. This may include deciding on the technologies that will be needed or the way the tasks or data of the system will be organized to fulfill both the functional requirements of the system and its security and privacy requirements. For example, a large system that has users from multiple countries may partition its data storage into multiple databases that can be geographically located so as to comply with national privacy regulations that specify where the data of a country's nationals may be held.

Technology research and development may be needed during the early phases of system design if the requirements cannot be met by existing solutions.

After a system is architected, *software development* starts. In this phase of creating a system, the requirements and system architecture are turned into a functional computer system. This may involve writing new software to implement desired functionality or, more commonly, modifying and building on existing software.

As elements of the system become sufficiently developed, they are subjected to *test and evaluation*. This phase of systems development ensures that each component of the system, as well as the system as a whole, meets its requirements.

Two additional work areas span all the aforementioned phases of developing a system. One, simply called *systems development*, focuses on ensuring that all the phases take place—from gathering requirements to testing the finished system—and that each phase is subdivided into the activities needed to effectively carry it out. The other work area, *risk management*, is responsible for identifying, documenting and managing any risks posed by the system. These risks may be related to software quality as defined by the internal standards of the organization creating the software, compliance with regulations, or security and privacy. Some risks may be identified in the requirements phase and mitigated through the design of the system architecture. Other risks may be mitigated after the system is deployed; for example, by providing additional training to users to prevent them from creating easily guessed passwords.

Operate and maintain. The operation and maintenance of a system is just as critical to its security and privacy goals as the way the system is created in the first place. *Systems administration*, for example, ensures that a system is installed and configured, both initially and over time, to meet security and privacy goals. *Network services* concern similar tasks for the computer networks across which a system is deployed or that a system's users employ to interact with the system. *Customer service and technical support* are sometimes overlooked when it comes to thinking about the security and privacy of a system, with dire consequences: Many attacks on computer systems—for instance, those that lead to theft of proprietary or personal data—target customer service and technical support. An example is phone SIM-card-swapping attacks, where an attacker tricks a mobile phone service provider into switching a victim's phone number to the attacker's device.⁴ The attacker can then use the stolen phone number to reset the victim's online banking and other passwords and thus gain access to the victim's private information and more.

Systems often generate or accumulate large volumes of potentially sensitive data. *Data administration* is concerned with managing the databases that house this information. Other aspects of operating a system as defined by the NICE framework include *systems analysis*, which examines the interoperation of an organization's systems, and *knowledge management*, which focuses on the

processes and tools for ensuring that an organization can keep track of the systems it has created and how to operate them.

Protect and defend. In addition to the previously described activities, part of attempting to ensure that a system will not be compromised is actively protecting the system. This includes *vulnerability assessment and management*—assessing and developing plans to address threats posed by attacker and vulnerabilities in the system being defended. Preventing or detecting attacks often requires infrastructure such as firewalls that prevent malicious network traffic and monitoring systems that make it possible to detect attacks. Creating and managing these is called *cyber defense infrastructure support*. Using these defensive components to prevent or detect attacks is called *cyber defense analysis*.

Finally, *incident response* takes place when attacks do occur; it is the process of documenting the details of the attack, determining the impact of the attack on the system and then deciding on the appropriate actions. The actions may include remedial measures to restore the system to a working state, notifications to users who may have been affected, and the development of plans to fix any software vulnerabilities that made it possible for the attack to succeed.

The importance of these tasks is highlighted by recent data breaches, such as the Equifax breach and the earlier Target credit card breach, where some of these tasks seem not to have been effectively carried out and this failure significantly contributed to the success of the attack or its fallout.⁵ In the Equifax breach, for example, knowledge of the vulnerability exploited by the attacker, as well as the fix for that vulnerability, was disseminated across standard channels; yet the vulnerability was not sufficiently addressed to prevent the attack. Unfortunately, Equifax was not an exception; multiple surveys indicate that many successful attacks would have been prevented by patching systems more promptly.⁶

Protecting and defending systems, as well as operating and maintaining them, involves tradeoffs between privacy and security, one of which relates to how much data is collected about how an application, a system or a network is used. Collecting more data may make it possible to detect attacks that might otherwise remain hidden and to better diagnose why a system did not perform as expected. In doing so, collecting more data may make it possible to make systems more secure, and so indirectly lower privacy risks associated with security breaches. On the other hand, collecting detailed usage information itself increases privacy risks, for example, for users whose detailed behavioral information is now stored and could be misused or lost, as well as to the organizations that take on the risks

associated with safeguarding this information. One way of mitigating the risk of collecting more information is to carefully anonymize or pseudonymize any personal identifiers.

Investigate. If a system is compromised through an attack, a thorough, timely investigation is important: to (1) discover what specific data may have been compromised—for example, so that consumers can be notified, (2) discover the specific method of compromise, so that similar attacks can be avoided in the future and (3) identify who perpetrated an attack, so that they can be prosecuted. As alluded to above, the success of an investigation may hinge on how much data is collected about the operation of the system. The NIST NICE framework includes several other cybersecurity work categories that impact individual systems but also have a broader scope.

Oversee and govern. This category of work deals with aspects of cybersecurity work such as legal advice, executive leadership and training and education. Relevant legal aspects could include awareness of and adherence to privacy laws, such as the GDPR. Training could include requiring a subset of developers to be trained on privacy engineering.

Collect and operate and analyze. These two areas of work deal with the collection of “intelligence”: information about potential attackers’ capabilities, intentions and possible ongoing activities. Activities in these work areas inform activities in the other work areas. For example, if an attack seems likely, then the level of effort invested into protecting and defending might increase, or the requirements might reflect that a system needs to be constructed to be more robust to attacks.

9.2 Attacks and What Makes Them Possible
Attacks that involve breaking into computer systems usually involve some combination of exploiting a software flaw, using malicious software and acquiring and using stolen login credentials. Denial-of-service (DoS) attacks, on the other hand, do not involve breaking into

systems but nevertheless cause substantial harm.

9.2.1 Software Vulnerabilities

Many attacks on computer systems involve a software error, or bug. The software bugs that an attacker can take advantage of to carry out an attack are called *software vulnerabilities*. Not every bug is a vulnerability. For example, if a programmer incorrectly implemented some mathematical operation so that it gives the wrong answer, we would call it a bug, but if this mistake does not present an attacker with a way to attack the program that performed this computation, we would not call it a vulnerability.

Probably the most well-known type of software vulnerability is a *buffer overflow*. A buffer is a contiguous area in the memory used by a program. When copying data into a buffer, it is important to make sure that the data is smaller than the buffer. If the data being copied into the buffer is bigger than the buffer, and appropriate checks to detect this are not in place, then the data that does not fit in the buffer may overwrite memory immediately next to the buffer—hence the name buffer overflow. If the attacker is able to control the data being copied into memory, they may be able to choose how memory is overwritten in a way that allows them to alter the intended behavior of the program. With enough sophistication, such alterations can give attackers the ability to execute arbitrary code on the victim machine.

A closely related type of software flaw that makes it possible for an attacker to exploit a buffer overflow is an *input-validation flaw*. Software often receives input from untrusted sources that it uses to guide its computation. For example, a search engine allows a user to type in a search string; that string is an input to the program that implements the search functionality. If this input string contains characters or sequences of characters the program is unprepared for, it might execute unexpectedly. Common types of attacks that take advantage of input-validation flaws are buffer overflow attacks, described above, and *cross-site scripting* (XSS) and *structured query language* (SQL) *injection attacks*. XSS attacks take advantage of input-validation flaws in a website or web application to inject code into a user's web browser, which can then take any data available to a legitimate user and send it to the attacker. XSS was allegedly responsible for a 2018 breach of the British Airways website that led to the theft of financial and personal data

belonging to 380,000 customers.⁷ In SQL injection, specially crafted inputs, unexpected by the application, cause database queries to go awry. An SQL injection attack was responsible for the theft over 100 million debit and credit card numbers from Heartland Payment Systems in 2012, which was at the time the biggest data breach ever.⁸

9.2.2 Malware

Attacks on computer systems often involve *malware*, malicious programs designed by the attacker. Malware is installed on a victim user's computer either by the exploitation of a software vulnerability or at a time when the attacker has unfettered access to the computer—for example, when software is being loaded onto the computer before the computer is sold. Malware causes a wide range of harms. *Keyloggers*, for example, are a type of malware that records a user's keystrokes, including when typing usernames and passwords. A keylogger was used as part of an attack on Cathay Pacific Airways in 2018, which led to the information of more than nine million passengers being exposed.⁹

Malware often changes the behavior of a computer system so as to avoid being detected; such malware is commonly called a *rootkit*. Because they are hard to detect, rootkits can run on an infected computer for a long time, potentially stealing user information or using the computer for nefarious purposes, such as distributing spam. Malware sometimes coordinates with *command-and-control servers* to put large sets of computers under the control of a single organization; such a set of computers is called a *botnet*, and each of the infected computers a *bot*. Botnets are often used by attackers to mount *distributed denial-of-service* (DDoS) attacks, in which the computers that are part of a botnet are instructed to connect to or interact with a victim server; if the botnet is large enough, the victim server may be overwhelmed with requests and crash. In 2016, a DDoS attack on domain name servers, a part of the internet infrastructure, disabled many high-profile sites such as Twitter, Netflix and CNN.¹⁰ According to the 2019 Verizon Data Breach and Incident Report, DDoS attacks in fact account for the majority of all security incidents.

9.2.3 Stolen Credentials

Most attacks in which an attacker breaches a computer system involve stolen credentials.¹¹ Attackers obtain legitimate users' usernames and passwords and then access a victim system under the guise of a legitimate user. The credentials

can come from many sources. They may have been stolen in previous attacks and made available, free of charge or for a fee, on the internet. They may have been captured by keyloggers installed by the attackers themselves, or they may have been collected through *phishing*.

Phishing is a type of *social engineering attack* in which a victim is tricked into logging in to what they think to be a legitimate site, but which is actually just a front set up by the attacker to collect users' login credentials. Phishing attacks are commonly delivered via email; for example, in the guise of messages asking users to reset their passwords. Besides tricking users into revealing their credentials, phishing attacks might try to trick or coerce victims into sending money to the attackers—for example, by asking to send money to a relative stranded on a trip or by threatening to release nonexistent compromising information about the victim. Most phishing attacks are not customized to specific potential victims; for example, the same phishing email asking to send money to a stranded relative might be sent to many potential victims. In *spear phishing*, on the other hand, attackers customize their messages to include personal information they have already uncovered about the victim; for example, using the actual name of a relative of the victim when asking for money to be sent. Spear phishing attacks sometimes target high-value individuals, for example, executives whose credentials may be particularly valuable. This variant of phishing is called *whaling*.

Spear phishing attacks are particularly successful. They are made easier by the amount of information that can easily be discovered about potential victims; for example, on both professional networking sites like LinkedIn and social networking sites like Facebook.

9.2.4 Misconfiguration, Insider Threat and Other Types of Attacks Another common cause of breaches is misconfiguration. Sometimes, one of several security mechanisms is misconfigured, which doesn't leave the system or its data completely exposed but makes it easier for an attack to succeed. A misconfigured firewall, for example, was part of the cause of a 2019 breach of 109 million records from Capital One.¹² Other times a misconfiguration leaves sensitive data publicly accessible to anyone who stumbles across it (even though stumbling across it may be unlikely). UW Medicine

inadvertently exposed more than a million customers' records containing personal health information in 2018. In that case, not only had internal files containing sensitive data accidentally been made publicly accessible, but they also became accessible to internet search engines—the leak was discovered by a patient finding the sensitive files when they searched for their name using Google search.¹³

Many attacks are perpetrated by or take advantage of insiders: Users who have elevated access or knowledge that can benefit the attacker. Insiders with access to sensitive information may decide to change jobs and take the sensitive information with them. In a famous recent alleged insider data breach, a Google employee working in its autonomous car division left the company and took thousands of files related to its autonomous car technology; a lawsuit was settled.¹⁴ An even more famous example is Edward Snowden's theft of thousands of classified documents, some of which he was authorized to access with his own credentials and others that he accessed with credentials from coworkers.¹⁵ Insider threat is particularly challenging to manage. Doing so can involve additional monitoring—often at the cost of employees' privacy—and instituting additional access-control checks, discussed in Section 9.4, and other safeguards such as prohibiting the use of USB devices, which can interfere with efficiency and convenience.

9.3 Security Properties and Types of Adversaries
So far, we have not yet discussed what it means for a computer system to be secure. For such a discussion to be meaningful, security must be defined more concretely, in terms of specific properties. The properties most commonly used to describe the security goals of a computer system are *confidentiality*, *integrity*, and *availability*.

Confidentiality, also called *secrecy*, refers to keeping sensitive data away from unauthorized users, including attackers. Depending on the data in question, a failure to protect confidentiality may also be a failure to protect privacy. The various data breaches discussed in this chapter are violations of confidentiality goals, and because the data in question is sensitive and associated with individuals, they are also violations of privacy. *Integrity* refers to preventing unauthorized modification of data, which could include replacing a correct value with an incorrect one or deleting data. While the link between integrity and privacy may not be as immediately clear as that between confidentiality and privacy, there is nevertheless a strong connection between the two. Privacy regulations such as the GDPR explicitly call out data quality as a requirement. This typically refers to collected personal information being correct and complete, which it could fail to be either because of errors or omissions at data collection time or because of failures to maintain the integrity of the data once it has entered a computer system. The last of the CIA triad properties, *availability*, focuses on ensuring that computer systems are available to legitimate users even when they are under attack. Availability, too, is important for privacy—implementing fair information practices often requires positive action to be taken, such as to notify consumers of a change in data usage policy or to provide consumers with timely access to their data. Interfering with the availability of systems that support these positive actions may also interfere with those actions, which are in support of privacy.

The CIA triad requirements are in tension with each other: Many ways to achieve one requirement may make another one harder to accomplish, so computer systems typically try to balance the extent to which they achieve these requirements. For example, to prevent the inadvertent or malicious deletion of data, which is part of ensuring the integrity of the data, many copies of the data may be kept; however, this may increase the risks to confidentiality, since it may now be possible for an attacker to gain access to the data if they successfully breach any one of the systems on which the data is replicated. As another example, databases are sometimes replicated in multiple locations to ensure that data can be accessed quickly and when network links are down. This improves availability but may pose challenges to integrity, since if a data item is changed in multiple locations in different ways, it may be difficult to determine which change should be considered the right one.

A critical concept in computer security is that of an *adversary*. Desired security properties, as discussed above, may be in tension with each other, but to understand the degree to which a particular set of mechanisms will be able to achieve these properties, it is also necessary to consider the computational capabilities and knowledge available to an adversary. For example, the mechanisms employed to maintain data integrity against an external attacker may not be adequate to also protect against insider threats. On the other hand, the mechanisms needed to achieve a property even in the face of a very powerful adversary—for example, through adding expensive cryptographic protection and many security checks—may make a system so painful to use that this will interfere with its availability, which might in turn make the system too unappealing to potential users.

9.4 Access Control Protecting the integrity and confidentiality of data while it is stored on disk or while it is in transit is typically accomplished through the use of cryptography. Cryptographic primitives are algorithms that provide the building blocks of cryptographic protocols and include hash functions (e.g., SHA-256) and symmetric key (e.g., AES) and public key cryptographic algorithms (e.g., RSA).

Cryptography is discussed in more detail in Chapter 3. For now, we will say only that the functionality of the most commonly used cryptographic primitives is defined specifically in terms of their ability to provide secrecy or integrity. Secrecy is provided by encryption, although many implementations of encryption do not provide integrity. Integrity is provided by

digital signatures and message authentication codes (MACs), although these accomplish nothing for secrecy. Hence, when using cryptography to protect data, it is critical to choose the cryptographic primitive that provides the property we wish to achieve.

For data to be useful, it needs to be accessed, either to be shown to consumers or used in a computation, or to be updated, as in the case of a database entry that holds a consumer's home address and needs to be updated to reflect that the consumer has changed addresses. Some methods of accessing data for the purpose of using it in a computation rely on a variant of encryption called *homomorphic encryption* to perform these computations without ever decrypting the data. In most practical cases, however, when data needs to be read or written, there is no technical mechanism to stop a user who was permitted to access data from using it or changing it in potentially unexpected or unwelcome ways. Hence, it is very important to ensure that data can only be accessed by users who are authorized to use it, and that these users can manipulate the data only in the specific ways that have been permitted to them. For example, designated users within an enterprise may be authorized to access clients' email addresses in a database, but only for the purpose of retrieving them; the same users may not have been authorized to change those addresses. *Access control* is the process of controlling which users have access to which data and in which way. In enterprise settings, access control is also sometimes referred to as *identity management*. Access control consists of two major parts: *authentication*, or determining the identity of the user who is attempting to access a resource, and *authorization*, or determining whether a request to access a resource (typically, but not always, by an authenticated user) should be granted.

9.4.1 Authentication

For the purpose of specifying access-control policy as well as for making access-control decisions, the identity of a human user is typically abstracted in a computer system as their username or another similar label. Before allowing access to protected resources, however, the computer system must identify the

actual human being sitting behind the keyboard; this process is called *authentication* and is discussed in detail in Chapter 4. Informally, authenticating to a computer system is often referred to as *logging in*.

Different methods of authenticating a user may lead to different levels of confidence that this identification was correct. For example, an authentication based on a username and a password will not be as confident as an authentication that additionally requires the user to input a temporary code generated by an app on their mobile phone. This is because an attacker is more likely to have stolen a username and password than to have done that and also stolen that user's mobile phone. Access-control systems, such as Microsoft's Dynamic Access Control, can capture this distinction in authentication confidence: Policy can specify, for example, that particularly sensitive files can be accessed only by a permitted set of users, and only when those users have confirmed their identity via a method in addition to providing the correct username and password.

In many situations, the system component that authenticates a user learns various pieces of private information about the user, such as their phone number, date of birth, or mother's maiden name. Authentication systems can also ask users to supply answers to *security questions*, which are typically personal questions to which the correct answers are unlikely to be known to people other than the specific user. Such additional personal information and answers to security questions are often used to authenticate a user who has forgotten their password. This kind of authentication is called *backup authentication*, since it takes place only when the main approach to authentication cannot be used. This additional information may also be used when more confidence is desired of the authentication decision; for example, at the time of the first observed authentication attempt from a different computer than the one from which the user has previously authenticated. That the authentication component learns various private information about users has consequences for privacy. Among them is that users may be forced to divulge personal information that they would prefer not to share, and that the accumulation of such personal information raises the chance of harm should the authentication component be compromised by an attack and the information stolen by an attacker.

9.4.2 Authorization (or Access-Control) Mechanisms

Authorization consists of *mechanism*, which is the technical

means for allowing or denying access, and *policy*, which is the specification of who should be allowed or denied which kind of access and under what circumstances. Ideally, the capabilities of an access-control mechanism match what the access-control policy seeks to accomplish. For example, if an access-control policy states that some users should have only *read* access to data and others should have both *read* and *write* access, then the access-control mechanism should provide the capability of giving access to data in a mode where it can be read but not changed, as well as a mode in which it can be both read and changed.

Deployed access-control mechanisms are sometimes not flexible enough to implement the policies we wish to implement. For example, a financial advisor at a bank may work with a specific set of clients, and so ideally the advisor's access to the bank's customer database should be constrained to just the data belonging to its clients, which may correspond to specific rows in a relational database. Yet, some popular databases, like MySQL, do not natively implement access-control mechanisms that control access at a per-row level. In such a situation, either additional access-control mechanisms need to be manually added through software, which can be laborious and prone to errors, or it may be impossible to implement the policy of giving users access to only specific rows in the database.

As these examples show, access-control mechanisms can differ in the *granularity at which they protect* data as well as in the *type of access* they are able to regulate. With respect to granularity of access, we discussed access to database tables versus access to rows in database tables. Access to data stored in files on a computer system is typically regulated at the granularity of files. In other words, it is rarely possible to specify that a user should be allowed access to just part of a file. Access control applies not just to users but also to programs, which often run on behalf of some user or set of users. A program may run on behalf of a specific user, in which case it can typically access only the data and resources for which that user is authorized. Some programs run on behalf of any user, and so may in principle need to be able to access any data that any of their users can access. Web server software is typically in this category, since it often needs to provide service to anyone on the internet. Hence, the program that implements a banking website

may have access to the financial information of all clients of that bank, but it would implement additional mechanisms to try to ensure that any specific instance of the web server program accesses only the data of the specific client who has logged into it.

With respect to type of access, we discussed the distinction between *read* and *write* access to data. The types of access sometimes supported are far richer. For example, the NTFS file system that is used by recent versions of Microsoft Windows also supports *read & execute* access, *modify* access and *list folder contents* access. Hence, it is possible to specify that a user may read a program file but not execute the program, or that a user is allowed to change the content of a file but not delete it.

9.4.3 Access-Control Models

Access-control systems differ in their approaches to specifying policy. The different approaches to specifying policy are often called *access-control models*. Access-control models are typically based around *subjects*, the users or programs who may be granted or denied access, and *objects*, the resources to which access is being regulated. We have so far discussed files and database tables as examples of objects. Other objects we might want to control access to could be functions—to distinguish who may invoke sensitive functions, for instance—and other computer resources, such as network interfaces.

One approach for specifying access-control policy is using *access-control lists* (ACLs). In this approach, every object is annotated with a list of the subjects who are allowed to access it, as well as the type of access that they are allowed. The subjects could be identified individually, but they could also be consolidated into groups, such as administrators. In this case, the group name is used as the subject, and a separate specification describes which individuals belong to which groups. Modern versions of Linux generally support ACLs.

Another popular model, *role-based access control* (RBAC), specifies who is allowed access in terms of *roles*. A user may be associated with a number of roles; for example, one for each of their responsibilities within an enterprise. The right to access data objects, such as files on a file system, is similarly associated with roles rather than directly with individual users. The access-control system will then give a user access to a file based on whether the file is labeled with a role for the one that has been assigned to that user. Because permission to access specific files and resources is specified through roles, it can be easier to keep up to date than if

permission were specified in terms of individual users. For example, when a user is assigned to a new role within an enterprise, in RBAC that will automatically make it possible for the user to access any new resources associated with that role, and it will remove the user's ability to access resources associated with roles they no longer hold.

Other models, such as *attribute-based access control* (ABAC) and *policy-based access control* (PBAC) allow access-control policy to be specified in terms of *attributes* that could describe users, objects or properties of the environment. This flexibility makes it easier to translate a desired policy from the way we would naturally express it in English to a specification in the access-control system. For example, the policy "Charlie is allowed to access sensitive files related to his projects only from the corporate network, but may access nonsensitive files related to his projects from anywhere" might use roles to give Charlie access to specific projects and attribute-based rules to capture the constraint that sensitive files should be accessible only from the corporate network.

Access-control systems differ by who is authorized to configure the access-control policy. In *mandatory access control* (MAC), policy is set by administrators; users have no ability to change the policy, even for their own data. In contrast, *discretionary access control* (DAC) systems allow users to change the access-control policies for the data they own.

Many access-control systems used in practice, such as Microsoft's Dynamic Access Control, introduced with Windows Server 2012, combine ideas from these various access-control models and approaches. This makes it possible, for example, to specify policy following the RBAC paradigm when convenient, but also to fall back on ACLs as well as to specify when users can change the access-control policy and when they cannot.

If the data being protected by an access control system is personal information, then the method of specifying policy, as well as the granularity of objects and the type of access given to them, can all have an impact on privacy. For example, if it is necessary for an analyst to have access to specific rows in a database (corresponding, say, to specific individuals' data), but the access-control system only supports giving access at the granularity of database tables, then we might be forced to allow access to the entire table. The consequence is that the analyst will have access to many database rows (hence, many individual users' data) that they have no need to access, increasing the risk of data compromise if the analyst turns malicious or their authentication credentials are stolen by an attacker.

It might seem that an access-control system that allows more fine-grained control and more ways of specifying policy is always better, since it would expose the least amount of data to unnecessary risk. However, if more fine-grained control also means the access-control system is more complex to configure, that complexity could increase the number of mistakes administrators make when specifying policy, and these mistakes could start being the dominant reason why data is unnecessarily exposed. Such an access-control system configuration mistake led to the apparent theft of memoranda from a computer system in the U.S. Congress in 2003.¹⁶

Another practical challenge in access control is that the system administrators who *configure* access-control systems are not the same people who *decide* what policy should be implemented. The person deciding on a policy is often a manager, who instructs a system administrator to implement that policy, such as giving an employee access to resources they require to complete a new task. But when this task is complete, the manager might easily forget to remind the system administrator to revoke the access the employee was given. A 2009 study showed that these kinds of challenges on the human side of configuring access-control policy frequently led to access-control systems being misconfigured, typically in ways that unnecessarily gave access to data.¹⁷ This implies that the method of specifying policy can have an impact on privacy too: If the abstractions in the access-control system are a good match for the abstractions using which decision-makers—or laws and regulations—express policy, then it is more likely that desired policy will be correctly implemented.

9.4.4 Federated Identity

The discussion of access control and authentication thus far did not tackle an important challenge: How these processes work effectively in a setting where many enterprises and organizations maintain their own separate computer systems, with independent methods of authenticating users and access-control systems that implement different access-control models.

Historically, each computer system that needed to authenticate users did so independently. If usernames and passwords were used for authentication, this meant that a user would have to create a username and password for each computer system that they would need to authenticate to. When individuals access many computer systems—and today it is common for people to have accounts on dozens or hundreds of systems—keeping track of so many usernames

and passwords is inconvenient, to put it mildly.¹⁸ Another reason to seek a better solution is that each computer system that authenticates users will need to safeguard the users' credentials, lest they be stolen and misused.

An early solution to this problem was in the form of protocols like Kerberos, which separated authentication into a service independent of the computer system or service that a user wanted to access.¹⁹ This service could then authenticate users on behalf of different computer systems; essentially, the authentication service would vouch for the user. Kerberos was typically used within a single organization or enterprise, allowing that organization to have a single point for authenticating users.

Kerberos was a precursor or an early form of *federated identity management*, which is the practice of outsourcing authentication not just to a different service within an organization, but to a different organization. In federated identity management, the service that authenticates users is called the *identity provider* (*IdP*) and the services that rely on the IdP to authenticate users are called *service providers* (*SPs*). Federated identity management is also called *single sign on* (*SSO*), since once a user authenticates, or signs on, with the identity provider, the identity provider can vouch for that user's identity to any service provider without requiring the user to authenticate again. Today, websites frequently allow users to authenticate with Google or Facebook instead of with the website itself.

Federated identity management can go beyond just authenticating users: Identity providers can also supply service providers with attributes that describe users. For example, if an identity provider knows a user's age or nationality, it can provide this information to service providers, in addition to or even instead of the user's name. For example, if a service only cares that users are at least 18 years old, then the identity provider's assertion to the service provider could include just this information, without any additional information about the user's identity. This has clear benefits for privacy, since the user's identity can be kept hidden from the service provider.

Federated identity management also has other advantages, for both users and service providers: Users no longer have to remember multiple sets of authentication credentials, and service providers are relieved of the burden of implementing authentication and protecting users' authentication information. This comes with a cost, however. Every time a service provider needs to authenticate a user, the identity provider will be consulted; hence, the identity provider learns all the service providers each user visits as well as in what order, at

what times of day and from what locations. This can add up to a far more detailed picture of a user's behavior and preferences than users may be comfortable sharing with an identity provider—clearly a privacy concern.

Federated identity management is closely related to *cross-enterprise authentication and authorization*. In cross-enterprise authentication and authorization, two enterprises may each run their own identity provider, primarily intended to authenticate users within each enterprise. For business reasons, however, the two (or more) enterprises may decide to trust each other's identity providers. This enables company A to allow users from company B to access A's computer systems, but while relying on B's identity provider to authenticate these users. Unlike the case in typical uses of federated identity management, these identity providers would be configured to work only with service providers from the two enterprises. In a cross-enterprise setting, it is also more common for identity providers to give service providers information about the roles and other attributes of authenticated users.

9.5 Principles for Building and Operating Systems to Be More Secure

There is no recipe, unfortunately, for how to build or operate a computer system so that it will not be compromised by an attacker. However, following a set of basic principles can reduce the chance of an attack succeeding and the harm that a successful attack can cause. The principles we will discuss have stood almost unchanged since being introduced by Saltzer and Schroeder in 1975.²⁰

Economy of mechanism. A simpler mechanism is less likely to have flaws than a more complex one. Hence, all other things being equal, the simplest security mechanism that suffices for a given task is likely the best one.

Open design. A long-standing principle is that the defender should not rely on the details of their security mechanisms remaining secret from the attacker—also

called *security by obscurity*—as a means to keep their system secure. A determined attacker is often able to bribe, steal or reverse-engineer their way into understanding the system they are attacking sufficiently to develop effective attacks (if any are possible). Not relying on the details of the mechanism remaining secret does not mean, however, that the defender cannot keep any *information* secret. In particular, most cryptographic mechanisms rely on the defender possessing a secret that the attacker is assumed not to be able to learn.

This principle is sometimes used as an argument to use open-source software instead of closed-source software. In most cases, however, the choice between the two is more complicated. The open-design principle does not unequivocally point to using open-source software; it merely asserts that if closed-source software is used, then it should not be considered more resistant to attack merely because the attacker cannot readily access it. Other important issues to consider when choosing what software to rely on are its track record, how quickly vulnerabilities are fixed by its developers, and the extent to which the software has been tested in practice or by software analyses.

Complete mediation. Complete mediation is achieved when every avenue by which a resource can be accessed is protected by a security check. This is akin to putting a lock on every door to a house. It seems obvious that this is an important principle to follow, but it can be surprisingly easy to forget. In an access-control setting, the principle of complete mediation also implies that access-control policy must be carefully protected so that, for example, a user who is not authorized to change a file also cannot change the policy so as to allow themselves to change the file.

This principle has ramifications beyond software design, too: It implies that if some information can only be accessed by authenticated and authorized users of a software, then similar restrictions should be put on how that information can be accessed if a user calls a help desk.

Least privilege. Echoing the economy of mechanism principle, the least-privilege principle asserts that any user, computer system or component of a computer system should have only the privileges it needs to do its job, and no more. If a component is compromised, any privileges or capabilities that it possesses are transferred to an adversary; the least-privilege principle ensures that harm is minimized.

This principle too applies beyond the design of software and computer systems: It should also be followed by users of computer systems, and particularly those

who normally have elevated privileges, such as system administrators, developers and sometimes help desk staff. Users with higher privileges than normal could be a tempting target for attackers who may attempt to compromise those users through either digital means, e.g., by installing a keylogger on their computer, or through more traditional means, also called rubber-hose attacks, e.g., physical threats and blackmail.

Multiple layers of defense. When possible, the security of a system should be protected redundantly or with complementary mechanisms that are unlikely to be all compromised by the same attack. A mistake that can compromise a computer system can creep in at many points—during design or implementation, through improper configuration or during operation and maintenance. Relying on a single mechanism, a single layer of defense, means an unlucky mistake might leave a system exposed to attack.

Psychological acceptability. Systems have users, and security mechanisms that make unreasonable demands on the users—on their attention, their knowledge, or their ability—are likely to fail. These failures may even be caused by intentional misuse by *benign* users, who may find a security mechanism so inconvenient that they purposefully work around it. A common example is sharing passwords: Users are typically asked to keep passwords secret and make them unique, but in many workspaces, passwords are written down on Post-it pads to make it possible for employees to access computer systems they need to do their jobs. In this case, it is the inflexibility of a security mechanism and the unreasonable demands it puts on users that cause it to be willfully circumvented. Hence, to be effective, security mechanisms must be *usable* by their intended operators.

Another example of a clash between security and practicality occurs surrounding the BYOD phenomenon. BYOD is the increasingly accepted practice of allowing employees to use their own mobile phones and laptops to perform work-related tasks, specifically, work-related tasks that require those devices to be used to access potentially sensitive data or internal company networks. From a security and privacy standpoint, allowing BYOD is a risk: Employees' personal devices may contain untrustworthy software or hardware, and so could be leveraged by attackers to steal user credentials or other sensitive data, or even as vehicles for further infiltrating company systems. Technical solutions, such as installing monitoring software on personal devices before they can be used to access company systems, may mitigate the risks, but only to a small degree. Yet,

despite the obvious risks, practical concerns such as cost savings and convenience often outweigh the safer choice.

Safe defaults. Systems should be configured to provide security out of the box, without any intervention. Systems that fail to do so run the risk of being attacked before they are reconfigured to be more secure; they also encourage users to leave them in an unsafe default state, since that may be more convenient for users, who may not have sufficient awareness of the consequences of this behavior for security. Finally, systems that are by default in an unsafe state may be more vulnerable to attacks in which the first step is to reset the system to a prior or default state.

A notorious example of overly permissive defaults is Facebook's 2009 decision to guide users to, by default, share their posts and status updates with everyone; the safe default would have been to share only with those with whom a user explicitly indicated they wished to share.²¹

9.6 Summary This chapter provides an introduction to computer security. This introduction was by no means complete: Missing are discussions of additional attacks and defenses and many operational aspects of computer security. In addition, we did not cover important topics to understand the current state of affairs in computer security practice, such as security economics, which explains, for example, why users may not always act to preserve the security of a system, and legal and ethical aspects related to attacking and defending computer systems.

This chapter did cover, however, a number of concepts that are critical to understanding computer security but that may not have been evident to a technologist who had not studied computer security: From the breadth of roles

needed to keep computer systems secure and the most common methods of attacking computer systems to the principles for controlling access and designing and operating computer systems to be secure.

Endnotes

- 1 Seena Gressin, “The Equifax Data Breach: What to Do,” *FTC Consumer Information* (blog), September 8, 2017, <https://www.consumer.ftc.gov/blog/2017/09/equifax-data-breach-what-do>.
- 2 Dan Goodin, “Failure to patch two-month-old bug led to massive Equifax breach,” *Ars Technica*, September 9, 2017, <https://arstechnica.com/information-technology/2017/09/massive-equifax-breach-caused-by-failure-to-patch-two-month-old-bug/>.
- 3 National Institute of Standards and Technology (NIST), *National Initiative for Cybersecurity Education, Cybersecurity Workforce Framework (NICE Framework), Special Publication 800-181*, U.S. Dept. of Commerce/NIST, August 2017, <https://doi.org/10.6028/NIST.SP.800-181>.
- 4 Lorrie Cranor, “Your mobile phone account could be hijacked by an identity thief,” *FTC Tech@FTC* (blog), June 7, 2016, <https://www.ftc.gov/news-events/blogs/techftc/2016/06/your-mobile-phone-account-could-be-hijacked-identity-thief>.
- 5 Melanie Eversley and Kim Hjelmgaard, “Target confirms massive credit-card data breach,” *USA Today*, December 18, 2013, <https://www.usatoday.com/story/news/nation/2013/12/18/secret-service-target-data-breach/4119337/>.
- 6 Roger A. Grimes, “8 ways your patch management policy is broke (and how to fix it),” *CSO*, October 3, 2019, <https://www.csoonline.com/article/3025807/why-patching-is-still-a-problem-and-how-to-fix-it.html>; Ray Lapena, “Unpatched Vulnerabilities Caused Breaches in 27% of Orgs, Finds Study,” *The State of Security, Tripwire*, June 3, 2019, <https://www.tripwire.com/state-of-security/vulnerability-management/unpatched-vulnerabilities-breaches/>.
- 7 Sam Varghese, “BA site breach through XSS flaw, says tech firm chief,” *ITWire*, September 8, 2016, <https://www.itwire.com/security/84379-ba-site-breach-through-xss-flaw-says-tech-firm-chief.html>.
- 8 Paul Ionescu, “Inside the Mind of a Hacker: Attacking Databases With SQL Injection,” *SecurityIntelligence*, May 12, 2016, <https://securityintelligence.com/inside-the-mind-of-a-hacker-attacking-databases-with-sql-injection/>.
- 9 Howard Solomon, “Keylogger, vulnerable server led to Cathay Pacific Airlines breach, says report,” *IT World Canada*, June 7, 2019, <https://www.itworldcanada.com/article/keylogger-vulnerable-server-led-to-cathay-pacific-airlines-breach-says-report/418805>.
- 10 Nicky Woolf, “DDoS attack that disrupted internet was largest of its kind in history, experts say,” *The Guardian*, October 26, 2019, <https://www.theguardian.com/technology/2016/oct/26/ddos-attack-dyn-mirai-botnet>.
- 11 Verizon, 2019 Data Breach Investigations Report, <https://enterprise.verizon.com/en-gb/resources/reports/dbir/>.
- 12 Emily Flitter and Karen Weise, “Capitol One Data Breach Compromises Data of Over 100 Million,” *The New York Times*, July 29, 2019, <https://www.nytimes.com/2019/07/29/business/capital-one-data-breach-hacked.html>.
- 13 Erin Dietsche, “Data error exposes 974K UW Medicine patients’ information,” *MedCity News*, February 22, 2019, <https://medcitynews.com/2019/02/974k-uw-medicine-patients/>.
- 14 Adam Lashinsky, “What’s Most Stunning About Uber’s Settlement With Waymo,” *Fortune*, February 12, 2018, <https://fortune.com/2018/02/12/google-waymo-uber-surprising-case/>.
- 15 Jaikumar Vijahan, “Snowden serves up another lesson on insider threats,” *Computerworld*, November 8, 2013, <https://www.computerworld.com/article/2485759/snowden-serves-up-another-lesson-on-insider-threats.html>.

- 16 U.S. Senate Sergeant at Arms, *Report on the investigation into improper access to the Senate Judiciary Committees computer system*, March 2004.
- 17 Lujo Bauer, Lorrie Faith Cranor, Robert W. Reeder, Michael K. Reiter and Kami Vaniea, “Real life challenges in access-control management,” *CHI 2009: Conference on Human Factors in Computing Systems*, (ACM Digital Library, April 2009), 899–908, <https://dl.acm.org/citation.cfm?doid=1518701.1518838>.
- 18 “Average Business User Has 191 Passwords,” *Security Magazine*, November 6, 2017, <https://www.securitymagazine.com/articles/88475-average-business-user-has-191-passwords>.
- 19 Memorandum by L. Zhu and B. Tung, “Public Key Cryptography for Initial Authentication in Kerberos (PKINIT),” June 2006, The Internet Society, RFC 4556, <https://www.rfc-editor.org/pdf/rfc/rfc4556.txt.pdf>.
- 20 J.H. Saltzer and M.D. Schroeder, IEEE Xplore Digital Library, “The protection of information in computer systems,” *Proceedings of the IEEE* 63, no. 9, (September 1975), <https://ieeexplore.ieee.org/document/1451869>.
- 21 Kevin Bankston, “Facebook’s New Privacy Changes: The Good, The Bad, and The Ugly,” Electronic Frontier Foundation, December 9, 2009, <https://www.eff.org/deeplinks/2009/12/facebooks-new-privacy-changes-good-bad-and-ugly>.

About the Contributors Executive Editor

Travis D. Breaux, CIPT

Travis D. Breaux is an associate professor of computer science at Carnegie Mellon University (CMU), where he teaches and conducts research to develop new methods and tools to build privacy-preserving, secure and trustworthy information systems. Breaux designed CMU's first privacy engineering course, which is part of the MSIT-Privacy Engineering program, and has published numerous award-winning papers on privacy and software accountability in IEEE and ACM journals and conference proceedings. He is the director of CMU's Masters of Software Engineering programs, and of the Requirements Engineering Laboratory, which conducts research in privacy sponsored by the National Science Foundation (NSF), Department of Homeland Security (DHS) and the National Security Agency (NSA). Breaux served as chair of the USACM privacy and security committee and on the USACM executive council. He is on the editorial board of the *ACM Transactions on Software Engineering and Methodology*. Breaux holds a PhD in computer science from North Carolina State University, a BS in computer science from University of Oregon and a BA in anthropology from University of Houston.

Contributors

Lujo Bauer

Lujo Bauer is a professor of electrical and computer engineering, and of computer science, at Carnegie Mellon University. His research interests are in various areas of computer security and privacy, including usable security, the use of formal methods to create systems with strong security guarantees and the security of machine learning algorithms. He served as the program chair for the flagship computer security conferences of the IEEE and the Internet Society. Bauer received his BS in computer science from Yale University and his PhD, also in computer science, from Princeton University.

Chris Clifton

Dr. Chris Clifton is a professor of computer science and (by courtesy) statistics at Purdue University. He works on data privacy, particularly with respect to analysis of private data. This includes privacy-preserving data mining, data de-identification and anonymization, and limits on identifying individuals from data mining models. He also works more broadly on data mining, including fairness issues, data mining of text and data mining techniques applied to interoperability of heterogeneous information sources. Fundamental data mining challenges posed by these include skew and bias in learning, extraction of knowledge from noisy data, identification of knowledge in highly skewed data (few examples of “interesting” behavior), and limits on learning. He also works on database support for widely distributed and autonomously controlled information, particularly issues related to data privacy.

Prior to joining Purdue in 2001, Dr. Clifton was a principal scientist in the Information Technology Division at the MITRE Corporation. Before joining MITRE in 1995, he was an assistant professor of computer science at Northwestern University. He has a PhD (1991) and MA (1988) from Princeton University and BS and MS degrees (1986) from the Massachusetts Institute of Technology. From 2013 to 2015, he served as a rotating program director in the Division of Information and Intelligent Systems and the Secure and Trustworthy Cyberspace Program at the National Science Foundation (NSF).

Lorrie Faith Cranor, CIPT

Lorrie Faith Cranor is the director and Bosch Distinguished Professor in Security and Privacy Technologies of CyLab and the FORE Systems Professor of Computer Science and of Engineering and Public Policy at Carnegie Mellon University. She also directs the CyLab Usable Privacy and Security Laboratory (CUPS) and codirects the MSIT-Privacy Engineering program. In 2016 she served as chief technologist at the U.S. Federal Trade Commission (FTC). She is also a cofounder of Wombat Security Technologies, Inc., a security awareness training company that was acquired by Proofpoint. Cranor has authored more than 200 research papers on online privacy, usable security and other topics. She coedited the seminal book *Security and Usability* and founded the Symposium On Usable Privacy and Security (SOUPS). She also chaired the Platform for Privacy Preferences Project (P3P) Specification Working Group at the World Wide Web Consortium (W3C). She has served on the Electronic Frontier Foundation board

of directors, the Future of Privacy Forum advisory board, the Computing Research Association board of directors, and the Aspen Institute cybersecurity group. She was elected to the ACM Computer Human Interaction (CHI) Academy, named an ACM fellow for her contributions to usable privacy and security research and education, and named an IEEE fellow for her contributions to privacy engineering. She also received the 2018 ACM CHI Social Impact Award, the 2018 IAPP Privacy Leadership Award and (with colleagues) the 2018 IEEE Cybersecurity Award for Practice. She was previously a researcher at AT&T Labs Research. She holds a doctorate in engineering and policy from Washington University in St. Louis.

Simson L. Garfinkel, CIPP/US

Dr. Simson L. Garfinkel is the senior computer scientist for confidentiality and data access at the U.S. Census Bureau. Garfinkel's research interests include computer forensics, the emerging field of usability and security, personal information management, privacy, information policy and terrorism. He holds six U.S. patents for his computer-related research and has published dozens of journal and conference papers in security and computer forensics. Dr. Garfinkel received three BS degrees from MIT in 1987, an MS in journalism from Columbia University in 1988 and a PhD in computer science from MIT in 2005.

David Gordon

David Gordon works on engineering and public policy matters at Carnegie Mellon University. His research has been focused on developing methods and tools to reconcile privacy requirements across multiple legal jurisdictions to help software developers build privacy-preserving systems. Gordon holds an MBA from the University of Buffalo and BS degrees in computer science and music from SUNY Geneseo.

David James Marcos, CIPM, CIPT

David James Marcos is the chief privacy officer of Azure and leads privacy strategy and policy for Microsoft's cloud and artificial intelligence division, managing and driving privacy governance across Microsoft's enterprise online services. Marcos previously worked for the National Security Agency (NSA), holding a variety of positions, most notably technical director of the NSA Office of Civil Liberties and Privacy, deputy technical director of the NSA Office of the Director of Compliance, and privacy research lead in the NSA Research Directorate. Marcos specializes in privacy engineering and governance, focusing on legal automation and ethical computation in cloud technologies. Marcos is both a Certified Information Privacy Manager (CIPM) and Certified Information Privacy Technologist (CIPT).

Aaron Massey

Aaron Massey is an assistant professor of software engineering at the University of Maryland, Baltimore County (UMBC) and the codirector of ThePrivacyPlace.org. His research interests include computer security, privacy, software engineering and regulatory compliance in software systems. Massey is a recipient of the Walter H. Wilkinson Graduate Research Ethics Fellowship and a recipient of a Google Policy Fellowship. Before coming to UMBC, he was a postdoctoral fellow at Georgia Tech's School of Interactive Computing. Massey earned a PhD and MS in computer science from North Carolina State University and a BS in computer engineering from Purdue University. He is a member of the ACM, IEEE, IAPP, and the USACM Public Policy Council.

Florian Schaub, CIPP/US, CIPT

Florian Schaub is an assistant professor of information and of electrical engineering and computer science at the University of Michigan. His research focuses on investigating and supporting people's privacy and security behavior and decision-making in complex socio-technical systems. His research interests span privacy, human-computer interaction and emergent technologies such as the internet of things (IoT). Schaub holds a PhD in computer science from the University of Ulm, Germany, and was a postdoctoral fellow in Carnegie Mellon University's School of Computer Science. His research has been honored with the 2019 Caspar Bowden Award for Outstanding Research in Privacy Enhancing Technologies, and with best paper awards at the ACM SIGCHI Conference on Human Factors in Computing and the Symposium on Usable Privacy and Security (SOUPS). Schaub is a member of the steering committee for the USENIX Conference on Privacy Engineering Practice and Respect (PEPR). He is also an editorial board member for the *Proceedings of Privacy Enhancing Technologies* and *IEEE Pervasive Computing*.

Stuart S. Shapiro, CIPP/G, CIPP/US

Stuart S. Shapiro is a principal cybersecurity and privacy engineer at the MITRE Corporation, a not-for-profit company performing technical research and consulting primarily for the U.S. government. At MITRE, he has supported a wide range of security and privacy activities involving, among others, critical infrastructure protection, policy frameworks, risk and control assessment, and incident response. In particular, he has led multiple research and operational

efforts in the areas of privacy engineering, privacy risk management and privacy-enhancing technologies (PETs) for government sponsors, including ones focused on connected vehicles and on de-identification. He has also held several academic positions and has taught courses on the history, politics and ethics of information and communication technologies. His professional affiliations include the IAPP and the ACM's U.S. Technology Policy Committee (USTPC, formally USACM), of which he is immediate past chair.

Manya Sleeper

Manya Sleeper is currently a user experience researcher at Google. She contributed to Chapter 6 of this book while at Carnegie Mellon University, where she received a PhD in the School of Computer Science. Her research has focused on usable security and privacy, including improving the usability of access control, aiding privacy decision-making, improving the design of security warning dialogs and understanding perceptions of online behavioral advertising. She received her undergraduate degree in computer science and government from Dartmouth College.

Blase Ur

Blase Ur is Neubauer Family Assistant Professor of Computer Science at the University of Chicago, where he researches computer security, privacy and human-computer interaction. He codirects the University of Chicago SUPERgroup, which focuses on using data-driven methods to help users make better security and privacy decisions as well as to improve the usability of complex computer systems. He has received three best-paper awards (CHI 2017, USENIX Security 2016 and UbiComp 2014) as well as two honorable mentions (CHI 2016 and CHI 2012). His research has been covered in *The New York Times*, *Forbes*, and *Ars Technica*. He received the 2018 SIGCHI Outstanding Dissertation Award, a 2018 IEEE Cybersecurity Award for Practice, the 2016 John Karat Usable Privacy and Security Student Research Award, a National Defense Science and Engineering Graduate (NDSEG) fellowship and a Fulbright scholarship. He holds degrees from Carnegie Mellon University (PhD and MS) and Harvard University (AB).

Index of Searchable Terms

A

- ABAC (attribute-based access control)
- ABC News
- A/B testing of usability
- Accelerometers
- Acceptance testing
- Access, privacy dashboards for
- Access control
 - authentication
 - authorization mechanisms
 - federated identity for
 - models of
 - overview
- Access control lists (ACLs)
- Accountability Principle, in OECD Guidelines of 1980
- ACLs (access control lists)
- Acquisti, Alessandro
- ACR (automated content recognition)
- AdChoices
- Administrative intrusions, as interference Administrators, role of
- AdNauseum browser extension
- Adobe Acrobat
- Adobe Corp.
- Adobe Flash
- Advanced Encryption Standard (AES, U.S.) Advertising
 - as decisional interference
 - location-based
 - targeted
 - user-facing explanations of
- AE (authenticated encryption)
- AES (Advanced Encryption Standard, U.S.) Aggregation, in taxonomy of privacy problems (Solove)
 - Aggregation-based approaches to identity and anonymity
- Agile software process models
- AI (artificial intelligence), in interference AICPA (American Institute of Certified Public Accountants)
- Algorithms and keys
 - for encryption
 - for secret key (symmetric) encryption
- Alpha testing

AMA (American Management Association)
Amazon.com
 account recovery services of
 Amazon Echo
 Amazon Mechanical Turk
 in first-party behavioral advertising
American Institute of Certified Public Accountants (AICPA) American Management Association (AMA)
Anchoring, in privacy decisions
Android platform
Anonymity, in Westin's Four States of Privacy Anonymization. *See also* Identity and anonymity approaches to
 client-side control of
 of microdata
 as weakest form of identity
Anonymous proxies
Anti-Bullying Bill of Rights (New Jersey) Anti-Goals, in goal-oriented analysis
AOL.com
AOL Time Warner
APEC (Asia-Pacific Economic Cooperation) API testing, as post-deployment testing Apple, Inc.
 account recovery services of
 Apple HomeKit
 App Store policies of
 automatic data encryption
 DigiNotar CA certificates removed by
 FaceTime Attention Correction feature of *Find My Friends* application of *Path* application and
 Safari browser of
 security flaws found in 2012
 Siri smart assistant in devices of S/MIME standard supported by
 Thawte CA evaluated by
 third-party app developers and
Application-level encryption
Appropriation
 in NIST model
 in taxonomy of privacy problems (Solove)
AR (augmented reality)
Artificial intelligence (AI), in interference Asia-Pacific Economic Cooperation (APEC) Astroturfing
Asus computers
ATMs (automatic teller machines)
Attribute-based access control (ABAC)
Audio and video tracking and surveillance closed-circuit TV for
 facial recognition in
 hidden cameras and microphones for
 protecting against
 speech recognition in
 tools for
 of voice over IP conversations
Augmented reality (AR)

Authenticated encryption (AE)

Authentication

- for access control

- biometrics for

- cross-enterprise

- device-based

- encryption for

- identity connection to

- location-based

- multifactor

- passwords for

Authorization

Automated content recognition (ACR)

Automatic teller machines (ATMs)

Availability

Availability heuristic, in privacy decisions

B

Backup authentication

Balebako, Rebecca

Bandwidth shaping

Basel II standard

Bauer, Lujo

Baumer, David L.

BBC

Beacons, for tracking

Behavioral advertising, as decisional interference Behavioral modeling, for tracking

Beta testing

Bhatia, Jaspreet

Biham, Eli

Biometrics

- authentication based on

- CCTV and

- for identity

- impossibility of revoking

- as trade space

BitTorrent peer-to-peer network

Blackmail, in taxonomy of privacy problems (Solove) Block ciphers

Block-level disk encryption

Bluetooth entertainment and communication systems Boehm, Barry

Boston Women's Salary Survey

Botnets

Boundary regulation process

Bounded rationality

boyd, danah

Brandeis, Louis

Brave Browser
Breux, Travis D.
Bring your own device (BYOD) practice
British Airways
British Telecom
Browser fingerprinting
Browser history stealing or sniffing
Browsers, privacy settings in
Brute force attacks
Buffer overflow, as software vulnerability Bug tracking, as post-deployment testing BYOD (bring your own device) practice

C

CA (certificate authorities)
CAA (*Certification Authority Authorization*) records CAC (Common Access Card) smart cards
CA DigiNotar
CALEA (Communications Assistance for Law Enforcement Act) of 1994
California Civil Code
California Consumer Privacy Act (CCPA)
Calo, Ryan
Cambridge Analytica
Canadian Institute of Chartered Accountants (CICA) CAN-SPAM (Controlling the Assault of Non-Solicited Pornography and Marketing) Act of 2003
Capital One, Inc.
Carwings (Nissan Leaf entertainment system) Catfishing
Cathay Pacific Airways
CBC (cipher block chaining)
C&C (component-and-connector) diagrams CCPA (California Consumer Privacy Act)
CCTV (closed-circuit TV) for tracking and surveillance CDA (Communications Decency Act)
Celebrities, insider threats to
Cell tower triangulation
Censorship
Center for Democracy and Technology
Central Intelligence Agency (CIA)
Certificate authorities (CA)
Certificate revocation list (CRL)
Certificate signing request (CSR)
Certification. *See* Public key infrastructure (PKI) *Certification Authority Authorization* (CAA) records Challenge response authentication
Channel for privacy interface delivery
Charter Communications
Chatbots
Chief privacy officers (CPOs)
Children, tracking
Children's Online Privacy Protection Act (COPPA) Rule Chilling effects
C-HIP (communication-human information processing) model (Wogalter) Choice, consent interfaces for
Choice architecture of systems

ChoicePoint data broker
Chosen plaintext attack
CIA (Central Intelligence Agency)
CIA triad (*confidentiality, integrity, and availability*) security objectives CICA (Canadian Institute of Chartered Accountants) CIPA (U.S. Children's Internet Protection Act) Cipher block chaining (CBC)
Ciphers
Ciphertext
City of Ontario v. Quon (2010)
Clayton, Richard
Clementi, Tyler
Client-server architecture
Client-side public key infrastructure (PKI) Clifton, Chris
Clipper chip
Cliqz
Closed-circuit TV (CCTV) for tracking and surveillance Cloud-based computing
Cloud services, control points for

CNN

Code of Virginia
Coding practices and reviews
Cohen, Julie
Collection, operation, and analysis, in NICE framework (NIST) Collection Limitation, in OECD Guidelines of 1980
Comcast, Inc.
Command-and-control servers
Commitments, as digital signatures
Common Access Card (CAC) smart cards
Communication about privacy protections Communication-human information processing (C-HIP) model (Wogalter) Communications Assistance for Law Enforcement Act (CALEA) of 1994
Communications Decency Act (CDA)
Community of practice
Compas algorithm Complete mediation, in secure systems
Compliance, privacy governance and
Compliance risk model
Component-and-connector (C&C) diagrams Computers
Asus
create, read, update and delete (CRUD), as functions of Deep Crack computer
Lenovo
monitoring through
Toshiba
Concept of operations (CONOPs)
Concurrent Versions System (CVS)
Confidentiality
Confidentiality, integrity, and availability (CIA triad) security objectives Confidentiality breach, in taxonomy of privacy problems (Solove) CONOPS (concept of operations)
Consent interfaces

Context

- privacy decisions and
in usability testing

Contextual advertising

Contextual Integrity heuristic

Control

- of privacy interfaces
- privacy settings for
- for risks

Controlled rounding

Controlling the Assault of Non-Solicited Pornography and Marketing (CAN- SPAM) Act of 2003

Control paradox

Cookies, HTTP

COPPA (Children's Online Privacy Protection Act) Rule Corporate accounting, Sarbanes-Oxley (SOX) Act
on Counter mode (CTR)

CPOs (chief privacy officers)

Cranor, Lorrie Faith

Create, read, update and delete (CRUD), as computer functions Credit risk, Basel II standard for
Creditworthiness

CRL (certificate revocation list)

Cross-device tracking and surveillance

Cross-enterprise authentication and authorization Cross-site scripting (XSS)

CrowdFlower crowdsourcing services, for usability testing Crowdsourcing services, for usability testing

CRUD (*create, read, update and delete*), as computer functions Cryptanalysis

Cryptographers

Cryptographic currencies

Cryptographic erasure and retention rules Cryptographic hash functions

Cryptographic keys, passwords *versus* Cryptographic system

Cryptosystem

CSR (certificate signing request)

CTR (counter mode)

Culture of privacy governance

Cumbersome privacy choices, as privacy dark patterns Currencies, cryptographic

Curtained memory

CVS (Concurrent Versions System)

Cyberbullying

Cybersecurity and privacy

- access control
- authentication
- authorization mechanisms
- federated identity for
- models of
- overview

breadth of

malware

misconfiguration, insider threat, and other attacks overview

principles for greater

- security properties and adversaries
- software vulnerabilities
- stolen credentials

D

- DAA (Digital Advertising Alliance)
- DAC (discretionary access control)
- Daemen, Joan
- Dark patterns
- Data, testing with
- Data at rest
- Database reconstruction
- Databases, encrypted
- Database schemas
- Data breaches, economic impact of
- Data Encryption Standard (DES, US)
- Data governance
- Data imputation
- Data in flight
- Data in motion
- Data life cycle
 - in completeness arguments
 - privacy and
- Data models, design representation for
- Data Quality Principle, in OECD Guidelines of 1980
- DDoS (distributed denial-of-service) attacks
- Deception, in usability testing
- Decisional inference, in taxonomy of privacy problems (Solove)
- Decisional interference
- Decoupled opt-out
- Deep Crack computer
- Deepfakes
- DeepNude* application
- Deep packet inspection (DPI)
- Default settings, as privacy dark patterns
- Defect
- DeGeneres, Ellen
- Delegated consent
- Demographics, tracking
- Denial-of-service (DoS) attacks
- Deployment
 - of software process models
 - testing engineering to protect privacy after DES (Data Encryption Standard, US)
- Designers, role of
- Design patterns
- Design representation
 - dark patterns
 - design patterns
 - design strategies
 - model-based systems engineering

- object and data models
- process models
- trade-space analysis
- Design strategies
- Details on demand, in UX design
- Device-based authentication
- Device-level encryption
- DevOps Agile-related software process models
- Differential cryptanalysis
- Differential identifiability
- Differential privacy
- Diffie, Whitfield
- Digital Advertising Alliance (DAA)
- Digital rights management (DRM)
- Digital Signature Algorithm (DSA, FIPS-186)
 - Digital signatures
 - to certify documents
 - hash functions for
 - public key (asymmetric) encryption and
 - for software
- Direct interference
- Disassociability, in NIST Privacy Engineering Program
- Disclosure
- Disconnect open-source tool
- Discoverability
- Discretionary access control (DAC)
- Disk-level encryption
- Distortion
- Distractions and delays, as privacy dark patterns
- Distributed denial-of-service (DDoS) attacks
- DNS (domain name system)
- DNT (Do Not Track)* privacy settings
- Document Object Model (DOM) storage
- Documents
 - hash functions for
 - secret sharing approach for
 - symmetric encryption of
- Domain name system (DNS)
- DOM (Document Object Model) storage
- Do Not Track* (DNT) privacy settings
- DoS (denial-of-service) attacks
- DPI (deep packet inspection)
- DRM (digital rights management)
- Drones, surveillance by
- DSA (Digital Signature Algorithm, FIPS-186)
- DuckDuckGo* search engine
- Duplex* voice assistant
- Dwork, Cynthia

E

- Eavesdrop packet sniffers
- ECB (electronic codebook)
- Eckersley, Peter
- Ecological validity
- E-commerce, encryption affected by

Economy of mechanism, in secure systems ECPA (Electronic Communications Privacy Act) of 1986

ECU (Electronic Control Unit), in vehicles EFF (Electronic Frontier Foundation)

Efficiency, in usability

Egelman, S.

Electronic codebook (ECB)

Electronic Communications Privacy Act (ECPA) of 1986

Electronic Control Unit (ECU), in vehicles Electronic Frontier Foundation (EFF)

Elliptic Curve Cryptography

Email

- blocking tracking of

- packets for

- S/MIME and PGP for encryption of

- tracking and surveillance of

- unsolicited (spam)

Emami-Naeni, Pardis

Employers

- employee privacy rights violated by

- internet monitoring by

Encryption

- algorithms and keys for

- cryptographic hash functions

- cryptographic keys *versus* passwords digital rights management and

- e-commerce impact on

- future

- modern

- oblivious random-access memory

- overview

- privacy information retrieval

- public key (asymmetric)

- public key infrastructure

- secret key (symmetric)

 - algorithms and key sizes for

 - applications of

 - attacks and threats to

 - entropy, random numbers, and key generation for modes of operation in

 - overview

- S/MIME and PGP for email

- vocabulary of

- World Wide Web secured with TLS

End-user license agreements (EULA)

Engineering development life cycle

Engineering to protect privacy

- combining models for

- compliance risk model for

- contextual integrity heuristic for

- defect, fault, error, failure, and harm, definitions of design representation for

- dark patterns

- design patterns
- design strategies
- model-based systems engineering
- object and data models
- process models
- trade-space analysis
- FIPPS for
- IT architecture in
- low-level design and implementation in
- NIST privacy risk model for
- overview
- privacy engineers in
- quality attributes in
- requirements engineering in
- acquiring and eliciting
- documenting
- overview
- privacy completeness arguments for
- privacy threat identification for
- trace matrices to manage
- risk management framework for
- risk management overview
- software process models in
- subjective/objective dichotomy model for
- taxonomy of privacy problems for
- testing, validation, and verification in
 - data, testing with
 - deployment, testing after
 - integration testing
 - live users, testing with
 - overview
 - system testing
 - unit testing
- Enigma family of ciphers (World War II) Entanglement principle, in QKD
- Entity tags (ETags)
- Entropy, for secret key (symmetric) encryption Ephemeral borders, privacy violations and Equifax data breach (2017)
- Equifax Security CA
- Erasure and retention rules, cryptographic Error
- ETags (entity tags)
- Ethical considerations in usability testing Eubanks, V.
- EU Directive 2009/136EC (“EU Cookie Directive”) EU Directive 95/46/EC
- EU ePrivacy Directive
- EULA (end-user license agreements)
- European Commission
- European Community Article 29 Working Party (WP29) EU-U.S. Privacy Shield
- EV (Extended Valuation) certificates
- “Evercookies”

Evidon's Open Data Partnership
Exclusion use, in taxonomy of privacy problems (Solove) Expectations of privacy
Expectations of system behavior
Explicit consent for data collection
Exposure, in taxonomy of privacy problems (Solove) Extended Valuation (EV) certificates
External threats
Extreme programming software process model

F

FAA (Federal Aviation Administration)
Facebook.com
 Application Developer API of
 Cambridge Analytica and
 contact mining on
 “nudges” of
 permissive defaults of
 user activities tracked by
Facebook Places app FaceTime Attention Correction feature (Apple, Inc.) Facial recognition
Failure, definition of
Fair Information Practice Principles (FIPPs) of 1977
Fair Information Practices (FIPs)
Farley, Ryan
Fault, definition of
FBI (Federal Bureau of Investigation)
FCC (Federal Communications Commission) Federal Aviation Administration (FAA)
Federal Bureau of Investigation (FBI)
Federal Communications Commission (FCC) Federal Information Processing Standard (FIPS) Publication
 Federated architectures and systems
Federated identity management
Field-level encryption
Fifth Amendment to U.S. Constitution
Find My Friends app *Find My Phone* app FIPPs (Fair Information Practice Principles) of 1977
FIPs (Fair Information Practices)
FIPS (Federal Information Processing Standard) Publication First-party behavioral advertising
First-party collection of data
First-party privacy settings
“Flash cookies”
Focus groups
Forced action, as privacy dark patterns Formative evaluation, in usability testing Foulds, J.
Foursquare mobile app Four States of Privacy (Westin)
Framing, as privacy dark patterns
Freund, Jack
Fried, Charles
Friedman, Batya
FTC (U.S. Federal Trade Commission). *See* U.S. Federal Trade Commission (FTC) Functionality privacy

G

Gamma, Erich

GAPP (Generally Accepted Privacy Principles) Garfinkel, Simson L.

Garmisch report

Gartner, Inc.

General Data Protection Regulation

(GDPR, EU) “clear and plain language” requirements of
on cloud computing
mandated notice or consent required by
personal data as focus of
privacy governance and
privacy policies and
registration services to comply with
scope of
transparency requirements of

Generalization, as anonymization technique Generally Accepted Privacy Principles (GAPP) Generative adversarial networks

Geographic information systems (GIS)

GLBA (Gramm-Leach-Bliley Act)

Global positioning system (GPS)

Gluck, Joshua

Gmail

Goal-oriented analysis

Google.com

autonomous car division of

digital certificate for domain name of

Google *Buzz* social networking app Google Chrome

Google Maps

Google Street View service

Google Wallet

packet sniffers used by

privacy policy of

search-based advertising on

user activities tracked by

U.S. government surveillance of searches on

Google Internet Authority

Google I/O Developers Conference of 2018

Gordon, David

Governance. *See* Privacy governance GPS (global positioning system)

Gramm-Leach-Bliley Act (GLBA)

Gresham College

Grossklags, Jens

Guidelines on the Protection of Privacy and Transborder Flows of Personal Data of 1980

H

Halverson, Casey

- Harbach, Marian
- Harm, definition of
- Harm Decisions (Calo)
- Hash collisions
- Hash functions, cryptographic
- Hawking, Stephen
- Health, Education and Welfare Advisory Committee on Automated Data Systems of 1972
- Health Insurance Portability and Accountability Act (HIPAA) on individually identifiable data
 - minimum necessary standard of
 - privacy governance and
 - Privacy Rule of
 - safe harbor rules of
 - Security Rule of
- Heartbleed bug in OpenSSL
- Heartland Payment Systems breach (2012) Hellman, Martin
- Helm, Richard
- Hidden cameras for tracking and surveillance High-profile customers, insider threats to HILP (Human in the Loop) model
- HIPAA (Health Insurance Portability and Accountability Act). *See* Health Insurance Portability and Accountability Act (HIPAA) Hollan, Jim
- Home automation
- Homomorphic encryption
- Honan, Mat
- HTML5 markup language
- HTTP and HTTPS (Hypertext Transfer Protocols) HTTP cookies
- Hubbard, Douglas W.
- Human in the Loop (HILP) model
- Hutchins, Ed
- Hyperbolic discounting, in privacy decisions Hypertext Transfer Protocols (HTTP and HTTPS)

I

- IaaS (infrastructure as a service)
- IAB (Interactive Advertising Bureau)
- IAPP (International Association of Privacy Professionals) IBM, Inc.
- Identifiability
- Identification
 - encryption for
 - in taxonomy of privacy problems (Solove)
- Identity and anonymity
 - aggregation-based approaches
 - anonymization
 - authentication of
 - definition of
 - issues in
 - strong *versus* weak identifiers Identity management. *See* Access control Identity providers (IdP), in federated identity management Identity theft, economic impact of
- IEEE (Institute of Electrical and Electronics Engineers) IMAP (Internet Message Access Protocol)

iMapWeather Radio IMDb movie database

Implementation, in software process models Implied consent for data collection

Incidental users, identifying

Incomplete information, privacy decisions and Increased accessibility, in taxonomy of privacy problems
(Solove) Indirect interference

Individual, identified

Individually identifiable data

Individual Participation Principle, in OECD Guidelines of 1980

Induced disclosure, in NIST model

Informational privacy notices

Information hiding practices

Information technology (IT)

- acquisition personnel

- administrators

- architecture in privacy engineering

- developers

- involved in privacy

- in privacy governance

Informed consent

Infrastructure as a service (IaaS)

Input-validation flaw, as software vulnerability Insecurity

- in NIST model

- in taxonomy of privacy problems (Solove)

Insider threats

Instagram social networking app Institute of Electrical and Electronics Engineers (IEEE) Institutional

- review boards (IRBs)

Integrated consent prompt

Integrated opt-out

Integrated privacy notices

Integration testing of engineering to protect privacy Integrity

- of digital signatures

- in security

- of system

Intelligent Tracking Protection (Safari) Intel SGX technology

Interactive Advertising Bureau (IAB)

Interconnected systems, as interference Interference

- administrative intrusions as

- behavioral advertising as decisional

- cyberbullying as

- framework for

- lessons learning from cases of

- machine learning bias as

- overview

- personal data exposed through software APIs

- social engineering and interconnected systems as unsolicited messages

Internal controls

International Association of Privacy Professionals (IAPP) Internet communications

Internet Explorer browser

Internet Message Access Protocol (IMAP) Internet monitoring. *See* Tracking and surveillance Internet of things (IoT)

Internet protocol (IP)

Interrogation, in taxonomy of privacy problems (Solove) Intimacy, in Westin's Four States of Privacy

Intrusion

as interference

in taxonomy of privacy problems (Solove)

Investigation, in NICE framework (NIST) IoT (internet of things)

IP (internet protocol)

IRBs (institutional review boards)

ISO 270XX, information security controls ISO 19944, *Cloud Services and Devices: Data Flow, Data Categories, and Data Use* standard ISO 27000 security standards

ISO 27552, Privacy Information Management System (PIMS) ISO 31000 standards

IT (information technology). *See* Information technology (IT)

J

Java code

JavaScript

Javelin Strategy & Research Report

JetBlue airlines

Johnson, Ralph

JonDonym anonymous proxies

Jones, Jack

K

k-anonymity Kant, Immanuel

Kelley, P. G.

Kentucky Department of Insurance

Kerberos protocol

Key generation for secret key (symmetric) encryption Keyloggers

Key search attack

Kismet packet sniffers

Kleinberg, J.

Known ciphertext attack

Known plaintext attack

Kravitz, David W.

KU Leuven (Belgium)

L

Law and policy, in privacy governance

Lawyers, role of

l-diversity Learnability, in usability

Learning life stages

Least privilege, in secure systems

Legal norms
Legal requirements completeness arguments
Lenovo computers
Leon, Pedro Giovanni
Life cycle of engineering development
Lightweight encryption algorithms
LINDDUN threat modeling method
(KU Leuven) Linkable data *versus* linked data
LinkedIn.com, contact mining on
Livelihoods Project
Live users, testing with
Local shared objects (LSOs)
Location-based authentication
Location tracking
 applications of
 geographic information systems in
 preventing
 by social media
 technologies for
 tools for
Log analysis, as post-deployment testing
Loomis, Eric
Loomis v. Wisconsin (2013)
Loose coupling to reduce object dependencies
Loss aversion, in privacy decisions
Lower Merion School District (Pennsylvania)
Low-level engineering design and implementation
LSOs (local shared objects)
Lucifer algorithm (IBM)

M

MAC (mandatory access control)
MAC (media access control) addresses
Machine learning
Mail user agent (MUA)
Maintenance of software process models
Malware
Manageability, in NIST Privacy Engineering Program
Mandatory access control (MAC)
Man-in-the-middle attacks
Marcos, David James
Marketing and sales, role of
Marwick, Alice
Marx, Gary
Massey, Aaron
Mathematics. *See* Encryption
Maximize-information-utility objective in data life cycle
McDonald, Aleecia
MD5 (Message Digest 5) cryptographic hash algorithm
Media access control (MAC) addresses
Medical information, HIPAA Privacy Rule on
Memorability, in usability
Merkle, Ralph
Message Digest 5 (MD5) cryptographic hash algorithm
Metadata, for tracking
Microdata, anonymization of
Microphones, for tracking and surveillance
Microsoft Corp.

application-level encryption supported by
DigiNotar CA certificate removed by
Microsoft Dynamic Access Control
Microsoft Edge
Microsoft Outlook
Microsoft Passport
S/MIME standard supported by
symmetric encryption for documents
web browser of

Minimize-privacy-risk objective in data life cycle Misconfiguration

Mitnick, Kevin
Mix networks
Mobile devices
Mobility
Modality of privacy interfaces
Model-based systems engineering
MongoDB
Morin, Dave
Mozilla Firefox
Mozilla Foundation
MUA (mail user agent)
Multifactor authentication
Multiparty computation
Multiple layers of defense, in secure systems

N

NAI (Network Advertising Initiative)
“Nanny cams”
National Bureau of Standards (NBS)
National Initiative for Cybersecurity Education (NICE) framework (NIST) NATO (North Atlantic Treaty Organization) Natural borders, privacy violations and NBS (National Bureau of Standards)
Near-field communication (NFC)
NebuAd behavioral advertising
Nest Thermostat
Netflix
Net neutrality
Netscape Navigator
Network Advertising Initiative (NAI)
Network-based profiling, in third-party behavioral advertising Network centrality
Network-scale monitoring
Network Time Protocol (NTP)
New Directions in Cryptography (Diffie and Hellman) *New Oxford American Dictionary*
Newport, Kenneth
New Yorker magazine *New York Times* NFC (near-field communication)
Nguyen, Duc
NICE (National Initiative for Cybersecurity Education) framework (NIST) Nielsen, Jakob
Nissan Leaf entertainment system (Carwings) Nissenbaum, Helen

NIST (U.S. National Institute of Standards and Technology). *See* U.S. National Institute of Standards and Technology (NIST) *NISTIR 8062, An Introduction to Privacy Engineering and Risk Management in Federal Systems* of 2017

NIST Privacy Framework

NIST privacy risk model

NIST Special Publication (SP) 800-53, *Security and Privacy Controls for Federal Information Systems and Organizations* Noise addition, as anonymization technique Nonrepudiation property

Norman, Don

Norms

- legal

- privacy expressed as

- social

Norm shaping, as privacy dark patterns

North Atlantic Treaty Organization (NATO) Northpointe, Inc.

NSA (U.S. National Security Agency)

NTFS file system

NTP (Network Time Protocol)

O

OASIS (Organization for the Advancement of Structured Information Standards) Obama, Barack

Objective harms to violate privacy

Object models, design representation for Object-oriented programming language

Oblivious random-access memory (ORAM)

Obstruction (decisional interference)

OCSP (Online Certificate Status Protocol) OECD (Organisation of Economic Cooperation and Development) Off-the-shelf products, privacy-preserving technology of Onion-routing systems

Online behavioral advertising

Online Certificate Status Protocol (OCSP) Online panels, for usability testing

Open design, in secure systems

Openness Principles, in OECD Guidelines of 1980

Open risk communication

Operation and maintenance, in NICE framework (NIST) Optimism bias, in privacy decisions

Opt-in and opt-out consent interfaces

ORAM (oblivious random-access memory)

Organisation of Economic Cooperation and Development (OECD) Organization for the Advancement of Structured Information Standards (OASIS) Oversight and governance, in NICE framework (NIST)

P

PaaS (platform as a service)

Packet inspections

Packets, for internet communications

Packet sniffers

Pan, Chao

Parents, internet monitoring by

Passive consent for data collection

Passwords

- to authenticate users
- cryptographic keys *versus* for symmetric encryption of documents
- Path* social networking app PbD (privacy by design)
- Peer-to-peer architecture
- Persistent VPNs, symmetric cryptography for Personal data exposed through software APIs Personal identification number (PIN)
- Personal Identity Verification (PIV)
- Personally identifiable information (PII) Personal spaces, administrative intrusions into PGP (Pretty Good Privacy)
- PGP for email encryption
- Phishing
- Phone tracking
- Phorm's Webwise system
- PIA (privacy impact assessment)
- PII (personally identifiable information) PIMS (Privacy Information Management System) PIN (personal identification number)
- PIR (privacy information retrieval)
- PIV (Personal Identity Verification)
- PKI (public key infrastructure). *See* Public key infrastructure (PKI) Plaintext
- Plan-driven software process models
- Platform as a service (PaaS)
- Platform for Privacy Preferences Project (P3P) tokens Platform privacy settings
- Pluggable encryption
- Plug-in-based architecture
- PMRM (Privacy Management Reference Model and Methodology) Ponemon Institute
- Post-deployment testing
- Post Office Protocol (POP)
- PRAM (Privacy Risk Assessment Methodology, NIST) Predictability, in NIST Privacy Engineering Program PreMasterSecret
- PRIPARE (Preparing Industry to Privacy-by-design by supporting its Application in REsearch) methodology Pretty Good Privacy (PGP)
- Primary users, identifying
- Principles and standards of privacy
- PRIPARE (Preparing Industry to Privacy-by-design by supporting its Application in REsearch) methodology PRISM program
- Privacy, overview of
 - data life cycle and
 - definition of
 - expectations of
 - IT professionals involved in
 - principles and standards of
 - risks in
 - as roadmap
 - security, data governance, and
- Privacy assessment, in privacy design process Privacy by design (PbD)
- Privacy calculus
- Privacy completeness arguments

Privacy concerns
Privacy dashboards
Privacy engineering
 IT developers in
 in privacy design process
 role of
Privacy expectations
Privacy Framework of 2005
Privacy governance
 compliance and
 core activities in
 culture of
 data governance in
 engineering development life cycle and
 evaluating
 industry standards of
 IT roles and responsibilities in
 law and policy
 security and
 technological controls for
 technology and
Privacy harm
Privacy impact assessment (PIA)
Privacy indicators
Privacy Information Management System (PIMS) Privacy information retrieval (PIR)
Privacy interfaces
 behavior *versus* preferences for design principles for
 design process for
 assessment, management, and engineering in
 identity unexpected data practices in
 identity user needs in
 leveraging design space in
 system UX integrated in
 user testing in
 factors in
 manipulation of privacy behavior
 overview
 types of
 usability and user experience of
 usability issues of
 usability testing
 best practices for
 items for
 reasons for
 techniques for
 user-centered
Privacy management in privacy design process Privacy Management Reference Model and Methodology

- (PMRM) Privacy notices
- Privacy paradox
- Privacy pluralistic world
- Privacy preferences, aspirational
- Privacy Project (*New York Times*) Privacy regret
- Privacy reminders
- Privacy Risk Assessment Methodology (PRAM, NIST) Privacy settings
- Private information turbulence
- Process models, design representation for Programmers, role of
- Project managers, role of
- Prolific crowdsourcing services, for usability testing Prosser, William
- Protection and defense, in NICE framework (NIST) Pseudonym
- Psychological acceptability, in secure systems P3P (Platform for Privacy Preferences Project) tokens Public data, for testing
- Public key (asymmetric) encryption
 - algorithms and key sizes for
 - description of
 - digital signatures and
 - overview
- Public key infrastructure (PKI)
 - certificate revocation in
 - certification principle of
 - client-side
 - limitations of
 - overview
 - time and
- Purchased data, for testing
- Purpose Specification Principle, in OECD Guidelines of 1980

Q

- Quality attributes, in engineering to protect privacy Quantum key distribution (QKD)
- Quantum technology
- Quasi-identifiers
- Quon, Jeff

R

- Radio frequency identification (RFID)
- Random-access memory retrieval
- Random numbers for secret key (symmetric) encryption Rate-limiting
- RATs (Remote Access Trojans) malware
- Ravi, Dharun
- RBAC (role-based access control)
- RC4 algorithm
- Reasonable assurance concept
- Re-encryption
- Refrainment, refinement by
- Regulation of Investigatory Powers Act of 2000 (UK) Relying party (RP), to verify digital signatures Remote

- Access Trojans (RATs) malware
- Replay attack
- Representation of self, interference with Representativeness heuristic, in privacy decisions
- Representative user populations
- Repurposing, in data collection
- Requirements engineering
 - acquiring and eliciting in
 - documenting
 - overview
 - privacy completeness arguments for
 - privacy threat identification for
 - trace matrices to manage
- Reserve, in Westin's Four States of Privacy Responses to risks
- Revocation certificates
- Rewards and punishment, as privacy dark patterns
- RFID (radio frequency identification)
- Right to Financial Privacy Act of 1978
- Rijmen, Vincent
- Risk
- Risk management
 - combining models for
 - compliance risk model for
 - contextual integrity heuristic for
 - FIPPS for
 - NIST privacy risk model for
 - overview
 - privacy engineering framework for
 - subjective/objective dichotomy model for
 - taxonomy of privacy problems for
- Risk model alignments
- Role-based access control (RBAC)
- Rootkit malware
- Roth, Aaron
- RP (relying party), to verify digital signatures
- RSA algorithm (Rivest, Shamir and Adleman)
- RSA public key system
- Rutgers University

S

- SaaS (software as a service)
- Safe defaults, in secure systems
- Saltzer, J. H.
- Samsung
- Sarbanes-Oxley (SOX) Act
- Satisfaction, in usability
- Schaub, Florian
- Schnorr, Claus P.
- Schools, internet monitoring by
- Schroeder, M. D.

SCM (source configuration management) systems Scrum software process model
Secondary use, in taxonomy of privacy problems (Solove) Secondary users, identifying
Secret key (symmetric) encryption
 algorithms and key sizes for
 applications of
 attacks and threats to
 entropy, random numbers, and key generation for modes of operation in
 overview
Secret sharing approach
Secure enclaves
Secure Hash Algorithm (SHA)
Secure multiparty computation
Secure sockets layer (SSL) encryption
Security. *See also* Cybersecurity and privacy privacy and
 privacy governance and
 value from
Security provision, in NICE framework (NIST) Security Safeguards Principle, in OECD Guidelines of 1980
Seiersen, Richard
Self-censorship
Sensor-based tracking and surveillance
 home automation
 internet of things (IoT)
 mobile device
 overview
 in vehicles
 wearable devices
Service-oriented architecture
Service providers (SPs), in federated identity management Service set identification (SSID), of wireless
 routers SHA (Secure Hash Algorithm)
Shamir, Adi
Shapiro, Stuart S.
ShareMeNot tool
Side-jacking attacks
SIMON lightweight encryption algorithm
Simple Mail Transfer Protocol (SMTP)
Single-origin policy
Single sign on (SSO), in federated identity management Skype.com
Sleeper, Manya
Small-scale user testing
Smart cards, private key stored in
Smart televisions, audio surveillance by S/MIME and PGP for email encryption
SMTP (Simple Mail Transfer Protocol)
Snowden, Edward
SOC (*Systems and Organization Controls*) 2
 Type 2
Social borders, privacy violations and
Social bots

- Social engineering
 - as interference
 - phishing attacks as
- Social media
- Social networking, interference through Social norms
- Social patterns
- Sockpuppeting
- Software as a service (SaaS)
- Software process models
- Software requirements specification (SRS) Software vulnerabilities
- Solitude, in Westin's Four States of Privacy Solove, Daniel
- Source configuration management (SCM) systems Spam (unsolicited messages)
- Spatial borders, privacy violations and Spear phishing attacks
- Specific user populations
- SPECK lightweight encryption algorithm
- Speech recognition technology
- Spiekermann, Sarah
- Spiral software process model
- SPs (service providers), in federated identity management Spyware
- SRS (software requirements specification) SSID (service set identification), of wireless routers SSL (secure sockets layer) encryption
- SSO (single sign on), in federated identity management Standard application programming interfaces (APIs) and frameworks, reusing Standards and principles of privacy
- Status quo bias, in privacy decisions
- Stolen credentials
- Stream ciphers
- STRIDE methodology for security threat modeling Strong *versus* weak identifiers Structured query language (SQL) injection attacks Subjective harms to violate privacy
- Subjective/objective dichotomy model
- Substitution, in ciphers
- Subversion source configuration management system Summative evaluation, in usability testing "Supercookies"
- Suppression, as anonymization technique Surveillance. *See* Tracking and surveillance Suwajanakorn, S.
- Sweeney, Latanya
- Synthetic data, for testing
- Systems Modeling Language (SysML)
- System testing of engineering to protect privacy

T

- Targeted advertising
- Target Stores, Inc.
- Taxonomy of privacy problems (Solove)
- TCP (transmission control protocol)
- Team Software Process model
- Telemarketing
- Telephone conferencing, secure
- Temporal borders, privacy violations and Terms of use (ToU) agreements

Testing engineering to protect privacy
after deployment
with data
of integration
with live users
in software process models
of system
of units

Thampi, Arun

Thawte SGC CA

Third-party behavioral advertising

Third-party browser extensions to block web tracking Third-party collection, in data collection Threat agents

Threat identification, for requirements engineering Threat modeling

Timing of privacy control display

TLS (transport layer security). *See* Transport layer security (TLS) Torch Concepts, Inc.

Tor onion-routing systems

Toshiba computers

ToU (terms of use) agreements

TPLs (Tracking Protection Lists)

Trace matrices to manage requirements engineering Tracking and surveillance

audio and video

closed-circuit TV for

facial recognition in

hidden cameras and microphones for

protecting against

speech recognition in

tools for

voice over IP conversations

behavioral modeling

cross-device

in data collection

of email recipients

employers, schools, and parent, internet monitoring for interference enabled by

internet communications

location tracking

applications of

geographic information systems in

preventing

by social media

technologies for

tools for

network-scale monitoring and deep packet inspections in NIST model

overview

preventing network-level

sensor-based

home automation

internet of things (IoT)

- mobile device
- overview
- in vehicles
- wearable devices
- spyware
- in taxonomy of privacy problems (Solove)
- tools for
- web tracking
 - beyond HTTP cookies for
 - blocking
 - blocking tools for
 - deciding what to block
 - email tracking, blocking
 - HTTP cookies for
 - overview of
 - third-party browser extensions to block
 - tools for
 - web-based privacy tools
 - web searches, blocking
- Wi-Fi eavesdropping
- Tracking Protection Lists (TPLs)
- Tracking Protection Working Group (World Wide Web Consortium, W3C) TrackMeNot, to hide search histories
- Trade-space analysis
- Transformed data, for testing
- Transitory borders, privacy violations and Transmission control protocol (TCP)
- Transparency
 - as industry standard
 - machine learning and
 - in privacy legislation
 - privacy notices on
- Transportation-mapping applications
- Transport layer security (TLS)
 - digital certificates and
 - as pluggable cryptographic protocol
 - to secure World Wide Web
 - symmetric cryptography for
 - use of
- Transposition, in ciphers
- Trap door functions
- Trust, facilitating
- Turner, Richard
- Twitter.com
- Two-factor authentication

U

Ubiquitous computing

- UDP (user datagram protocol)
- Unanticipated revelation, in NIST model Unified Modeling Language (UML)
- Uniform resource locator (URL)
- United States v. Jon Tomero
- Unit testing of engineering to protect privacy University of California-Berkeley School of Information
- University of Cambridge (UK)
- University of Washington
- Unmanned aerial vehicles, surveillance by Unsolicited messages (spam)
- Unwarranted restriction, in NIST model
- Ur, Blase
- URL (uniform resource locator)
- URL rewriting
- Usability
 - privacy interface issues and
 - of privacy interfaces
 - trade-offs in
 - value from
- Usability testing
 - best practices for
 - items for
 - reasons for
 - techniques for
- U.S. Army
- USA Today* U.S. Children's Internet Protection Act (CIPA) U.S. Constitution, Fifth Amendment to
- U.S. Department of Defense (DOD)
- U.S. Department of Homeland Security (DHS) Use Limitation Principle, in OECD Guidelines of 1980
- User agreements
- User-centered privacy design
- User controls
- User datagram protocol (UDP)
- User rights, in privacy legislation
- Users
 - in experience of privacy interfaces
 - identifying
 - representative and specific populations of
 - role of
 - in testing of privacy interfaces
- U.S. Federal Trade Commission (FTC)
 - Controlling the Assault of Non-Solicited Pornography and Marketing (CAN- SPAM) Act of 2003
 - implemented by deceptive business practices settlement with Google of fair information practice
 - principles of
 - on fake product reviews
 - FIPPs as regulatory standard of
 - FIPPS in recommendations of
 - on internet advertising
 - privacy regulated by
 - regulatory enforcement actions of

- surveillance investigations of
- U.S. Internal Revenue Service (IRS), on virtual currencies
- U.S. National Institute of Standards and Technology (NIST) cloud-based computing defined by
- NICE framework of
- post-quantum cryptography project of
- Privacy Engineering Program of
- Secure Hash Algorithm (SHA) of
- U.S. National Security Agency (NSA)
- U.S. NIST Privacy Control AR-8
- U.S. NIST Special Publication 800-53
- U.S. NIST Special Publication 800-88
- U.S. Privacy Act of 1974
- U.S. Supreme Court
- Utility of systems
- UW Medicine

V

- Validation. *See* Testing engineering to protect privacy
- Value-sensitive design
- Value swapping
- VASCO Data Security International
- Vehicles, sensor-based tracking and surveillance in
- Verification. *See* Testing engineering to protect privacy
- Verizon Data Breach and Incident Report
- Virtual private networks (VPNs)
- Vlissides, John
- Vocabulary of encryption
- Voice authentication
- Voice over IP (VoIP) conversations, monitoring
- VPNs (virtual private networks)

W

- Wang, Lingyu
- Warren, Samuel
- Waterfall software process model
- Wearable devices
- Web-based profiling, in third-party behavioral advertising
- Web bugs, for tracking
- Web of Trust
- Web tracking
 - beyond HTTP cookies for
 - blocking
 - deciding what to block
 - email tracking, blocking
 - HTTP cookies for
 - overview
 - third-party browser extensions to block
 - tools for
 - tools for blocking
 - web-based privacy tools
 - web searches, blocking
- Wei, Molly

Wells Fargo
WEP (Wired Equivalent Privacy)
Wesley, Charles
Westin, Alan
Whaling attacks
Wi-Fi
 eavesdropping of
 in location tracking
 Wi-Fi Protected Access (WPA) encryption scheme WikiLeaks
Wikipedia.com
Windows Server 2012
Windows Time Service
Wired Equivalent Privacy (WEP)
Wireless networks, symmetric cryptography for Wireshark, for Wi-Fi eavesdropping
Wiretap Act
Wogalter, M. S.
World Wide Web, secured with TLS
World Wide Web Consortium (W3C)
WPA (Wi-Fi Protected Access) encryption scheme

X

X.500 standard
XSS (cross-site scripting)

Y

Yahoo. com, search-based advertising on Yang, Hannah
Yelp app

Z

Zhang, Shikun